SAP PRESS

Authorizations in SAP S/4HANA® and SAP Fiori®

- Configure and maintain ABAP authorizations for SAP S/4HANA and SAP Fiori
- Work with roles, profiles, authorization objects, and system traces
- Maintain system users, manage roles with SAP Access Control, and more

Alessandro Banzer
Alexander Sambill

Rheinwerk Publishing

SAP PRESS is a joint initiative of SAP and Rheinwerk Publishing. The know-how offered by SAP specialists combined with the expertise of Rheinwerk Publishing offers the reader expert books in the field. SAP PRESS features first-hand information and expert advice, and provides useful skills for professional decision-making.

SAP PRESS offers a variety of books on technical and business-related topics for the SAP user. For further information, please visit our website: http://www.sap-press.com.

Joe Markgraf, Alessandro Banzer
SAP System Security Guide
2018, 574 pages, hardcover and e-book
www.sap-press.com/4307

Jonathan Haun
SAP HANA 2.0 Security Guide (2nd Edition)
2020, 608 pages, hardcover and e-book
www.sap-press.com/4982

Lehnert, Luther, Christoph, Pluder, Fernandes
GDRP and SAP: Data Privacy with SAP Business Suite and SAP S/4HANA
2018, 430 pages, hardcover and e-book
www.sap-press.com/4652

Iwona Luther, Nicole Fernandes
SAP Information Lifecycle Management: The Comprehensive Guide
2020, 609 pages, hardcover and e-book
www.sap-press.com/5072

Densborn, Finkbohner, Freudenberg, Höft, Mathäß, Rubarth
Migrating to SAP S/4HANA (2nd Edition)
2021, 606 pages, hardcover and e-book
www.sap-press.com/5279

Alessandro Banzer, Alexander Sambill

Authorizations in SAP S/4HANA® and SAP Fiori®

Rheinwerk Publishing

Dear Reader,

When you think about it, authorizations are everywhere in our lives—we just don't always notice them. You're only authorized to enter certain parts of a school, office, or public building, depending on whether you're a visitor, student, or employee. You're only authorized to drive on one side of the road, unless you're on a multi-lane highway or in an emergency vehicle. At a store, you're authorized to pick up any merchandise on the shop floor but need to ask a clerk to check in the back stock room for you. Even at home, certain family members might be authorized to do certain tasks while others are not (for example, my husband is the only person in my house who can be trusted to use power tools safely!).

In the world of SAP, authorizations are just as pervasive and perhaps even more important. Alessandro Banzer and Alexander Sambill have written this book to help you navigate the twists and turns of best practices, legal requirements, and security needs so you can better understand who should have access to what data—and how to make that happen seamlessly. The authors' extensive real-world expertise will help you configure your SAP S/4HANA and SAP Fiori authorizations in a way that not only makes sense for your business needs, but feels natural, easy, and clear to all users.

So what did you think about *Authorizations in SAP S/4HANA and SAP Fiori*? Has it helped you implement a stronger authorization concept? Your comments and suggestions are the most useful tools to help us make our books the best they can be. Please feel free to contact me and share any praise or criticism you may have.

Thank you for purchasing a book from SAP PRESS!

Rachel Gibson
Editor, SAP PRESS

rachelg@rheinwerk-publishing.com
www.sap-press.com
Rheinwerk Publishing • Boston, MA

Notes on Usage

This e-book is **protected by copyright**. By purchasing this e-book, you have agreed to accept and adhere to the copyrights. You are entitled to use this e-book for personal purposes. You may print and copy it, too, but also only for personal use. Sharing an electronic or printed copy with others, however, is not permitted, neither as a whole nor in parts. Of course, making them available on the Internet or in a company network is illegal as well.

For detailed and legally binding usage conditions, please refer to the section Legal Notes.

This e-book copy contains a **digital watermark**, a signature that indicates which person may use this copy:

Copy No. a84s-gnd7-z92r-bu5k
for personal use of
Arun Singal
arun.singal560@gmail.com

Imprint

This e-book is a publication many contributed to, specifically:

Editor Rachel Gibson
Acquisitions Editor Hareem Shafi
Copyeditor Yvette Chin
Cover Design Graham Geary
Photo Credit iStockphoto.com: 116381599/© hatman12
Production E-Book Hannah Lane
Typesetting E-Book SatzPro, Krefeld (Germany)

We hope that you liked this e-book. Please share your feedback with us and read the Service Pages to find out how to contact us.

The Library of Congress has cataloged the printed edition as follows:
Names: Banzer, Alessandro, author. | Sambill, Alexander, author.
Title: Authorizations in SAP S/4HANA and SAP Fiori / by Alessandro Banzer and Alexander Sambill.
Description: 1st edition. | Bonn ; Boston : Rheinwerk Publishing, 2022. | Includes index.
Identifiers: LCCN 2021050812 | ISBN 9781493220366 (hardcover) | ISBN 9781493220373 (ebook)
Subjects: LCSH: SAP HANA (Electronic resource) | SAP Fiori. | Database management. | Computers--Access control. | Business enterprises--Data processing.
Classification: LCC QA76.9.D3 B3639 2022 | DDC 005.74068--dc23/eng/20211129
LC record available at https://lccn.loc.gov/2021050812

ISBN 978-1-4932-2036-6 (print)
ISBN 978-1-4932-2037-3 (e-book)
ISBN 978-1-4932-2038-0 (print and e-book)

© 2022 by Rheinwerk Publishing, Inc., Boston (MA)
1st edition 2022

Contents

Preface 19

1 Introduction to SAP Authorizations 23

1.1 What Are Authorizations? 24

1.2 User Access in the SAP System 25

1.3 Evolution of Authorizations from SAP ERP to SAP S/4HANA 26

1.3.1 SAP ERP 26

1.3.2 SAP S/4HANA 27

1.3.3 SAP S/4HANA Deployments 30

1.3.4 Other SAP Cloud Solutions 33

1.4 SAP Fiori (Presentation Layer) 34

1.5 Native Authorizations in SAP HANA (Database Layer) 37

1.6 Hybrid System Landscapes and Implications on Authorizations 38

1.6.1 Business Roles and SAP Business Technology Platform 39

1.6.2 SAP Cloud Identity Access Governance 40

1.6.3 Access Provisioning in Hybrid Landscapes 41

1.6.4 Access Risk Analysis in Hybrid Landscapes 43

1.7 Summary 45

2 ABAP Authorization Concept 47

2.1 Influences on the SAP Authorization Concept 48

2.2 Basic Principles for an SAP Authorizations Concept 49

2.3 ABAP Authorizations 51

2.3.1 Components 52

2.3.2 Authorization Default Values 56

2.3.3 Code-Based Namespaces 57

2.3.4 Creating Custom Authorizations 58

2.3.5 Creating Custom Organizational Levels 61

2.4 Roles and Profiles 65
2.4.1 Roles 65
2.4.2 Profiles 67

2.5 Users 70
2.5.1 User Master Record 71
2.5.2 User Buffer 72
2.5.3 User Types and Maintenance 73

2.6 Authority Checks 74
2.6.1 Locking Status Checks 74
2.6.2 Application Start Checks 75
2.6.3 Transaction Start Plausibility Checks 76
2.6.4 Parameter Checks 77
2.6.5 Kernel Checks 78
2.6.6 Program Code Authority Checks 78
2.6.7 SAP System Authorization Check Processing 80
2.6.8 Switchable Authorizations 81
2.6.9 Deactivating Authorization Checks 85

2.7 Critical Authorizations 87
2.7.1 Critical Access Scenarios 88
2.7.2 Audit-Focused Authorization Objects 96

2.8 Authorizations in SAP ERP Human Capital Management 102
2.8.1 Business Transactions and Authorization Components 103
2.8.2 All-Access in SAP ERP Human Capital Management 105

2.9 Different Transaction Types 106
2.9.1 Overview of Available Transactions 107
2.9.2 Creating Custom Transactions 111
2.9.3 Locking and Unlocking Transactions 120

2.10 SAP System Check for Security Flaws 121
2.10.1 System Configuration Analysis 122
2.10.2 Document Analysis 125
2.10.3 Roles Analysis 125
2.10.4 User Analysis 128

2.11 Customizing of SAP Security Settings 130
2.11.1 Table PRGN_CUST 131
2.11.2 Table SSM_CUST 132
2.11.3 Table USR_CUST 133

2.12 Summary 133

3 Designing Authorization Concepts 135

3.1 Role Design Approaches 135

3.2 Role Types 139

3.2.1 Single Roles 139

3.2.2 Composite Roles 141

3.2.3 Enabler Roles 142

3.2.4 Authorization Templates and Standard Roles 143

3.2.5 Comparison of the Role Design Concepts 145

3.3 Segregation of Duties 146

3.4 Determining When to Use Enabler Roles 147

3.5 Role Naming Convention 152

3.6 Summary 154

4 Xiting Authorizations Management Suite 157

4.1 Overview 158

4.2 Xiting Role Designer 159

4.2.1 Capabilities 160

4.2.2 Analysis and Design 161

4.2.3 Reporting Options of Xiting Role Designer 162

4.2.4 Reporting Options for Menu Objects 163

4.2.5 Reporting Options for Business Data 164

4.3 Xiting ABAP Alchemist 165

4.4 Xiting Role Replicator 169

4.4.1 Bulk Processing of Users, Roles, and Authorizations 169

4.4.2 OrgSet Replication 171

4.5 Xiting Role Builder 172

4.6 Xiting Times 174

4.7 Xiting Role Profiler 176

4.8 Xiting Security Architect 179

4.9 Summary 182

5 Transaction SU24: Authorization Default Values 183

5.1 Overview 184
5.1.1 What Are SAP Authorization Default Values? 184
5.1.2 Technical Background of Authorization Default Values 187
5.1.3 Helpful Tables 190
5.1.4 System Layer Alignment 191

5.2 Transaction SU24 Maintenance 192
5.2.1 Instruments of Transaction SU24 192
5.2.2 Proposal and Check Indicator Statuses 194
5.2.3 Maintenance of Default Values and Check Indicators 195
5.2.4 Comparison between SAP Data and Customer Data 199

5.3 Transaction SU24N 200
5.3.1 General Changes 200
5.3.2 Maintaining a Description for Transaction SU24 Data 202
5.3.3 Default Data Variants 202

5.4 Populating Data from Traces 205

5.5 Best Practice Maintenance of Transaction SU24 208
5.5.1 Authorization Field Maintenance 209
5.5.2 List Navigation 214
5.5.3 Menu Navigation 216
5.5.4 Navigation Considerations 220
5.5.5 Cockpit Transactions 220

5.6 Upgrading Authorization Default Values 223
5.6.1 Importance of Upgrading 223
5.6.2 Report SU24_AUTO_REPAIR 225
5.6.3 Related Applications and Tables for a Transaction SU25 Upgrade 227
5.6.4 Performing the Upgrade for Default Values 228
5.6.5 Troubleshooting 238

5.7 Transaction SU24 Optimization Tools 239

5.8 Xiting Authorizations Management Suite: Transaction SU24 Optimization Tools 241
5.8.1 Xiting Role Profiler 241
5.8.2 Xiting ABAP Alchemist 242
5.8.3 Xiting Role Builder SU24 Checkman 242

5.9 Summary 243

6 Role Maintenance in Transaction PFCG 245

6.1 Navigation within Transaction PFCG 247
6.1.1 Initial Screen of Transaction PFCG 247
6.1.2 Single Role Maintenance Options and Tabs 248
6.1.3 Composite Role Maintenance Options and Tabs 254

6.2 Creation of Different Roles 256
6.2.1 Role Building and Naming 257
6.2.2 Single Roles 259
6.2.3 Composite Roles 259
6.2.4 Reference and Derived Roles 261
6.2.5 Customizing Roles 265
6.2.6 Role Templates 268
6.2.7 Assigning and Removing Roles via Transaction PFCG 269

6.3 Role Menu Objects 270
6.3.1 Different Maintainable Applications 270
6.3.2 Using Transaction SU24 Variants 271
6.3.3 Role Menu Comparison 273

6.4 Authorization Maintenance in Roles 274
6.4.1 Authorization Maintenance Buttons 275
6.4.2 Authorization Object Statuses 277
6.4.3 Authorization Object Update Status Texts 281
6.4.4 Maintenance of Organizational Levels 282
6.4.5 Where-Used Lists 285
6.4.6 Authorization Templates and Other Authorization Insert Options 286
6.4.7 Import of Traces to Roles 287

6.5 Sustainable Role Building 290
6.5.1 Best Practice Presettings for Role Maintenance 291
6.5.2 Best Practice Role and Authorization Maintenance 292
6.5.3 Role Profile Generation 296

6.6 Role Versions 297

6.7 Roles Overview Status 299

6.8 Selected Mass Maintenance Options for Roles 301
6.8.1 Mass Role Maintenance 301
6.8.2 Mass Generation of Role Profiles 304
6.8.3 Mass User Comparison of Roles 305

6.9 Transfer of Roles 306

6.10 Xiting Authorizations Management Suite: Virtual Role Design with Xiting Role Designer 308

6.10.1 Project Cockpit ... 309
6.10.2 Design Cockpit ... 310
6.10.3 Reports Cockpit ... 311

6.11 Summary ... 312

7 Authorization Analysis, Trace Tools, and Authorization Debugging 315

7.1 Overview ... 316
7.1.1 Analysis Tools ... 316
7.1.2 Selected Authorization Trace Return Codes ... 318
7.1.3 Activation of Profile Parameters ... 319
7.1.4 Trace Tool Use Cases ... 320

7.2 Transaction SU53 ... 320
7.2.1 Description ... 321
7.2.2 Authorization Check Failures Evaluation ... 322

7.3 Transactions ST01/STAUTHTRACE ... 323
7.3.1 Description ... 324
7.3.2 Trace Evaluation for an Authorization Error ... 326

7.4 Transaction STUSOBTRACE ... 329
7.4.1 Description ... 329
7.4.2 Authorization Default Value Maintenance ... 331

7.5 Transaction STUSERTRACE ... 333
7.5.1 Evaluation of Specific Job Functions ... 334
7.5.2 Using Transaction STSIMAUTHCHECK ... 335

7.6 Authorization Debugging ... 337

7.7 Xiting Authorizations Management Suite: Enhanced Trace Evaluation ... 344
7.7.1 Description ... 345
7.7.2 Rapidly Analyze Authorization Failure ... 346

7.8 Summary ... 347

8 SAP Fiori Authorizations 349

8.1 Overview ... 349
8.1.1 Principles of SAP Fiori ... 349
8.1.2 SAP Fiori End-User Applications ... 350

8.2 SAP Fiori Architecture 351

8.3 Deployment Options 353

8.3.1 Embedded Deployment 353

8.3.2 Central Hub Deployment 354

8.3.3 SAP Launchpad Service 355

8.4 SAP Fiori Apps Reference Library 356

8.4.1 Overview 356

8.4.2 Technical Components 358

8.5 SAP Fiori Administrative Tools 360

8.5.1 SAP Fiori Launchpad Designer 360

8.5.2 SAP Fiori Launchpad Content Manager 362

8.5.3 SAP Fiori Launchpad App Manager 363

8.5.4 Manage Spaces and Pages App 365

8.6 OData Services 366

8.6.1 Description 366

8.6.2 Activation of OData Services in Backend Servers 367

8.6.3 Overview of Activated Services 369

8.7 SAP Fiori Concept Implementation 369

8.7.1 Technical and Business Catalogs 370

8.7.2 Business Groups 374

8.7.3 Business Spaces and Pages 377

8.7.4 SAP Fiori Launchpad Personalization 378

8.8 Frontend/Backend Server Authorizations 379

8.8.1 SAP Fiori Role Concept 380

8.8.2 Role Building Preparation 382

8.8.3 Role Building for SAP Fiori Applications in the Embedded Deployment 385

8.9 Troubleshooting Tools for SAP Fiori 386

8.10 Xiting Authorizations Management Suite: Tool-Driven SAP Fiori Objects Implementation and Analysis 392

8.10.1 Xiting Role Replicator 392

8.10.2 Xiting Role Profiler 393

8.11 Summary 394

9 User Maintenance 395

9.1 Maintenance of the User Master Record 395

9.1.1 Different User Types 396

9.1.2 Creating and Maintaining a User ... 397
9.1.3 Copying a User ... 406
9.1.4 Change Documents for Users ... 406
9.1.5 Mass User Changes with Transaction SU10 ... 409
9.1.6 Inactive Users ... 415

9.2 Password Rules ... 415

9.3 The User Buffer ... 417

9.4 User Naming Conventions ... 419

9.5 User Classification ... 421

9.6 User-Related Tables ... 421

9.7 User Access Reviews ... 422

9.8 User Lock Status ... 423

9.9 Security Policies ... 423

9.10 Securing Default Accounts ... 428

9.11 Maintaining User Groups ... 430

9.12 Central User Administration ... 432
9.12.1 Overview ... 432
9.12.2 Distribution Parameters for Fields (Transaction SCUM) ... 433
9.12.3 Central User Administration-Related Tables ... 435

9.13 SAP Usage Data for Users ... 436

9.14 Summary ... 437

10 Access Governance with SAP Access Control and SAP Cloud Identity Access Governance 439

10.1 SAP Access Control ... 439

10.2 SAP Cloud Identity Access Governance ... 443
10.2.1 Core Functionalities ... 443
10.2.2 Key Capabilities of SAP Cloud Identity Access Governance ... 447
10.2.3 Integrated Identity Access Governance for Hybrid Landscapes ... 448

10.3 Understanding the Ruleset ... 449
10.3.1 Ruleset Components ... 449
10.3.2 Ruleset Architecture ... 451
10.3.3 SAP Standard Rulesets ... 452
10.3.4 Organizational Rules ... 454
10.3.5 Simulating Risk During Role Building with the Risk Terminator ... 455

10.4 Segregation of Duties Management Process ... 456
10.4.1 Phases of Segregation of Duties Management ... 456
10.4.2 Remediation and Mitigation of Risks ... 457
10.4.3 Continuous Segregation of Duties Monitoring ... 462
10.5 Custom Transactions for the Ruleset ... 463
10.5.1 Analyzing Custom Transactions ... 463
10.5.2 Enhanced Analysis with Xiting ABAP Alchemist ... 466
10.6 Business Roles ... 468
10.7 User Access Review ... 470
10.8 Roles for Firefighters ... 471
10.8.1 Defining Appropriate Usage ... 472
10.8.2 Firefighter Types ... 473
10.8.3 Provisioning Strategies for Firefighters ... 474
10.9 Impact to Governance, Risk, and Compliance When Migrating and Upgrading SAP Systems ... 475
10.10 Summary ... 476

11 Interface Authorizations and Hardening of Interfaces 477

11.1 Remote Function Call Security ... 477
11.1.1 Overview ... 478
11.1.2 Trusted and Untrusted Remote Function Calls ... 479
11.1.3 Challenges and Risks with Remote System Connections ... 480
11.1.4 Authorization Objects to Secure Your Remote Connections ... 481
11.1.5 Remote Function Call Callback Whitelisting ... 484
11.1.6 Remote Function Call Connections with Logon Data ... 486
11.2 Best Practices ... 486
11.2.1 Golden Rules ... 487
11.2.2 Interface User Best Practices ... 488
11.2.3 Interface Authorizations Best Practices ... 489
11.3 SAP Unified Connectivity ... 491
11.3.1 How Unified Connectivity Works ... 491
11.3.2 Unified Connectivity and Authorizations ... 492
11.4 Xiting Authorizations Management Suite: Automated and Risk-Free Role Testing and Go-Live ... 493
11.5 Summary ... 494

12 Migrating Authorizations to SAP S/4HANA 497

12.1 Overview 498
12.1.1 Simplifications within SAP S/4HANA 499
12.1.2 SAP S/4HANA Data Management Architecture 502

12.2 SAP HANA Database 504
12.2.1 User Types 505
12.2.2 SAP HANA Authorizations 506

12.3 SAP S/4HANA Deployment Options 507
12.3.1 SAP S/4HANA Cloud 508
12.3.2 SAP S/4HANA Cloud, Extended Edition 509
12.3.3 SAP S/4HANA Cloud, Private Edition 510
12.3.4 SAP S/4HANA: Managed by SAP HANA Enterprise Cloud 511
12.3.5 SAP S/4HANA: On-Premise or Managed by Hyperscale Cloud Providers 512
12.3.6 Comparison of SAP S/4HANA Deployment Options 513

12.4 Business Process Changes through SAP S/4HANA 516

12.5 Core Data Services in SAP S/4HANA 519
12.5.1 ABAP versus SAP HANA Core Data Services Views 520
12.5.2 Security in ABAP Core Data Services 521
12.5.3 ABAP Core Data Services View Troubleshooting 523

12.6 Preparing for an SAP S/4HANA Migration 527
12.6.1 Migration Considerations 527
12.6.2 SAP S/4HANA Approaches 528
12.6.3 Simplification Item Check 532
12.6.4 SAP Readiness Check 533
12.6.5 SAP Best Practices Explorer 534
12.6.6 SAP S/4HANA Migration Cockpit 535
12.6.7 Custom Code Validation 536
12.6.8 Regulatory Requirements and Compliance 539

12.7 Migrating Authorizations to SAP S/4HANA with Standard SAP Tools 541
12.7.1 Project Administration and Basis Activities 542
12.7.2 Analyzing Current Role Concepts 544
12.7.3 Upgrading and Maintaining Authorization Default Values 548
12.7.4 Analyzing SAP S/4HANA-Related Role Changes 550
12.7.5 Evaluating and Defining Job Function Roles 551
12.7.6 Transition and Enhancement of Roles for SAP S/4HANA 553
12.7.7 Testing Your Authorization Concept 556
12.7.8 Go-Live and Project Documentation 561

12.8 Xiting Authorizations Management Suite: Helpful SAP S/4HANA Migration Features 563
12.8.1 Comprehensive Usage Data Collection 563
12.8.2 Role Changes through the Simplification List 564
12.8.3 Security Concept 565

12.9 Summary 566

13 Migrating Authorizations to SAP S/4HANA with the Xiting Authorizations Management Suite 567

13.1 SAP S/4HANA Migration Strategies with the Xiting Authorizations Management Suite 568
13.1.1 Greenfield Migrations 569
13.1.2 Brownfield Migrations 572

13.2 Preparation Phase: Role Concept Validation 574
13.2.1 Verifying Role Concept Quality 575
13.2.2 Authorization Default Values Compliance 578
13.2.3 Consistency Verification of the Inheritance Concept 583

13.3 Design Phase: Conceptual Role Migration 583
13.3.1 Virtual Role Concept Design 584
13.3.2 Analyzing SAP S/4HANA-Related Role Changes 585
13.3.3 SAP Fiori Analysis 587

13.4 Implementation Phase: SAP S/4HANA Role Implementation 588
13.4.1 Role Migration to SAP S/4HANA 589
13.4.2 Extension of Roles with New SAP S/4HANA Functions 591
13.4.3 Template Roles Replication 595

13.5 Validation Phase: SAP S/4HANA Role Concept Analysis 599
13.5.1 Defining and Preparing Test Scenarios 600
13.5.2 Evaluating and Implementing of Test Results 601

13.6 Activation Phase: Role Concept-Protected Go-Live 605
13.6.1 End-User Cloning 605
13.6.2 Authorization Backups 607

13.7 Summary 609

The Authors 611
Index 613
Service Pages I
Legal Notes I

Preface

SAP S/4HANA is the latest enterprise resource planning (ERP) software product from SAP. In comparison to the former SAP ERP 6.0 system, it includes updates to the entire ERP processing and comes with many functional and technical changes that impact security. This book provides you with information about the use of roles and authorizations in SAP S/4HANA and SAP Fiori. Whether you're just starting out with roles and authorizations or you're already well-experienced, you can find what you need in this book. It introduces tools that will help you become more proficient with maintaining, implementing, and migrating authorization concepts. This book includes best practices, tips, and tricks for implementing roles and authorizations. Our key focus is always on the latest tools and concepts for SAP S/4HANA and SAP Fiori—for example, the best method to migrate your roles and authorizations from SAP ERP 6.0 to SAP S/4HANA. We provide the relevant technical information as well as the project approaches and best practices required to undergo such a migration.

Since SAP security—and roles and authorizations in particular—is such a broad topic, this book will be your go-to reference for basic and advanced concepts and is organized in an easy-to-understand way. Getting the basics right is an important step when it comes to implementing a sustainable, transparent, and maintainable authorization concept. The information in this book is based on SAP's own best practices, as well as SAP Notes and technical information provided by SAP itself. It covers everything from the basics of authorization concepts all the way to specific information for advanced security administrators. The book also provides insight into standard tools available for every SAP customer in addition to expert tools like the Xiting Authorizations Management Suite (XAMS).

A solid understanding of authorizations will help you locate and remedy security issues and errors that you or your end users might face more efficiently. Therefore, this book provides you with all the basics of implementing and managing roles and authorizations as well as guidelines for investigating errors.

Target Audience

This book is intended for the following audiences:

- SAP security administrators
- SAP security consultants
- Newcomers to SAP security
- Professionals interested in SAP S/4HANA and SAP Fiori
- Project managers for SAP Fiori and SAP S/4HANA projects

Personal Copy for Arun Singal, arun.singal560@gmail.com

Regardless of whether you are looking for security fundamentals or specific expert topics, this book's content can be a useful reference at all experience levels.

Please note that the role of a security administrator or consultant is most commonly held by a technically minded person who understands how SAP NetWeaver works on a technical level. Often, a security administrator is also a Basis administrator or comes from a system administration background. Security administrators are responsible for the overall security of the SAP system. This includes not only the application security, like maintaining end-user authorizations, but also functional security, like the prevention of unintended access or activities as well as segregation of duties and least privilege principles.

Structure of This Book

This book is divided into thirteen chapters, as follows:

- **Chapter 1** introduces you to the topic of SAP authorizations, their necessity, and their importance as the security framework of SAP Business Suite. This chapter explains the need for proper authorizations management due to laws and regulations to which companies must adhere. Additionally, it touches on new technology trends and hybrid system landscapes in the context of authorizations.
- **Chapter 2** covers the basics of SAP authorizations. It contains an extensive overview of the most important technical information, such as users, roles, profiles, authorization checks, and applications like transactions. This chapter also provides you with best practices for system security checks and settings.
- **Chapter 3** focuses on role concepts, as they constitute the theoretical and practical framework for provisioning roles and authorizations to users. This chapter provides an overview of different role concept approaches, why you might favor some over others, and how to use role concepts in practice.
- **Chapter 4** introduces the Xiting Authorizations Management Suite (XAMS), its various modules, and their specific usage of authorizations. It also builds the foundation for the integration capabilities discussed in other chapters.
- As the authorization default values are the backbone of authorizations in the SAP Business Suites, **Chapter 5** explains the core functionality of role building and role maintenance. It also covers different maintenance approaches, expert tools, and tips for upgrading your custom proposals.
- **Chapter 6** discusses the profile generator (Transaction PFCG) and explains how to build and maintain roles in SAP, as well as how the profile generator integrates with other functionalities. This chapter also provides information about the standard tools for modeling a role concept and shows how to maintain a concept that's compliant with SAP's best practices and standard functionalities.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- Since tracing authorizations is often a required action for any SAP security administrator solving authorization issues, **Chapter 7** explains the various traces, including when and how to use them, as well as integration scenarios with other functionalities to check the causes of authorization failures. It also contains information about debugging authorizations when traces don't provide the required information.
- When discussing SAP S/4HANA, it is inevitable to also discuss the technical and authorization-related topics for SAP Fiori. Therefore, **Chapter 8** explores the architecture, tools, and components required to authorize end users within SAP Fiori.
- Since user maintenance is a daily task, it is important to understand how the interaction between roles and users is relevant to your cybersecurity strategy. We cover this information in **Chapter 9**.
- **Chapter 10** explores how authorization administrators can use SAP Access Control and SAP Cloud Identity Access Governance to maintain and review a sustainable authorization concept. It describes how to use these tools alongside authorizations management, including performing checks for segregation of duty (SOD) conflicts or critical access.
- In the age of digitalization and increasing cybersecurity incidents, it's of utmost importance to secure your technical interfaces. **Chapter 11** provides sustainable information about remote function calls (RFC) and show you how to securely authorize your technical users to safeguard the connectivity between systems and applications.
- SAP delivers many innovations, changes, and new possibilities with SAP S/4HANA. Thus, in **Chapter 12**, we introduce the SAP S/4HANA authorization migration process, prerequisites, technical basics, architecture, and conceptions. This chapter provides you with tips and tricks as well as step-by-step instructions for using standard SAP tools for your transition to SAP S/4HANA.
- **Chapter 13** focuses on authorization migration to SAP S/4HANA utilizing expert tools such as XAMS. It discusses how to structure, prepare, test, and implement a migration using these tools to increase efficiency.

Acknowledgments

This book is based on years of project and work experience in the wide-ranging area of SAP security and authorizations. It includes best practices from many different customer projects that each had specific needs and requirements. Therefore, we wanted to extend our gratitude to our customers, who always challenge us with new projects and continuously trust us to provide them with the best possible solutions.

We also want to thank our family, friends, and colleagues for their continuous support, lovely words, and understanding during the writing process.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Finally, a heartfelt thank you to the following people who tirelessly helped us with this book by reviewing content and providing information as well as support and patience. Without these people, this book would not have been possible:

Erik Trouillet (Managing Consultant – Xiting AG), Nicole Wolderling (Managing Consultant – Xiting AG), Jennifer Schmider (Managing Consultant – Xiting AG), Vanessa Albuera (SAP Security Consultant – Xiting GmbH), Will Dunkerley (Managing Director – Xiting UK Ltd.), Stefan Wohlschlag (Managing Consultant – Xiting AG), Marc Spitzer (Managing Consultant – Xiting GmbH), Matyas Pattantyus (Managing Director – Xiting ROM SRL), Patrick Bockel (CEO – Xiting), Daniel Kindermann (SAP Director Training – Xiting AG), Martin Trachsel (Managing Director – Xiting AG), Carsten Olt (Managing Consultant – Xiting GmbH), Abdullah Alebrahem (SAP Security Consultant – Xiting GmbH), Otto Gold (Security Developer – Xiting AG), Julius Bussche (Director Development – Xiting AG), Steffen Schatto (Managing Consultant – Xiting AG), Levele Joseph (SAP Security Consultant – Xiting LLC), Daniela Schoene (SAP Security Consultant – Xiting ROM SRL), Sabina Barcutean (Marketing Associate – Xiting ROM SRL), Beatrix Kiss (Marketing Associate – Xiting ROM SRL), Hareem Shafi (SAP PRESS), and Rachel Gibson (SAP PRESS).

Yours sincerely,
Alessandro Banzer and **Alexander Sambill**

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 1
Introduction to SAP Authorizations

This chapter introduces you to the topic of authorizations in SAP, why and when authorizations are needed, and how to implement authorizations in SAP Business Suite as part of your security framework. We'll reflect on the evolution of SAP systems and its effect on security, which is no longer a matter for your application layer only. Security has become even more important on the layers underneath (typically an SAP HANA database) and above (SAP Fiori or any other client). In addition, we'll shine a light on current trends, including digitalization, big data, connectivity, platforms, and their effects on today's SAP landscapes as we move to hybrid environments consisting of both on-premise and cloud-based solutions. This chapter emphasizes the authorizations point of view when operating such a hybrid SAP system landscape.

SAP technology has significantly changed in recent years. New technologies have been introduced; platforms, modules, and solutions have been consolidated; and new applications have been integrated. In this process, SAP's cloud-first strategy has impacted entire business processing and system landscapes. The power of modernization and digitalization has also driven a focus on the user experience (UX). However, whether application security is still guaranteed with all these changes is not always clear.

Whenever we talk about security concepts, two terms are commonly tossed around, leading to confusion—authentication and authorization. *Authentication* is when the user logs on to an SAP system with a user name and password or other credentials. An authentication provider validates if your user name and password are correct and allows you to log on. Authentication determines "who you are" but not "what you can do."

Once a user is authenticated, *authorizations* come into play to define what the end user can do in the system. A user without authorizations can still log on to the system but is not enabled to use any functionalities within due to missing authorizations. At this point, the user is *authenticated*, but not *authorized*.

A common concern is designing authorizations in the right way so your organization can manage access effectively and efficiently. In this chapter, we'll focus on the term "authorization," describing its necessity, its various types, and how it fits into the SAP world.

Personal Copy for Arun Singal, arun.singal560@gmail.com

1.1 What Are Authorizations?

Authorizations enable end users to perform activities in a system, from a business operations point of view. Typically, end users have dedicated responsibilities and tasks for which they require specific authorizations. Lacking authorization results in missing access to particular system functions. Access requirements vary across business functions. In rare scenarios, a user may even require several position-specific authorizations due to cross-functions, deputy roles, or job-sharing.

Authorizations also enable the management of access to sensitive functions or data. As such, access to mission-critical system functions or sensitive business data may not be granted to all users. Unauthorized access could result both in a violation of internal policies, as well as a violation of laws or regulations, such as data protection requirements.

Generally, various requirements affect how the access model is designed and how access is granted to your users. These requirements can generally be categorized in the following way:

- **External requirements**
  - Legal obligations (Sarbanes-Oxley Act, Foreign Account Tax Compliance Act [FICA], General Data Protection Regulation [GDPR], Law of Obligations)
  - GxP requirements (Good manufacturing practices)
  - Industry standards (IEEE standards)
  - Certifications (Cybersecurity Maturity Model Certification, ISO/IEC 27001 — Information security management)
- **Internal requirements**
  - Internal controls (over financial reporting)
  - Internal policies (code of conduct)
  - Principles (least privilege)
  - Standards (best practices, quality controls)
  - Guidelines (guided procedures)
  - Ethics and culture (access to information)

Not all of these requirements will be necessary for access management in your specific case. For example, external requirements, such as obtaining certifications, might impact your business operations only. In contrast, other requirements like internal controls can play a major role in defining the access rights of your end users. Implementing a robust, sustainable, and effective authorization design helps establish controls in the system efficiently. In conclusion, authorizations are a key element in an organization to grant access to system functions. Authorizations should reflect both

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

external and internal requirements while still being aligned to your company's governance policies for managing all levels of the organization.

1.2 User Access in the SAP System

To establish appropriate access governance, all employees require a user ID. While various authentication methods are available, the level of access is always determined by roles and profiles being assigned to a user. The type and extent of access—that is, from a functional and organizational perspective—are based on authorizations in profiles. Functional access can be a transaction, a Web Dynpro application, or an authorization to be able to execute the services that drive SAP Fiori apps. These functional authorizations are complemented by organizational authorizations, which relate to a particular business context, such as a plant. Figure 1.1 shows the correlation among all these elements.

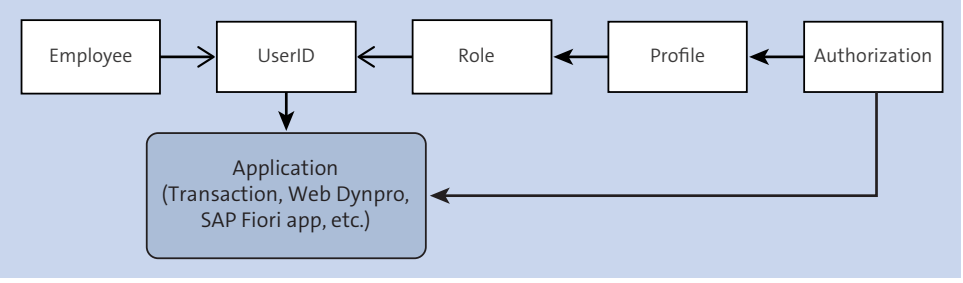


Figure 1.1 SAP User Access Simplified

After a successful logon, the kernel directly loads the end user's authorizations into the *user buffer* based on the assigned authorization profiles in the user master record. Typically, profiles are generated from roles but can theoretically be assigned to a user ID directly.

What roles and profiles should be assigned to a user always depends on your authorization concept. Each company faces unique environments and requirements. Thus, strategies for establishing an effective authorization concept can vary, depending on different criteria like location, industry, business area, technology, or area of responsibility.

Besides strategies and approaches when setting up authorizations properly, increased landscape complexity has raised the demand for tools to automate the authorization management process. With various tools, you can maintain users, roles, and authorizations and implement authorization concepts in a sustainable way. In light of recent SAP S/4HANA transformations, such tools facilitate the migration of authorizations and reduce migration efforts tremendously. These tools can help you stay on top of security matters in fast-growing and hybrid landscapes.

Personal Copy for Arun Singal, arun.singal560@gmail.com

1.3 Evolution of Authorizations from SAP ERP to SAP S/4HANA

In this section, we'll reflect on the evolution of SAP ERP into SAP S/4HANA and what this development meant for authorizations. We'll also discuss deploying SAP S/4HANA Cloud and other cloud-based SAP solutions.

1.3.1 SAP ERP

In 1992, SAP released SAP R/3 as the first enterprise resource planning (ERP) system that leveraged the advantages of a distributed three-tier architecture consisting of database, application, and presentation layers. To maximize flexibility, the new architecture supported many operating systems and database management systems (DBMSs). The architecture was highly scalable and could meet the need for the larger and more complex system landscapes required by organizations that operated globally. SAP R/3 used a common client-server architecture and for the first time included a Web Application Server (Web AS). Also, SAP R/3 was the first release that enabled the seamless integration of various applications to run business processes in a single system, bringing together the areas of finance, sales, and human resources (HR). Simultaneously, the authorization model evolved further to accommodate the demand for segregated access to business functions. For instance, the ability to post an accounting document in the finance area required access to Transaction FB01. At that time, typically, the naming convention indicated which process area the transaction belongs to. For example, most transactions starting with an "F" were typically related to a finance process. Fine-grained access within transactions was managed through authorization objects that controlled the type and extent of access. For instance, you could differentiate between display or update access (for posting an accounting document) for a particular company code.

The next major evolution step was SAP NetWeaver 2004, later renamed to SAP NetWeaver 7.0. The architecture created a stable and sustainable business technology platform that could be extended. An enhancement package (EHP) framework was delivered with SAP NetWeaver 7.0, enabling you to implement further enhancements as needed. Another significant change was its ability to integrate with third-party technologies, like .NET, WebSphere, and Java. Particularly, SAP NetWeaver Application Server (AS) could serve an ABAP and/or Java (J2EE) stack, as shown in Figure 1.2. The authorization model has not changed, however, and provided capabilities to integrate with Java-based SAP solutions, such as SAP Enterprise Portal.

In the past decade, changes in the IT environment—both from a legal perspective (data protection requirements or federal tax reporting obligations) and a technological perspective (digitalization, the Internet of Things [IoT], mobile devices, or connectivity)—have significantly increased demand for a capable, high-performance computing application to run business processes even more efficiently.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

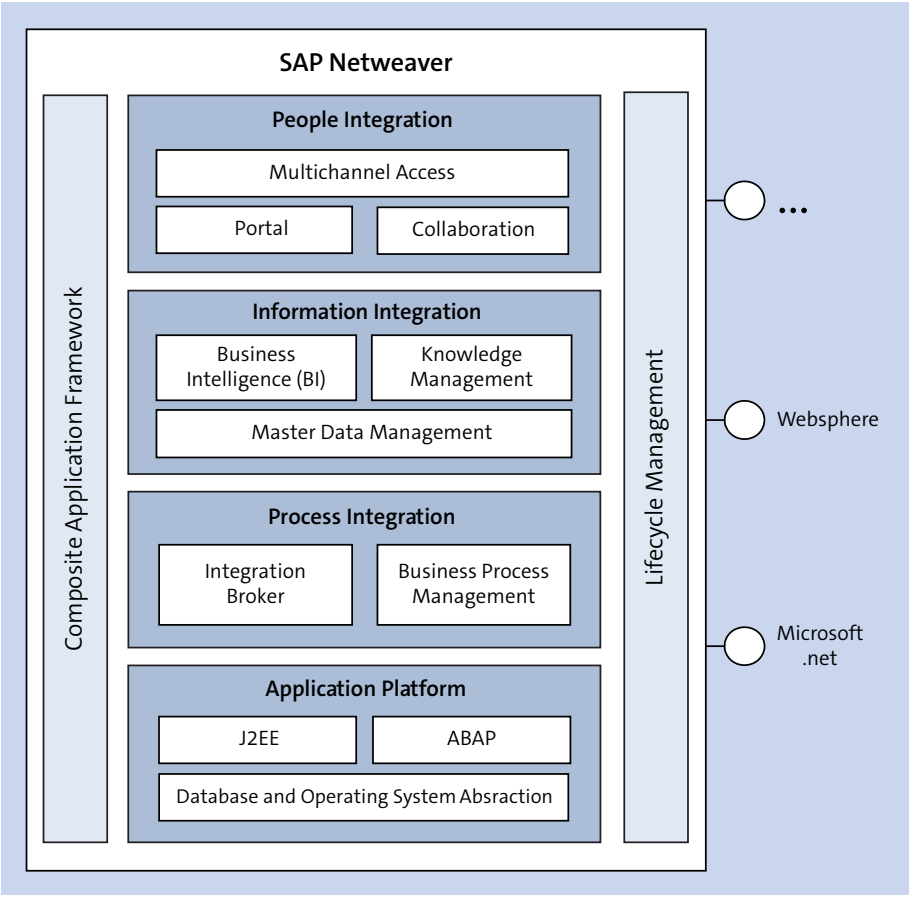


Figure 1.2 SAP NetWeaver Components

The next step involved the simplification of the security architecture and increasing transparency into how access is granted to critical business data and functions. Technology has become a key element in the IT strategy of many organizations to keep up or even to gain an advantage in highly competitive markets.

1.3.2 SAP S/4HANA

In addition, SAP Business Suite has grown consistently for many years, and thus, integration effort has increased disproportionally to the extensibility of the system (particularly with SAP NetWeaver as a central development platform and runtime environment). This growth in effort highlighted the need for a new technology, thus leading to the fourth generation of SAP Business Suite—SAP S/4HANA.

Even though SAP S/4HANA is still using ABAP for its code, its underlying database—SAP HANA—helps resolve some significant disadvantages and limitations that existed in previous SAP ERP releases, through the following capabilities:

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Simplification of the data model and related processes
- Integrated solution with large extensibility
- Real-time data analytics
- Performance improvement
- Cloud computing

SAP HANA was released for the first time in 2011. Later, SAP HANA was quickly adopted for architectures with SAP Business Warehouse (SAP BW) to benefit from performance gains in real-time operational reporting and then made available to SAP ERP systems. Finally, the first release of SAP S/4HANA in 2015 used a new data model and leveraged SAP HANA's capabilities, as shown in Figure 1.3.

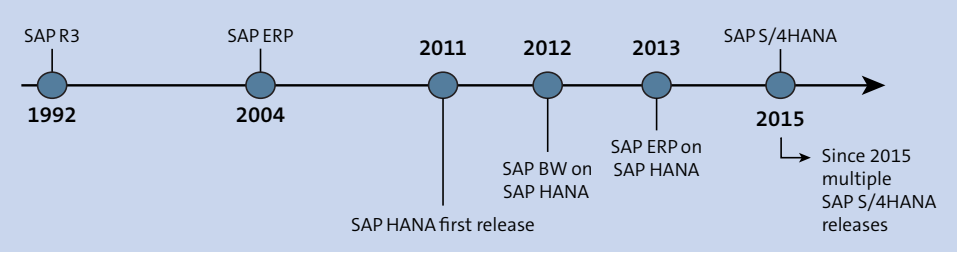


Figure 1.3 SAP's Evolutionary Process at a Glance

Whereas technology integration has been the main focus of the SAP NetWeaver platform with SAP S/4HANA, the focus has moved to business process integration using a harmonized, fully integrated, and simplified data model. To benefit from performance improvements, real-time reporting is possible to support decision-making processes on all levels of your organization. To leverage these capabilities, a fundamental prerequisite is running SAP S/4HANA on an SAP HANA database.

SAP HANA is an in-memory relational database management system (RDBMS) that enables you to operate your systems, typically SAP ERP and SAP BW systems, with a significant performance gain over traditional RDBMS systems. As the database is column-oriented, high compression rates can be achieved. Data that is used often can be held in-memory and can thus be called up quickly, with tangible effect on program execution speed. Data is not entirely stored in the persistence layer any longer. In conclusion, SAP HANA facilitates real-time operational reporting scenarios with enhanced analytics that integrate any type of data source, such as big data, geospatial data, or social and business networks.

SAP HANA can serve as an open application development platform supporting various programming languages, such as R, SQL, or Java. SAP HANA is therefore not only a classic RDBMS. You can use SAP HANA in any scenario as a central development platform since SAP HANA can host a variety of applications of different nature. The XS engine,

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

SAP HANA's native application server, facilitates the efficient deployment of applications to enable end users to access complex analytics using a variety of interfaces. In this way, data can be made accessible easily regardless of the user interface (UI) technology used on the presentation layer.

For example, as shown in Figure 1.4, SAP Fiori applications can consume data via OData services in the ABAP backend, and the data is presented based on HTML5 technology. The entire calculation logic sits on the database layer, and the data is therefore already preprocessed, thus leveraging all the advantages of SAP HANA's in-memory data processing technology. SAP Fiori app content is hosted on an ABAP application server, the application layer. SAP Fiori apps are built using the SAPUI5 framework, which includes an HTML5 rendering library for presenting content on the client side, on the user interface (UI) layer.

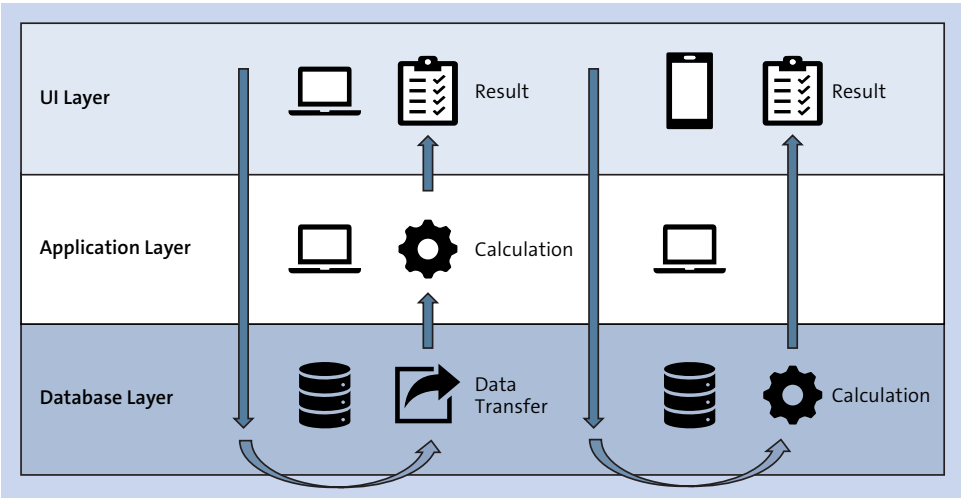


Figure 1.4 Layers of the Architecture Compared

Having now multiple entry points to the system (i.e., an SAP Fiori application, an SAP GUI transaction, or a report that retrieves data directly from an SAP HANA database), you'll need to establish an authorization concept that spans across all layers of your architecture. While both presentation and application layers still use the ABAP authorization model, SAP HANA utilizes a privilege framework on the database layer.

In previous decades, the ABAP security and authorization model had not changed significantly, even in SAP S/4HANA. Defining and implementing access controls has always been a compulsory task in the course of object development, whether developing ABAP programs or core data services (CDS) views. Authority checks must be part of the program code. Access can be granted through authorizations included in profiles assigned to a user directly or via roles.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Chapter 7 explains in detail how to analyze primary security components in ABAP program codes.

Commonly, the infrastructure of an SAP system was located in-house or in the data center of a service provider. Eventually, this approach caused high total cost of ownership (TCO) due to high costs for system operations and maintenance. To respond to this business demand, cloud-based solutions have been developed, the next step in the evolutionary process of SAP Business Suite. A distributed system architecture in the cloud can provide resources when needed. Processes are harmonized and stay close to the standard. Simplification is a key element enabling positive effects on security by reducing the effort in otherwise time-consuming user and role management activities.

This paradigm change means suddenly IT plays an essential role in business planning and must be considered during the design of business processes. In conclusion, IT will focus less on operations and maintenance activities, including security, instead focusing more on creating business value by leveraging the advantages of technology hosted in the cloud. This shift also applies to SAP S/4HANA, also available in the cloud.

1.3.3 SAP S/4HANA Deployments

SAP S/4HANA can be deployed in many different ways, including using a shared infrastructure or existing infrastructure. What is considered the best fit for your company depends on multiple elements that should be taken into consideration when evaluating the various deployment options, including the following areas:

- Infrastructure
- Licensing
- Functional scope

Other considerations may reflect on extensibility, configuration, roles and responsibilities, financial aspects, business value, and much more. The higher the degree of standardization while accepting a low degree of flexibility, the lower the TCO. In such a scenario, service providers can assume much more responsibility, particularly on the IT infrastructure and operations side, while you, as the customer, can focus on creating business value. Nonetheless, standardization requires a fit-to-standard approach with inevitable effects on business processes, as shown in Figure 1.5.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

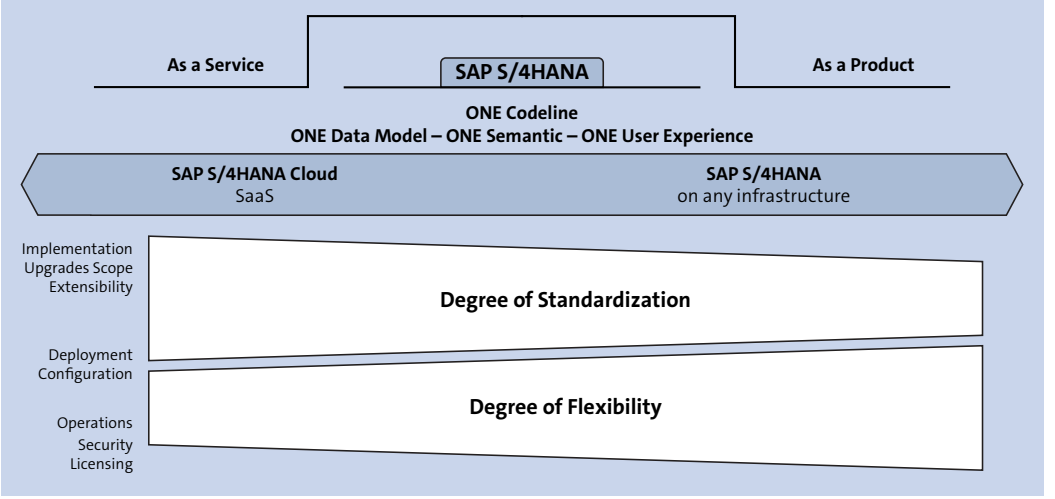


Figure 1.5 Balancing Standardization and Flexibility

Maximum flexibility is granted when SAP S/4HANA is installed on-premise on a dedicated infrastructure, which may be operated by SAP, another service provider, or in-house. When your infrastructure operations are outsourced to a third-party provider, you have adopted an infrastructure as a service (IaaS) model. In these scenarios, you will have full responsibility for managing security. In contrast to the software as a service (SaaS) model, an IaaS enables the flexibility to implement appropriate security measures tailored to your own requirements, including an enhanced authorization model that goes beyond the traditional management of read and write access in business applications. For example, data protection measures can be implemented to prevent the disclosure of sensitive information within a business application or report.

When SAP S/4HANA is hosted in the cloud, in this SaaS model, SAP is responsible for providing and maintaining the software, as shown in Figure 1.5. Depending on the deployment option, you may have chosen SAP to serve as the cloud provider, or you've chosen another hyperscale cloud provider, such as Microsoft Azure, Amazon Web Services (AWS), or Google Cloud. In either case, the hyperscale cloud provider or SAP operates the infrastructure based on standardized processes, services, and service level agreements (SLAs). The more extensibility you require (for instance, in relation to add-ons or the implementation approach being used), the more flexibility you'll need.

SAP offers multiple deployment options, either in the cloud or on-premise, as listed in Table 1.1.

Personal Copy for Arun Singal, arun.singal560@gmail.com

	SAP S/4HANA Cloud	SAP S/4HANA Cloud, Extended Edition (EX)	SAP S/4HANA Cloud, Private Edition	SAP S/4HANA, Managed by SAP HANA Enterprise Cloud	SAP S/4HANA
Infrastructure	Public cloud	Private cloud	Private cloud	SAP HANA Enterprise Cloud/customer data center/hyperscale cloud provider	Your own data center/hyperscale cloud provider
Licensing	Subscription	Subscription	Subscription	Bring Your Own License	Bring Your Own License
Functional scope	Core ERP	SAP S/4HANA (on-premise)*	SAP S/4HANA (on-premise)*	Full SAP S/4HANA	Full SAP S/4HANA
UI	SAP Fiori only	SAP Fiori + SAP GUI	SAP Fiori + SAP GUI	SAP Fiori + SAP GUI	SAP Fiori + SAP GUI
Implementation approach	Greenfield only	Greenfield or bluefield	Greenfield, brownfield, or bluefield	Greenfield, brownfield, or bluefield	Greenfield, brownfield, or bluefield

* With minor limitations

Table 1.1 SAP S/4HANA Deployment Options

Standardization often impacts security. If you opt to implement SAP S/4HANA Cloud, security will always be limited to the feature scope of the relevant solution. The user access model is significantly simplified using predefined roles. In consequence, security administration efforts will shift from role design to user access provisioning. In contrast, with less standardization and more customization, options are available so you can implement a more sophisticated user access model that fits our individual needs and that is aligned to your specific system landscape.

Hint

For more details about SAP S/4HANA and the migration process, see Chapter 12 and Chapter 13.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

1.3.4 Other SAP Cloud Solutions

In addition to SAP S/4HANA Cloud, the portfolio of cloud-based SAP solutions has grown throughout the last decade. A variety of business applications has been made available as cloud-only solutions to leverage a high degree of standardization and to provide line of business solutions at a lower TCO. SAP offers numerous cloud-based business applications, some of which are listed in Table 1.2.

Application	Description
SAP Ariba	SAP Ariba is a cloud-based solution for managing the entire source-to-pay process integrated into the SAP S/4HANA digital core. Suppliers and buyers can connect directly on a global platform to streamline supply chain, procurement, and contract management processes.
SAP SuccessFactors	SAP SuccessFactors is a cloud-based HR solution that focuses on people and employment. Also referred to as a human experience management (HXM) suite, SAP SuccessFactors supports the entire employee lifecycle (such as recruiting, onboarding, performance, compensation, learning, succession, and development) and assists in strategic HR decision-making.
SAP Fieldglass	SAP Fieldglass is a cloud-based vendor management system to procure and manage external workforces. This solution enables contingent workforce management, service procurement, worker profiles, and assignment management.
SAP Concur	SAP Concur is a cloud-based travel, expense, and invoice management solution. Time-consuming, often paper-based, processes can be transformed into a fully digital, simplified travel and expense management process in a single system. Invoices are captured and approved via defined workflows.
SAP Integrated Business Planning for Supply Chain (SAP IBP)	SAP IBP enables end-to-end supply chain planning, supported by analytics; scenario-based simulations; and responses to forecast changes. Available as a cloud-based solution, the sales, operations, and inventory planning capabilities of SAP IBP are aligned to demand, both forecast and actual.

Table 1.2 Selected Cloud-Based SAP Solutions

All these SAP applications are fully cloud based. However, the security model varies among these applications.

Personal Copy for Arun Singal, arun.singal560@gmail.com

1.4 SAP Fiori (Presentation Layer)

In a three-tier architecture, the database, the application layer, and the presentation layer are separated from each other. All business logic and functionality should run on the application layer, including processes and resources. The output, which is the processed data resulting from an executed program, is transmitted in a readable format to the end user via the presentation layer. As shown in Figure 1.6, a user's interaction with the system occurs through various clients, generally supporting different UI technologies.

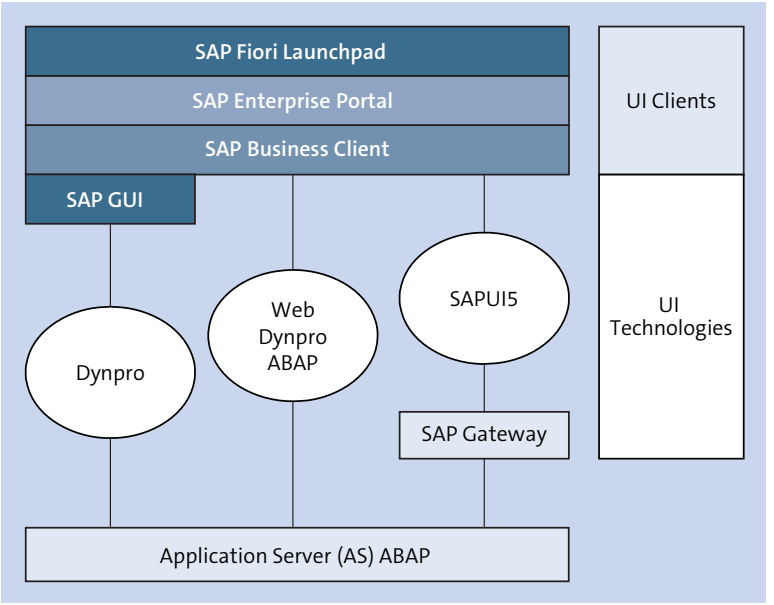


Figure 1.6 SAP UI Clients and Underlying Technologies

Initially, only the traditional SAP GUI client was available to access an ABAP-based SAP system. The user access model followed a role-based approach designed to enable a user to perform all activities in the system to the extent required by that user's job function. SAP GUI, shown in Figure 1.7, served as the single entry point to the system. The following SAP GUI application types are available:

- SAP GUI for Windows
- SAP GUI for Java
- SAP GUI for HTML

SAP Business Client, shown in Figure 1.8, was developed to support access to multiple technologies and to enable seamless integration among SAP GUI transactions, Web Dynpro ABAP business applications, and other web content applications.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

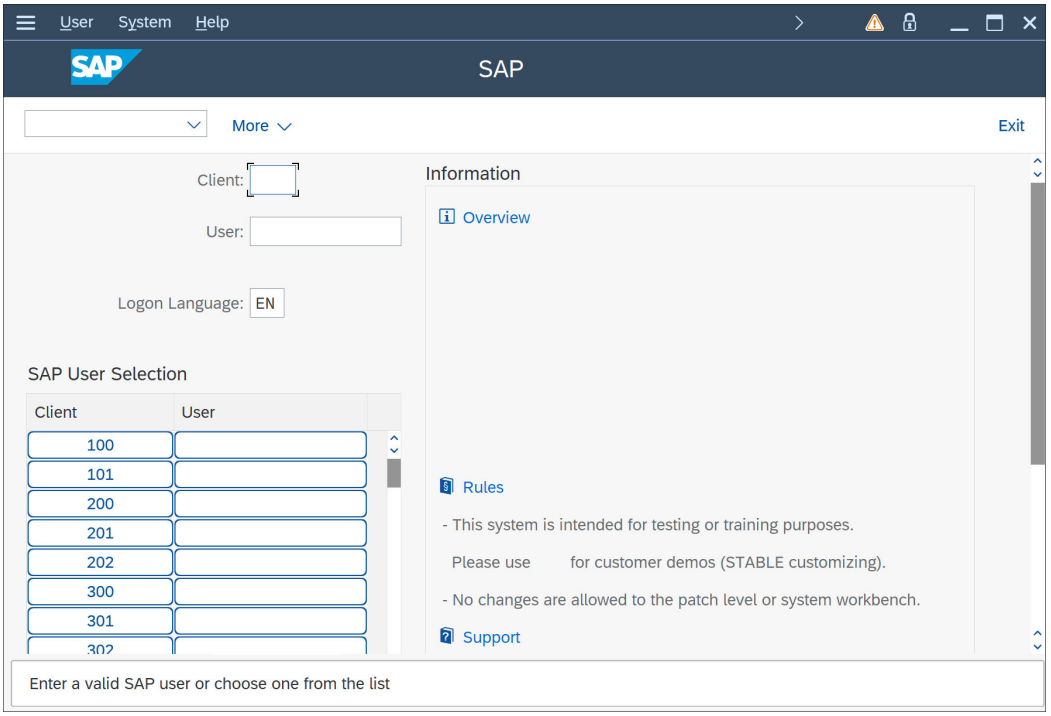


Figure 1.7 SAP GUI UI

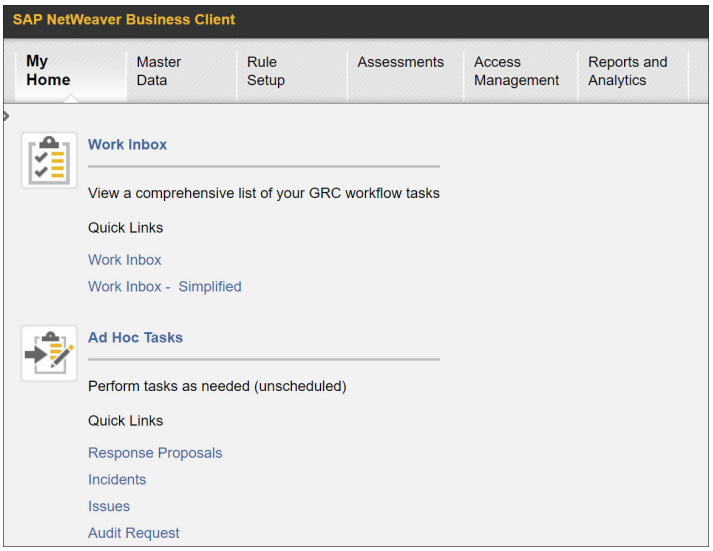


Figure 1.8 SAP Business Client UI

SAP Business Client could serve as a single entry point to the system while significantly improving the UX in comparison to SAP GUI. The user access model also followed a role-based approach.

Personal Copy for Arun Singal, arun.singal560@gmail.com

As the latest technology, the SAP Fiori 3.0 UI has been developed to achieve the following objectives:

- Simplified and more intuitive UI across devices
- Minimum training requirements and personalized role-based user access
- Enhancement of mobile connectivity and accessibility

As shown in Figure 1.9, navigation in SAP Fiori is based on *apps*, generally leaner in design, to facilitate a less complex UI with an improved UX. Consequently, SAP Fiori applications are designed for distinct purposes, unlike traditional SAP transactions, which often served several demands at once. SAP Fiori provides a central launchpad to host these apps and make business applications available end users without the need for a proprietary client like SAP GUI. In contrast to SAP Business Client, SAP Fiori uses SAPUI5 technology and can also run on mobile devices.

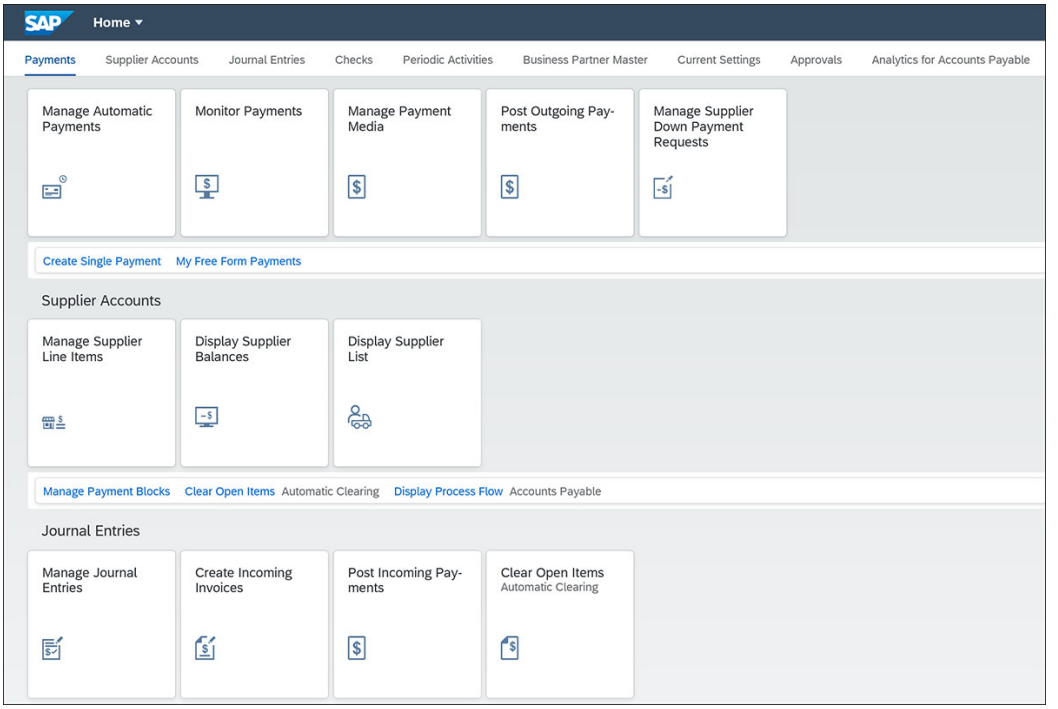


Figure 1.9 SAP Fiori UI

From a security point of view, the consumption of SAPUI5 applications also additionally requires authorizations for specific services. Business applications still run on the application server and provide all data via the Open Data (OData) protocol. The data is consumed by the SAP Fiori app and then presented in a readable format to the end user.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

1.5 Native Authorizations in SAP HANA (Database Layer)

SAP HANA is equipped with many security features to enable you to secure your platform end-to-end, as shown in Figure 1.10. This security framework is fundamentally different from ABAP-based applications. While many features are comparable, their technical implementations differ since the foundation is no longer ABAP.

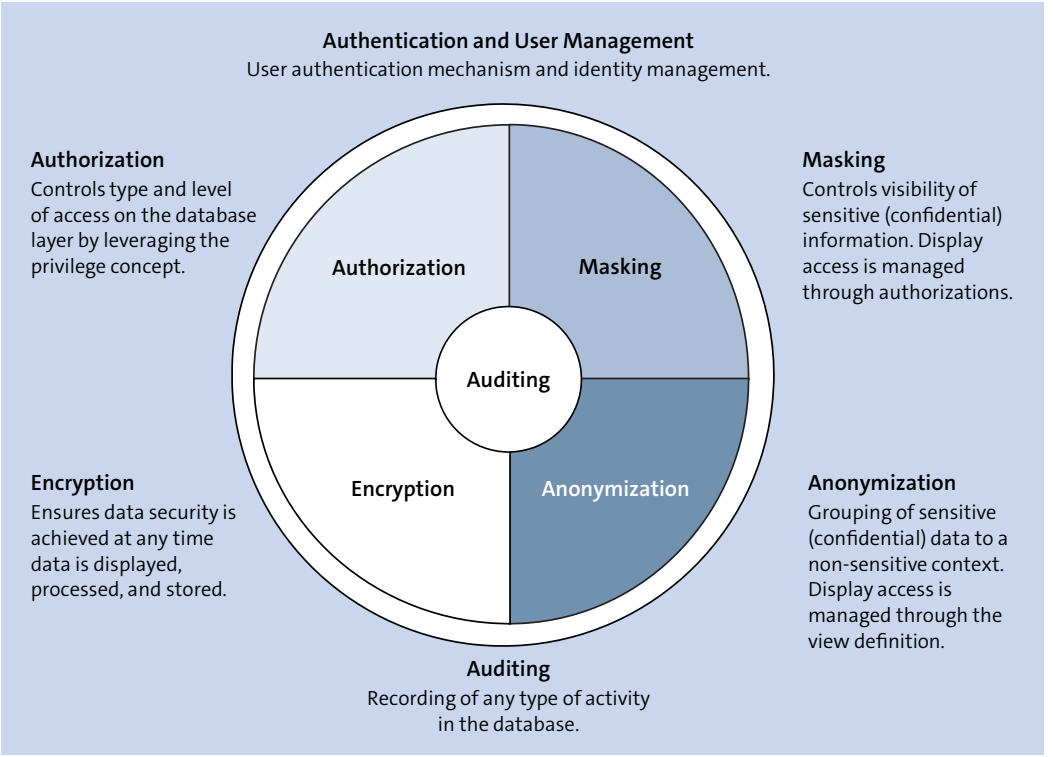


Figure 1.10 SAP HANA Security Features

As in ABAP, the main security mechanisms in SAP HANA are based on authentication and user management as well as authorizations. To perform any activity, the user must be authenticated first. The most common authentication methods still use passwords or single sign-on (SSO), for instance, Kerberos or Security Assertion Markup Language (SAML). However, fewer user types are generally available in SAP HANA, and all of them allow users to log on in dialog mode, including manually created technical users. In contrast, dialog mode is not available to all user types in ABAP applications, such as the `SYSTEM` or `REFERENCE` users.

Once authenticated, user access depends on the authorizations assigned to the user ID. In SAP HANA, authorizations leverage a privilege framework. Privileges can be compared to authorizations in ABAP, that is, as fully maintained authorization objects. Multiple privileges may be required to perform certain activities in an SAP HANA database,

Personal Copy for Arun Singal, arun.singal560@gmail.com

as is typically the case for SAP ERP applications with ABAP authorizations. To fully execute an operation in an ABAP program (e.g., reports, transactions, etc.), often more than one authorization is required. Similarly, accessing an SAP HANA column view object may require multiple privileges. Access is provisioned via roles that embed another role or privilege. Nonetheless, privileges can also be assigned directly.

Privileges in SAP HANA can be categorized into the following five privilege types:

- System privileges
- Object/SQL privileges
- Package privileges
- Analytic/structured privileges
- Application privileges

Hint

Chapter 12 elaborates in detail on the purpose of each privilege type and explains some SAP HANA basics.

Major differences exist when comparing and contrasting a common ABAP authorization concept with an SAP HANA database authorization concept. Implementing security is an effort throughout the entire architecture of the system landscape and therefore must be applied consistently across all layers. Thus, all conceptual elements should be aligned to ensure effective control design no matter on what layer the user is interacting with the system.

Hint

For a comprehensive look at security in SAP HANA, familiarize yourself with *SAP HANA 2.0 Security Guide* by Jonathan Haun (2nd edition, SAP PRESS, 2020), available at *www.sap-press.com/4982*.

1.6 Hybrid System Landscapes and Implications on Authorizations

SAP landscapes have evolved from simple architectures to complex, highly integrated, hybrid architectures with a variety of solutions hosted on-premise and in the cloud. Cybersecurity risks are on the rise while the attack surface expands due to the growth of landscapes and the use of new technologies. New regulations have gone into effect that impact security requirements and thus authorizations. An important task of the security team of an organization is to accommodate these requirements in all facets of the company's authorization concept to effectively manage risks in relation to unauthorized access.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

1.6.1 Business Roles and SAP Business Technology Platform

Hybrid system landscapes consist of a mix of both cloud-based and on-premise solutions where the authorization concepts may differ from each other. The ultimate challenge is establishing an effective approach to provision and maintain user access efficiently across the entire landscape. The more automation, the less effort required to administer security and authorizations.

A key principle to achieve this goal is the implementation of a business role concept. *Business roles* can be understood as containers for all authorizations across systems required to perform a user's daily tasks in the business environment. From a technical point of view, a business role consists of multiple roles in various systems. Also, non-SAP systems can be included if these solutions can technically be integrated. A user would only need to request a business role, and upon approval, a role or set of roles is then assigned to the user in each system automatically. Given the evolutionary process from simple, purely on-premise system landscapes to sprawling, hybrid system landscapes, business roles must also include access requirements to cloud-based solutions.

Hint

Chapter 10 describes more in detail the capabilities the business role management module of SAP governance, risk, and compliance solutions and SAP Cloud Identity and Access Governance.

With SAP Business Technology Platform (SAP BTP), formerly known as SAP Cloud Platform, SAP has enhanced enterprise applications with capabilities in the following areas:

- Database and data management
- Analytics
- Application development and integration
- Intelligent technologies

Hint

Chapter 10, Section 10.2 elaborates on SAP BTP's capabilities in detail.

For example, SAP S/4HANA Cloud, SAP Ariba, and SAP SuccessFactors can be hosted in SAP Cloud. However, the extensibility framework can leverage the features of SAP BTP, such as running an ABAP-based third-party application using the SAP BTP, ABAP runtime environment.

Given the variety of requirements related to security, SAP BTP offers multiple services to facilitate efficient and effective identity and access management in hybrid architectures, shown in Figure 1.11, including in particular the integration of the many cloud

Personal Copy for Arun Singal, arun.singal560@gmail.com

solutions mentioned earlier. All cloud security services share in common the same technical baseline: SAP Cloud Identity Services, which consists of two components (Identity Authentication and Identity Provisioning).

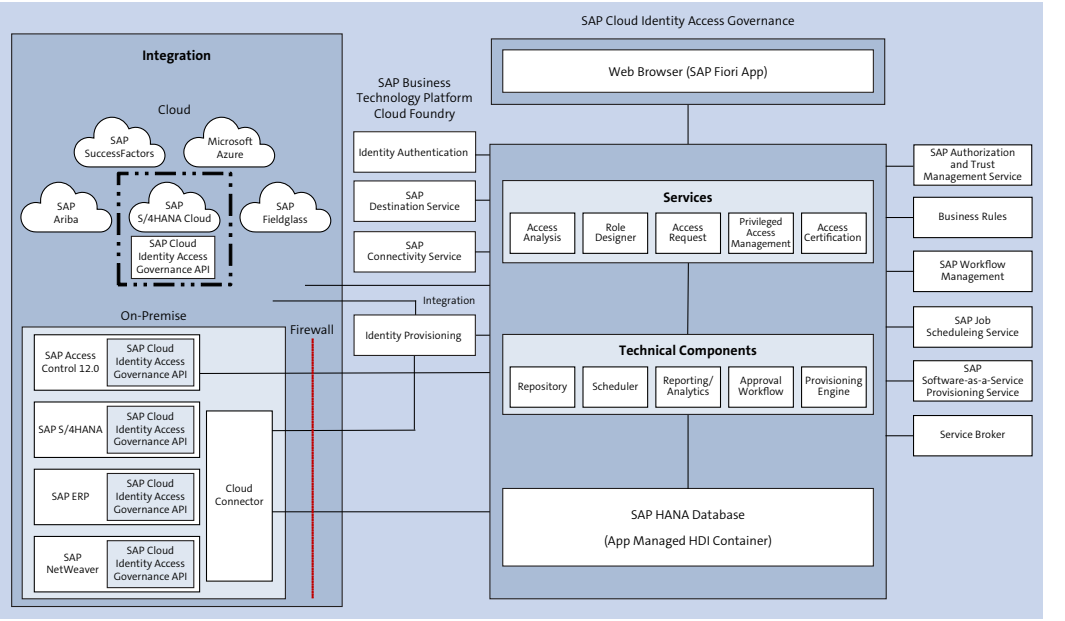


Figure 1.11 Integrated Hybrid Architecture Utilizing SAP Cloud Identity Services

1.6.2 SAP Cloud Identity Access Governance

As shown in Figure 1.11, the architecture integrating both cloud-based and on-premise solutions utilizes the Identity Authentication service and the Identity Provisioning service. Let's look at key features of both services next:

- **Identity Authentication service**
  - Enables simple and secure access to web-based applications
  - Allows secure authentication and SSO for cloud and on-premise applications
  - Contains enterprise-level features like password policies, multifactor authentication, and risk-based authentication
  - Supports on-premise user stores and allows for easy consumer and partner onboarding via self-services and System for Cross-domain Identity Management (SCIM) support
- **Identity Provisioning service**
  - Provisions identities for cloud and on-premise systems
  - Automatically sets up user accounts and authorizations

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- Optimized for SAP Cloud applications
- Utilizes existing on-premise and cloud user stores and integrates with SAP Identity Management (SAP ID Management)

On top of these two components, SAP has developed SAP Cloud Identity Access Governance to leverage the capabilities of the SAP Cloud Identity Services. SAP Cloud Identity Access Governance satisfies the demand for a risk and compliance solution for hybrid architectures and can be considered the cloud-based equivalent to SAP Access Control. The main benefits of SAP Cloud Identity Access Governance include the following:

- Multitenant solution built on top of SAP BTP and the proprietary SAP HANA database
- Provides a unified access governance model for SAP landscapes
- Can serve as a single point of truth for identity and access management, including access risk analysis
- Provides out of the box integration with SAP's latest cloud applications such as SAP Ariba, SAP SuccessFactors, SAP S/4HANA Cloud, SAP Analytics Cloud, and other cloud solutions

Since SAP Cloud Identity Access Governance can integrate both cloud-based and on-premise solutions, it removes the technical barriers that governance, risk, and compliance (GRC) solutions face in hybrid landscapes, enabling you carry out risk analysis and mitigation procedures centrally. SAP Cloud Identity Access Governance is an important building block for the process of evolving into a full-blown risk management solution in line with SAP's cloud-first strategy. As a purely cloud-based solution, SAP Cloud Identity Access Governance leverages a simplified, web-based frontend using the SAP Fiori technology.

1.6.3 Access Provisioning in Hybrid Landscapes

Hybrid architectures vary depending on your strategy and your existing solutions for identity and access management activities, particularly for the on-premise side of the architecture. For instance, an SAP ID Management solution may already be in place before cloud-based solutions have been connected and deployed. Another example is the existence of SAP Access Control in the SAP landscape for managing access provisioning, including access risk reviews for all on-premise systems. In any case, to provision access to cloud-based solutions, using the Identity Provisioning service is a prerequisite.

Hint

Please refer to Supported Systems in the SAP Help Portal for the full list of source and target systems that can use SAP Cloud Identity Service Identity Provisioning: *http://s-prs.co/v203601*.

Personal Copy for Arun Singal, arun.singal560@gmail.com

In a scenario with a preexisting SAP ID Management solution that served your on-premise applications, such as SAP S/4HANA, the Identity Provisioning service connects straight to the SAP ID Management solution, as shown in Figure 1.12. Besides, the Identity Authentication service would directly integrate with the corporate identity provider whose user store is synchronized with the SAP ID Management solution. Business roles are supported by SAP ID Management so that those are simply extended by the cloud solution-specific roles or role collections. All user and role provisioning activities reside in SAP ID Management, where they are also managed centrally.

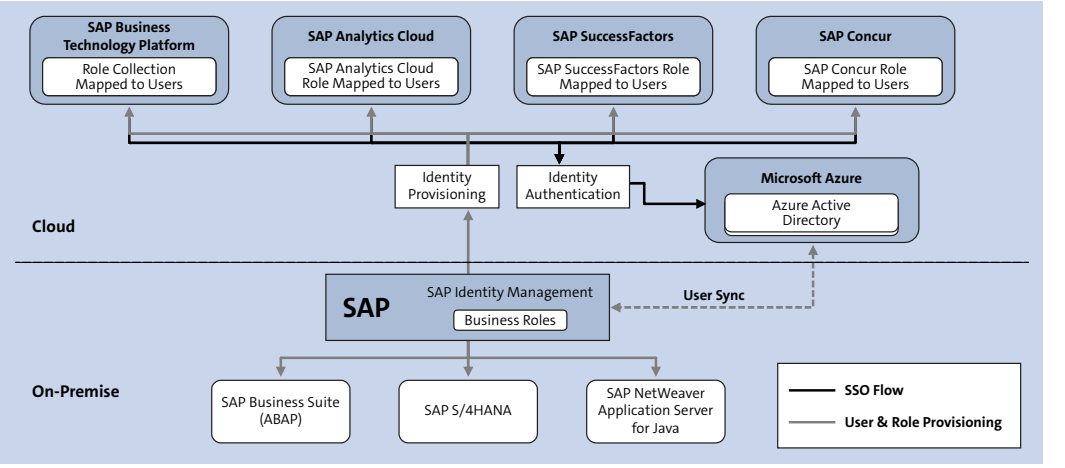


Figure 1.12 Example of a Hybrid Architecture with SAP ID Management

To connect on-premise systems to the cloud infrastructure, you would use the cloud connector. In this way, SAP Cloud Identity Access Governanceis empowered to interact with your on-premise solutions directly (i.e., for risk analysis). Access provisioning is carried out through the Identity Provisioning service. All cloud-based solutions interact with SAP Cloud Identity Access Governance through the same service to enable seamless integration for access provisioning.

As in our earlier scenario, having a dedicated identity management solution in place, the Identity Authentication service acts either as a proxy to another (corporate) identity provider or as a single identity provider (without delegation of an authentication request), as shown in Figure 1.13. All role and user management activities reside in SAP Cloud Identity Access Governance with full support for business roles and the respective access provisioning service.

Quite a few organizations have already implemented SAP Access Control to connect their many systems. Even though SAP Access Control can be connected to SAP Cloud Identity Access Governance, SAP Access Control does not support user access provisioning for a large number of cloud-based solutions.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

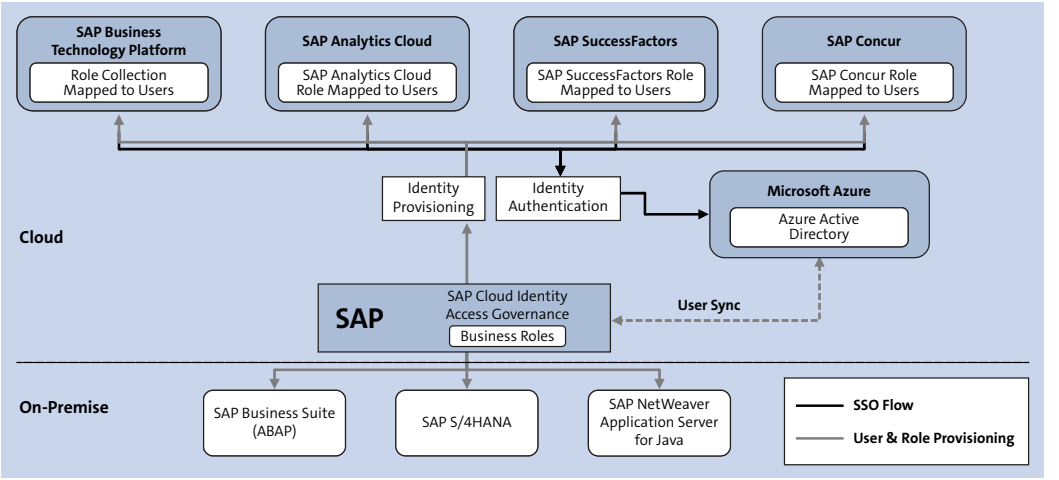


Figure 1.13 Example of a Hybrid Architecture with SAP Cloud Identity Access Governance

Essentially, you may require a shift to SAP Cloud Identity Access Governance, where user access is managed and governed centrally, to integrate all relevant solutions as a prerequisite for an effective business role concept.

The remaining challenge is determining the appropriate access rights to cloud-based solutions for each business role. Role-mining strategies become relevant to identify what is considered "appropriate" access in line with the tasks and responsibilities of a particular job function. In conclusion, establishing a robust and sustainable business role concept across the hybrid landscape depends on the effectiveness of job role design for the on-premise systems of the architecture.

1.6.4 Access Risk Analysis in Hybrid Landscapes

Failed access controls will ultimately result in potential access risks. The higher the likelihood and impact of the risk, the more attention you should pay to these risks. Thus, potential access violations may need to be detected before they occur. In a hybrid system landscape, processes typically span across multiple systems hosted in the cloud or on-premise. Therefore, access risks no longer only relate only to on-premise applications. Particularly, when a segregation of duties (SoD) must be enforced among multiple applications where two activities might conflict with each other, the respective authorizations may not be granted both to the same individual. For example, in the procure-to-pay (PTP or P2P) process, the systems involved might be SAP Ariba and SAP S/4HANA 2020 for the access risk resulting from the combination of functions **Create fictitious vendor invoice** in SAP Ariba and **Pay vendor invoice** in SAP S/4HANA. Consequently, the ruleset used for the access risk analysis must evolve to the next maturity level by considering cross-application access risks.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

SAP Cloud Identity Access Governance provides powerful capabilities for access risk analysis to enable and foster centralized compliance management. Access risks are defined in relation to a business process regardless of the technology used and consist of one or more critical access elements called *functions*, which specify what authorizations are critical. SAP Cloud Identity Access Governance is the only GRC solution connecting to most SAP Cloud software products (as of July 2021). All other solutions, including the on-premise equivalent SAP Access Control face some technical limitations and are therefore not as capable as SAP Cloud Identity and Access Governance for integrating cloud-specific access elements through functions.

If already available, an SAP Access Control instance can be integrated with SAP Cloud Identity Access Governance. In such a scenario, SAP Access Control can serve as a bridge to close the current feature gap, and thus you can benefit from the advantages of both solutions. However, before adopting changes in your risk management processes, significant differences must be taken into consideration, listed in Table 1.3.

	SAP Access Control	SAP Cloud Identity Access Governance
Hosting	On-premise	SAP Cloud (SAP BTP)
Cloud application integration	No*	Yes
Access Risk Analysis	Ad hoc/scheduled	Scheduled only
Access Risk Analysis Scope	As selected	All systems
Ruleset	Prepopulated via business configuration (BC) sets	Provided upon request

* Only SAP SuccessFactors can be integrated into SAP Access Control 12.0.

Table 1.3 Comparing SAP Access Control and SAP Cloud Identity Access Governance

Hint

See Chapter 10 for further information regarding SAP Access Control and risk analysis.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

1.7 Summary

Authorizations are not a simple and straightforward topic. This chapter has pointed out the complexity of authorizations, particularly in relation to SAP ERP systems. The evolutionary process we described has shown how the technology has changed and highlighted the important role SAP HANA has played. Security is no longer just about securing ABAP code. Other applications are now affected, with a clear trend in favor of deployment scenarios in the cloud. With the newest SAP technology, SAP BTP, you can secure access in the cloud using the cloud. To continue our journey, the next chapter starts with the basics of ABAP authorizations before moving on to best practices for managing authorizations in on-premise applications and describes the extent to which these best practices can be applied in a cloud-based environment.

In the next chapter, we'll discuss the ABAP authorization concept.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 2
ABAP Authorization Concept

Authorizations are the lowest common denominator in the SAP Business Suite authorization concept. They control what functions an end user can execute and which data records they have access to. Therefore, every security administrator must understand elementary authorization components, protection mechanisms against fraudulent actions, and related maintenance activities to build a sustainable, secure, and customized authorization concept.

In recent decades, the development and improvement of company-wide digitalization have increased enormously. An enterprise resource planning (ERP) solution is the information technology (IT) platform to cover all enterprise processes, technical requirements, and stakeholder integrations for a business within one software. Nowadays, companies of a particular size can't avoid using such software to remain competitive. Therefore, many companies try to be the first to adopt novel software features and add-ons to differentiate themselves from their competitors. Driven by this economic pressure, companies often prioritize functionality over security in their system setup and configuration. This emphasis leads to an unhealthy focus on the business, causing system security and secure technical business integration with the company's ERP software to diverge. Thus, an enterprise system might offer various targets for external and internal threats. Also, specific requirements from different stakeholders, such as supplier cooperation terms or governmental restrictions, have risen steadily. To keep pace with this rapid development of technology and business demands, an essential goal is to cover appropriate system security and data access controls. Otherwise, you might face security issues and fail to follow compliance standards.

This section explains the fundamentals of ABAP authorizations so you can gain the required knowledge to understand the functionalities of the intended tools. You'll receive information about what influences an authorization concept, about different user types, and about related SAP security considerations. Moreover, this chapter provides all the necessary theoretical and practical content on the ABAP authorizations concept, for instance, the SAP authorization processing logic; its related components like authorization objects, roles, and profiles; and the different authorization checks available. Furthermore, we'll introduce you to the specific authorization concept in SAP ERP Human Capital Management (SAP ERP HCM). Another important topic is the different transaction types and how you create and use them to fit best practices for SAP

Personal Copy for Arun Singal, arun.singal560@gmail.com

authorizations. To round out this chapter, we'll include some information about the security-related system parameters, special system settings, and best practices for your system security analysis as well.

2.1 Influences on the SAP Authorization Concept

In the economy and in your company's day-to-day business, your SAP authorization concept is continuously evolving. Whenever new employees are hired, user identifications (IDs) for each person are required in the system. Since the user ID contains the person-dependent user master record, you can use this ID to assign specific authorizations to specific end users. Suppose a new employee holds an entirely new job function. As a security administrator, you must adjust and extend your existing authorization concept to meet these new business needs. For instance, your business must define the new job's duties, activities, and program access requirements. Then, you must convert this specification into the system and authorization concept. Typically, changing business needs, functional issues through SAP upgrades, and emergencies will continue to impact your roles and user concept.

Moreover, every company must satisfy its IT system's internal and external compliance requirements and adjust end-user authorizations when those regulations change. Adherence to these restrictions is often expected by governments and other stakeholders, both customers and vendors. Thus, a security administrator's challenge is to technically convert and implement these regulations and changes as efficiently as possible.

Usually, during your day-to-day work as a security administrator, you'll face many different influences on your authorization concept that are often independent of each other. For instance, you must deal with new users and their related authorizations or job functions. Process changes and new organizational structures often lead to such considerations and subsequent maintenance as well. On the other side, periodic internal or external standards changes might also provoke additional maintenance effort. These changes could involve new governmental restrictions concerning the Sarbanes-Oxley Act, the US Food and Drug Administration (FDA), or General Data Protection Regulation (GDPR). New contract presets might be required for new suppliers or customers or even to reflect internal regulations, thus perhaps leading to regular customizing and adjustment work on your authorizations concept. Even if you have high standard compliance in your authorization concept, recurring user and role maintenance actions and periodic system upgrades will inevitably lead to recurring concept adjustments.

All these influences could have a profound impact on security. An authorizations administrator's job is to implement these restrictions or adjustments with a high-level security focus in a timely manner. Thus, this administrator must have the skills and tools to know what to focus on and how to manage these challenges.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

2.2 Basic Principles for an SAP Authorizations Concept

One of your primary goals should be achieving a regulated, consistent, and secure authorization concept. Therefore, a necessary task is to define fundamental principles and to reflect these principles in your technical system integration. Before starting with this implementation, however, understanding the main principles underlying any SAP authorization concept is necessary.

Principles are universally valid descriptions of standards that allow a transformation to specific needs. You must cover various types of IT security principles for your technical and documented authorization concept. Some important principles for achieving a transparent and regulations-compliant authorization concept include the following:

- **Identity management principle**
  Every business user master record (user ID) requires a unique connection to a natural person who owns that user identity. The user master records of individuals should be created with the SAP user type `DIALOG`. This transparent connection allows a direct link to responsibilities and ensures a clear audit trail through user-specific *change documents*. Multiple concurrent logons to the same user master record are generally not permitted. For the communication between systems, you should only provide users in the `SYSTEM` and `SERVICE` user types. The name of the responsible (real) person should be documented in the master record of these technical users.

> **Hint**
>
> You'll find detailed information about the various SAP user types in Section 2.5.

- **Least privilege principle**
  All users must have their logical system-specific authorizations with a minimum level of data and system functionality access. Hence, you must guarantee that the end users (including administrators) obtain sufficient authorizations to complete their designated tasks and job function. This authorization assignment needs the restriction to the lowest common denominator so that the users do not have more access than necessary (need-to-know). According to the Internal Control System (ICS), limitations or exceptions are permitted but must be documented regarding their internal or external requirements and enterprise-specific risks.

  Additionally, confidential data records may only be displayed, saved, changed, deleted, downloaded, or used in any way by authorized personnel. Consider continuously tracking such critical data usage.

- **Principle of critical authorizations**
  For SAP security, the term *critical authorizations* primarily refers to authorization object definitions and transaction codes or to SAP HANA database privileges that control access at a system administration level. This administration level grants

Personal Copy for Arun Singal, arun.singal560@gmail.com

access to specific activities, such as direct table maintenance or browsing, developer rights, debugging applications or databases, changing system settings, and transport administration. These rights must be restricted to a selected user group and only temporarily assigned via an emergency access management (EAM) scenario in a productive system (PRD).

Hint

For more details about SAP HANA database privileges, see Chapter 2, Section 2.2.

- **Principle of audit trails**
  The audit trails principle ensures that every business- and authorization-relevant process is documented and accessible in a written form. For instance, an audit trail may contain documentation of the maintenance processes for authorization objects, roles, users, balance- and payment-related information, and all other business processes that require demonstrability. Furthermore, this principle enables the inspection and verification of audit trails by internal and external inspection authorities. For this purpose, we recommend you initiate permanent logging and periodic monitoring of such critical actions.
- **Control principle**
  A security administrator must control the assignment of every authorization with approval processes. The documentation of approvals processes and assignments is obligatory and guarantees the ability for internal and external auditing. Therefore, your business authorization concept document must contain, for example, relevant information about user maintenance, segregation of duties (SoDs), a security control matrix for security-relevant business aspects, system settings, and/or database record access protocols. A *security control matrix* is a predefined technical rule set containing all necessary system functions and data access in written and technical form. Only this extensive matrix allows accurate and meaningful internal and external audits. Besides mandatory external audits, also internal audits are highly recommended.

Besides these essential principles, with which you should base your own authorization concept, some further principles you should also consider as best practices in system security include the following:

- **Job function principle**
  Every SAP user is assigned to one or multiple predefined specific job function(s) with explicit tasks within the organization. Therefore, whether a real job description exists is irrelevant because many job tasks summarize specific job-related functions in an organizational structure.
- **"Four-eyes" principle**
  At least two persons should control critical or important business data activities.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **SoD principle**
  This principle type, an enhancement of the "four-eyes" principle, describes the separation of authorizations and tasks within one process on various users. This principle enables process control and reduces the likelihood of overauthorization.
- **Approval principle**
  The direct and indirect assignment of every authorization needs an approval process. This process could involve indirect approval through a job function affiliation or could involve a direct approval process, as in the case of an individual authorization assignment.
- **Standard principle**
  Standard compliance is essential for user and role maintenance, system upgrades, and your entire authorization concept. This principle is the basis for technical and processing regulations and compliance.
- **Written form principle**
  Written information about the business processes and authorization concept should also be created and approved. This documentation should also include all third-party tools in use to enable a clear understanding of the system's security framework.

Hint

Building up a complex and extensive SAP security concept aligned with business processes, regulations, and mitigations is necessary according to these various principles. Besides technical integration and the establishment of an authorization concept, you must also cover topics like your SAP system settings, architecture, developer guidelines, ISO norms, business restrictions, or other internal IT concepts and preconditions in your written concept. As mentioned earlier, the written form principle is required for an internal and external revision.

2.3 ABAP Authorizations

Authorizations are the technical components that provide the framework for determining the extent to which an end user can access data, system resources, and functionalities. An authorization is the smallest unit of your authorization structure. Within your authorization concept, one of the most important principles to follow is to only grant access to information and data that an end user requires for their specific daily tasks (according to the least privilege principle). You must thus allocate and adjust various authorizations differently to meet these requirements.

SAP authorizations are necessary to execute and use various applications and functionalities in SAP's ERP business suites. These core elements within SAP security are

Personal Copy for Arun Singal, arun.singal560@gmail.com

based on the source code of the targeted program. In almost every SAP standard ABAP program, `AUTHORITY-CHECK` statements secure data access and access to an application's possible functions. The outcome of this specific check statement determines whether an end user can execute a specific business action. Thus, the system checks the end user's authorizations during the different executions to determine whether that user has the required authorization to pass these checks. In this way, authorizations restrict access to data records and restrict access to the functions and programs in your ERP system landscape.

2.3.1 Components

The focus of authorizations is to protect business processes through security-based parameters. Business processes often contain more than one parameter, like analyzing and ordering new inventory, or represent rudimentary actions like create, change, and delete. Therefore, you'll also need your various independent authorization components to be flexible in your authorization assignment. Furthermore, to verify different access points for each end user, you'll also need various authorization components. SAP provides different authorization classes, objects, fields, and values to enable flexibility.

Figure 2.1 shows the big picture, focusing on the interaction and relationship between various authorization components. Whereas *authorization* is the generic term that enables system usage, this term also contains more specific subgroups. An authorization consists of one or more *authorization objects* and is merged into an *authorization profile*, also called a *role profile*. As shown in Figure 2.1, on the left, notice that every authorization object belongs to an *authorization object class*, which contains the authorization fields and values of SAP Standard. The authorization profile exists as a required system entity generated through your *role* maintenance and role profile generation. The role itself is a container for authorizations and must be assigned to an end user so they can access specific system functions.

The following sections cover the different authorization components in detail, starting from the authorization object class down to the smallest element, the authorization value.

Authorization Object Classes

The top-level container for authorization objects is the authorization class, which is a logical collection of objects with the same module-based relation or affiliation. Figure 2.2 shows some examples. For instance, all authorization objects required for sales activities are typically subordinated to the **Sales and Distribution** (**SD**) authorization class.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

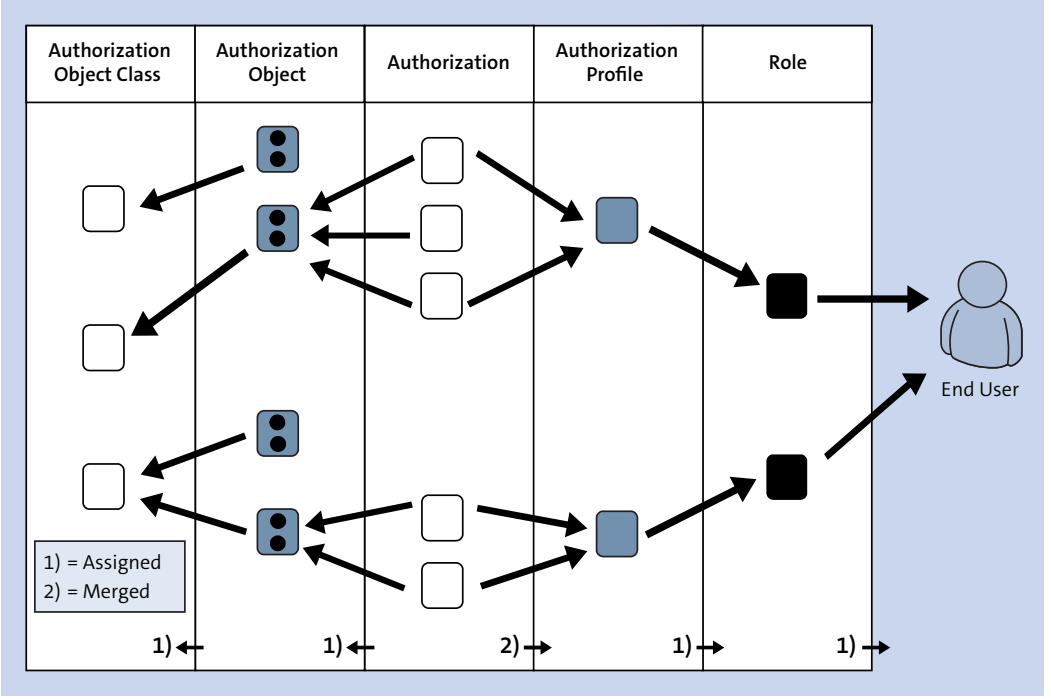


Figure 2.1 Authorization Components and Their Relationships and Assignments

Maintained	Materials Management: Inventory Management/Phys.Inventory	MM_B
Maintained	Materials Management: Purchasing	MM_E
Maintained	Materials Management: Master Data	MM_G
Maintained	Plant Maintenance	PM
Maintained	Production Planning	PP
Maintained	Project System	PS
Maintained	Public Sector Management - Cloud	PSMC
Maintained	Quality Management	QA
Maintained	Sales and Distribution	SD

Figure 2.2 Examples of Authorization Classes

Hint

Use Transaction SU03 to check all the authorization classes and their objects available within your SAP Business Suite.

Authorization Objects

The authorization object consists of at least one but a maximum of ten authorization fields with maintainable authorization values. SAP Standard authorization objects belong to an authorization class and cover the relevant system and data permissions. Thus, these objects are used to protect and limit access to specific applications with

Personal Copy for Arun Singal, arun.singal560@gmail.com

their related functions. These core elements of an authorization concept are each critical on their own and in combination with others. Authorization objects, with their authorization fields and values, are assigned to end users by roles through a role profile (see Section 2.4 for more information on roles and profiles). Some examples of authorization objects in the authorization object class **Sales and Distribution (SD)** are shown in Figure 2.3.

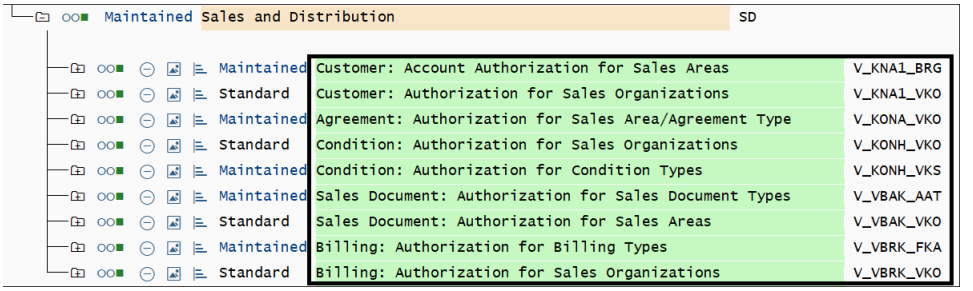


Figure 2.3 Examples of Authorization Objects

Please note that an authorization object might have more than one authorization instance. By default, these object instances start with **T-*** in their role profile names. These instances determine various functional scopes provided through the same authorization object but using different authorization field values, as shown in Figure 2.4. To see all authorization objects available in your SAP system, you can launch Transaction SU21.

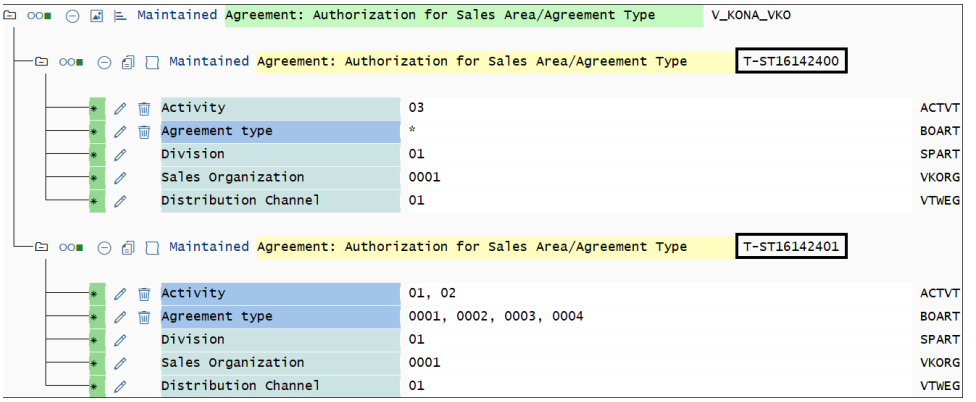


Figure 2.4 Different Authorization Object Instances

Hint

For more information about critical authorizations and SoD, see the following sections:

- Chapter 10, Section 10.3
- Chapter 10, Section 10.4

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Authorization Fields

Authorization fields and their values translate a business process's exact parameters into the technical language of an SAP system. These fields are the lowest-level entities you can maintain to separate and distinguish access to system data, as shown in Figure 2.5.

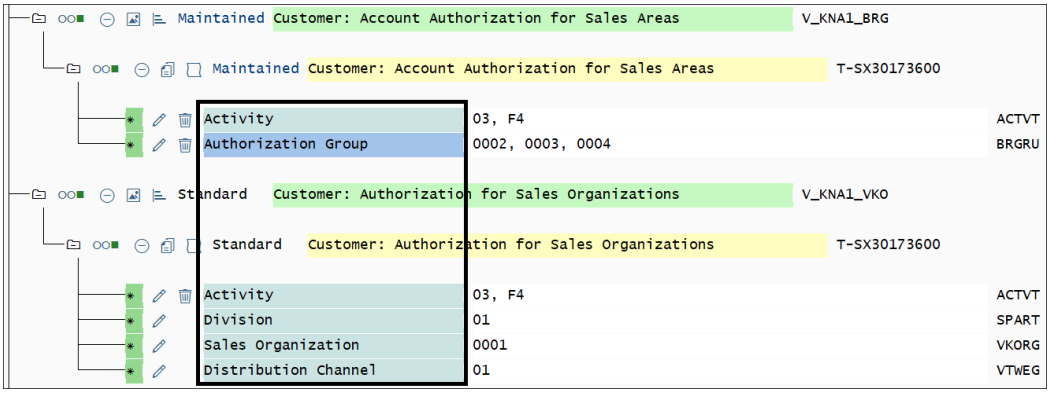


Figure 2.5 Examples of Authorization Fields

Hint

Check table TOBJ for a list of all available authorization objects with their related fields.

Authorization Values

You can fill in authorization fields with various authorization values, which describe the characteristics of an authorization field, as shown in Figure 2.6. Thus, authorization field values for authorization objects control what actions an end user can perform in a related business process. Please not-e that the values can be a maximum of 40 digits long. Furthermore, only the 2 special characters, an asterisk (*) and double quotation marks ("), grant access in the SAP standard. You can maintain nearly every special character, if usable in the SAP system and the referring programs' source code. Usually, the authorization values are numbers (**0002**), letter sequences, or a combination of the two (**F4**).

Cumulative Processing Logic

Note that SAP authorizations use a cumulative processing logic. This logic is the opposite of an additive approach, which means that every authorization object instance stands for itself with its different authorization fields and their values. Thus, each instance provides for a specific access or function.

Personal Copy for Arun Singal, arun.singal560@gmail.com

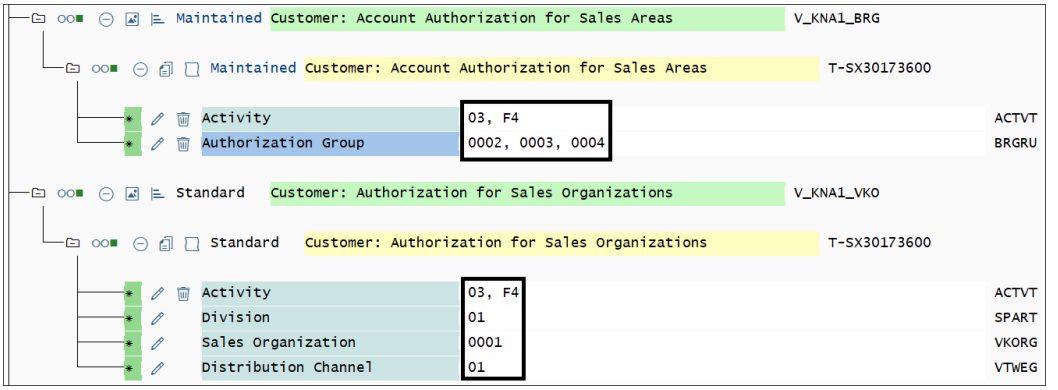


Figure 2.6 Examples of Authorization Values

Suppose you have an authorization object with two instances, as shown earlier in Figure 2.4. The related assigned role with its generated role profile would grant access to the following two levels:

- Instance **T-ST16142400**: Display (**03**) access to all (*) sales agreement types for the underlined organizational values (**division**, **sales organization**, **distribution channel**)
- Instance **T-ST16142401**: Create (**01**) and change (**02**) access only to the agreement types **0001**, **0002**, **0003**, and **0004** with the related organizational values

In this example, the salesperson does have extensive view access and can only maintain specific agreement types for certain target organizational structures. No overlapping of both instances exists within the role, but each instance provides for specific access.

2.3.2 Authorization Default Values

Generally, in almost every SAP standard program, authority checks are included in the source code. Thus, end users will require the relevant authorization objects, fields, and values to execute programs. End-user authorizations must satisfy various authorization checks for program start, for specific features, and for program execution within an application. Otherwise, the kernel, which compares a program's authority checks in the ABAP program code with its own maintained end-user authorizations (user buffer), blocks or allows the desired executions. To provide the correct collection of necessary authorization objects and their values, SAP provides default values for most role menu objects like transactions, function modules, or Web Services. These proposals are essential for further role and authorization maintenance to provide your users targeted access by default. You can also adjust these default data values to meet your specific requirements. If you do not use the proposals, you cannot guarantee a secure, sustainable, and maintainable authorization concept.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The default values of standard SAP programs are maintained and delivered by SAP through tables USOBT and USOBX, which are accessible through Transaction SU22. For adjustments, you should only work with Transaction SU24 and the related tables USOBT_C and USOBX_C.

Hint

You must understand the impact and necessity of authorization default values for sustainable and secure authorization maintenance. Therefore, we recommend reading Chapter 5 for all the required information.

2.3.3 Code-Based Namespaces

SAP provides a fixed namespace for its various development and system objects (SAP code) and non-SAP-related objects. This indication is necessary to differentiate the relationship of items like applications, tables, and authorization objects according to items from SAP, from its customers, or from its partners. Within an SAP system, three namespaces for authorizations and role menu objects are available:

- SAP code: Starting with letters from "A" to "W"
- Partner code: Starting with "/" (registered at SAP)
- Customer code: Starting with "Z" or "Y"

Suppose you want to create some custom authorization objects. In this case, you must start the names of your objects with a "Z" or "Y" or your partner code if your company is a registered partner. In addition, you must use a customer-specific naming convention within your custom namespace to differentiate the ownership of your various components.

Hint

For detailed information about namespace prefixes and related issue fixes, refer to the following SAP Notes:

- SAP Note 20643: Naming Conventions for Authorizations
- SAP Note 395083: FAQ: Namespace for Authorizations and Auth. Objects, Fields, and Profiles
- SAP Note 16466: Customer Name Range for SAP Objects
- SAP Note 84282: Development Namespaces for Customers and Partners

Check the reference documents for further suggestions too.

Personal Copy for Arun Singal, arun.singal560@gmail.com

2.3.4 Creating Custom Authorizations

Suppose you want to implement custom developments on your system. In this case, not only must you guarantee proper authority checks within your custom code—you might also need custom authorization objects, fields, and values in addition to the standard. Otherwise, you may not securely cover a program's usage, external and internal security policies, or the principles that underly a secure and sustainable authorization concept.

Before you start creating your required custom authorizations, you'll need the required authorization values for the authorization object S_DEVELOP, as restricted for packages and objects with Z* or Y* in SAP S/4HANA. In SAP ERP 6.0, you will also need an additional SSCR developer key. Furthermore, you'll require an object directory package. This section outlines the process of creating custom authorization objects and fields.

Hint

For details on why the SSCR license key procedure is no longer supported in SAP S/4HANA, please refer to SAP Note 2309060.

Custom Authorization Objects

To create a custom authorization object, you must assign the object to a custom authorization class. A fixed technical connection thus exists between these two components.

In Transaction SU21, you can create a new authorization object class from scratch, as shown in Figure 2.7., but you can also use an existing custom class.

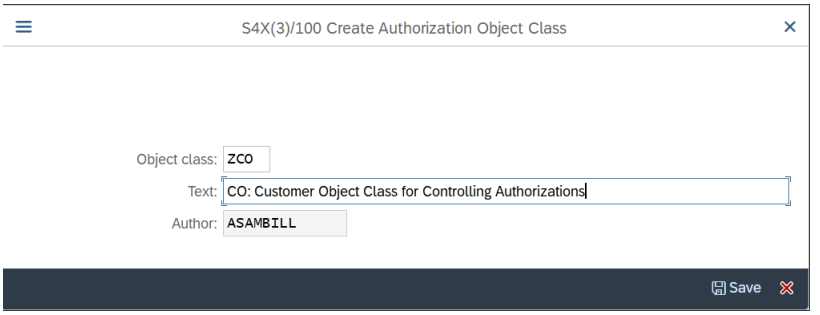


Figure 2.7 Creating a Custom Object Class

After creating a custom authorization class, you can create a custom authorization object and maintain the required authorization fields, as shown in Figure 2.8. For instance, you can define a custom authorization object for a cost center with an activity (**ACTVT**) and a cost center (**KOSTL**) field.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

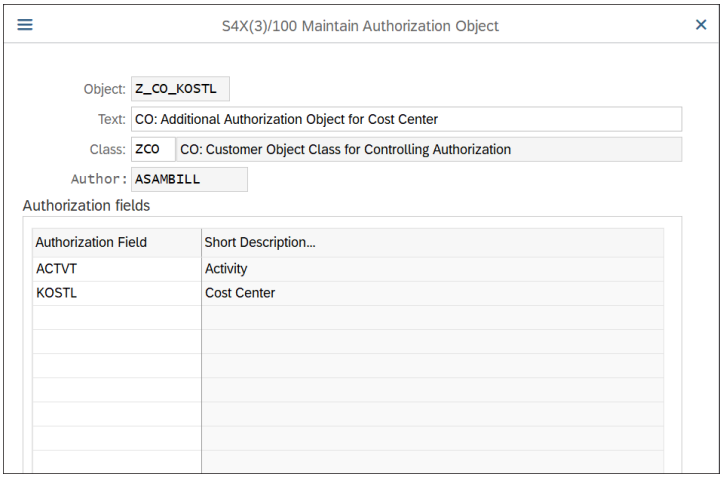


Figure 2.8 Creating a Custom Authorization Object

Afterward, you must restrict the permissible activities, as shown in Figure 2.9. In this way, you can restrict the ability to maintain values, which administrators can maintain in an end-user role. However, be aware that you must enable all the activities that are necessary for all the custom development's functionality by clicking the **Permitted Activities** button. Thus, before creating a custom authorization object, you should clarify with your developers which `AUTHORITY-CHECK` statements exist in the application source code or debug it yourself. Based on this information, you and/or your developers must create the related custom authorization objects.

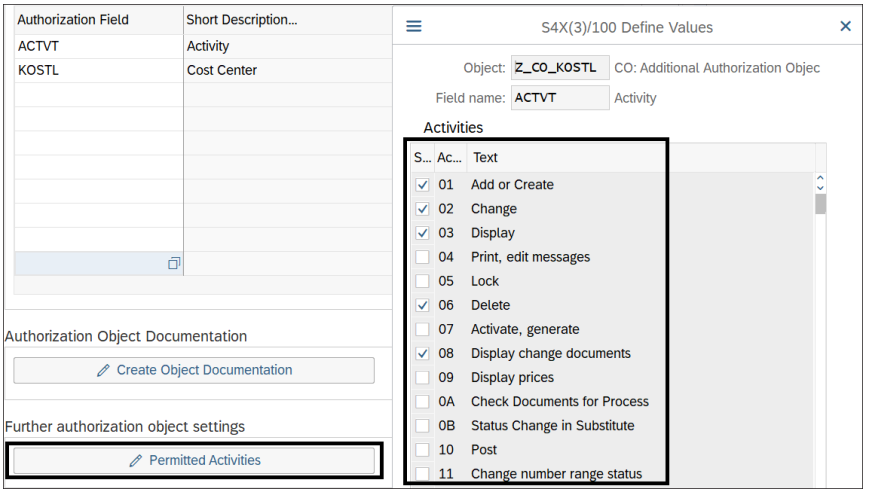


Figure 2.9 Maintaining the Permitted Activities for the Custom Object

Then, you should maintain the proposal values for the targeted application in Transaction SU24. Please note that you should not maintain the proposal values in the same

Personal Copy for Arun Singal, arun.singal560@gmail.com

way as how you maintained the possible restrictions in Transaction SU21. Thus, you do not have to include all permissible values (e.g., ACTVT) in Transaction SU24. What you maintain in Transaction SU24 depends on your business processes and restrictions. If you maintain the intended proposals and integrate the custom application in the role menu, all maintained proposals are automatically pulled into the authorization profile, if the **Automatic Profile Merge** option is active on your system (see Chapter 6 for more details). Before generating the role profile, you must maintain any open authorization fields and generate the role profile. All end users with this assigned role can now pass the custom authority checks based on this custom authorization object.

Generally, your program developers are responsible for creating and maintaining the required authorization objects, including their fields and values.

Hint

A crucial task is to document your custom authorization objects for internal and external work and revisions. For this goal, click the **Create Object Documentation** button shown earlier in Figure 2.9.

Custom Authorization Fields

To create additional custom authorization fields, launch the Transaction SU20. Then, click on the **Create** button for the **Authorization Fld** field in the header bar. Enter a name for the custom authorization field (starting with "Z" or "Y") and enter a related data element in the **Data Element** field, as shown in Figure 2.10.

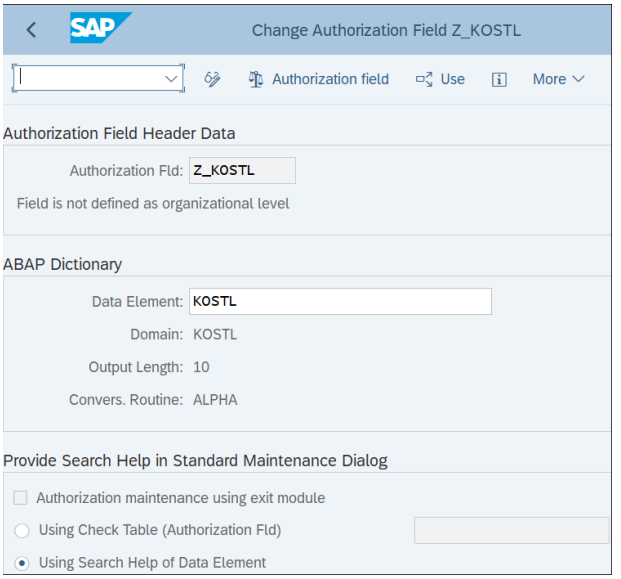


Figure 2.10 Creating Custom Authorization Field

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

You should use your custom data elements, which a developer can create. Then, complete these settings by choosing the referring developer package and workbench request.

Hint

In addition to all other authorization objects and fields, customer-specific objects and their fields are also contained in the SAP standard table TOBJ.

2.3.5 Creating Custom Organizational Levels

In some cases, you might need to promote authorization fields to organization levels (sometimes also called orgfields). The main reason to promote a field to an organization level is to decrease the effort required to maintain and administer roles across your organizational structure or if required for the integration of custom development requirements. Within an ABAP system, you can promote a non-organizational authorization field to an organizational field.

In general, SAP standard organization levels will be sufficient for your role maintenance. Many authorization fields are, however, not appropriate for organizational usage. Do not use this strategy if you cannot uniquely map an authorization field to an organizational level. Doing so can negatively impact other authorization objects with the same field, but which are not restricted in the same organizational manner. All the authorization values of the promoted field within the same role will get the same value regardless of the authorization object. Thus, you can only use a promoted field if it wholly fits the business requirement of the job function role. For example, in production planning, you'll often deal with authorization field AUTYP (order type). Promoting this field to an organization level would negatively affect your role concept because you usually maintain the activity level for order types individually. Thus, if the order type is an organizational field, you could not distinguish among order types anymore. Furthermore, please note that promotion is client independent and required on each system where you want to use the promoted orgfield, for instance, the development system (DEV), the quality system (QAS), or the PRD.

In conclusion, besides the promotion effort, irreparable issues can arise that will affect your authorization concept's security. Thus, you should think twice about authorization fields being raised to an organizational-related entity. Once you promote an authorization field to an organization level, you cannot revert this change quickly or easily.

With Basis version release 7.50 support package (SP) 9, you can use Transaction SUPO to promote authorization fields to customer-specific organizational levels.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

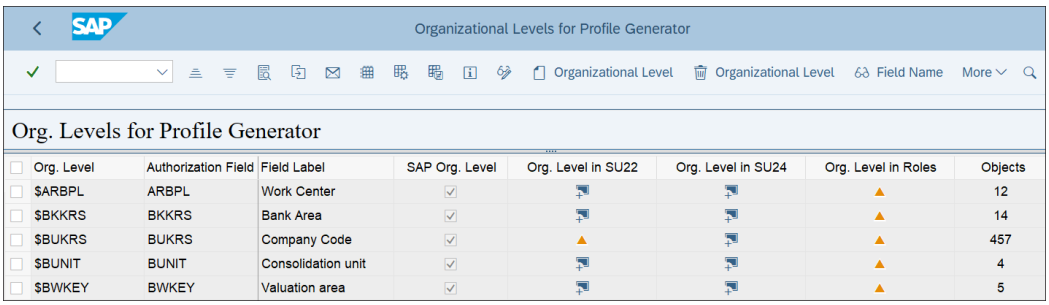
Please note that former reports for the organizational promotion (like reports PFCG_ORGFIELD_CREATE, PFCG_ORGFIELD_UPGRADE, or PFCG_ORGFIELD_DELETE) are obsolete with Basis version release 7.50 SP 9. SAP Notes 727536 and 2535602 provide additional information about Transaction SUPO and what you must consider when working with this tool.

The following sections introduce you to Transaction SUPO and show you how to promote individual authorization fields to organization levels.

Overview in Transaction SUPO

When you launch Transaction SUPO, you'll see an overview of all available organizational fields in SAP standard, as well as your customer-specific ones. These organizational fields should only be centrally maintained within a role in Transaction PFCG and within not each authorization object. Moreover, you can see where an organizational level is in use. As shown in Figure 2.11, the following information is available for each authorization field:

- The **SAP Org. Level** checkbox shows whether the field exists in its original organization level or a customer organization level.
- SAP Standard applications through Transaction SU22 data (**Org. Level in SU22**)
- All applications (SAP and customer-specific) through Transaction SU24 data (**Org. Level in SU24**)
- Roles that contain the organizational level (**Org. Level in Roles**)
- Authorization objects that use the organizational level field (**Objects**)



Org. Level	Authorization Field	Field Label	SAP Org. Level	Org. Level in SU22	Org. Level in SU24	Org. Level in Roles	Objects
$ARBPL	ARBPL	Work Center	☑			▲	12
$BKKRS	BKKRS	Bank Area	☑			▲	14
$BUKRS	BUKRS	Company Code	☑	▲		▲	457
$BUNIT	BUNIT	Consolidation unit	☑			▲	4
$BWKEY	BWKEY	Valuation area	☑			▲	5

Figure 2.11 Initial Screen of Transaction SUPO

By double-clicking on various fields, you can access details about the selected authorization field, including specific applications or roles that contain this organization field.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Promotion of an Authorization Field

To promote an authorization field, you must activate change mode first. Then, you'll see the create and delete buttons. As shown in Figure 2.11. for instance, suppose you want to promote the authorization field **RESPAREA**. The responsibility area is a known candidate for this promotion because you can distinguish between cost center and profit center access scenarios without using value roles for this differentiation. Therefore, click the **Create** button. Then, enter the target authorization field in an empty field in the **Authorization Field** column. Save these settings with a transport request. Figure 2.12 shows the authorization field **RESPAREA** to the promoted organization level **$RESPAREA**.

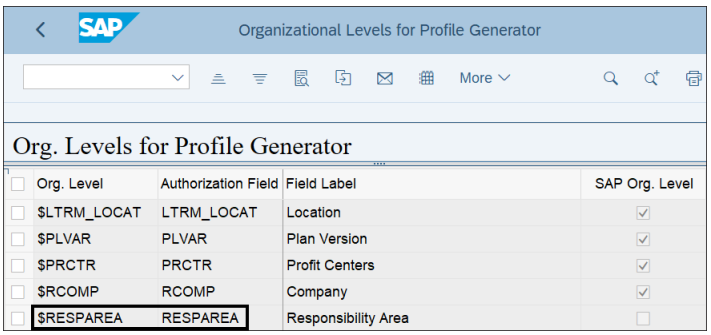


Figure 2.12 Promoting a Custom Authorization Field

Hint

Please note that you cannot maintain proposals for promoted authorization fields in Transaction SU24 anymore.

After promotion, you must update the roles containing this authorization field, which now exists in organization level **$RESPAREA**. Before updating your roles, you must introduce the new organizational field into your authorization default values setting of Transaction SU24. Therefore, click on the target icon in the **Org. Level in SU24** column, as shown earlier in Figure 2.11. In the new window, synchronize all required authorization objects to implement your new organization level as an organizational authorization field in your proposal data. The authorization field **RESPAREA** might exist in various roles (e.g., for controlling) through applications with authorization objects like K_CCA, K_PCA, or K_ORDER. If you do not update the authorization profile, existing roles still contain the newly promoted organization level as a standard authorization field. Thus, you must update the roles because you only adjusted the global organization level setting with Transaction SUPO, which does not include an automatic update

Personal Copy for Arun Singal, arun.singal560@gmail.com

on the role level. Therefore, click on the field value of the **Org. Level in Roles** column of the promoted field in Transaction SUPO to see the affected roles (with the red icon). Select the target roles and synchronize them with the promoted organization level. This synchronization introduces your new organizational field into the roles.

Hint

In the role synchronization window, notice an additional column labeled **Values**. The yellow icon indicates that you must migrate already maintained values as organization level values in the role manually. In contrast, the green icon indicates that the system merged the existing values as central values for the specific organizational field with your synchronization.

Afterward, maintain each affected roles' authorization profile by double-clicking on the intended role name. The system navigates you to the target authorization profile in change mode. Now, maintain this new organizational value centrally by promoting each authorization field individually. Please note that this approach only works if you have maintained your roles with default values. Moreover, test and validate the impact of these changes on your current roles and your current authorization concept before using the newly promoted organizational level in production.

Transaction SUPO is a helpful tool for promoting any authorization field to an organizational field. This approach simplifies the authorization management process and the introduction of custom developments and related custom authorizations. However, you should be aware of the potential risks and impact on your system, primarily through the promotion of SAP standard authorization fields. Please note that a promotion should only be performed as a major change request with all related analyses and approvals conducted first. We recommend you promote authorization fields during a new implementation, not on an already functional landscape.

Technically removing a promoted organizational level in Transaction SUPO is not that easy. You cannot delete this organization level any longer since it exists in table AGR_1252. Put simply, you must perform all promotion activities in reverse order. Please note that we highly recommend this approach for removing custom organization levels because otherwise you could irreversibly ruin your roles. Thus, you must first desynchronize all affected roles and then maintain and generate the role profile again. Also, you'll need to desynchronize the proposal data for the intended authorization objects. Afterward, you can delete the custom organization level.

According to this cumbersome process, you should think twice before promoting organization levels if not required.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

2.4 Roles and Profiles

Roles and profiles are the central components for allocating authorizations to end users in SAP Business Suite on the application server layer. These items contain authorizations for executing applications, accessing data records, and working in the system. Security administrators are typically responsible for their maintenance. You should manage the entire SAP authorization allocation to end users with roles, and their profiles as shells for authorizations.

The application of the authorization concept and the maintenance of end-user rights are made manifest through roles and profiles, which enable you to authorize an end user for targeted actions and data access. We'll discuss roles and profiles in the following sections.

2.4.1 Roles

In SAP, roles are technical containers for authorization data definition and maintenance. Formerly called *activity groups*, roles are the precursor and replacement of manual profiles previously built via Transaction SU02. Typically, a role contains at least one authorization object. However, a role can also not contain a single authorization object to serve as an empty technical body (e.g., for the Java stack's authorization allocation within a dual-stack SAP system or for SAP Help Portal functions). Please note that this approach is typically rare.

An SAP system does not directly analyze the authorizations within a role. Instead, the system receives authorization information from the related role profile. Therefore, a role and its profile exist in a 1:1 relationship. You may see a role that seems to have more than one role profile. However, these additional profiles are only subprofiles of the leading role profile.

Hint

The main profile name consists of 10 digits, whereas a subprofile has 12. Profile splitting can occur when a single profile has reached the limit of 150 authorization objects. Then, the system generates subprofiles automatically. The counter in the subprofile starts with the 11th and 12th profile digits from 00 up to 99. The first 10 digits remain consistent with the main profile. Thus, the end user might have one main profile and *n* subprofiles for one single role. See SAP Notes 2293683 and 410993 for further information on this topic.

The central role maintenance application is the profile generator: Transaction PFCG. Table 2.1 describes the essential components of a single role, which you can also see in the profile generator.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Component	Description	Benefit
Role menu	Contains all menu objects like transactions, function modules, Web Dynpro applications, or OData services.	You can access an overview of your role content and automatically use SAP's default authorization values.
Role authorizations	Shows privileges and access to business data and functions.	You can differentiate and maintain the authorizations for each role and job function separately.
Role users	A role can be assigned to end users to provide system authorizations.	An end user cannot do anything on the system until you assign them a role with the right authorizations. Use Transaction SUIM (User Information System) for a list of all user assignments.

Table 2.1 Essential Components for a Role

Two main types of roles exist—single roles and composite roles. Both have their place but will result in different effects on your authorization concept. They are distinguished by their technical and conceptual approach. For comprehensive information about roles and their conception, refer to Chapter 3 and Chapter 6.

A *single role* is the primary role within a best practice role concept. This role contains all applications like transactions, function modules, or OData services via the role menu, as shown in Figure 2.13. This menu maintenance enables you to automatically introduce the default authorization values for the intended application via the role's **Authorizations** tab in Transaction PFCG.

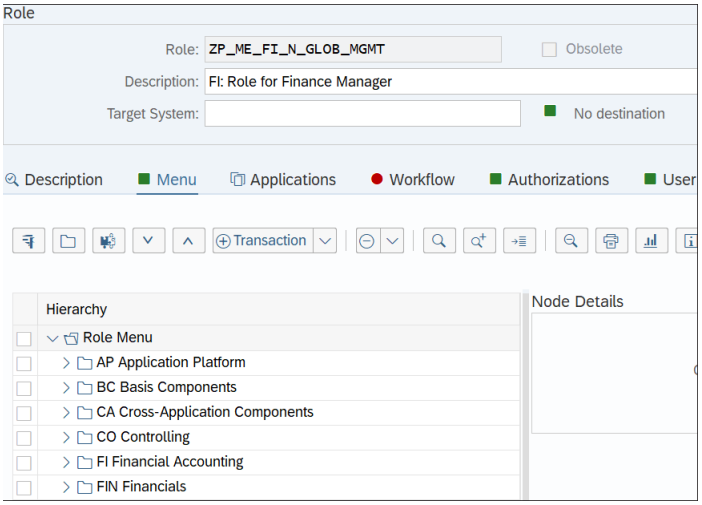


Figure 2.13 Single Role Menu Tab in Transaction PFCG

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

You can use role inheritance or another equivalent differentiation option to restrict access to an organizational hierarchy. In this methodology, you would copy individual "master" roles to serve as functional templates and then derive organizationally distinct derived single roles. In this process, you can separately maintain various organization level fields in the derived roles but still use the template role's entire functional extent. Thus, a derived role, in terms of its technical nature, is still a single role.

Composite roles are collections of single roles and are used to indirectly assign multiple single roles via a single composite role assignment, as shown in Figure 2.14. A composite role must contain at least one single role to be usable. The role menu of composite roles is not maintainable, except through menus the single roles that make up the composite role. Composite roles are only containers for single roles to improve the organization of your role structure.

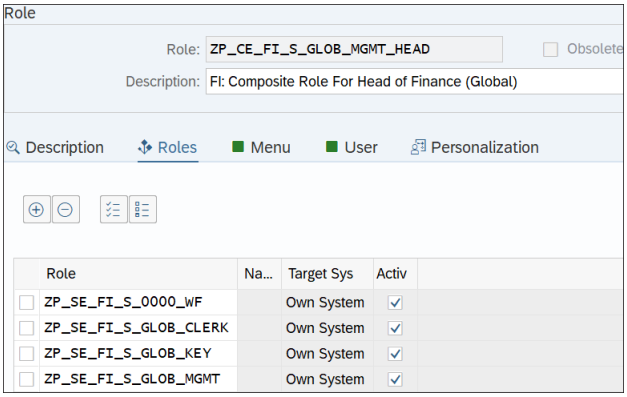


Figure 2.14 Composite Role in Transaction PFCG

2.4.2 Profiles

Profiles existed long before roles. Before SAP R/3, manual profiles were key elements for authorizing users to access SAP systems. Nowadays, after introducing roles for allocating authorizations, a profile is only a technical remainder required by the system, and even assigning profiles manually is still possible.

Think of a profile like a UPC or EAN code common on food labels. All the necessary information—in this case, authorization data—is converted from a maintainable, human-readable form for administrators via Transaction PFCG to a technical structure (role profile) for the kernel to read. This role entity is a prerequisite for the SAP system to quickly read and understand the countless constellations of authorizations that generally exist in a system.

Two profile types exist—role profiles and manual profiles. Manual profiles vary between single profiles (e.g., S_A.SYSTEM) and composite profiles (e.g., SAP_ALL).

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Since Basis version release 7.50, the limit of 312 profiles per user master record no longer exists. For more information regarding profile limits, see SAP Note 410993.

Role Profiles

If you generate the authorization profile for a role, the system automatically creates a related role profile that contains its actual authorization objects and their value characteristics. Every time you change a role's authorizations, you must generate the role profile to include your adjustments. A single profile is limited to 150 authorization objects. If a role reaches that limit, the system automatically generates multiple subprofiles for the same role to cover this surplus. You'll see the generated profile under the **Authorizations** tab for the role in Transaction PFCG, shown in Figure 2.15.

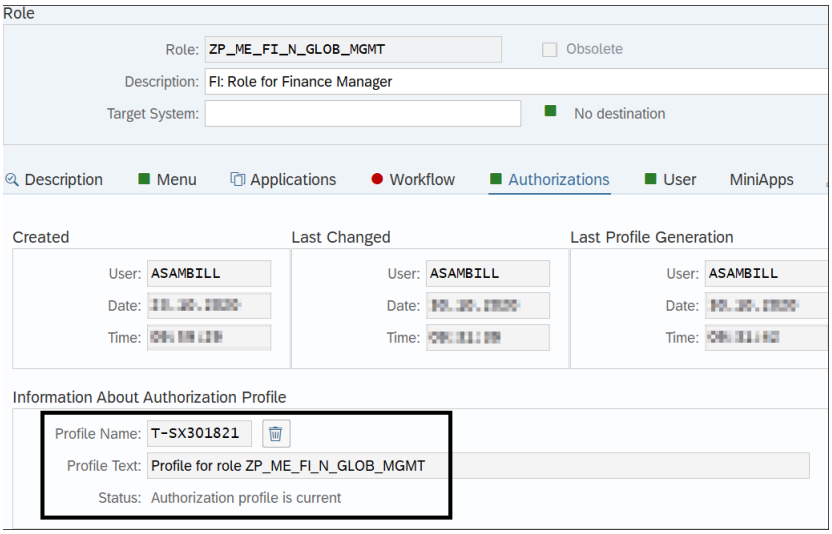


Figure 2.15 Generated Role Profile in Transaction PFCG

For the sake of comprehension, you must understand what authorization profiles and role profiles are. Their differences are actually quite small. An authorization profile is the entirety of all authorizations within one role but can also exist as an independent manual profile. A role profile (generally distinguished between main role profiles and subprofiles) is a generated authorization profile with a one-to-one relationship to its role. A role profile is necessary so that the system can validate all authorization characteristics within a role. Since you should not work with manual profiles and since activity groups are obsolete, an authorization profile is a kind of role profile. Whereas

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

authorization profiles (the included authorizations) are maintainable through transaction PFCG, role profiles are not. The system automatically generates the role profile(s) of the correlating role based on the maintained authorization profile. The role profile is only the technical container required by the SAP system for further authorization processing of end-users.

Hint

Typically, customer profiles start with **T-*** and are generated by the system, as shown in Figure 2.15. You should avoid changing this name or working with custom role profile names, which will require maintenance. Changing this setting would result in high levels of additional maintenance effort required during role creation.

Manual Profiles

Manual profiles were created in Transaction SUO2 before SAP introduced Transaction PFCG to combine different authorizations. This profile type was the way you authorized people in the past, before SAP R/3. With the introduction of roles, manual profiles are generally no longer used to authorize end users. In contrast to generated role profiles via Transaction PFCG, manual profiles do not have an application connection through a where-used list. Furthermore, you always must manually update manual profiles after an SAP upgrade release to fit the new system's authorization requirements. Thus, you must adjust the system and your business needs for new functions on your own and cannot use the automatic proposal mechanism. Besides the high maintenance effort required with using manual profiles, they typically result in overauthorizations and unwanted critical permissions.

In a nutshell, SAP Best Practices no longer recommend using manual profiles to authorize end users.

Common Standard Profiles

An SAP system also contains common standard profiles, often created through an SAP system installation or after release upgrades. You can also update these profiles yourself. They grant extensive and often critical access to the system, and therefore, they are often in the scope of auditors.

Such standard profiles are also manual profiles. For instance, profiles like SAP_ALL, SAP_NEW, S_A.SYSTEM, or S_A.DEVELOP exist on SAP systems. The SAP_ALL profile contains almost all system and business authorizations and thus is the most powerful authorization for an SAP system. You can regenerate your system-specific SAP_ALL profile via Transaction SU21. Table 2.2 summarizes some common standard profiles.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Common Standard Profile	Short Description
SAP_ALL	Contains almost all SAP system authorizations and grants access to all data, system configurations, component maintenance, customizing, and operations.
SAP_NEW	Contains all new authorizations through Basis version release 7.31. Only use this profile after upgrades if you need to test new applications or features. Regarding later releases, the role SAP_NEW replaces the profile SAP_NEW (SAP Note 2227969).
S_A.SYSTEM	Contains all Basis authorizations for the system, user, and role maintenance.
S_A.DEVELOP	Contains developer authorizations for full system access.

Table 2.2 Common Standard Profiles in SAP

Hint

To sum up, a best practice for profiles is to never use manual profiles to authorize end users, especially in a PRD. First, the maintenance effort is enormously high because you must manually adjust every change after a system upgrade release. Also, you cannot set validity dates for profiles to end users, as you can with roles. Moreover, these profiles provide hard-to-control authorizations with nearly no traceability for administration and auditing. Therefore, especially due to the manual composite profile SAP_ALL, you should avoid assigning manual profiles to end users in your system.

You should only work with a role-based authorization concept—more precisely, a job function role model. For detailed information regarding creating a sustainable role concept, refer to Chapter 3.

SAP Notes 2548064 and 1711620 also contain information about the common standard profiles SAP_ALL and SAP_NEW.

2.5 Users

Users are typically people who have access to an SAP system through a user-specific user type (`DIALOG`) or a user-unspecific user type (`SERVICE`). A user ID contains all related user master data like detailed user information and authorization roles as well as their profiles. The end users receive their authorizations through the authorization profiles. This profile is a technical entity that comes from the assigned end user role and its generated role profile (authorization profile). It might also be possible that an end user's authorizations come through a direct manual profile assignment rather than indirectly from a role. With those entities, these end users can execute applications and do their jobs within the SAP system landscape.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

This chapter only provides a first look at users in SAP systems and their maintenance. You can find more extensive information on this topic in Chapter 9.

2.5.1 User Master Record

The roles in a user master record provide authorizations that allow an end user to perform operations (e.g., to view, update, or delete relevant data in an SAP system). In SAP NetWeaver Application Server (SAP NetWeaver AS) ABAP, you generally have a positive authorization concept approach, except, for instance, with SAP ERP HCM. Thus, a security administrator must explicitly specify which functions an end user can execute and what data they can access through role and profile assignments.

Besides authorizations (roles and profiles), a user master record includes the following information as well:

- User credentials with validity, locking status, and authentication characteristics
- Information about the natural person like a name, department, function, responsibilities, user group, user type, and SAP license type
- Personalized settings like parameters, spools, or time and date information

Hint

A user master record is client dependent, and therefore, you must create user IDs in every system client where they are required. Table USR02 contains all related user information.

Please note that a user ID can be a maximum of 12 digits long and should not contain special characters. Using non-Latin letters might lead to unintentional processing issues for specific SAP solutions and third-party tools that are not oriented for the use of special characters in their source code.

A user master record is highly important for compliance with regulations and for the security of your system landscape. The handling of this sensitive data varies (e.g., from country to country, branch to branch, and also according to external and internal regulations). In general, a user master is confidential because it contains person-specific information. Different regulations require different retention periods. For instance, financial documents with person-specific data typically are stored for 10 years in Germany (in accordance with HGB). In contrast, the GDPR states that you must delete all data if this person no longer interacts with your company's environment. Thus, you

Personal Copy for Arun Singal, arun.singal560@gmail.com

must always consider country-specific regulations and other obligations made by local government.

Hint

You can find more information about the retention and deletion of user data in SAP Note 550718. Keep in mind that, when you delete a user ID, application data and change documents still exist for records that the end user in question has generated or edited.

2.5.2 User Buffer

The *user buffer* is a temporary container of all assigned authorization objects, fields, and values of an end user. The system fills in this buffer when a real user logs on to the system. Until the end user logs out or restarts the SAP Easy Access menu through a new session, the same user buffer is active. This buffer is necessary for faster system calculations, movements, and actions. Otherwise, the kernel would always analyze each assigned authorization for each program step every time another system action is performed. Using this buffer, the system can directly analyze and match all existing end-user authorizations. Thus, end users can pass authority checks of many programs seamlessly if they have the required authorizations.

As a security administrator, you can view the user buffer via Transaction SU56 to check your own user buffer or the buffers of other users, as shown in Figure 2.16. This transaction is also beneficial for checking specific end-user authorizations without needing to check all assigned roles.

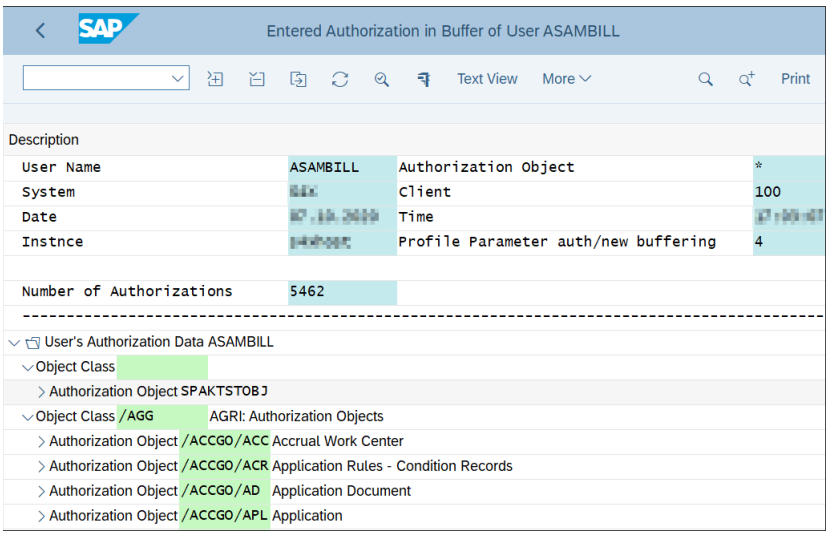


Figure 2.16 User Buffer in Transaction SU56

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

2.5.3 User Types and Maintenance

You can create and authorize users with five different user types within an SAP system, via Transaction SU01, through the **User Type** dropdown list, as shown in Figure 2.17:

- **A Dialog**
- **B System**
- **C Communications Data**
- **L Reference**
- **S Service**

Commonly, you'll distinguish these types between users who can work with dialog processes and those who cannot.

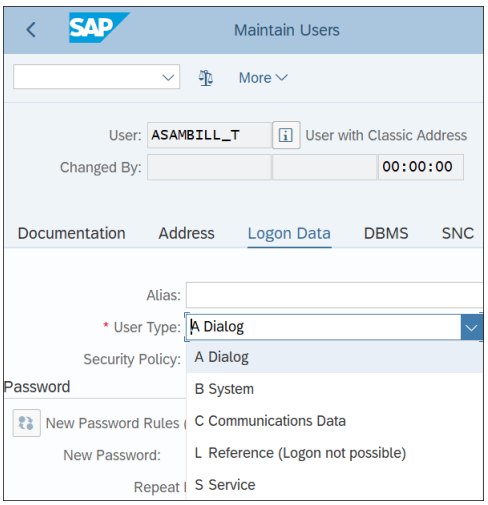


Figure 2.17 Different User Types in Transaction SU01

Hint

SAP Notes 327917, 622464, and 2557442 contain further information about the different user types.

Changing user master data and assigning authorizations through roles, in general, is the central meaning of user maintenance. The creation, changing, and deactivation of various users belong to the day-to-day work of user administration. To maintain the user master records you need, you'll require access to Transaction SU01. Alternatively, for mass user maintenance, you can use Transaction SU10. You can create, change, and delete end users and their related data within these user maintenance applications, including their roles, properties, parameters, and logon information.

Personal Copy for Arun Singal, arun.singal560@gmail.com

2.6 Authority Checks

Authorizations are the key component for working within an SAP system in a restrictive manner. They are checked each time an end user accesses any system function that needs protection. You can primarily distinguish between implicit checks customized or integrated into the system and explicit checks written by developers in ABAP code. All applications typically have embedded authority checks in their program code to enable functional use and guarantee access and function restrictions. Therefore, an individual ABAP authorization concept exists to protect data, applications, services, and related parts like transactions, programs, or cross-system access in SAP systems from unauthorized access. Based on the whole authorization processing structure, a security administrator must understand the involved authorization components to make correct assignments regarding the targeted actions of end users.

The following sections present the most common authorization checks and their purposes. Further, we'll provide detailed considerations about distinct critical access scenarios like table or program access. Finally, this section also includes a discussion of how you can globally or individually deactivate authority checks, even though this action is not recommended because you might end up with an unsecured and unstable system with complete access for all end users.

2.6.1 Locking Status Checks

The background validation of the application's locking status is called the *TSTC check*. This check does not require any authorizations in the user buffer but can restrict application access as well. At application start, the system always validates whether the target transaction is locked in table `TSTC`. If a lock flag exists, the application is inaccessible system wide. The relevant information in table `TSTC` is located in field `CINFO`, which contains only rudimentary hexadecimal values. Thus, you must translate these values to reveal their meanings.

Hint

Section 2.9.3 explains how to lock and unlock transactions according to the TSTC check.

For instance, Transaction **SU01** has the entry **84** in table **TSTC**, as shown in Figure 2.18. The value **84** indicates that Transaction SU01 is a report transaction that is not locked and has a valid TSTCA object entry.

Table: TSTC

TCOD...	PGMNA	DYPNO	MENUE	CINFO	ARBGB	TTEXT
SU01	SAPMSUU0	1000		84		User Maintenance

Figure 2.18 Table TSTC Entry for Transaction SU01

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Use report RSAUDITC_BCE via Transaction SA38 for an overview of all transactions, locking statuses with related information.

2.6.2 Application Start Checks

Long before the program code's authority checks (`AUTHORITY-CHECK` statements) are called into action, the application execution itself triggers authorization checks that are independent of the program's source code checks. Called *application start checks* or *start authorization checks*, these checks are configured by default in the SAP system and are the first level of security for accessing applications. Every time you start an application, the system check validates your end-user buffer to find the required S_* start authorization objects and the intended value. If the user buffer of an end user lacks the correct authorization objects with the correct values, that user cannot start the intended application.

Suppose you want to start Transaction PFCG. You'll require authorization object **S_TCODE** with the authorization field **TCD** and value **PFCG** within your user buffer, as shown in Figure 2.19.

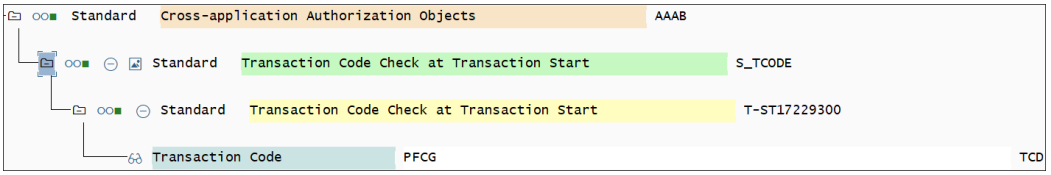


Figure 2.19 Authorization Object S_TCODE in the Authorization Profile

Table 2.3 lists the most crucial start authorization objects, which are checked at application start.

Applications	Start Authorization Object
Transactions	S_TCODE
Reports	S_PROGRAM (/ S_PROGNAM)
Remote function calls (RFCs)	S_RFC
External services	S_SERVICE
Services for object catalog entries	S_SERVICE
OData services	S_SERVICE

Table 2.3 Calling Entities and Their Start Authorization Objects

Personal Copy for Arun Singal, arun.singal560@gmail.com

Applications	Start Authorization Object
Web Dynpro applications	S_START
Web Dynpro configurations	S_START

Table 2.3 Calling Entities and Their Start Authorization Objects (Cont.)

According to this predefined start check logic, the system does not propose the necessary authorizations through the authorization default values. Instead, it directly integrates them into the authorization profile when you maintain your roles via the role menu in Transaction PFCG.

Hint

Please note that Table 2.3 assumes that you've activated the S_START check logic through table USOBAUTHINACTIVE via Transaction SM30 (SAP Note 1413011).

Also, S_PROGNAM only affects your authorization concept if you activate this check scenario via Transaction SACF (SAP Notes 1413011 and 1838854). Chapter 2, Section 2.6.8 contains more information about switchable authorizations via Transaction SACF.

2.6.3 Transaction Start Plausibility Checks

After starting an application, the system additionally performs *plausibility checks*, sometimes called *prechecks* or *before-the-program checks*. These checks are predefined in the system, and end users need their requirements in their user buffers to start the intended application. Mostly, these prechecks are customized and delivered by SAP. But you can also adjust these settings or integrate your own plausibility checks.

First, the TSTCA check is a dynamic authorization check translated from Transaction SE93 customizing into a generic authority check statement through the common code method GET_TSTCA_OBJECT_FOR_TCD. Whenever an application has a customized TSTCA entry in table TSTCA, the system examines this start plausibility check. Although not mandatory, this check adds one more layer of security. Thus, please note that, regardless of whether your user buffer contains all required start and program authorizations, you cannot start the desired application without having this predefined table TSTCA object and possible related values. Thus, the first advantage of this additional check is that you can add more granularity to an authorization check combined with the start and program authorization checks. The second advantage is that such a check can be easily defined in Transaction SE93, and as a system administrator, you can add this check without changing the source code of a program.

For instance, after maintaining the **Authorization Object** field in the **Start Option** section of any transaction, the system flags this entry in table TSTCA. Based on this flag, the

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

system now will always automatically check the required table TSTCA object for every application start from now on.

Figure 2.20 shows an example of TSTCA object **S_USER_AGR** with **ACTVT** and **ACT_GROUP** for Transaction **PFCG**.

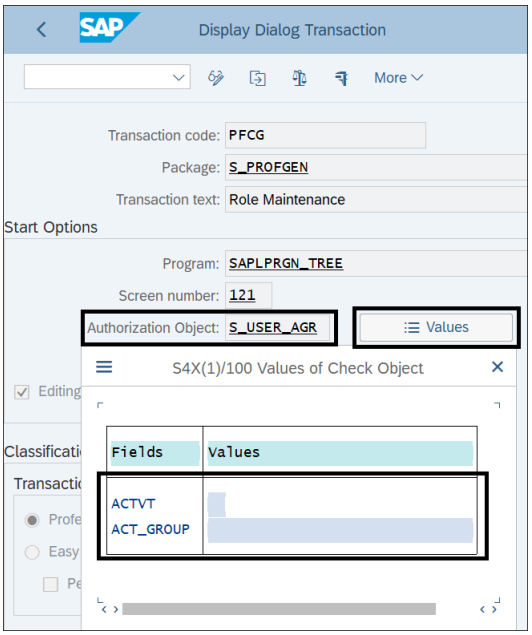


Figure 2.20 Table TSTCA Object for Transaction PFCG

2.6.4 Parameter Checks

Besides the TSTCA check, parameter checks are based on an application's customizing. As with the TSTCA check, these authority checks are also not explicitly included in a program's source code and are thus considered implicit checks. Parameter checks are dynamic and based on your customizing in Transaction SE93.

For instance, you can create a parameter transaction for a report in Transaction SE93. You would specify the report name as the intended parameter for this transaction, as shown in Figure 2.21. The check against this specific parameter is also introduced as an AUTHORITY-CHECK statement in the source code but based on the individual predefined value.

Default Values

Name of screen field	Value
D_SREPOVARI-REPORT	RFKORD10

Figure 2.21 Default Value as a Parameter in Transaction SE93

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

To learn how to create parameter transactions and understand their benefits, see Chapter 2, Section 2.7 and Section 2.9.2.

2.6.5 Kernel Checks

Some non-optional authorization checks for the application code are built into the ABAP program language itself and performed automatically by the kernel. You cannot debug these checks or turn them entirely off.

A known example of this kind of check relates to operations on the file system of the application server. Such file actions are often performed using `DATASET` commands to, for instance, to create, read, or delete files from ABAP programs. For security compliance, such data access checks are invisible but checked automatically in the background. Thus, even if no `AUTHORITY-CHECK` statement for the authorization object S_DATASET exists in the program code, the kernel still performs authority checks for data access. Therefore, without the correct end user authorizations (for S_DATASET), the program will dump into an OPEN_DATASET_NO_AUTHORITY error. These authorizations will be checked anyway beyond the program's source code. Therefore, an end user requires the necessary authorizations in the user buffer when accessing data in an ABAP system.

Hint

Suppose you want to find the correct data access authorities through a program to authorize end users correctly before they dump. In this case, use the function module `AUTHORITY_CHECK_DATASET`. This function module allows you to check authorization to access files based on the authorization object S_DATASET and keywords like `OPEN DATASET`, `READ DATASET`, or `DELETE DATASET`.

2.6.6 Program Code Authority Checks

This kind of authority check begins with the development of an application. First, your SAP developers will write all necessary program and subprogram code to enable an application's target functionalities and actions. While developers are writing the ABAP source code structure, they will also integrate `AUTHORITY-CHECK` statements. This step is necessary to restrict access to data and functionalities provided through the program. Therefore, an essential requirement with customer developments is that they contain such authorization checks as well. These statements are among the most used code patterns, but other patterns like `CALL_TRANSACTION` statements also require specific end-user authorizations to pass.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Typically, developers also create the authorization objects and their fields for the implemented authorization checks. These items are defined depending on the activity and meaning of the program. Afterward, the programs is tested based on the provided functionalities to ensure the checks are authorization objects are working correctly. If a program passes the validation, developers can create the shells for the program, like a transaction. They may also maintain the necessary authorization objects with their fields and values in table USOBT. These application-related authorization objects are the default authorization values based on the AUTHORITY-CHECK statements in a program's source code. Thus, developers also record the required check indicators in the table USOBX.

Whenever you use a program and its various features, the system checks whether you have the required authorizations to perform the targeted actions based on the program code authority checks. The basis for these checks is typically AUTHORITY-CHECK statements, as shown in Figure 2.22. This code statement explicitly determines which authorization object, field, and value combinations are required in the user buffer so that the end user can execute the desired program steps. Based on the official SAP developer guidelines, almost every SAP standard program contains at least one of these authority checks.

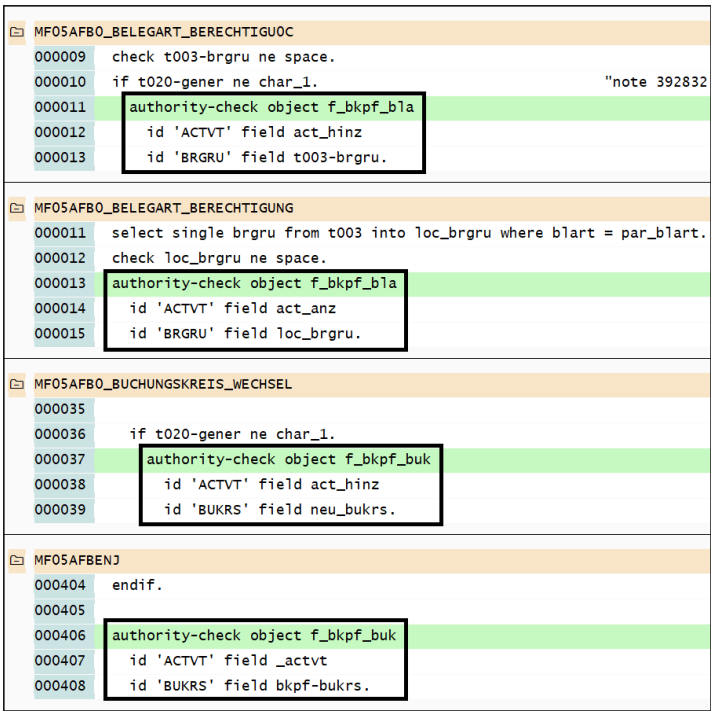


Figure 2.22 Example of Authority Checks in Program SAPMF05A

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

You can use the SAP report RS_ABAP_SOURCE_SCAN via Transaction SA38 to scan the source code of specific programs for various strings like AUTHORITY-CHECK or SQL statements.

2.6.7 SAP System Authorization Check Processing

As mentioned earlier, you can distinguish among several types of authority checks by the time or the means by which they are performed, as follows:

- Locking status check (entries in table TSTC)
- Application start checks (e.g., S_TCODE, S_RFC, S_SERVICE, S_START)
- Application start plausibility checks (entries in table TSTCA)
- Parameter checks (customized start requirements)
- Kernel checks (performed automatically by the kernel)
- Program code authority checks (all checks explicitly written in the program code)

Thus, not only can you consider the required program authorizations, you can also involve other checks, like application start checks or transaction start plausibility checks.

For instance, suppose you want to start Transaction PFCG. First, you would log on to the SAP system. In the background, the kernel fills your user buffer. This buffer contains all assigned authorizations provided through roles profiles or manual profiles. Thus, the buffer constitutes the system's basis for evaluating the upcoming authority checks. Then, whenever you execute Transaction PFCG, the system performs the TSTC check, as shown in Figure 2.23, validating whether the target transaction is locked (i.e., unavailable for all users) in table TSTC. If this locking status check is successful, the S_TCODE and TSTCA checks start. At this point, the kernel compares your user buffer data against the required S_TCODE value and customized TSTCA object in table TSTCA. Both authorization checks, first the S_TCODE check and then the TSTCA check, must be successful before you can start Transaction PFCG. Since you typically do not access any data or parameters directly via Transaction PFCG, the kernel neither performs automatic S_DATASET nor parameter checks. Thus, after those start checks, the system performs the program code authority checks based on your actions in this transaction. Now, you can display, maintain, change, or delete roles due to your assigned authorizations or jump into other applications while using the underlying program code.

To sum up, the SAP authorization check process for transactions includes several checks, such the locking status, start authorization, and program authority checks.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

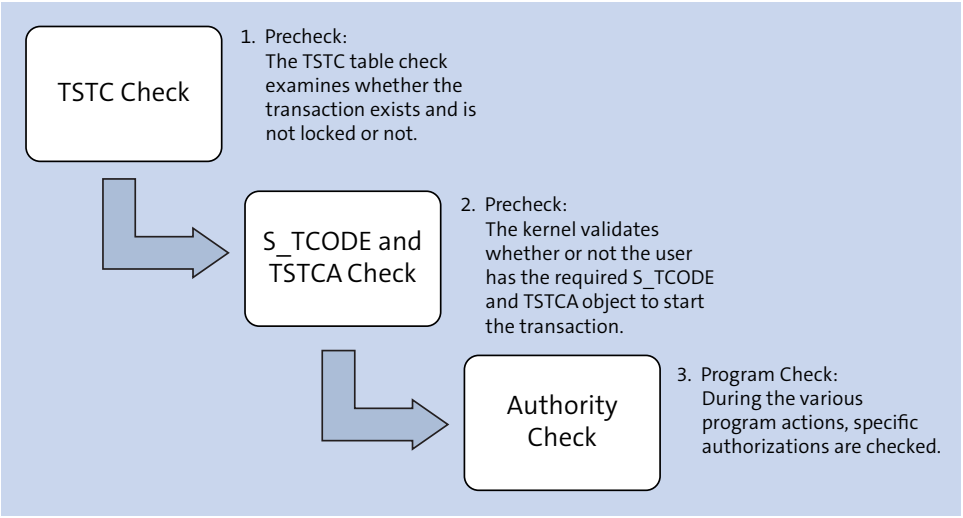


Figure 2.23 Authorization Check Sequence of a Transaction

2.6.8 Switchable Authorizations

During upgrades to higher SPs, SAP might also introduce new functionalities with additional authorization objects. This introduction affects not only dialog users but also, for instance, technical users maintained in RFC connections. Thus, you must evaluate the changes and maintain the authorizations accordingly, leading to cumbersome role maintenance effort, which you should ideally perform immediately. However, experience has shown that resolving this issue immediately is often not possible. Assigning the manual profile SAP_ALL to use the new features is no solution within a secure authorization concept. Therefore, SAP provides a framework for new security-related scenarios, delivered to you in an inactive status. The application used for this is called workbench for switchable authorization scenarios and enables the activation of such new scenarios on demand to avoid interruptions. The kernel skips the newly introduced authorization checks if the new scenario is inactive. Thus, the old authorizations still work for end users and new application features. The security administrator can check the inactive scenarios, update the affected roles on that account, and test them before activating new scenario definition in production.

You can manage scenario activation or inactivation with Transaction SACF, the workbench for switchable authorization scenarios. In addition, you can use different status settings and modes for SAP's predefined scenarios to introduce the new features and authority checks into your system.

Please note that checking switchable authorizations during your SAP upgrade process is currently not only recommended but mandatory.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

You can access switchable authorization checks through SAP Notes and SPs. These resources enhance the source code so that you can use the new check mechanism. They mostly contain a definition and description of the scenario. SAP recommends reading SAP Notes 1908870 and 1922808 before starting your Transaction SACF activities.

For instance, let's say you want to introduce a new authorization check for authorization object S_PROGNAM. But, like for a Transaction SU25 upgrade, you must first transfer the new values (scenario) from SAP into your customer system (namespace). First, start Transaction SACF_COMPARE and run **Set Initial Values** for the intended scenario (**BC_GENERIC_REPORT_START**) to load this inactive scenario into your customer system data. In addition, please consider that you'll require the necessary SAP Note in the system.

Hint

After system upgrades, it might be useful to run the **Automatic Comparison with Scenario Definitions** report to update active scenarios with possible new enhancements or adjustments via Transaction SACF_COMPARE.

With this transaction, you can also perform a consistency check to analyze your switchable authorization scenarios.

Afterward, select the scenario **BC_GENERIC_REPORT_START** from Transaction SACF's selection screen, as shown in Figure 2.24. Then, execute your selection to enter the scenario maintenance area.

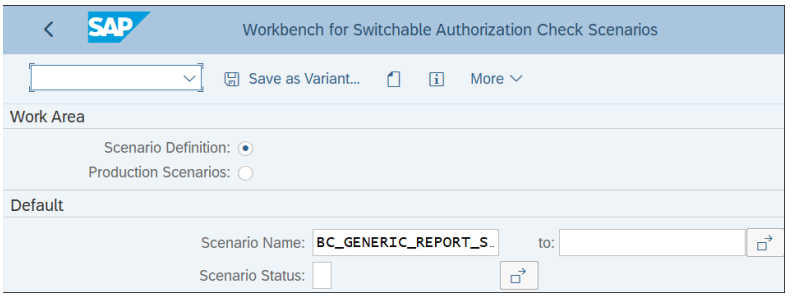


Figure 2.24 Initial Selection Screen of Transaction SACF

Double-click on the scenario name, and the system reveals its maintainable components. Before you can use this scenario, you must transfer the scenario to a production scenario. Thus, click on the **Scenario** button, as shown in Figure 2.25. A best practice is to activate the production scenario to enable all changes in your custom namespace.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

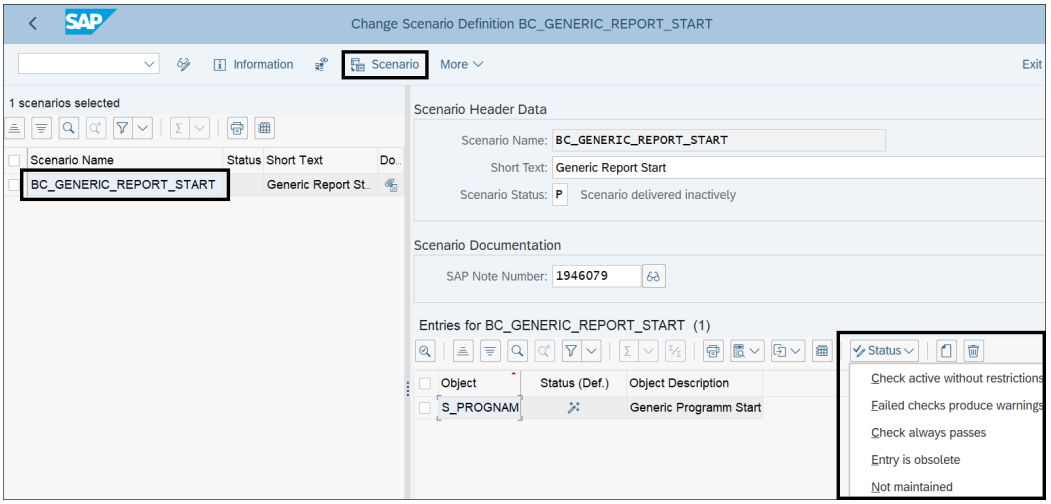


Figure 2.25 Transaction SACF Maintenance View in Change Mode

Next, start Transaction SACF again for the intended scenario, but instead of selecting the **Scenario Definition** radio button in the **Work Area** section, select the **Production Scenarios** radio button, as shown earlier in Figure 2.24. Then, switch to change mode and confirm the workbench request for your upcoming adjustments. Finally, double-click on the scenario name and set the **Scenario Status** field to **L** for logging mode, as shown in Figure 2.26. This mode enables you to call a simulation mode on production. Thus, the scenario and its authorization checks are active, but the authorization checks are always successful regardless of whether the end user has the necessary authorizations. In this way, you can analyze end-user traces to find the required authorizations based on usage. Also, set the **SAL Status** (security audit log status) field to **A** to record all checks.

You can also use various **Status** options for the target authorization object **S_PROGNAM**, a helpful approach if you have a scenario with more than one related authorization object. In this way, you can configure various statuses for the different authorization objects involved.

Hint

For Basis version release 7.40, you can use the authorization object S_PROGNAM to authorize individual programs rather than via program groups. Please note that you must activate the feature via Transaction SACF first. See SAP Notes 2272827, 1908870, 1946079, 1922808, and 101146 for more details.

Please note that a scenario exists for batch processing with S_PROGNAM, called BC_GENERIC_REPORT_START_BATCH.

Personal Copy for Arun Singal, arun.singal560@gmail.com

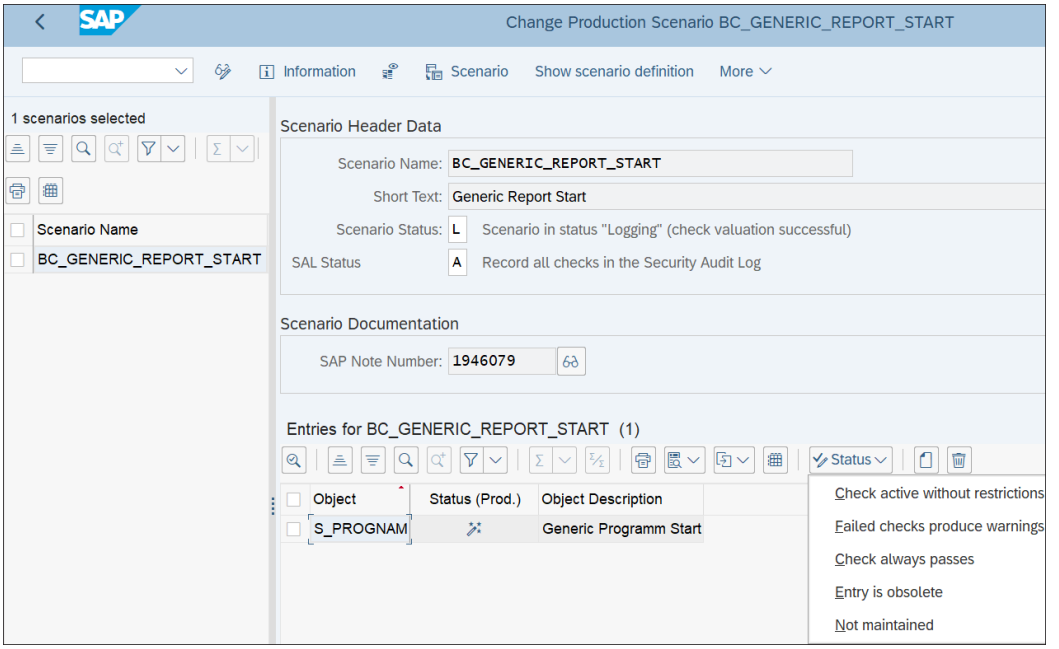


Figure 2.26 Maintaining the Active Production Scenario

Finally, testers can use the new feature without causing an authorization error with the logging functionality. The system logs missing authorizations in the background. After reviewing and correcting the logged authorization errors in the affected end-user roles, you can disable this logging feature for the specific scenario. Afterward, activate the scenario and test it again with the maintained roles. If no more authorization errors arise, you can transport the related roles and scenario into the PRD as an active scenario.

Table 2.4 lists the important transactions besides Transaction SACF that you can use to handle your switchable authorization use cases.

Transaction	Short Description
SACF_COMPARE	You can activate and compare scenarios from scenario definitions.
SACF_INFO	You can access an overview all existing scenarios in the system.
SACF_TRANSFER	You can perform a data-based transport of all scenario definitions.

Table 2.4 Useful Transactions in the Context of Switchable Authorizations

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

If you want to analyze switchable authorizations in the source code, you'll see that they don't use AUTHORITY-CHECK statements. Instead, switchable authorizations call an application programming interface (API), and the authority check is processed within the API. Based on this method and the various Transaction SACF scenarios, you might also have different return codes in your traces.

2.6.9 Deactivating Authorization Checks

SAP also provides a function to deactivate or activate application- and authorization object-specific authorization checks. For the sake of completeness, as a security administrator, you'll need to know how to deactivate authority checks. However, deactivating any source code-based authorization checks is not a best practice due to internal and external compliance assurance. For instance, AUTHORITY-CHECK statements are fundamental to the entire SAP authorization concept and enable a secure system access strategy. Without these checks, you cannot prevent full data and system access. Also, SAP recommends avoiding disabling such predefined authorization checks. The following subsections introduce you to how to deactivate authorization checks, both application-specific and nonspecific checks.

Global Deactivation

SAP allows the deactivation of authorization checks globally for all authorization objects other than those starting with S* and P*. For this task, go into Transaction SU25 and execute the Deactivate Authorization Object Globally report. You can also start this report directly in Transaction AUTH_SWITCH_OBJECTS. You can easily deactivate an authorization object by deselecting the checkbox to its left, as shown in Figure 2.27. If you disable the authority check for a targeted authorization object, the object turns red. The kernel no longer checks the deactivated authorization object for every program that requires it through the AUTHORITY-CHECK statement. Such a deactivation must be transported into subsequent systems.

Hint

You can only deactivate the authorization checks globally if the system profile parameter auth/object_disabling_active has the value "Y." To activate this, use Transaction RZ10. Please note that you can only change the configuration of deactivated authorization objects if the client is not in a PRD, and customizing is allowed in the target client. See SAP Note 2926224 for further information about the new security settings for SAP S/4HANA.

Personal Copy for Arun Singal, arun.singal560@gmail.com

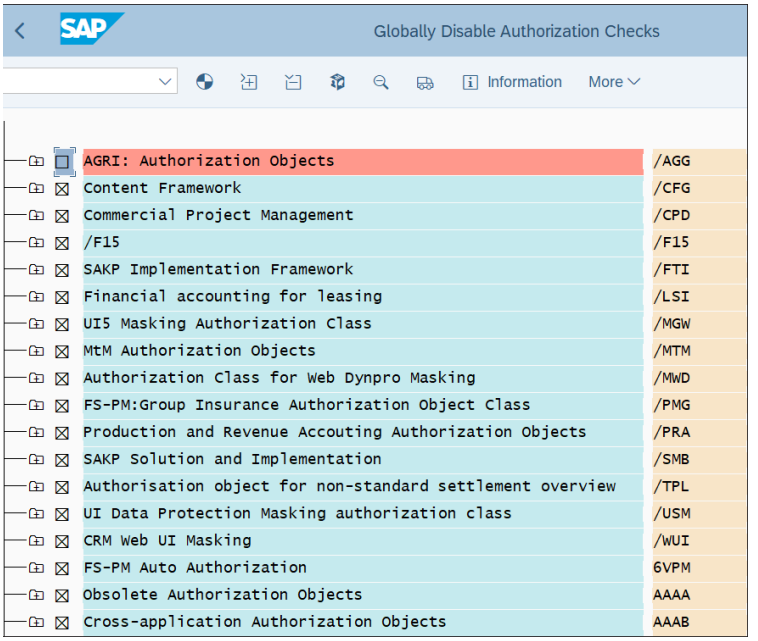


Figure 2.27 Global Activation and Deactivation of Authorization Checks

Individual Deactivation

You can also deactivate the check indicators for authorization objects in Transaction SU24, except for Basis- or SAP ERP Human Capital Management (SAP ERP HCM)-related authorization objects. But first, you might need to enable the profile parameter `auth/no_check_in_some_cases` in Transaction RZ10. The SAP default setting for this parameter is "Y." Please note that `AUTHORITY-CHECK` statements are only possibly in a program's source code, including this authorization object. Otherwise, the deactivation does not have any effect. Consequently, if you simply add an authorization object to an application as a proposal value in Transaction SU24, it does not necessarily get checked. All authorization checks, except start authorizations like S_TCODE and TSTCA, must be explicitly implemented in the source code via an `AUTHORITY-CHECK` statement.

However, if you need to deactivate such a statement via Transaction SU24, you simply need to change the status in the **Check Ind.** (check indicator) column to **Do Not Check**, for example, as shown in Figure 2.28.

The **Do Not Check** status adjustment causes the kernel to evaluate the `AUTHORITY-CHECK` statement successfully in the applications' source code (e.g., Transaction SU01) even if the correct value is missing in the end-user buffer. Thus, while the system compares the authorization requirements in the user buffer of the end user, it does not evaluate the return code, if integrated into the `AUTHORITY-CHECK` statement, against the authorization object **B_BUP_PCPT**.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

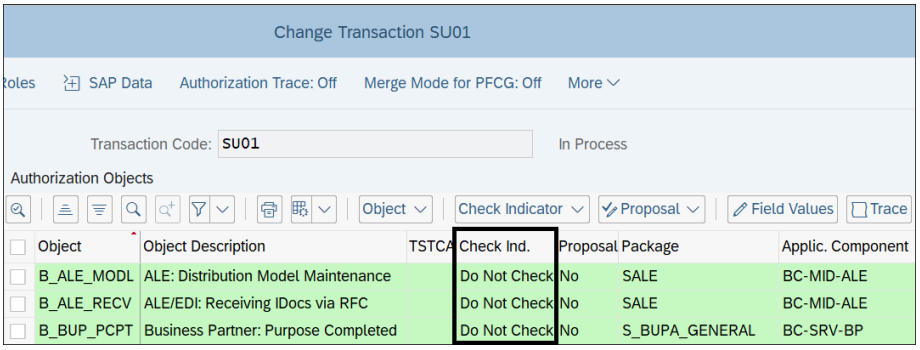


Figure 2.28 Deactivating Check Indicators for Transaction SU01

Moreover, if you deactivate a specific authorization object of the application in Transaction SU24, it also turns the proposal status to **NO**.

Hint

You can also individually block cross-application navigation via the authorization object CALL_TRANSACTION, which enables particular transactions so you can jump from one transaction directly into another. Chapter 5, Section 5.1.3, describes the implementation and adjustment possibilities for navigation restriction.

2.7 Critical Authorizations

Countless authorization objects should be assigned restrictively to end users. Such authorization objects are often related to the System Administration component in SAP and start with S*. Besides, some common business authorization objects like K_CCA, K_PCA, K_ORDER, or P_ABAP (and their combinations) may be critical depending on your internal and external restrictions. Thus, periodically focusing and monitoring your roles for such authorizations are essential to guarantee a secured IT system and compliance with data access strategies. The first and easiest way is to check table AGR_1251 to ensure your business roles refer to the relevant authorization objects.

Hint

To analyze your role concept for critical authorizations, you can also use Transaction SUIM or reports like report RSUSRAUTH or RSUSR008_009_NEW with variants for periodic monitoring. SAP governance, risk, and compliance solutions might also be good support for these use cases. Moreover, SAP Partner tools like the Xiting Authorizations Management Suite (XAMS) with its integrated Critical Authorization Framework (CRAF) help you identify and permanently monitor such authorizations. See Chapter 4 and Chapter 10 for related information.

Personal Copy for Arun Singal, arun.singal560@gmail.com

In this section, we'll discuss some of the most important authorization objects you should always watch to determine whether they are assigned to end users. These authorization objects provide extensive system and data access and should only be assigned to end users in the PRD for specific business demands, and mostly in display-only mode. Often, administrators will require these authorizations for their tasks and duties.

2.7.1 Critical Access Scenarios

Most business applications provide end users indirect access to the data stored on the database. Who can access this data and to what extent depends on the assigned end-user authorizations. An end user must pass various system and program step authorization checks based on their activities and the underlying source code requirements. Thus, the various involved programs ensure the security of the target business data operations (like create, change, or read). However, this control does not apply to generic transactions like Transactions SE16, SM30, or SA38.

Hint

Please note that, with SAP S/4HANA, you also must consider new, related transactions like Transactions S416N, S4H16N, S416H, or S4H16H. See SAP Note 2140828 for more details.

Critical access authorization objects mainly start with S*, which directly shows that they are related to system administration and are not designed for normal business processing. If you use those transactions, the kernel only checks the necessary start authorizations (like S_TCODE) and target actions for a predefined data source (like direct maintenance of the user data table USR02). No follow-up checks exist in the program code to prevent further execution and maintenance, and thus, generic transactions override the predetermined business applications, with their subprogram check logic. Direct data access is provided so that the user can display, modify, or delete data directly without any code-based restriction. The granting of these authorizations cannot be designed according to actual requirements, which may violate protection requirements and the observance of the least privilege principle.

Thus, every security administrator must focus on these generic applications, and you must avoid assigning these Basis transactions to common end users. With these generic transactions, you cannot guarantee security and compliance for sensitive data operations within your business role concept.

Hint

See Section 2.9.2 for further information on how to prevent this generic access.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The following sections explain some specific access scenarios within an SAP system that are critical, and their involved authorizations should be restrictively assigned to end users.

Table Access

Table access through generic transactions such as Transactions SE16 or SM30 constitutes raw data access in the SAP system's data model. Therefore, these access scenarios must be classified as critical and restricted. The classification also depends on existing business requirements and the sensitivity of the data contained in the target table. For instance, as shown in Figure 2.29, table PA0008 contains the payroll information (salaries) of employees in SAP ERP HCM). Furthermore, table USR02 stores user credentials and user-specific information.

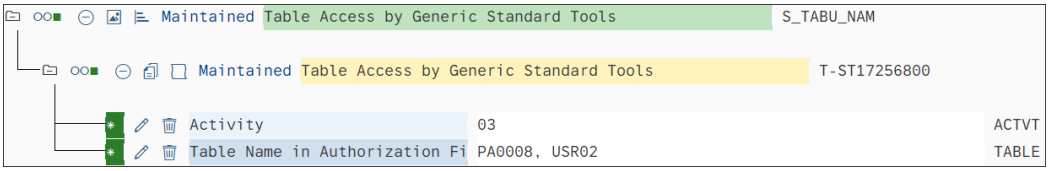


Figure 2.29 Table Authorizations for Tables PA0008 and USR02

Many tables must be protected from unauthorized generic access and abuse. In the case of direct table access, you also must consider that the standard protection mechanisms in SAP applications may be overridden because, by default, no granular follow-up check exists.

Moreover, in SAP applications, the company code (BUKRS) logic and the associated checks are an integral part of the check flow logic. Thus, for example, data from company codes are only displayed for which the end user is also authorized. In contrast, table access is, by default, undifferentiated and non-transparent. In other words, this transaction contains cross-company data, so all data in the table is displayed, even if the user would otherwise only access a subarea through an SAP application.

Thus, generic table transactions listed in Table 2.5 are potential security risks for your company.

Transaction	Short Description
SE16	Data Browser
SE16N/ (S416N)	General Table Display (new)
SE16H/ (S416H)	General Table Display (enhanced)

Table 2.5 Selected Standard Transactions for Table Access

Personal Copy for Arun Singal, arun.singal560@gmail.com

Transaction	Short Description
SE17	General Table Display
SM30	Call View Maintenance
SM31	Call View Maintenance Like SM30
SM34	View Cluster Maintenance Call

Table 2.5 Selected Standard Transactions for Table Access (Cont.)

Your focus should be on table transactions and related authorization objects that handle critical table access scenarios. Typically, no one except system administrators requires such applications in production. Table 2.6 lists the most crucial authorization objects you should master while creating your secure table access concept.

Authorization Object	Short Description
S_TABU_CLI	Cross-Client Table Maintenance
S_TABU_DIS	Table Maintenance (for table groups)
S_TABU_LIN	Authorization for Organizational Unit
S_TABU_NAM	Table Access (for table names)
S_TABU_SQL	Authorization Object for SQL Command Editor

Table 2.6 Selected Standard Authorization Objects for Table Access

Hint

The authorization object S_TABU_DIS contains the authorization fields `ACTVT` (activity) and `DICBERCLS` (table authorization group). With this object, you can authorize specific actions on a table group. Thus, you should always assign tables, especially custom tables, to table groups. Otherwise, the system automatically introduces these tables into the table group `&NC&` (not classified). This group is a container for all unassigned tables. When authorizing this table group, you'll give full access to all the tables within this nonspecific group. Thus, you should avoid assigning the value `&NC&` as a table group in the authorization field `DICBERCLS` to an end user. Instead, for granularity, you should use authorization object S_TABU_NAM so that you can assign specific table names instead of assigning entire table groups.

You can use various standard tools for table access analysis to evaluate your role concept, as listed in Table 2.7.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Type	Tool	Short Description
Generic table access	Transaction SUIM	Select the report **Users by Complex Selection Criteria** and check for generic transactions like Transactions SE16 or SM30 or manual profiles like SAP_ALL.
Table access for users and roles	Report SUSR_TABLES_WITH_AUTH	Enter the user or role you want to analyze.
Table group assignments	Transaction S_ALR_87101219 Alternative: Table TDDAT	Enter your table names, process the selection, and then check the column **Authorization Group**.
Maintain table group assignments	Transaction STDDAT	Using this transaction, you can assign tables to table groups.
Create table groups	Transaction SE54 Alternative: Transaction SM30 via table V_BRG_54	Enter the table group name and click on **Create/Change**. Enter a description and select a package. Then, save these settings.

Table 2.7 Selected Table Access Analysis and Maintenance Options

For transparent table access, use parameter transactions as a substitute for generic transactions. This approach enables secure, sustainable, and compliant data record operations. For example, suppose you have a business need to provide generic table access on table TCURR to finance key users so that they can change exchange rates. In this case, you can create a table parameter transaction for this specific table, which is also maintained in Transaction SU24, in the authorization object S_TABU_NAM, as shown in Figure 2.30.

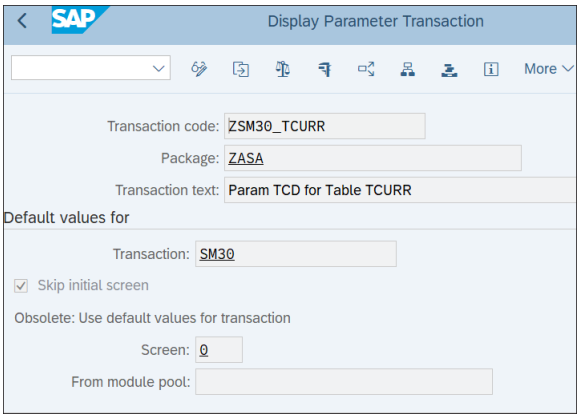


Figure 2.30 Parameter Transaction for Table TCURR Maintenance

Personal Copy for Arun Singal, arun.singal560@gmail.com

In this way, you would only provide explicit table TCURR access and avoid extensive access to other tables through transactions like Transactions SE16 or SM30, as shown in Figure 2.31.

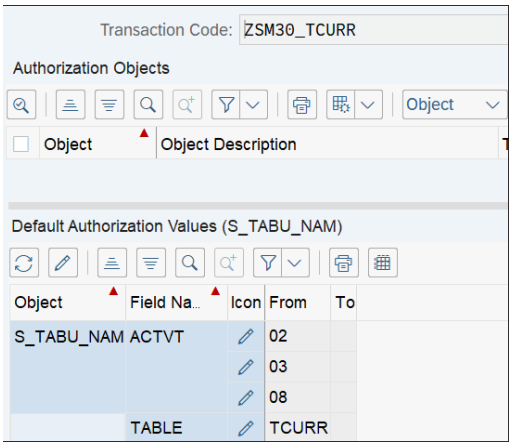


Figure 2.31 Transaction SU24 Maintenance for Transaction ZSM30_TCURR

Hint

If you already use parameter transactions for table access in an SAP ERP 6.0 system, you must check whether these tables also exist in your SAP S/4HANA system. Some may be obsolete due to the new data structure, which adheres more strongly to the principle of one. For instance, tables KNA1 and LFA1 are now obsolete. Instead, table BUT000 consumes these other tables through the enhanced business partner approach in SAP S/4HANA. Also, you should check your custom transactions and, if required, convert their underlying tables into new SAP S/4HANA tables.

Program Access

The direct assignment of generic access program start transactions like Transactions SA38 or START_REPORT is strongly not recommended for business users. Often, starting reports is required in various use cases, for instance, running payroll reports every month. Since you cannot maintain reports in the role menu or in their proposals in Transaction SU24, you'll require parameter transactions for this business need. In particular, Transactions SA38 and START_REPORT are to be classified as critical since reports provisioning cannot be made explicitly, only at the program group level in SAP standard. As a result, for reports using the authorization object **S_PROGRAM**, you can only grant access to the program group with the relating authorization field **P_GROUP** in SAP standard, as shown in Figure 2.32.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

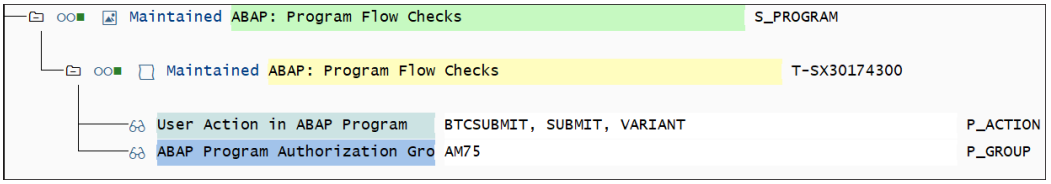


Figure 2.32 Maintained Authorization Object S_PROGRAM

This technical predefinition leads to an issue: report authorizations with S_PROGRAM require the correlating program group to which the report belongs. Thus, authorizing specific reports is impossible through this authorization object by default, only in combination (program group) with programs with the authorization field P_GROUP. The system checks whether the end user who starts the program has the related program group, not the program name first. The P_ACTION field with the value SUBMIT is typically checked as the necessary command to start a report. In conclusion, the end user can start every program that belongs to the assigned program group if you assign a generic program start transaction like Transaction SA38 to the job function as well. For instance, asset accounting often requires running various reports periodically. Before you assign Transaction SA38 and full access to the programs of the maintained program group, or even to all programs not belonging to a program group (not classified), if you leave this field empty, create parameter transactions for them so they can run reports without using any generic transaction.

Please note that, if you do not assign an authorization group to a report, the report starts within Transactions SA38 or START_REPORT cannot be prevented at all if missing follow-up checks in the code do not additionally prevent further execution, which constitutes full access to all existing programs without being assigned to a program group. Thus, using Transaction SA38 or other generic report start transactions additionally requires the maintenance of programs into program groups (authorization group). In practice, doing so is nearly impossible.

Like generic table access, generic program access may violate protection requirements and the observance of the least privilege principle because you cannot limit and document generic program starts.

Hint

See the documentation for authorization objects S_PROGRAM and S_PROGNAM for further information about their authorization check logic.

Through Transaction SACF, you can activate the authorization object S_PROGNAM to specify program access, which is not activated in SAP Standard. Note that this activation leads to additional maintenance effort and considerations about granular program restrictions. Please note that Transaction SACF scenario for the authorization

Personal Copy for Arun Singal, arun.singal560@gmail.com

object S_PROGNAM is no replacement for S_PROGRAM like S_TABU_NAM for S_TABU_DIS but an additional authorization check. See SAP Notes 1946079, 2272827, and 1908870 for details.

Table 2.8 lists some helpful tools to monitor and evaluate this critical and generic program access.

Type	Tool	Short Description
Generic report access	Transaction SUIM	Select the **Users by Complex Selection Criteria** report and check for generic transactions like Transactions SA38 or START_REPORT or manual profiles like SAP_ALL.
Existing program groups	Report RSCSAUTH Alternative: Table TPGP	This report shows all existing program groups and enables you to maintain new program groups.
Program group assignments	Table TRDIR	Shows the program group of the related program in field SECU.

Table 2.8 Selected Program Access Analysis and Maintenance Tools

Hint

If you already use parameter transactions for reports in SAP ERP 6.0, you must also check whether the programs still exist for SAP S/4HANA or are obsolete and have been replaced. Customer-specific transactions should be checked accordingly and converted to the latest reports.

Query Access

The query concept within SAP Business Suite enables the creation of reports based on tables, logical databases, or other data sources and accordingly follows the same principle governing access to raw data as direct table access. Table 2.9 lists the primary transactions for working with SAP queries.

Transaction	Short Description
SQVI	QuickViewer
SQ00	SAP Query: Start Queries
SQ01	SAP Query: Maintain Queries

Table 2.9 Selected SAP Query Transactions

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Transaction	Short Description
SQ02	SAP Query: Maintain InfoSet
SQ03	SAP Query: Maintain User Groups

Table 2.9 Selected SAP Query Transactions (Cont.)

With queries using tables as a data source, the system also performs an authorization check to evaluate access to these tables. Accordingly, you must ensure that the required table authorizations are assigned to the user executing the query. Queries are technically generated programs whose name does not change as long as important query parameters (such as the user group, the underlying InfoSet, or the query name itself) remain unchanged.

Hint

An InfoSet defines the required tables and links between tables and their content (like fields) which are used through an SAP query.

These query parameters are part of the generated program name and directly influence the generated program name if you change them. Please note that the authorization object S_QUERY is additionally necessary to create and maintain queries.

Hint

Typically, you should assign only Transaction SQ00 for end users so they can execute, but not create, queries in production. On the other hand, special key users or process owners who must create queries might require transactions like Transactions SQ01, SQ02, and SQ03. In this case, you must maintain the corresponding table authorization objects S_TABU_DIS or S_TABU_NAM with extensive values to enable the required raw data access. Activate, if not already done, those authorization objects in Transaction SU24 for the intended query transactions. Afterward, analyze the job function roles for their provided table access through standard applications. Based on this analysis, assign all these groups and tables to the S_TABU_* authorization objects in the query job role, which you build for each business unit when required. This approach enables you to provide restrictive query access based on business demands initially. Enhance this role step by step when power users need additional table access for their query processing. However, you must assign extensive table authorizations, which you can avoid if you create parameter transactions for the specific queries because they are single programs. Therefore, launch Transaction SE16 and check table TRDIR for Name: AQ*. This list shows you all available queries in production, for which you must create such parameter transactions. Especially for common end users, you would use this approach to restrict table authorizations to a minimum and only provide the required authorizations based on the intended parameter and its transaction.

Personal Copy for Arun Singal, arun.singal560@gmail.com

A best practice is to always create queries in DEV and transport them to subsequent systems. Also, please note that ideally you would provide query access, not via transactions like Transaction SQ00, but through dedicated parameter transactions because queries are, by their nature, also only reports.

Hint

Suppose you're already using parameter transactions for queries in an SAP ERP 6.0 system. In this case, you must also check whether the table sources still exist in the SAP S/4HANA system or are possibly obsolete.

2.7.2 Audit-Focused Authorization Objects

Besides the critical authorizations based on the various access scenarios described in the previous section, you should periodically monitor whether and how access scenarios are assigned to end users and also administrators. In the following sections, we'll show you some selected authorizations that are often focused on audits and enable extensive system or data access if assigned.

ABAP Workbench

The required authorization object for debugging and maintaining development objects is authorization object **S_DEVELOP**—one of the most powerful authorization objects in the entire SAP system. Through this authorization, even with limited values like only **ACTVT 02** and **OBJTYPE DEBUG**, an end user with some developer knowledge can do nearly anything in the system and has full data access. This combination enables you to debug a program and change the return code of any failed authorization check to access the program and its data without having the correct authorizations assigned. Thus, the authorization object S_DEVELOP, as shown in Figure 2.33, provides you the opportunity to jump into the source code and manipulate everything there via debugging modes, which can absolutely undermine your entire authorization concept.

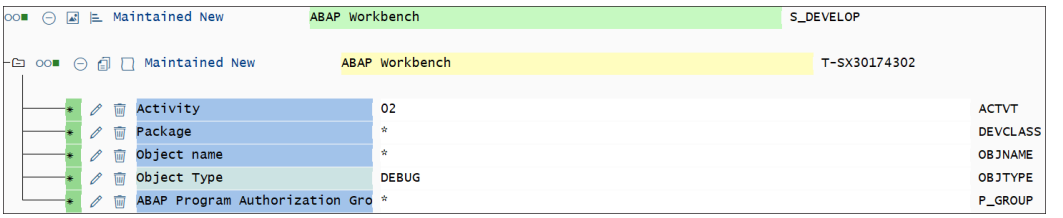


Figure 2.33 Critical S_DEVELOP Characteristics

Background Jobs

First, a best practice is to always run background jobs in a technical user context (user type SYSTEM) since these users are subject to different user policies. Moreover, the SAP

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

system will not warn you if background jobs run in a dialog user context or if this end user no longer exists. In this case, every job in this dialog user context runs into an error and stops, which may also occur if the user is locked or his authorizations have been changed. Thus, job validity always depends on the background user's authorizations and status.

Avoid assigning related authorization objects to every business user; only assign these objects to administrators or key users who start or plan jobs. The transactions listed in Table 2.10 are necessary to work with jobs and schedules for yourself or other users.

Transaction	Short Description
SM36	Schedule Background Job
SM37	Overview of Job Selection
SMX	Display Own Jobs

Table 2.10 Selected SAP Job-Related Transactions

The primary object of background jobs is the authorization object S_BTCH_JOB, which provides authorizations for background jobs. For administrators, you might also require the authorization object S_BTCH_ADM, which enables you to administer jobs created by other users. To schedule jobs in another user's context, such as a technical user, you'll require the authorization object S_BTCH_NAM.

Hint

With Basis version release 7.52, you can also use the authorization object S_BTCH_NA1 to invoke a system check on the program name and user name. See SAP Note 101146 for further information.

Batch Sessions

To load data via batch inputs into the system, you'll also require the authorizations for batch input sessions. You can monitor these sessions via Transaction SM35. All actions that you can perform in batch input management are checked using authorization object **S_BDC_MONI**, including for example, starting a batch input session or displaying a log or a recording. This authorization controls batch input management and the monitoring of those sessions. For business users, you should only provide the authorization values shown in Figure 2.34 for the field **BDCAKTI** so these users can monitor their own sessions only.

For example, within the finance department's environment, a useful step might be to add, in addition to the `0*` authorization values, the value `ANAL` to the authorization field `BDCAKTI`. This approach enables the analysis of foreign sessions in display-only mode.

Personal Copy for Arun Singal, arun.singal560@gmail.com

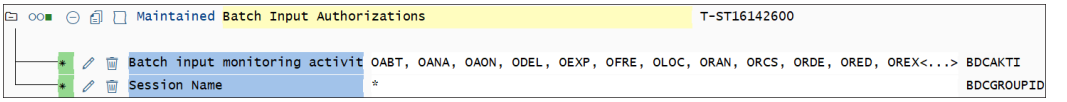


Figure 2.34 S_BDC_MONI Authorizations Restricted to the User's Own Batch Inputs

Download Authorizations

In many business cases, uploading and downloading data to/from the SAP system is necessary, especially for business units like Basis, production, quality management, finance, and controlling. Thus, this authorization poses a risk in that sensitive data can quickly leave your organization or malware can enter your organization. Therefore, you should focus on authorization object **S_GUI** with activities **60** (Import) and **61** (Export), as shown in Figure 2.35. This characteristic enables data uploads and downloads to the frontend. The issue with this authorization object is that it does not differentiate between the type of data you want to export or import, and no further specific restrictions are possible. It is not sustainable to avoid the assignment of **S_GUI** with the values **60** or **61** because the business process requires data (e.g., to download quality reports or to import a general task for quality notifications). However, maintain and assign this authorization object only in a highly restrictive manner.

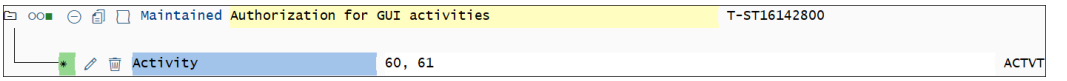


Figure 2.35 Importing and Exporting Data through Authorization Object S_GUI

Hint

SAP offers two user exits to enhance the security of downloads and resolve the authorization object S_GUI issue. See SAP Note 28777 for a detailed explanation.

Spool Authorizations

The SAP system contains its individual spool system, allowing end users to print documents (spools), send documents, or list documents. Consequently, with the correct authorizations, you can manage output devices or access the spools in the SAP spool system, called *temporary sequential data (TemSE)*. This flaw might constitute a crucial risk because spools might contain sensitive data that not every employee should access, for instance, payroll or balance sheet data. Thus, you must be familiar the different spool-related authorization objects and the transactions designed to prevent such security gaps. The transactions listed in Table 2.11 are the main applications for managing spool activities and administration.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Transaction	Short Description
SP00	Spool and related areas
SP01	Output Controller (own/others)
SP02	Display Spool Requests (own)
SP12	TemSe Administration
SPAD	Spool Administration

Table 2.11 Selected Spool Transactions

To access spool devices, you'll need the authorization object **S_SPO_DEV**. End users with this authorization are indicated by an asterisk (*), as shown in Figure 2.36.

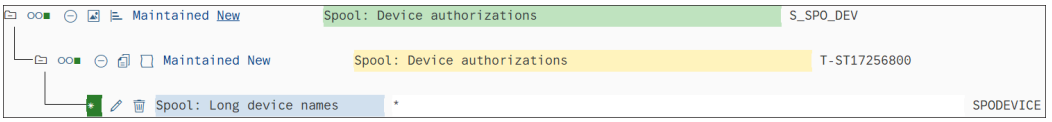


Figure 2.36 All Spool Device Access through Authorization Object S_SPO_DEV

In this case, these users can access every output device. To control how many pages an end user can print, you must maintain the authorization object S_SPO_PAGE.

Hint

You must set the Transaction RZ10 parameter `rspo/auth/pagelimit` to "1" so that the authorization object S_SPO_PAGE is checked by the SAP system. A fixed correlation exists between that profile parameter and the check logic of the SAP system for this authorization object. that transaction code and that authorization object.

Besides monitoring spool administration authorizations, you should also focus on which spools are accessible and viewable through specific end-user authorizations. For the spool selection of your own or other spools, you'll need the authorization object S_SPO_ACT. The related authorization field `SPOACTION` provides various access types to spools. For instance, as shown in Figure 2.37, you can reveal all the personal spools with the authorization values **BASE** and **DISP** and a specific user ID (e.g., **ASAMBILL**) for the authorization field **SPOAUTH** of the person for which you want to see their spool.

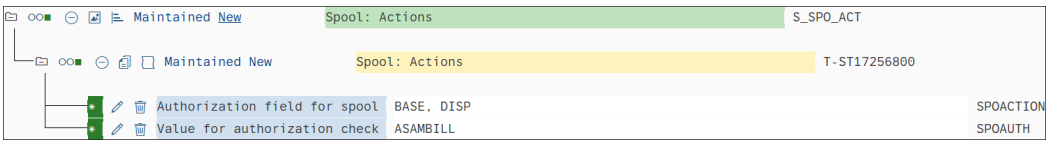


Figure 2.37 Spool Access of End User ASAMBILL

Personal Copy for Arun Singal, arun.singal560@gmail.com

For your own spools, you don't need any authorizations for object S_SPO_ACT because the system only checks authorization field SPOAUTH if you want to see foreign spools. Furthermore, you additionally require the authorization object S_ADMI_FCD with the authorization field values SP01 or SPOR to access spools from other users.

Value Help (F4) Authorization

According to the extensive General Data Protection Regulation (GDPR), SAP introduced the additional authorization value "F4" for the value help. This additional authorization restricts the content you can display by pressing the value help key F4. Regardless of whether you already have display access via the value "03," you won't see value help content. If you want to enable the end user for value help content, they require the authorization value "F4" in authorization field **ACTVT**, as shown in Figure 2.38. This authorization enables a distinction between granting view permissions to data (**03**) versus only to value help (**F4**). Thereby, you can separate information view access for end users. The value help itself might provide critical information, like personnel or controlling information. For this reason, you can restrict it.

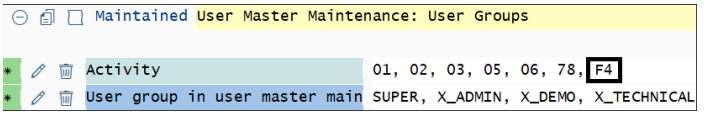


Figure 2.38 Authorization Value F4

Carry out this action within your authorizations concept because it significantly impacts the daily work of end user. If you always use Transaction SU25 for your proposal upgrades, no gap will exist because SAP introduces this value in their Transaction SU22 data transports. If you have any issue handling this new authorization value, you can temporarily use the new SAP standard role SAP_NEW_F4 to avoid this maintenance effort. Do not use this role permanently to provide value help authorizations but instead maintain value "F4" separately in various job function roles.

Hint

SAP Notes 2682142, 1539556, 2606478 contain all the essential information about this topic.

Remote Function Call Authorizations

An RFC is a technical communication interface within or between SAP or non-SAP systems. Additionally, this interface is necessary for IDoc processing, application link enabling (ALE), and business application programming interfaces (BAPIs). RFC can result in risky system access because they are typically connected to other systems, and

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

the underlying technical user can be abused. To manage these potential issues, two different RFC call types exist: trusted and untrusted. Through a trusted RFC, the calling system (client) is a trusted source for that connection. This client system does not require any authentication for the calling user on the destination system (server).

On the contrary, with an untrusted RFC, the client system must authenticate itself with logon credentials (technical user and password) to access the server system. You can maintain RFC connections via Transaction SM59.

For the authorization of RFC connections, you must distinguish between calling (as a client) and serving as a destination (server systems). Before the RFC occurs, the calling system checks the authorization object **S_ICF** of the system user who starts the call (client). Like the predefined TSTCA check for transactions, this check secures access to RFC destinations in the calling system based on SAP's internet communication framework (ICF). As a result, that object grants destination access but is only relevant if a related authorization value exists in the calling system's RFC destination. Then, the authorization objects **S_RFCACL** and **S_RFC** are checked in the called system (destination), as shown in Figure 2.39.

Object	Field Name	Icon	From	To
S_ICF	ICF_FIELD			
	ICF_VALUE			
S_RFC	ACTVT			
	RFC_NAME			
	RFC_TYPE			
S_RFCACL	ACTVT			
	RFC_CLIENT			
	RFC_EQUSER			
	RFC_INFO			
	RFC_SYSID			
	RFC_TCODE			
	RFC_USER			

Figure 2.39 RFC-Specific Authorization Objects in Transaction SU24

The calling user of an RFC communication requires the authorization object S_RFCACL, and its various authorization fields maintained, to access the destination system for a trusted RFC connection. Once the dialog user passes the validation check, the destination system checks authorization object S_RFC for the calling RFC user, who now tries to perform RFC activities to process or collect data in the called destination system. Please note that the various RFC authorization objects involved have many specific fields, which you must individually maintain in the role authorization profile for each scenario and not entirely in the authorization default values of the involved function modules. Various values will be required based on your system setup and desired scenarios, especially for authorization fields `RFC_CLIENT` (system client number) and `RFC_SYSID` (system ID name). Also, authorization field `RFC_EQUSER` is important: The value "Y" indicates whether the user can be called by a user with the same ID. For instance, if an

Personal Copy for Arun Singal, arun.singal560@gmail.com

end user (ASAMBILL) in source system **PRD**, client **100**, wants to call a function module in the target system under the same user ID (**RFC_EQUSER** value **Y**), the end user will need the right authorizations in the target system, as shown in Figure 2.40.

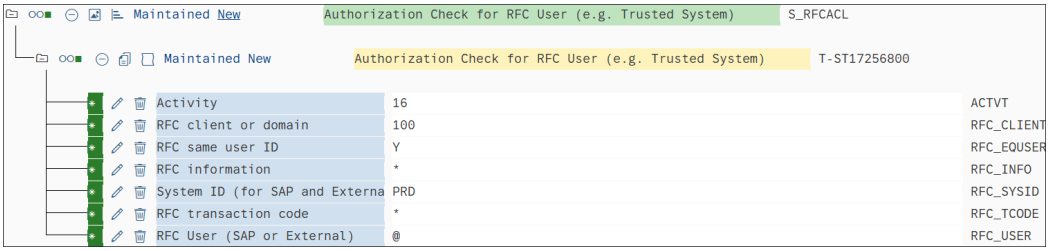


Figure 2.40 RFC Authorizations for Calling in the Same User Background

Within untrusted RFC scenarios, the system authentication happens against the technical RFC user and its credentials without checking the authorization object S_RFCACL. Afterward, the same authorization check logic starts as for a trusted RFC.

Hint

To follow the least privilege principle, do not assign manual profiles like SAP_ALL to technical RFC users. Otherwise, an RFC connection might be a security flaw and call critical functions and data as well. See Chapter 11 and SAP Note 1682316 for some best practices. Moreover, authorization object S_RFCACL is not integrated into the SAP_ALL profile by default. Check whether the automatic integration is active in table PRGN_CUST with YES as the value for parameter ADD_S_RFCACL.

2.8 Authorizations in SAP ERP Human Capital Management

In addition to the typical SAP ERP 6.0 or SAP S/4HANA core, you can enhance your system with SAP modules like SAP ERP HCM, SAP Customer Relationship Management (SAP CRM), SAP Supplier Relationship Management (SAP SRM), or SAP Business Warehouse (SAP BW) as integrated systems or as separate systems. Especially in big companies, separation from each other might be necessary, and you'll manage several individual systems and areas of responsibility. These modules require a specific authorization concept.

SAP ERP HCM is an important SAP module for all personnel-related information and activities. This solution enables your company to implement HR-based processes and personnel structures within an SAP system. Within SAP ERP HCM, you'll still implement your authorization concept via Transaction PFCG. In contrast to typical SAP authorizations, however, some essential differences exist.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

2.8.1 Business Transactions and Authorization Components

In the context of SAP ERP HCM transactions, like Transactions PA10, PA20, PA30, PA40, PM01, or PA51, unique HR authorization objects, fields, and values exist that you must consider during role maintenance. Table 2.12 lists the most important HR authorization objects.

Authorization Object	Short Description	Definition
P_ABAP	HR: Reporting	Used for HR reports.
P_PCLX	HR: Clusters	Used for HR table cluster restriction.
P_ORGIN	HR: Master Data	Used for HR data when HR infotypes are edited or read.
P_ORGINCON	HR: Master Data with Context	Used for HR data when HR infotypes are edited or read with an enhanced restriction on structural profiles.
P_PERNR	HR: Master Data – Personnel Number Check	Used for accessing the data of the own personnel number.
P_TCODE	HR: Transaction Codes	Used for the authorization of the different HR transactions.
PLOG	Personnel Planning	Used for the restriction of specific fields in the personnel management components.

Table 2.12 Important SAP ERP HCM Authorization Objects

Depending on the authorization object, you'll have to maintain several authorization fields. Therefore, you must understand various fields and their relevance for HR data accessibility, as shown in Figure 2.41:

- **Authorization level (AUTHC)**
  Authorization field AUTHC regulates HR data access activities like read, write, or update. This field is similar to the authorization field ACTVT (activity).
- **Infotype (INFOTYP)**
  Infotypes constitute the technical entity for personnel, organizational, or individual HR data in SAP ERP HCM. An infotype is one of the most crucial fields for HR data access and could be time dependent or country specific. In addition to the SAP standard infotypes, you can configure enterprise-related infotypes in customer tables to cover your specific needs. The following ranges are essential for organizing infotypes:
  - Infotypes 0000 through 0999: HR master data (and sometimes applicant data)
  - Infotypes 1000 through 1999: Organizational management

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Infotypes 2000 through 2999: Time data
- Infotypes 4000 through 4999: Applicant data
- Infotypes 9000 through 9999: Customers

Hint

A sensitive infotype is infotype 0008, which contains salary information. Constantly monitor the assignment of this value in SAP ERP HCM or SAP Human Capital Management for SAP S/4HANA, on-premise edition.

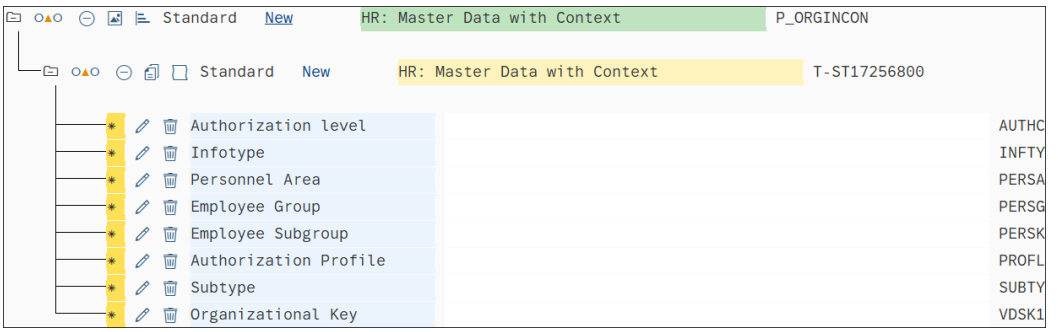


Figure 2.41 Authorization Fields of the Authorization Object P_ORGINCON

- **Object type (OTYPE)**
  If you want to cover organizational elements like the job (C), the organizational unit (O), the person (P), or the position (S), you must maintain this field. You can customize object types in infotype 1000.
- **Plan version (PLVAR)**
  Regarding personnel planning and future purposes, you might restrict access to this information, which can be sensitive or confidential. You can use this authorization field to specify which plan version(s) a user is authorized to access. A plan version is also an organizational level.
- **Planning status (ISTAT)**
  According to the plan version, you also have various status attributes, like active, planned, or rejected. So, to differentiate among plan versions of different statuses, you can use this field.
- **Function code (PPFCODE)**
  This field clarifies which actions (like display or edit) a person is authorized within the authorization object PLOG for personnel planning. This field is similar to field AUTHC.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Personnel area (PERSA)**
  If you want to restrict access to personnel data, especially regarding country-specific divisions, you must maintain the persons' areas for each HR end user.
- **Employee group (PERSG)**
  The employee group is an organizational entity for structuring the employees within the organization. For example, to divide between active, inactive, extern, or retired.
- **Employee subgroup (PERSK)**
  Again a subdivision of the employee group (field PERSG), you can use this field to differentiate among your groups more precisely. For instance, the employee group "active" contains workers, tariff employees, or non-tariff employees.
- **Authorization profile (PROFL)**
  This authorization field PROFL determines which structural profiles a user is authorized to access. This check takes place when HR infotypes are edited or read in the context of authorization object P_ORGINCON. This field should contain a predefined structural profile and is assigned to a user based on table T77UA data.
- **Subtype (SUBTYP)**
  Subtypes are a subdivision of infotypes to clarify and complement detailed data about the infotype. If you authorize an infotype, you should always consider its subtypes as well, if available.
- **Organizational key (VDSK1)**
  Like the personnel area, this authorization field enables you to differentiate, with your organization, the administration areas of your HR operators. This authorization field can be used to run diverse authorization checks by organizational assignment in the context of the authorization object P_ORGIN. The content of an organizational key is either derived by the system from the fields of the organizational assignment infotype (infotype 0001) or entered manually by an administrator.

Hint

Organizational fields play only a subordinate role in SAP ERP HCM. Only one main organizational field exists for an organizational division—the plan version (PLVAR). In most cases, organizational levels are not used because the specific HR authorization objects already restrict enterprise-related access allocations, like control over access to field VDSK1.

2.8.2 All-Access in SAP ERP Human Capital Management

As described in Section 2.4.2, the manual profile SAP_ALL contains nearly all SAP system authorizations. Thus, this profile is not only critical, but also all-access. For SAP ERP HCM, even a standard authorization object like authorization object P_ABAP can

Personal Copy for Arun Singal, arun.singal560@gmail.com

enable profound access to the HR data. Suppose you have the characteristic combination shown in Figure 2.42. In this case, you have full SAP ERP HCM access if an HR report uses the logical database **PNP** as its data source. Please note that many HR reports use this information source.

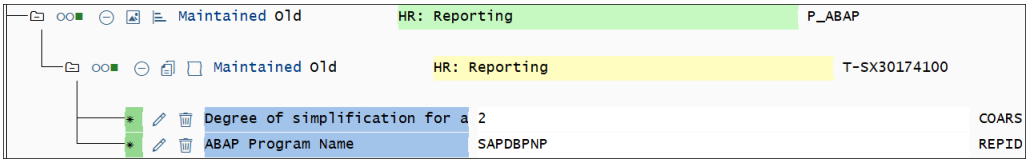


Figure 2.42 Critical Authorization Combination for Authorization Object P_ABAP

The value **2** for the field **COARS** (degree of simplification for authorization check) disables any authority check when executing HR reports. The report name **SAPDBPNP** corresponds to the logical database PNP. Thus, this report provides HR data access, not from the related tables, but through queries from that direct data source. Whenever end users have these authorizations assigned, they can run this report SAPDBPNP without being checked, which undermines all other authorization checks based on existing and assigned HR transactions because users can directly access that logical database to get the data records. Thus, these end users can see all SAP ERP HCM data, which might be sensitive, without having the SAP_ALL profile.

Hint

Never assign these all-access authorizations to an HR operator or only with strong restrictions (e.g., for the head of HR only). Otherwise, you bypass your secured authorization concept and will fail to meet compliance requirements with those crucial authorizations.

2.9 Different Transaction Types

Within SAP Business Suite, you can use different types of transactions to execute specific applications and their included features. Thus, transactions are shells for programs lodged in alphanumeric codes—the transaction codes. These codes are the basis for working within an SAP system and for performing the desired tasks. To start a transaction, enter the transaction code in the command box, or alternatively, you can start transactions from your user or SAP menu. A system authority check sequence starts when you execute a transaction, as described in Section 2.6. If all authority checks are successful, you can start working within the targeted application. Naturally, SAP standard transaction codes are generally enough for most business cases. According to

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

internal or external requirements or additional use cases, you might require custom transactions, perhaps to avoid generic or critical data record access. For these individual issues, the standard transactions might not be enough. Such use cases could be, for example, to provide only a specific functional setup of the target program or to avoid assigning critical transactions. Therefore, you can use Transaction SE93 to create, change, or delete transactions.

This section provides an overview of the different available transaction types in an SAP system. Furthermore, this section explains how to use transaction types and their various fields of utilization. In addition, you'll learn how to use Transaction SE93 to create unique transaction codes.

2.9.1 Overview of Available Transactions

The following types of transactions are available, as shown in Figure 2.43:

- **Program and dynpro (dialog transaction)**
- **Program and selection screen (report transaction)**
- **Method of a class (OO transaction)** (object-oriented transaction)
- **Transaction with variant (variant transaction)**
- **Transaction with parameters (parameter transaction)**

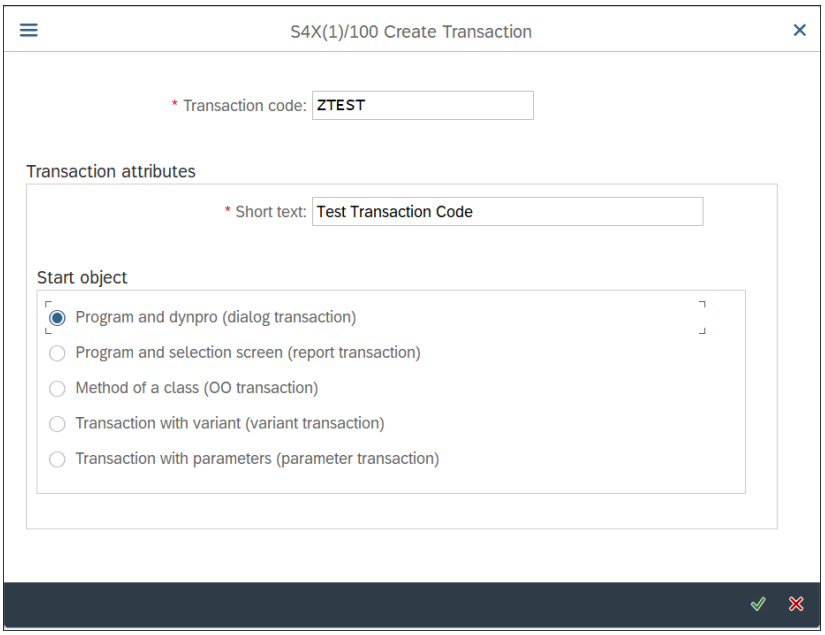


Figure 2.43 Creating a Custom Transaction Code in Transaction SE93

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Don't forget to maintain the proposal values via Transaction SU24 for your custom transactions. In some cases, another helpful approach is to adjust SAP transaction proposals to integrate business demands. Chapter 5 explains these maintenance actions in detail.

Let's now discuss these transaction types in more detail:

- **Dialog transactions**
  Dialog transactions start a single program where a sequence of different Web Dynpro screens predetermines the program's flow. In addition, particular programs often belong to a module pool type. A module pool are reports prepared for different screens and to manage the sequence of events of these screens (Web Dynpro applicationss). In Transaction SE80, you can see all relating Web Dynpro applications of the program. Thus, for a dialog transaction, you must always define the initial screen that will be started when a user executes the transaction code.

  For instance, Transaction **PFCG** initially opens **Screen number: 121** of its executing program, as shown in Figure 2.44.

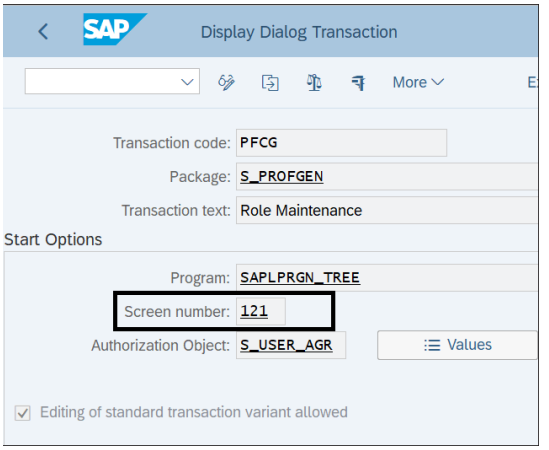


Figure 2.44 Example of the Dialog Transaction PFCG

- **Report transactions**
  Report transactions start an executable program to display data in an output list. This type of transaction is typically required to indicate processing or calculation results in a simplified form.

  An indicator for report transactions is a predefined specific **Selection screen** (**1000**), as shown in Figure 2.45 for report Transaction SUO1.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

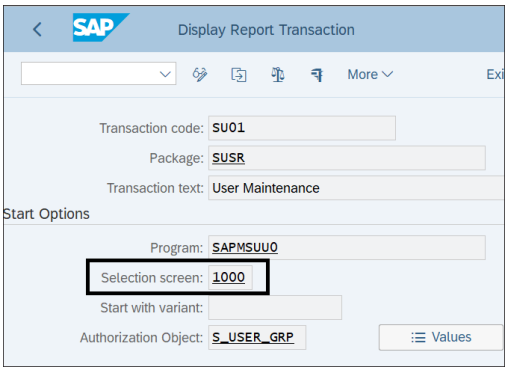


Figure 2.45 Example of the Report Transaction SU01

- **Object transactions**
  Object transactions do not start a program but instead execute an ABAP class method directly. For example, Transaction **SCOT** is an object-oriented transaction that you can use to configure outgoing emails. If you execute Transaction **SCOT** in your command box, the system starts the **START** method of the class **CL_BCS_ADM_NODES**, as shown in Figure 2.46.

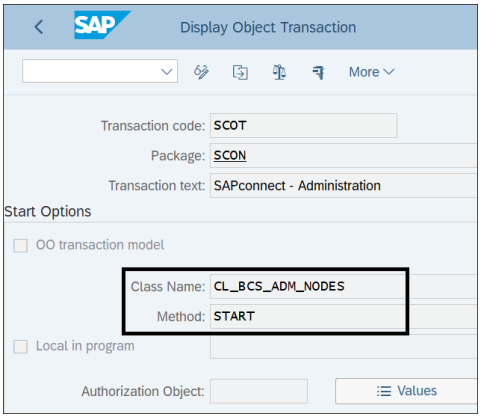


Figure 2.46 Example of the Object-Oriented Transaction SCOT

Hint

ABAP class methods are internal procedures within an ABAP class. Methods define the behavior of a repository object and can access all related class attributes, for instance, changing the data content of an object.

- **Variant transactions**
  You can create specific transaction variants with variant transactions to prevent an end user from generic application access that cannot be protected with specific

Personal Copy for Arun Singal, arun.singal560@gmail.com

authorization objects. Thus, variant transactions enable various operational scenarios with exact functional program restrictions. For instance, you can define specific application functions and menu attributes or hide specific screens as well. Moreover, you can enable operational scenarios through proposals in Transaction SU24. For example, Figure 2.47 shows you a customized start option for a variant transaction of Transaction **ZSU01_VAR_LOCK** in Transaction SU01; this start option uses the transaction variant **ZSU01_USR_LOCK_MGMT**.

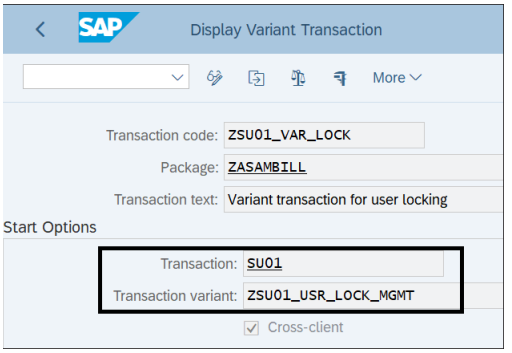


Figure 2.47 Example of the Variant Transaction ZSU01_VAR_LOCK

Hint

Please note that variant transactions are not the same as Transaction SU24 default data variants. For detailed information about this variant type, see Chapter 5, Section 5.3.

- **Parameter transactions**

  Parameter transactions allow specific, preassigned fixed values (parameters) to a transaction's initial selection screen. You can also skip the first screen entirely through this transaction type so that the user automatically proceeds with a predefined selection. This approach enables secure data access because the end user cannot enter a generic transaction like Transactions SE16 or SM30 and make their own selections. In this way, you avoid assigning generic access to common end users.

  An example of this parameter-bound transaction is the client administration Transaction **SCC4**, which is a parameter transaction of Transaction **SM30** that skips the first screen to proceed immediately and directly to table **T000**. Thus, when users execute Transaction **SCC4**, the system automatically starts Transaction **SM30** with the table **T000**, as shown in Figure 2.48. Furthermore, this parameter transaction prevents end users from entering another table name or changing the predefined selection criteria via Transaction SM30.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

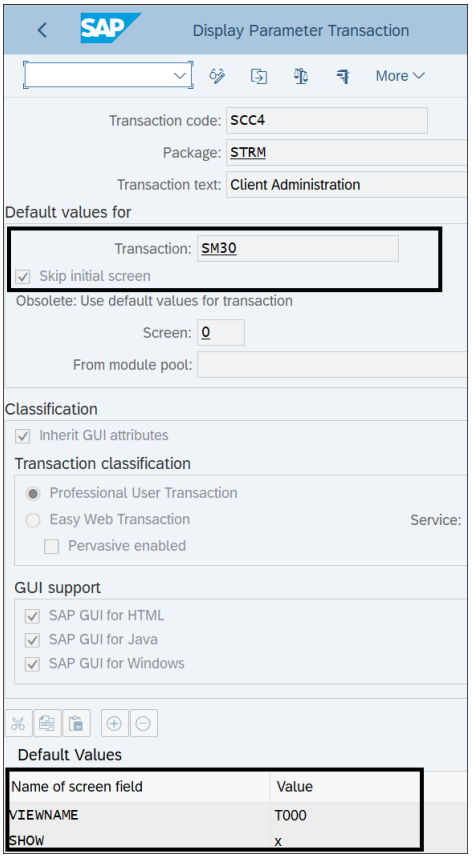


Figure 2.48 Example of the Parameter Transaction SCC4

Hint

You should use parameter transactions to remedy critical authorization conflicts by a generic view or maintenance access on tables through transactions like Transactions SE16 or SM30. Moreover, parameter transactions are also useful for generic program execution to avoid assigning Transactions SA38, SE38, or START_REPORT to end-user roles.

According to SAP Best Practices, you can define authorization default values in Transaction SU24 to build stable roles through parameter transactions.

2.9.2 Creating Custom Transactions

The primary transaction to create, change, or display all custom transactions is Transaction SE93. With this transaction, you can build up a structure of business-related transactions for your role concept. You should consider meaningful transaction names

Personal Copy for Arun Singal, arun.singal560@gmail.com

and short descriptions for your new transactions. Transaction names can be a maximum of 20 digits long and should start with "Z" or "Y" (custom code namespace).

Before creating custom transactions, the common transactional principle should be understood, even though you, as a security administrator, don't influence this principle when creating custom transaction codes. The ACID (atomicity, consistency, isolation, durability) principle describes four significant characteristics or rules for processing transactions. A transaction code must satisfy the ACID principle so that transactional data queries within the database management system (DBMS) are reliable and consistent. A summary of the four constituents of ACID is provided in Table 2.13.

Constituents	Short Description
A (Atomicity)	The transaction succeeds completely or not at all.
C (Consistency)	The transaction generates a new valid database condition or falls back into an old condition.
I (Isolation)	Changes within a transaction are only visible and changeable for other persons after the action's final commitment.
D (Durability)	The results of the transaction are durable because they are firmly committed to the database.

Table 2.13 Summary of the ACID Principle

If necessary, always remember to maintain proposal values in Transaction SU24 for your custom or changed transactions. In this section, we'll cover three different scenarios for creating custom transactions.

> **Hint**
>
> If you need extensive information about maintaining proposals and using them to establish a sustainable and maintainable authorization concept, see Chapter 5.

Creating Variant Transactions

Suppose you want to disable extensive access to sensitive data or hide certain screens from end users. In this case, transaction variants might be a viable solution. Transaction SHD0 offers the flexibility to create transactions and screen variants to hide specific menu options or buttons for various applications' dynpros.

For instance, user management via Transaction SU01 contains a number of sensitive data and critical tasks. Thus, not everyone should be able to see and execute all functionalities within this transaction. If you start restricting access through the role maintenance of authorization objects and the proposals, you may not entirely achieve a

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

sustainable role concept. You cannot prevent all access scenarios through these actions, and maintaining such specific proposal differentiation is cumbersome work. For example, you might only want to enable a user to display and lock some user co-administrators. With Transaction SU01, they can still see all the other buttons, regardless of what you restricted in the authorization profile. In the user's roles, you must maintain the authorization object S_USER_GRP only with ACTVT = 05, so that the co-administrator can only lock and unlock users.

Thus, you must clear all predefined authorization values in field ACTVT of the authorization object S_USER_GRP of Transaction SU01 via Transaction SU24 so that you can maintain various activities in the different role authorization profiles. Another option is using Transaction SU24 default data variants. Unfortunately, a poorly maintained authorization concept can also undo all this work, causing undesirable functionalities to remain available to a user.

With Transaction SHD0, you can limit the initial screen's visibility with a variant transaction and only display the lock/unlock icon. However, before creating a new variant transaction, you must customize a variant in Transaction SHD0, where you'll enter the initial Transaction **SU01** and enter a variant name (**ZSU01_USR_LOCK_MGMT**), as shown in Figure 2.49. Then, click on the create icon.

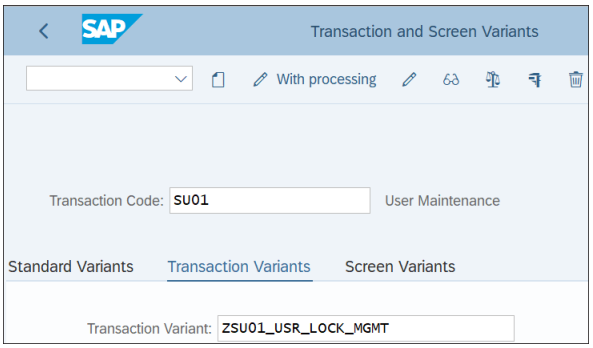


Figure 2.49 Transaction Variant Creation in Transaction SHD0

The system forwards you to Transaction SU01. If you enter a user ID and press Enter, Transaction SHD0 interrupts the process, as shown in Figure 2.50, because you must confirm the selected screen entries to make specific field entries and buttons invisible or visible in this popup window. To hide menu functions, click on the **Menu functions** button.

In this hierarchical structure, click on the options you want to hide from the Transaction SU01 main screen. For instance, you can enable only the **Display**, **Exit**, and **Lock** functions, as shown in Figure 2.51. The uncolored lines are the enabled functions. Click on the checkmark icon to save these settings.

Personal Copy for Arun Singal, arun.singal560@gmail.com

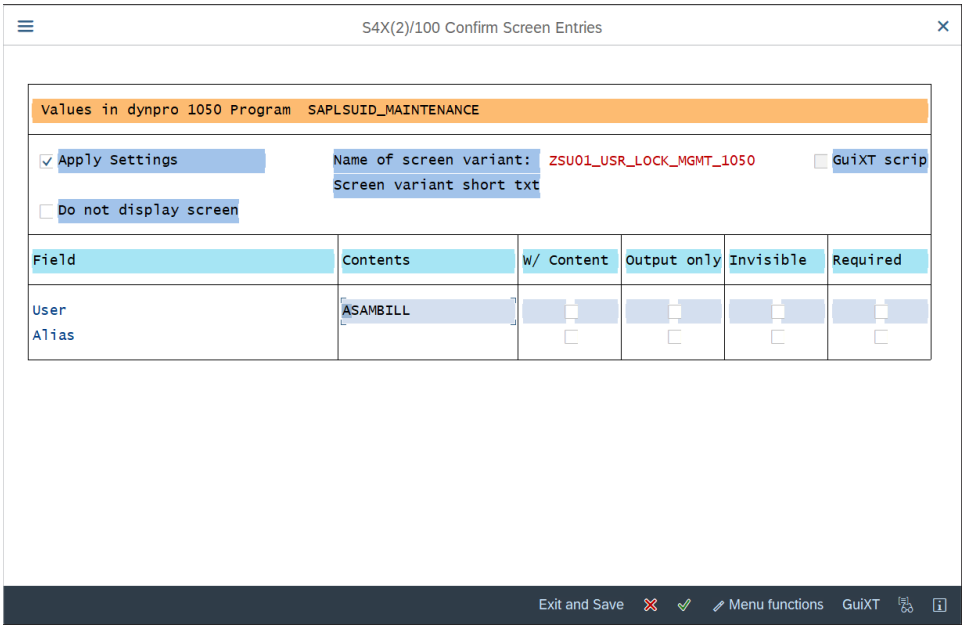


Figure 2.50 Popup Window for Defining Screen Variants in Transaction SHD0

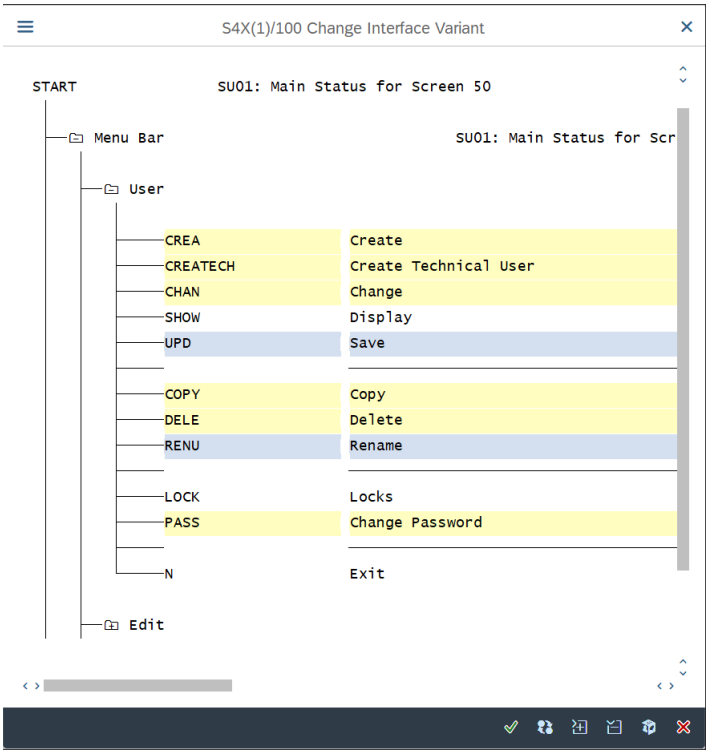


Figure 2.51 Change Menu Options in Transaction SHD0

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The system opens a new popup window displaying an overview of your variant settings. You can enter, for example, a short description for your variant or modify your customizing. Finally, save the variant through an object directory package and a workbench request.

Once you've saved the transaction variant, launch Transaction SE93 where you can create a custom transaction of type variant transaction, as shown in Figure 2.52.

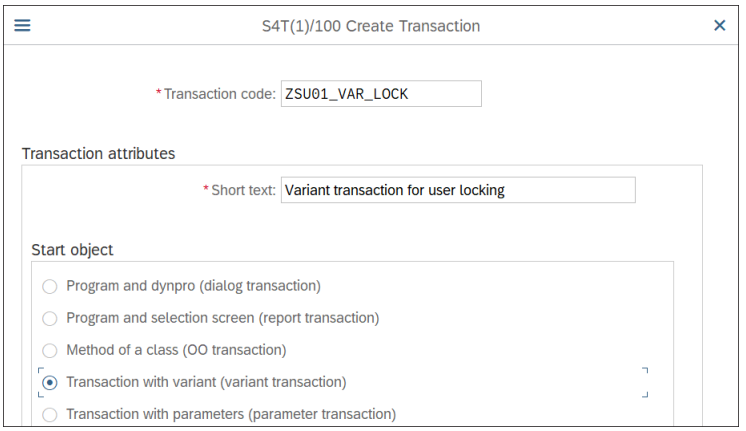


Figure 2.52 Creating a Variant Transaction

In the next maintenance window, enter the initial transaction for your variant transaction (i.e., Transaction **SU01** in the **Transaction** field) as well as the **Transaction variant** (**ZSU01_USR_LOCK_MGMT**). Select the **Inherit GUI attributes** checkbox so your variant transaction receives all the attributes of Transaction **SU01**. Ensure that you've enabled the **Cross-client** setting because transactions belong to the systems' repositories, as shown in Figure 2.53. Afterward, save your new transaction variant.

Launch Transaction SU24 and maintain the target proposals for your variant transaction manually or by clicking on the inheritance from Transaction SU01. This option enables you to check the proposed authorization objects in the initial transaction (Transaction SU01). Be careful while maintaining authorization objects, fields, and values. You should customize these items according to the specific purpose of your target transaction variant. For this example, only activities 03 (display) and 05 (lock/unlock) are necessary. Finally, maintain this new transaction in the role menu and generate the role profile. Then, assign the role profile to the targeted end user, test it, and, if successful, provide the transaction variant on the PRD.

Now, if a co-administrator executes our variant Transaction ZSU01_VAR_LOCK, the initial screen only shows the customized buttons. You've suppressed all sensitive data access and access to functionalities not required from the initial screen, as shown in Figure 2.54. The end user can only display, lock, or unlock users.

Personal Copy for Arun Singal, arun.singal560@gmail.com

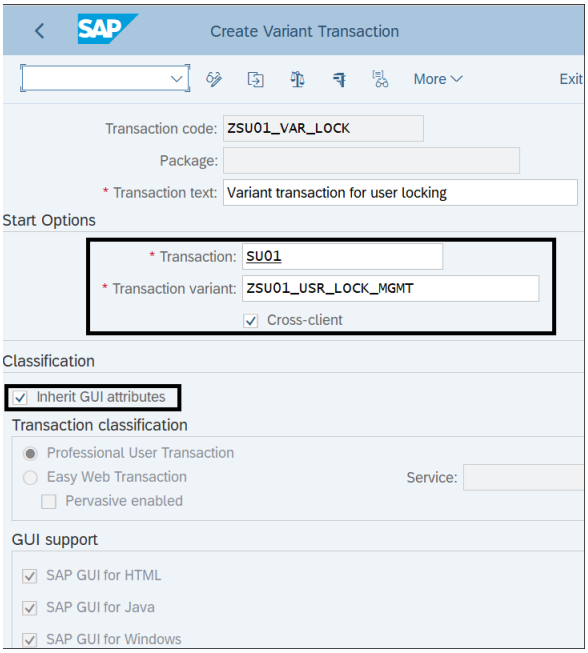


Figure 2.53 Variant Transaction ZSU01_VAR_LOCK Creation in Transaction SE93

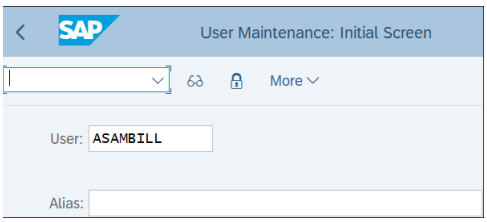


Figure 2.54 Initial Screen of the Variant Transaction ZSU01_VAR_LOCK

Creating Parameter Transactions

Concerning best practices for authorization concepts, you must consider generic access to sensitive data. For instance, Transactions SE16 or SM30, which provide extensive display or change options on tables, must be in scope. Although you should not assign these transactions to your end users directly, they might be required for the business, for example, to change exchange rates. This need is often not compatible with the security approach by SAP standard transactions. Therefore, you can use parameter transactions to avoid giving users generic table access. In this way, you can encapsulate a specific table view or maintenance action within a transaction, thus reducing risky table access or the manipulation of sensitive data. Also, parameter transactions allow for the proper definition of authorization proposals in Transaction SU24.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Suppose production management has a business need to check table AFRU to see order confirmations directly. Before assigning Transaction SE16 or assigning the authorization object S_TABU_NAM manually with table AFRU to a role, consider using a parameter transaction. You can create a transaction that also calls the initial Transaction SE16. But by predefining the parameter value with table AFRU, we force the end user to jump directly into that table without them seeing the initial selection screen of Transaction SE16, as shown in Figure 2.55.

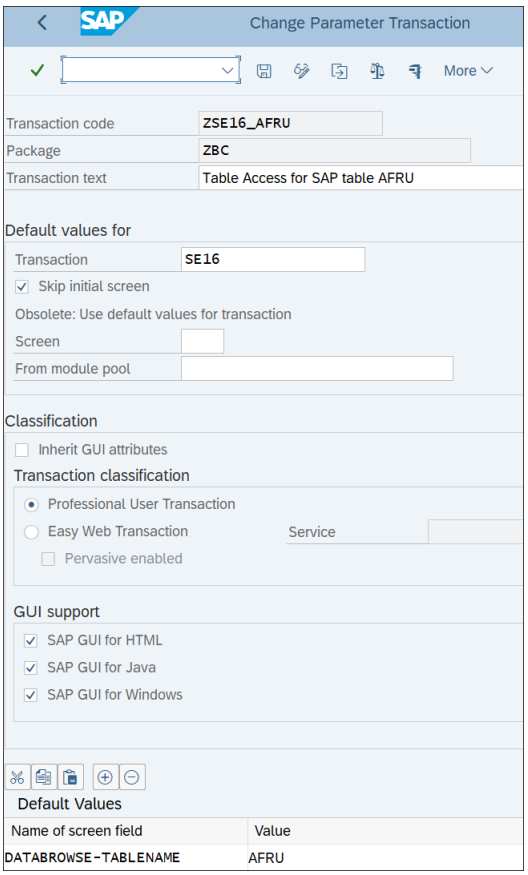


Figure 2.55 Parameter Transaction for Access to Table AFRU

Launch Transaction SE93 to create a parameter transaction. Enter a meaningful transaction name and a short description. In the **Default values for** section, enter Transaction SE16 and select the **Skip initial screen** checkbox. You must choose this option because, otherwise, you would provide generic access via Transaction SE16 again. This flag directly forwards the end user to table AFRU instead of the initial screen of Transaction SE16. In addition, do not forget to set value of the **DATABROWSE-TABLENAME** field as **AFRU** in the **Default Values** area shown in Figure 2.55. Also, consider activating all the checkboxes under **GUI support**.

Personal Copy for Arun Singal, arun.singal560@gmail.com

The last step for creating your parameter transaction is integrating the required proposal values in Transaction SU24. Thus, you must maintain authorization object S_TABU_NAM with the relevant values, like table AFRU and ACTVT 03, for our example parameter transaction ZSE16_AFRU. By doing so, the system proposes the required authorization objects and values with a where-used list in the authorization profile if you add the custom parameter transaction to the targeted role menu. According to Transaction SU24 maintenance, you might consider breaking the inheritance from the initial Transaction SE16. The inheritance is active by default through the parameter connection in Transaction SE93. Based on this setting, the system initially proposes the authorization objects S_TABU_NAM and S_TABU_DIS to the parameter transaction from the initial Transaction SE16. Indeed, you have a predefined table call to table AFRU and thus do not require the open authorization objects S_TABU_DIS and S_TABU_NAM. Instead, only enter the fixed parameter AFRU and activity display (03) for S_TABU_NAM as the authorization default values.

With this approach, you guarantee sustainability in your role concept because whoever adds a parameter transaction to the role menu gets fully proposed authorizations. Thus, a role administrator no longer needs to figure out the required authorizations for the custom development to maintain it in the authorization profile.

Hint

You can see all existing parameter transactions within your SAP system in table TSTCP.

Transaction Creation for Separated Proposal Data

Sometimes, end users must receive different authorizations through the same application. This use case is hard to manage with the SAP authorization default value set if you do not want to corrupt your role and user concept with manual authorization objects or require high role maintenance effort. Therefore, you can create different types of transactions based on an initial transaction and adjust the proposal values differently to handle the various authorization demands of various end users. For instance, to separate display and maintenance of business partners, you can create two custom dialog transactions based on the initial base Transaction BP.

First, start Transaction SE93, enter a meaningful transaction name (for instance, "ZBP_DISPLAY") and an appropriate short description. Please note that you must use the customer namespaces (staring with "Z" or "Y") for your custom transaction names. Also, choose the transaction type of the initial transaction. For this example, choose the **Dialog transaction** type. Afterward, copy all attributes from the initial transaction, Transaction BP, as shown in Figure 2.56.

Save your custom transaction as a repository object and in a workbench request. You've now finished your work in Transaction SE93 but still need to adjust the proposal

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

values in Transaction SU24. For our example shown in Figure 2.57, we've only maintained the **ACTVT** values **F4** (display in value help) and **03** (display) because we want a display-only transaction based on Transaction BP. For the correct authorization objects, copy the required proposals from the initial transaction or use the embedded trace options in Transaction SU24.

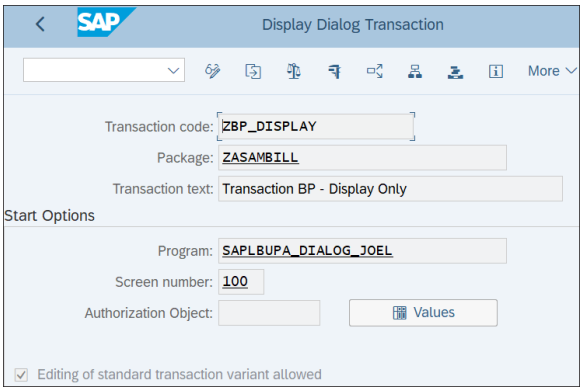


Figure 2.56 Custom Dialog Transaction ZBP_DISPLAY

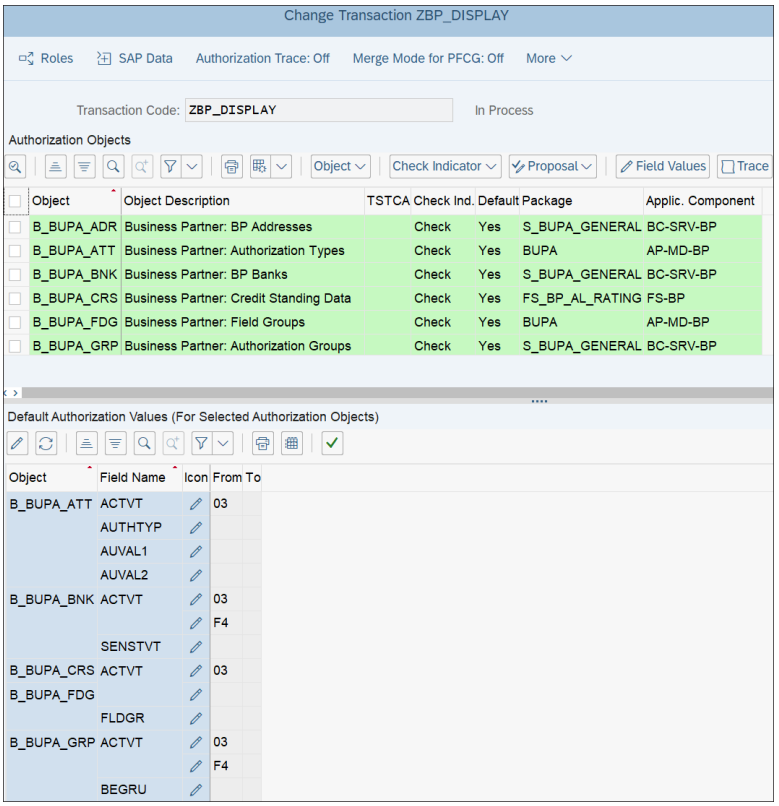


Figure 2.57 ZBP_DISPLAY Authorization Default Values Maintenance

Personal Copy for Arun Singal, arun.singal560@gmail.com

This individualization of proposal values for one transaction to meet different business requirements is a handy solution to differentiate your transactional access scenarios. You can now have two or more transactions with the same default objects but with various value definitions.

Hint

See Chapter 5, Section 5.3, for more information about a better way to maintain different authorization objects, fields, and values for the same initial application, using Transaction SU24 default data variants.

2.9.3 Locking and Unlocking Transactions

An SAP system offers features to lock transactions so that end users cannot start those transactions. But, of course, you can also unlock these settings again. This lock constitutes the first kernel check against table TSTC and determines whether a transaction is locked or not. Thus, you must know where you can adjust these settings.

Before BASIS version release 7.50, you would use Transaction SM01 to change these settings. With Basis version release 7.50 or later, the lock and unlock transactions functionality is encapsulated in Transactions SM01_CUS and SM01_DEV. Table 2.14 lists the differences between these two transactions.

Transaction SM01_DEV	Transaction SM01_CUS
Maintenance of the global application start lock.	Maintenance of the local application start lock.
Client independent (global).	Client dependent (local). (Exception: using Transaction SM01_CUS in client 000 can also be used for global locking.)
Locks can be transported through a workbench request (mandatory transport).	Locks can be transported through a workbench request (an optional feature to transport).
No locking restrictions exist, but this affects SAP and partner namespace transactions and is reserved for SAP and its partners only (see SAP Note 2234192).	Locking restrictions exist, except in client 000. This transaction is intended for customers instead of using Transaction SM01_DEV.

Table 2.14 Differences between Transactions SM01_DEV and SM01_CUS

Suppose you want to lock Transaction SCC5. Launch Transaction SM01_CUS, enter "SCC5" in the selection screen and select the **Not Locked** checkbox, as shown in Figure 2.58. Next, execute and select the value **SCC5** from the results list. You can lock the

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

transaction and transport this locking status to the subsequent systems via the header bar buttons.

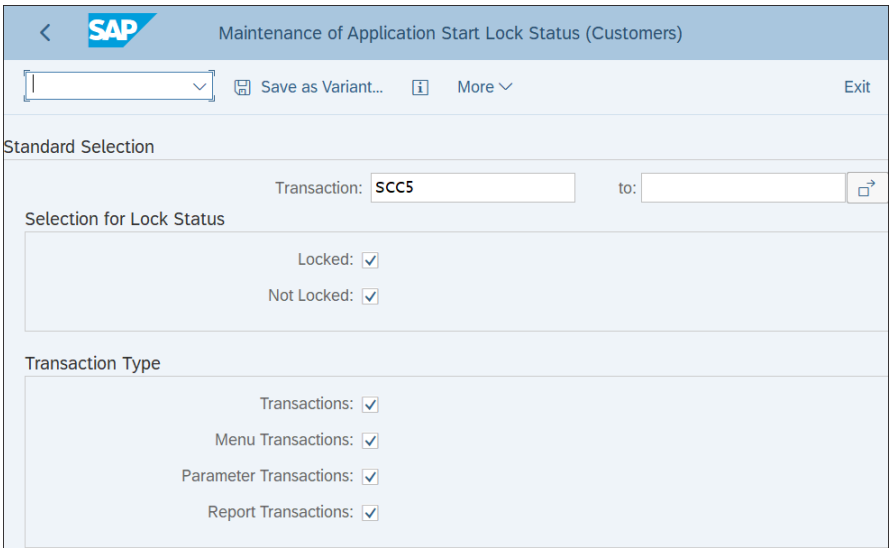


Figure 2.58 Selection Screen of Transaction SM01_CUS

Hint

Read SAP Note 2234192 for detailed information regarding Transactions SM01_DEV and SM01_CUS.

2.10 SAP System Check for Security Flaws

In the context of a secured SAP system, a periodic security analysis of your system landscape will be necessary. Especially for a PRD, you must handle various internal and external challenges that often change. A well-maintained authorization concept is half the battle; you also must check whether your system security level is still healthy and compliant over time.

In this section, we'll explain some selected analysis points as an initial guideline for SAP security analysis on a PRD. This section contains four primary areas of coverage: system configurations, documents, roles, and users.

Hint

This section covers a few options for conducting your security analysis and does not contain the individual or SAP customer-specific checks that you might have to add. This general guideline is for a first impression of how to carry out and assess a security

Personal Copy for Arun Singal, arun.singal560@gmail.com

analysis. The upcoming points are focused on PRDs and not, or only particular, to DEV or QAS layers, given their divergent objectives, needs, and settings.

Please note that this guideline also does not represent an overall SAP security check.

2.10.1 System Configuration Analysis

Individual system configurations are the basis for security. If you lack a secure system configuration, you cannot handle flaws within your authorization concept. Thus, you must initially configure the following parameters according to the upcoming recommendations:

- **System changeability**
  Check Transaction SCTS_RSWBO004 to determine whether your global settings, software components, and namespaces/name ranges are modifiable. Set these items to **N not modifiable**, as shown in Figure 2.59.

- **Client configuration**
  PRD clients must be secured against overwriting and copying data, as shown in Figure 2.60. The Basis team can adjust these settings via Transaction SCC4.

- **Security audit log configuration**
  The SAP Security Audit Log (SAL) feature can be active for all users and clients (*) in a PRD via Transaction RSAU_CONFIG, as shown in Figure 2.61. However, this setting often depends on your activated rules in SAL.

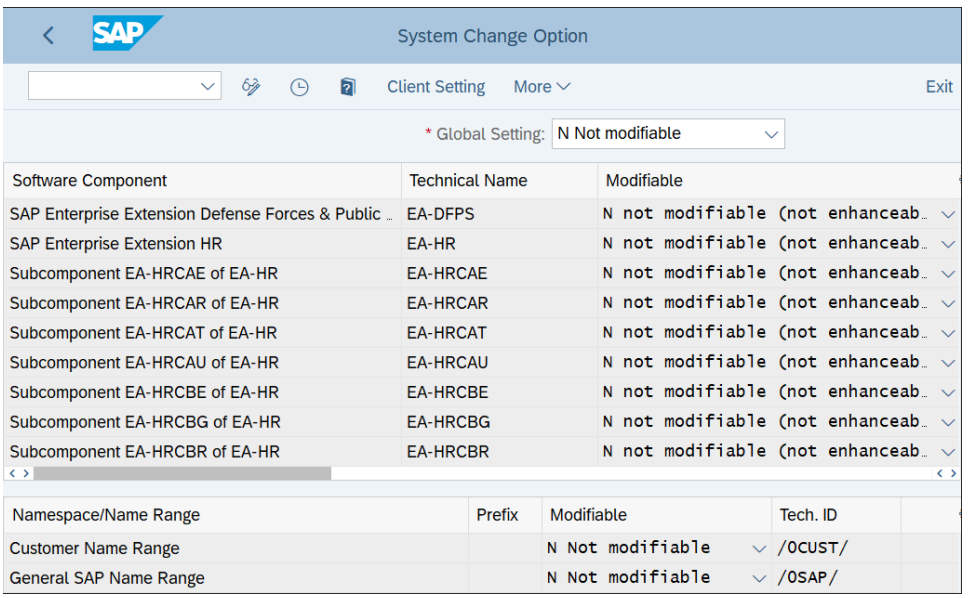


Figure 2.59 System Change Options

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

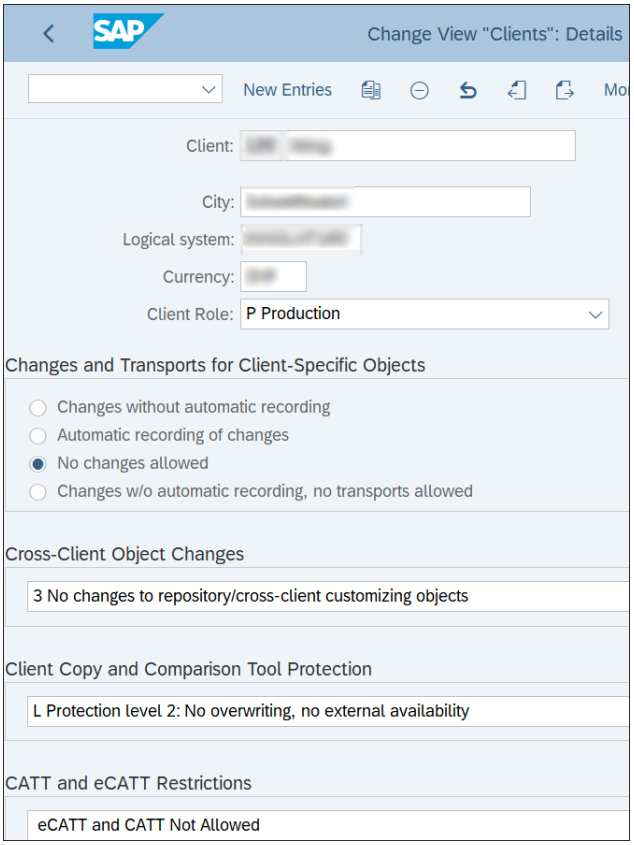


Figure 2.60 PRD Client Settings

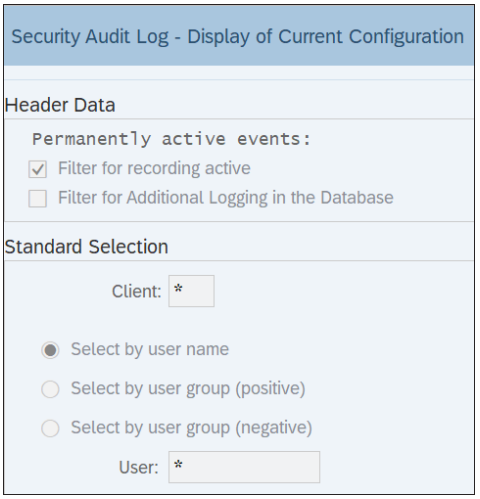


Figure 2.61 Security Audit Log Configuration

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Table auditing**
  Activate the table protocolling for the parameter `rec/client` through Transaction RSPFPAR, as shown in Figure 2.62. This option enables a far-reaching table auditing process. You must flag the parameter `RECCLIENT` in the transport tool as well via Transaction STMS.

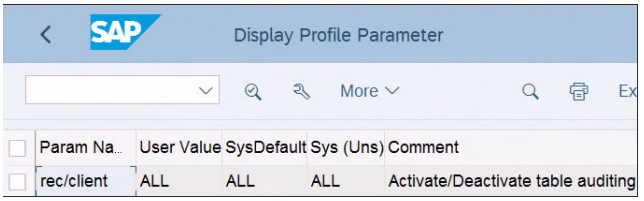


Figure 2.62 REC/CLIENT Parameter in Transaction RSPFPAR

- **Table security**
  You should check table `TDDAT` for the authorization field `CCLASS` with value `&NC&` via Transaction SE16. This analysis lets you see how many tables lack an assigned table group, as shown in Figure 2.63. Please note that the generic table group **&NC&** poses a significant security flaw if an end user has this table authorization.

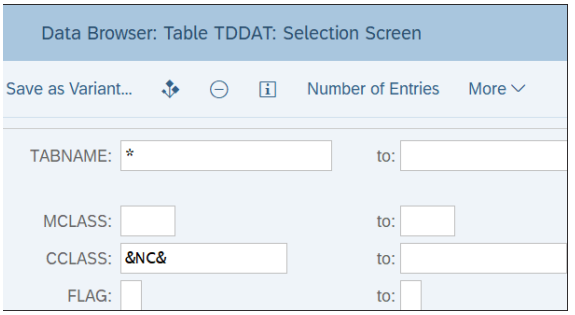


Figure 2.63 Tables within the Generic Table Group &NC&

Hint

For further information regarding table access, Section 2.7.1.

- **Transaction SU25 update**
  Authorization default values must always be up to date according to your current SAP release. You can check this area through Transaction SU25 through the timestamps for step 2 or directly by comparing tables `USOBT` and `USOBT_C` through Transaction SE16. The timestamps must be equal to the latest Transaction SU22 data import.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Chapter 1, Section 1.6, explains this requirement in more detail.

2.10.2 Document Analysis

You must have a written SAP security concept for transparency and the documentation of every regulation and requirement in your authorization concept. Only having technically integrated your security concept into your system is not sufficient. The minimal standard for documentation is a comprehensive authorization concept outlining all role and user strategies as well as authorization restrictions. This documentation should also contain information about company-related critical authorizations and SoD. In a nutshell, this concept should contain all SAP security-related topics like those explained in this chapter. Especially for authorization concept content, you can align relevant information from this chapter.

We also recommend integrating related concepts like a company-wide IT regulation, EAM, and high-privileged user (HPU) concepts.

2.10.3 Roles Analysis

Roles contain an end user's authorizations and grant a user access to data and the use of certain system functions. Therefore, given the importance of roles, they must be your analysis's primary focus. The SAP standard Transaction SUIM enables you to perform a comprehensive analysis of roles. Additionally, you should use reports RSUSRAUTH and RSUSR008_009_NEW via Transaction SA38 to analyze your role concept for critical authorizations and SoD. To integrate entire authorization rule set definitions as variants in your analyses, you must create them via Transaction SU_VCUSRVARCOM_CHAN before using report RSUSR008_009_NEW. Combined with checking tables like table AGR_1251, these essential tools enable full role authorization evaluations against the SAP standard.

As you create your analysis, keep the following points in mind:

- **Role quality**
  Using applications in an SAP system is based on end-user roles with their maintained authorizations in SAP standard. Therefore, roles can guarantee sustainability and transparency for your authorization and user concept. Thus, assigned role authorizations and their maintenance quality are essential. Consequently, you must analyze role quality to identify possible security and role maintenance issues. Table 2.15 lists some scenarios you should assess during this analysis.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Scenario	Focus of Analysis
Missing where-used list in roles and possible overauthorization	Manual authorization objects
Role profile generation issues	Open authorization fields or wrong maintained proposals
Critical data and organizational access	Intervals, asterisks, or critical authorization values in fields
Full or partial system access	Authorization values with an asterisk (*)
Organizational access issues	Missing or incorrect role derivations

Table 2.15 Role Quality Analysis Scenarios

- **Critical authorizations and SoD**
  Critical transactions, authorization objects, and their combinations can always cause security issues and flaws. Not only should you focus on critical or generic transactions like Transactions SE16, SM30, SM34, SA38, SE37, and SE38; you should also review other system and administrator transactions in end-user roles to uncover critical business transactions and conflicting combinations of them. For instance, Transaction ME21N enables users to create purchase orders, and Transaction ME29N enables users to release purchase orders. Having both transactions is an SoD conflict and overrides the four-eyes principle by granting overlapping critical business permissions to a single person. Commonly, a high number of SoD conflicts will be uncovered during an initial analysis of a big enterprise. Therefore, you should contact your business departments, key users, process owners, and module owners for a list of critical permissions and processes. Please note that you should not only focus on transactions but also on authorization objects and their values. The authorization objects, fields, and values provide the most system access, while transactions are simply technical shells.
- **Critical access scenarios**
  About 3,500 different authorization objects exist in SAP Business Suite. Some of these authorization objects provide critical access to any data in the system. Thus, you always must analyze whether such authorization objects are implemented in your role concept. Table 2.16 lists the primary critical authorizations that could provide unwanted access or functionalities. You can enlarge this list with many more **S_*** Basis authorization objects and others like **P_*** for HR authorization objects. Note that Table 2.16 is only an overview of various scenarios to get started on an initial work scope.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Scenario	Authorization Object
Data Access	S_TABU_DIS S_TABU_NAM S_TABU_CLI S_TABU_LIN S_TABU_SQL
Change Documents	S_SCD0
System File Access	S_DATASET
Program Access	S_PROGRAM S_PROGNAM
Development Access	S_DEVELOP
RFC Access	S_RFC S_RFCACL S_ICF
System Administration	S_ADMI_FCD S_RZL_ADM S_RFC_ADM S_SECPOL
Job Administration	S_BTCH_JOB S_BTCH_NAM S_BTCH_NA1 S_BTC_ADM
Transport Administration	S_TRANSPRT S_CTS_ADMI S_CTS_SADM
User Administration	S_USER_AGR S_USER_GRP S_USER_PRO S_USER_ADM
Spool Administration	S_SPO_ACT S_SPO_DEV S_TMS_ACT
Archive Administration	S_ARCHIVE

Table 2.16 Selected Critical Authorization Objects

Personal Copy for Arun Singal, arun.singal560@gmail.com

Scenario	Authorization Object
Cost Center Accounting	K_CCA
Profit Center Accounting	K_PCA
Internal Orders	K_ORDER
HR Master Data	P_ORGIN
HR Reporting	P_ABAP

Table 2.16 Selected Critical Authorization Objects (Cont.)

Hint

See Section 2.7 or Chapter 10 for more detailed information.

2.10.4 User Analysis

As a consequence of the role analysis, another mandatory step is to check your users. Each user may have one or more roles assigned in their user master record, and therefore, in the combination of different assigned roles, additional SoD conflicts might also occur. Moreover, you must analyze the assignment of manual profiles and the SAP standard user's security. You can also use Transaction SUIM and its reports in SAP standard for these analyses. Be sure to check the following points when performing a user analysis:

- **Logon activity**
  First, check whether end users have logged on to the SAP system within the last 180 or 90 days using Transactions RSUSR200 or SUIM. A good idea is to lock (via an administrator lock) such dormant users because they represent a potential security issue. Dormant user accounts can potentially be abused without the real user being aware. Thus, you won't know the real person behind the malicious actions. Moreover, you might be paying for licenses that are not in use.

  Figure 2.64 shows you the criteria to set in the initial selection mask.

- **Common SAP standard profiles**
  SAP manual standard profiles like SAP_ALL and S_A.SYSTEM provide nearly all system administration authorizations. No end user should have these profiles or any other manual profile; otherwise, you'll undermine your authorization concept as well as your data and system security.

  Also, keep an eye on possible SAP standard roles that might contain excessive authorizations. Again, you can perform this analysis easily with Transaction SUIM.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

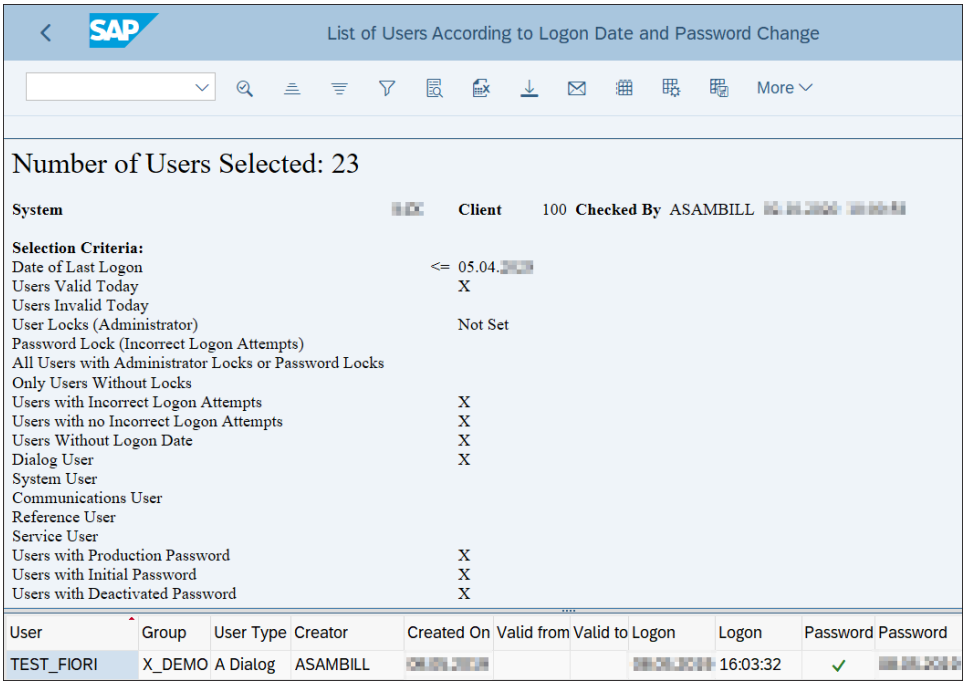


Figure 2.64 Selection Criteria for End-User Logon Analysis

- **SAP standard users**

  Always check whether SAP standard users like DDIC, SAP*, SAPCPIC, or EARLYWATCH are locked by the administrator, when currently not required, and have the user type SYSTEM or DIALOG. Also, the initial password must be changed (e.g., for RFC connections or background jobs). These users constitute a high system access risk because the default passwords for these users are easily available on the internet. Furthermore, these users might have many system authorizations, and you should only unlock them if you need them for internal system actions or upgrades. Finally, please note that you must not delete these standard users because they are required for many system processes and SAP standard processes.

  You can perform a detailed analysis for these users via report RSUSR003 in Transaction SA38, as shown in Figure 2.65.

Hint

Please note that you can only lock the standard user DDIC if this system user is not involved in the import job RDDIMPDP. See SAP Note 1998382 for more details on this topic.

Personal Copy for Arun Singal, arun.singal560@gmail.com

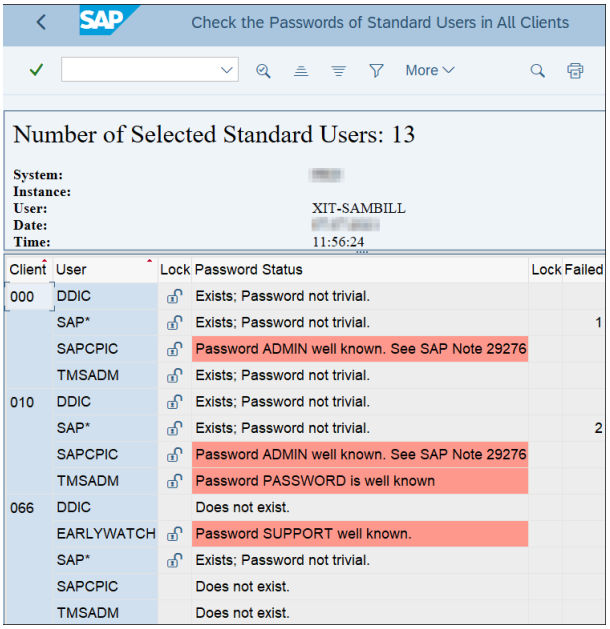


Figure 2.65 Analysis of SAP Standard Users

2.11 Customizing of SAP Security Settings

At the end of this chapter on ABAP authorizations with all the theoretical parts, advice, and best practice hints, we must also focus on specific SAP security settings. The optimization of these settings might improve the overall SAP system behavior and avoid possible inconsistencies. The definitions of these general security settings are located in tables PRGN_CUST, SSM_CUST, and USR_CUST. Please note that they contain many different adjustment options, and some settings may have a visible and noticeable effect on users. In addition, these settings also have dependencies in your existing authorizations concept.

Therefore, the following section explains the different tables with their adjustment options and provides some best practice recommendations for customizing these settings. Through these settings, you can maintain secure, optimized, and sustainable customizing for your profile generator, solution manager, and users.

Hint

For table maintenance, use Transaction SM30. Enter the table name and and access the matchcode feature by pressing F4 to check the available parameters. All table adjustments have a cross-client impact, and you should keep in mind that some entries might not exist in the value help, for instance, the value SU2X_SET_FORCE_MIX for table PRGN_CUST.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

2.11.1 Table PRGN_CUST

The profile generator's customizing allows security administrators to define and change individual settings like the check processing for S_USER* authorization objects. Also, these settings affect preconditions for the user password generator or for proposal behavior. Please note that, if the values of customizing parameters GEN_PSW* are smaller than the default values, the system automatically switches them back to the system's default.

Table 2.17 lists some recommendations for table PRGN_CUST.

Parameter	Default Value	Recommended Value	Description
ADD_S_RFCACL	NO	NO	Gives full authorization to S_RFCACL in SAP_ALL. (SAP Note 2624572)
ASSIGN_ROLE_AUTH	ASSIGN	ASSIGN	Checks when assigning users to roles. If set to CHANGE, the administrator requires S_USER_GRP with ACTVT 02 for change and also S_USER_AGR with ACTVT 22 to assign. If set to ASSIGN, only S_USER_AGR with ACTVT 22 for assignment is necessary. (SAP Note 312682)
CHECK_S_USER_SAS	YES	NO	Activate the authorization object S_USER_SAS. (SAP Note 536101)
CLIENT_SET_FOR_ROLES	NO	NO	Apply the client-specific customizing setting to role maintenance. (SAP Note 1723881)
GEN_PSW_MAX_DIGITS	Up to 40	*	A maximum number of digits in the generated password. (SAP Note 662466)
GEN_PSW_MAX_LENGTH	Up to 40	*	A maximum number of the length in the generated password. (SAP Note 915488)

Table 2.17 Recommended Values for Table PRGN_CUST

Personal Copy for Arun Singal, arun.singal560@gmail.com

Parameter	Default Value	Recommended Value	Description
GEN_PSW_MAX_LETTERS	Up to 40	*	A maximum number of letters in the generated password. (SAP Note 662466)
GEN_PSW_MAX_SPECIALS	Up to 40	*	A maximum number of specials in the generated password. (SAP Note 662466)
PFCG_RFC_CONNECT	YES	NO	Allows importing roles via RFC. (SAP Note 511918)
SU2X_SET_FORCE_MIX	NO	NO	Directly introduces proposal changes in the role profiles. (SAP Note 1896191)
R3PERSISTENCE	NO	NO	Switch on support for SAP R/3 persistence adapter for the user management engine (UME). (SAP Note 770133)
REF_USER_CHECK	W	E	Checks while assigning a reference user whether the user type is REFERENCE. Parameter E forces the reference user type or shows an error. (SAP Note 513694)
USER_REL_IMPORT	YES	NO	Import role assignments for users. (SAP Note 571276)
PROFILE_TRANSPORT	YES	YES	Allows transporting generated role profiles when transporting the roles. (SAP Note 727085)

Table 2.17 Recommended Values for Table PRGN_CUST (Cont.)

2.11.2 Table SSM_CUST

You can adjust table SSM_CUST (Session Manager Customizing) parameters for the presentation of the end-user menu. These settings do not influence the authorizations but optimize the menu regarding the company requirements.

Table 2.18 lists some recommendations for the settings of table SSM_CUST.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Parameter	Default Value	Recommended Value	Description
ALL_USER_MENUS_OFF	NO	NO	Do not display the user menu on the SAP Easy Access screen. (SAP Note 380029)
CONDENSE_MENU	NO	NO	Eliminates redundancies in the role menu. (SAP Note 203994)
DELETE_DOUBLE_TCODES	NO	YES	Deletion of redundant transactions in the role menu. (SAP Note 1246860)
SORT_USER_MENU	NO	NO	Alphabetically sorted user menu. (SAP Note 322853)

Table 2.18 Recommended Values for SAP Table SSM_CUST

2.11.3 Table USR_CUST

Table USR_CUST contains some options user customizing options, as listed in Table 2.19.

Parameter	Default Value	Recommended Value	Description
CHECK_NONPW_LGNDATA	<SPACE>	X	Check for activity 36 during the change of non-password-based logon data. (SAP Note 1882254)
PRGN_PROF_PREFIX	<SPACE>	*	Namespace adaptation for generated profiles. (SAP Note 1380203)

Table 2.19 Recommended Values for Table USR_CUST

2.12 Summary

SAP authorizations are an essential part of any SAP system. They control what end users can see and do in the system and which data they can access. Thus, authorizations are required to protect your data and your business processes. The capabilities and opportunities of using authorizations and how to use them to your advantage are versatile and complex. Thus, a mandatory skill for any SAP security administrator is knowing how to handle and maintain an enterprise-wide authorization concept concerning its business needs. You also must focus on the security and sustainability of your authorization concept so that you can guarantee a secure and compliant system.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Again, authorizations are the basis of all SAP Business Suite access, which is based on program source code. Staying in control of your authorization management avoids compliance flaws and security issues. Security issues can lead to a poor corporate development and system landscape.

This chapter covered IT and SAP security principles and described how authorizations work at their root. Therefore, we introduced you to the basics like the influences of and principles behind an authorization concept. Furthermore, you were introduced to the complex components within ABAP authorizations, to authorization default values, to varying namespaces, and to the creation of custom authorizations. Since this chapter provided an extensive overview, we also covered topics like users, roles, profiles, and transactions. Furthermore, this chapter also included information necessary to understand the entire processing of ABAP authorizations and various critical or specific authorizations, like system or SAP ERP HCM authorizations. Finally, we provided insight into various security parameters and system settings and described how you can use numerous tools to achieve a healthy security level.

By using and implementing the information from this chapter, you'll be on track to establish an individual, comprehensive, transparent, and secure role concept aligned with business your demands. We'll discuss these concepts further in the next chapter.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 3
Designing Authorization Concepts

Designing authorization concepts is an ambitious task that requires thorough planning and deep understanding of the technical components of an authorization concept. You'll also need to understand fully how your organization runs its processes.

This chapter provides an overview of different role design concepts and approaches, including why to favor some over others and how to use them in practice. The overall goal of a role concept is to help establish maximum security, provide sufficient authorizations for end users to fulfill their job duties, simplify user maintenance, and help you sustainably maintain your roles.

Designing an authorization concept is a complex task with multiple drivers that must be taken into account. First and foremost, you must ensure that your end users can do their jobs and run the business, but at the same time, you'll need to adhere to access governance and compliance laws and regulations. The pitfalls of a poorly designed authorization concept include loss of productivity, high maintenance effort, exposed risk for the organization, failure in audits, inefficient access provisioning, and many more. Therefore, properly thinking through a concept that is sustainable, maintainable, transparent, and upgradable in the future is vital.

Ideally, your company discusses and addresses security considerations before an actual implementation. However, more often, companies have not proactively addressed security design beforehand and are thus challenged with costly role redesign projects shortly after go-live. All too frequently, companies change, expand, and merge with or acquire other companies, thus resulting in changes to the security design. A solid and sustainable design must be flexible enough to adjust to these changes.

3.1 Role Design Approaches

For various reasons, as shown in Figure 3.1, a company may consider (re)designing its authorization concept. The main drivers are system upgrades (e.g., migration to SAP S/4HANA); remediation of compliance issues, such as segregation of duties (SoD) or legal requirements; mergers and acquisitions that lead to integration projects; or simply because the current design is not maintainable and access governance cannot be ensured.

Personal Copy for Arun Singal, arun.singal560@gmail.com

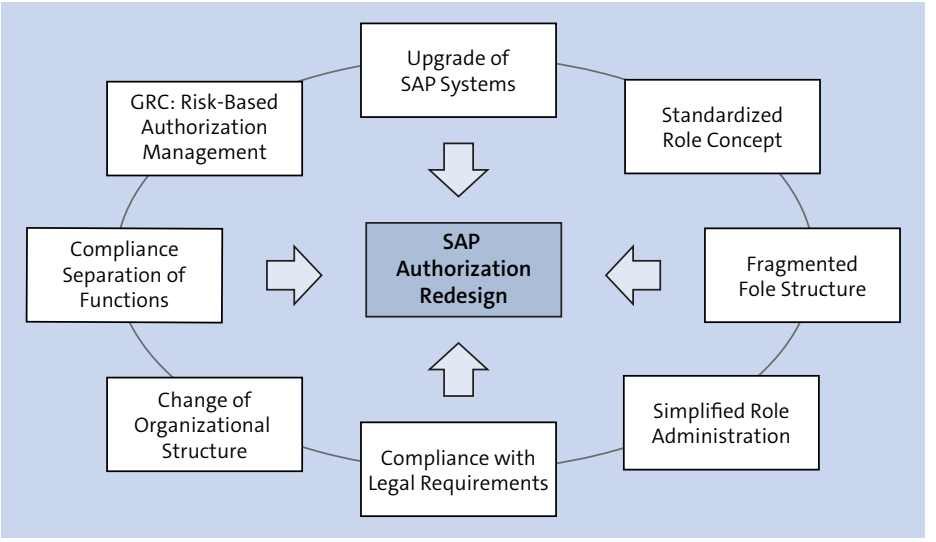


Figure 3.1 Reason for Authorization Redesign

Figure 3.2 shows some important trends regarding role design.

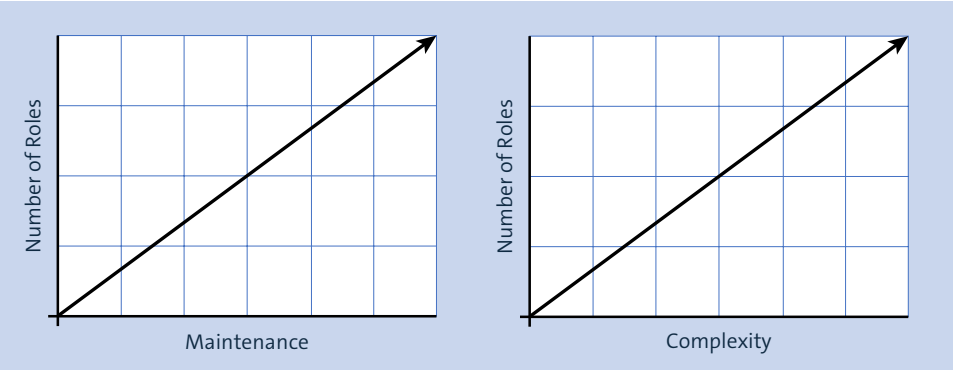


Figure 3.2 Role Design Complexity and Maintenance Effort

Regardless of the approach taken, your role concept should be as simple as possible to ensure that the investment is sustainable and long term. The number of roles should (if possible) be kept small and specific so that maintenance overhead is reduced. Complexity can be reduced when utilizing function-related (job-related) single roles. This approach increases flexibility and transparency for future adjustments of business processes, especially when considering a risk approach due to SoD or other compliance regulations.

Implementing an authorization concept can be performed in multiple ways. Two main approaches exist for building an authorization concept, but a hybrid of the two approaches can also be adopted. The first approach is the "top-down" approach, which

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

is a proactive way to design and conceptualize the necessary authorizations upfront, based on an analysis of business processes and job functions. With the "bottom-up" approach, the analysis starts with the available statistical usage data as well as with existing authorizations and their assignments.

Both approaches have their pros and cons. The "top-down" approach helps address security risks and requirements during the blueprinting phase but might prove to be difficult to implement. This approach requires a deep knowledge of the business processes, laws and regulations, and security implications like financial and audit requirements. The "bottom-up" approach is particularly difficult when remediating SoD conflicts, which requires inputs and an understanding of the business processes performed by business process managers. Without this knowledge, this approach tends to lead to a high number of roles built specifically to remediate SoD conflicts, which can lead to difficulty in provisioning as well as negatively impact the maintainability and sustainability of the authorization concept. This potential issue stems from the fact that, in most cases, SoD conflicts are avoided on the role level, which requires a separation of each job function.

Let's now briefly summarize the two approaches:

- **Top-down approach**
  Information will be acquired by interviews and an analysis of the business processes performed in your organization:
  - Analysis of business processes
  - Jobs within processes
  - Core activities
  - User groups
- **Bottom-up approach**
  Information will be acquired by an analysis of the current system and its user history data:
  - Existing authorizations
  - Existing role assignments and users
  - Use of transactions and other menu objects
  - Existing organizational restrictions in the system

To further highlight the difference between the bottom-up and top-down approaches, to summarize, the bottom-up approach uses existing data (transaction usage, current role and authorization assignments, etc.) to drive the role design. In contrast, the top-down approach utilizes business processes to shape the role design. Regardless of the approach, defining security requirements early in the project is important as being proactive helps ensure efficiency during implementation. In addition, we recommend leveraging tools like SAP Access Control or similar solutions, to analyze and monitor role design to address potential SoD violations early on.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Combining both approaches allows for the best results when redesigning authorization concepts, as shown in Figure 3.3. You can take usage data and existing authorizations from the "bottom-up" approach and use that information to come up with a draft design. That draft can then be discussed with business process managers to separate out functions and fine-tune the design based on how your company runs its processes.

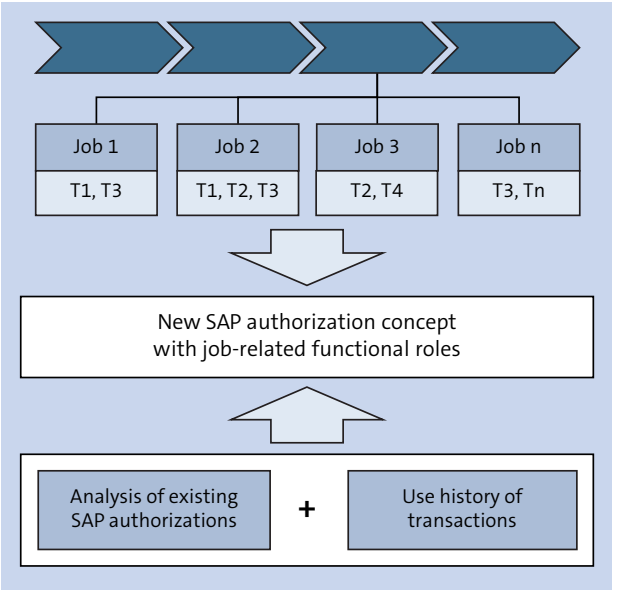


Figure 3.3 Top-Down and Bottom-Up Approaches

Before beginning the work of creating roles as part of your effort to enhance security in your SAP systems, an important decision must be made. You must decide between using *job-based roles* or *task-based roles*, and this choice will impact how your roles will be designed.

Let's briefly look at these two concepts next:

- **Job-based roles**
  Job-based roles are designed for including all of a person's job activities into one single role. For instance, a person with the position of a "sales order specialist" must perform certain activities such as creating, changing, and displaying sales orders. A role encompassing all those activities for that position is an example of a job-based role design. Utilizing this role design method uses fewer roles by consolidating job duties into one role instead of creating a role for each individual job task. Be mindful, however, that this approach can be prone to SoD conflicts due to the broader access subsumed under one role. While utilizing this method, make sure you put effort into mitigating these conflicts.

  Using the top-down approach "to create your job-based roles, you first must analyze business processes and their jobs-related tasks. This analysis helps outline of how

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

the job-based role should look. Then, you'll move on to identifying the core activities within those jobs. This step assists with discovering the relevant transactions for the job-based role. Finally, you'll map out your user groups to help you assign users with the right role assignments. Knowing how users are grouped together (i.e., a department) allows for efficient job role assignments through user groups.

- **Task-based roles**
  In a task-based role design, a role is created for each job task within a job function. Continuing our earlier "sales order specialist" example, this position requires several tasks such as creating, changing, and displaying sales orders. In a task-based role design approach, a separate role will be created for each of the job task: One role will be designed for creating sales orders; another role, for changing sales orders; and the final role, for displaying sales orders—for a total of three roles. As a result, more roles are required in a task-based role in comparison to a job-based design where the role count would be one. SoD conflicts still need to be considered, but they may be reduced (on a role level) since access is more granular in these roles.

  Using the bottom-up approach" to create your task-based roles, you would first analyze existing authorizations. Being knowledgeable on existing authorizations allows you to gauge existing access levels. Combining this information with the next step while reviewing existing user role assignments, you can tailor appropriate access to users based on the tasks performed in their business functions. Finally, analyzing the use of transactions helps you select which tasks should be included a task-based role. Understanding how transactions correlate to the tasks helps you properly build roles for different areas of your business.

3.2 Role Types

From a technical point of view, only two types of roles are available in SAP—single roles and composite roles. Single roles can further be divided into child roles that only differ from the parent role on the organizational level. However, many organizations have additional "types" of roles, for example, enabler/value roles, which technically are still single roles but have distinct intentions.

3.2.1 Single Roles

A single role contains all the necessary authorization objects and field values (organizational and non-organizational) required for the transactions that the role contains. In SAP, many authorization objects are represented by two types of authorization fields: the activity field and the organization value field. Technically, you cannot separate these two fields because the kernel evaluates them together during an authority check, and thus, both fields must be defined in the same role.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

See Chapter 2, Section 2.2 for more information about the cumulative aspect of SAP authorizations.

However, a single role can have multiple individual authorization instances to represent different combinations of field values when these values cannot be merged into one authorization instance to be evaluated by the system check. Thus, a single role can also be a composite of authorization instances.

Typically, when someone talks about the single role concept, they are referring to a job-/position-based role design. In such cases, the role contains all the required authorizations for a user's job/position in a single role. A user might, however, have more than one job/position, such as a purchaser and a contract manager. Each role has authorizations to complete the transactions that are contained in each of the two single roles so that they are functional on their own. With this approach, no dependencies exist.

However, many "single role" designs won't contain all of a user's required authorizations. Some employees might have additional authorizations to execute special tasks. As a result, such employees may get an "additional access" single role assigned to them, for instance, with the ability to close accounting periods or approve purchase requisitions. Figure 3.4 shows an example concept of functional roles. Likewise, a common practice, as shown in Table 3.1, is to create a "basic authorization" role that contains transactions and authorizations that are common for all users, for example, the ability to print or to access office mailboxes in SAP.

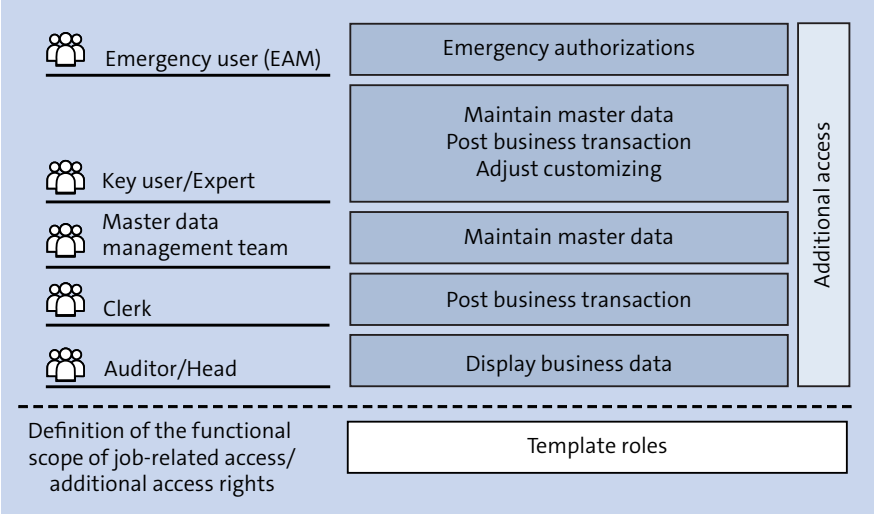


Figure 3.4 Concept of Functional Roles

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Types of Role	Subtypes	Explanation
Single Roles	Template roles (Layer 00)	The role is used in the project (design phase) as a template (master role) for all singles role to be created.
	Function-related (job) roles (Layer 01-05)	Terms for the creation of functions or job profiles within the business processes such as accountants, buyers, sellers, Basis administrators, SAP developers, etc.
	Special roles (critical) (Layer 06)	Assigned for specific use or critical authorizations (such as SoD, SFX, FDA, DSG) and are targeted at specific users.
	Special roles for controlling (Layer 06)	This is only used if the requirement is to make restrictions in the area of controlling, such as cost centers, orders, profit centers, etc.
Composite Roles	Function-related roles	Terms for the summary of the function-specific roles and special roles (such as accountants, buyers, Basis staff, etc.

Table 3.1 Types of Roles and Subtypes

Likewise, you can also use single roles for role derivation. Derived roles consist of a master or parent role and additional child roles that differ from the master and from each other only in their organizational values. Please note that limitations exist with this approach. If you try to promote non-organizational fields to organizational fields, then, in this case, the values must all be the same within one role, regardless of which authorization object is using the field. In other words, you should not use different non-organizational fields in combination with derived roles because the values across all child roles will always be the same as the master role and will affect all objects.

Hint

Chapter 2, Section 2.3.5, contains extensive information about promoting non-organizational authorization fields.

3.2.2 Composite Roles

A composite role is a collection of single roles grouped together into a common composite role menu. As a result, you can indirectly assign multiple single roles to a user by assigning a composite role that contains single roles. However, you may be tempted to build numerous smaller single roles without considering the required user assignments.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Many businesses using SAP leverage composite roles to reduce the number of direct single role assignments to users. However, this approach often leads to less transparency, higher effort for maintaining more roles, and an increased risk of accidental inheritance of incorrect authorizations from a single role impacting multiple composites. The ability to change single roles rapidly leads to the side effect of having more single roles to maintain.

Technically, a composite role is a bundle of single roles to map a task-level single role (in the worst case, a transaction-level single role) to a broader role. The goal of a composite role is often to simplify the assignment of roles to users since composite roles often represent a job function. In addition to the number of single roles that may result, your organizational structure and its changes can also play a role in the choice of approach.

3.2.3 Enabler Roles

In recent years, we've seen role concepts in which the SAP standard has not been followed. These concepts are often called *enabler role concepts* or *value role concepts*. In these concepts, you would separate organizational authorization values from functional authorizations, which results in the need for two roles to execute a transaction successfully.

In these authorization concepts, a functional role contains all the authorization objects and values, but not the organizational level. A second, also required, enabler role contains the "missing" organizational values and enlarges a user's authorizations. Thus, to successfully execute a transaction, a user requires both the functional role and its corresponding enabler role.

The idea behind enabler roles lies in the desire to isolate organizational fields and simplify user assignments when it comes to purely organizational, non-functional distinctions.

However, any organizational type of field, which also has an "activity" field in the same authorization object, cannot be separated into a different role. This limitation is almost always the case in SAP authorization objects. Due to this absolute disadvantage, enabler roles sometimes cannot work as designed, which typically results in a proliferation of authorizations in enabler roles and the number of enabler roles, which often exceeds the number of users.

The enabler role concept sometimes looks tempting on paper, and some businesses might expect enabler roles to behave similarly to organizational management in SAP ERP Human Capital Management (SAP ERP HCM). However, you cannot apply it to authorization objects and role-based authorization concepts nor to the modern menu-based visibility access concepts, such as SAP Fiori applications and SAP Enterprise Portal/SAP Business Warehouse (SAP BW) reporting.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

In addition to enabler roles for organizational values, subsets of your authorization concept can benefit from implementing enablers, for example, to restrict access to controlling scenarios or to implement a release strategy for purchase orders.

In purchasing, for example, a release strategy for purchase orders is defined, which means that purchase orders released through Transaction ME24(N) require specific authorizations. The release strategy might define the required approval level based on the purchase order amount. A user who wants to approve a purchase order requires the correct release code and release group authorizations through authorization object M_EINK_FRG. Since approval limits are sometimes not directly related to a job function, the release strategy is often defined in enabler roles that are individually assigned to users.

Enabler roles are special roles that can be valuable for maintaining a sustainable role concept while reducing the complexity that comes with including these special authorizations in job roles. For more information on how to determine when to use or not use an enabler role, see Section 3.4.

3.2.4 Authorization Templates and Standard Roles

SAP standard roles and authorization templates can serve as reference points for role creation so that you don't have to start from scratch when creating roles. SAP provides standard roles and authorization templates to find business authorizations and transactions that may be relevant to your business. Using these templates and roles as starting points can save time in terms of the research effort to identify authorizations and transactions for a particular role. Template roles usually have a wide coverage of authorizations, so they should be used as a reference to tailor roles to your business needs. For instance, the authorization template SAP_AIF_USER is for personnel responsible for error handling and monitoring interfaces. This template comes with a set of authorizations and transactions, such as editing fields, restarting, and canceling data messages. However, you must keep in mind that templates are valuable in sandbox and testing environments, but should be avoided in productive landscapes. Authorization templates are manually added authorizations that are far reaching. SAP standard roles are also far reaching, and the roles are routinely updated by SAP. As a result, during the next system upgrade, SAP-delivered roles are overwritten. Therefore, you should never use standard roles or standard authorization templates directly in your productive landscape as assignments to your end users. Standard templates and roles from SAP should only serve as reference points for building your own distinct custom roles.

To add authorizations from a template, follow these steps:

1. Go to Transaction PFCG.
2. Enter your role name and click on the kind of role you want to create (**Single** or **Composite**). In this example, we are creating a single role.

Personal Copy for Arun Singal, arun.singal560@gmail.com

3. Go to the **Authorizations** tab.
4. Click on the icon next to **Expert Mode** for **Profile Generation**.
5. As shown in Figure 3.5, follow the menu path **Edit** • **Insert authorization(s)** • **From template...**.

Using templates as a starting point, you can then tailor transactions and authorizations as needed for your company.

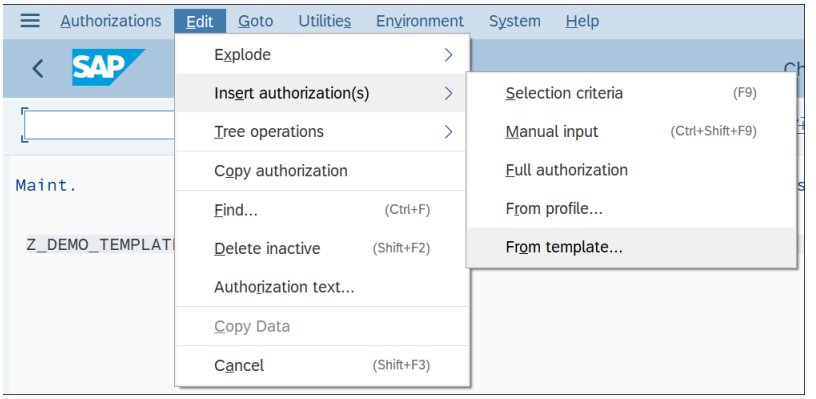


Figure 3.5 Inserting Authorizations from a Template

Please keep in mind that inserting authorizations from a template adds all the authorizations as manual objects, as shown in Figure 3.6. This approach goes against best practices but is helpful when trying to understand what authorizations are required. To properly authorize your roles, you should add the transactions through your role menu so that you can leverage authorization proposals from Transaction SU24.

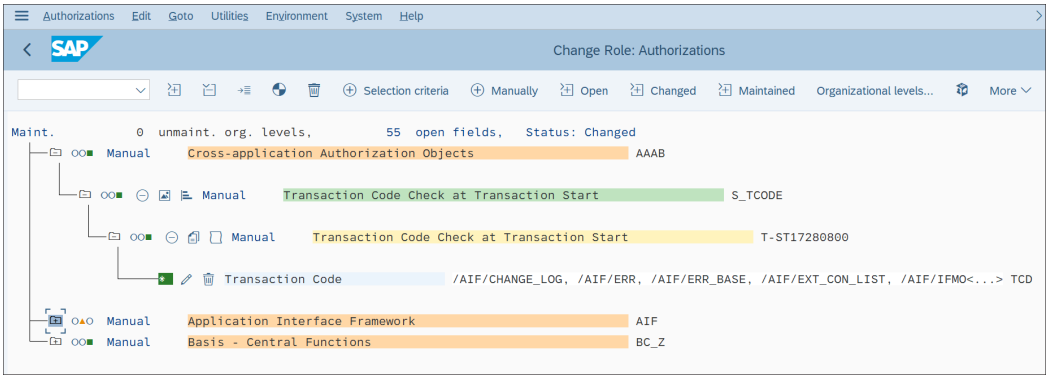


Figure 3.6 Manually Inserted Authorizations from a Template

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

In addition to using templates as a reference, you can also refer to SAP-delivered standard roles that are available in Transaction PFCG. SAP standard roles start with the prefix "SAP_".

3.2.5 Comparison of the Role Design Concepts

Table 3.2 provides a detailed overview of the pros and cons of the various role design concepts and is a product of years of experience and best practices. Earlier, Figure 3.4 showed a proposed model for building your own roles.

Requirements	Enabler Roles	Single Roles (with Optional Derivation)	Composite Roles
Effort of initial role definition	Well supported	Well supported	Partially supported
Possibility to optimize grouping of applications	Partially supported	Well supported	Partially supported
Possibility to individualize role assignments	Not supported	Well supported	Partially supported
Reduction of Functional/organizational redundancies	Partially supported	Well supported	Partially supported
Effort of functional role maintenance	Not supported	Well supported	Not supported
Effort of organizational role maintenance	Partially supported	Partially supported	Partially supported
Effort of user assignment maintenance	Not supported	Partially supported	Partially supported
Compliance in data protection at role level	Well supported	Well supported	Well supported
Compliance with SoD at the role level	Partially supported	Well supported	Well supported
Possibility of role mining	Partially supported	Partially supported	Not supported
Cascading of SAP role design	N/A	Well supported	Not supported
Reporting (auditing, transparency)	Not supported	Well supported	Partially supported

Table 3.2 Comparison of Different Role Designs

Personal Copy for Arun Singal, arun.singal560@gmail.com

Requirements	Enabler Roles	Single Roles (with Optional Derivation)	Composite Roles
Upgrade capability (e.g., enhancement packages [EHPs], SAP S/4HANA)	Not supported	Well supported	Well supported
Maintenance after role creation	Not supported	Well supported	Not supported

Table 3.2 Comparison of Different Role Designs (Cont.)

As shown in Table 3.2, building single roles (with optional derivation) is considered a best practice for SAP role designs. This approach offers the greatest flexibility, transparency, and the broadest support in terms of requirements and upgrades. On the other side of the spectrum, you might use enabler roles, which are the least flexible and have several design and maintenance disadvantages.

3.3 Segregation of Duties

No matter the approach you choose, you should always consider SoD during your role design. SoD is an internal risk management control used to separate critical functions of a business process among different individuals. SoD is an effort to lessen risks and fraud by preventing one individual from having too much authorization within a business process. A good demonstration of SoD would be separating the responsibilities of creating a purchase order and the receiving of goods to two different individuals. Leaving both purchasing tasks to one person can lead to increased risk of fraud because no control is in place to prevent an individual from engaging in fraud.

Keeping SoD in consideration during role design helps improve security by reducing the area where risks can occur and be exploited. Depending on your company's architecture, modeling the design of your SoD process can be time consuming and cumbersome. Thus, be mindful when creating your SoD policies and risk levels. SoD risk levels help your business prioritize risk mitigation. An example of risk levels could be critical, high, medium, or low. A critical risk in most cases would be prioritized over a medium- or low-level risk. This classification scheme helps a business control how and when risks are dealt with. Knowing the organizational risks and SoD rules can help you calculate the number of roles that need to be created when segregating access on a role level, as shown in Table 3.3. Regardless of which role design approach you choose, SoD should be an integral component of your role design process.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Number of Risks	Number of SoD Functions	Number of Organizations (Departments)	Calculation of Number of Single Roles
20	15 to 30	10 company codes	15 × 10 = 150 30 × 10 = 300
50	40 to 75	10 company codes	40 × 10 = 400 75 × 10 = 750

Table 3.3 Role Calculation Based on SoD

A few key aspects to keep in mind when considering SoD in your role concept include the following:

- Keep risks low. Discuss the necessity of specific risks with your internal and external auditors. More risk leads to more separation, and thus, more roles are required.
- Define the criticality of the specific risks by using risk levels (critical, high, medium, low, etc.). This approach helps you prioritize risks.
- Encapsulate SoD functions in separate roles only when risks have been defined with the highest criticality.
- Encapsulate SoD functions in separate roles only when risks have no defined mitigation. If mitigations and compensating controls are available, mitigate the risk rather than split on the role level.
- Encapsulate SoD functions in separate roles only when a functional separation is possible and can be implemented in the future organizational and procedural framework.

SoD can have a huge influence on role design, and you must determine on which level the separation should take place. At the end of the day, SoD conflicts matter on the user level but must be separated on the role level in order to fully remediate. However, depending on the risk and whether mitigations are available, SoD conflicts should be managed on the role level.

3.4 Determining When to Use Enabler Roles

The enabler role concept is a non-standard approach to role design. Its origins are based on the assumption that you cannot create a role that can display all items but only change a subset. Technically, this impossibility is because an authorization object with two or more fields will check all of them and require that they are present in the same role authorization.

Personal Copy for Arun Singal, arun.singal560@gmail.com

The following section describes a simple example of an enabler role for Transaction FK03 (Display Vendors). The single role contains the transaction (a transactional single role), and another single role contains the organizational values (the enabler role).

The transactional single role contains Transaction FK03 with all its authorization objects and values, as shown in Figure 3.7. The organizational level (**BUKRS** in this example) for object **F_LFA1_BUK** is left empty, or the authorization object is deactivated.

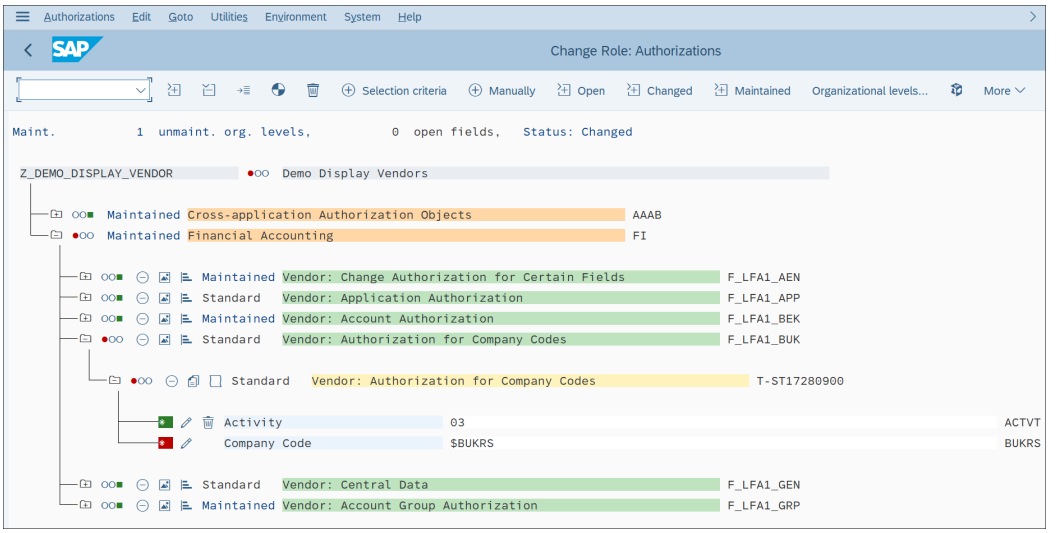


Figure 3.7 Example of the Transactional Role for Transaction FK03

A second role, the enabler role, contains the organizational values for authorization object F_LFA1_BUK only, as shown in Figure 3.8. No other authorizations—other than the objects with organizational values—are maintained in this enabler role.

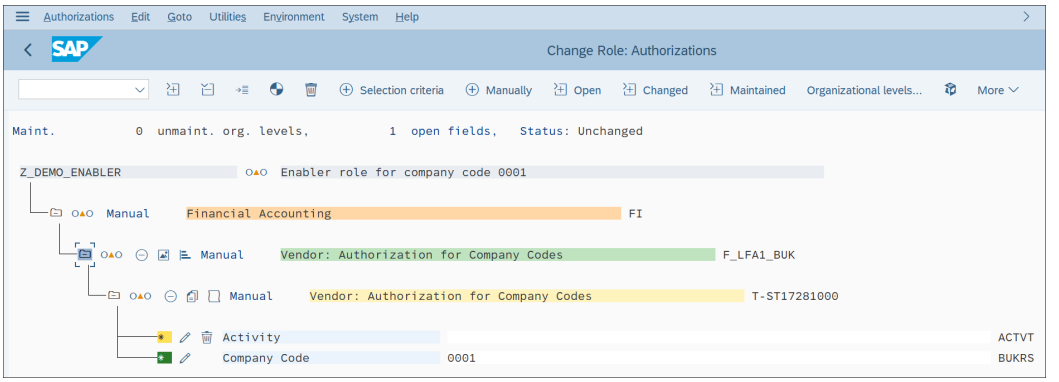


Figure 3.8 Enabler Role Containing Object F_LFA1_BUK

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

When the two roles are assigned to a user, you can check the user buffer to see the totality of assigned authorizations. In the user buffer (Transaction SU56), shown in Figure 3.9, you'll see the two authorization profiles assigned to the user, with two instances of the authorization object **F_LFA1_BUK** Notice how the **ACTVT** value **03** comes from the transactional single role, but the company code comes from the enabler role.

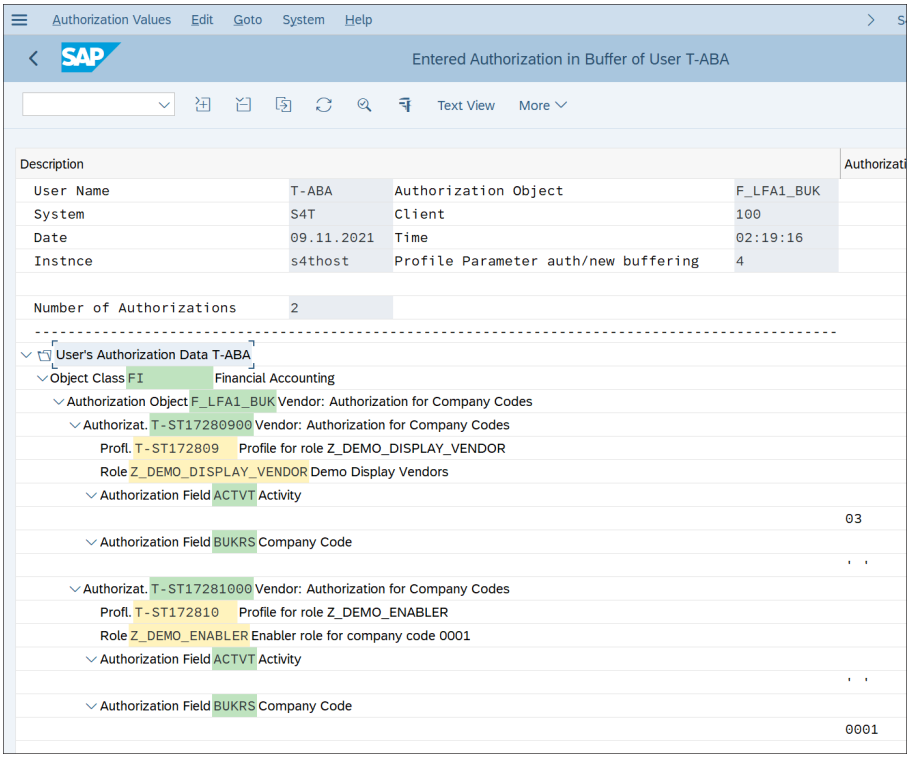


Figure 3.9 User Buffer of User with Both Roles Assigned

Since the two authorizations are in different authorization profiles, the authorization check does not succeed. This failure is because, when the kernel performs an authority check, it checks the values of one authorization instance. As shown in Figure 3.10, the user can still successfully launch Transaction FK03 but is missing the authorization for company code 0001.

At this point, the user can successfully execute the transaction but cannot view vendors in company code 0001, even though the enabler role contains the company code. Since the kernel checks the activity and the company code in the same authorization instance, the authorization check was unsuccessful. Therefore, you cannot have activity in one role and the organizational field in another and expect that the check will be successful as a whole.

Personal Copy for Arun Singal, arun.singal560@gmail.com

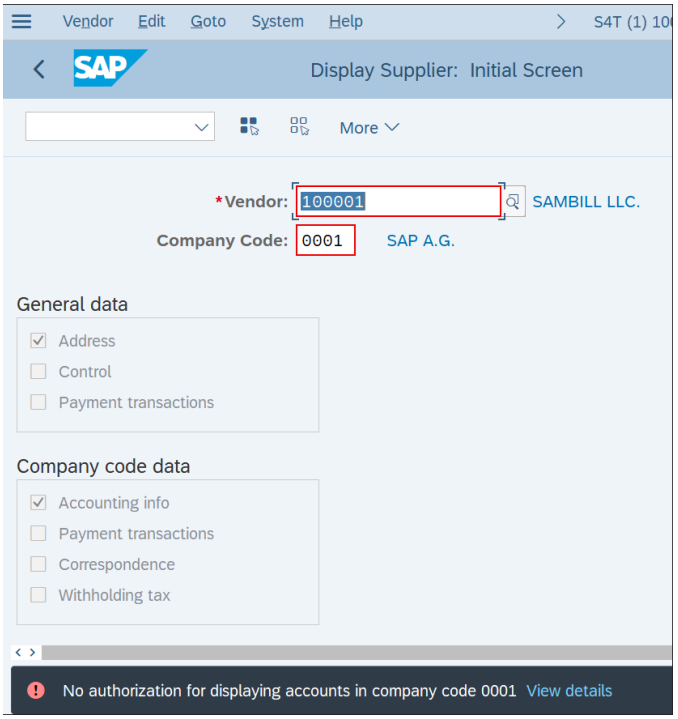


Figure 3.10 Authorization Error while Accessing Company Code 0001 in Transaction FK03

To counter this issue, you must authorize your enabler roles with the activity fields that control the company code. In this particular case, you must ensure that authorization object F_LFA1_BUK is restricted to display access (**ACTVT** = **03**) because, otherwise, you'll overauthorize these users. This potential issue is a main concern when using enabler roles since your enablers tend to carry far-reaching authorizations that may cause critical access and SoD conflicts.

Another downside to this approach is the fact that, in typical enabler concepts, the enabler roles contain almost every authorization object that has organizational fields. Since many critical business authorization objects within SAP contain organizational fields, often all these fields are added to the enabler role, since the goal of the enabler concept is to keep the number of enablers low.

In addition to this complexity, enabler role designs can also lead to several other issues, such as the following:

- You're breaking with the SAP standard. Transaction SU24 is used to propose required authorization objects into Transaction PFCG. Breaking this standard and manually inserting objects will impact upgrades, security patches, complexity, where-used list reporting, and more.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- You must use manually inserted objects with enabler roles instead of relying on solid Transaction SU24 proposals for the activity type of fields. As a result, authorization objects and values in the role profiler are not related to an application. You cannot use the where-used list to see why the authorization object was added in the first place. Over time, as role requirements change, typically obsolete authorization values become a mess that no longer matches their original intention to "enable" the transaction.
- Maintenance of roles after creation is typically more labor intensive than a derived role design due to the lack of automation. The number of enabler roles can explode such that there are more roles than there are users in the system.
- You cannot run SoD analysis on the role level with governance, risk, and compliance (GRC) tools like SAP Access Control or check on S_TCODE and the related authorizations of other objects. If transactions, activities, and organizational authorization objects are separated, you would need to simulate the correct pairing of roles to have the full set of authorizations to be assigned to a user. Please note that SoD conflicts matter the most when assigned to a user. At this point, enabler role concepts are tempted to use composite roles for role assignments, in this way adding the additional disadvantages of composite roles on top of enabler roles.
- Enabler role designs increase the complexity of role mining during the user provisioning process. For a requestor who has to request access, finding two roles is significantly harder than finding one. Especially when using tools like SAP Identity Management (SAP ID Management) or SAP Access Control, a requestor must both understand the concept as well as identify and find matching pairs of roles.
- Role testing becomes exponentially more complex since you'll need to test pairs of roles. This effort continues to be required as an organizational structure changes and roles must be tested again to ensure they reflect these changes.

Most of these issues arise because of missing Transaction SU24 content for what the application needs. Over time and by necessity, manually inserted authorization objects become obsolete, become incorrect, and overauthorize users. Since manually inserted objects are not attached to a transaction, no easy way exists to identify to which transaction they belong and why they were added to the enabler role in the first place. In the long run, maintaining and upgrading these roles is a nightmare.

If composite roles are additionally used for user assignments, then a cascading problem occurs, and changing an enabler role is nearly impossible—thus, administrators typically must create more new enabler roles to compensate.

Personal Copy for Arun Singal, arun.singal560@gmail.com

3.5 Role Naming Convention

Before you start building your roles, we recommend spending some time developing a role naming convention that suits your organization. A common mistake is building roles without any convention, thus resulting in a messy design that is hard to maintain in the long run. Also, the lack of naming convention increases the complexity of finding and assigning roles to end users. Especially when companies use tools such as SAP ID Management or SAP Access Control for role provisioning through workflows where a requester has to enter the roles that shall be assigned to a user.

Table 3.4 is an example of a role naming convention that has been implemented successfully with many clients.

Character Number	Description	Examples
1	Fixed value "Z" for customer namespace	
2	Identifier for the system level	P – Production D – Development T – Test S – Sandbox Q – Quality I – Integration
3	Fixed character "_" for separation	
4	Identifier for role type	S – Single role C – Composite role M – Master role
5	Identifier for user group	C – "Common" role for basic functions for all users E – end user role for job function I – IT roles for administrators, developers, etc. T – Technical roles for remote function calls (RFC), batch jobs, Web Services, etc. R – Reference user roles
6	Fixed character "_" for separation	

Table 3.4 Example of a Role Naming Convention

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Character Number	Description	Examples
7 – 8	Identifier for business area	BC – Basis BI – Business Intelligence CR – Customer Relations CO – Controlling EC – ERP Component FI – Finance HR – Human Resource MM – Material Management PI – Process Integration PS – Project Systems SD – Sales & Distribution SM – Solution Manager SR – Supplier Relations
9	Fixed character "_" for separation	
10	Identifier for leading organizational element	A – All N – None C – Company Code P – Purchasing organization P – Plant D – Division
11	Fixed character "_" for separation	
12 – 15	Organizational value in regard to the organizational element	A – GLOB (all) N – GLOB (none) C – $BUKRS (value from company code) S – $VKORG (value from sales organization) P – $WERKS (value from plant)
16	Fixed character "_" for separation	

Table 3.4 Example of a Role Naming Convention (Cont.)

Personal Copy for Arun Singal, arun.singal560@gmail.com

Character Number	Description	Examples
17 – 19	Identifier for activity group in regard to the user group	COM – Common job authorizations REP – Reporting with display only authorization EAM – emergency access authorizations KEY – Key user authorizations MDM – master data authorization ADM – administration authorization HPU – High-privileged user (HPU) authorizations
20	Fixed character "_" for separation	
21+	Free text	

Table 3.4 Example of a Role Naming Convention (Cont.)

Based on the role naming convention in Table 3.4, a few practical examples might resemble the following role names:

- `ZP_SI_BC_N_GLOB_HPU_OPEN_CLIENT`
  A single role for a productive system (PRD) that does not include any organizational data and is considered an HPU role to open clients.
- `ZP_CE_FI_C_1000_REP_ACCOUNTANT`
  A composite role for a PRD that includes organizational values for company code 100 with display-only access for reporting purposes, typical for an accountant.

With this kind of role naming convention, not only can an administrator easily understand a number of roles, so can an end user. Also, since identifiers are defined and follow a specific pattern, role analysis can be simplified. For example, a role that contains "REP" in characters 17 to 19 is a reporting-only role that should not include any insert, change, update, or delete authorizations. For role quality and sustainability purposes, a strictly enforced role naming convention is therefore mandatory.

3.6 Summary

The decision to (re)design a company's authorization concept can be stem from a variety of reasons. Some main drivers include system upgrades (e.g., migration to SAP S/4HANA); remediating compliance issues (e.g., SoD, legal requirements); mergers and acquisitions that lead to integration projects; or because the current design does not meet the desired security standards of your company. When choosing between the types of approaches (top-down or bottom-up), be mindful of how each can affect your

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

authorization concept design. Additionally, some areas to take note of when designing your company's authorization concept include the following:

- Existing SoD policies
- Role naming conventions
- Job- or task-based roles
- Knowing when to use single, derived, composite, enabler, or template roles

In the next chapter, we'll discuss the Xiting Authorizations Management Suite (XAMS).

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 4

Xiting Authorizations Management Suite

The Xiting Authorizations Management Suite (XAMS) is a third-party solution by SAP PartnerEdge gold partner Xiting designed for authorizations management. XAMS simplifies and automates SAP roles and authorizations management and at the same time increases the quality of your security design. XAMS is officially certified for SAP S/4HANA Cloud and is also the recommended solution for authorization redesign for remote function call (RFC) users, as described in SAP Note 1682316.

This chapter covers XAMS in great detail. Xiting developed XAMS software to provide innovative tools to support companies in their security projects by automating costly and time-consuming tasks, improving compliance, and reducing the risk of errors.

XAMS is endorsed by SAP in SAP Note 1682316 as the preferred solution for redesigning authorizations for RFC and other technical users.

Requirements and legal regulations require companies handle authorizations restrictively, which often leads to the revision or creation of new authorization concepts to meet numerous challenges. This task requires profound know-how.

With XAMS, you can access highly specialized know-how and expertise in SAP authorizations. XAMS enables the easy execution of authorization projects. Critical, time-consuming phases can be drastically shortened and efficiently managed. On this basis, a best-practice approach to the holistic administration of SAP authorizations in an ABAP environment has been developed.

XAMS offers practical solutions for authorization projects, role redesign and maintenance, vulnerability analysis of custom ABAP code, and the creation of SAP security concepts with the help of seven modules. We'll cover these modules in great detail in this chapter.

Hint

Keep an eye out for references to XAMS-related use cases at the end of several subsequent chapters in this book. Additionally, in Chapter 13, we'll walk you through an entire SAP S/4HANA migration project using XAMS.

Personal Copy for Arun Singal, arun.singal560@gmail.com

4.1 Overview

XAMS has been developed entirely in ABAP and seamlessly integrates into SAP by relying solely on standard business application programming interfaces (BAPIs) and functions. As a result, the solution is compatible with all releases of SAP NetWeaver 7.0 or higher.

You can install and distribute XAMS across multiple clients using standard SAP transport mechanisms. Based on your licensed XAMS components, installation might require additional customizing steps before the software can be used.

Note that XAMS is much more than an individual software component; this feature-rich suite provides solutions to a wide variety of SAP security- and authorization management-related issues. Nevertheless, you can license individual XAMS modules to support specific projects or use cases. As shown in Figure 4.1, XAMS supports the entire authorization lifecycle, from getting clean to staying clean.

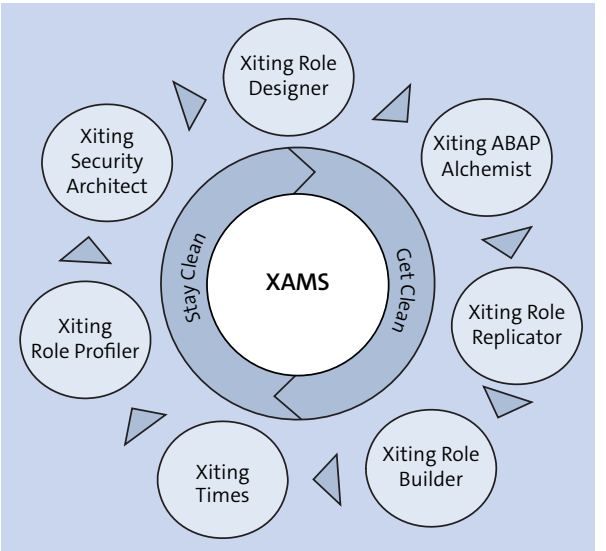


Figure 4.1 XAMS Lifecycle

At the time of writing, XAMS consists of the following seven modules and a set of free tools:

- **Xiting Role Designer**
  For creating a suitable and sustainable role authorization concept for all users in your SAP system landscape.
- **Xiting ABAP Alchemist**
  For identifying and optimizing existing authorization checks and correcting implementation errors in your own developments.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Xiting Role Builder**
  For testing new authorizations otherwise unnoticed in a production system with the revolutionary Productive Test Simulation (PTS) capability.
- **Xiting Role Replicator**
  For reducing the time and effort required in creating, assigning, and maintaining organizational levels with mass replication capabilities.
- **Xiting Times**
  For eliminating potential risks during the operational transfer of new SAP authorizations with the Protected Go-Live (PGL) feature.
- **Xiting Role Profiler**
  For verifying your role design with new SAP authorizations and checking the quality of the implemented authorization concept.
- **Xiting Security Architect**
  For documenting your SAP security concept and comparing it with the current settings in your systems.
- **Free tools**
  For several tasks, including user locking/unlocking (Xiting User Locking Tool) and the analysis of your RFC landscape (Xiting RFC Stocktake Tool).

4.2 Xiting Role Designer

Carrying out an authorization project is always a time-consuming and lengthy affair since a lot of data must be analyzed and processed. Xiting Role Designer is a helpful tool for carry out such a project efficiently and in a timely manner.

One key advantage of Xiting Role Designer is that a preliminary authorization concept can be created and discussed based on a virtual environment before committing changes to your system. Using the included analysis features of Xiting Role Designer, role admins can execute a live coverage analysis based on historical usage data to detect authorization gaps before they become an issue during go-live.

Numerous reports support authorization administrators in implementing and simulating new role concepts and various usage scenarios. Additionally, you can use Xiting Role Designer to detect segregation of duties (SoD) conflicts during the role design phase.

Xiting Role Designer also dramatically shortens the testing phase of roles, since significantly fewer corrections must be made. Furthermore, Xiting Role Designer replaces the cumbersome spreadsheets that are often used in classic redesign projects. This section covers the core capabilities of Xiting Role Designer including the analysis of existing roles and the design of new roles as well as vast reporting features.

Personal Copy for Arun Singal, arun.singal560@gmail.com

4.2.1 Capabilities

Our experience has shown that SAP users are often overauthorized. However, performing a manual trace analysis to determine what authorizations users actually need is cumbersome, time-consuming, and error prone. As shown in Figure 4.2, virtual role designing within the Xiting Role Designer module in XAMS (accessed via Transaction /N/XITING/ROLEDESIGNER) can help address this issue, regardless of whether you're using an SAP ERP 6.0 system or an SAP S/4HANA system or want to migrate to SAP S/4HANA.

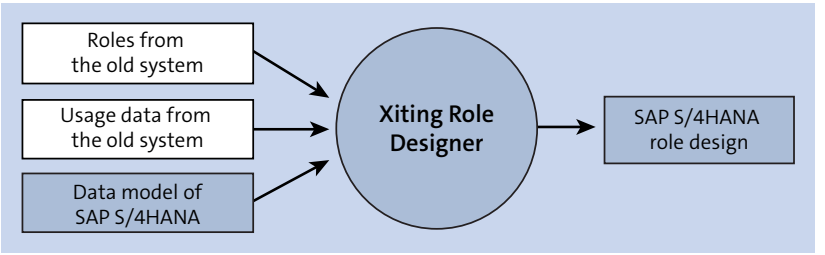


Figure 4.2 Xiting Role Designer Systematic

Often, transparency into which roles might be missing an authorization and which organizational structures a user belongs to is lacking.

Another challenge is anticipating potential SoD conflicts, which are often only identified during role assignment. If issues are found, the affected roles must be updated in a development environment before being transported back to production—a resource-consuming process.

With Xiting Role Designer, you can evaluate a user's historical usage data and, in combination with best-practice role templates, create a suitable authorization concept for your users based on the least privilege principle. This tool ensures that all your users are properly authorized but without too far-reaching permissions.

Even during the role design phase and before the roles are created in the profile generator (Transaction PFCG), you can analyze all existing roles for critical authorizations. Additionally, you can simulate the impact of role changes on end users in real time.

Xiting Role Designer enables role administrators to design new roles in a drag-and-drop cockpit virtually and simulate what-if scenarios through virtual role assignment.

Additionally, Xiting Role Designer is equipped with analysis tools that are indispensable for an authorization redesign. Tool-based authorization redesign projects can drastically reduce effort and save time while reducing risks when transferring to a productive system (PRD). In addition to technical challenges such as assigning transactions to new roles and the expression of authorization objects, organizational aspects, such as the assignment of the new roles to each user, must also be taken into account so that the right users have the necessary permissions to perform business transactions.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Xiting Role Designer can also test new roles against SoD conflicts and other issues, either against SAP Access Control or XAMS's internal risk framework. If you're planning on migrating your SAP ERP system to SAP S/4HANA, Xiting Role Designer can instantly migrate your existing roles, possibly saving you months of manual labor.

4.2.2 Analysis and Design

Role administrators can easily assign transactions to roles (and roles to users) via an intuitive drag-and-drop interface. As a result, admins can quickly and conveniently create new roles using the virtual design cockpit found in Xiting Role Designer, as shown in Figure 4.3. Additionally, Xiting Role Designer can leverage statistical usage data (e.g., usage of transactions) of the end users from the production system to determine how well the new roles cover the user requirements (see the **Used**, **Unauth**, and **Percent** columns).

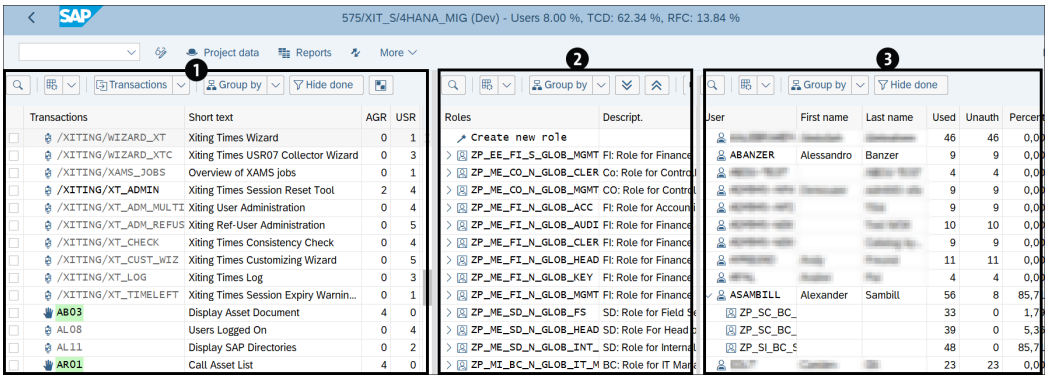


Figure 4.3 Virtual Role Design in Xiting Role Designer

Figure 4.3 depicts the following:

❶ All used menu objects

❷ Your virtual roles, including menu objects

❸ Users with virtual role assignments and coverage rates

As part of Xiting Role Designer's analysis capabilities, role admins can import the transaction history and gain valuable insights into what applications and functions users have typically used in the past.

Based on this information, you can create a template role to easily create role menu structures for any future roles you design. This approach can apply to both smaller authorization projects and to complete redesigns.

Xiting Role Designer can also help you with an SAP S/4HANA migration by enabling automated role migration from SAP ERP 6.0 to SAP S/4HANA, based on SAP's simplification list. On one hand, your project teams can better estimate the impact and effort

Personal Copy for Arun Singal, arun.singal560@gmail.com

of such a migration, and on the other hand, old transactions can be quickly removed or replaced with the click of a button.

4.2.3 Reporting Options of Xiting Role Designer

The reports available in Xiting Role Designer offer more detailed information about users, roles, RFC interfaces, transactions, and business data. These reports also offer optimization options for your virtual role design as well as roles that already exist in the system.

The user-based reporting functions in Xiting Role Designer allow you to find the best-fitting roles for your users or to find smaller roles that include less "transaction overhead" while fully covering the selected users based on their statistical usage data.

You can also quickly find unused roles or unused transactions within roles and view user reports in Xiting Role Designer, as shown in Figure 4.4, which is an overview of users along with other reports that are available.

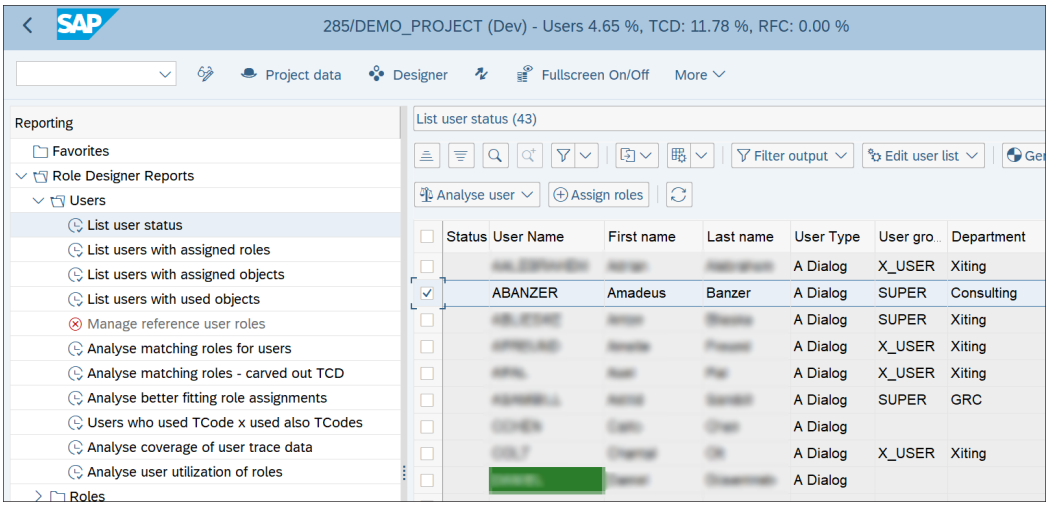


Figure 4.4 Example Report in Xiting Role Designer

For instance, the role reporting feature in Xiting Role Designer allows you to scan roles for transactions used that you can replace with parameter transactions. A common business requirement is limiting access to generic table browser transactions like Transactions SE16, SE16N, SM30, or SM34 to prevent users from accessing these tables directly. The same requirement might be true for Transactions SE38, SA38, etc. when accessing programs and reports.

You can also identify "friend transactions" that can make the newly designed roles more robust. For example, if you authorize a user for Transaction SU01, also including Transaction SU01D (the display version of Transaction SU01) makes sense. Xiting Role

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Designer provides a list of suggested "friends" based on your individual role design, including an indication of their priority (mandatory, recommended, or optional). With the role reports in Xiting Role Designer, shown in Figure 4.5. you can access a list of roles with unused menu objects. This list indicates, for example, transactions that have not been used by any user assigned to the role—a good opportunity to remove unused applications to avoid the overauthorization of users.

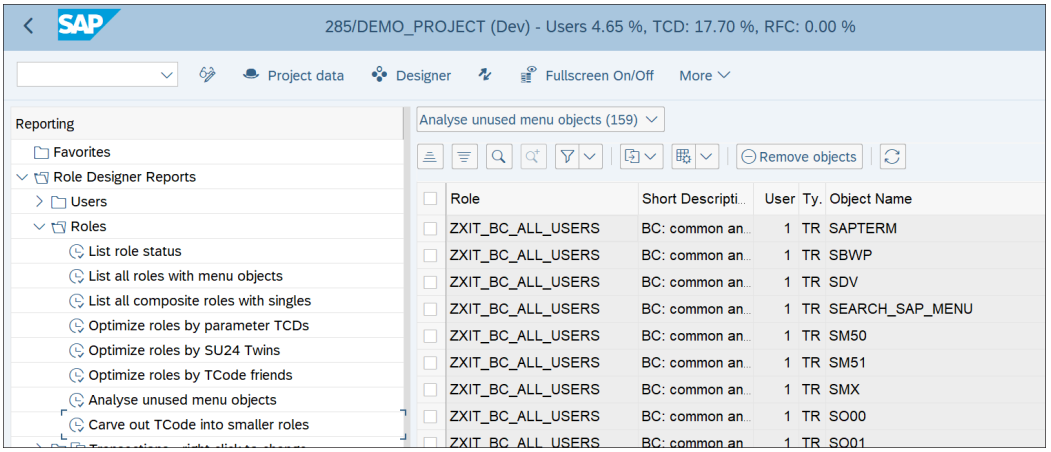


Figure 4.5 Analyzing Unused Menu Objects in Xiting Role Designer

4.2.4 Reporting Options for Menu Objects

Using the transaction reporting feature in Xiting Role Designer, you can find unused transactions that you haven't assigned to users yet, but that users require be properly covered (based on their historical usage data). You can also use this feature to easily find and assign SAP Fiori catalogs and SAP Fiori groups to assign to roles. A transaction report in Xiting Role Designer, shown in Figure 4.6, displays the open transactions for a user, which indicates transactions that are not considered in the newly designed roles for the users in scope but had been used in the past.

Also, RFC function module reporting capabilities in Xiting Role Designer enable the quick identification of which function modules haven't been assigned to users yet. You can also easily find existing roles that include the required function modules and assign and maintain them in other roles.

Xiting Role Designer has the same capabilities for different types of applications as shown in Figure 4.7, including function modules, Web Services, Web Dynpro applications, and IDocs as well as SAP Fiori catalogs and SAP Fiori groups.

Thus, when designing new roles, Xiting Role Designer can fully handle not only transactions that are in scope but a variety of different types of applications.

Personal Copy for Arun Singal, arun.singal560@gmail.com

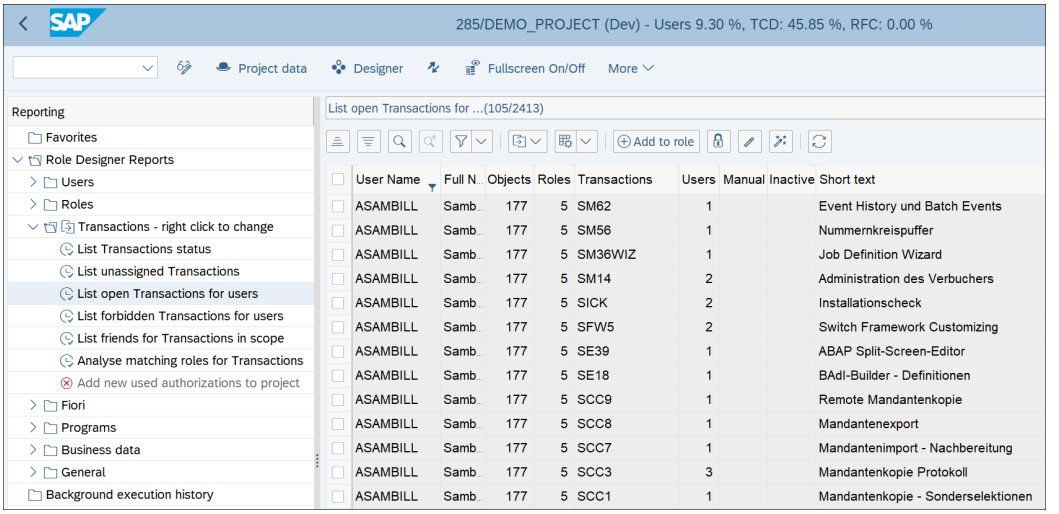


Figure 4.6 Xiting Role Designer: List of Transactions Open for Users

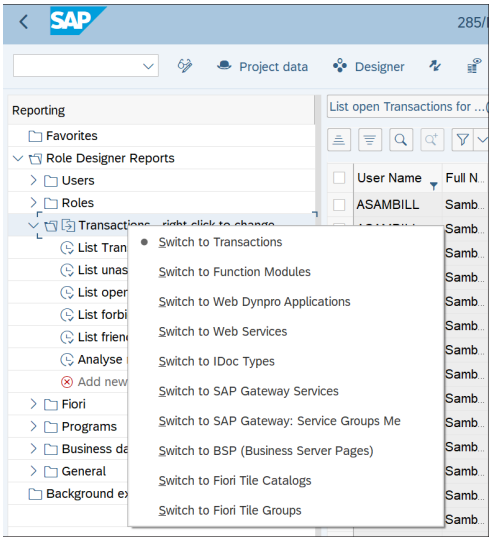


Figure 4.7 Switching between Reporting for Different Types of Applications

4.2.5 Reporting Options for Business Data

Xiting Role Designer also allows you to quickly extract the change documents of relevant business data associated with users in scope for the role design project. The purpose of change documents is to provide insight into the organizational values used and other important authorizations to determine role derivations, among other things. For example, the change documents of table `BKPF` provide details about what company

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

codes (field BUKRS) have been used by the users in scope. This information can be vital to determine role derivations for accounting roles, for example.

The following change documents are available for extraction:

- FI: Accounting (BKPF)
- FI: Customer master (KNB1)
- FI: Vendor master (LFB1)
- FI: Sales customer master (KNVV)
- FI: Equipment Segment (ANLA)
- FI: Asset Classes (ANKA)
- FI: G/L Accounts (SKB1)
- SD: Sales (VBAK)
- SD: Invoicing (VBAK)
- MM: Purchasing (EKKO)
- MM: Material master (MARA)
- CO: Object Document Header (COBK)
- CO: Order master data (AUFK)
- HR: Info types

An important point to remember is that all that's being extracted is the change documents so you can see which user created or changed certain objects types for organizational relevant fields. Change documents do not include display authorizations since display type access is not recorded in a change document.

4.3 Xiting ABAP Alchemist

Despite best-practice guidelines and the numerous tools provided by SAP, developing custom applications always introduces risk into your SAP landscape. Correct authorization assignments are difficult with self-developed applications if the developer did not implement the proper authority checks in the source code. However, the existence and accuracy of authority checks in the source code is essential to provide proper access control in SAP.

Security is an important and central aspect in an authorization concept. To ensure internal and external regulation compliance, security mechanisms must be implemented in the source code of a program. These mechanisms can ensure differentiated access control to data in an SAP system and enable the correct authorization assignments to protect against critical actions. Furthermore, correct access control via the authorization system is possible by establishing and optimizing security checks for

Personal Copy for Arun Singal, arun.singal560@gmail.com

in-house developments. Reliable protection of your business data is therefore directly related to the secure development of your programs.

Granular access control of authorizations is only possible after security checks have been established and optimized in your custom applications. However, traditional code scanning techniques only tend to focus on identifying classic coding errors, without providing sufficient information to developers and role administrators about how to fix resulting authorization issues.

With Xiting ABAP Alchemist, you can quickly and easily analyze program code to look for errors and fix them before this code is transported to your production landscape.

The SU24 optimization feature ensures that your authorizations proposals database is also optimized for your custom code, not only for standard transaction codes.

With the API Finder, you can support your development teams by enabling them to reuse already tested code instead of always writing new ABAP code from scratch.

All the tests and checks included in Xiting ABAP Alchemist can be executed on demand or automatically by making them part of the SAP transport mechanism.

Shown in Figure 4.8, Xiting ABAP Alchemist is the XAMS module that you can use to perform custom development scanning. Xiting ABAP Alchemist can help you optimize custom ABAP code and makes recommendations for missing authorization checks. The built-in API Finder helps developers find standard SAP functions (e.g., BAPIs) that can be easily reused in custom code, thereby reducing the risk of introducing redundant code that might contain vulnerabilities.

Xiting ABAP Alchemist also offers recommendations for implementing additional security checks that may have not been implemented within the source code. Possible weaknesses can be identified and remediated based on suggested improvements, and potential security gaps can then be closed.

Some of Xiting ABAP Alchemist's most useful features include the following capabilities:

- **Technical analysis**

  With the support of Xiting ABAP Alchemist, you can optimize your custom source code to ensure your developers have included all the necessary authority checks and have not introduced other potential vulnerabilities.

  Xiting ABAP Alchemist provides a wide range of detailed analysis options and predefined check scopes to ensure the correct and safe implementation of your custom programs and applications. Additionally, you can use the detailed test reports as part of an existing internal control framework.

  Depending on your role within the organization and your familiarity with ABAP code, you can select from various "views" that present the raw data in an actionable form.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

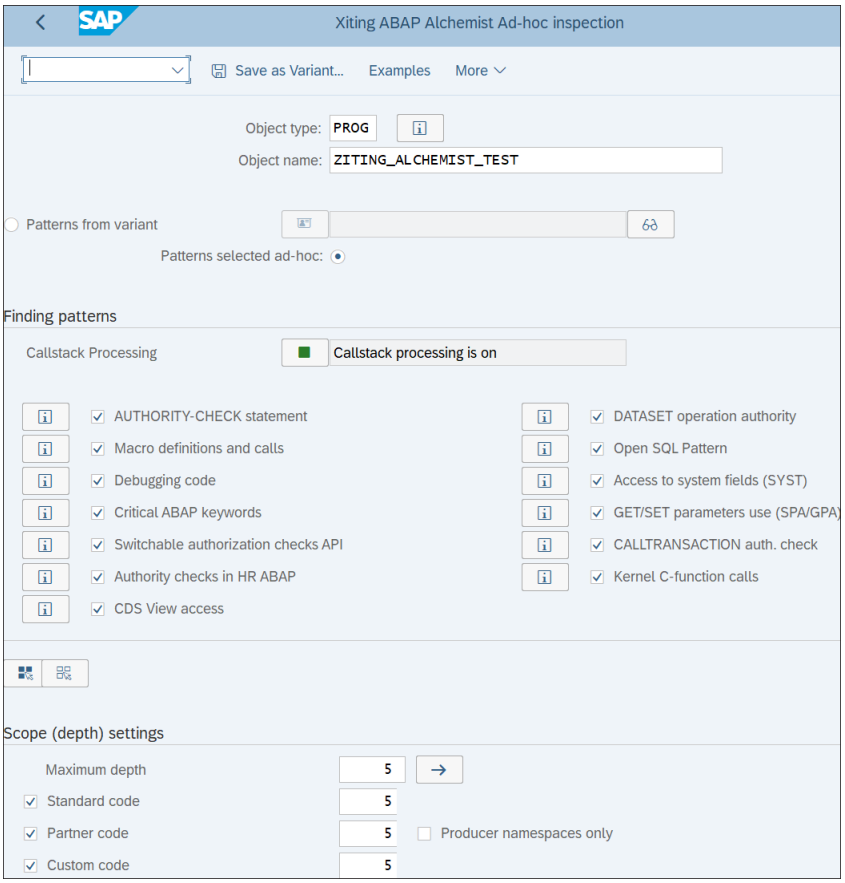


Figure 4.8 Xiting ABAP Alchemist Ad Hoc Scan Options

- **Call stack analysis**
  One of the many valuable features of Xiting ABAP Alchemist is its call stack analysis feature, which allows you to examine code that goes beyond the boundaries of the selected object. For example, Xiting ABAP Alchemist can scan a transaction code (Transaction TCODE) as well as any programs, functions, and methods that are part of the call stack.

  As a result, Xiting ABAP Alchemist supports both developers and authorization administrators in identifying encapsulated functions within the source code.

- **Transaction SU24 optimization**
  The integrated optimization function for SAP's authorizations proposals database (Transaction SU24) allows you to compare and maintain suggested values for analyzed development objects based on the security checks contained in the code, as shown in Figure 4.9. As a result, you can keep your Transaction SU24 database properly maintained, which increases transparency and role maintainability.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Flexible configuration options that allow you to define the scanning scope and the depth of the scan (call stack) make Xiting ABAP Alchemist a favorite tool among developers and role admins. Predefined checks can be used on a recurring basis and serve as a proactive measure for internal and external regulatory compliance.

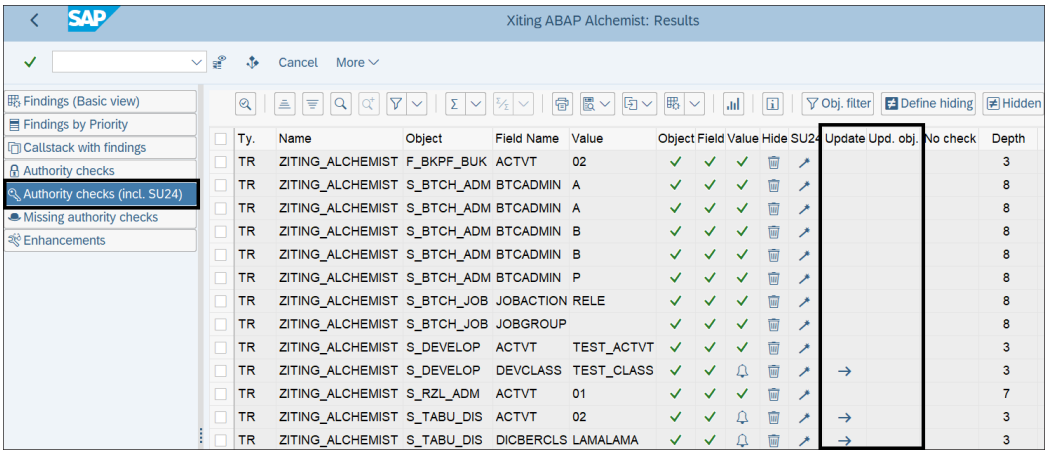


Figure 4.9 Transaction SU24 Optimization via Xiting ABAP Alchemist Code Scanning

- **API Finder**

  Xiting ABAP Alchemist includes a search engine for APIs, shown in Figure 4.10, so your developers can quickly identify and reuse SAP standard code or custom code blocks that have been previously developed and tested.

  Reusing BAPIs and functions that SAP provides out of the box, instead of writing your own code, significantly improves the overall quality of your custom developments and reduces the length of test cycles.

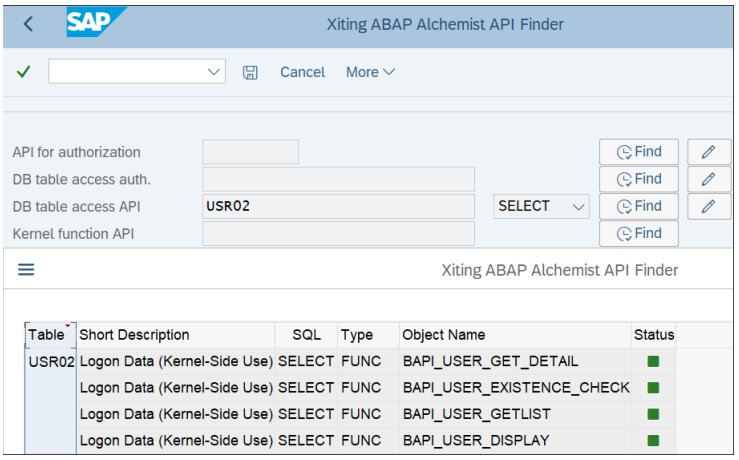


Figure 4.10 Xiting ABAP Alchemist: API Finder

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

4.4 Xiting Role Replicator

Mapping an organizational structure to SAP security roles is a complex challenge. While SAP provides the tools to maintain organizational levels within the roles (such as company codes, plants, locations, etc.), doing so requires significant administrative effort.

For example, adding a company code to hundreds or thousands of roles after an acquisition is a manual effort that can take anywhere from weeks to months. Experience has shown that adapting roles for maintaining different organizational levels can involve enormous time and effort on the part of authorization administrators.

As shown in Figure 4.11, the XAMS module Xiting Role Replicator can mass process roles and authorization data. With Xiting Role Replicator, role administrators can easily make changes to an organizational structure and replicate those changes to all affected roles with the click of a button.

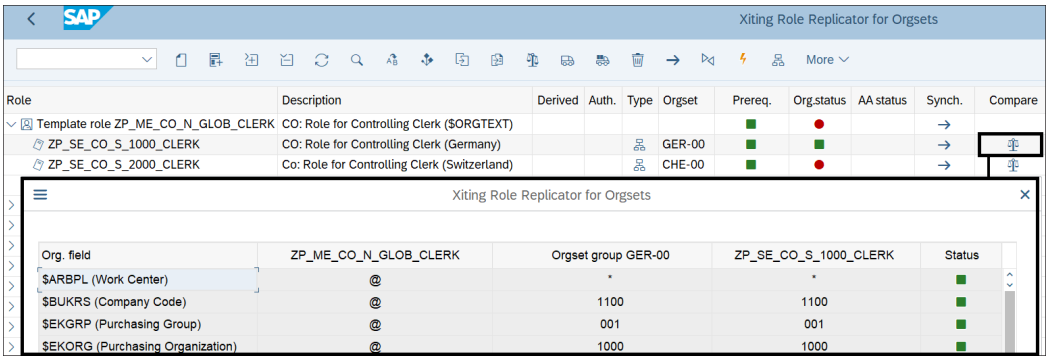


Figure 4.11 Xiting Role Replicator's Role Derivation via OrgSets

Additionally, Xiting Role Replicator provides status reporting to highlight discrepancies in organizational fields and values between what is defined in the tool and Transaction PFCG. The role administrator then can overwrite the manual changes with what is defined in the OrgSet model.

Besides simplifying the maintenance of organizational data, Xiting Role Replicator provides dozens of bulk processing capabilities, which we'll discuss in the following section. We'll also provide an overview of how you can use the Xiting Role Replicator for OrgSet replication.

4.4.1 Bulk Processing of Users, Roles, and Authorizations

Xiting Role Replicator enables role administrators to quickly and efficiently batch process roles, users, parameter transactions, and SAP Fiori objects. As shown in Figure 4.12, some popular features of Xiting Role Replicator include the following capabilities:

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Bulk creation of users and bulk processing of user master data, including role assignments, user locking capabilities, mass password resets, reassignment of roles, and much more.
- Mass maintenance of organizational structures in roles, as described further in Section 4.4.2.
- Mass processing tools to mass delete, mass create, and replicate roles; reassign single roles into composites roles; mass update role descriptions and languages; role versioning; and much more.
- Tools for ABAP objects to mass create parameter transactions for transactions like Transactions SE16 and SM30, as well as other parameter transactions.
- Mass tools for the bulk creation of SAP Fiori catalogs and groups, including tiles and target mappings, with the ability to transport them completely.

In addition, Xiting Role Replicator offers upload and download functionalities using Microsoft Excel files or .CSV files to conveniently process large amounts of data.

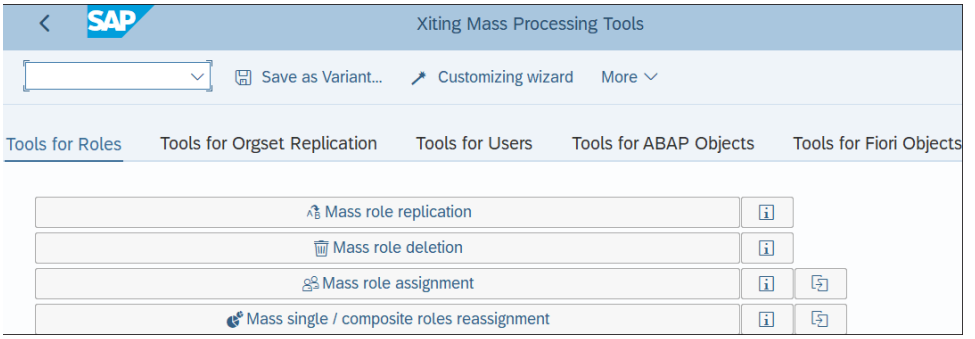


Figure 4.12 Tool Registers of the Xiting Role Replicator

Xiting Role Replicator can significantly reduce the time and effort required to maintain organizational fields. With this solution, you can model your organization using OrgSets (e.g., based on geographic location, business unit, or a combination thereof).

The solution enables a clear and efficient implementation and processing of the organization sets. New organizational structures can be created quickly and easily by copying roles and defining organizational levels in a single step. If necessary, individual changes or mass changes can also be carried out in the shortest possible time.

Various reports support the sustainable management and control of your defined OrgSets (the targeted organizational values in the roles). Status reports show all roles in Transaction PFCG that are not synchronized with the defined organizational set in Xiting Role Replicator.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

If, for example, someone had manually changed an organization field for a role in Transaction PFCG, Xiting Role Replicator would report this discrepancy and provide a detailed analysis of the differences. You then have the option of overwriting all manual changes with the target value that was specified in the predefined model.

If changes to the organization fields are necessary, you can make the changes directly in Xiting Role Replicator and then conveniently replicate these changes to all affected roles with the push of a button. The solution not only reduces the effort required to maintain organizational fields, but also prevents roles from deteriorating because of manual changes in Transaction PFCG.

4.4.2 OrgSet Replication

Use the tools **Maintain Orgsets** and **Org.Fields Replicator** to represent your company structure in XAMS and to derive roles from this structure, as shown in Figure 4.13. Once the organizational structure has been defined, you can, at any given time, analyze, compare, and replicate your derived roles with the OrgSet, which serves as master data that can be replicated to your derived roles.

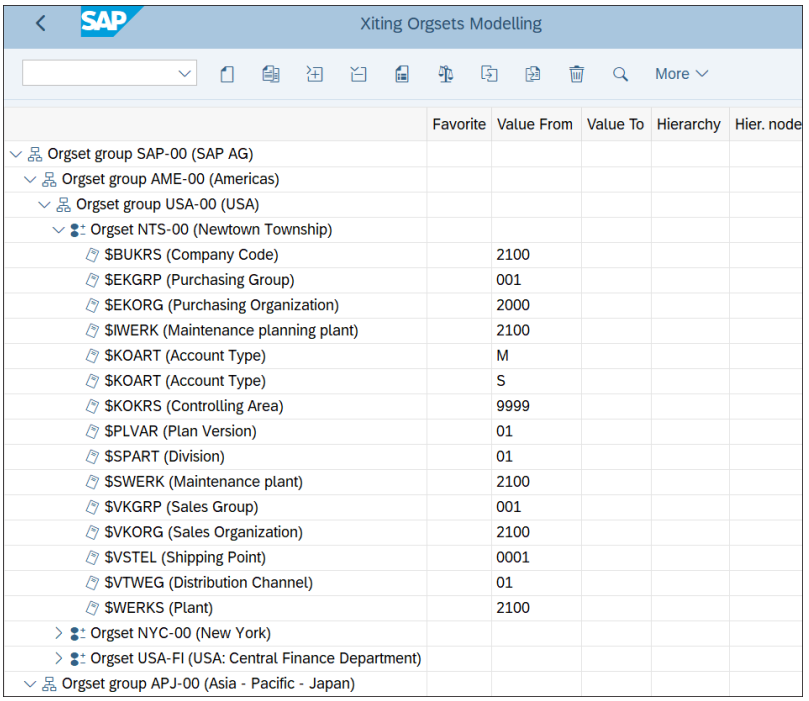


Figure 4.13 OrgSet Definitions via Xiting Role Replicator

For example, you could use Xiting Role Replicator to design an organizational structure based on the various locations your business operates in. For instance, let's say your company has offices in the United States, Canada, and Mexico, and you'd like to design

Personal Copy for Arun Singal, arun.singal560@gmail.com

roles for accounts payable personnel working in each of those locations. Instead of creating duplicate accounts payable roles—one for each country and then manually changing the relevant organization fields and values—you can let Xiting Role Replicator do the work and automatically replicate the require roles for you while taking into account the different organizational information.

In other words, Xiting Role Replicator simplifies the initial creation of role copies that differ only in organizational values. Moreover, Xiting Role Replicator also helps you maintain existing roles by keeping their organizational data in sync with your predefined organizational structure. In other words, adding, for example, a new company code to a set of replicated roles is as simple as pushing a button in Xiting Role Replicator.

Xiting Role Replicator can significantly reduce the time and effort involved in the maintenance of organizational fields and their replication to affected roles. This module also prevents the quality of roles from degrading by detecting manual changes to organizational fields in Transaction PFCG.

4.5 Xiting Role Builder

Traditional role test cycles are time consuming and error prone, and they significantly impact business users. As a result, organizations try to avoid or postpone necessary role redesign or remediation projects unless required due to audit findings. As shown in Figure 4.14, XAMS can support your entire role concept creation process. For instance, Xiting Role Builder, combined with Xiting Times (see section Section 4.6), features the unique PTS technology. Using this technology, role administrators can test new roles in a production environment without negatively affecting end users.

Additionally, Xiting Role Builder simplifies traditional unit testing by automatically creating so-called *delta roles* based on failed authorization checks. Delta roles are automatically and instantaneously assigned to testers so they can continue testing without interruption. Xiting Role Builder comes with a whitelist/blacklist feature that you can use to avoid the automatic assignment of critical authorizations that are blacklisted.

You can also use the included Xiting Role Builder SU24 Checkman to compare analysis data (e.g., user authorizations) with authorization default values (Transaction SU24). As a result, you can quickly identify inconsistencies between analysis data with authorization proposals in Transaction SU24 and add missing values directly from within Xiting Role Builder.

In combination with Xiting Times, Xiting Role Builder offers the unique PTS feature (see Section 4.6 for more information on Xiting Times). This innovative solution allows role administrators to simulate how new roles would work based on user activity in the production system. Practically speaking, new roles can be tested in production without impacting end users.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

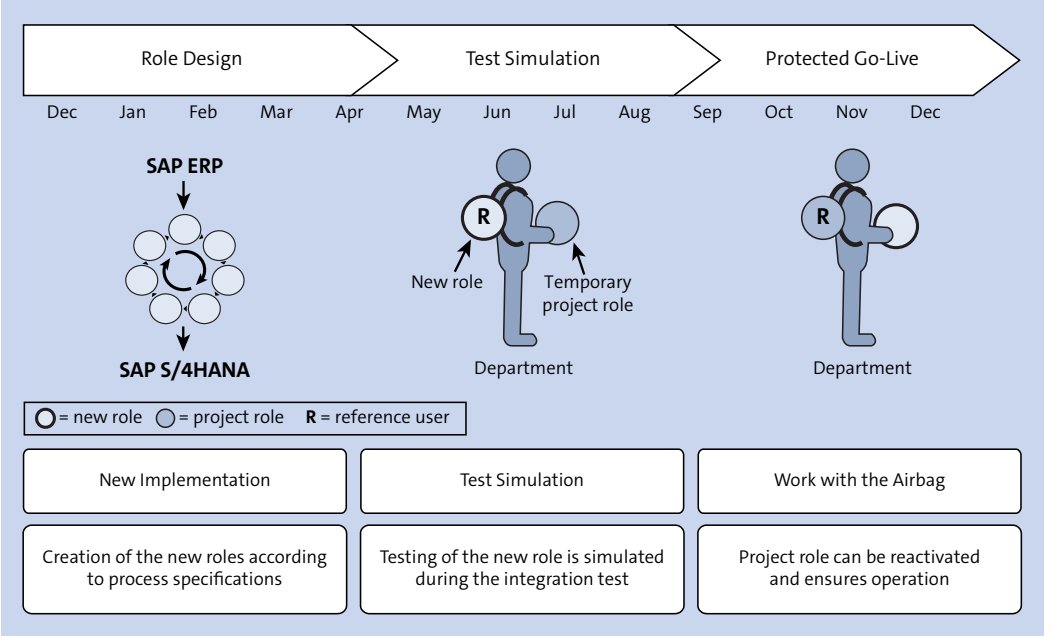


Figure 4.14 XAMS Role Concept Process Summary

Xiting Role Builder enables this audit-compliant capability by leveraging a special user type in SAP called a *reference user*. Each dialog user included in the test simulation is assigned a reference user that is associated with the new roles that fall within in the test scope.

Whenever an authorization check is performed, the entire user buffer is analyzed, which means the authorizations assigned to the dialog user as well as the authorizations from the reference user assigned to the dialog user. Depending on the return code and reason code of the authority check, a collector program behind PTS picks up the authorizations missing from the authorizations of the reference user. A log entry is created that provides information to role administrators about which authorizations are missing in the new role. All of this happens without the end user's knowledge.

As a result, new roles or role changes can be conveniently tested in production without the need for a test environment, test scripts, or the involvement of testers or end users. The graphic shown in Figure 4.15 illustrates how this process works.

Identified gaps and authorization issues can be fixed in the background without disrupting the business. This novel, forward-looking project approach enables a go-live without risks and guarantees simultaneous, nearly automated testing of business processes and required authorizations without waiting times or interruptions. With the help of this innovative Xiting technology, testing lead times are radically reduced, cost-saving potentials are released, and efficiency increases are achieved thanks to high test automation.

Personal Copy for Arun Singal, arun.singal560@gmail.com

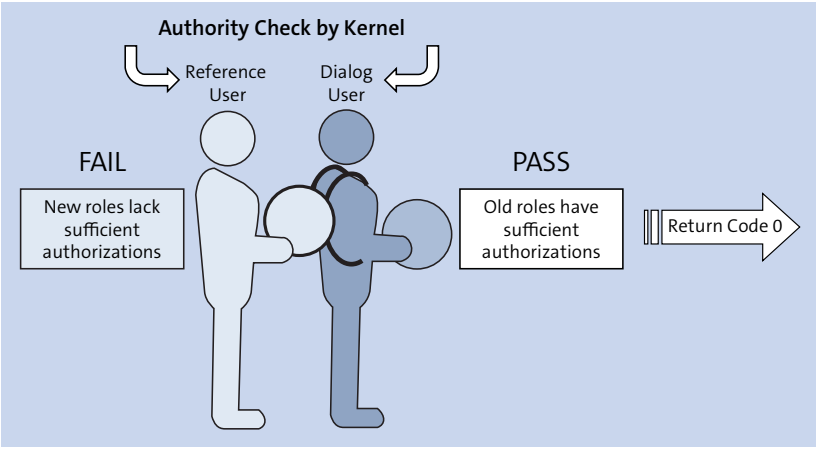


Figure 4.15 PTS at Work

Additionally, Xiting Role Builder allows the provision of missing authorizations to be fully automated without the intervention of an administrator. By automatically generating delta roles, Xiting Role Builder can assign missing authorizations as soon as they are identified. The typical use case for this scenario is when redesigning RFC authorizations. However, this approach can also be used in similar fashion when testing role changes, preferably in sandbox environments as deemed critical. The automated delta role generation feature can be helpful when testers require extensive authorizations, but the authorization profile SAP_ALL as well as other Basis or critical authorizations should not be authorized.

The advantage of using this functionality is that testers can fully manage test scenarios quickly, without waiting for authorization issues to be resolved by an authorization administrator (end-to-end testing), therefore significantly reducing the lead time for testing.

Critical authorizations are intercepted in the course of automatic provisioning via a blacklist, which can be extended according to your requirements. This approach ensures that critical authorizations are not automatically assigned to testers, thus maintaining compliance with existing laws and regulations.

Within the framework of background processing, roles for interface users and system users can be continuously optimized, enabling authorizations to be assigned according to the least privilege principle. With this approach, system users cannot misuse their authorizations, and only the intended activities are possible in background processing.

4.6 Xiting Times

One of the most critical phases in a role redesign project is the go-live, when role changes are finally deployed into PRDs. Despite extensive testing, errors are often only

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

detected in this late phase, frequently disrupting organizational processes, which increases risks and can become a source of problems in authorization projects.

Xiting Times can help eliminate the risk of access problems during go-live. In the event of authorization errors, end users can temporarily get the old access back, in a controlled environment that offers extensive reporting and management of collected data to support the analysis and fixing of authorization-related issues during go-live, as shown in Figure 4.16.

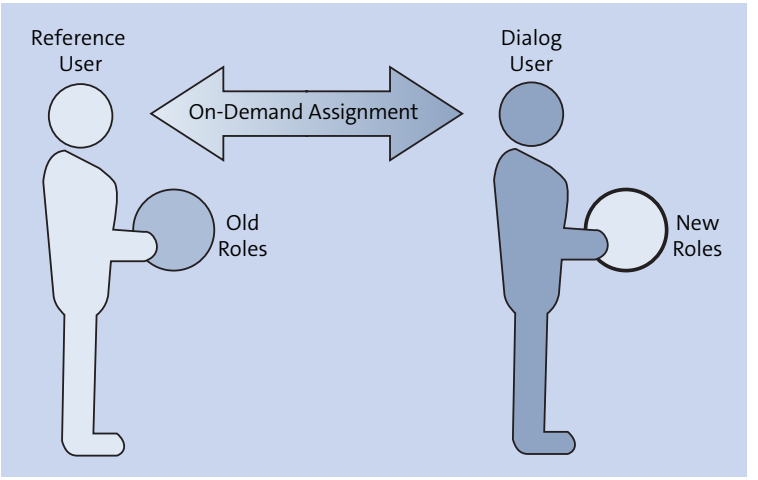


Figure 4.16 PGL in Action

If an authorization error occurs during the go-live phase, end users can request their old roles to be automatically assigned to them via a reference user for a limited period. This feature saves time because the affected end user doesn't have to submit a support ticket or call someone and wait for a fix to be implemented. Instead, the end user can continue working while designated personnel receive an email with a detailed and audit-compliant trail of the issue and all relevant authorization data. Alternatively, Xiting Times allows the implementation of flexible approval workflows, similar to those of traditional emergency access management (EAM)/firefighter solutions.

In case of emergencies, administrators sometimes need elevated access to the SAP system that requires special authorizations that you wouldn't want to assign to any dialog users on a permanent basis. In such instances, you'll need an EAM solution that allows certain users to request elevated access quickly and efficiently while maintaining an appropriate audit trail.

Xiting Times implements this EAM concept by leveraging regular SAP reference users. So, in case of a system emergency, predefined administrators can assign themselves a reference user who has the appropriate authorizations (via its roles) to carry out the required tasks.

Personal Copy for Arun Singal, arun.singal560@gmail.com

All reference user assignments can be subject to approval processes and workflows that meet your individual security and audit guidelines. Additionally, configuration settings allow for the automatic removal of reference user assignments, so administrators cannot forget to release them.

Numerous logging options guarantee maximum transparency and traceability, protecting your company from fraud or penalties from auditors. All audit logs can also be sent automatically via email to defined distribution groups (e.g., your internal auditing team).

As with EAM, you can also use Xiting Times to implement a backup user concept. For example, Xiting Times can allow ordinary users to assume the roles and authorizations of others—for example, to cover for colleagues who are on vacation or sick leave. As a result, you can prevent interruptions to your business processes without requiring users to share accounts and passwords.

In this backup user scenario, compliance with internal audit guidelines is of course important, which is why Xiting Times provides numerous reporting options that provide a transparent audit trail of all actions users performed in the SAP system.

4.7 Xiting Role Profiler

Authorization systems are as dynamic as their underlying business processes and thus are subject to frequent change. Every time you start a new IT project, you introduce new requirements that often trigger changes to the existing role and authorization concept. As shown in Figure 4.17, Xiting Role Profiler can analyze existing roles and users to find critical authorization and SoD conflicts based on an existing or XAMS-provided ruleset, among many other things.

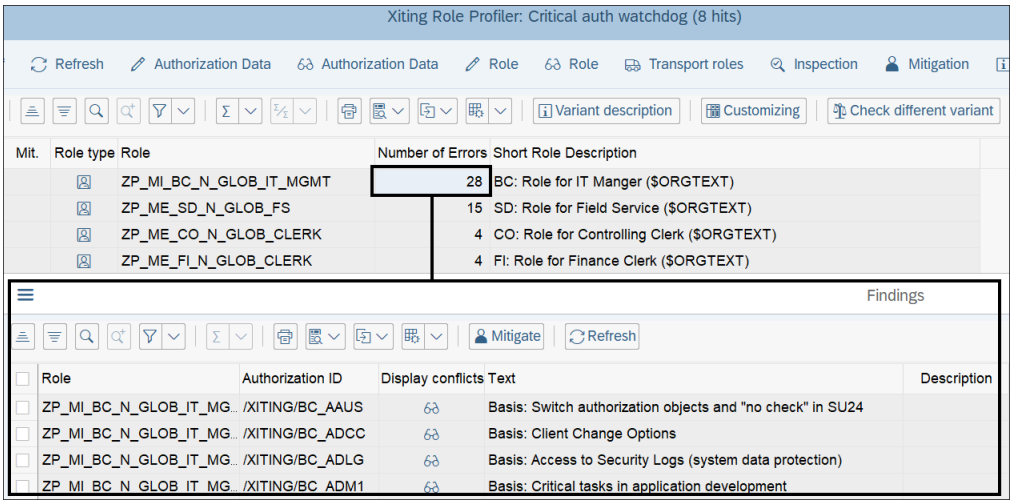


Figure 4.17 Xiting Role Profiler Critical Authorizations in the Roles Watchdog

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

In the course of this work, incorrect and incomplete implementations of requirements can occur, which in turn can lead to the accidental assignment of critical authorizations and the introduction of SoD conflicts. For example, you might accidentally include "change authorizations" to "display roles" that are meant—as the name implies—to display information only. Non-display authorizations should never be a part of such roles.

Furthermore, authorizations that enable access to sensitive personnel or human resources (HR) data should only be maintained in roles assigned to employees of the HR department.

In general, critical authorizations should only be available to a selected group of people. Checking the quality of roles and compliance requirements is, therefore, an important aspect of any role design.

With Xiting Role Profiler, over 120 comprehensive reports are available to examine SAP authorizations for qualitative aspects and risks, including the following kinds of reports:

- Analysis of role quality and sustainability, such as discovering roles with open, changed, or * authorizations and more
- Checks for critical authorizations and SoD conflicts
- Derived roles to identify discrepancies between parent and child roles
- Transaction SU24 optimization reports to optimize your authorizations proposals database using system roles and usage data
- Mitigation reports
- SAP HANA and SAP S/4HANA reporting to quickly assess the impact on your roles during an SAP S/4HANA migration, identify critical database privileges, and more
- SAP Fiori reports
- Transaction ST03N evaluations to identify unused transactions in your roles and more
- License classification to find out if your users have the appropriate licenses assigned to them
- RFC and batch service reports for an overview of your RFC landscape and technical users
- Analysis of SAP Business Warehouse (SAP BW) authorizations for users

Xiting Role Profiler also offers various tools and reports to mitigate security risks. For example, you can easily identify and analyze purely technical users (e.g., RFC interface users) and ensure that they have the proper technical roles assigned. Using the *watchdog reports*, you can check roles for critical errors in their intended functions and get insights into the following areas:

- Roles that contain non-display authorizations
- Roles that allow access to HR data

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Roles that have critical Basis authorizations according to the Deutsche SAP Anwendergruppe (DSAG) test guidelines
- Roles that contain critical authorization combinations according to the DSAG test guidelines

Integration into the SAP Transport Management System (STMS) ensures that authorizations are not transported if they do not meet a defined quality standard. In this way, operative alignment with the authorization concept can be ensured and made sustainable for the long term, and a continuous optimization process can be initiated.

You can also use Xiting Role Profiler to optimize Transaction SU24 to improve the quality of your role concept and to simplify the creation of new roles.

Note

The effort involved in making the necessary updates to your authorization concept after SAP upgrades can be enormous if the SAP default values are poorly maintained. Manually inserted authorization fields and values have no technical connection to their related authorization objects. In other words, you cannot rely on the where-used list to find out how and why those manual insertions were made. As a result, the correct maintenance of SAP default values is vital for a standard-compliant authorization concept and to reduce administration costs.

From a technical point of view, an SAP system allows you to maintain authorization proposals for any type of applications that can be added to the role menu in Transaction PFCG. SAP provides default values for various applications (e.g., transactions). Maintaining and optimizing these suggested values via Transaction SU24 based on best practices increases the transparency and maintainability of your entire role and authorization concept.

Xiting Role Profiler supports you in maintaining authorization default values and implementing a sustainable authorization system. For example, during the creation of new roles, Xiting Role Profile is beneficial for leveraging authorization proposals as much as possible instead of manually inserting objects, fields, and values.

With Xiting Role Profiler, you can easily identify and close gaps in your authorization proposals database. Additionally, Xiting Role Profiler can be used to check SAP authorizations for qualitative criteria. This capability enables you to comply with internal and external regulations by offering proof that audits have been carried out.

Many reports in Xiting Role Profiler can assist auditors and security admins in proving internal and external regulation compliance, as shown in Figure 4.18, especially the reports under **Role Quality & Sustainability**. In addition, **Role Activity Watchdog Reports** in XAMS offer extensive role and user scanning capabilities for checking critical authorizations, compliance with data protection, individual security checks, and SoD.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

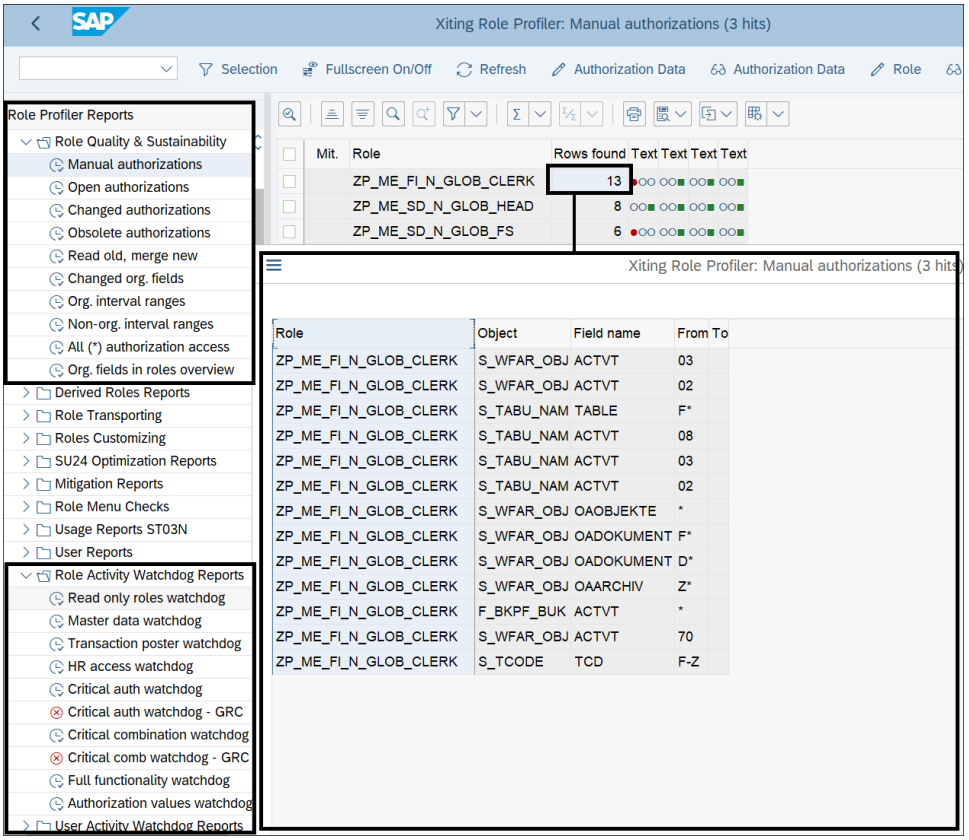


Figure 4.18 Xiting Role Profiler Security Compliance Reports

Integration with the SAP transport management system (STMS) ensures that authorizations are not transported if they do not meet a defined quality standard. In this way, operative alignment with the authorization concept can be ensured sustainable in the long term, and a continuous optimization process can be initiated.

4.8 Xiting Security Architect

SAP constantly delivers new functions and extends existing functionality. But understanding the settings for these functions and how your security concepts must be adapted accordingly requires extensive knowledge and a lot of time. Often, security concepts are not up to date—sometimes, not available at all. As shown in Figure 4.19, Xiting Security Architect is the XAMS module that can be used for security monitoring and conception generation.

All of these factors make it difficult for security administrators to prepare for external security audits and to mitigate potential findings efficiently.

Personal Copy for Arun Singal, arun.singal560@gmail.com

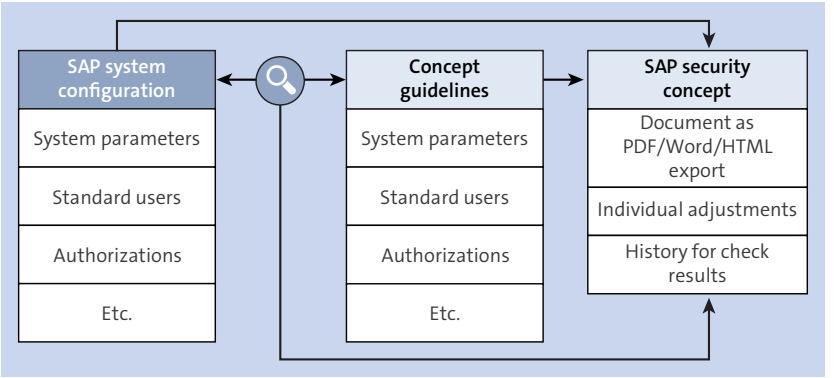


Figure 4.19 Xiting Security Architect Systematic

One of the first steps to better prepare for audits is the creation of an internal security concept. Unfortunately, establishing such a concept and keeping it updated can be time consuming because you often must take legal and compliance regulations into account. Additionally, you must also analyze and take internal requirements and risks into account. All of these steps are required to establish and implement a comprehensive security concept. Updating and adapting the concept based on frequently changing requirements of numerous business units and departments is another challenge that many organizations underestimate.

But you'll need to consider even more. The next step is to periodically compare your actual SAP systems with the guidelines and parameters defined in your security concept to detect potential discrepancies and audit issues.

Such validation should be carried out regularly due to constantly changing SAP system settings to ensure that the system status always corresponds to the security concept and that any defects can be rectified on time.

With the help of Xiting Security Architect you can generate an SAP security concept based on best practices for your SAP system environment, either by system or from a central system (e.g., SAP Solution Manager). The creation of the security concept is either based on a predelivered Xiting best practice template or on a company-owned template, which can be easily integrated into Xiting Security Architect via an upload function. An example of a concept template is shown in Figure 4.20.

Xiting offers a variety of prebuilt concept templates for the areas of SAP Security, SAP governance, risk, and compliance solutions (SAP GRC solutions), SAP Solution Manager, SAP HANA, SAP ERP Human Capital Management (SAP ERP HCM), J2EE, and ABAP code. By using a best practice template, you save yourself the time-consuming task of creating concepts on your own, while still adapting it to your requirements with just a few clicks. For example, you can easily incorporate your company logo and adapt the document to your corporate identity. Additionally, you can quickly add, remove, or hide specific chapters based on your internal requirements.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

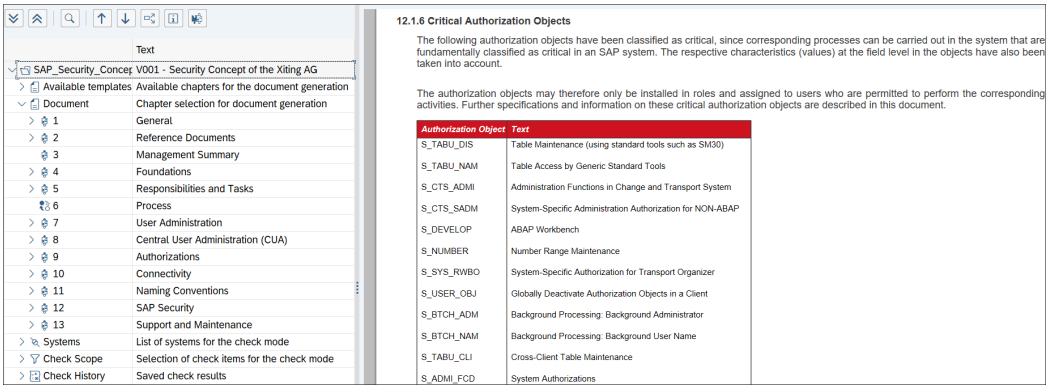


Figure 4.20 Example Section of the Xiting Default Security Concept

This security concept helps you implement the secure administration of your systems and supports you in, among other things, planning a role redesign. The concept can also be used as a basis for future IT audits.

Once a security concept has been created, it can be printed or exported as a Microsoft Word document or HTML file. You can also take a snapshot of your current concept and compare the current concept with previous versions.

Xiting Security Architect comes with *check modes* that allow you to check the current state of your systems against the target state defined in the document. These check modes are either predefined or can be fully customized to your needs. This process can be performed locally for one system, as well as a centrally from a central system (e.g., SAP Solution Manager) for several systems. Thus, you can test and monitor your system security configuration at any time and save your test results. Compliance with requirements can then be compared over time and tracked accordingly.

The integrated tests and checks determine the current status of your systems in the following areas, comparing the current state to the requirements defined in the security concept:

- User administration (e.g., checking of standard users, etc.)
- Authorizations (e.g., checking for critical authorizations, etc.)
- Role management (e.g., checking the naming conventions of roles, etc.)
- System settings (e.g., parameter check for the security audit log, etc.)
- System security (e.g., checking Secure Network Communication [SNC], RFC connections, etc.)

Each of these check categories comes with an extensive set of individual tests (check IDs) that you can enable, based on your requirements. You can also create your own check IDs based on a predefined API.

Personal Copy for Arun Singal, arun.singal560@gmail.com

All tests can be carried out on demand or scheduled via background jobs. After completing a test, you can either display the results in line with your security concept or in a separate table view, or you can receive a comprehensive report via email.

Compared to the manual procedure for creating and maintaining a security concept and checking systems, the use of Xiting Security Architect can save you an enormous amount of time. In addition, you'll always have an up-to-date and audit-compliant security concept that can be easily implemented in your systems.

Xiting Security Architect delivers ready-to-use security concepts for SAP that are based on best practices and SAP's security guidelines. With Xiting Security Architect, you can generate and publish a best-practice security concept and continuously monitor your SAP systems for compliance issues. When using Xiting Security Architect in a centralized approach, you can manage your global SAP security concepts and compare them against connected systems.

4.9 Summary

This chapter covered XAMS, SAP's preferred and recommended solution for RFC authorization cleanup, as mentioned in SAP Note 1682316. The same principles and tools also apply to regular end-user authorizations and offer numerous simplifications and time savings. XAMS not only helps you implement authorization concepts more efficiently, you can also more easily move security to the next level and cut out inconsistencies in your role design. Frameworks like the PTS offer new ways for testing authorizations without negatively impacting your end users while at the same time saving effort both on the IT as well as the end-user side. XAMS is fully built in ABAP, is SAP certified for SAP S/4HANA, works with every SAP release higher than SAP NetWeaver 7.00, and fully utilizes SAP's best practices. XAMS can be licensed perpetually, as well as subscribed for short- and long-term use.

In the next chapter, we'll discuss authorization default values.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 5

Transaction SU24: Authorization Default Values

Authorization default values form the backbone for sustainable role creation and maintenance within SAP Business Suite. Integrating these default values into your authorization concept ensures the proper usage of applications and reduces role maintenance effort after new SAP upgrade releases. This topic is fundamental for a security administrator to fully understand how to maintain, upgrade, optimize, and use these proposals correctly.

The primary safety barrier in almost every SAP application's source code are its AUTHORITY-CHECK statements. This code entity specifies which authorizations are necessary to pass the authority checks that the developers have implemented. However, more than 3,500 SAP standard authorization objects exist in SAP Business Suite. A common role maintenance challenge for SAP security administrators is to find the correct combination of the required authorization objects, fields, and values required to execute the menu objects in end-user roles (also called *role menu objects*). Therefore, SAP delivers *authorization default values*, also called *proposals*, which is technical data that constitutes the required authorization objects with their fields and values for almost every role menu object, such as transactions, function modules, or Web Services. The SAP system automatically merges the correlated authorization default values into the role's authorization profile when maintaining the objects in the role menu. These proposals are fundamental for sustainable source code-based role maintenance. The accuracy and consistency of these proposals depend on their regular updating to reflect changes made to the authority checks in the underlying source code, such as during SAP upgrades, support packs (SPs), and SAP Notes. Please note that you cannot build a consistent and maintainable role concept without using proposals.

Proposals become significantly more essential when moving from SAP ERP 6.0 to SAP S/4HANA. This new SAP product involves an extensive simplification approach, including process consolidation, architectural enhancements, and novel feature integration. Thus, a one-to-one authorization transition is impossible. The more you use proposals, the more efficiently your current role concept can be transferred to SAP S/4HANA.

This chapter contains extensive information for understanding, implementing, and maximizing the advantages that come with proposals for managing your authorization

Personal Copy for Arun Singal, arun.singal560@gmail.com

concept. We'll also provide technical and theoretical insight into working with the corresponding expert tool—Transaction SU24. You'll learn about the relationship and impact of Transaction SU24 on security-relevant topics and discover why proposals are necessary to reduce your role maintenance effort. Moreover, we'll share information about release-dependent authorization default value upgrades and various optimization opportunities, for example, for introducing your business processes into proposal data.

5.1 Overview

Authorization objects are the key determinant for enabling operators to work with applications in the SAP system. Thus, you must assign proper authorizations to end user roles to enable users to pass various system authority checks. To find and provide for technical requirements like authorization objects, fields, and values for an intended end user's actions for each application, you can specify authorization default values.

This section introduces you to the theoretical preconditions for understanding the proposal values framework and its benefits. We'll introduce you to the SAP authorization default values and describe why they are necessary.

5.1.1 What Are SAP Authorization Default Values?

Generally, in every SAP standard application, authority checks (via `AUTHORITY-CHECK` statements) are included within the ABAP program code. Almost every function in an application is protected through such a code statement. Based on these checks, SAP also delivers a ready-to-use authorization bundle for each application, called *authorization default values*. These bundles depict the authorization requirements to successfully pass an application's source code authority checks for the intended program functions.

> **Hint**
>
> In addition to program authority checks, other independent system checks also exist. Please note that they also have their own requirements, as described in Chapter 2, Section 2.6.

In our example shown in Figure 5.1 for Transaction FBO3 (Display Document), you'll see the link between authority checks and authorization default values. Recall that a transaction is only a specific shell for a program. The program behind Transaction FBO3 is **SAPMF05L**, as shown in Figure 5.1.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

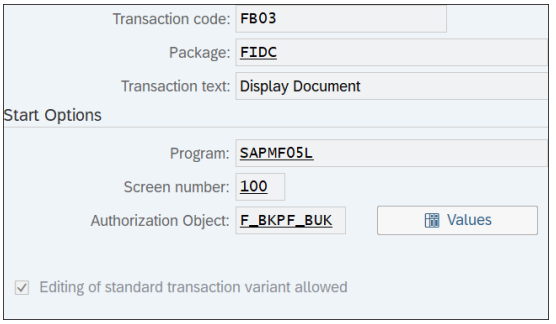


Figure 5.1 Technical Overview of Transaction ME21N

This program contains various AUTHORITY-CHECK statements within its source code, which restrict the functional accesses of the program used by Transaction FB03 (program SAPMF05L). Figure 5.2 shows an extract of AUTHORITY-CHECK statements for the authorization object **F_BKPF_BED** or **F_BKPF_BEK**. The lines below these statements specify the required authorization fields and values needed to pass the checks. Consequently, you must maintain these necessary authorizations in your end-user roles to enable the use of Transaction FB03.

```
000256       AUTHORITY-CHECK OBJECT 'F_BKPF_BED'
000257         ID 'ACTVT' FIELD ber-act
000258 * (del) id 'BRGRU' field knb1-begru.                    "Note 321533
000260       IF sy-subrc NE 0.
000261         IF ber-act = '02'.             "Aenderungstransaktion
000262           AUTHORITY-CHECK OBJECT 'F_BKPF_BED'
000263             ID 'ACTVT' FIELD '03'
000264 * (del)     id 'BRGRU' field knb1-begru.                "Note 321533
000312                                 xbmodz.                  "Note 321533
000313     IF sy-subrc NE 0.
000314       AUTHORITY-CHECK OBJECT 'F_BKPF_BEK'
000315         ID 'ACTVT' FIELD ber-act
000316 * (del) id 'BRGRU' field lfb1-begru.                    "Note 321533
000318       IF sy-subrc NE 0.
000319         IF ber-act = '02'.             "Aenderungstransaktion
000320           AUTHORITY-CHECK OBJECT 'F_BKPF_BEK'
000321             ID 'ACTVT' FIELD '03'
000322 * (del)     id 'BRGRU' field lfb1-begru.                "Note 321533
000361       a03-rcode xbmodz.
000362     IF sy-subrc NE 0.
```

Figure 5.2 Authority Checks in SAP Program SAPMF05L

To avoid time-consuming and complicated role maintenance requirements, you can use authorization default values to find and maintain the correct authorizations (authorization objects, fields, and values) for all necessary applications. You can retrieve these requirements (e.g., **F_BKPF_BED** or **F_BKPF_BEK**) in the authorization default values for Transaction FB03 in Transaction SU24, as shown in Figure 5.3.

Personal Copy for Arun Singal, arun.singal560@gmail.com

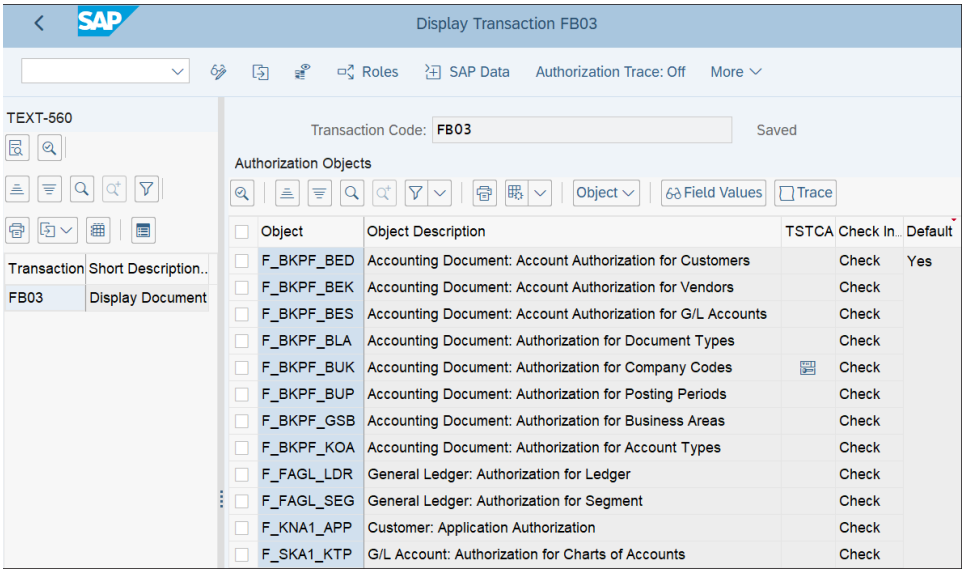


Figure 5.3 Selected Proposals of Transaction FB03

The purpose of proposals is that, if you maintain Transaction FB03 in the role menu, the profile generator proposes all required authorizations into the authorization profile, as shown in Figure 5.4 for Finance (FI) authorization objects.

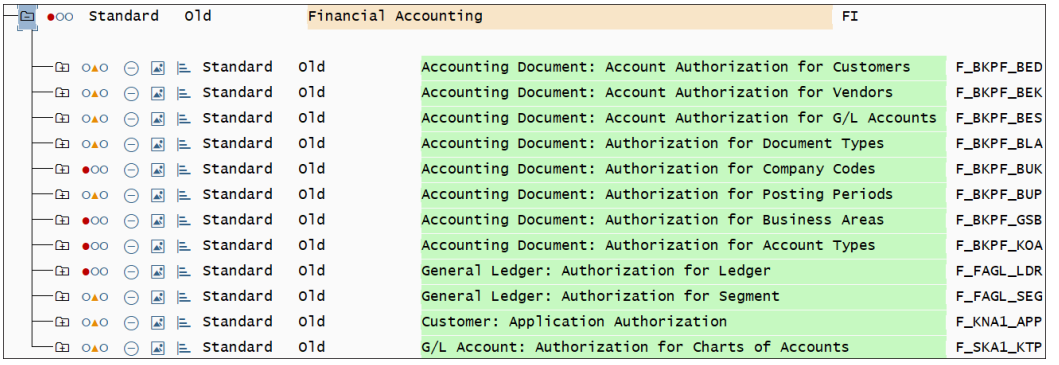


Figure 5.4 Financial Accounting Authorization Objects for Transaction FB03

Hint

Please note that the delivered authorization default values depict a general condition. Based on your business requirements, you might need to adjust these proposals or add authorization objects in Transaction SU24 to enable additional functional access or restrictions.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

You can directly cover your authorization needs through these direct connections between the application's program checks and intended proposals. Finally, you only must maintain the open authorization fields to specify data access.

Using authorization default values offers many advantages for authorization and role maintenance, including the following:

- You can maintain the proper authorizations end users require for executing and working within a program.
- You do not need to find and maintain the necessary authorization objects manually.
- You can easily maintain the required authorizations by only maintaining the application in the role menu.
- You have a direct link between existing authorizations and applications in your role profile.
- You can follow the least privilege (also called *need-to-know*) principle for your end-user authorization provisioning when using the authorization default values.
- You can maintain proposals according to your business needs individually through Transaction SU24.
- You save time when maintaining your role authorizations and follow all best practices.
- Your roles are permanently upgradable for further releases by using authorization default values.

Hint

Using authorization default values is important to avoid manual authorization objects. These kinds of authorization objects do not have any application context, and thus, no where-used list information is in the authorization profile. Thus, their initial requirement is not relatable anymore. Not having the where-used list means that you can only guess to which transaction the authorization object belongs. Besides, if your roles do not carry the where-used list from Transaction SU24, your role remediation tasks will be negatively impacted. You require this information to evaluate the security quality of your roles. Thus, using various manual objects in your business roles increases the risk of granting end users critical access and incomprehensible authorizations.

See Chapter 6, Section 6.4.2, for more information about the authorization object status **Manual**.

5.1.2 Technical Background of Authorization Default Values

Figure 5.5 shows a straightforward but essential roadmap from the integration of authority checks in applications to the generation of role profiles to pass to the system's validation checks. This diagram should help you understand the intention of

Personal Copy for Arun Singal, arun.singal560@gmail.com

authorization default values and why they are mandatory for role creation and maintenance according to best practices.

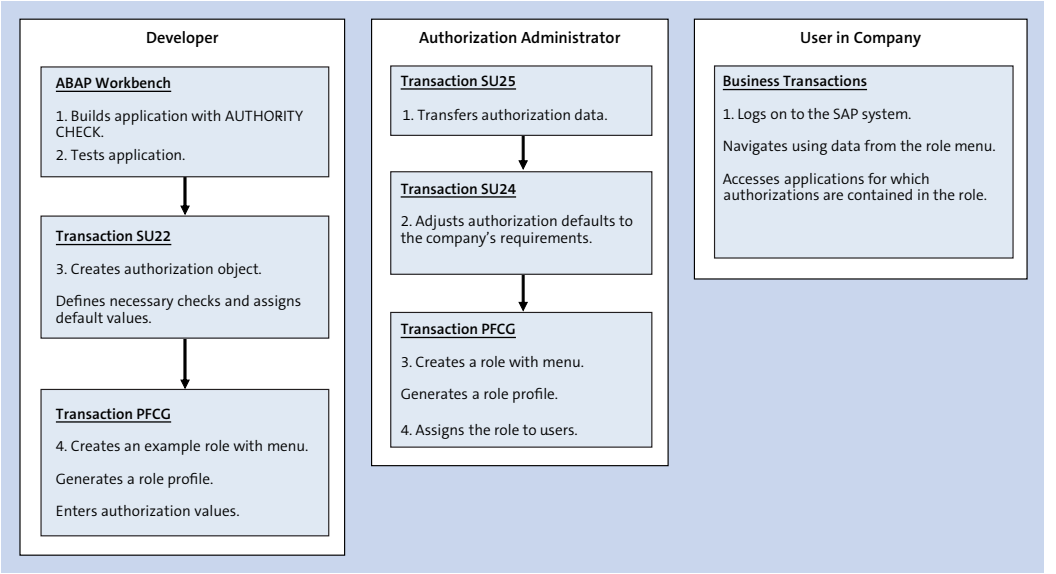


Figure 5.5 Flowchart from Programmed AUTHORITY-CHECK to Role Usage

In the first phase, SAP developers create programs based on the ABAP code. They also determine which authorization objects, fields, and values should be checked in the source code via `AUTHORITY-CHECK` statements. Moreover, developers will create the required authorization objects and fields and customize the maintainable authorization values in the fields. Afterward, they will test the application and its authority checks. If the tests are successful, the developer can insert default value definitions via Transaction SU22 in table `USOBT` for the related application. These value definitions store the required check indicators in table `USOBX`. A check indicator shows whether the system checks the authorization object or not within a specific application. Finally, developers will also test the proposal integration in example roles via the role menu.

As an authorization administrator, you can view these SAP standard tables to check SAP proposed values but cannot change them manually. These two tables are updated with new proposals during system release upgrades. While the SAP standard tables (tables `USOBT` and `USOBX`) are overwritten, tables `USOBT_C` and `USOBX_C` will contain your preferred values. Use Transaction SU25 to load the provided authorization default values from the standard tables `USOBT` and `USOBX` into the customer-related tables `USOBT_C` and `USOBX_C` initially, and then maintain your customer-specific values in the customer tables. SAP proposal upgrades do not overwrite your customer-specific tables unless

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

specified. Do not ever merge your SAP and customer tables manually. You can customize proposals via Transaction SU24. Every time you use Transaction SU24 to maintain the proposal values and indicators, tables USOBT_C and USOBX_C are updated. Always carry out periodic SAP proposal upgrades via Transaction SU25 if SAP delivers new Transaction SU22 data, which may contain security- and function-relevant content due to the latest ABAP code changes. Only these updates enable you to always be up to date with your role authorizations and new source code requirements.

Furthermore, a fixed connection exists between Transactions SU24 and PFCG. Since the proposals constitute the application's authorizations, you can use them in the profile generator when building and maintaining roles. For this task, you must maintain the applications via the role menu. The profile generator proposes the intended authorization objects, fields, and values for the maintained applications, like transactions. This approach eliminates the guesswork about which authorizations you must add. Through this automatic mechanism, you can also carry out an authorizations where-used list within your authorization profile. This list shows you the link between proposals and their applications, which helps you build sustainable roles and avoid manual authorizations. Manual authorizations in business roles are effectively orphaned—they are not linked back to an application—and often lead to overauthorization of roles. In such cases, you won't see any relationship between authorizations and applications, and you won't know why specific authorization objects are assigned, thus making removing or changing them difficult because you can't determine whether they are needed or not.

Finally, your end users can log on to the SAP system. Immediately, the system pushes the authorizations of the role profile into the user buffer. Then, the system compares this buffer with the program's AUTHORITY-CHECK statement requirements and other system checks when the user runs an application. So that end users can access data, business objects, or execute programs, they require the corresponding authorizations. Therefore, an administrator assigns authorizations to end users to specify which actions they can execute in the SAP system based on the underlying source code requirements. Via the roles and their role profiles assigned to a user ID, you can enable the end user to work with Transaction FBO3, for example, as shown in Figure 5.6.

Hint

See Chapter 6, Section 6.5, for detailed information about secure and sustainable role maintenance to fit the SAP standard and best practices.

Personal Copy for Arun Singal, arun.singal560@gmail.com

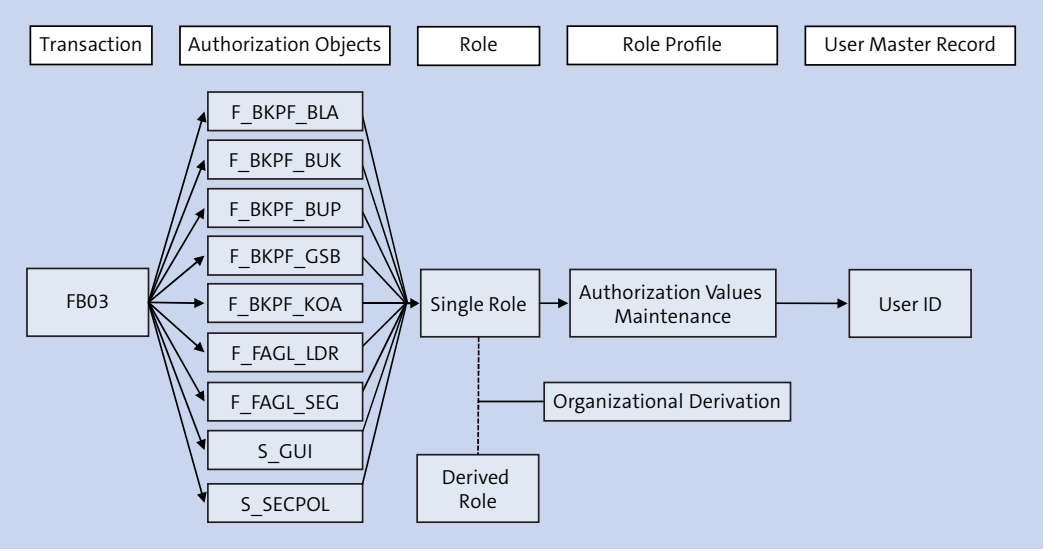


Figure 5.6 Transaction Assignment to End Users for Transaction FB03

5.1.3 Helpful Tables

Table 5.1 lists some helpful tables in the context of authorization default values. In addition, you can use Transaction SU20 to check the short descriptions of authorization fields and their associated repository components.

Tables	Short Description	Table Content
USOBT	Relation transaction > authorization object	SAP default values for menu objects (standard)
USOBX	Relation transaction > check indicator for authorization object	SAP default check indicators for menu objects (standard)
USOBT_C	Relation transaction > authorization object (customer)	SAP default values for menu objects (customer adjusted)
USOBX_C	Relation transaction > check indicator for authorization object (customer)	SAP default check indicators for menu objects (customer adjusted)
TDDAT	Maintenance areas for tables	Authorization areas for all existing SAP tables within the system

Table 5.1 Useful Tables in the Context of Transactions SU24 and SU25

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Tables	Short Description	Table Content
TADIR	Directory of repository objects	Holds the directory of repository objects
TRDIR	System table TRDIR	Contains all client-independent programs
DD02L	SAP tables	Shows all tables that exist in your SAP system
TSTC	SAP transaction codes	Contains technical variables and short descriptions for transactions
TSTCA	Values for transaction code authorizations	Shows the TSTCA objects for all transactions
TSTCP	Parameters for transactions	Consists of all parameter transactions for a transaction
TSTCT	Transaction code texts	Contains the short description of a transaction in different languages (depends on the SAP system language packages)

Table 5.1 Useful Tables in the Context of Transactions SU24 and SU25 (Cont.)

5.1.4 System Layer Alignment

Before you start working with Transaction SU24 and its related customer tables, you must consider the activities that occur on various system layers.

First, authorization default values are considered client-independent data and thus affect all system clients. Accordingly, these values are only necessary to maintain on a single development system (DEV) once. Please note that a best practice recommended by SAP is to only maintain your proposals on the DEV. In this way, you can guarantee that you have transparent change and transport documentation and the same proposal customizing on every upstream system. Every time you change a proposal setting on your DEV or after a Transaction SU25 upgrade, you should transport this data through subsequent systems into the productive system (PRD). You can transport your authorization default data entirely through Transaction SU25, step 3. Individual Transaction SU24 changes always require a workbench request so that you can transport these changes.

Table 5.2 provides an overview of proposal maintenance activities in the context of a three-layer system, including the quality system (QAS). Note that DF stands for "designed for," indicating that you should carry out the related system layer's activities. On the other hand, NDF indicates this activity is "not designed for," which means you should not do these activities on that system layer to align with best practices.

Personal Copy for Arun Singal, arun.singal560@gmail.com

System Layer/Activities	DEV	QAS	PRD
Maintenance	DF	NDF	NDF
Upgrade	DF	NDF	NDF
Transport	DF	DF	NDF

Table 5.2 Proposal Activities Depending on the System Layer

Another best practice is to transport proposal-related tables from one DEV to another if possible. This transport must have the same authorization consistency on every SAP system as a joint base for your role building activities.

5.2 Transaction SU24 Maintenance

Through Transaction SU24, you can maintain all the proposals for your SAP, partner, and custom applications. The main objective of maintaining Transaction SU24 is to configure your proposals to represent your technical requirements and your business processes.

This section provides the basics for understanding the technical components and proposal maintenance options in Transaction SU24.

5.2.1 Instruments of Transaction SU24

When you launch Transaction SU24, the initial selection screen will open, as shown in Figure 5.7.

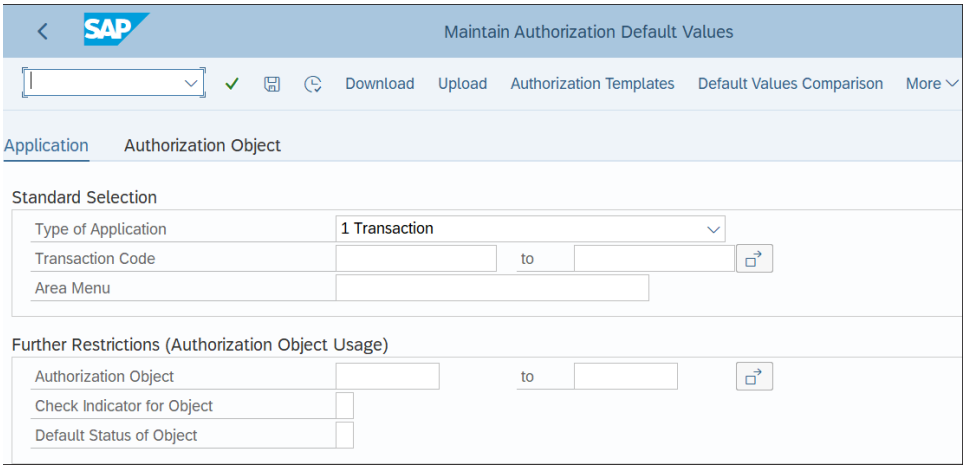


Figure 5.7 Initial Selection Screen of Transaction SU24

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

This screen provides you the following options:

- **Download and Upload**
  Within a complex system landscape, usually you'll need the same proposal consistency in all systems. Use the transport mechanism in Transaction SU25 to distribute your customer tables or back up your data records within a transport task. Alternatively, you can click the **Download** or **Upload** buttons to export, import, and store your proposals. Although not recommended due to security concerns, for instance, you can modify downloaded data directly with an editor.
- **Authorization Templates**
  This button enables proposal adjustments for SAP authorization templates that you can insert into a role's authorization profile. Using such profiles is not recommended for business roles because these templates contain manual authorization objects and do not accurately depict customer-specific authorizations since these authorization collections lack direct relationships with applications.
- **Default Values Comparison**
  If you want to compare the SAP default data records and customer default data records of one or more applications, you can click this button. However, this activity is not recommended for a complete upgrade of SAP authorization default values, only for specific comparisons. For upgrades, use Transaction SU25, step 2b.
- **Selection screen options and execution**
  On the main selection screen of Transaction SU24, two application tabs are available for you to select your targeted maintenance objectives, as shown in Figure 5.8.

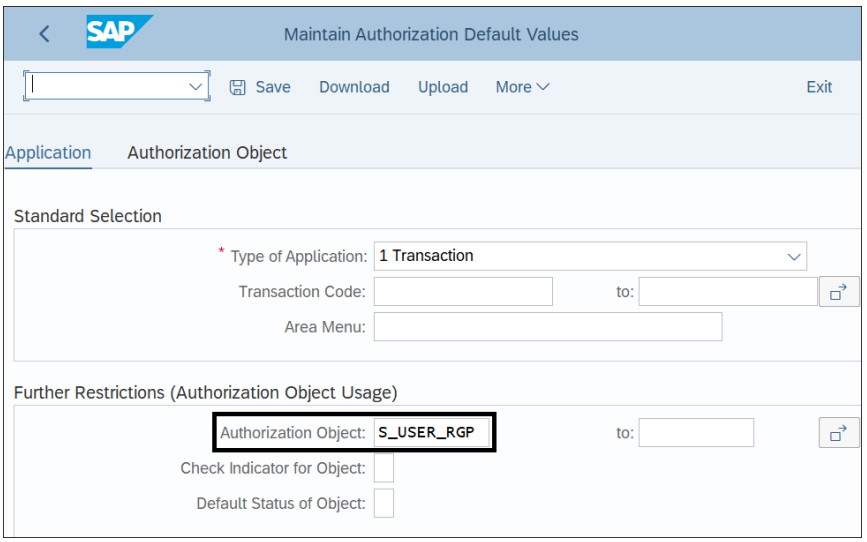


Figure 5.8 Looking for All Applications with Authorization Object S_USER_GRP in Transaction SU24

Personal Copy for Arun Singal, arun.singal560@gmail.com

The first tab is the **Application** tab. The **Standard Selection** area allows you to search for a specific menu object to customize the related authorization objects and their data. First, make a selection in the **Type of Application** dropdown list and enter a name for the application. For a more granular selection, in the **Further Restrictions (Authorization Object Usage)** section (**Authorization Object Usage**), choose between **check indicators**, **default status**, or the concerning **authorization object** (e.g., **S_USER_GRP**). The second tab is the **Authorization Object** tab. This selection filter enables you to search for an application with a specific authorization object.

5.2.2 Proposal and Check Indicator Statuses

The most important data you can maintain in Transaction SU24 is an application's default values and the check indicators for its related authorization objects. These items have considerable influence on your entire authorization concept. Proposals can be in one of three main statuses, listed in Table 5.3. A proposal in status "Yes" enables the automatic introduction of authorizations into an authorization profile. However, don't forget that this feature only works if you also activate its check indicator.

Status	Explanation
Yes	The system automatically proposes the authorization default values in the profile generator, but you must adjust certain open fields.
Yes, Without Values	The system automatically proposes the default authorization default object in the profile generator without any authorization values.
No	The system does not automatically propose authorization default values in the profile generator.

Table 5.3 Proposal Statuses

Besides proposal statuses, check indicators for various applications are also essential. You can set whether the system checks the related authorizations based on the implemented program checks in the application or skips authorizations with certain indicators. Even if a fixed `AUTHORITY-CHECK` statement exists in the source code, the system compares this code statement with the check indicator status in transaction SU24 for the intended application. A value of 0 for the return code (RC) is provided directly if the indicator is set to **Do Not Check**. Please note that this check adjustment is authorization object and application specific. Disabling specific checks, however, significantly affects your authorization default values, their statuses, and indeed your entire authorization concept and may lead to critical system access and abuse. Keep in mind that you can change the check statuses of HR and Basis authorization objects. Table 5.4 contains the two available check statuses.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Status	Explanation
Check	The system checks the authorization objects against the implemented program AUTHORITY-CHECK statements.
Do Not Check	The check is disabled, and the system skips the comparison of the end-user master record data with the program's AUTHORITY-CHECK statements for this authorization object.

Table 5.4 Check Indicator Statuses

Hint

You must be aware that simply adding an authorization object to an application in Transaction SU24 does not mean that it will be checked. All authorization checks, except S_TCODE and TSTCA, must be called by an AUTHORITY-CHECK statement. However, if you need to deactivate a statement check for a specific application, you can change its status in the check indicator column to **Do Not Check**. This feature requires the enabled profile parameter auth/no_check_in_some_cases in Transaction RZ10, which by default has the value "Y."

5.2.3 Maintenance of Default Values and Check Indicators

To understand the fundamental maintenance actions and instruments of Transaction SU24, in this section, we'll work through an example of proposal maintenance for Transaction SU01. First, you must enter the transaction in the main selection screen of Transaction SU24, as shown in Figure 5.9. Execute the selection to open the maintenance window.

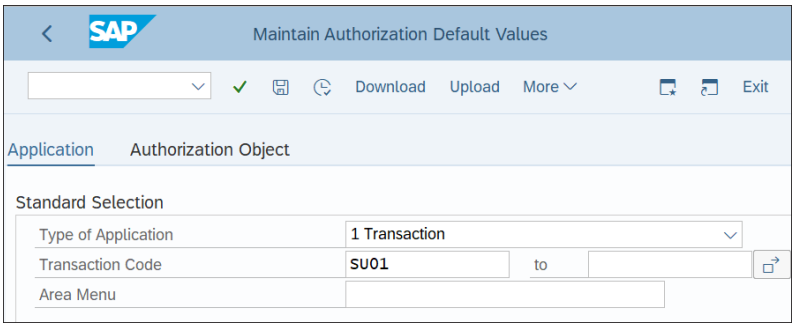


Figure 5.9 Selection of Transaction SU01 in Transaction SU24

In the initial maintenance view, the header bar provides access to some essential features, as shown in Figure 5.10.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Figure 5.10 Header Bar in Transaction SU24 Maintenance Area

While the features of the **Save** icon or the switch between display and change modes are fairly obvious, let's look at a few more important buttons:

- **Other objects**
  If you click the icon, you can add more transactions to your selection result area on the left. Which menu object type you can add depends on your initial application type settings in the main selection.
- **SAP Data**
  Click this button to see the original default values with the proposal status "Yes or No." Please note that the authorization fields and values are only displayed if the authorization object has the status "Yes."
- **Authorization Trace**
  This button shows whether an authorization trace is enabled or disabled. Click on it to see further information. You can also enter the authorization trace tool with Transaction STUSOBTRACE.

Hint

See SAP Note 543164 and Section 5.4 for more information.

- **Merge Mode for PFCG**
  This indicates whether the automatic role profile merge mode for your roles is activated (**On**) or deactivated (**Off**).

  When activated, the merge mode results in a direct merging. Transaction SU24 data changes immediately affect your roles with a maintained role menu when you save your maintenance settings. As a result, when the changed defaults are saved, the system checks whether the changed application is used in the role menu and whether changes to the default values cause changes to authorizations. If so, the affected roles are placed in the status **Profile comparison required** (merge mode). When the authorization data for these roles is next changed, the authorization data is compared to the roles with the changed default values. This behavior corresponds to Transaction SU25, step 2c.

  If you have this mode off, the system only stores default values and does not check for follow-on activities that might be required in Transaction PFCG.

Hint

To activate or deactivate this automatic adjustment feature in the profile generator, you must enable or disable the parameter `SU2X_SET_FORCE_MIX` in table `PRGN_CUST`.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Roles**
  By clicking this button, you can list all existing roles containing the selected application in the role menu. This feature is like a where-used list for roles.
- **Maintenance Area**
  Below the header area, on the left, you'll see the selection result with Transaction **SU01**, as shown in Figure 5.11. On the right, you'll see a list of all authorization objects that are maintainable for this application.

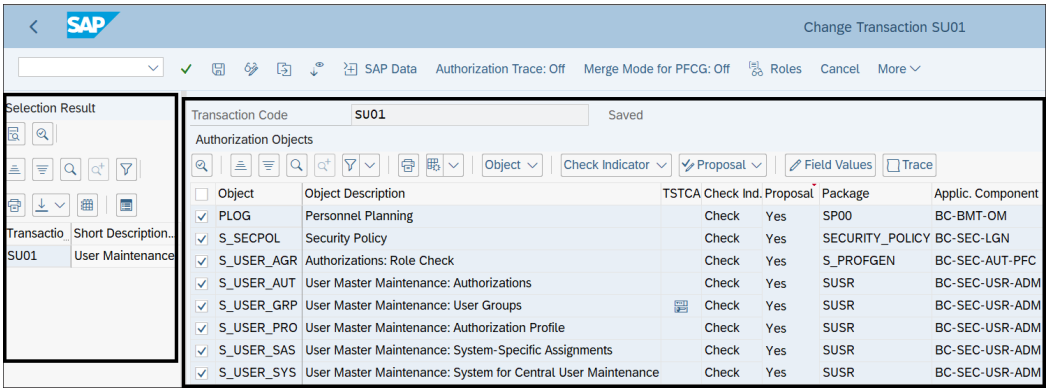


Figure 5.11 Maintenance Area for Transaction SU01

Hint

You should only change the default values for authorization fields (other than organizational levels) in Transaction SU24.

You can click on the **Object** button to add a new authorization object if the desired object is mandatory for your business process or the usage of the application. Otherwise, work with SAP's predefined default values and check indicators. Through the **Check Indicator**, **Proposal**, and **Field Values** buttons, you can maintain an application's various statuses and authorization object characteristics. You can also use the **Trace** function to enrich your current data based on end-user activities.

In the **Object** column, you'll see the authorization objects maintained for Transaction SU01. However, the system does not necessarily directly merge these objects into your authorization profile. Note that this activity only occurs if the proposal status is **Yes** and you've maintained the application in the role menu. The next column is the **Object Description** column, which provides some information about the nature of the authorization object. Then, you have the **TSTCA** column. In our example, the authorization object **S_USER_GRP** and its fields are required for the additional system precheck (TSTCA check) to enter Transaction SU01. This mandatory definition is maintained in Transaction SE93. You cannot remove this definition in Transaction SU24 because it is fixed in table TSTCA. The fifth column is the **Check Ind.** status column. Usually, this col-

Personal Copy for Arun Singal, arun.singal560@gmail.com

umn is locked to **Check** if the proposal status in the **Proposal** column is set to **Yes**. The **Proposal** column shows whether the system proposes the authorization object and has either the status **Yes** or **No**. The last two columns describe the referring developer package (**Package**) and component (**Applic. Component**).

If you want to change the default authorization field values of Transaction SU01, switch to change mode. Double-click on the authorization objects with values that you wish to adjust. Select the target authorization object in change mode and click the **Field Values** button. In the maintenance area, adjust the characteristics of the authorization field as needed.

For instance, in the context of Transaction SU01, SAP only provides the necessary default values for the object **S_USER_GRP**, except the activity **08** for "Display Change Documents," as shown in Figure 5.12. To see who has changed a user, the value "08" is essential.

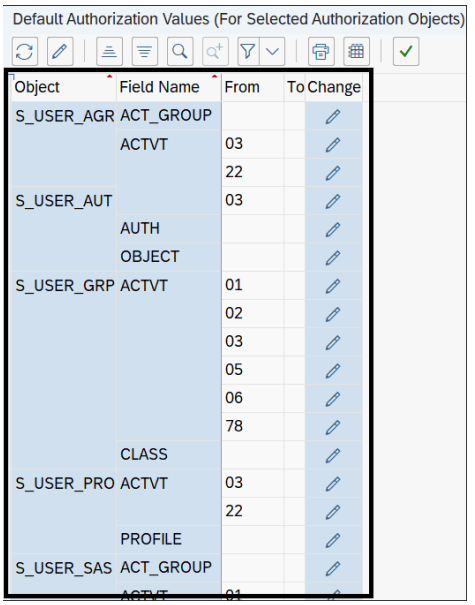


Figure 5.12 Field Value Maintenance Selection of Transaction SU01

Click on the icon in the **Change** column. Next, add activity **08** to the authorization object **S_USER_GRP** and save these settings through a workbench request, as shown in Figure 5.13. Please note that you might also have fixed TSTCA authorization values. In this case, you must ensure that the required values are maintained in Transaction SU24.

Hint

For more details about the TSTCA authorization object, see Chapter 2, Section 2.6.5.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Object	Field name	Icon	From	To
S_USER_GRP	ACTVT		01	
			02	
			03	
			05	
			06	
			08	
			78	
			F4	
	CLASS			

Figure 5.13 Field Values for S_USER_GRP with ACTVT 08

Afterward, launch Transaction PFCG. Enter the role containing Transaction SU01 in the role menu and move to the **Authorization** tab. Maintain the authorization profile with the expert mode option **Read old status and merge with new data**. The system automatically proposes **S_USER_GRP** with an additional **ACTVT** field value **08**, as shown in Figure 5.14.

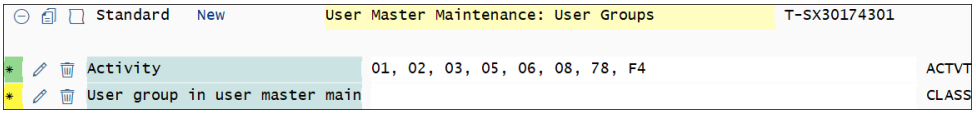


Figure 5.14 Added Activity 08 in Authorization Object S_USER_GRP

5.2.4 Comparison between SAP Data and Customer Data

For recurring proposal data maintenance, comparing your customizing against the original SAP defaults can be helpful. For this task, access the comparison mode via the **SAP Data** button in Transaction SU24, located in the maintenance area's header bar. The system uncovers additional columns—**SAP ChkInd** (SAP check indicator) and **SAP Propsl** (SAP proposals)—with initial statuses, as shown in Figure 5.15. The system also compares tables USOBT/USOBX and USOBT_C/USOBX_C for specific applications in the background.

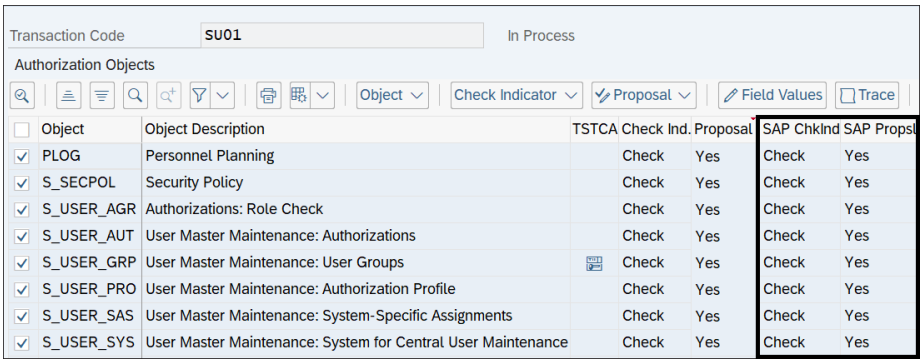
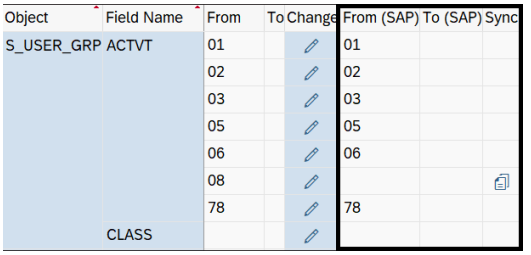


Figure 5.15 Comparison of Customer and SAP Data Proposals

Personal Copy for Arun Singal, arun.singal560@gmail.com

Select the authorization objects and click the **Field Values** button to enter the field value maintenance mode. You'll now see extra columns, as shown in Figure 5.16. You can change your customization to match the initial SAP values by clicking the synchronization icon, as shown in Figure 5.16. Please note that you might accidentally remove important custom values with this maintenance.



Object	Field Name	From	To	Change	From (SAP)	To (SAP)	Sync
S_USER_GRP	ACTVT	01			01		
		02			02		
		03			03		
		05			05		
		06			06		
		08					
		78			78		
	CLASS						

Figure 5.16 Comparison of Customer and SAP Data Proposal Values

5.3 Transaction SU24N

In Basis release 7.54, Transaction SU24 received an enhancement, the new Transaction SU24N. Refer to SAP Note 2798443 for official information about this new proposal maintenance application.

This section explains this enhancement's innovations from general changes up to the two impressive new features: maintaining descriptions and maintaining default data variants.

Hint

Please note that with SAP S/4HANA 2021, SAP converted the new Transaction SU24N functions into Transaction SU24. Thus, Transaction SU24N is no longer available with this release.

5.3.1 General Changes

In contrast to the traditional Transaction SU24, if you enter Transaction SU24N, you'll see the enhanced selection screen shown in Figure 5.17. You can choose from a greater variety of maintainable types of applications. You also have an enhanced selection and search features for more granular proposal investigations.

With Transaction SU24N, you can also use new layout options to distinguish between **Default Status: Single-Column** and **Default Status: Two-Column** to change the maintenance layout of Transaction SU24N. Thus, the single-column option allows to use several new default value statuses, and the option of maintaining check indicators is disabled.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

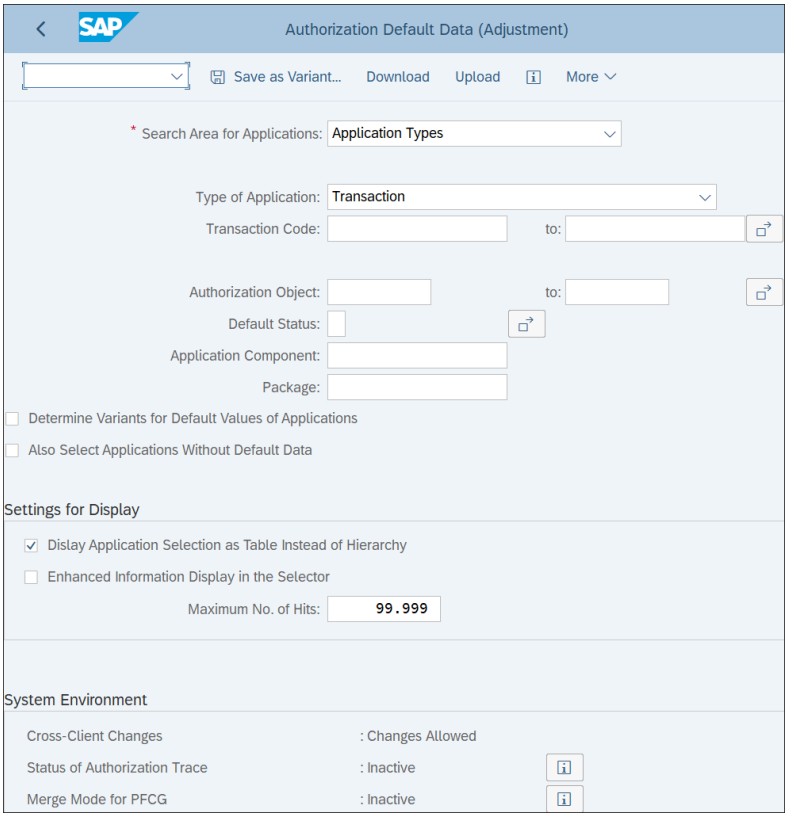


Figure 5.17 Initial Selection Screen of Transaction SU24

If you set a check indicator status to **Do Not Check** in the past, the default value status is automatically changed to **No**. The new default value data statuses in the **Default Status: Single-Column** mode include the following:

- **Set Status YES**
- **Set Status Yes, Inactive Default**
- **Set Status Yes, Without Values**
- **Set Status NO**

For the **Default Status: Two-Column** mode, the maintenance is summarized to the maintenance status without the option to maintain the related check indicator separately. The statuses for this mode include the following:

- **Set: Default with Field Values**
- **Set: Default without Field Values**
- **Set: Default Inactive**
- **Set: No Default**
- **Set: Authorization Check inactive**

Personal Copy for Arun Singal, arun.singal560@gmail.com

With both, you can also introduce an inactive authorization object into an authorization profile.

5.3.2 Maintaining a Description for Transaction SU24 Data

SAP provides options for maintaining comments or descriptions for Transaction SU24 data, which greatly improves transparency into data changes in Transaction SU24. For example, you can maintain information about decisions, approvers, or editors that added default value changes in the target application description field, shown in Figure 5.18. You can use this documentation as a changelog to capture the current proposal maintenance level.

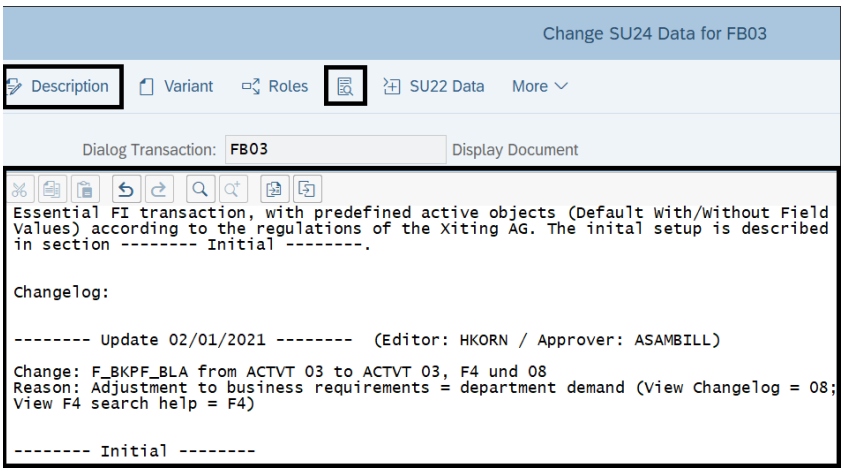


Figure 5.18 Description Field for Transaction SU24 Data

Hint

Please note that you can currently check these descriptions through the print preview. If you need to compare some texts between objects or overview the descriptions, launch table SU2X_TEXT via Transaction SE16(N).

5.3.3 Default Data Variants

For your authorization concept, the inclusion of variants for default data can have the most impact. These proposal variants distinguish among multiple maintenance possibilities within a single transaction. In some scenarios, previously you would have to leave authorization default values empty to have the opportunity to maintain different authorization field values for different roles. Now, with Transaction SU24, you can gain this flexibility through the use of default data variants. In this method, you'll define the required business differentiations for the same application in Transaction

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

SU24 beforehand and then add the default data variants in your roles. Thus, you can integrate different data variants for different job function roles.

For example, Transaction BP is a powerful cockpit transaction in SAP S/4HANA that encapsulates many business partner-related features. But not every operator should have access to the full potential of this transaction. Therefore, you must maintain activity levels independently. Instead of leaving the field ACTVT blank and then manually define its values in each job role, you can now use default data variants.

First, enter Transaction SU24 and select the transaction for which you want to build a variant (in our use case, Transaction BP). In the maintenance view, click on the **Variant** button, as shown in Figure 5.19.

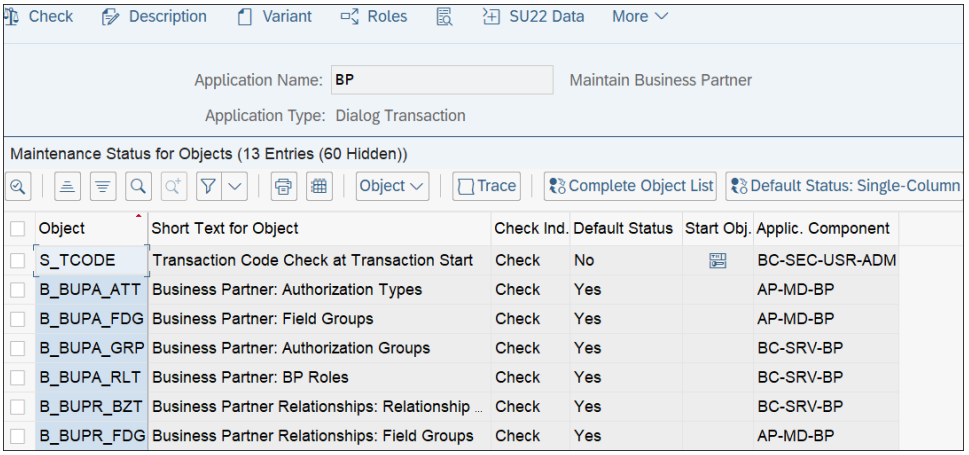


Figure 5.19 Transaction SU24 Variant Button

You must specify a name and description for that new variant. Please note that the variant name must begin with "Z" or "Y." To save these settings, you must select a custom developer package and record your variant frame in a workbench transport. Afterward, you can adjust the authorization objects, fields, and values in as needed for your business process. In our example shown in Figure 5.20, the variant is a display-only version of Transaction BP with **ACTVT 03**, (08), and **F4**. Save your settings once again, and now, you've finished your first Transaction SU24 variant.

To change your application variant, go to the initial selection screen of Transaction SU24 and select the targeted application. Then, select the **Determine Variants for Default Values of Applications** checkbox, shown in Figure 5.21, and execute your selection. You'll see a list of all Transaction SU24 variants for the target application, and from this list, you can display, maintain, or delete them.

Chapter 6, Section 6.3.2, explains how you can use these variants in the profile generator to raise your current role concept to a new level.

Personal Copy for Arun Singal, arun.singal560@gmail.com

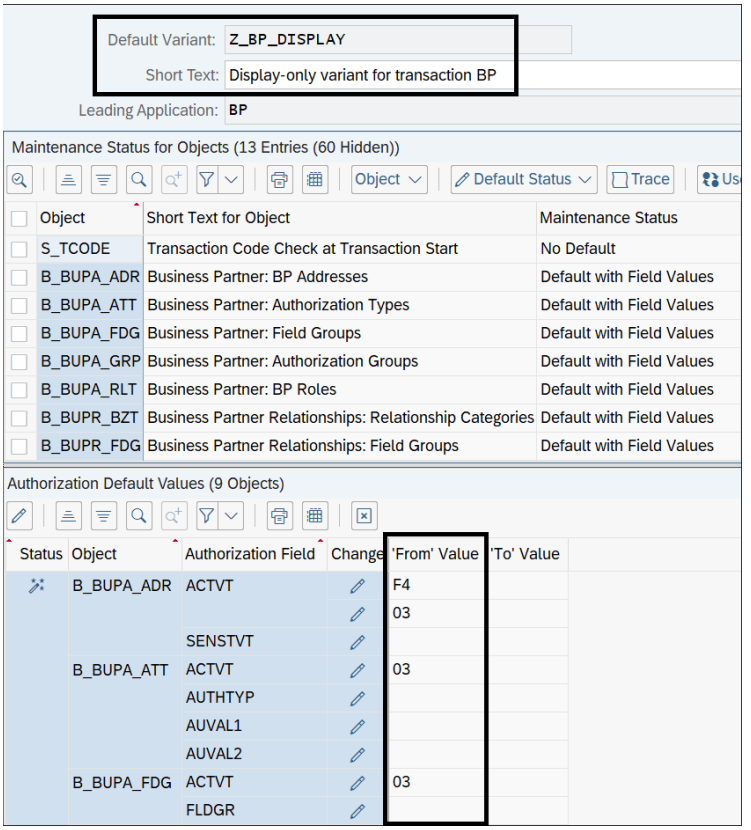


Figure 5.20 Display-Only Variant for Transaction BP

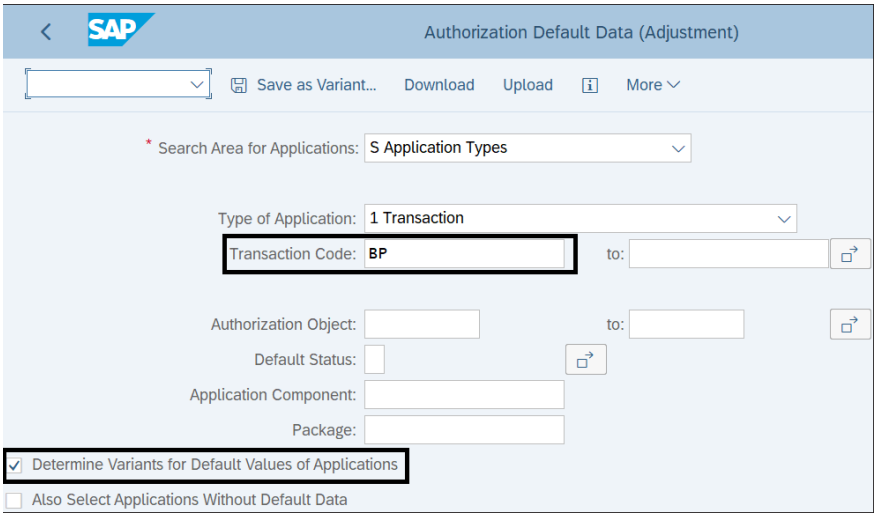


Figure 5.21 Selection Mask for Transaction SU24 Variants of Transaction BP

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Refer to SAP Note 2809885 for detailed information about the usage of authorization default value variants. Note that a "Transaction SU24 variant" is not a "variant transaction."

5.4 Populating Data from Traces

When an end user encounters program or data access issues, the cause is usually missing or inappropriate authorizations. Mainly this problem occurs in the context of incorrect values maintained in roles. When authorization issues occur with custom developments, in most cases, the problem stems from unmaintained default values for a specific menu object. Depending on the particular business processes and system functions, you might also require additional proposals in addition to the general delivery setting. Concerning these causes, you might need to enrich your current Transaction SU24 data records with the integrated trace option.

Hint

Refer to Chapter 7 for additional background on trace options.

You can activate an authorization trace on your SAP system via Transaction STUSOBTRACE. You might have to enable this tracing method initially via Transaction RZ11. Within the profile parameter editor, set the parameter `auth/authorization_trace` to value "Y" (for activation) or "F" (for activation with filter options). For more information regarding this profile parameter, see SAP Note 1854561. After completing these preparatory steps, you can start the enhancement of your proposal values.

Hint

You can also use the trace methods Transaction STAUTHTRACE or Transaction STUSERTRACE.

For instance, providing display access might be useful to check authorization groups for all existing tables in table `TDDAT`. Therefore, you can create a parameter transaction to avoid generic table access via Transaction SE16 or SM30.

Hint

For comprehensive information about various transaction types, especially parameter transactions, see Chapter 2, Section 2.9.

Personal Copy for Arun Singal, arun.singal560@gmail.com

After creating custom transactions, you can maintain the SAP proposals to create a secured and functional authorization concept. Initially, you do not have any proposal data for your custom transactions in Transaction SU24, as shown in Figure 5.22. Thus, maintain the correct authorizations to enable display-only access for the targeted table (**TDDAT**). Of course, through its inheritance relationship to Transaction **SE16**, the system automatically introduces authorization object S_TABU_DIS into the targeted role profile when the Z* transaction is in the role menu but only with the maintained proposals of Transaction SE16. This approach is not a best practice according to the least privilege principle. Our experience has shown that a better approach is to disable the inheritance status (e.g., Transaction SE16) and then maintain the proposals individually. Otherwise, if you only disable inheritance, the system only proposes the authorization object S_TCODE with the value **ZSE16_TDDAT** to start the transaction. But you still also require table authorizations.

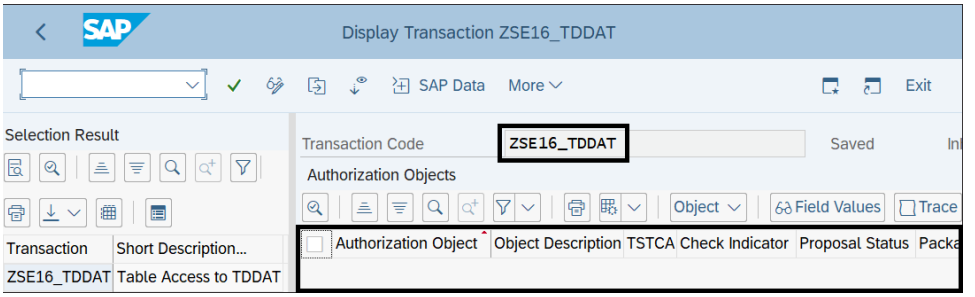


Figure 5.22 Parameter Transaction ZSE16_TDDAT without Any Default Values

However, you may not always know which authorization objects, fields, and values you need. In this case, the authorization trace and the integrated trace feature in Transaction SU24 can be used. After starting the trace, launch the new Z* transaction with your administrator rights. Execute as many targeted actions as possible within this transaction so that the trace receives all the necessary data. Then, enter Transaction SU24 for this specific application (**ZSE16_TDDAT**). Click on the **Object** button and select **Insert Objects from Trace** and **Authorization Trace (STUSOBTRACE)**. In this case, you can automatically list all check authorization objects for your Z transaction based on your testing. Whether you choose the **Local** or **Target System** option as the source depends on which system you activated the trace, as shown in Figure 5.23. The system automatically adds all missing authorization objects based on the trace data.

As a final step, you must decide whether you need all of these authorization objects, as shown in Figure 5.24. Since the current example is a parameter transaction for display-only table access, you do not need to introduce all the suggested authorization objects. In fact, you shouldn't maintain and set proposal statuses to "Yes" for all objects, which would greatly increase your role and Transaction SU24 administration effort. Authorization objects like **S_ALV_LAYO**, **S_ALV_LAYR**, or **S_GUI** are not necessary for this transactional context.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

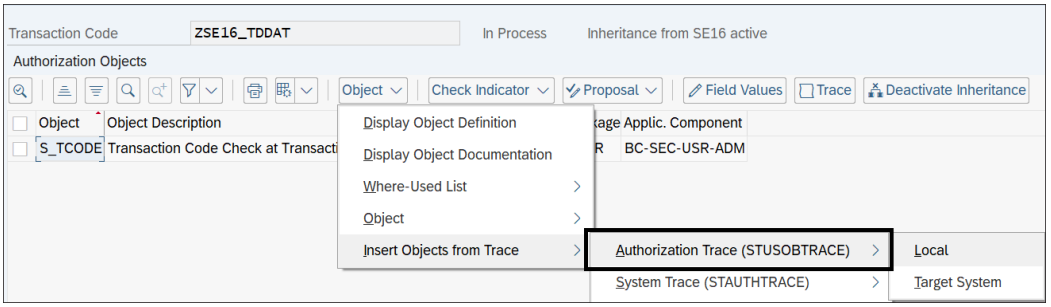


Figure 5.23 Insert Objects by STUSOBTRACE for Transaction ZSE16_TDDAT

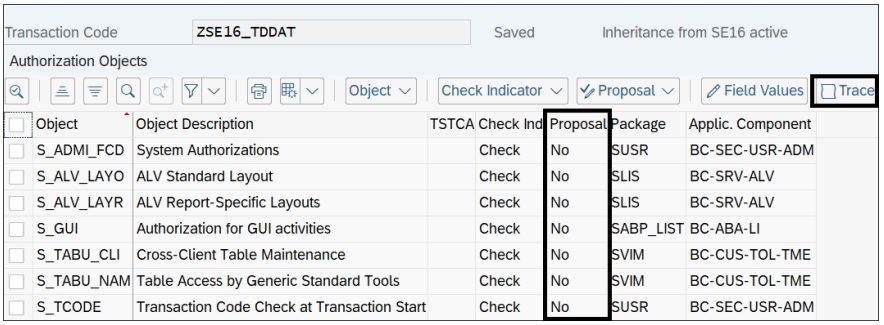


Figure 5.24 Initial Proposal Setting after Trace Integration for Transaction ZSE16_TDDAT

These authorization objects often represent background noise, which is often checked for tables, for instance, to determine whether you have the authorization to specify layouts or download a list. Mostly, you'll cover these requirements through other transaction proposals. The authorization object **S_ADMI_FCD** for system administration is also not required for table access, and authorization object **S_TABU_CLI** is also unnecessary because we have a display-only parameter transaction for one system and don't want client-independent access.

Since the introduction of authorization object **S_TABU_NAM**, you only need to adjust this object. Of course, if you wish, you can also use authorization object **S_TABU_DIS**, but **S_TABU_NAM** provides more extensive table authorizations than **S_TABU_NAM** because you would maintain a table group instead of a single table name. Thus, choose **S_TABU_NAM**, click on the **Trace** button, and select the **STUSOBTRACE** option once again.

Select **S_TABU_NAM** and maintain the required values for your transaction directly by clicking **Transfer**, as shown in Figure 5.25. Make sure you maintain the right settings for your Z* transaction based on the trace data analysis, including the **Object**, **Values**, **Proposal Status,** and **Check indicator**.

Personal Copy for Arun Singal, arun.singal560@gmail.com

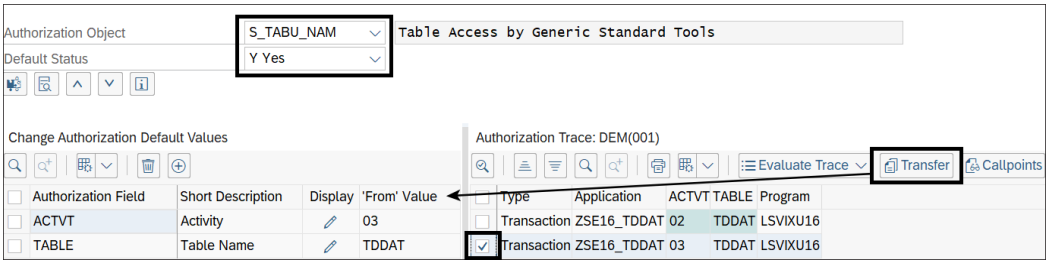


Figure 5.25 Insert Values by STUSOBTRACE for Transaction ZSE16_TDDAT

Finally, for our example, the authorization default values setting of custom Transaction ZSE16_TDDAT should resemble the screen shown in Figure 5.26.

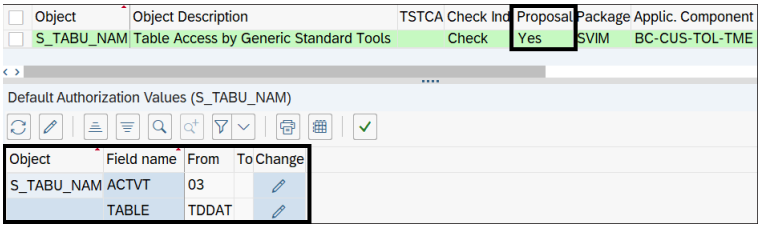


Figure 5.26 Required Authorizations for Transaction ZSE16_TDDAT

5.5 Best Practice Maintenance of Transaction SU24

Working with Transaction SU24 is inevitable if you want your role concept to stay standard-compliant according to the program's source code requirements. Whenever you maintain a role menu object, the system drives default data for the implemented application into the authorization profile, which also happens if you change any proposals in Transaction SU24 and click the **Expert Mode for Profile Generation** under the **Authorization** tab of the profile generator to introduce updated proposals into the role's authorization profile. To highlight why SAP calls this approach "expert mode," you must understand that the ulterior motive is often to handle business-related requirements that demand you change authorizations in your role scope. Another purpose of Transaction SU24 maintenance is to cover individual business processes with authorization default values. The expert methodology of performing this maintenance involves deciding whether you can change the values in the role or which transaction requires changes in your proposal's setup. Therefore, the consistency and accuracy of authorization proposals depend on the quality of your Transaction SU24 maintenance. Authorization default data maintenance always impacts all roles containing the same application, which shows again that Transaction SU24 is an expert transaction. Every role you update will benefit from proposal changes, regardless of whether you're changing the objects in the role menu or not.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

This section explains some typical use cases in the context of authorization default values and describes how you can use them to optimize your authorization concept.

Hint

Please note that even SAP proposals might be incomplete or might fail to fit the technical and functional application requirements. SAP developers mostly maintain default data using the authorization trace (Transaction STUSOBTRACE) based on their testing. Thus, a gap might exist between testing data and business data due to custom activities.

5.5.1 Authorization Field Maintenance

The importance of using proposals for sustainable role building and security should now be evident. We also highly recommend understanding the maintenance context of authorization fields in Transaction SU24. With this knowledge, you can build up custom proposal value settings to reflect your company's daily business needs, specific SAP systems, and process structures. Please note that the discussion in this section mainly pertains to maintaining proposals for transactions in Transaction SU24.

Authorization Fields You Should Maintain

Many different fields of authorization objects will have a one-to-one relationship to appropriate applications. Furthermore, these connections exist for almost all application types. Often, you may find it necessary to determine the direct program correlation or authorization values due to the application's intention. The following examples provide insight into what a unique destination for a specific field value means.

For instance, Transaction MM03 is used for "Display Material" and allows nothing more than display rights in the SAP standard. Thus, the value for the authorization field ACTVT (activity) is set to "03" (display). SAP recommends retaining this unique reference between the application and its description. The activity needed in the transaction context is often predefined, and static connections to other authorization fields like P_GROUP exist. Thus, the program's related program group must be an exact value behind the transaction. An example is Transaction FD15, which only needs **S_PROGRAM** with field **P_GROUP** and value **F_001**, as shown in Figure 5.27.

If a unique relationship exists between the application and the necessary field value, you should adjust this relationship via Transaction SU24. Otherwise, you'll always have to maintain these values in your roles.

Personal Copy for Arun Singal, arun.singal560@gmail.com

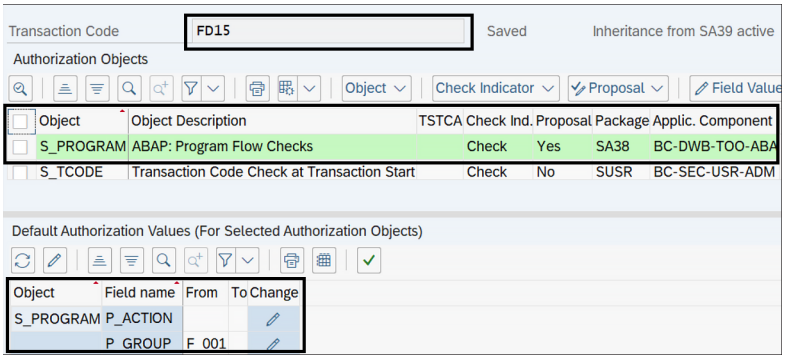


Figure 5.27 S_PROGRAM Relationship to Transaction FD15

ACTVT and Other Activities

The authorization field ACTVT (activity) is maintained for thousands of applications in Transaction SU24. This powerful authorization field often enables the most functional application usage through its values. Additional authorization fields can control the activity level but may not be called ACTVT. These fields, listed in Table 5.5, should be adjusted as well.

Field Name	Description
ACTION	The action of the authorization
ACTVT	The activity of the authorization
AUTHC	Authorization level
BTCUNAME	Background User Name for Authorization Check
CO_ACTION	Actions for CO-OM Authorization Check
FBTCH	Action for Automatic Procedures in Financial Accounting
SPOACTION	Authorization field for spool actions

Table 5.5 ACTVT and Other Activity Field

Hint

Check available transactions in table TSTCT and filter for a distinctive description like "*isplay* (for display) or "*ist*" (for list) in field TTEXT or "*03*" in field TCODE. With this method, you can display transactions that have some kind of display activity field values, and you can check whether they have the correct intended authorization field values via Transaction SU24.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

P_GROUP and Other Parameters

More authorization fields beyond the activity-related ones exist in the proposal context that you should maintain with the required values. For instance, you might also have a technical connection from a calling application to a target transaction through a fixed parameter. For instance, suppose you want to provide a parameter transaction to start a program or enter a table directly. For this purpose, the custom transaction requires predefined values in the related default data. You must maintain the authorization field program group (P_GROUP) within the authorization object S_PROGRAM or program name (P_PROGNAM) included in S_PROGNAM. For tables, for instance, the authorization field table group (**DISCBERCLS**) in authorization object S_TABU_DIS or a table name (**TABLE**) in S_TABU_NAM must be maintained, as shown in Figure 5.28, with some other examples for Transaction SU24 maintenance.

Object	Field Na...	Icon	'From' Value	To
S_PROGRAM	P_ACTION		BTCSUBMIT	
			SUBMIT	
			VARIANT	
	P_GROUP		AM75	
S_TABU_NAM	ACTVT		03	
			08	
	TABLE		BKPF	

Figure 5.28 Selected Parameters for Authorization Values

The direct links to target data destinations are fixed parameters based on the application and underlying source code. These parameter transactions, which need nothing more and nothing less, are the best examples of such a Transaction SU24 data predefinition. Many applications have only one clear target. Table 5.6 lists some authorization objects where defining characteristics in advance could be useful.

Authorization Object	Technical Description
B_MASSMAIN	Cross-Application Mass-Maintenance Tool
K_KA_RPT	CO: Interactive Drilldown Reporting - Reports
S_ARCHIVE	Archiving
S_NUMBER	Number Range Maintenance
S_PROGRAM	ABAP: Program Flow Checks
S_PROGNAM	Generic Program Start
S_TABU_CLI	Cross-Client Table Maintenance
S_TABU_DIS	Table Maintenance (using standard tools such as SM30)
S_TABU_NAM	Table Access by Generic Standard Tools

Table 5.6 P_GROUP and Other Objects for Parameters

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Refer to standard table TSTCP to check your parameter transactions and check whether their required authorization values fit the fixed parameters via Transaction SU24.

Authorization Fields You Cannot Maintain

On the other hand, some authorization objects cannot be maintained, which is often caused by technical restrictions or system configurations. The following scenarios cover the most known instances of fields you cannot maintain:

- **Table USORG (Organizational Fields)**
  A well-known example involves authorization fields that you must maintain on the organizational field level in the authorization profile. These specific authorization fields are stored in table USORG, and you cannot maintain them in Transaction SU24. To sum up, all organization levels like company code ($BUKRS), plant ($WERKS), or purchasing organization ($EKORG) are not maintainable authorization default values in Transaction SU24. The intention is that you should maintain these values concerning your organizational structure directly in your roles. Authorization objects using these fields have at least one additional field (usually ACTVT) that should have a fixed value by default.

Hint

For more information on how to promote authorization fields to organizational levels and what you must consider during that process, refer to Chapter 2, Section 2.3.5. See also SAP Note 2535602 for technical details.

- **Global deactivation of authorization fields in Transaction SU25**
  With Transaction SU25, you can globally deactivate an authorization object by executing the report **Deactivate Authorization Object Globally**. This application switches off the system-wide authority check against the selected authorization object. In the background, the system skips all checks against this authorization object with a positive return code (RC = 0). As a result, it does not matter whether the end user role has the related authorization object or not. This setting suppresses the authorization proposal usage, and you cannot maintain them in Transaction SU24 anymore.

  The term "globally" is slightly misleading, and coverage is only client-dependent, but for all authority checks against the specific authorization object. Moreover, you cannot adjust objects that belong to the BC module (for SAP NetWeaver) or HCM module (for SAP ERP Human Capital Management [SAP ERP HCM]).

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Do not deactivate authorization checks for any authorization object and verify that the system parameter `auth/object_disabling_active` is set to "No" in Transaction RZ10.

- **Local deactivation of authorization fields in Transaction SU24**
  Like global deactivation, you can also locally deactivate the authority check against an authorization object. In this case, you can disable this authority check against a specific authorization object for a particular application. This behavior is announced by the check indicator status **Do Not Check** in Transaction SU24. You might see many authorization objects with this flag because SAP remodeled the underlying source code or reused existing code structures from one application for new applications or functions. However, SAP does not want or require such strict authority checks for the new application as it is used for the initial one.

Hint

Only deactivate the check indicator if doing so is essential and you cannot handle it in another way. Then, verify periodically that the system parameter `auth/no_check_in_some_cases` is set to "Y" in Transaction RZ10. Consider that Transaction SU24 changes are client independent and thus affect the entire system.

- **Table TSTCA issue based on Transaction SE93**
  As described in Chapter 2, Section 2.6.3, the kernel automatically checks the authorization objects S_TCODE and TSTCA when you execute a transaction. The TSTCA object is stored in the related table `TSTCA`. You cannot change this default setting in Transaction SU24; you can only customize these authorization objects in Transaction SE93, as shown in Figure 5.29.

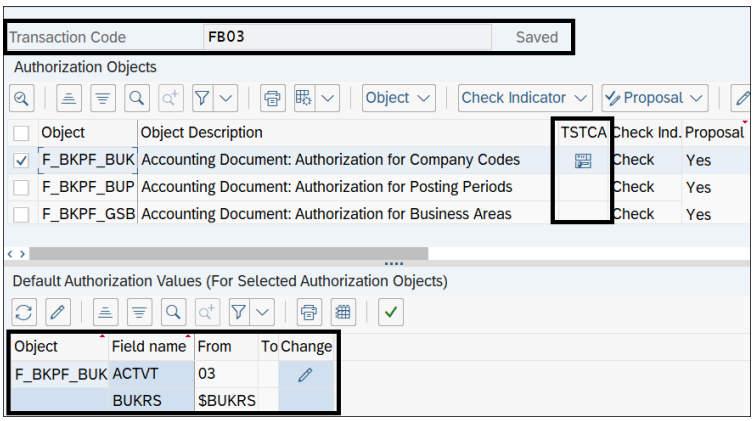


Figure 5.29 TSTCA for Transaction FB03 in Transaction SU24

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Suppose you have a good reason or business demand to deactivate or enhance the standard TSCTA customizing for an application. In this case, launch Transaction SE93. Now, enter the target application in change mode and delete the TSTCA entry, like the authorization object **F_BKPF BUK** for Transaction **FB03**, as shown in Figure 5.30. Finally, save your maintenance settings with a transport request.

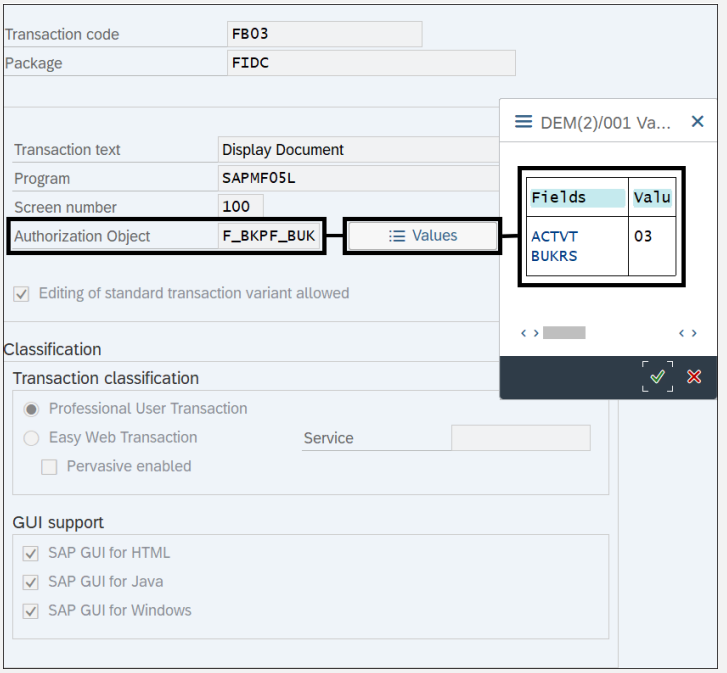


Figure 5.30 TSTCA for Transaction FB03 in Transaction SE93

5.5.2 List Navigation

Besides their source code-based intention, proposals enable you to include your business processes and company structure into your unique authorization concept. In the context of forward navigation options, the key tool is the ABAP List Viewer (ALV). The related reporting transactions are mostly named S_ALR_* in SAP standard. These transactions are necessary for collecting and analyzing different data records in your database. You cannot use all available SAP Business Suite functions without them. Even though this reporting is often display only, these reports might contain crucial data and cross-application functionalities.

For instance, when an end user executes an ALV report, the system presents a result list with drilldown capabilities or cross-reference features for further information. During

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

report execution, the system checks the access authorizations for this program and also validates the authorizations for further navigation actions and drilldown access. Thus, you must think about these various functions and how far into the data you want to allow end-user access.

Hint

If you need more specific and individual report options for your business use case, and the SAP core features are not enough, check out SAP's business intelligence (BI) solution—SAP Business Warehouse (SAP BW).

One approach to enable forward navigation is integrating the *friends principle* into your authorization concept. According to this principle, you connect similar applications (with the same or related meanings) between each other in S_ALR* report proposal data. You can enrich the ALV report's default values with your necessary authorization values like transactions or other reports into the start transaction. This approach provides additional forward navigation steps within the same or similar job activities. Also, you might offer a business-related combination of two or more otherwise separate transactions, which might be required together in a specific job. In this way, you enable a single point of entry for multiple transaction. A best practice concerning this option is to add proposals via Transaction SU24 to the start application, which end users can operate in their user menu or another frontend application (cross-over applications). For instance, you can add forwarding transactions as authorization values in the authorization object S_TCODE, which enhances the reporting ability.

One question you must answer is how robust and precise your roles and authorization profiles should be. The more you equip forward navigation into your role concept, the more access your end users will have to a complex reporting structure. With forward navigation management following the friends principle, you might establish a more business-related and maintainable role concept. You'll need a few roles for complex business processes because you've integrated them into your proposals. You'll also get additional where-used information within an authorization profile according to the maintained applications through this integration by default.

On the other hand, this approach can directly lead to an "open book" approach because you've provided too much access. In addition, with the enhanced Transaction SU24 data customizing, the maintenance of your proposals will rise as well. Whereas ALV reports often provide "display-only" activities, the drilldown capabilities might require a change to the standard for other activity levels like change or create. You should notice how generous proposal maintenance might affect specific critical authorization objects and their fields, like the controlling-related responsibility area (RESPAREA). In this case, you might be providing too much access to sensitive data. You should avoid

Personal Copy for Arun Singal, arun.singal560@gmail.com

using this approach for controlling or HR applications if organizational or other similar authorization fields are inbounded.

Hint

You might abstract this method on the role level as well. Roles that contain the start applications could also include the forwarding transactions. In this case, you could maintain similar or related applications within a single job function or task in the same job function role menu. For instance, if someone needs Transaction FB01 to create financial documents, you would assign Transaction FB03 to display those documents too.

5.5.3 Menu Navigation

Covering your menu navigation within your role concept is often more important than covering list navigation. Menu navigation is set as a `CASE` statement in the source code. The `CASE` statement is a `CALL TRANSACTION` pattern that enables users to go back or forth between calling applications. This behavior is convenient and, in business processes, usually desirable. An end user may jump from one transaction to another, related transaction that is entirely different and contains sensitive data. The most significant exposure is that end users can access a cross-application feature. The following example describes two different scenarios for the same transaction to highlight how complex menu navigation adjustments in Transaction SU24 can be made.

Where to Make an Adjustment

For instance, let's look at Transaction STMS, which is an application that includes the most transport-related features for an SAP system. How you configure its values depends on who is working with this application and what is needed. You must consider factors such as who should have the authorization to which type of transport request, how to monitor transports, and how to administer the transport system. This transaction code is popular for varying groups of end users depending on their job functions. However, crucial issues can arise when this transaction is misused. The top taskbar in Transaction STMS contains various menu options to access other transactions like Transaction SCC4 (Client Maintenance) or Transaction SE06 (System Change Option). The application beyond Transaction STMS offers crucial activities and dives deeper into Basis administration and security. By passing a simple `CALL TRANSACTION` statement in the underlying source code, navigating from Transaction STMS directly to Transaction SE06, as shown in Figure 5.31, is possible.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

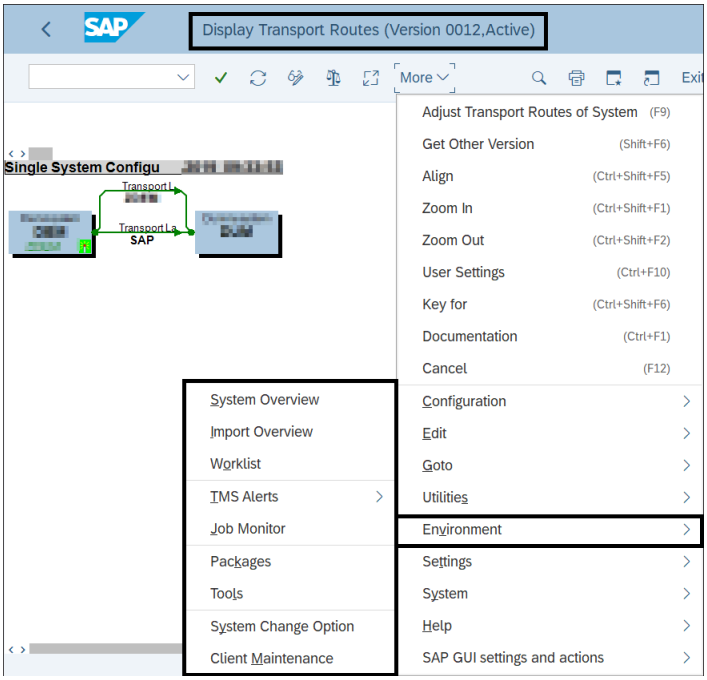


Figure 5.31 Convenient Navigation in Transaction STMS

Suppose you customize the activity level to "display" for an application that auditors, developers, and key users use on a PRD. In this case, you can provide these users with forward navigation options on the condition that they only have display access. By doing so, the related end-user roles do not require further role menu objects. If adding the application Post-Installation Actions for Transport Organizer (Transaction SE06) authorizations as a default value of Transaction STMS in the authorization object S_TCODE, you would allow the users to exploit the navigation conveniently. This maintenance solves the following three issues directly:

- End users can use convenient navigation features that the application itself provides through proposals.
- Movement across applications is possible without the need for those transactions to be included in the role menu, which reduces the functional extent of your roles and their subsequent maintenance.
- You can provide necessary but restrictive access in the PRD, with less effort for role and authorization profile maintenance.

Figure 5.32 shows an example with Transaction **STMS**. First, you must customize the authorization object **S_TCODE** in Transaction SU24 with authorization value **SCC4**. Then, you must add the **S_TABU_NAM** object, for table name restriction, with the activity "**03**" for display and table name "**T000**," which contains the system change parameters.

Personal Copy for Arun Singal, arun.singal560@gmail.com

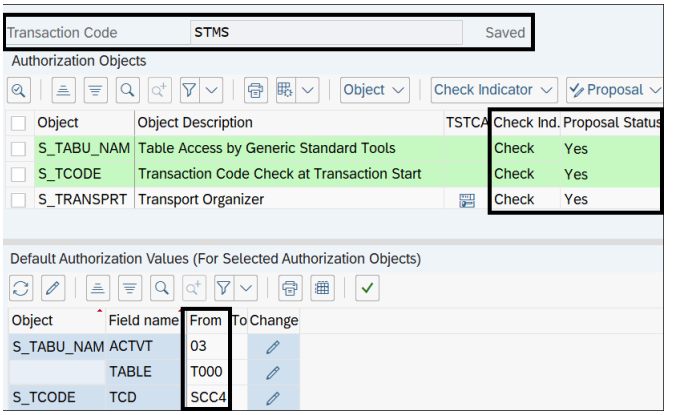


Figure 5.32 Display and Convenient Navigation Adjustment for Transaction STMS

Hint

For multipurpose transactions like Transaction STMS, implementing display-only activity levels for all necessary authorization objects within the transaction makes sense on a PRD. Doing so ensures that no one can change crucial settings on the PRD. On the other hand, you must enhance your role concept and ensure that strong authorizations are well maintained. For example, you should encapsulate transport actions like importing transports (Transaction STMS_IMPORT), exporting transports (Transaction STMS_EXPORT), or controlling transports (Transaction STMS) in a critical Basis administrator role. Alternatively, you can integrate these authorizations and applications into your emergency user concept.

Where Not to Make an Adjustment

In terms of maturity in your Transaction SU24 proposals, you may not need to change the SAP standard values and default settings. Transaction STMS also offers navigation to Transaction SE06. The ability to change system options via Transaction SE06 is not functionally related to the transport management system. You can reinstall a whole system or run a database copy or migration. Due to the activity level, you may also need more than only "display" access to change the system settings. Three possible issues in this case include the following:

- The menu navigation could give access to an unrelated application.
- You have a distinction between the activity levels create (01), change (02), and display (03).
- The internal business processes are strict, and they prohibit adjustment.

You should not customize the default values for Transaction STMS, including Transaction SE06, or change the related actions to "display," which might prevent you from

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

using the fully intended capabilities of those administration transactions. To overcome this gap, use Transaction SE97 to block the application navigation by specifically restricting its calling applications. Moreover, you don't have to change your proposals or the source code (which is not recommended). Using this method ensures that you can prevent such navigation from the application start, and thus, you won't have to think about whether an end user has these specific authorizations.

For this approach, enter Transaction SE97. Then, filter for **the calling Transaction STMS** and select the line for Transaction **SE06** in change mode, as shown in Figure 5.33.

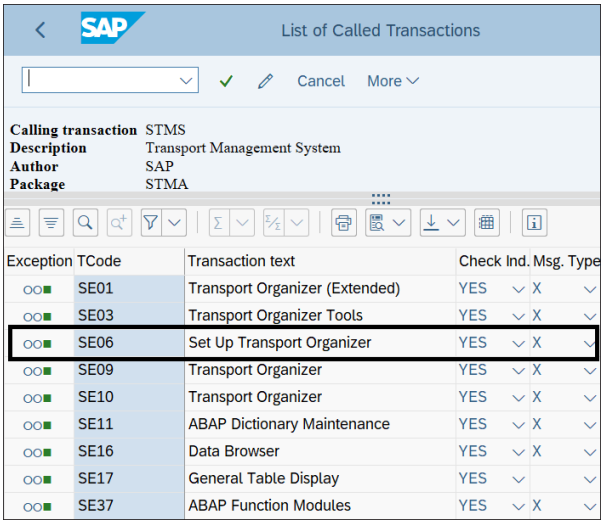


Figure 5.33 List of Called Transactions for Transaction STMS in Transaction SE97

Now, amend the **Message Type** by selecting one of the options listed in Table 5.7.

Flag	Indicator	Reaction
I	Information	An info message appears, but the navigation continues.
E	Error	An error message occurs, and the end user remains in the starting transaction.
A	Aborted	The session terminates and returns to the SAP Easy Access menu.
W, X, space	Warning	An error message occurs, and the end user returns to the SAP Easy Access menu.

Table 5.7 Transaction SE97 Application Navigation Flags

Hint

See SAP Note 358122 for more information about Transaction SE97.

Personal Copy for Arun Singal, arun.singal560@gmail.com

5.5.4 Navigation Considerations

The integration of the friends principle is valuable for list navigation and also affects menu navigation. The core differences between these navigation options are their parameter values. For list navigation, you need exact and mostly related parameters to integrate. End users can go deeper into the reporting features and documents through the initial transaction. Menu navigation does not require any parameter values for its navigation features. However, the navigation itself may not be related to the source transaction itself. You aren't clicking in a related data list menu but should be able to enter superordinated or similar system functions through the header bar navigation. Suppose you click on a menu option or some unrelated header bar button. The data that is accessible through these buttons could be completely different from any line item or restrictions you used for the list authorization. On that account, you should fill that gap and control the viewing of and possible actions on sensitive data. Before starting your navigation proposal maintenance, keep in mind the following SAP security criteria considerations:

- The number of roles and the expense and resources to maintain them decrease significantly.
- You preemptively neutralize authorization errors within reporting functions.
- Your role concept transforms increasingly into an individual job function role concept with integrated business processes.
- Only some users may require a complex application structure within your maintained navigation.
- You must change the "display-only" activity level in some cases.
- Higher effort for role provisioning and the introduction of new administrators to your role concept will be required.
- A time-consuming and labor-intensive task is to find and maintain navigation options within Transaction SU24 initially.

Please work restrictively with list and menu navigation features and carefully consider internal and external regulations. You should only provide access as far as your business requires, and not more.

5.5.5 Cockpit Transactions

Cockpit transactions should remain in focus during your proposal customizing to follow best practices. These transactions provide extensive data access and authorizations and, as a result, can dilute your existing role concept. Examples of cockpit transactions include Transactions BP, MIGO, SUIM, SU01, and PFCG. These transactions consist of one or more screens with different sections to move through and maintain your data. You can move forward into different transaction features within these applications,

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

launch other programs, or access cross-application features. Usually, these transactions have multiple, powerful activity field values. Unfortunately, not every job function requires such extensive access. Determining how to prevent unintentional access while still enabling various job function roles with the same transaction can be quite difficult.

Thus, the first action is to customize the proposal for the authorization field ACTVT. But, before you can customize this proposal, you must determine which logic you want to use with your proposal adjustment for these unique transactions. Then, you can divide activities into three various approaches, each of which you have to maintain differently:

- Using a cockpit transaction's full potential: You activate all activities like create, change, and display, as shown in Figure 5.34.

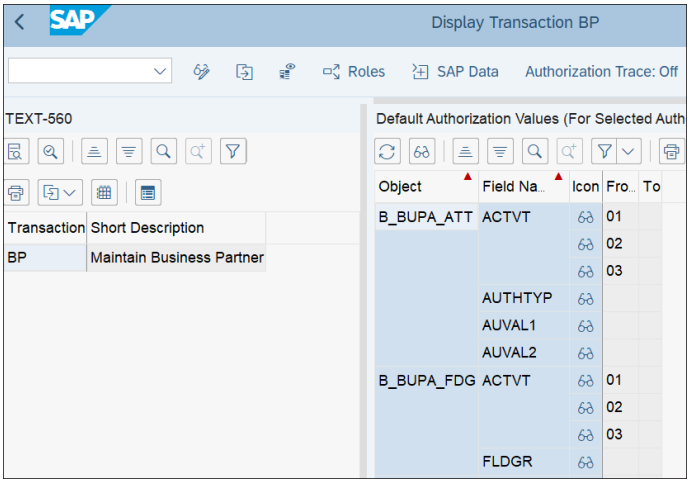


Figure 5.34 Transaction BP Initial Proposal Maintenance Extract

- Using a cockpit transaction's partial potential: You need to leave the **ACTVT** fields empty, as shown in Figure 5.35.

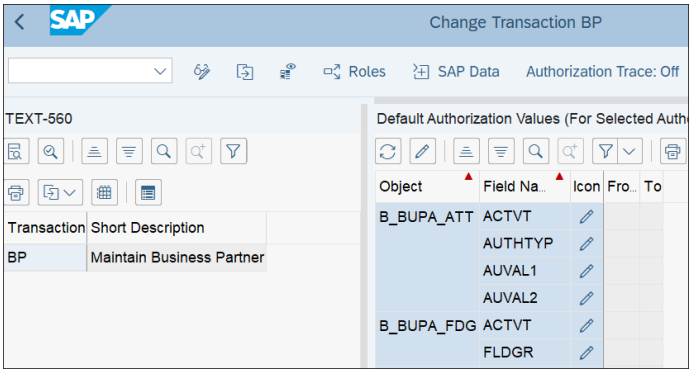


Figure 5.35 Transaction BP Empty Proposal Maintenance Extract

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Not using a cockpit transaction's potential: Only maintain the activity value level "display," "view," or "list," as shown in Figure 5.36.

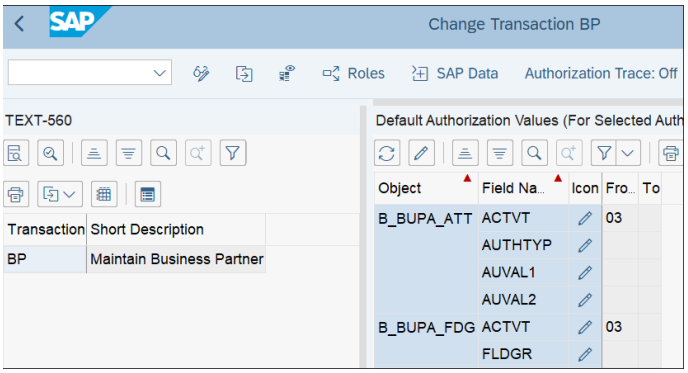


Figure 5.36 Transaction BP Display Proposal Maintenance Extract

In this regard, you should also consider some authorization fields other than ACTVT to restrict or extend this logic.

The best option is to leave the ACTVT field blank even though SAP recommends filling it in. SAP's predefined default logic provides a ready-to-use proposal setting to start working with the system directly. When working with cockpit transactions, you must maintain and adapt your authorization concept according to your company's needs. For example, a typical warehouse employee should not reverse goods inwards, but the proposals for Transaction MIGO would allow that activity. The broad rule for cockpit transactions is usually to leave the ACTVT field empty, thus restricting the required values for the activity level to the values in the roles themselves. In this way, you can handle one transaction for different job functions and their needs through a regulated business process. At the same time, you can also prevent overauthorization. This option is only one of several but is especially useful if you lack access to Transaction SU24.

The second and more sustainable option is to use Transaction SU24 and its default data variants. You can use proposal variants to cover these unique business and security requirements. Thus, you won't need to use alternative transactions or leave fields blank within your proposal data. See Section 5.3 for more details on this topic.

The third option is to provide a similar substitute instead of providing the end user with full access to a transaction. For instance, for Transaction SU01, you might offer the display-only cousin Transaction SU01D. Thus, instead of leaving the authorization field ACTVT proposal empty for Transaction SU01, you would assign Transaction SU01D to your end users.

Note that SAP mostly proposes all authorization default values. An open authorization field in Transaction SU24 is preferable to a changed authorization instance because of the potentially negative impacts of modifying proposal presets directly in your role

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

profiles. Proposal customizing is always better than altering the authorization defaults of a role. This strategy reduces the chance of error when performing future role updates and also reduces role maintenance effort required over time, typically saving you from cumbersome work.

5.6 Upgrading Authorization Default Values

Due to the processing development of the SAP software, features, and source code, you'll need to update your system releases and components periodically. This update schedule ensures a secured and up-to-date system landscape. When SAP upgrades provide new features or enhancements to current features, authorizations will be affected as well. Many businesses plan to migrate to SAP S/4HANA and accordingly require the latest authorizations for this new solution.

This section's objective is to introduce you to the requirements of performing a Transaction SU25 upgrade of your customer-related `USOBT_C` and `USOBX_C` tables. Moreover, we'll guide you through the update process for proposal data.

5.6.1 Importance of Upgrading

SAP highly recommends regularly upgrading your authorization default values. Leading indicators for this are pointed out in the upgrade notes through new Transaction SU22 data or even specific SAP Notes, which you must implement manually. Please note that proposal upgrades are directly related to the newly provided program codes, which might be changed and adjusted by new releases, applications, and modifications. Some changes might also close security vulnerabilities or solve historical issues in default data records. Therefore, upgrading also covers compliance restrictions and business security concerns. In addition, you'll reduce your role maintenance effort working with the SAP standard. Thus, if you have well-maintained role menus, you only need to upgrade your proposals and can directly introduce all these changes into your role profiles. Afterward, you only need to validate and maintain open authorization fields. Thus, you also stay compliant with the "need-to-know" principle so your end users only get the authorizations that suit their job functions. Furthermore, regarding automatic proposal integration, you avoid adding manual authorization objects.

With an upgrade, you must ensure that you have all required authorizations for all new functionalities in your roles. Based on new or enhanced code structures, additional authority checks might be required. Thus, you also must adjust your end-user authorizations to ensure they pass the underlying system checks. Optimized and up-to-date authorization default values may also affect your role creation and management processes, potentially saving you time and costs while allowing you to integrate existing business processes into your authorization concept.

Personal Copy for Arun Singal, arun.singal560@gmail.com

All those benefits should encourage you to perform the periodic updates since SAP provides the required enhanced Transaction SU22 data. If you work in the SAP standard with Transactions SU24 and SU25, you can significantly reduce your maintenance effort and increase your role concept quality.

Hint

For your new SAP S/4HANA authorization structure, you must consider that the simplification approach, enhanced database model, new processes, and dozens of new functionalities still require authorization default values—more so than on SAP ERP 6.0 because of the more regular update frequency. See Chapter 12 for an introduction to that topic and which key facts you must observe.

Before we start the proposal upgrade process, let's look at the required tools and information. SAP Notes on SAP Support Portal are most important in this regard. Numerous SAP Notes are helpful and necessary for the latest Transaction SU25 upgrades and updated Transaction SU24 information. Within SAP Notes, you'll find technical descriptions of various issues and their solutions. SAP Note 440231 contains a list of all correction recommendations for Transaction SU25 and its upgrade process. SAP Note 1539556 provides additional information regarding update and maintenance activities for default data. Table 5.8 lists some additional valuable SAP Notes on the topic of authorization default values and their upgrades.

SAP Note	Short Description
1539556	SU22/SU24 - Administration of authorization default values (incl. SU24_AUTO_REPAIR)
440231	SU25 - FAQ: Upgrade post-processing for profile generator
2753331	SU24_AUTO_REPAIR - Incorrect values in authorization default values are retained
2117868	SU24_AUTO_REPAIR - For default values for transactions
1646692	SU24 - General consistency check
2042284	SU25 - Missing time stamp for step 2a
1850378	SU25 - Handling of defective records in SU24 data
1861859	SU25 - Authorization default values of transaction X for object Y inconsistent - Message no. 5@015
2042284	SU25 - Missing time stamp for step 2a
1696484	SU25 - Handling customer-defined default values

Table 5.8 Useful SAP Notes Related to Transactions SU22, SU24, and SU25

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

SAP Note	Short Description
1599128	Optimization of upgrade post-processing
1691992	SU2X: Optimization of authorization default values maintenance
887221	Missing authorization default values
887138	Incomplete or incorrect authorization defaults
2632422	Authorization objects were deleted after merging authorizations.
1577135	SU22/SU24 - Default value inheritance for parameter transactions
440231	SU25 - Upgrade post-processing for profile generator
727536	FAQ - Use of customer-specific organizational levels in PFCG
2121800	SU25 - Enhancement of "Clean Up Application Header Data" function
2068383	SU2X - Incomplete header data for authorization default values

Table 5.8 Useful SAP Notes Related to Transactions SU22, SU24, and SU25 (Cont.)

5.6.2 Report SU24_AUTO_REPAIR

Report SU24_AUTO_REPAIR is a program that automatically detects and repairs Transaction SU24 inconsistencies that might otherwise harm the Transaction PFCG merge mechanism or upgrade postprocessing. Make sure that you've implemented the latest version of this report through the related SAP Notes.

This program includes several clean-up options, accessed via checkboxes, such as the following:

- **Delete SU24 default values without check indicator ref.**
  You can delete all authorization default values without the check indicator status "Check" and the proposal status "Yes" in your Transaction SU24 data. The system removes such superfluous authorization data from affected roles during the subsequent role profile maintenance. This superfluous data mainly results from outdated or unnecessary table entries and thus are no longer required.
- **Repair bad field list in SU24 default values**
  This option activates a consistency check between all authorization default values and the defined authorization objects in Transaction SU21. The report removes or adds all authorizations fields to the default data, where they do not correspond to the object definition in Transaction SU21. This option does not affect authorization objects that do not exist in the target system.
- **Delete invalid SU24 check indicators**
  This flag deletes all invalid or outdated check indicator values like "E" or "D."

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Complete missing modification flags in SU24 data**
  During your Transaction SU24 maintenance, you must always save your customizing. The system stores the data in tables USOBT_C and USOBX_C. The system also automatically flags adjusted authorization objects as maintained by the customer. You should manually run this check to ensure that all authorization objects have been correctly flagged, as shown in Figure 5.37. The report validates the custom proposals' timestamps with the latest data records in Transaction SU22 since the last run of Transaction SU25, step 2a. In this way, all data customized or updated through Transaction SU24 is flagged as modified, which is crucial so that your customer-related changes are not overwritten during the next Transaction SU22 data import and post-processing steps.

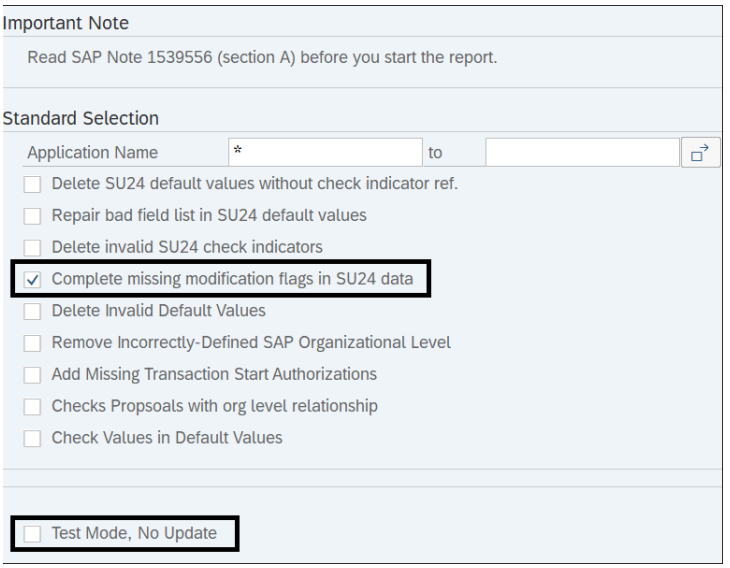


Figure 5.37 Execution of the SAP Report SU24_AUTO_REPAIR with Modification Flags Checkbox

Hint

Note that you must perform this report before Basis runs a system upgrade or other updates containing new SAP authorization default values. Doing so ensures that all maintained proposals are flagged correctly and that the import of SAP's new authorization default data does not directly overwrite your custom proposals via Transaction SU25, step 2a.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Delete Invalid Default Values**
  By selecting this checkbox, you can delete or correct all proposals in Transaction SU24 with a blank space or an asterisk (*) plus at least one other value, to serve as the authorization field value entry. Such combinations could be confusing while maintaining the authorizations for your roles because you will always get yellow traffic light warnings.
- **Remove Incorrectly-Defined SAP Organizational Level**
  In the past, SAP accidentally delivered the authorization field $CLASS (User Group) as an organizational level through the SAP GRC plug-in. The report resets that misleading problem by switching the organization level in Transactions SU22 and SU24 data to a common authorization field again. Be careful with this checkbox because this option also deletes the existing values in current roles containing the authorization field $CLASS if you maintain the role profile. Then, the system automatically replaces your custom values with an empty value. You should save the current maintenance data of Transaction SU24 and save your roles before running this report with this checkbox selected. Use this function preventatively, for instance, after a role import from other systems with SAP GRC.
- **Add Missing Transaction Start Authorizations (only with SAP Note 2117868)**
  You can add missing transaction start authorizations to complete SAP authorization default values for those transactions. If you've implemented SAP Note 2117868, an absolute requirement is to select this checkbox after Transaction SU25, step 1 or 2a.
- **Check Values in Default Values**
  This checkbox ensures that the authorization fields with references to an organizational level also have the required placeholder (like $BUKRS) for the appropriate organization level in Transaction SU24.

5.6.3 Related Applications and Tables for a Transaction SU25 Upgrade

Tables USOBT and USOBX are the SAP standard tables for authorization default values and their check indicators, and you can access these tables through Transaction SU22, as shown in Figure 5.38. The customer-related tables, which are also maintainable tables, are tables USOBT_C and USOBX_C, and you can customize these tables via Transaction SU24. You must use Transaction SU25 to transfer the new Transaction SU22 data, imported during an SAP system update, into your customer tables (Transaction SU24 data). This step is the mediator between the two kinds of USOB* tables. You can compare your customer-specific default values separately and update these values using SAP's new data during this merging process.

Personal Copy for Arun Singal, arun.singal560@gmail.com

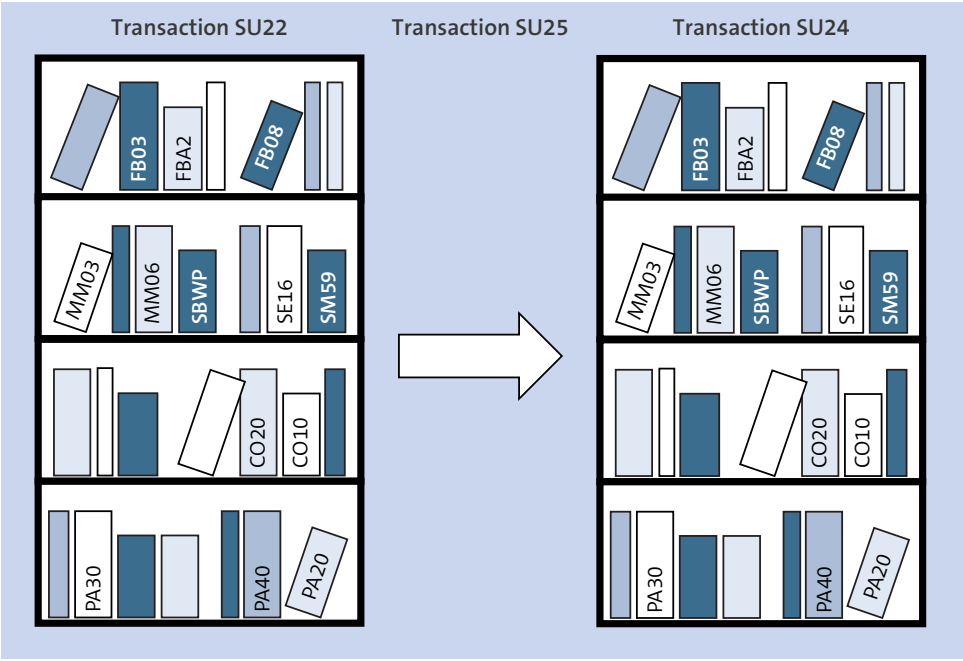


Figure 5.38 Relationship between Transactions SU22, SU25, and SU24

5.6.4 Performing the Upgrade for Default Values

With all the theoretical and technical background about the upgrade process from the previous sections, you are now ready to perform the upgrade. This section covers the entire proposal upgrade process to introduce new SAP data in Transaction SU22 into Transaction SU24 so that you can maintain your proposal to meet your needs.

Upgrade Overview

The red bullets shown in Figure 5.39 provide a short overview of the process order. Please note that you must always carry out such an upgrade on the DEV. Before you execute Transaction SU25, you must create two workbench transport requests. The first one is the backup transport. This preventive step recovers your default values in the event of an error. The second request is necessary to save your upgraded data so that you can transport the new content to your QAS and PRD systems.

After this, you can launch Transaction SU25 and check the available SAP Note 1539556 to get the latest information about changes and hints for your upcoming upgrade. At this point, it is highly recommended to read this SAP Note carefully before starting the procedure.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

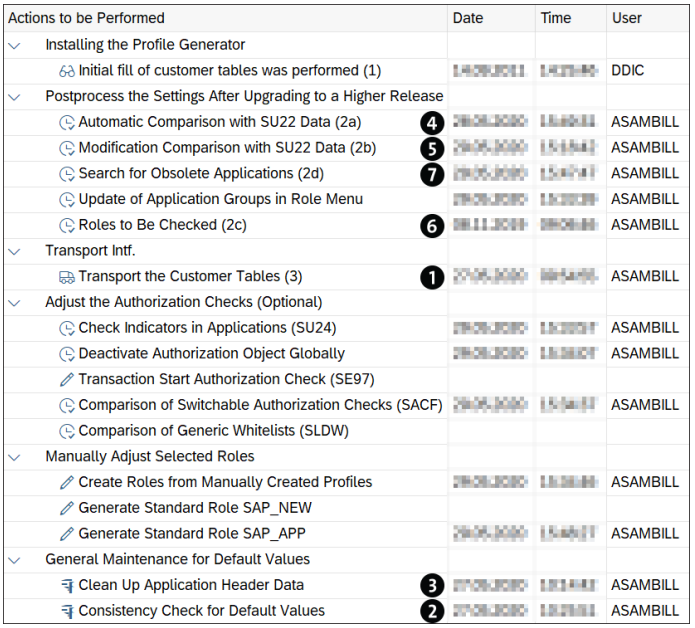


Figure 5.39 Transaction SU25 Upgrade Process

Note that you do not need to execute step 1, **Initial fill of customer tables was performed (1)**, because this step is only necessary if you've customized your system from scratch. In this case, you would first import the initial SAP proposals into your USOB*_C tables. Otherwise, start with the guided procedure shown in Figure 5.39. Table 5.9 summarizes the necessary upgrade steps within Transaction SU25.

Steps	Short Description
❶	Back up your current USOB*_C tables.
❷	Perform a consistency check of your existing Transaction SU24 data, including running report SU24_AUTO_REPAIR.
❸	Clean up the application header data for TADIR-bounded services.
❹	Process an automatic comparison of the new Transaction SU22 data to Transaction SU24, including running report SU24_AUTO_REPAIR.
❺	Force a manual comparison between your customized Transaction SU24 with Transaction SU22 data.
❻	Check the upgrade impact on your existing role concept. Update and regenerate your role profiles if necessary.
❼	Uncover obsolete applications through the new SAP upgrade. Use this information to determine further actions for covering business process interruptions.

Table 5.9 Transaction SU25 Upgrade Steps Overview

Personal Copy for Arun Singal, arun.singal560@gmail.com

Performing the System Upgrade

Let's now look at step-by-step instructions for your Transaction SU25 upgrade. Follow these steps:

1. **Create data backup for Transaction SU24 data**
   Store all data from tables USOBT_C (Default Values) and USOBX_C (Check Indicator) into the predefined workbench recovery transport by executing step 3, **Transport the Customer Tables (3)**, in Transaction SU25. Enter the transport organizer and release the task and request. The system generates the corresponding transport files (data and control files) at the SAP server's operating system level. The transport is now closed, and you can no longer overwrite it with further adjustments. You do not need to import this transport into subsequent systems and thus can delete it from the import queue. This action does not remove the transport files at the operating system level but prevents importing in other system layers.

   Another option for saving your customer tables is to use the two reports to download and upload the data records from Transactions SU24 (Customer Data) or SU22 (SAP Data). Launch Transaction SA38 and run report RSU22DOWN. Select the target applications and select the **Customer data** checkbox. Then, execute the report. If you want to upload your data, perform the same actions but with report RSU22UPLD. To summarize:

   – RSU22DOWN to download the customer data
   – RSU22UPLD to upload the customer data

2. **Proposal data consistency check**
   Inconsistencies can cause problems when performing the upgrade. Accordingly, you should check the consistency of your default values before beginning. Concerning missing application headers for TADIR-bounded services, you'll need to run the application header report in Transaction SU25 to remove these flaws.

3. **Consistency check for default values**
   Start the report **Consistency Check for Default Values** in Transaction SU25, in the **General Maintenance for Default Values** section, as shown earlier in Figure 5.39. You can choose between checking authorization objects and default values or checking the organizational levels. You'll see a result list with error and warning messages. If any inconsistencies exist, use report SU24_AUTO_REPAIR to correct them. We recommend running this program with the checkboxes shown in Figure 5.40 selected.

4. **Clean up application header data**
   Start the report **Clean Up Application Header Data**, shown earlier in Figure 5.39. This program repairs incomplete or not displayed header data for TADIR-bounded service applications like business server pages applications, Web Dynpro applications, Web Dynpro configurations, and IDoc default values. This report is also relevant to SAP Fiori applications. The clean-up register services are not always available in the input help when adding such a service to a role via Transaction PFCG.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

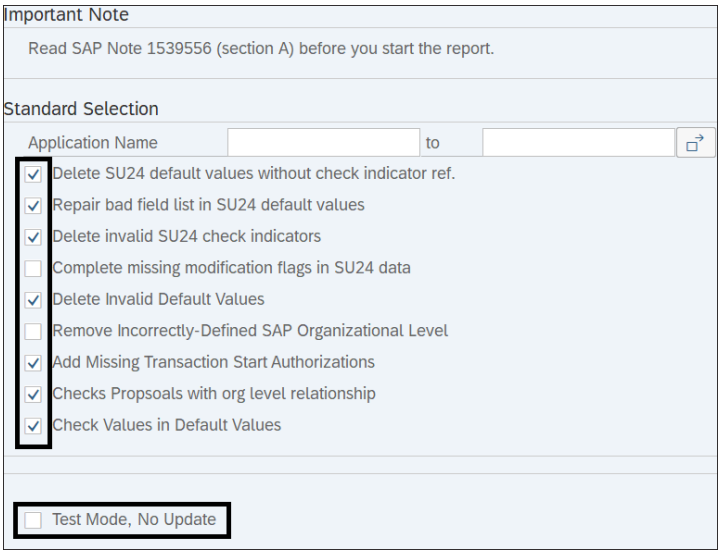


Figure 5.40 Inconsistency Correction with Report SU24_AUTO_REPAIR

Hint

To keep costs, time, and effort for future Transaction SU25 upgrades as low as possible, you should only correct inconsistencies for actively used transactions. Check Transaction ST03N data to determine which objects are used in the PRD and then filter this list of objects in report SU24_AUTO_REPAIR. Use this approach also for upcoming upgrade processes to stay focused on only the required applications.

5. **Post-process the settings after upgrading to a higher default data release**
   At this point, you can make an automatic and manual comparison between the SAP and customer USOB tables. This step is a central part of your proposal upgrade to access newly released content. You should integrate report SU24_AUTO_REPAIR in this step to avoid inconsistencies. After this processing, we recommend checking the impact on your current roles and applications.
6. **Automatic comparison with Transaction SU22 data**
   Execute report **Automatic Comparison with SU22 Data (2a)**, shown earlier in Figure 5.39. Select the **Selection Respects SAP Standard Applications** checkbox, as shown in Figure 5.41. You can also update your customer or partner applications, but only if these applications are officially integrated by SAP in their updates. The program compares the modification flags (unequal to SAP) in table USOBT with USOBT_C. Then, the system directly updates your Transaction SU24 data for all transactions that you had not changed in the past.

Personal Copy for Arun Singal, arun.singal560@gmail.com

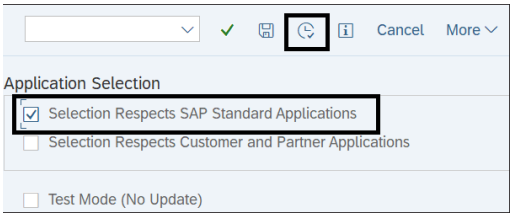


Figure 5.41 Execution of Transaction SU25, Step 2a

Start this report in test mode initially by selecting the **Test Mode (No Update)** checkbox, shown in Figure 5.41, for an overview of what changes will take place. The summary shows which applications the system can automatically update. All custom modified Transaction SU24 applications will require updating manually through Transaction SU25, step 2b. If you agree with the automatic changes, move back one step and execute the report—this time without selecting **Test Mode (No Update)** checkbox. Figure 5.42 shows an example of such an output list.

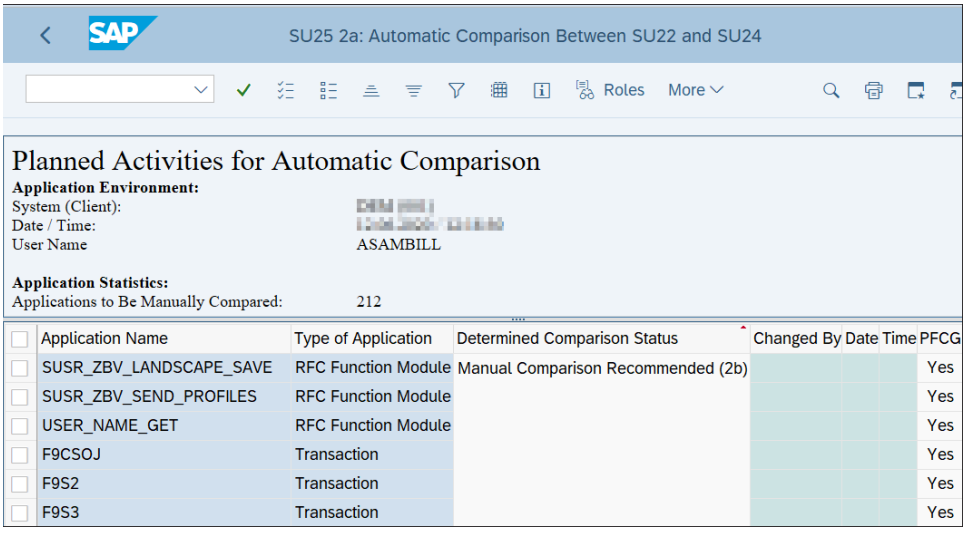


Figure 5.42 Step 2A: Planned Activities for Automatic Comparison

7. **Reassessment of inconsistencies**
   After the automatic SAP data transfer in the previous step (2a), corrupt data records might exist in your USOB*_C tables. Therefore, you should use report SU24_AUTO_REPAIR once again to clean up any new inconsistencies that may have arisen. The setting of the checkboxes is the same as shown earlier in Figure 5.40.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

8. **Upgrading customer-specific organizational levels (optional)**
   If you're using customer-specific organizational levels and your Basis version release is below 7.5x, each level must be updated individually. SAP does not deliver these promoted fields as originals by default. You can carry out this process by using the SAP standard report PFCG_ORGFIELD_UPGRADE.

   For SAP NetWeaver 7.5x, this step is obsolete, and you can manage the organizational fields with Transaction SUPO. With this release, the organization level update process is automated.

9. **Modification comparison with Transaction SU22 data**
   Now, execute the report **Modification Comparison with SU22 Data (2b)** within Transaction SU25, shown earlier in Figure 5.39. During this upgrade phase, the report compares the data in table USOBT_C (default data source for transaction SU24) with USOBT (default data source for transaction SU22). You are presented with a list of all applications for which a manual comparison is recommended, as shown in Figure 5.43. All these applications have already been changed by the customer and are now affected during the upgrade process, because the system does not upgraded them automatically with step 2a. SAP does not want to change your customizing, and thus you must specify whether to introduce the new data or not for each application.

List of Applications to Be Manually Compared

Application Environment:
System (Client):
Date / Time:
User Name: ASAMBILL

Application Statistics:
Applications to Be Manually Compared: 188

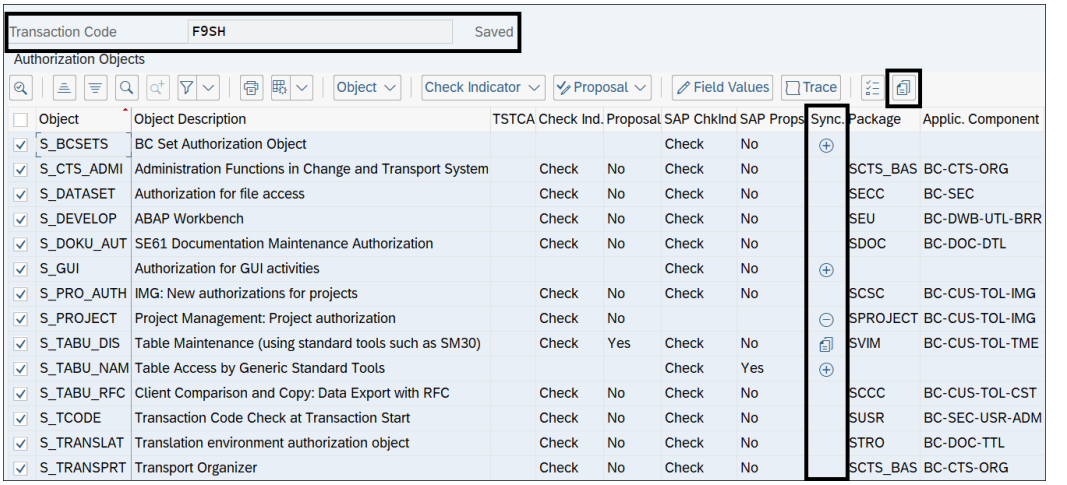
Application Name	Type	Determined Comparison Status	Changed By	Date	Time	PFCG
F9CSOJ	Transaction	Manual Comparison Recommended (2b)				Yes
F9S2	Transaction					Yes
F9S3	Transaction					Yes
F9S6	Transaction					Yes
F9S8	Transaction					Yes
F9SB	Transaction					Yes
F9SC	Transaction					Yes
F9SE	Transaction					Yes
F9SF	Transaction					Yes
F9SH	Transaction					Yes
FAGL_FC_VAL	Transaction					Yes
FB03	Transaction					Yes
FB70	Transaction					Yes
FICD	Transaction					Yes

Figure 5.43 Step 2B: Planned Activities for Manual Comparison

You'll need to think about upcoming changes in business processes and default data and decide whether to choose the new SAP authorization default values or if your

Personal Copy for Arun Singal, arun.singal560@gmail.com

customer-specific values are still correct and required. Carefully check if the default values represent your business processes and security regulations. As an unwritten rule, customer-adjusted proposals should be retained. Select all applications and click on the **Manual Comparison** button. Finally, maintain each menu object in the output list, as shown in Figure 5.44.



Object	Object Description	TSTCA	Check Ind.	Proposal	SAP ChkInd	SAP Props	Sync.	Package	Applic. Component
S_BCSETS	BC Set Authorization Object				Check	No	⊕		
S_CTS_ADMI	Administration Functions in Change and Transport System		Check	No	Check	No		SCTS_BAS	BC-CTS-ORG
S_DATASET	Authorization for file access		Check	No	Check	No		SECC	BC-SEC
S_DEVELOP	ABAP Workbench		Check	No	Check	No		SEU	BC-DWB-UTL-BRR
S_DOKU_AUT	SE61 Documentation Maintenance Authorization		Check	No	Check	No		SDOC	BC-DOC-DTL
S_GUI	Authorization for GUI activities				Check	No	⊕		
S_PRO_AUTH	IMG: New authorizations for projects		Check	No	Check	No		SCSC	BC-CUS-TOL-IMG
S_PROJECT	Project Management: Project authorization		Check	No			⊖	SPROJECT	BC-CUS-TOL-IMG
S_TABU_DIS	Table Maintenance (using standard tools such as SM30)		Check	Yes	Check	No		SVIM	BC-CUS-TOL-TME
S_TABU_NAM	Table Access by Generic Standard Tools				Check	Yes	⊕		
S_TABU_RFC	Client Comparison and Copy: Data Export with RFC		Check	No	Check	No		SCCC	BC-CUS-TOL-CST
S_TCODE	Transaction Code Check at Transaction Start		Check	No	Check	No		SUSR	BC-SEC-USR-ADM
S_TRANSLAT	Translation environment authorization object		Check	No	Check	No		STRO	BC-DOC-TTL
S_TRANSPRT	Transport Organizer		Check	No	Check	No		SCTS_BAS	BC-CTS-ORG

Figure 5.44 SAP Authorization Default Object Synchronization of Transaction F9SH

Hint

Filter the result list in Transaction SU24 with your transaction usage data from your end users working in a PRD using Transaction ST03N. For more information about end user usage, see Chapter 9, Section 9.14.

Select a target application and start your selective adjustments. You must pay particular attention to new authorization objects, fields, and value characteristics that did not exist in your proposals before. Please note that you must consider the authorization object and its field value list. Possible new values are only available if you copy the SAP synchronization data for the authorization objects, indicated by the **Sync** column, as shown in Figure 5.45.

The following icons show indicate whether upgrade actions are required:

- You are adjusting or replacing existing authorizations with additional or other content through the update.
- ⊕ You are adding updated default data.
- ⊖ You are removing existing authorizations through this update.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

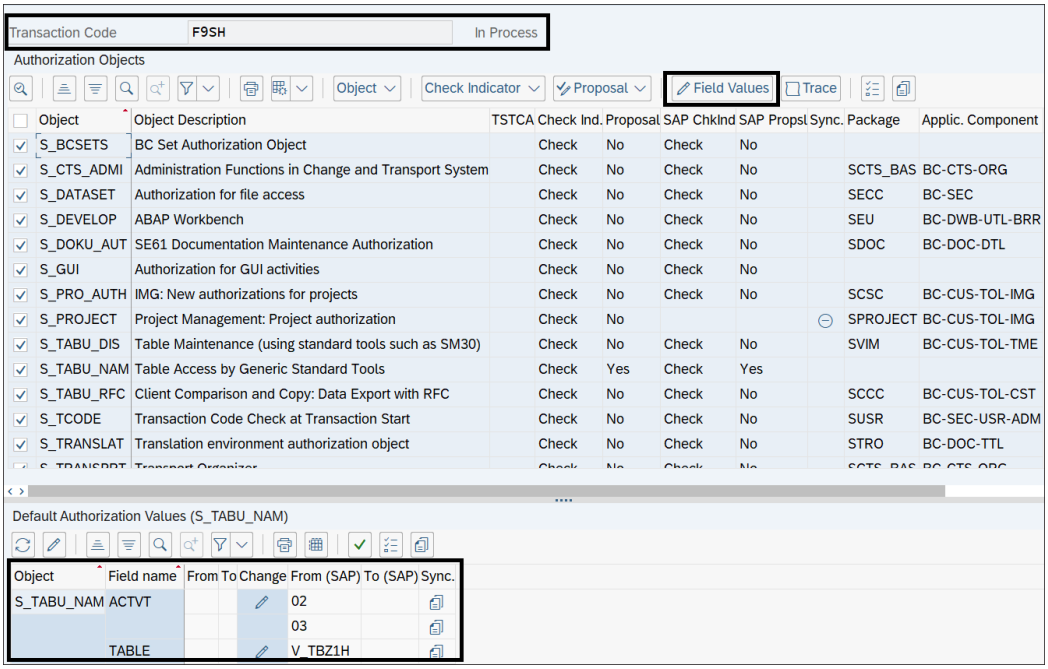


Figure 5.45 SAP Authorization Default Data Synchronization of Transaction F9SH

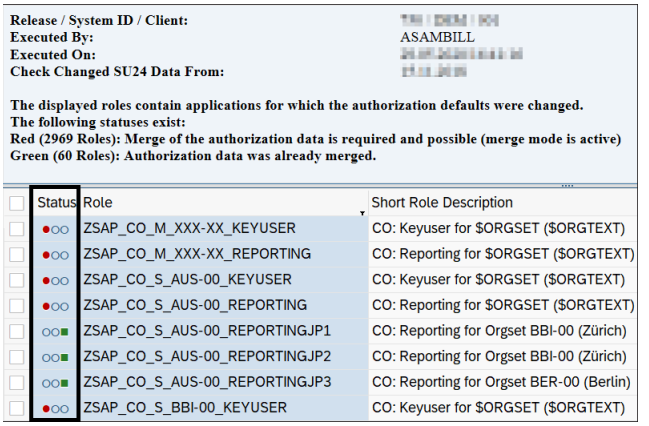
A best practice in general is to insert new authorization objects and values since these new items are based on the newly provided coding structure of the latest SAP release, enhancement package (EHP), or SAP Note. The second synchronization step is to check the new authorization values. Values that you should usually copy are shown in Figure 5.45. The synchronization also depends on your customizing. If authorization objects, fields, or values exist that SAP suggests removing, their removal is not always the best decision. We recommend skipping the removal step because SAP provides a general default setting for all customers based on a worldwide standard. Be aware that you cannot directly remove TSTCA objects, even if SAP suggests you do so.

10. **Check the upgrade impact on your roles**

    Execute the step **Roles to Be Checked (2c)** in Transaction SU25, shown earlier in Figure 5.39. This step is also mandatory to reveal the upgrade impact on your existing role profiles. When implementing new proposals via Transaction SU25, you also must update your role concept. Before moving forward in your upgrade post-processing, you should again use report SU24_AUTO_REPAIR with the selections from the earlier **Consistency Check for Default Values** step. By running step Transaction SU25, step 2c, you'll see a list of all roles that need an adjustment in light of the new default values. Figure 5.46 shows an example of that list. You must enter each role profile with Transaction PFCG's expert mode option **Read old status and merge with new data.** Then, maintain or inactivate open authorization fields, check the

Personal Copy for Arun Singal, arun.singal560@gmail.com

new fields, and generate the role profile. Next, transport the roles to the QAS for testing. After a successful testing phase, you can import these roles into the PRD. After this step, you'll have ensured that all technical changes are incorporated into your role concept.



Release / System ID / Client: [redacted]
Executed By: ASAMBILL
Executed On: [redacted]
Check Changed SU24 Data From: [redacted]

The displayed roles contain applications for which the authorization defaults were changed.
The following statuses exist:
Red (2969 Roles): Merge of the authorization data is required and possible (merge mode is active)
Green (60 Roles): Authorization data was already merged.

Status	Role	Short Role Description
●○○	ZSAP_CO_M_XXX-XX_KEYUSER	CO: Keyuser for $ORGSET ($ORGTEXT)
●○○	ZSAP_CO_M_XXX-XX_REPORTING	CO: Reporting for $ORGSET ($ORGTEXT)
●○○	ZSAP_CO_S_AUS-00_KEYUSER	CO: Keyuser for $ORGSET ($ORGTEXT)
●○○	ZSAP_CO_S_AUS-00_REPORTING	CO: Reporting for $ORGSET ($ORGTEXT)
○○■	ZSAP_CO_S_AUS-00_REPORTINGJP1	CO: Reporting for Orgset BBI-00 (Zürich)
○○■	ZSAP_CO_S_AUS-00_REPORTINGJP2	CO: Reporting for Orgset BBI-00 (Zürich)
○○■	ZSAP_CO_S_AUS-00_REPORTINGJP3	CO: Reporting for Orgset BER-00 (Berlin)
●○○	ZSAP_CO_S_BBI-00_KEYUSER	CO: Keyuser for $ORGSET ($ORGTEXT)

Figure 5.46 Result List of Transaction SU25, Step 2c

11. **Check for obsolete applications**
    To check all applications that will be obsolete after the upgrade, you must execute **Search for Obsolete Applications (2d)** in Transaction SU25, shown earlier in Figure 5.39. When you run this report, the output includes all applications that are replaced by another application or a new application during the upgrade. Especially concerning an SAP S/4HANA authorization migration, this step is required for the whole update process. You can use this information to notify your end users in advance about possible changes to their daily work and thus avoid interruptions or excessive support tickets. Figure 5.47 shows an example of this obsolete application list.

12. **Transport the upgraded USOB*_C tables**
    A general rule is that proposals must be the same in all system layers for consistency reasons and, especially, for adaptation by check indicators. This step is necessary because the update may change DEV default data significantly. Your upgrade process impacts the proposal values assigned to your roles and their check indicator statuses as well. On one hand, you must update the authorization profiles in the roles. On the other hand, and more important for subsequent layers, are the changed check indicators. You require these new check rules combined with the latest authorization default values on the PRD. Therefore, transport the updated authorization default data (tables `USOBT_C` and `USOBX_C`) using your second workbench transport.

    Please note that, if you adjusted your roles during the Transaction SU25 upgrade process, you must also transport these changes to the PRD.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Status	Role	De	Node ID	Old TA	Old Transaction	Automatic Adjustment	D	Lo	New TA	New Transaction
●○○	WCHXIT_SAPMENU		36683	Transaction	S_EBS_44000445	Old entry will be deleted	☑	☐		
●○○			51947	Transaction		Old entry will be deleted	☑	☐		
●○○			7356	Transaction	SE81	Old entry will be deleted	☑	☐		
●○○			7357	Transaction	SE82	Old entry will be deleted	☑	☐		
●○○			415	Transaction	SO80	Old entry will be deleted	☑	☐		
●○○			30842	Transaction	SWH_EXIT_DISPLAY	Old entry will be deleted	☑	☐		
●○○			19633	Transaction		Old entry will be deleted	☑	☐		
●○○			32054	Transaction	VIS1	Old entry will be deleted	☑	☐		
●○○			31611	Transaction		Old entry will be deleted	☑	☐		
●○○			40811	Transaction		Old entry will be deleted	☑	☐		
●○○			32055	Transaction	VIS2	Old entry will be deleted	☑	☐		
●○○			31612	Transaction		Old entry will be deleted	☑	☐		
●○○			40812	Transaction		Old entry will be deleted	☑	☐		
●○○			6889	Transaction	VL13	Old entry will be deleted	☑	☐		
●○○			7053	Transaction		Old entry will be deleted	☑	☐		
●○○			50767	Transaction	WLAM	Entry will be replaced	☐	☐	WLAMN	Layout Maintenance
●○○			50575	Transaction		Entry will be replaced	☐	☐		
●○○			20364	Transaction		Entry will be replaced	☐	☐		
●○○			20362	Transaction	WLMM	Entry will be replaced	☐	☐	WLMMN	Layout Module Mai
●○○			50573	Transaction		Entry will be replaced	☐	☐		
●○○			50765	Transaction		Entry will be replaced	☐	☐		

Figure 5.47 Result List of Transaction SU25 Step 2d

13. **Use Transaction SU25 expert mode**
    Regarding individual use cases, you can also use the report **SU24: Expert Mode for Transferring SU22 Data**, as shown in Figure 5.48. This report is helpful for appropriate adjustments or application-dependent activities. You can find this report, labeled with **Expert Mode for Step 2**, in the header bar of Transaction SU25.

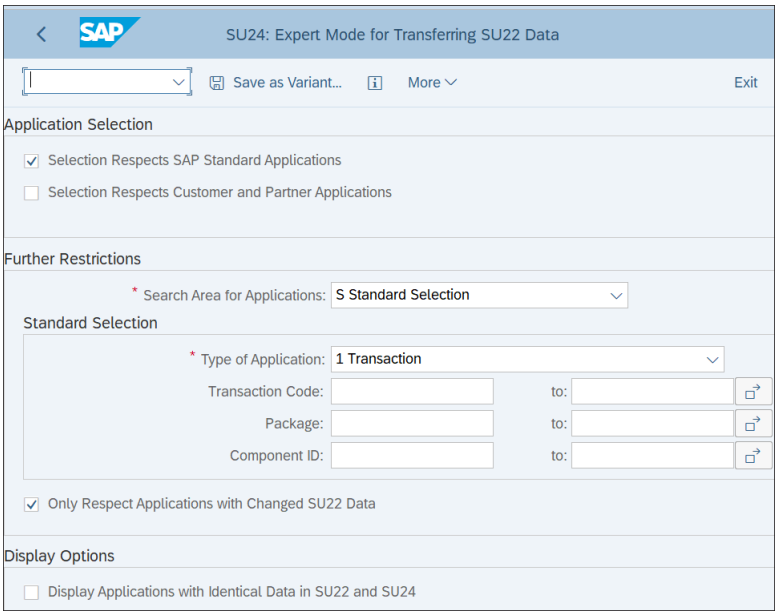


Figure 5.48 Expert Mode for the Comparison between Transaction SU22 and SU24 Data

Personal Copy for Arun Singal, arun.singal560@gmail.com

As with Transaction SU24, you can search for specific applications and additional packages and component IDs. Concerning the used application types of your end users by the ST03N data, expert mode offers you an excellent way to keep your upgrade process on the application level or in the scope of business needs. For instance, you can view the list of all used transactions from the PRD via Transaction ST03N and enter them into the expert mode transaction selection.

Hint

Refer to Chapter 9, Section 9.14, and Chapter 4, Section 4.3, for more information regarding Transaction ST03N and the benefit of usage data.

5.6.5 Troubleshooting

While performing a Transaction SU25 upgrade or adjusting some individual proposals, you might run into issues. The following list gives some tips for managing these issues, including where to find additional information to solve the problem:

- **SAP Notes**
  One of the most important resources to resolve a possible upgrade issue is to use SAP Notes. As first-level support, you should routinely check out SAP Notes 440231 and 1539556 to get the latest information about corrections, new updates, or existing failures. Check especially the "References" and "See also" sections.
- **Consistency check and report SU24_Auto_Repair**
  Sometimes, technical issues exist within an SAP system that are out of your control, such as a mechanical failure. Run the consistency check in Transaction SU25 and report SU24_AUTO_REPAIR once again to rebuild or fix any flawed data fragments.
- **Manual comparison and adjustments of Transaction SU22 and SU24 data**
  Open both Transactions SU22 and SU24. Filter for the target applications and check the defaults in both transactions. You might have incomplete or incorrect data and thus need a new proposal value upgrade through Transaction SU25. You can also compare the `USOB*` tables, but you should use the appropriate programs to avoid direct table changes. Additionally, you might need to adjust inconsistencies by yourself, which means you need to complete Transaction SU24 data similar to Transaction SU22 data if the automatic process or a manual step does not work correctly.
- **Restoring your backup transport**
  Since you stored your functioning and consistent Transaction SU24 data in your backup transport before the upgrade, you can restore this data if you cannot solve inconsistencies after the upgrade. However, you'll need to perform the entire Transaction SU25 upgrade once again. Therefore, you should first verify the consistency of the new Transaction SU22 data provided by SAP to avoid upgrade issues again.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Basis**
  Contact your Basis department and verify whether the Transaction SU22 data import was corrupt or not complete. In this case, reimport the data.
- **SAP Support Portal**
  If you still cannot solve the problem, report an incident on *https://support.sap.com*.

5.7 Transaction SU24 Optimization Tools

Besides SAP applications, you'll need to focus on optimizing your custom development proposals. To suit your business processes or regulations, you might need to develop new programs or enhance current applications with custom objects. In fact, every developer should follow the SAP developer guidelines and its presets. One of these regulations is to create the required custom authorization objects and maintain Transaction SU24 data records. You can use Transactions SU24 for direct proposal maintenance if you know the missing authorizations. On the other hand, you may often need to find the missing or required authorizations. Therefore, you can use various support tools like traces or code scanners. As described in Section 5.4, you can mainly use three trace types to enrich your custom default data. These tools are Transactions STUSOBTRACE, STAUTHTRACE, or STUSERTRACE. The long-term authorization trace is especially valuable for maintaining your proposals. All traces lead you to the correct values for your authorization default data optimization and maintenance with SAP standard tools.

Another option is to use Transaction SU53 to check which missing authorizations lead an end user to an authorization error. Then, you can find, evaluate, and add the correct values as necessary via Transaction SU24. This process is more or less a straightforward iterative procedure. Please be careful using this approach to handle your Transaction SU24 optimization, however. Strictly avoid maintaining all trace results. Focus on the ones that are suitable for all end users and constitute fixed internal processes.

Hint

Refer to Chapter 7 for more information about the various trace types.

Another possibility is to use report RS_ABAP_SOURCE_SCAN via Transaction SA38. Please note that this approach requires excellent knowledge of ABAP code and the ability to read it. Otherwise, you won't achieve your goal of optimizing your proposal values in this way.

Enter the referring program for the requested transaction, which you can find for standard and custom applications in Transaction SE93. In the **String searched for** box, enter "Authority-check," as shown in Figure 5.49.

Personal Copy for Arun Singal, arun.singal560@gmail.com

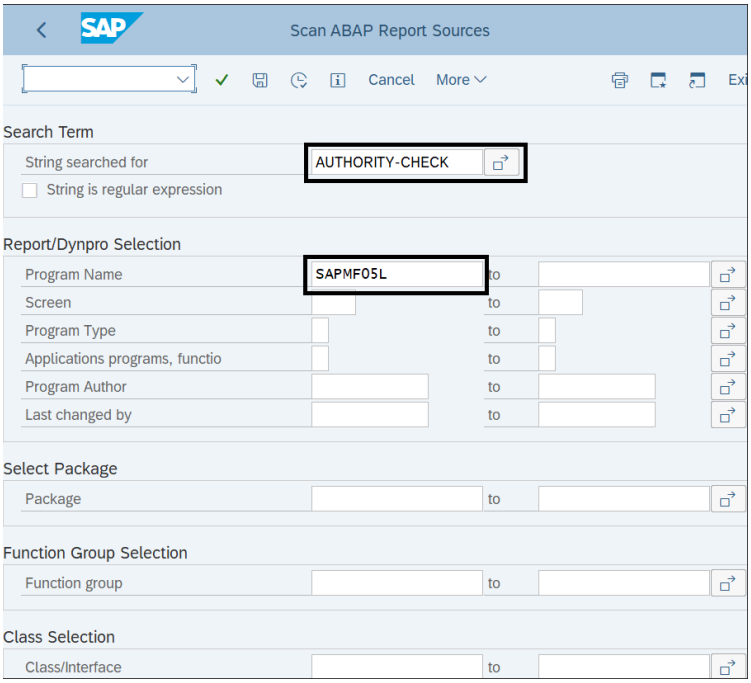


Figure 5.49 Selection Screen Example of Report RS_ABAP_SOURCE_SCAN

Execute the report. Check the authorization objects, fields, and values within these AUTHORITY-CHECK statements, as shown in Figure 5.50. Compare these checks with the application's existing proposal data. Next, validate whether you can integrate some values as default for standardized business processes. Finally, when required, add the missing values in Transaction SU24 for the specific application.

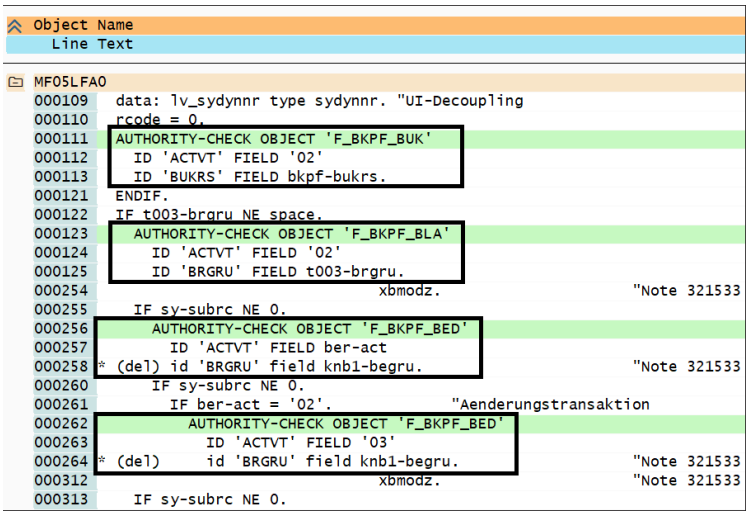


Figure 5.50 Source Code Scanning for AUTHORITY-CHECK Statements

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Alternatively, you can also use Transaction SCI (Code Inspector) to find related proposal candidates.

5.8 Xiting Authorizations Management Suite: Transaction SU24 Optimization Tools

The manual default data optimization approach can be an incredibly time-consuming process and assumes a professional level of programming understanding. Alternatively, XAMS offers an efficient and automated approach to Transaction SU24 optimization via its modules Xiting Role Profiler, Xiting ABAP Alchemist, and Xiting Role Builder.

Thus, this section introduces you to the extensive authorization default values optimization and proposal-related code scanning capabilities available with XAMS.

5.8.1 Xiting Role Profiler

With Xiting Role Profiler, you can optimize your Transaction SU24 proposal values almost automatically. In addition, based on decades of project experience, this module contains all the must-have default values that are often missing in SAP systems. You can quickly insert these known lacking proposals when referring to the transaction context for diverging use cases.

You can check the integrity of authorization default values for all existing roles and their menu objects. This approach enables an operator to use all applications within their roles correctly. You only need to define your role selection and click on the desired reports. This solution enables proposal maintenance on used applications. The presented reports depict various scenarios like table or program access in proposal integration. Then, you can integrate the missing values with one click. You can see an example of Transaction SU24 optimization report for S_PROG* in Figure 5.51.

Concerning display-only transactions, you can also check whether only display values exist for that target application in Transaction SU24 or whether some non-display activities have been erroneously maintained. Additionally, Xiting Role Profiler contains features to check for maintained TSTCA objects, closing open default authorization fields, or keeping an eye on your HR structural authorization proposals. All of these optimization reports improve your role concept's overall robustness and make it easier to create new job function roles based on your existing source code.

Personal Copy for Arun Singal, arun.singal560@gmail.com

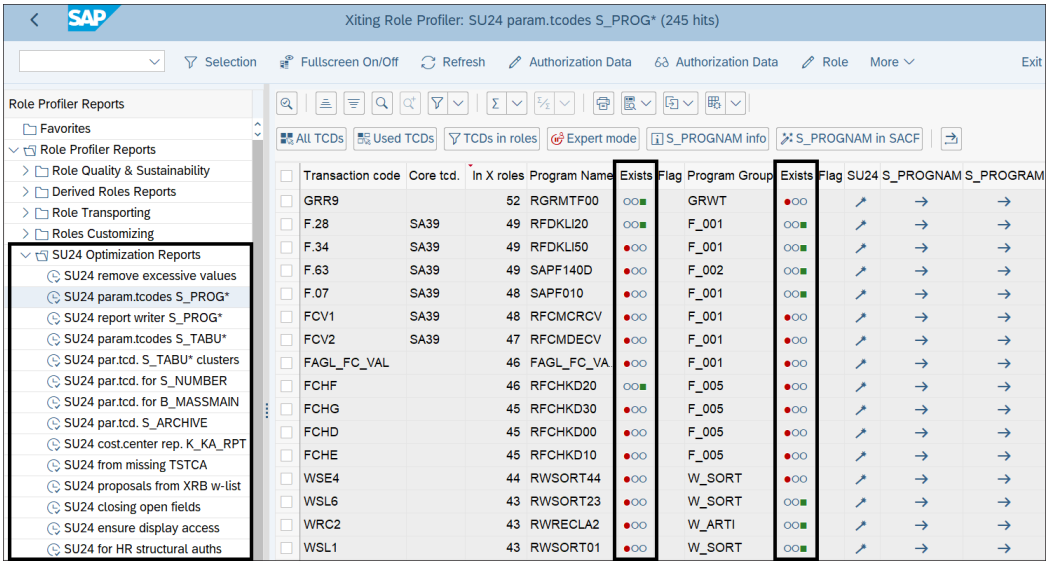


Figure 5.51 SU24 Optimization According to Parameter Transactions for S_PROG* via Xiting Role Profiler

5.8.2 Xiting ABAP Alchemist

One of the use cases of Xiting ABAP Alchemist is to scan your custom code. With this module, you can find all existing authority checks in your programs easily. This solution provides features to directly maintain the Transaction SU24 proposal data of the related applications without using any traces. In this way, you can easily compare the already maintained values of an application with the required values, as shown in Figure 5.52. If you do not maintain your custom developments, they will not be functional and might also present some security vulnerabilities.

Besides security admins, this tool could be valuable for developer in need of extensive code scanning. For example, in the context of SAP security administration, you can use this module to search for statements like `CALL TRANSACTION` or `AUTHORITY-CHECK`.

5.8.3 Xiting Role Builder SU24 Checkman

For more complex cases, some required values might only become apparent upon the execution of the transaction. To assist with these cases, you can use Xiting Role Builder SU24 Checkman. This tool highlights missing authorization proposals from different trace sources. As shown in Figure 5.53, you can directly see the missing authorization objects, fields, and values based on the menu object usage. This tool is helpful for transactions and all other application types maintainable in Transaction SU24.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

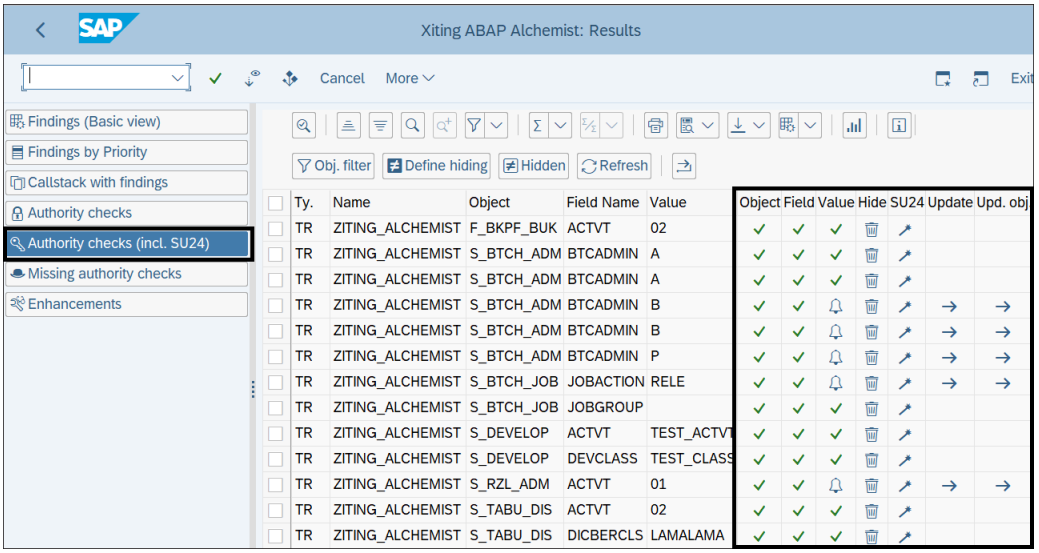


Figure 5.52 Xiting ABAP Alchemist SU24 Optimization

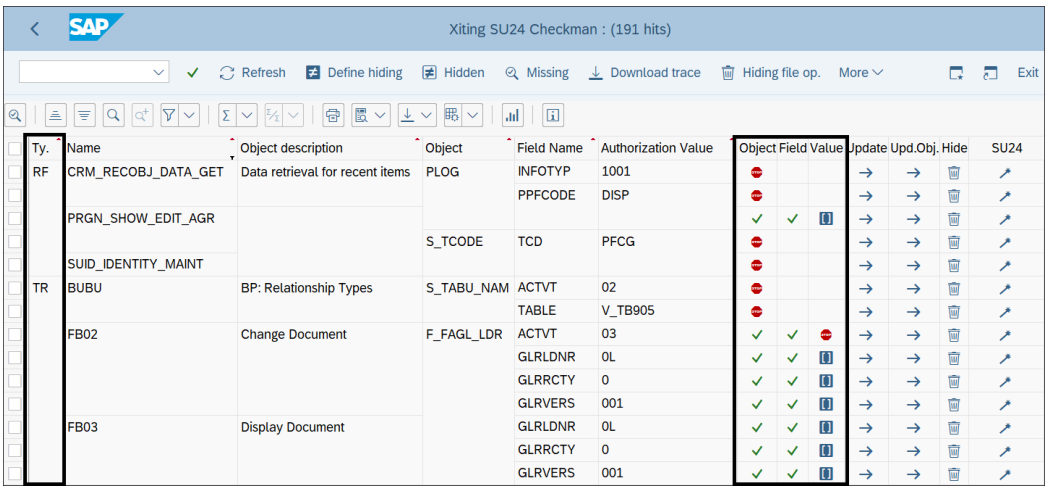


Figure 5.53 SU24 Optimization according to Trace Data via Xiting Role Builder

5.9 Summary

Authorizations are an essential aspect of any SAP system since they control what an operator can see and do. Authorization default values are predefined authorization objects, fields, and values for role maintenance to run any application securely and correctly. Otherwise, you would jump from one authorization error to another. Default values are helpful for a sustainable and rule-based role concept. This chapter explained the purpose of authorization default values, their technical background, and their

Personal Copy for Arun Singal, arun.singal560@gmail.com

dependency on the system layer. Furthermore, you were introduced to general settings, functions, and instruments in Transaction SU24 as well as how you can maintain proposals with these tools to follow best practices. We also included complex best practice-informed instructions for performing a proposal upgrade. Finally, we showed you how you optimize authorization default values in SAP standard and with XAMS.

In this chapter, you also learned how authorization defaults work at their root and how to use different approaches and tools to master authorization defaults. Understanding the capabilities of authorization proposals and how to use them to your advantage are mandatory skills for any SAP security administrator because these features are based on the provided application program code. To sum up, proposal values are essential for a sustainable, secure, and upgradable authorization concept that suits your business processes. As a security administrator, you should never work without Transaction SU24 or without authorization default values. Otherwise, you'll create an unscalable workload, with a lot of guesswork and security issues. Please note that the less you use proposals, the more effort role maintenance will require, increasing exponentially over time and by the number of roles.

Moreover, using authorization default values prevents authorization issues and trace actions in many cases. In the next chapter, we'll introduce you to another important authorization task—role creation and maintenance—and the information in this chapter is required for this task.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 6
Role Maintenance in Transaction PFCG

Role creation and maintenance are among the most crucial activities for any SAP security administrator. Roles are the core elements for assigning authorizations to end users. This assignment enables them to work within the SAP system. Therefore, roles and their related role profiles form the foundation for any authorization allocation activities and for the secure utilization of the functionalities available in SAP Business Suite.

Before SAP Business Suite R/3, manual authorization profiles were the central components for authorizing end users for system functions and data access. Today, with SAP ERP 6.0 or SAP S/4HANA, *roles*, formerly called *activity groups*, are the fundamental elements for end-user authorizations. They enable the granular assignment and maintenance of authorizations. Roles are the maintainable technical containers for all required application authorizations.

After authorization maintenance within roles, the system automatically converts the maintained authorizations into a related role profile when you actively generate it. These role profiles are a technical remainder from the old profile world and are essential for the system and further authorization processing. The underlying authorization check has not changed. So, profiles are still needed but not created and maintained in the old way. When an end user logs on to the SAP system, the kernel directly deposits all assigned end-user authorizations based on the profiles (role or manual profiles) in the end user's unique user buffer. In this way, the system can quickly compare and validate an end user's actual authorizations for the desired actions and access through the underlying authorization checks present in an application's source code.

Therefore, roles enable you to manage maintainable, sustainable, and secure authorization allocations, which can serve as the single source of truth for all end-user authorizations. The use of manual authorization profiles is not only out of date because of new technical prerequisites for SAP systems, but because manual authorization profiles compromise your authorization concept, end-user authorization upgradability, and system security. Manual authorization profiles also often contain countless critical authorizations, and you should avoid assigning this profile type.

Your focus as a security administrator should be on roles and their related role profiles. The central cockpit to create or maintain roles and authorization data or to assign roles

Personal Copy for Arun Singal, arun.singal560@gmail.com

to end users is the profile generator. You can launch this tool via Transaction PFCG. This powerful application has extensive functions with various maintenance options for roles. If you do not work with this transaction, following the SAP standard and best practice approach, you may suffer daily business interruptions and security issues.

This chapter explains all the important information you need to use Transaction PFCG and its activities from a basic level to an advanced level. We'll cover the different role types; navigation through the profile generator; and further actions like authorization maintenance, role transport, and role versioning. Moreover, this chapter provides a guideline for sustainable role creation and maintenance. We'll provide an introduction on how to use the essential functionalities of the profile generator correctly. This knowledge will enable you to build a secure and solid role concept for your entire company.

Hint

Before starting with a deep dive into the profile generator and role maintenance, you should recall the difference between manual profiles and roles. Primarily, our main focus is on the advantages of using roles. For basic information, refer to Chapter 2, Section 2.4, and keep the following points in mind:

- **Technical**
  Since Basis version release 7.50, no role profile assignment limit exists for end users, which should consider while maintaining your roles. For manual profiles, a 312-profile limit still exists (see SAP Note 410993).
- **Code based**
  Through the role menu, you can automatically integrate proposals for the maintained applications according to the appropriate `AUTHORITY-CHECK` statements in the program code. Also, this code-based dimension provides the where-used list in the authorization profile to see the related applications that require each authorization object.
- **Maintainable**
  You can avoid excessive maintenance effort required to provide your desired applications' correct authorizations. This dimension also applies when updating end-user authorizations after any SAP release upgrades.
- **Organizationally structured**
  The maintenance of organizational levels for all related authorization objects through the central mode is more user friendly and straightforward than maintaining each authorization object.
- **Secure**
  You can avoid overauthorizing your end users through the correct authorization assignments using authorization default values and job function role maintenance.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Manageable**
  You can directly manage role assignments to end users with validity dates via Transaction PFCG.

6.1 Navigation within Transaction PFCG

The profile generator (Transaction PFCG) is the central cockpit to create, change, and delete your role types. Before you begin any of these actions, you must understand the capabilities and opportunities of this tool.

This section navigates you through the main functions and options available in the profile generator.

6.1.1 Initial Screen of Transaction PFCG

The initial screen of Transaction PFCG provides access to various role maintenance functions. Before you can execute most of these features, you must specify a role by entering a role name or ID in the **Role** field, as shown in Figure 6.1.

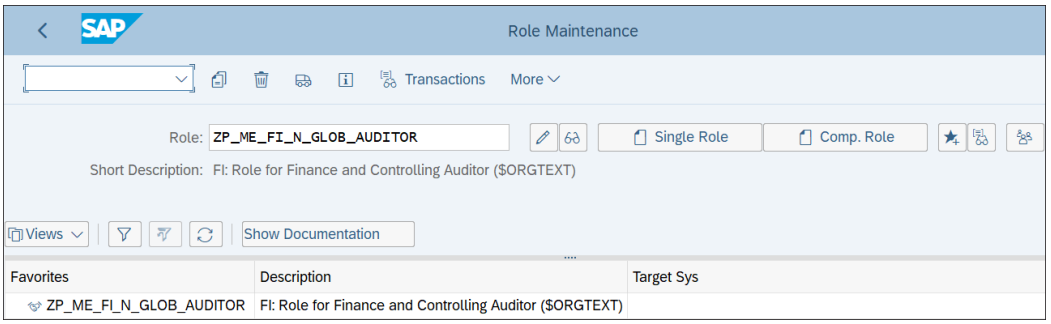


Figure 6.1 Transaction PFCG Initial Screen

The header bar allows you to copy, delete, and transport the selected role. Moreover, you'll see some information about the role creation process (info icon), and you can also search for roles with specific transactions. The **More** button offers further functionalities, such as role adjustment options, mass actions for roles, role change documents, and cross-application features with role-related applications like Transaction SU25, as shown in Figure 6.2.

Figure 6.2 Transaction PFCG Initial Screen: Header Bar

Personal Copy for Arun Singal, arun.singal560@gmail.com

Furthermore, you can select different Transaction PFCG view options by navigating to **More • Goto • Setting**. This step enables you to switch between simple maintenance, basic maintenance, or complete maintenance views. Note that these settings provide you more or fewer tabs and features in the role's maintenance area.

Hint

Some essential mass maintenance role options are described in detail in Section 6.8.

The middle of the initial screen)contains the functions to change or display existing roles and create new roles, as shown in Figure 6.3. You can choose between creating a single role or a composite role by clicking the **Single Role** or the **Comp. Role** buttons. Next to those buttons, from left to right, are icons for adding the currently called role to your **Favorites** section, checking whether this single role belongs to a composite role, and for the role's assignments to users.

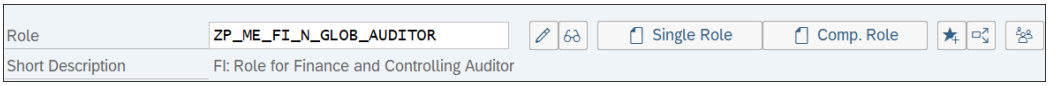


Figure 6.3 Transaction PFCG Initial Screen: Middle View

The overview area is primarily a view of your role **Favorites** with their related short **Description** and **Target System** fields, if the role is distributed via a remote function call (RFC) connection, as shown in Figure 6.4. You can also list all your single roles or composite roles within your **Favorites** section and sort them by specific criteria.

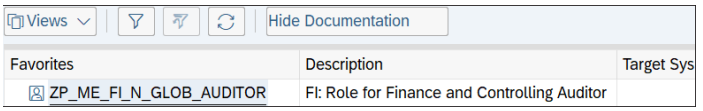


Figure 6.4 Transaction PFCG Initial Screen: Favorites Area

6.1.2 Single Role Maintenance Options and Tabs

The maintenance area for single roles has comprehensive features you can modify during your role creation and maintenance processes. Single roles, as the best practice role type for authorization maintenance, enable various options to establish a secured and sustainable role concept. To launch this area, enter a role name according to your role naming convention and click on the **Single Role** button to create this role, shown earlier in Figure 6.3.

Hint

A best practice is to use single roles and avoid composite roles for your role concept. For detailed information, refer to Chapter 3.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The following list describes several maintenance options you can use for maintaining your single roles:

- **Menu bar and role information**
  First, the header bar, shown in Figure 6.5, allows you to switch between the display and change modes. Also, you can select another role or check for inheritance. Clicking the information icon shows a procedural description for role creation. Furthermore, you can access various advanced role options via the **More** button. Beneath the header utilities, you'll see basic information about your roles, including the role's name (**Role**), short **Description**, and **Target System** (if you distribute these roles via RFC). The **Obsolete** checkbox is an information flag indicating that this role is no longer relevant for user assignment, which enables you to exclude these roles during role analysis. You can exclude roles by clicking the **More** button, in the **Role** section. Note that you can still assign this role. Thus, this flag has no functional influence.

  These settings, except the **Target System** field, are also available for composite roles.

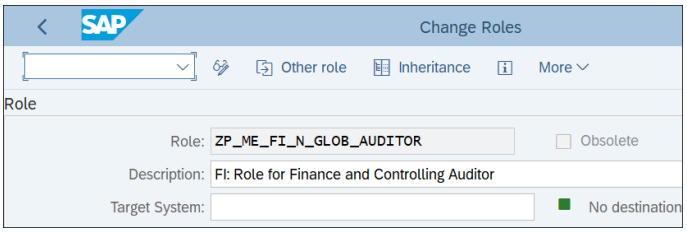


Figure 6.5 Header Bar and Basic Role Information of a Single Role

- **Description**
  The **Description** tab includes information about the creation of the role, including its created-on and last-changed dates (**Administration Information** section), its existing inheritance (**Transaction Inheritance** section), and its long description (**Long Text** area), as shown in Figure 6.6. These details are essential for an informative overview of your selected role, and you can create a role changelog through the role's **Long Text** field. The long descriptions for your roles can contain information about the role's creator (**USER**), capturing changelog dates (**DATE**), project or internal ticket number (**REFERENCE**), and a summary of the role changes (**DESCRIPTION**). For this task, you can also use external data by downloading and uploading .txt files. Figure 6.6 shows an example of a role's **Long Text** in use.

Hint

Another good approach is to keep the long description info quite basic to ensure that your administrators do not only rely on the provided data in this changelog, which depends on the administrators understanding how relevant this information is. We recommend checking the system role changelogs via **More** • **Utilities** • **Display**

Personal Copy for Arun Singal, arun.singal560@gmail.com

changes, as shown earlier in Figure 6.5. This information is always up to date based on automatic data collection during role changes.

Furthermore, the Xiting Authorizations Management Suite (XAMS) provides valuable tools for creating and maintaining role short and long descriptions en masse.

The **Transaction Inheritance** area shows the parent master role if you are using the SAP derivation approach. This master role can be used as a reference because it propagates the functional authorizations to its derived roles. The derived role only differs in organizational level. You must then maintain these levels separately in each derived role.

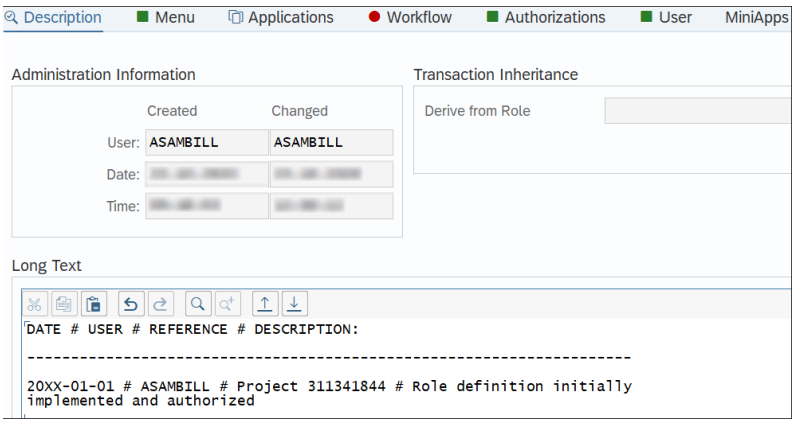


Figure 6.6 Description Tab of a Single Role

Hint

See Section 6.2.4 for more information about the inheritance approach.

- **Menu**

  The role menu, under the **Menu** tab, is one of the most crucial tabs in the single role maintenance area. The maintenance of applications in the role menu greatly influences the sustainability and quality of your roles. Role menu objects include, for example, transactions, RFC modules, Web Services, Web Dynpro applications, or SAP Fiori business catalogs and groups. Adding role menu objects enables the use of the authorization default values under the **Authorizations** tab, as shown in Figure 6.7. This approach fits the SAP standard and best practice.

Hint

For further information and considerations about the importance of the role menu, refer to Section 6.3.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Please note that the individual menu tree in the **Hierarchy** pane, shown in Figure 6.7, generates the SAP Easy Access menu that your end users see when they log on. Thus, the better you structure the role application hierarchy (the role menu), the more easily your end users can work with it. Also, you can display role documents or import role menus **From the SAP Menu, From Another Role, From Area Menu, from SAP Easy Access Favorites**, or from a file or trace. Enhanced menu options allow the definition of specific attributes of the role menu.

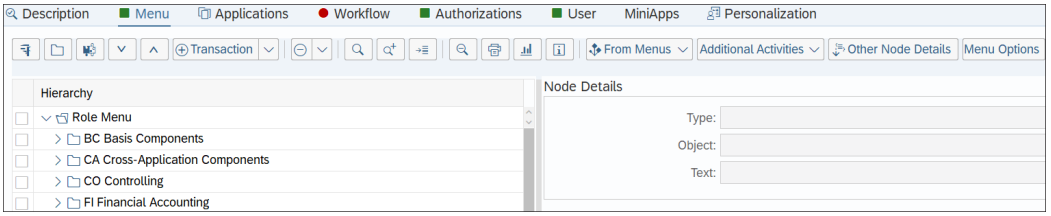


Figure 6.7 Menu Tab of a Single Role

Hint

You can create an individual company menu and use this menu to provide intuitive and simplified working environments for all your end-users through their assigned roles. However, this approach might require huge administrative effort in terms of initial role creation and subsequent role changes. So, take this issue into account when you considering a company-wide SAP Easy Access menu structure.

- **Applications**

  When using Transaction SU24 default data variants within your role concept, you also can access the additional **Applications** tab for menu objects with existing default data variants, as shown in Figure 6.8. In this way, you can activate the desired **Variant** to add predefined proposals into your authorization profile.

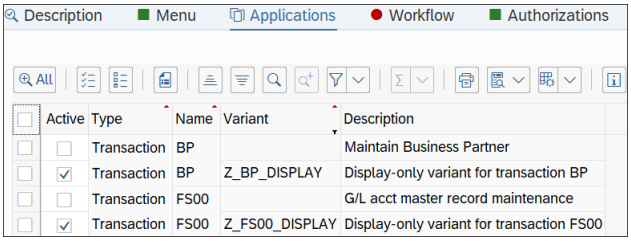


Figure 6.8 Applications Tab of a Single Role

- **Workflow**

  The **Workflow** tab includes workflow processes that enable end users to start a workflow. For instance, suppose an employee wants to order a company vehicle and

Personal Copy for Arun Singal, arun.singal560@gmail.com

requires a related manager's approval, as shown in Figure 6.9. Before the end user can use start this process, you must create a workflow task, assign users to this task, and add that process to a role. You can also perform these actions with Transaction PFCT, but don't forget to align the correct single role to the task.

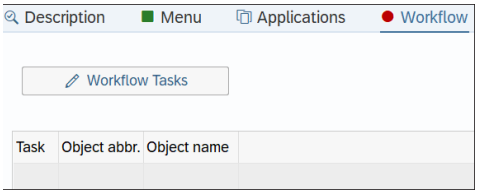


Figure 6.9 Workflow Tab of a Single Role

- **Authorizations**

  The **Authorizations** tab contains role and authorization information. First, you'll see dates in the **Created**, **Last Changed**, and **Last Profile Generation** sections, as shown in Figure 6.10, as well as basic information about the role. To maintain the authorization data and generate the profile, you have two options. The first option is to click the **Change Authorization Data** button, and the second option is to click **Expert Mode for Profile Generation**, as shown in Figure 6.10.

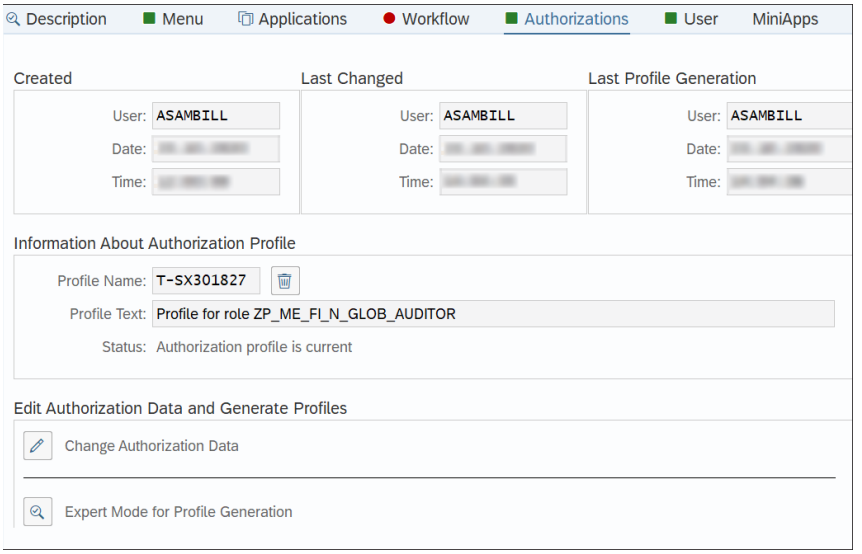


Figure 6.10 Authorizations Tab of a Single Role

Hint

Refer to Section 6.4 and Section 6.5 for detailed information about the capabilities of these maintenance options.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **User**

  Under the **User** tab, you'll see role assignments to end users with corresponding validity dates, as shown in Figure 6.11. Through this tab, you can add and remove roles to/from end users. After assigning a role to a user, you might need to click the **User Comparison** button to match new or updated role assignments with user master records. You can also click the **Organizational Mgmt** button to assign roles to end users indirectly through organizational structures in SAP ERP Human Capital Management (SAP ERP HCM) and its job role definitions.

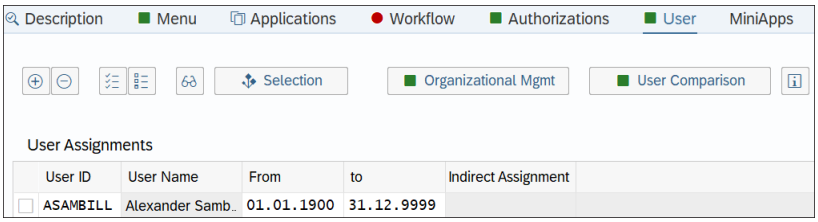


Figure 6.11 User Tab of a Single Role

Hint

You can activate the automatic user comparison mode through the header bar by navigating to **More** • **Utilities** • **User Settings**. Then, select the **Automatic User Master Adjustment when Saving Role** checkbox to reduce repetitive administrative effort.

- **MiniApps**

  Listed under the **MiniApps** tab, shown in Figure 6.12, MiniApps are applications, pieces of information, or services that an end user can see and use in a web browser. Alerts, calendars, company news, and share price tickers are good examples of MiniApps, as shown in Figure 6.12. Another use case is to create employee self-service apps. You can create MiniApps via the web application builder by clicking the **Create MiniApp** button. By assigning these apps to roles, you can specify which end users can use and see them.

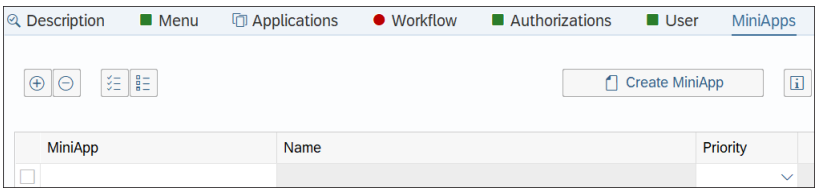


Figure 6.12 MiniApps Tab of a Single Role

- **Personalization**

  The **Personalization** tab enables individualized settings using personalized objects, as shown in Figure 6.13. If personalization exists within roles, for instance, workflow,

Personal Copy for Arun Singal, arun.singal560@gmail.com

approvals, or predefined application layout settings, these settings affect all assigned end users. Especially for restricted query transaction access, this restriction is a handy solution for predefining end-user views. You can also personalize individual end-user settings through Transaction SU01 or personalize a single role for multiple end users via Transaction PFCG.

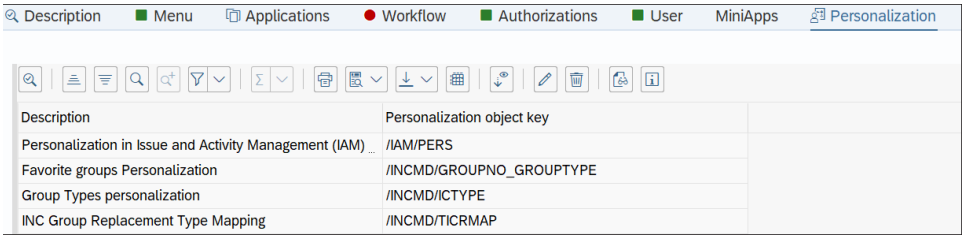


Figure 6.13 Personalization Tab of a Single Role

6.1.3 Composite Role Maintenance Options and Tabs

A composite role is the second primary role type. This kind of role acts as a container for at least one single role and does not provide any authorization maintenance options. Thus, you must create and maintain single roles and then assign them to a composite role via Transaction PFCG. The single roles provide the technical components, the role menu objects, and related authorizations. Therefore, the configuration scope for composite roles is much smaller than for single roles.

Some maintenance options for your composite roles are accessed via the following tabs:

- **Description**
  For composite roles, this tab is similar to the single role and likewise divided into the **Administration Information** section and the **Long Text** section, as shown in Figure 6.14.

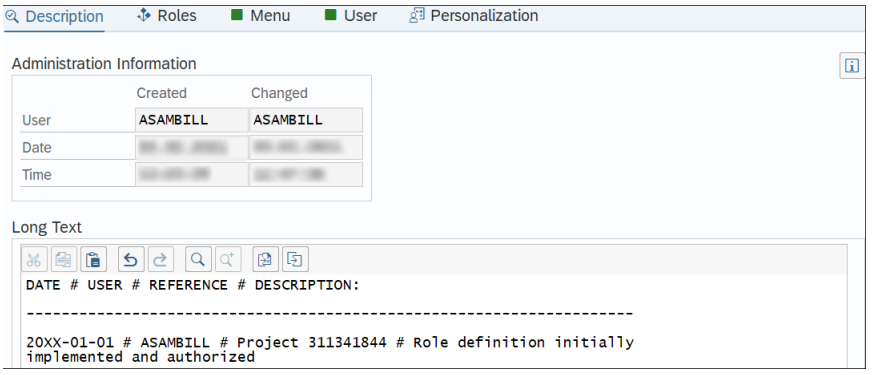


Figure 6.14 Description Tab of a Composite Role

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Roles**

  Under the **Roles** tab, you can assign or remove single roles to or from a composite role, as shown in Figure 6.15. Regardless of whether you assign a single role to a composite role, you can separately activate or inactivate the assignment as well by selecting or deselecting the **Activ** checkbox. On this screen, you can easily see which single roles are active for the composite role and are thus indirectly assigned to an end user through the composite role assignment. If you deselect the **Activ** checkbox, the system ignores this single role assignment. Please note that you should always run the user comparison function when adjusting this option. The **Target Sys** column shows from which system the composite role retrieves the selected single role, for instance, while using central user administration (CUA).

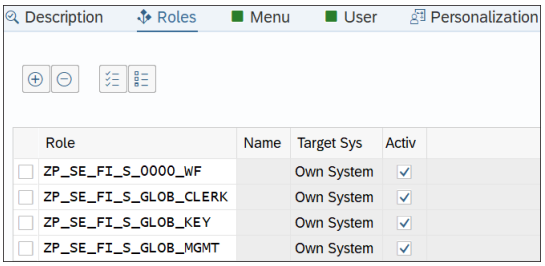


Figure 6.15 Roles Tab of a Composite Role

- **Menu**

  The **Menu** tab for a composite role is not as essential or as maintainable as in a single role, as shown in Figure 6.16. If you only enter a few single roles in the composite role, this tab remains empty. But if you actively import a menu **Hierarchy Structure**, you can use the menu structure from the included single roles by clicking on the **Import Menu** button. The system incorporates the menus of the single roles into the menu of the composite role. In this way, you can easily update your menu structure when you change single role assignments. If you have various menu structures in the associated single roles, the system merges them and displays the combined result accordingly. Please note that you cannot enter role menu objects for composite roles manually. The **Additional Activities**, **Other Node Details**, and **Menu Options** buttons are similar to the single role options.

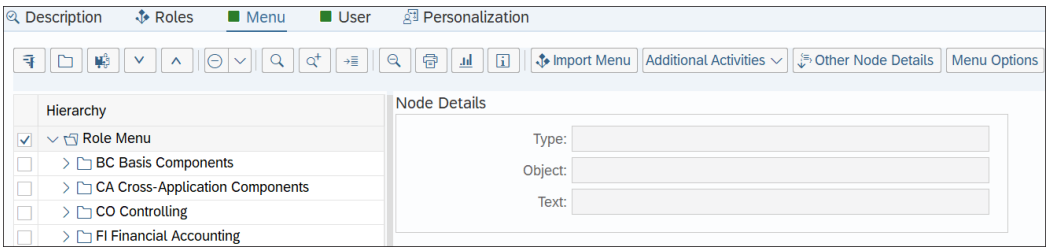


Figure 6.16 Menu Tab for a Composite Role in Transaction PFCG

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **User**
  The **User** tab is how you access the assignment feature, as for single roles, as shown in Figure 6.17. You can assign the composite role to end users directly or indirectly through SAP ERP HCM (**Organizational Mgmt**).

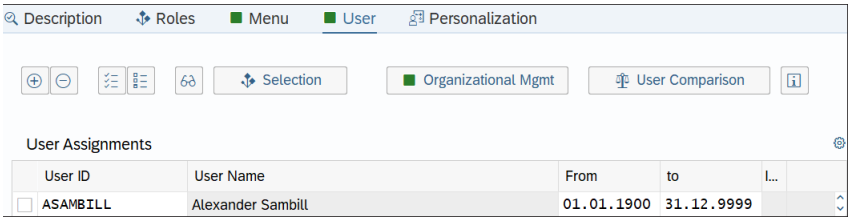


Figure 6.17 User Tab of a Composite Role

Hint

Activate the automatic user comparison mode via a variant of Transaction PFUD through a background job. This approach enables the automatic update of the role assignment and role profile to end users and also affects composite roles. For further information about the user comparison function, Section 6.8.3 and Chapter 9.

- **Personalization**
  You can enter individual end-user settings through the **Personalization** tab to provide user-dependent data, as shown in Figure 6.18, as for single roles or in Transaction SU01. For instance, you can use this tab to cover license data or predefined project management settings on the role level.

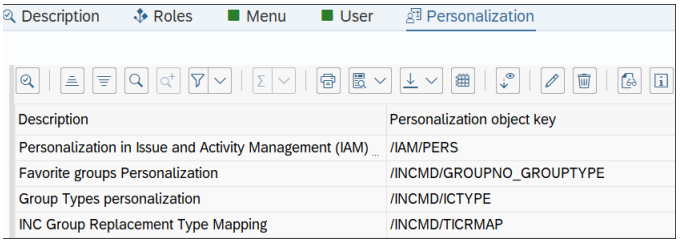


Figure 6.18 Personalization Tab of a Composite Role

6.2 Creation of Different Roles

At first glance, you can only distinguish between creating or maintaining a single or composite role through the profile generator. Thus, to provide as much individualization as possible to cover various business and security cases, you must convert these demands into your single role maintenance. For this task, you can provide different single role types through role maintenance. For instance, to cover organizational

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

access, you can create both master and derived roles. For restrictive system customizing access, you can create specific customizing roles to enable a more granular role concept based on single roles.

This section provides information and considerations about your role naming convention, including how you can create the single role types and which role templates you can use, if necessary.

6.2.1 Role Building and Naming

First, you must consider the system layer before creating your roles and role concept. You must build or maintain your roles only on the development system (DEV) layer and transport them to subsequent systems. SAP recommends this procedure itself, as described in SAP Note 571276. After role maintenance and profile generation, you can transport finished roles into your quality systems (QAS) and productive systems (PRD) and assign them to end users. The following list shows you the relevance of this approach:

- The DEV is (as the name indicates) designed for any customizing objects like roles.
- The profile generator automatically uses the proposal data specified through your role menu maintenance. Thus, you must maintain those proposals also on the DEV.
- You'll need the same role concept on each system layer (e.g., QAS or PRD) to ensure consistency and the opportunity to test the roles on QAS for PRD. This consistency can be achieved through customizing transport requests. The authorization profiles of roles must be consistent on all systems.
- After role maintenance, often a necessary step is performing a role test. Testing may involve a trial-and-error approach, which should be avoided on PRDs with real data usage and business processes. Doing so could directly negatively impact your business environment.
- Also, end users could immediately use the new role adjustment without any approval or testing if you had created them on the PRD.
- You would need to provide critical authorizations and transactions to administrators for their role-building duties on the PRD.
- Because in table `PRGN_CUST` the `CLIENT_SET_FOR_ROLES` flag has been set to `YES`, customizing changes are disabled on PRD, and thus, role changes are prevented because they are assumed to be development changes and require a customizing transport request.

Hint

Table 6.1 lists some helpful tables for role administration.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Table	Description
AGR_DEFINE	Contains basic role information.
AGR_TEXTS	Contains a role's short description.
AGR_1251	Contains all authorization data for the role.
AGR_1252	Contains all organizational levels of the role.
AGR_AGRS	Contains the assignment of a single role to a composite role.
AGR_1016	Contains the role profile name and its status.
AGR_PROF	Contains the role profile name and its name.
AGR_USERS	Contains the role's assignment to end users.
AGR_TIME	Contains various timestamp information about the role.
AGR_BUFFI	Contains internet links for the role.

Table 6.1 Helpful Tables for Role Administration

Before you can start with role creation, you must consider the following system regulations concerning role names:

- A role name is client dependent and cannot exist twice in the same client.
- You cannot use the prefix "SAP" in customer systems. Use the namespace prefix "Z" or "Y."
- You can only enter a role name up to 30 digits long.
- Only Latin capital letters, numbers from 0 to 9, and special characters (such as "_", "&", "+", and so on) are allowed.

A crucial task is developing your own individual naming convention for your roles. No one correct standard naming convention exists because role names should always depend on your enterprise and its requirements. Nevertheless, you must spend some effort building up a naming convention to achieve a consistent, maintainable, and transparent role concept for your company. Thus, you should cover at least the following four characteristics in your naming convention:

- Target system, for instance, D for DEV, Q for QAS, and P for PRD
- Role type, for instance, S for a single role, C for a composite role, M for a master role, and D for a derived role
- Application area, for instance, FI, CO, SD, LO, MM, PP, and QM
- Organizational affiliation, for instance, OrgSet, company code, plant, or division

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

For further considerations and more information regarding role naming conventions, with an example, refer to Chapter 3, Section 3.5.

6.2.2 Single Roles

To create a single role, you must first define an appropriate role name that adheres to your role naming convention. Then, click on the **Single Role** button, as shown in Figure 6.19.

Figure 6.19 Single Role Creation

Next, enter a short and long description (shown earlier in Figure 6.5 and Figure 6.6) and, under the **Menu** tab, enter all required role menu objects (applications). Save the role and then move to the **Authorizations** tab. The SAP system automatically integrates the required default authorizations based on your maintained applications when clicking the **Change Authorization Data** button or accessing one of the expert mode options to enter the authorization profile. Maintain all empty authorization field values, if necessary, and generate the role profile. Finally, transport the role and assign it to an end user via the **User** tab on PRD.

Hint

For more information regarding the correct authorization maintenance and sustainable single role building, continue with Section 6.4 and Section 6.5.

6.2.3 Composite Roles

A composite role serves as a container for one or more single roles and is the second role type you can build from the initial screen of Transaction PFCG. First, enter a role name and click on the **Comp. Role** button, as shown in Figure 6.20.

This role type is intended to simplify the assignment of single roles to end users. Enter a short description for the role and move to the **Roles** tab. Now, assign single roles to the composite role. Also, you can activate or deactivate single roles from composite roles, as shown in Figure 6.21. For readability and maintainability, we recommend removing single roles if they are no longer required, rather than just disabling them.

Personal Copy for Arun Singal, arun.singal560@gmail.com

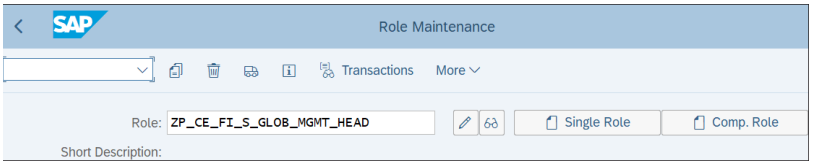


Figure 6.20 Composite Role Creation

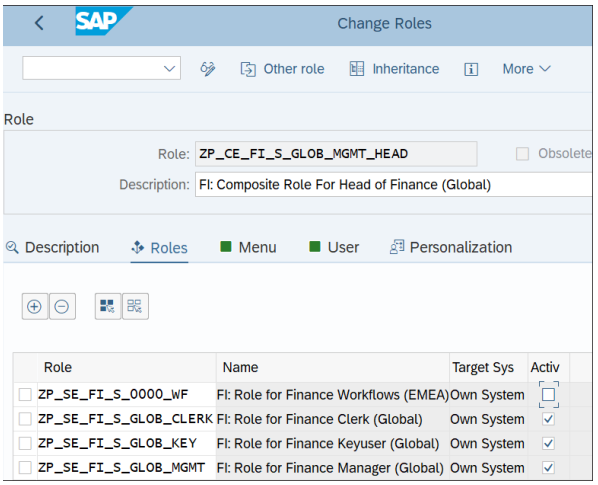


Figure 6.21 Single Role Maintenance in a Composite Role

Next, assign the composite role to your end users through Transactions PFCG or SU01 on PRD. Once assigned to an end user, the system automatically assigns the associated single roles indirectly to the end user. An example of an indirect role assignment is shown in Figure 6.22. All related, maintained, and active single roles become indirectly introduced into the user master record if you assign their composite role.

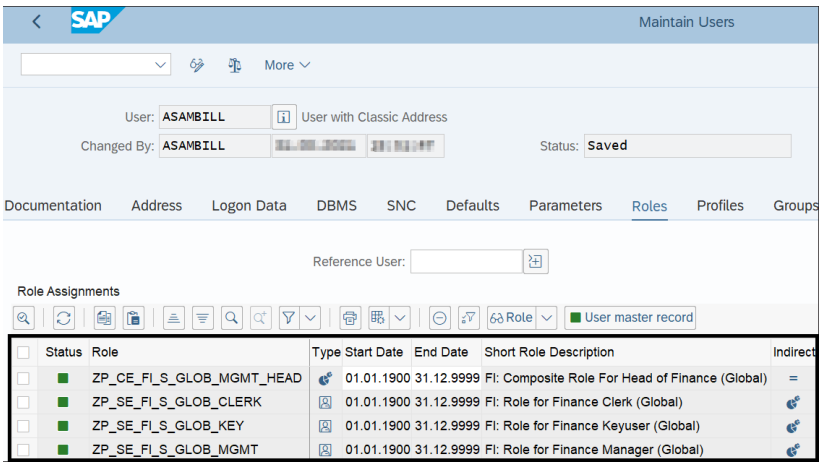


Figure 6.22 Indirect Role Assignment through a Composite Role

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

6.2.4 Reference and Derived Roles

The SAP inheritance function enables the differentiation of organizational levels in roles. Typically, you cannot and must not build one job function role for your entire company that includes all required applications and organizational access (organization levels). Otherwise, you could provide full data access to end users that should not have such extensive authorizations. Therefore, you must use the SAP inheritance concept or a similar concept. A reference role, also called a master or template role, includes applications as role menu objects and proposed authorizations in SAP standard. The derived role, also called the child role or the replicated role, inherits all authorization objects and their maintained characteristics with one exception. A child role does not assume the values of the organizational level fields from the reference role. Thus, the derived role only differs from its master role in its organizational levels. To enable this derivation, you should leave the organizational fields in the master role empty. You can also enter a special character like the dummy value "@" to prevent administrative access and enable the authorization objects to be considered as maintained (green icon), as shown in Figure 6.23.

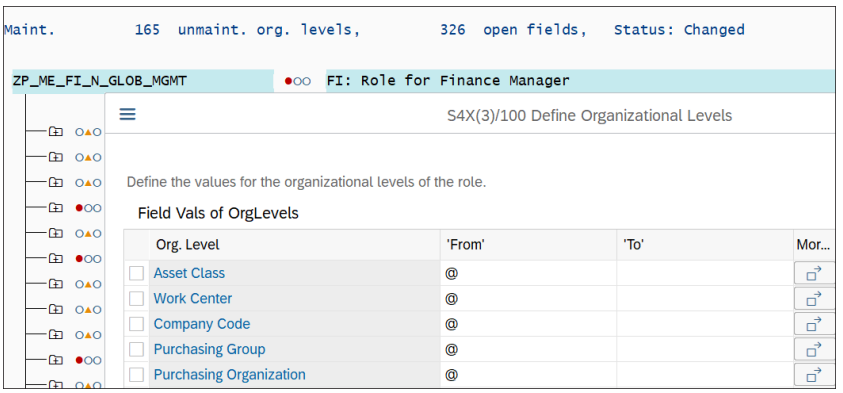


Figure 6.23 Special Characters in Organization Levels of Master Role

In summary, a master role propagates its functional authorizations to its derived roles. The derived roles only differ in their organization level values, which you must maintain separately in each to provide flexible organizational access scenarios. On one hand, you'll benefit from clean differentiation among your organizational roles using the inheritance concept. On the other hand, you'll only need to update a master role and then distribute the changes down to its child roles directly without further maintenance actions for each role.

To create a new master role, launch Transaction PFCG. Enter a role name for the master role and click on the **Single Role** button since a master role is technically a single role. Afterward, enter a short description for the role and maintain the role menu by introducing the necessary applications. Save the role and enter the roles' authorization profile in the role's **Authorization** section. Skip the first popup screen, which asks you to

Personal Copy for Arun Singal, arun.singal560@gmail.com

maintain the organizational levels or enter a non-source code-related special character (like "@"). These organization level fields should remain empty or be filled with nonspecific values because we are working on the master role, and we want to maintain organizational access in each derived role. Figure 6.23 shows a best practice example for maintaining nonspecific organization levels in a master role. Otherwise, if you maintain, for example, asterisks (*) in a master role, you might enable company-wide access to the intended organization levels in the derived roles based on the authorization proposals. This mistake would not only cancel out the inheritance concept, but also damage your entire role concept because you do not restrict roles to specific organizational values. So, avoid assigning any specific organization level values in master roles since they should only provide the functional role scope. Then, child roles must contain the required organizational access. An exception to this recommendation are standardized values that function for the entire company and can be fixed in the master role.

However, you must maintain all other authorization fields with concrete values (except for organization level) to meet predefined business demands and internal regulations. Once the role maintenance status icon turns green, generate the role profile. The role is now only functionally ready to use. With the organization levels still empty, ignore the warning from the profile generator that not all authorization fields have been maintained.

Hint

Never assign a master role to end users because this role should only provide functional, job-related scope, not actual organizational access. Organizational access should only be guaranteed through the specific organization levels specified in each derived role.

Finally, create the derived role as a traditional single role with a role name that is strictly related to its master role via Transaction PFCG. Again, enter a short description for the role and enter the master role name in **Derive from Role** field in the **Transaction Inheritance** section, as shown in Figure 6.24. When you save this role with inheritance, you'll see that the **Menu** tab indicator turns green. The system automatically inherits all role menu objects from the master role to this derived role. The **Transaction Inheritance** area shows you the parent master role, which you can use as a reference.

Hint

The first **S** in our example role name stands for a single role, and the second **S** indicates that the organization level values come from an OrgSet, as shown in Figure 6.24. The string **GLOB** indicates that this OrgSet is a global OrgSet. You can use other identifiers, as described in Chapter 3, Section 3.5. An OrgSet is a typical term used in Xiting Role Replicator and the integrated automatic organization level provisioning capability. See Chapter 4, Section 4.4 for detailed information about this tool.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

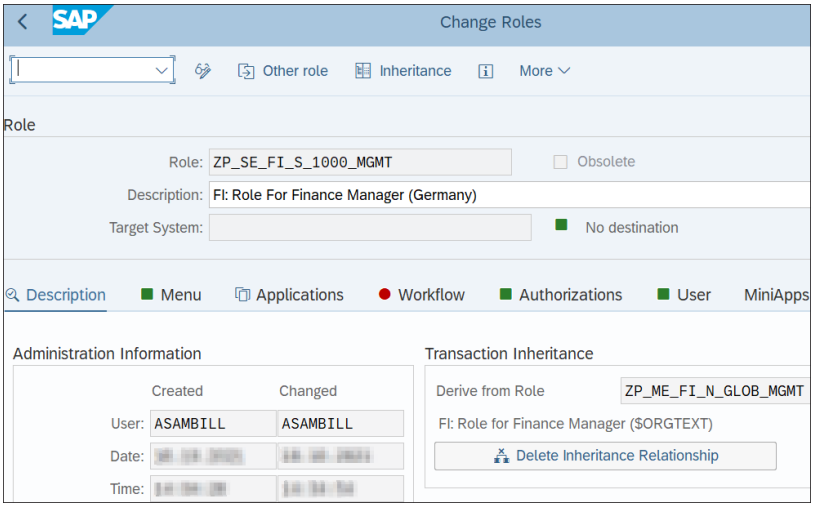


Figure 6.24 Creation of a Derived Role from the Master Role

Navigate to the **Authorizations** tab and maintain the organization levels according to your business needs and the organizational intention for the derived role, as shown in Figure 6.25.

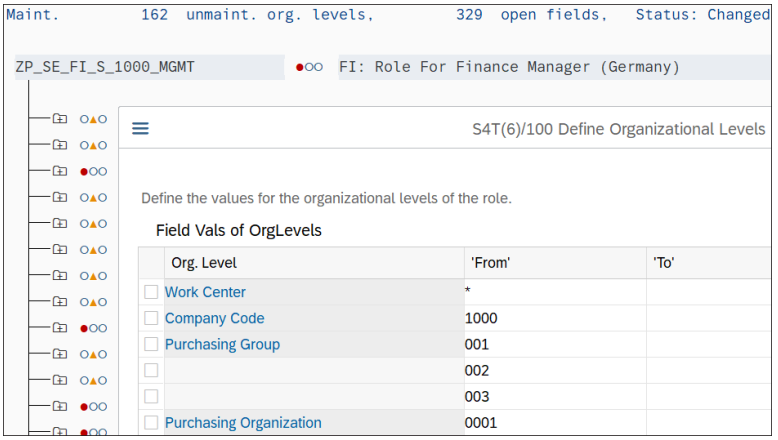


Figure 6.25 Definition of Organization Levels in the Derived Role

Maintaining the remaining authorizations is not required because you are using the inheritance mechanism. Thus, click on the **Copy Data** button, as shown in Figure 6.26. Read the popup window message before continuing. The system automatically maintains the open fields with the same characteristics as predefined in your master role. Finally, generate the role profile, and the derived role is ready for assignment to end users.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Figure 6.26 Copying Authorization Data from the Master Role to the Derived Role

In addition to flexible organizational access differentiation, the SAP inheritance mechanism has another advantage. If you maintain role menu or authorization objects in a master role, you can directly distribute these changes to derived roles. Therefore, you should never change the authorization values in a derived role because those changes are overwritten from the master role through the inheritance concept. In enterprises differentiating among multiple organizational levels, this feature simplifies maintaining roles in the long run since you only need to make the changes once, in the master role. For instance, suppose you want to change an authorization field value, as shown in Figure 6.27 for the activity of the authorization object **F_BKPF_BUK** from asterisk (*) to specified characteristics like **01**, **02**, or **03**.

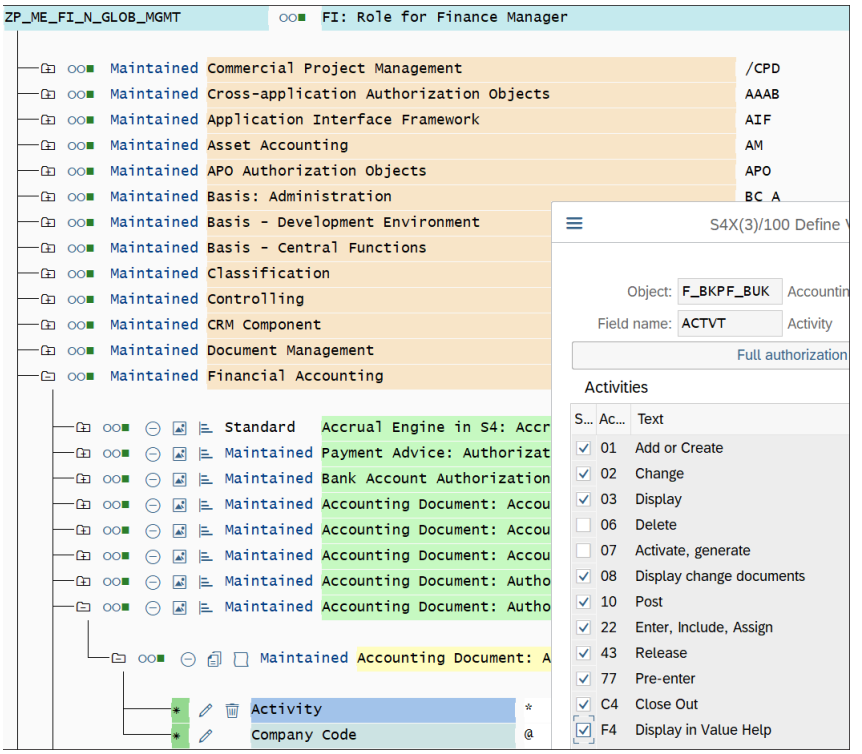


Figure 6.27 Change Authorizations in the Master

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Avoid maintaining asterisks (*) in fields, especially activity fields or similar authorization fields. This extensive authorization value might lead to tremendous unintentional end-user access to data records. An asterisk value only works when you don't have any restrictions, when don't provide risky or sensitive access, and when you would otherwise require huge effort to enter countless maintainable values.

To process these changes into your derived roles, you must adjust the values in the related master role and generate the role profile to save these changes. Click on the **Generate Derived Roles** button in the maintenance area's header bar to directly introduce the changed characteristics into all derived roles, as shown in Figure 6.28. You can also use the option available by navigating to **More • Authorizations**. This action automatically refreshes the role profile, so the updated derived roles are immediately useable for all end users.

Figure 6.28 Generate Derived Roles Button in the Master Role

6.2.5 Customizing Roles

Typically, SAP provides its business software in a consistent delivery state for all its customers. This consistency allows for direct implementation and rudimentary usage of the core functionalities and modules within the software. Suppose you want to adjust this standardized structure or its functions to meet specific enterprise needs. In this case, you must change these settings through SAP system customizing. The central Transaction SPRO (SAP Reference Project Object) enables customizing for individual business divisions and modules. To restrict the usage of extensive system functions, you would go through the project-based SAP customizing features of Transaction SPRO. In this transaction, SAP enables the creation of specific customizing roles. These roles contain only some nodes from the Transaction SPRO tree so as to avoid overauthorization through this critical transaction.

Hint

Before starting the following activities, make sure you clarify who is responsible for SAP customizing activities and whether creating and using the IMG project for customizing roles in Transaction SPRO is allowed.

First, you must define the functional scope of your customizing roles. Launch Transaction SPRO_ADMIN and create an individual customizing project. As shown in Figure 6.29, enter an appropriate name for the project, in our case, **CUST_CO** (for customizing

Personal Copy for Arun Singal, arun.singal560@gmail.com

controlling), and maintain the **Title** field. Next, you must customize the functional extent of your customizing role through the implementation guide (IMG) project. Under the **Scope** tab, click on the **Specify scope...** button to make a manual selection. You can also choose an IMG project scope related to application components and countries, if necessary or desired, as shown in Figure 6.29.

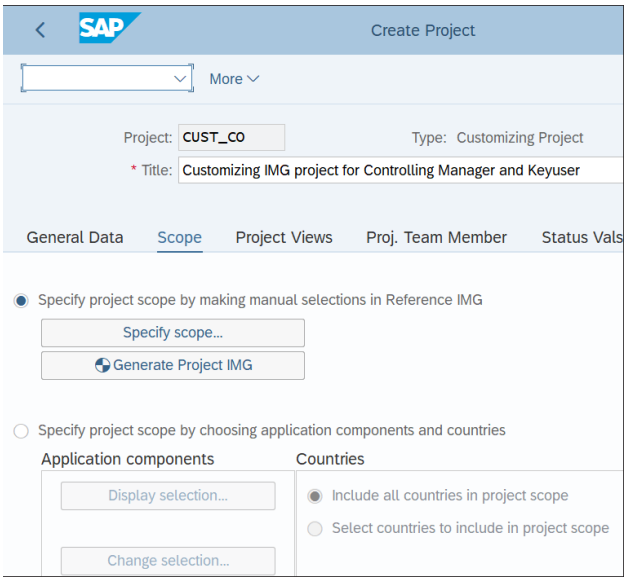


Figure 6.29 Creation of an IMG Project

Concerning the project name, choose the entire node structure **Controlling**, as shown in Figure 6.30.

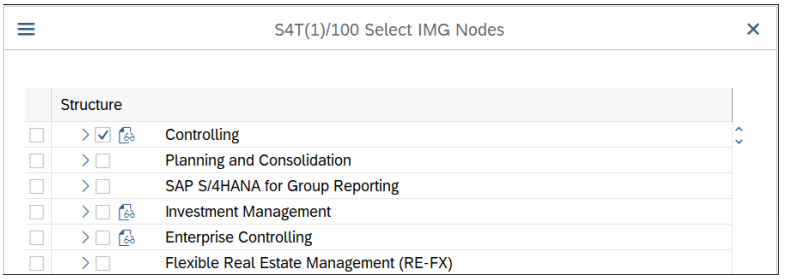


Figure 6.30 Selecting the Controlling Node

This selection directly introduces all menu objects within the node controlling into your IMG project (**CUST_CO**), and the system saves these choices. Then, click on **Generate Project IMG**, as shown earlier in Figure 6.29. This step is similar to maintaining roles and their related profiles. Not only must you save the IMG project; you also must generate it. Finally, you're ready to integrate the IMG project into your customizing role. To

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

specify the access within the IMG project as well, you can create various *project views*. These views, if customized, provide only restricted functions of the entire IMG project. For instance, a restriction to only access the non-critical access views that the **CUST_CO** IMG project contains. You can also customize different node views through manual selections.

After maintaining your settings in Transaction SPRO_ADMIN, you can launch Transaction PFCG to create a new single role. Save this role and, in the header, click the **More • Utilities • Customizing auth**. Then, add your IMG project or IMG project view. The system now adds all menu objects under the system IMG section node controlling and, as shown in Figure 6.31, Transaction SPRO has been added into your role menu.

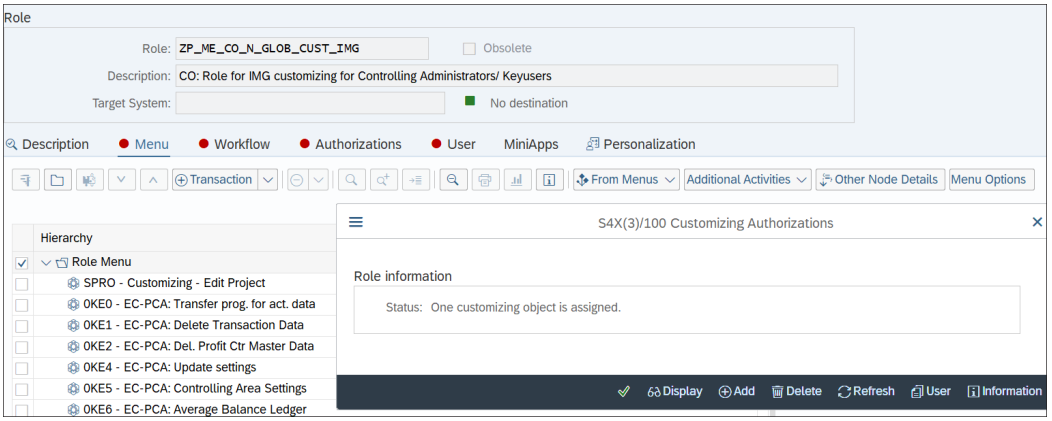


Figure 6.31 Creation of a Customizing Role

The menu tab's message indicates that you've created a customizing role, as shown in Figure 6.32.

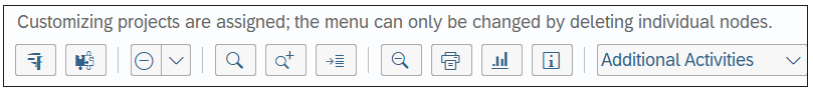


Figure 6.32 An Assigned Customizing Project to a Single Role

The last step is to enter the authorization profile and fill in the required open authorization fields. Finally, generate the role profile and transport the role into the systems where business customizing is required.

Customizing roles enables individual restrictions of the different Transaction SPRO customizing and system functionalities. A best practice is to customize data or system configurations on the DEV and transport these changes to subsequent system layers. You might also need customizing access on the PRD, for instance, to check the current configuration status. Therefore, you should only provide such customizing roles based on Transaction SPRO with display-only authorizations. Unfortunately, the challenge

Personal Copy for Arun Singal, arun.singal560@gmail.com

for this use case is that customizing transactions often provide more than display access. Thus, providing restricted customization access with IMG project roles on PRD can be cumbersome. As a Basis or process administrator, you can change the most basic customizing features on the DEV layer and transport these changes to avoid high-privileged user (HPU) roles on the PRD. You should assign such customizing roles to key users on the DEV, so that they can customize according to their own business needs there and then transport these settings. On PRD, you should strictly follow a display-only authorization assignment for system customizing. Only for hardship cases should it be necessary to provide addition customization options but then still according to the need-to-know principle to avoid unintentional system access. Another good way to simplify your authorization maintenance effort is to use emergency access management (EAM) applications like SAP Access Control to provide critical authorizations to specific end users on PRD for emergencies, with a complete set of workflows, approvals, and granular session activity logs.

6.2.6 Role Templates

SAP also provides an initial role setting with predefined role names, descriptions, and applications. You can easily find these role templates via the initial screen of Transaction PFCG. Enter "SAP*" and check the value input help by pressing F4, as shown in Figure 6.33. Around 4,800 roles are predelivered in the SAP standard for SAP S/4HANA.

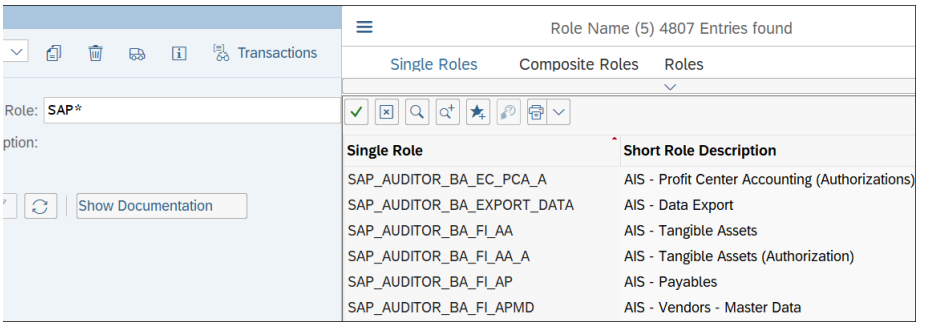


Figure 6.33 SAP Role Template Examples

All predelivered SAP roles start with the **SAP*** namespace prefix. These roles contain predefined applications for various business use cases, modules, or job functions. If you're new to SAP or looking for some hints for specific job functions, you can use these predelivered roles for inspiration. Please note that you must copy these roles into your namespace, according to your role naming convention, since they are overwritten by new SAP role template transports. Furthermore, you must maintain some open authorization field values. Finally, SAP template roles provide a general overview for job function roles and can serve as a quick start alternative to building roles from

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

scratch. Regarding customer-dependent regulations and needs, SAP template roles are limited in their usability; instead, creating your own authorization concept with customed business roles is mandatory. Thus, avoid assigning these predelivered roles in the long term and only use them as a quick start to help build your individual role concept.

6.2.7 Assigning and Removing Roles via Transaction PFCG

Within an SAP system, multiple ways exist for assigning roles to and removing roles from end users. In local systems, you can use three methods; Transaction SU01 for single users and Transaction SU10 for mass user maintenance are the most common options.

The third option is Transaction PFCG. Open the intended end-user role and change the assignments under the **User** tab by entering or removing user IDs, as shown in Figure 6.34. Don't forget to click the **User Comparison** button so all role changes are introduced into the master records of these end users.

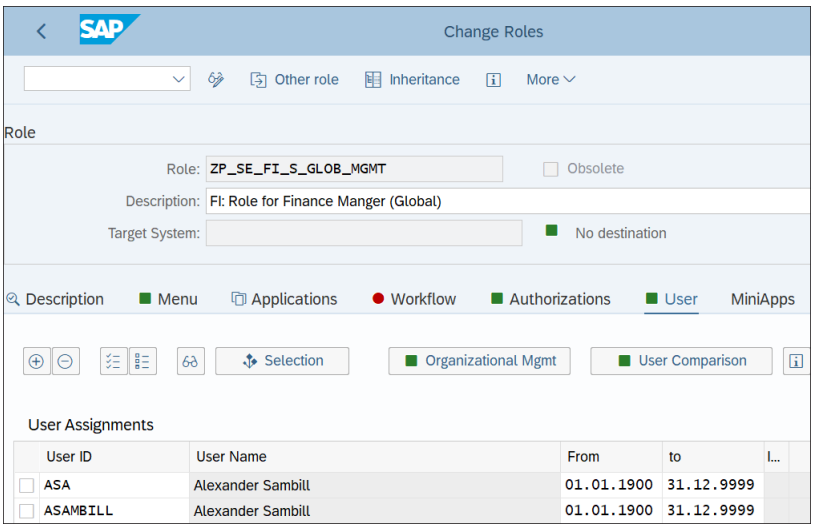


Figure 6.34 Role Assignment to End Users via Transaction PFCG

Tip

You can also use Transaction PFUD to perform mass user comparisons for multiple roles assigned to users. This analysis is also useful for generating selection variants for the program to be included in a background job that periodically updates the role assignments on PRD. See Section 6.8.3 for more details.

Personal Copy for Arun Singal, arun.singal560@gmail.com

6.3 Role Menu Objects

A security administrator needs to deal with various role menu objects, which are shells for related applications. You must cover applications like transactions, OData services, and function modules for end users to access via their role menus by enabling the automatic proposal capability in each role, under the **Authorizations** tab. Otherwise, you cannot achieve a sustainable role concept based on the program's source code.

This section explains the various role menu objects that you can maintain. We'll also provide an introduction to the usage of Transaction SU24 default data variants to enable diverse maintenance opportunities for the same application. You'll also learn how to use the role menu comparison capability to find, cover, and rectify menu object redundancies that may exist between different roles.

6.3.1 Different Maintainable Applications

Role menu objects are technical constructs of applications that you can maintain in roles in order to authorize end users. The whole basis for SAP system usage is based on these objects. Therefore, the correct implementation of the required menu objects to the role menu is necessary.

Hint

For detailed information about the necessity and importance of role menu object maintenance, Section 6.5.

Table 6.2 lists different menu objects you can use with Basis version release 7.54 to maintain your roles.

Role Menu Objects/Application Types	Object Token
Transaction	TR
RFC function module	RF
Report	–
SAP Fiori launchpad catalog	–
SAP Fiori launchpad group	–
SAP Fiori launchpad space	–
SAP Business Warehouse (SAP BW)	–
JCO iView	IVIEW

Table 6.2 Maintainable Application Types in Transaction PFCG

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Role Menu Objects/Application Types	Object Token
People Centric UI Service (CRM)	PC-UI
CRM Web Channel Experience Management Module	WEC
Web Service	WS
SAP Gateway OData V4 Backend Service Group & Assignments	G4BA
HTTP Service	HTTP
IDoc Type	IDOC
SAP Gateway: Service Groups Metadata	IWSG
SAP Gateway Business Suite Enablement	IWSV
Data Source (Delivered Version)	OSOD
Workflow template	PDWS
Application Job Catalog Entry	SAJC
ABAP Push Channel Application	SAPC
SRF Report Category	SRFQ
Assignment: Service → Authorization Object	SUSH
(Business Server Pages) Application	WAPA BSP
Web Dynpro Application Configuration	WDCA
Web Dynpro Application	WDYA
Others (various uncategorized objects)	–

Table 6.2 Maintainable Application Types in Transaction PFCG (Cont.)

6.3.2 Using Transaction SU24 Variants

As described in Chapter 5, the new Transaction SU24 is essential for professional role maintenance. This transaction allows you to maintain and automatically integrate multiple authorization default value sets for a single application in your roles. These predefined collections are called *default data variants*, and they enable you to create different proposal variants for the same application. For Basis release 7.54, you can use these variants to personalize your proposal adjustments according to multiple distinct business needs for one and same application. This enables a more granular authorization maintenance in contrast to the initial SAP deliveries without using manual authorization objects or changing the proposed authorization in the authorization profile.

Personal Copy for Arun Singal, arun.singal560@gmail.com

This approach has a significant positive impact on your subsequent role design and enables you to distinguish your business regulations with more granularity.

For instance, Transaction BP (Business Partner) is an extensive cockpit transaction within SAP Business Suite. Before the introduction of default data variants through Transaction SU24, issues existed with default value customizing. You could only leave the activity (ACTVT) fields empty in Transaction SU24 or provide only one exact proposal combination for all job function roles using the application. Leaving the authorization fields empty leads to significant maintenance effort in each role containing Transaction BP because you always must maintain all open authorization fields according to specific business needs. On the other hand, maintaining a single combination of proposals means that every end user with Transaction BP has the same business authorizations that you defined in Transaction SU24. Therefore, you could not separate the functional extent of Transaction BP for different job function roles. Transaction SU24 default data variants correct this issue in your roles.

Suppose in your use case you must authorize auditors who want to analyze your enterprise. They need display rights but not authorizations to create or change data records. Thus, you require an only-display variant for Transaction BP. First, create a Transaction BP proposal variant for view access, as shown in Chapter 5, Section 53.3 . Next, you must activate the proposal variant in your auditor role by maintaining the initial Transaction BP in the auditor role menu. In this way, the profile generator reveals another maintenance tab, the **Applications** tab. Click this tab and choose your **Display-only variant for transaction BP**, as shown in Figure 6.35. Activate this option with the **Active** checkbox and save the role. You might also need to choose variants for other transactions in the role menu if any customized Transaction SU24 variant exists for them, for example, for Transaction **FS00**. The explicit choice of one default data variant, regardless of whether you choose a standard or custom variant, is necessary. The system will then introduce the relevant proposals into the authorization profiles of these roles. Figure 6.35 shows you such variants and their integration under the **Applications** tab.

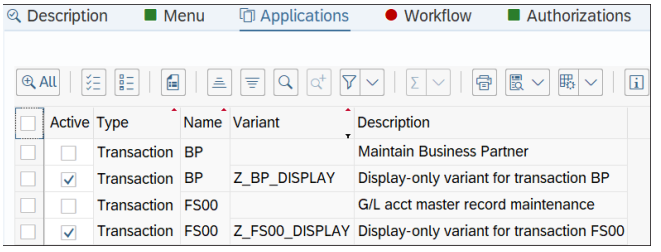


Figure 6.35 Integration of Transaction SU24 Variants in Transaction PFCG

Afterward, enter the authorization profile and maintain the open authorization fields. Also, check whether this role has display-only authorizations. In our example shown in Figure 6.36, the Transaction **BP** variant **Z_BP_DISPLAY** proposes the desired view access in the context of the where-used list of authorizations.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Role ZP_ME_FI_N_GLOB_AUDITOR
Transactions, RFC functions, and services that require authorization object B_BUPA_ADR:

Type of Application	Application	Application Variant	Short Description	Authorization fld	Value
Transaction	BP	Z_BP_DISPLAY	Display-only variant for transaction BP	ACTVT	03
					F4
				SENSTVT	

Figure 6.36 Where-Used List for Default Data Variant Z_BP_DISPLAY

You should use this role maintenance approach, especially for cockpit transactions and applications that provide significant cross-application access or authorizations. This approach enables sophisticated job function role maintenance for the same transaction to achieve a new level of individualization for your role authorizations.

6.3.3 Role Menu Comparison

A role menu comparison is often necessary for checking particular menu object redundancies between various roles. This analysis allows you to compare and adjust role menus in the local system or through RFC connections in a remote system. As a result, you can reduce the number of role menu objects and thus reduce the maintenance effort required for different roles with the same job function. This makes your role concept more efficient and secure.

In Transaction PFCG, click on the **More** button and select then select **Utilities • Role Menu Comparison**. The system forwards you to the initial comparison screen, shown in Figure 6.37.

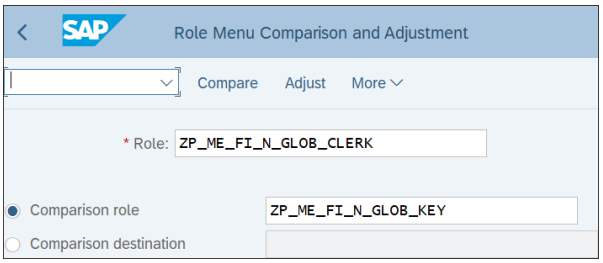


Figure 6.37 Initial Screen of the Role Menu Comparison Report

Enter the base role and the second role you want to compare. You can also choose between local roles or create a comparison through an RFC destination. For instance, this RFC option can be useful to compare a role from DEV against the same role in PRD.

Hint

You can also disable transaction redundancies within one role menu when activating the parameter DELETE_DOUBLE_TCODES in table SSM_CUST.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Choose two roles for the analysis and click the **Compare** button. The report shows the results of the comparison with various color indicators. The red icons indicate a difference among role menu objects, and the green color, the matching role menu objects, as shown in Figure 6.38.

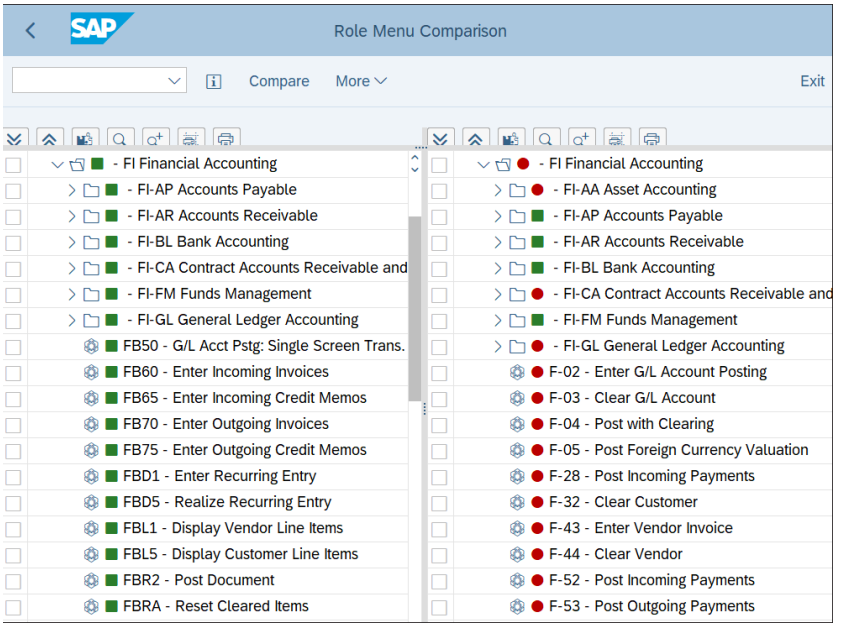


Figure 6.38 Example of Role Menu Comparison

Hint

Note that the report only compares role menu objects, not role authorizations.

6.4 Authorization Maintenance in Roles

Authorization maintenance is the key task of a security administrator. Merely including the desired applications in the role menu for the targeted job function is insufficient for a working role concept. Thus, the basis for the activities described in upcoming sections is role menu administration. With this knowledge, you can start maintaining authorization profiles.

The following section describes all authorization maintenance essentials, including necessary actions, maintenance options, and authorization object statuses. We'll describe the prerequisites for working with authorizations related to the SAP standard and explore a best practice approach.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

This section is an introduction to end-user authorization maintenance activities, providing basic theoretical knowledge. A general guided procedure for best practice role and authorization maintenance is described in Section 6.5.

6.4.1 Authorization Maintenance Buttons

Under the **Authorizations** tab of a single role, you can see who **Created** and **Last Changed** the role as well as who last generated the role profile (**Last Profile Generation**). Two buttons are available for maintaining authorizations (the **Change Authorization Data** button) and for generating the related role profile (the **Expert Mode for Profile Generation** button), shown in Figure 6.39.

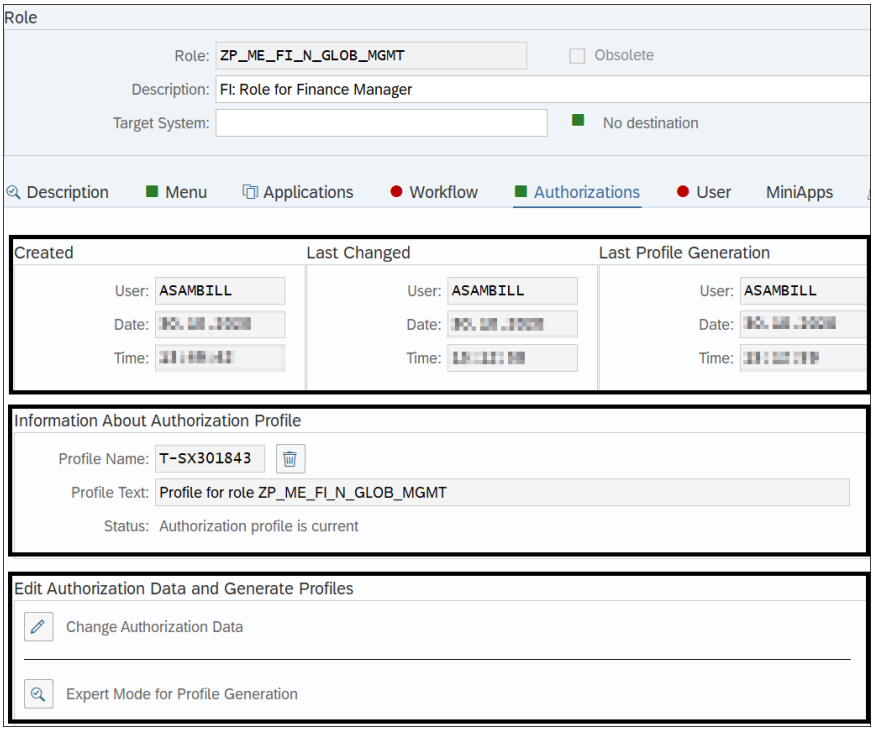


Figure 6.39 Authorizations Tab in Transaction PFCG

Hint

One prerequisite for authorization and role maintenance is a fundamental knowledge of the necessity of and capabilities involved in authorization default values. You should read Chapter 5 before creating or changing roles to avoid mistakes in role administration.

Personal Copy for Arun Singal, arun.singal560@gmail.com

By clicking the **Change Authorization Data** button, you can jump directly into an authorization profile. However, you can choose among three further options to maintain an existing authorization profile, in expert mode, as shown in Figure 6.40.

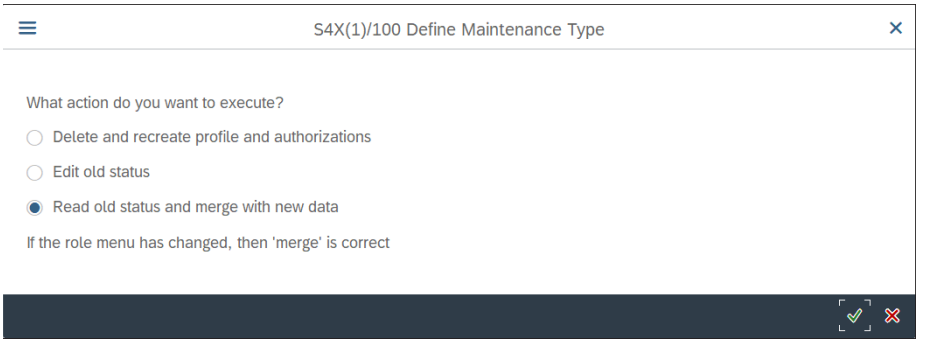


Figure 6.40 Available Maintenance Types in the Profile Generator

Let's look at these three advanced options next:

- **Delete and recreate profile and authorizations**
  This option is for deleting an entire authorization profile. With this option, you'll delete existing authorizations and pull new data from table `USOBT_C` into your authorization profile. Please note that this function does not delete organizational level values or manual authorization objects.
- **Edit old status**
  With this option, you can edit the current authorization status without introducing new or changed Transaction SU24 data. This option is not recommended.
- **Read old status and merge with new data**
  This option is the recommended option for editing the current authorization status because this option checks for new or changed Transaction SU24 data. With this option, the profile generator pulls the authorization default values from table `USOBT_C` and merges them into the authorization profile through this mode.

If you've made any role menu changes, the **Change Authorization Data** button works like the expert mode option **Read old status and merge with new data**. If no changes in the role menu have been made, the button works in the **Edit old status** mode. Thus, the system won't consider the changed or new proposals of Transaction SU24 in existing applications, and thus, you risk not using the latest authorization default values. Thus, a best practice approach for authorization maintenance is to always use the **Read old status and merge with new data** option to keep your authorizations up to date.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Exceptions for not using the third radio button include when you are deleting the whole current authorization profile, maintaining the solution manager roles, creating value roles (for example, for cost center and profit center authorizations), or maintaining third-party tool roles, which do not use authorization default values. Always focus on reworking the Transaction SU24 maintenance of missing default values to achieve sustainable role maintenance.

6.4.2 Authorization Object Statuses

As preparation for sustainable role building and as basic knowledge for your authorization maintenance activities, you must understand the different statuses that authorization objects can have. The content of an authorization profile is based on the role menu objects and the associated Transaction SU24 data by default. If you now edit the profile, you can see different statuses and colored icons. Figure 6.41 shows an example of a mostly unmaintained authorization profile.

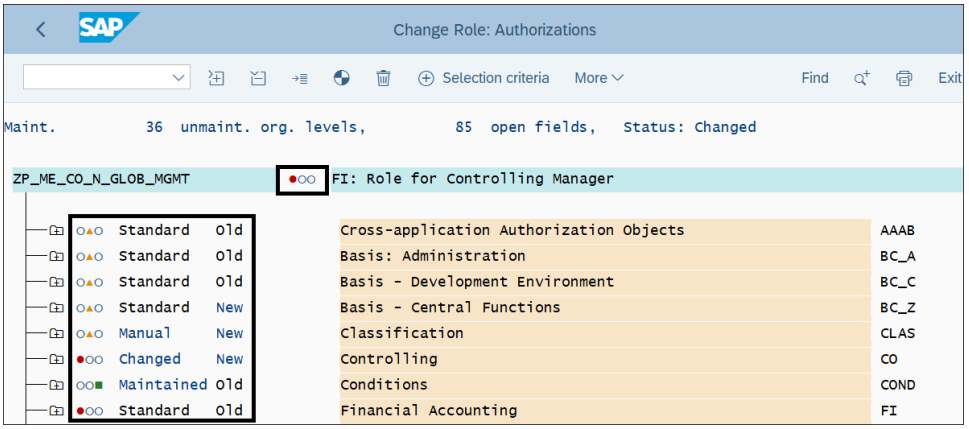


Figure 6.41 Different Authorization Object Statuses in the Authorization Profile

These statuses describe different authorization maintenance-related settings that you must consider while maintaining the desired authorization object characteristics. Thus, you must understand their meanings and their advantages and disadvantages for role building.

The first difference to note are the green, yellow, and red icons, as described in Table 6.3. Please note that the main traffic light icon next to a role name represents the status of the entire role profile. The icons next to each authorization object class indicates the maintenance status of that authorization object, as shown in Figure 6.41.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Colored Icon	Description
Green Square	All authorization field values are maintained.
Yellow Triangle	Open authorization fields exist.
Red Circle	Unmaintained organizational levels exist.

Table 6.3 Authorization Objects Maintenance Status Icons

Your objective for maintaining authorization characteristics is to maintain all open fields with the necessary values to achieve a green light icon or otherwise inactivate these fields if not required. After completing your authorization maintenance activities, you won't see any popup warnings about empty fields when generating your role profile. Assigned users can now functionally work with the targeted applications through the role.

The maintenance status flags are shown next to the descriptions of the authorization objects. Various flags might occur through these status texts, as shown in Figure 6.41. The following list describes some possible flags and their intended messages:

- **Status Standard**
  This status reveals that your role uses the proposal data maintained in Transaction SU24. In this status, the authorization object only contains proposals from table USOBT_C. Except for organizational levels, you won't need to maintain anything further. For instance, through Transaction FBO3, the system pulls many different authorization objects, like **F_BKPF_BUK**, into the authorization profile. Suppose you now update this proposal object for Transaction FBO3 in Transaction SU24 and merge this change into your role. Now, the profile generator will automatically adjust the value with the flag **Updated**. Figure 6.42 shows the same authorization object instance (**T-SX30185200**), but the second instance is newly updated, with additional display values.

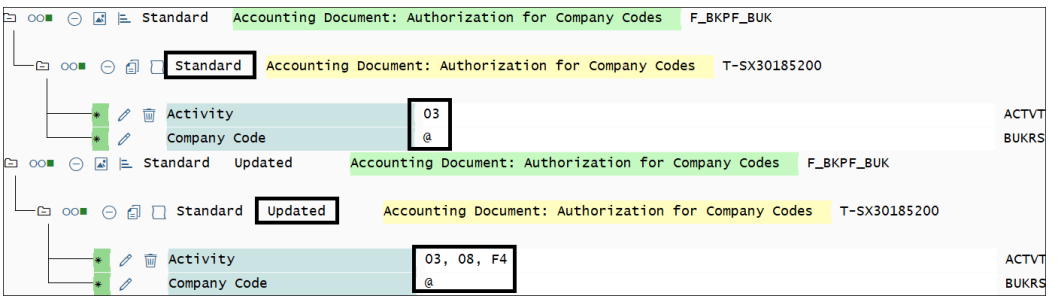


Figure 6.42 Example of an Updated Standard Authorization Object Proposal

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Status Maintained**
  An authorization object turns to the status **Maintained** if the proposal values in Transaction SU24 contain at least one empty authorization field in addition to the organizational level that you maintained in the authorization profile, as in the where-used list shown in Figure 6.43. Open authorization field values are common and also considered the best practice when a single proposal value is not appropriate for all roles that contain the same application. This option enables individualization in defining missing values during role maintenance.

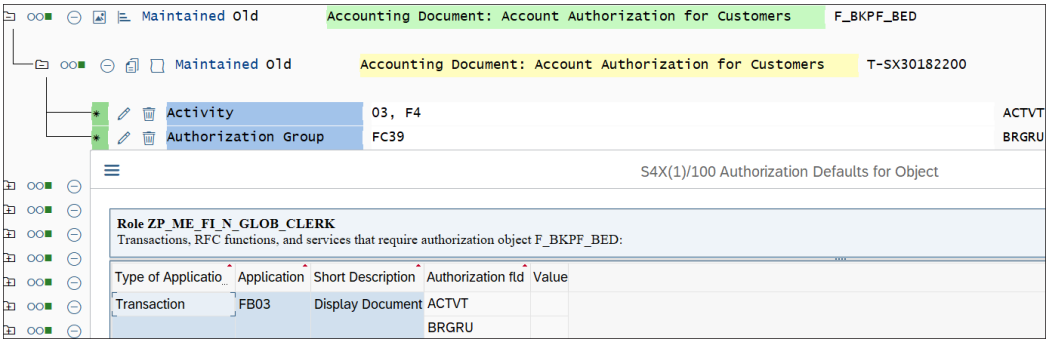


Figure 6.43 Example of a Maintained Authorization Object with the Where-Used List

- **Status Changed**
  The authorization status is **Changed** if you change a standard proposal value introduced from table USOBT_C or if you individually maintain the organizational fields in the authorization object instead of using the central **Organizational Levels Maintenance** button, as shown in Figure 6.44 Changing the proposed standard authorizations directly in the authorization profile is not recommended since it levers out the predefined proposal values. You must not change any default values in the authorization profile, which would cause conflicts during upgrades and reduce role maintainability and security.

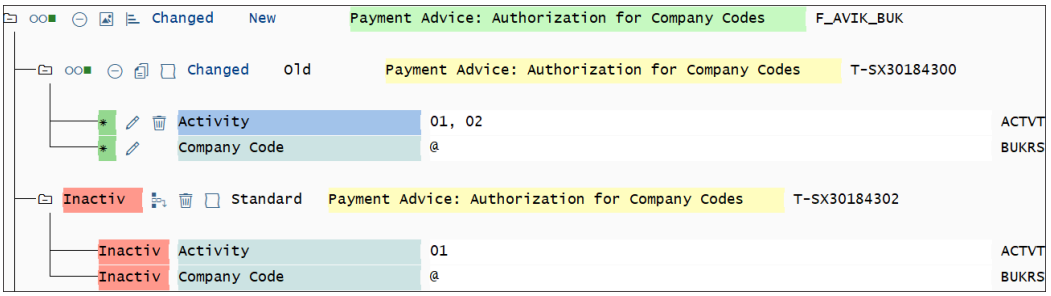


Figure 6.44 Example of a Changed Authorization Object

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

With Basis version release 7.50, the profile generator automatically inactivates an authorization object if you change its related proposal in the authorization profile. Furthermore, the system offers the changed object as an new active object instance, as shown in Figure 6.44. Do not delete those inactive standard authorization objects in the role.

You still can use the where-used list to see the correct information about the relationship between the authorization and menu objects. Before this release (Basis version release 7.50), if you used the **Read old status and merge with new data** functionality of Transaction PFCG's expert mode, the changed authorization object would be reintroduced to the role as a default from Transaction SU24. This leads to the additional update status "New" next to the changed status. These authorization objects remain in the authorization profile as orphans with no where-used list visibility, so they are difficult to clean up.

- **Status Manually**

  You can manually add authorization objects into your authorization profile through the **Manually** button of the header bar, shown in Figure 6.45. Such authorizations are not proposed through any role menu object and are instead manually integrated into the authorization profile. This option is not recommended, and you should use manual authorization objects only in rare exceptions and restrictive ways. Manually integrated authorization objects are the worst-case scenario since no link back to a transaction or other object exists, based on the role menu. Thus, the automatic profile merge mechanism of applying proposals into an authorization profile cannot work in a manual object. Thus, you also cannot use the where-used list to see the relationship between existing authorizations and applications. In addition, manually inserted authorizations mostly result in unmanageable and orphaned authorization profiles. As the name suggests, manual authorization objects are detached from any technical application connection and exact requirements. SAP recommends avoiding manual authorization objects, and you should use them only for special use cases like for value roles or SAP Solution Manager authorizations. However, before using manual authorizations, you should consider updating Transaction SU24 to propose the intended authorizations.

Hint

A best practice with manual authorizations is to capture the necessity of the authorization object in its text in the authorization profile. By double-clicking on an object's short text, you can add information like "- required for restricted archive actions in FI."

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

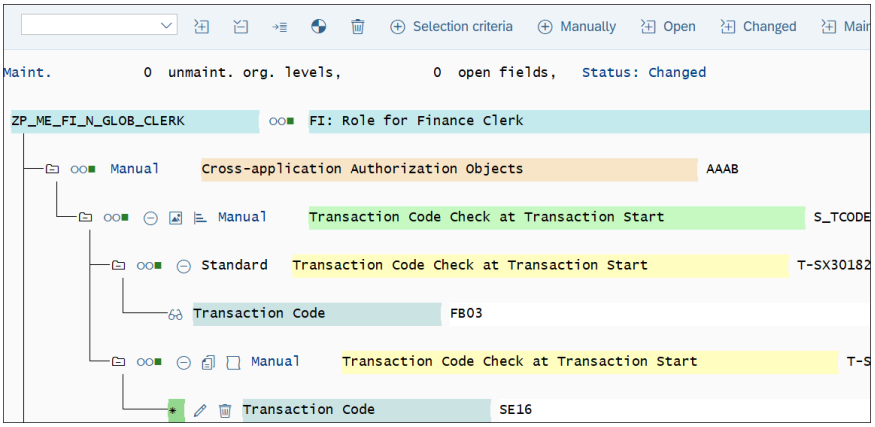


Figure 6.45 Example of a Manually Introduced Authorization Object

According to your needs, a best practice approach is to maintain open authorizations and use authorization default values. This approach is only possible if you add the desired application through the role menu. Then, you can use the **Standard** and **Maintained** statuses to achieve sustainable roles. Using these standard authorizations can simplify the role maintenance processes and also reduce risk during an upgrade because you can automatically introduce new authorization objects, fields, and values into your roles through Transaction SU24 or role menu maintenance. Avoid using the **Changed** or **Manually** statuses for your authorization objects, which interrupts automatic proposals according to your maintained applications in the role, as shown earlier in Figure 6.41. Even though changed authorization objects still appear in the where-used list, using the standardized proposals is more automatic, which is also more sustainable.

In a nutshell, manual authorizations might negatively impact your role concept because of the following disadvantages:

- You cannot benefit from the advantages that come with using Transaction SU24 proposals.
- You are not working entirely with the SAP standard.
- You will lack information about the necessity of your maintained manual authorizations.
- You can only assume why possible critical or segregation of duties (SoD)-relevant authorization objects are maintained.

6.4.3 Authorization Object Update Status Texts

Depending on your Transaction SU24 maintenance and how you've updated roles (for instance, through the **Read old status and merge with new data** functionality in the profile generator), you might see different authorization object update statuses. Possible

Personal Copy for Arun Singal, arun.singal560@gmail.com

statuses could be **Old**, **New**, or **Updated**. Table 6.4 lists the different statuses and provides their meanings.

Statuses	Short Description
Old	The authorization already exists in the current role profile, and no new proposals are introduced through an update of the role profile.
Updated	The authorization object already exists in the current role profile, but new proposal values are introduced by updating the role profile (see SAP Note 871787).
New	The authorization object is newly introduced into the role profile through new role menu objects or updated proposals in Transaction SU24.

Table 6.4 Authorization Objects Update Status Texts

Hint

You might encounter the phenomenon where the update status **Maintained New** for particular authorization objects does not change to **Maintained Old** after role profile generation. In this case, you've run into a proposed standard mechanism. On investigation, you'll find that you have two authorization instances (**Maintained New** and **Maintained Old**) for the same authorization object for the same application. This duplication happens because the **Maintained New** authorization object has the same authorization field as the **Maintained Old** instance, but often, its value has been changed from an empty field to a maintained field that differs in at least one authorization value. Thus, the SAP system does not know whether the administrator would prefer to keep the old "maintained" values or accept the new "standard" one. Thus, the system retains the status as **New** despite merging these values to flag that you need to decide how to deal with these overlapping values in each example to separately align to your business processes.

In this way, SAP wants to make a role administrator aware that a decision is required whether the **Maintained Old** authorization object and its values are still necessary or not. Afterward, you can delete the old instance manually if required.

For more detailed information, refer to the following SAP Notes:

- SAP Note 113290 - PFCG: Merge process for authorization data maintenance
- SAP Note 766483 - PFCG: Merging and combining authorizations (2)

6.4.4 Maintenance of Organizational Levels

Maintaining organization level values is essential for meeting any enterprise structure-related restrictions. Most business transaction proposals provide specific organizational fields as placeholders (like `$BUKRS` for company code) based on the `AUTHORITY-CHECK` statements within the program code. Therefore, you only need to maintain

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

specific values for the organization levels like company code, purchasing group, sales organization, or plant in a role's authorization profile to enable administrative access through the related application. Remember that you must handle organization levels differently from other authorization fields. Typically, an organization level field like $BUKRS is used in various authorization objects within the same role. Thus, the organization level value is valid for the whole role and equal for each relevant authorization object that contains it. To verify this mechanism, click on the **Organizational Levels** button in the header bar of the authorizations profile, as shown in Figure 6.46. You'll see visual notification that unmaintained organization levels exist in your role via the red circle icon next to a role's name. If you see this icon, click on **Organizational levels...** and maintain the values as required. Once you centrally maintain all organizational values in this way, each authorization object that contains this authorization field will receive a value proposed from this central maintenance activity.

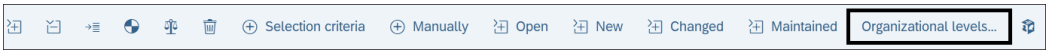


Figure 6.46 Organizational Levels Button in the Authorization Profile

Never maintain different organization levels separately in an authorization object; instead, use the central maintenance button. Directly changing the proposals can negatively impact your role administration effort, especially when using a role inheritance concept, and can provoke audit issues. Once you change an organization level authorization field in the related authorization object directly, you can no longer maintain it through the default **Organizational levels...** maintenance function. Since Basis version release 7.50, the system deactivates the standard maintained authorization object and creates the changed authorization object. In this way, the system ignores the maintained values in central maintenance for this authorization object. Also, this manual maintenance overwrites the organizational values of derived roles when manually maintained in the master role. Thus, each manual organization level overrides the centrally maintained values and best practices. SAP shows its recommendations for central maintenance through an informational popup window when you manually change an organizational field in the related authorization object as well, as shown in Figure 6.47.

Hint

If you manually maintained your organizational levels, you should revert the affected roles to the default. However, the system still won't introduce the values from central maintenance for the specific authorization objects. Therefore, you must run report AGR_RESET_ORG_LEVELS via Transaction SA38, which resets manually maintained authorization fields and triggers the system to use the centrally maintained organization level values again. Then, you can maintain the values centrally.

Personal Copy for Arun Singal, arun.singal560@gmail.com

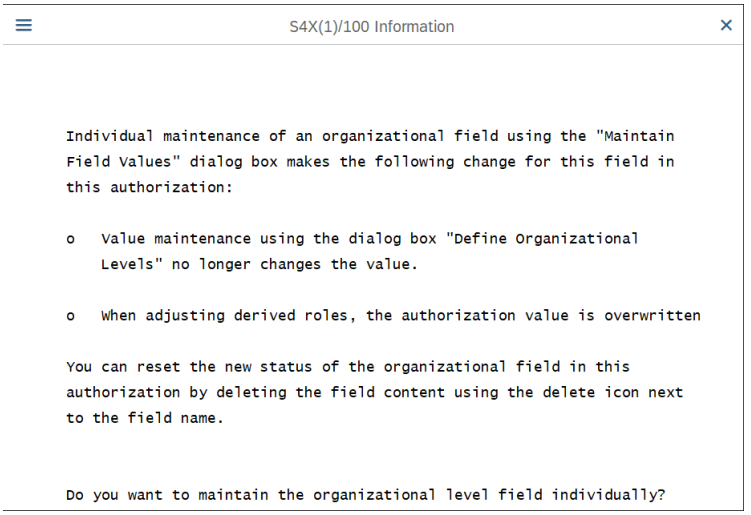


Figure 6.47 Information Popup Window from Individual Organization Level Maintenance

The following example shows you the best practice and SAP standard organization level maintenance approach. Suppose you've maintained various financial transactions in the role menu that provide different proposals. You initially have an empty authorization fields for the company code (**BUKRS**) to enable organizational access, as shown in Figure 6.48. The red icon indicates an unmaintained organization level.

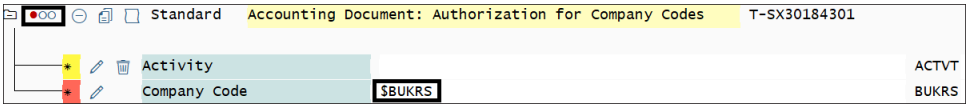


Figure 6.48 Unmaintained Organization-Level Company Code (BUKRS)

In this case, the business requirement is that company code value **1000** provide access to this organizational structure. You maintain this value in the **organizational levels** maintenance area with the required value, as shown in Figure 6.49.

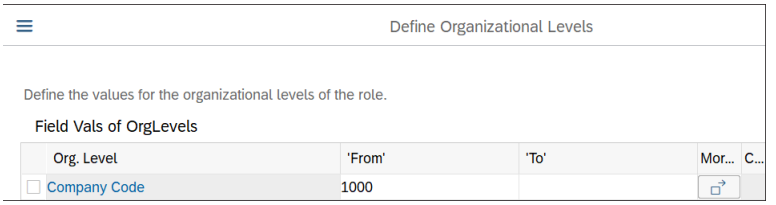


Figure 6.49 Organization-Level Company Code Maintenance with Value 1000

Now, each authorization object in the role containing the authorization field **BUKRS** will obtain the value **1000**. You've thus enabled both protection and usage of your organizational structure so that the end users can use all applications, but their functions

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

are restricted to a predefined company code. Figure 6.50 shows you the result in central maintenance, with the **Maintained** status (green icon) for our example authorization object and instance (**T-SX30184301**).

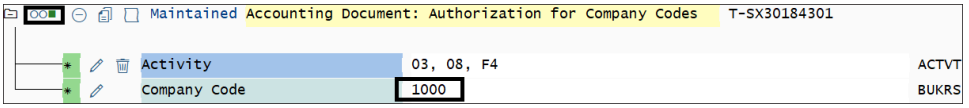


Figure 6.50 Maintained Organization-Level Company Code (BUKRS)

One of the main advantages of organization levels is the central maintenance functionality enabled for an entire role, leading to less role administration effort. Another advantage is that you can build various roles based on organizational restrictions and follow the derivation concept.

6.4.5 Where-Used Lists

The where-used list within an authorization profile is an essential feature for maintaining your roles sustainably. You'll find these lists for each authorization object based on the maintained applications in the role menu. The where-used list is directly correlated to Transaction SU24 proposal data, and therefore, you can see which transaction or menu object proposes those authorization objects, fields, and values, as shown in Figure 6.51. Accordingly, if you change the default values, you'll also see changed where-used list data.

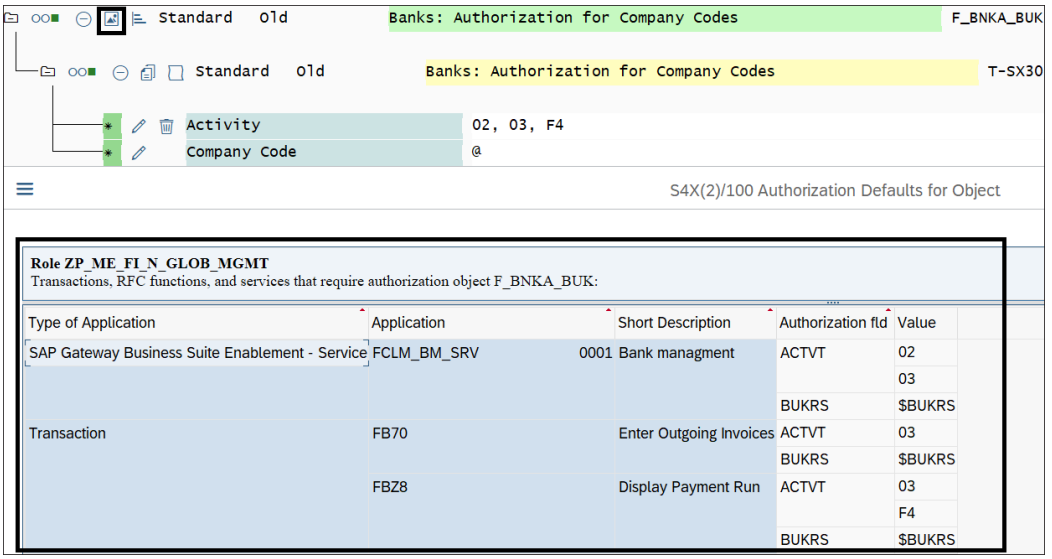


Figure 6.51 Where-Used List for Authorization Object F_BNKA_BUK

Personal Copy for Arun Singal, arun.singal560@gmail.com

Always include where-used lists into your considerations when trying to maintain open authorization fields. This tool can help you enter the appropriate values according to an application's purpose and for risk remediation if no specific business demands exist.

For instance, suppose you have an open authorization object field and don't know which activity value (**ACTVT**) you should enter into this field. Check the application behind the target authorization object. Suppose you have display transactions (e.g., in the **Short Description** column, the word **Display** appears). These transactions typically require activity levels (**ACTVT**) **03**, **08**, and **F4**, as shown in Figure 6.51. Thus, you should only maintain these values instead of providing change (02) or create (01) values. Clearly, the display application should only provide view features and thus does not require any other activity values. Consider customizing these applications in Transaction SU24 to enable the proposed display access automatically and thus reduce your maintenance efforts.

6.4.6 Authorization Templates and Other Authorization Insert Options

Authorization templates are manually configured default combinations of authorization objects, fields, and values to provide predefined authorizations for roles and job functions. SAP allocates many values by default. For instance, you can choose between different authorization templates for job functions, for business intelligence (BI/SAP BW), for SAP Solution Manager, or for SAP Application Interface Framework. These templates are based on manual authorization objects and might provide extensive system access without any application correlation. If you initially create a role without using the role menu, you can move to the authorization profile and choose a proposed authorization template. Another option is to insert such authorizations in an existing role by selecting **More** • **Edit** • **Insert authorization(s)** • **From template...**, as shown in Figure 6.52.

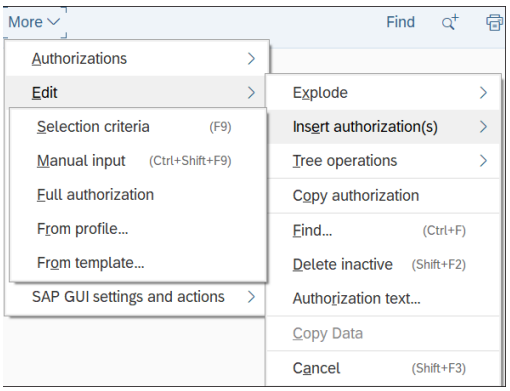


Figure 6.52 Insert Authorization(s) Options in Transaction PFCG

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

This section also enables integration options like inserting specific manual authorization objects (via the **Manual input** option), full authorizations (via the **Full authorization** option), or manual profile authorizations (via the **From profile...** option).

Using such authorization templates, however, is neither practical nor sustainable according to best practices because manual authorizations lack reference to any application, and general templates often don't fit the custom business needs entirely.

You can use authorization default templates or maintain your own company-related default templates for particular use cases like SAP Solution Manager or SAP BW authorizations. Their usage might be helpful because SAP delivers the required authorizations, but as manual authorization objects in roles. To maintain these authorizations, launch Transaction SU24 and click the **Authorization Templates** button in the header bar. Then, you can pick an existing template to maintain, copy, or you can delete this template or create your own, as shown in Figure 6.53.

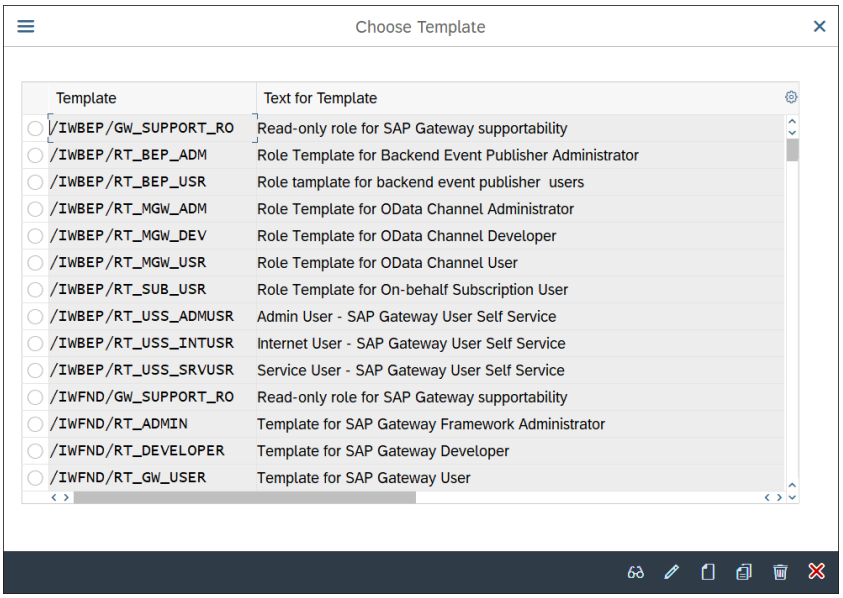


Figure 6.53 Authorization Templates Selection in Transaction SU24

However, you should avoid setting up manual authorizations in typical job function roles, which can negatively impact your role administration, a role's upgradeability, and security assurance, and does not fit best practices in authorization maintenance.

6.4.7 Import of Traces to Roles

Tracing authorizations is an essential part of any security administrator's day-to-day work to find required authorizations for end user roles. For this task, Transaction PFCG provides the direct usage of two trace functionalities. You can use them for the import

Personal Copy for Arun Singal, arun.singal560@gmail.com

of role menu objects and authorization objects with their field values. These options are strictly system-related, and you should combine the trace results with the business unit demands and feedback.

For instance, you can use these trace integration options to build individual job function roles based on previous key user actions. To do this, first, activate the intended trace function like the system trace via Transaction STAUTHTRACE in the quality system (QAS). Afterward, the appropriate end user must execute the necessary job function actions and tasks in the QAS. Based on this business simulation, the system collects the trace data, and you can create or maintain the end-user role with the required business authorizations.

Hint

If you're not familiar with the various trace methods, refer to Chapter 7 first.

Finally, launch Transaction PFCG and create or maintain a single role. Within the **Menu** tab of a role, select **From Menus** and **Import from Traces**, as shown in Figure 6.54. Whether you choose the trace source STUSOBTRACE, STAUTHTRACE, STRFCTRACE, or STUSERTRACE depends on what you used for the key user trace.

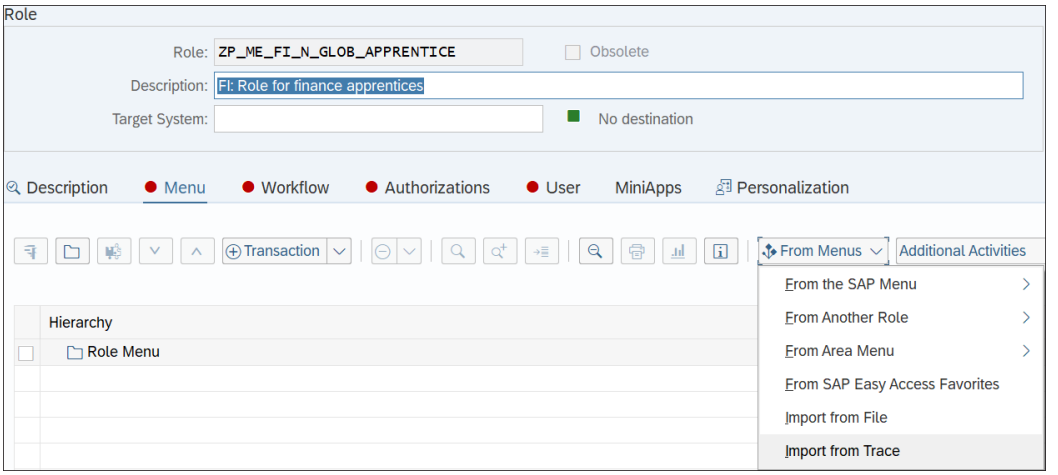


Figure 6.54 Menu Objects Import from Traces in Transaction PFCG

Evaluate the data from your chosen trace method and transfer the result list into your role menu section. Please note that you should only import the applications into the role menu that are approved by the involved business unit, as shown in Figure 6.55. This menu object import process depends strictly on the department areas' regulations and conducted test activities and thus, you should always consult with your business units to verify their demands.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

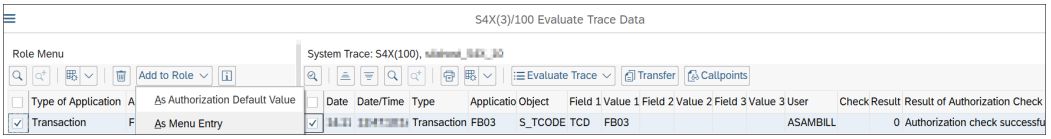


Figure 6.55 Role Menu Creation through Trace Data

After completing the menu entry transfer, save the role, and move into the authorization profile. Unlike using Transaction SU53 to manually check for missing end-user authorizations, you can also define the open authorization fields based on trace data of previous user actions. In this way, you can fill in open or missing authorization values based on actual usage. This function can be accessed via the header bar of the authorization profile, as shown in Figure 6.56.

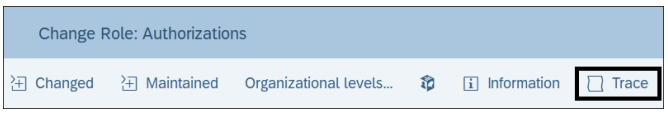


Figure 6.56 Trace Option in the Authorization Profile of Transaction PFCG

Again, initially load the trace data in your result list through **Evaluate Trace**. While you verify the data, avoid transferring all results. Only transfer the data that correlates to the previously introduced role menu objects and business requirements. In this case, from the **Filter for Applications** dropdown list, you would select **Applications in Menu** to enable this feature. To cover authorization issues for existing roles with this method, select the **Trace for errors only** checkbox, shown in Figure 6.57.

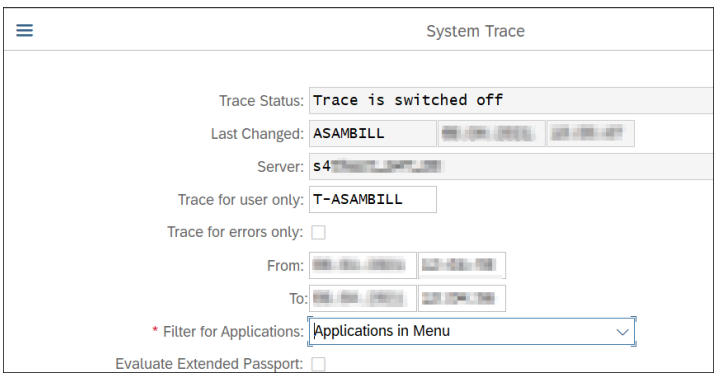


Figure 6.57 System Trace Filter Options

After your selection, continue with all existing **Authorization Objects** and check their trace results, as shown in Figure 6.58. Note that you cannot maintain organization levels by using this method. Integrate other authorizations if required and generate the role profile. You've now completed the role creation process for a specific job function task based on trace data.

Personal Copy for Arun Singal, arun.singal560@gmail.com

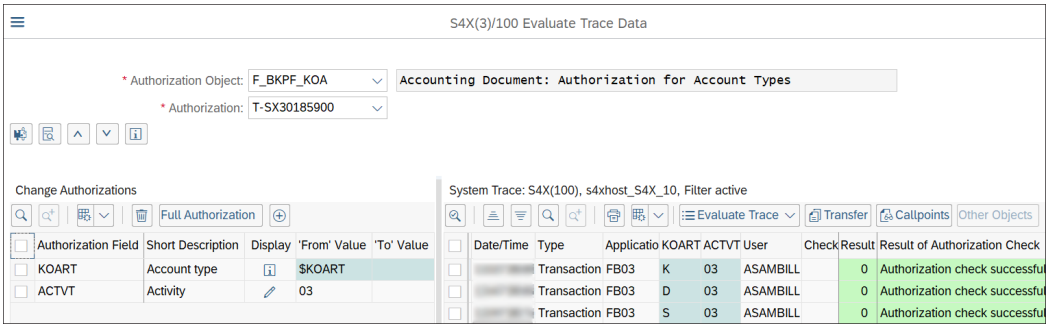


Figure 6.58 Authorization Maintenance Through Trace Data

Hint

Another smart method for leveraging trace data for end-user job function role authorizations is the Productive Test Simulation (PTS) feature with XAMS. You'll no longer need specific testers on QAS because you can trace data from the real business processes in PRD without interrupting businesses processes. See Chapter 4, Section 4.5, and Chapter 13, Section 13.5, for further information.

6.5 Sustainable Role Building

Sustainable role building describes creating an individual role concept for your enterprise according to the SAP standard and best practices for authorization maintenance. The goal is to create maintainable, secure, and program code-based roles. Besides functional and business-related objectives, another goal of sustainable roles is their upgradeability with new system or add-on release updates. If you're using the SAP standard mechanism for your role and authorization maintenance, especially when combined with best practice role concept approaches, you're well on track for an audit- and standard-compliant authorization concept.

The following section outlines some best practices and helpful presettings for authorization maintenance. Moreover, we'll describe the fundamental actions you must consider and fulfill during your role creation and maintenance activities.

Hint

Chapter 3 provides detailed information about the various conceptual approaches and role types.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

6.5.1 Best Practice Presettings for Role Maintenance

Before creating or maintaining a role and its authorization profile, you should enable some profile generator settings. These useful settings can simplify your work and provide some additional maintenance views and options.

Besides the typical authorization maintenance tree structure, you can also use the ABAP List Viewer (ALV) grid for authorization maintenance since Basis version release 7.31. Your choice depends on your personal preferences. To enable the new view, move into an authorization profile in Transaction PFCG. Select **More • Utilities • Settings...**, as shown in Figure 6.59, and select the **Use ALV Tree (Call Authorization Maintenance Again)** checkbox in the **Display** section.

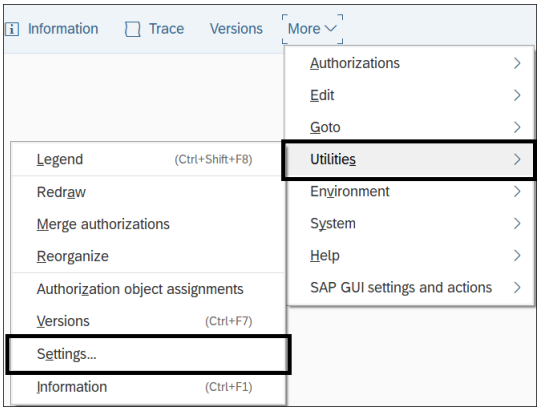


Figure 6.59 Utilities in Transaction PFCG

Hint

See SAP Note 2086293 for more details about the ALV authorization maintenance grid.

In the **Other settings** section, shown in Figure 6.60, some other essential options should be activated. First, select the **Show Technical Names** and **Activate Confirmation Prompts** checkboxes, which displays the technical names of the authorizations and results in system prompts for confirmation of several maintenance actions, for example, to confirm an adjustment. These settings improve your maintenance view and the actions you can perform. Furthermore, another useful setting is to select all the checkboxes in the **Icons in Tree Structure** section to enable buttons for copy, merge, and delete authorizations and to enable the where-used list, as shown in Figure 6.60.

Additionally, in Transaction PFCG, under the **Menu** tab for the role, switch on the role menu's technical application names. Also, activate the **Menu: Do not insert existing entries.** option in the user's setting through **More • Utilities** in the profile generator. This setting prevents application redundancies in the role menu.

Personal Copy for Arun Singal, arun.singal560@gmail.com

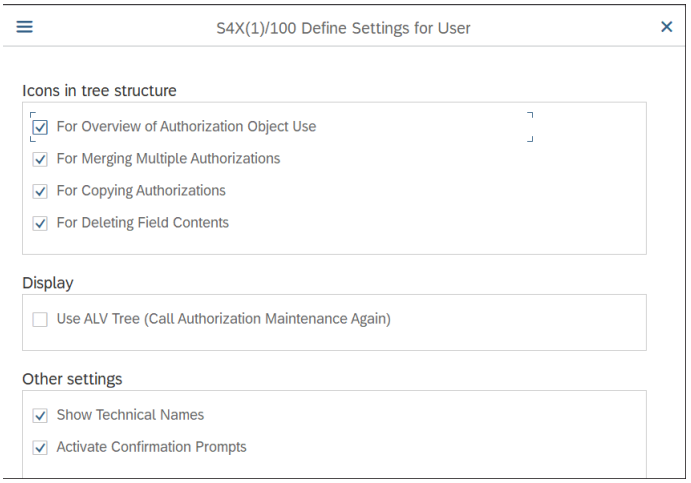


Figure 6.60 Authorization Maintenance Settings in Transaction PFCG

6.5.2 Best Practice Role and Authorization Maintenance

In the following section, we'll describe some best practices in role building using, as a guideline and an example, a controlling clerk role to explore comprehensive insights about sustainable role building and authorization maintenance.

First, determine the role name according to your company's naming convention. Create the role and enter a short description. Move to the role **menu** and add all required applications as role menu objects. You should create a logical menu structure to enable a consistent user menu for all end users, as shown in Figure 6.61. This application integration is essential so that the system can verify the introduced applications and, based on these applications, pull the required authorization default values from table `USOBT_C` into the authorization profile of the intended role.

Hint

Suppose you change the role menu by deleting or inserting some transactions. In this case, the Transaction SU24 default data mechanism directly impacts the authorization profile because it changes the authorizations as well. Thus, you must maintain and regenerate the role profile. A role menu change always affects your role's authorizations if proposals exist for this application.

Comprehensive knowledge about authorization default values and their usage is a prerequisite for sustainable and secure role maintenance. Thus, be sure you read Chapter 5 closely if you're unfamiliar with this topic.

Finally, enter the authorization profile by clicking the **Expert Mode for Profile Generation** button and select the **Read old status and merge with new data** radio button, as shown in Figure 6.62.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

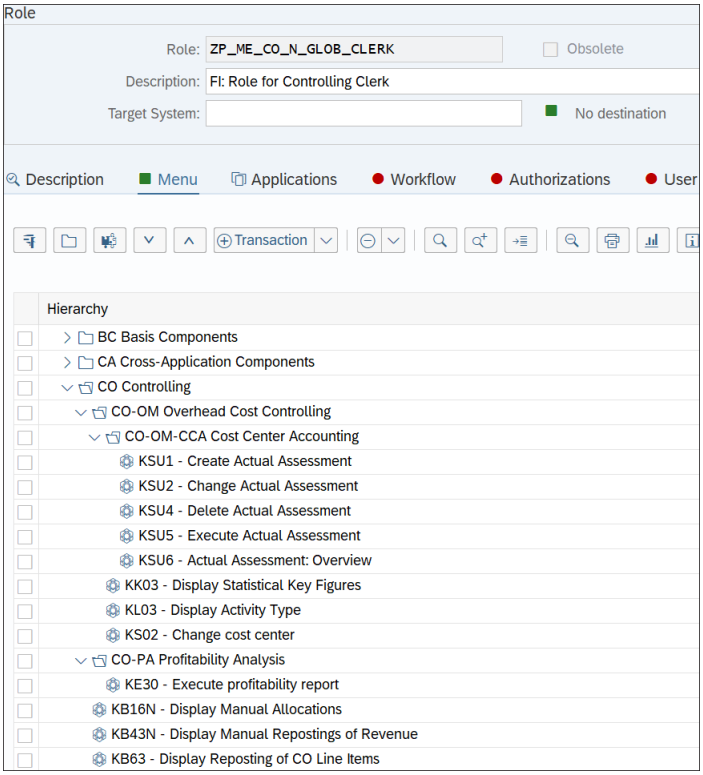


Figure 6.61 Maintained Role Menu in Transaction PFCG

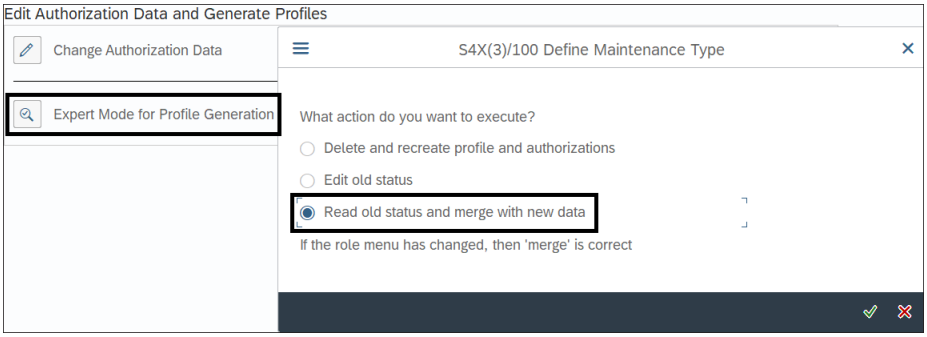


Figure 6.62 Expert Mode Options in Transaction PFCG

In most cases, when you're using the role menu and you initially enter the role's authorization profile, you'll see a popup window for central organizational field maintenance. Enter the relevant values to provide organizational access if this role is a direct end-user role. Suppose you're using an inheritance approach and maintaining a master role. In this case, you should leave the organization level fields empty or, better still, enter a special character like "@" in every **From** row, which functions as a dummy value. Avoid using ranges within organizational restrictions. Over time, doing so might

Personal Copy for Arun Singal, arun.singal560@gmail.com

result in overauthorizations through new value definitions, like new subsidiaries, which are then included in this range as well. Strictly avoid maintaining organization levels separately in each related authorization object. Save your organizational settings, and the role status icon will switch from red to yellow. This new color indicates that the organizational levels are maintained, but open authorization fields still exist.

Hint

Details about the usage of special characters within master roles was described earlier in Section 6.2.4. For deeper considerations about the inheritance approach, refer to Chapter 3.

At this point, start the initial authorization maintenance for all open authorization fields for the roles' intended for business demands and technical requirements. You'll see the authorization profile's total number of **open fields** in the header bar. This number indicates your scope of work. Click on a role name and expand the open authorization fields, as shown in Figure 6.63.

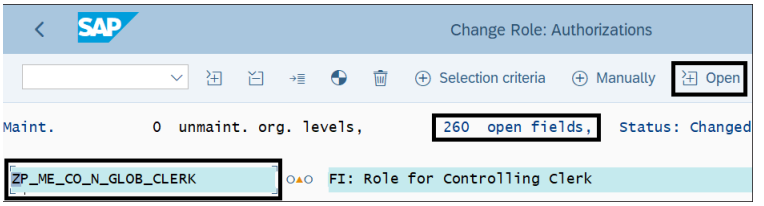


Figure 6.63 Open Authorization Fields in the Authorization Profile

Move from one authorization object with a yellow status icon to another or press PgUp and PgDown to navigate through this list. The same authorization object can exist several times in an authorization profile, with different characteristics or open fields. These different value combinations, called *authorization instances*, depict an independent authorization to another instance of the same authorization object. According to the job-related functions and access you want to provide to the end user, you should maintain the open authorization fields for each instance separately. You can inactivate an entire authorization object or instance if not relevant to the job function. Another helpful step is to click on the where-used list to check the source for the existing authorization fields and values. Figure 6.64 shows such a list. Please note that this list is only available when Transaction SU24 proposals are maintained and when you insert the applications via the role menu. A best practice is maintaining authorization field values according to the role's job function and the provided value help. Combined with the where-used list and your business requirements, you should be able to determine specific values. If you're unsure which authorization value is required or you lack business unit specifications, enter a special character or inactivate the authorization object instance. Finally, you can validate the correct values during role testing.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

You should avoid intervals in your authorization values as well for the same reason as you should avoid organizational values. You cannot provide generic functions or generic access through newly introduced values that you cannot observe when using ranges.

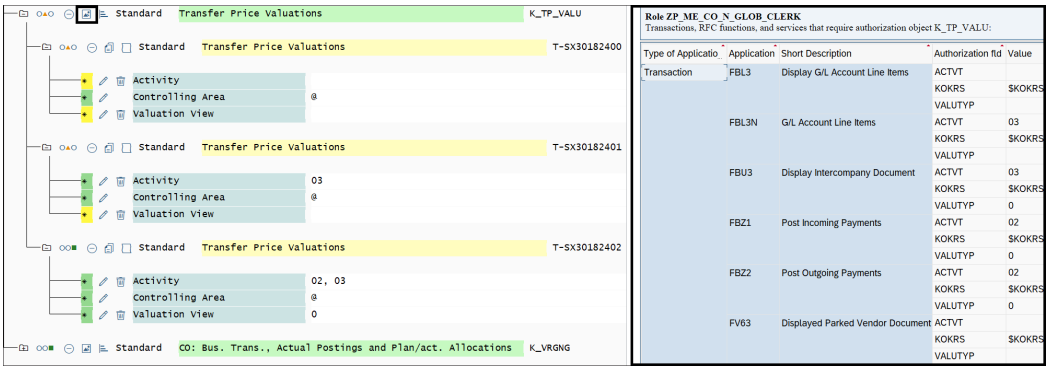


Figure 6.64 Where-Used List in the Authorization Profile

When you consider an authorization default value to be wrong or unsuitable for your business, you should update Transaction SU24 for the relevant application. This maintenance brings updated proposals into the authorization profile if you merge them in expert mode. Especially for cockpit transactions like Transactions MIGO or BP, you should leave authorization fields like **activity** open in Transaction SU24. Thus, you can maintain authorization values differently and according to job function. The new alternative for Basis version release 7.54 is to create default data variants via Transaction SU24. Also, be careful when maintaining Transaction SU24 proposals for SAP standard transactions because changes to the SAP-defined authorizations will occur and increase your required Transaction SU25 upgrade effort.

You can also copy blank authorization object instances to achieve various maintenance tasks for the same authorization object. Click on the icon, shown in Figure 6.65. Copied authorization instances (in our example, **T-SX30182402** or **T-SX30182403**) have higher instance counters than their source instance (in this case, **T-SX30182401**). Please note that you cannot inactivate these instances, only delete them.

When you maintain authorization profiles, make sure you avoid using manual authorization objects, because otherwise, you do not have any references between the application and its required authorization defaults. Once you start maintaining manual authorizations to suit business demands, you create an unmaintainable role concept with many copycat authorization objects when your roles are continuously maintained with manual authorizations. On one hand, you won't know why an authorization is required, and you'll always leave them in your authorization profiles. On the other hand, you'll override the authorization default value mechanism, thus negatively impacting role maintenance, security, and upgradability with new release updates.

Personal Copy for Arun Singal, arun.singal560@gmail.com

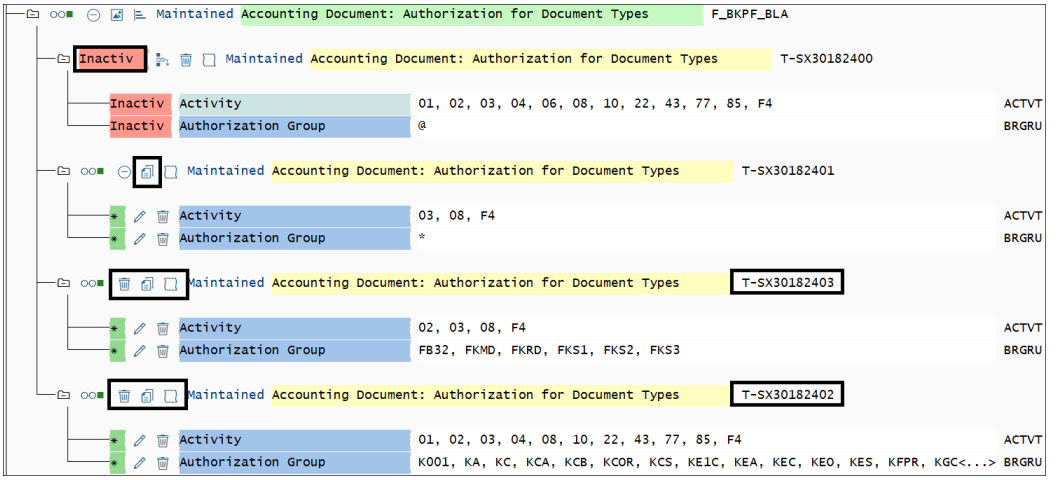


Figure 6.65 Authorization Instance Adjustments in the Authorization Profile

Overauthorizations, audit issues, business interruptions due to system upgrades, and increased role maintenance effort can also occur. Please note also that, with manual authorizations, you won't meet an application's source code requirements as designed.

6.5.3 Role Profile Generation

When you're maintaining the authorization profile, you should generate the role profile from time to time. Please note that clicking the **Save** icon within the authorization profile does not generate the profile, which is necessary so that end users can work with the assigned role. The **Save** icon only locks the current maintenance status and enables a fallback scenario if the system crashes or if you want to perform mass profile generation with Transaction SUPC. End users can also only use new role adjustments after saving the maintained authorizations and changes and regenerating the role profile. Thus, every time you maintain a role menu or an authorization profile, you must generate the role profile again. This regeneration is achieved by clicking on **Generate** button on the authorization profile maintenance screen, shown in Figure 6.66.

Figure 6.66 Role Profile Creation Button in the Authorization Profile

Hint

See Section 6.8.2 for more information about mass generation options.

Never create role profiles manually (i.e., via the **Profile Name** field), which leads to inconsistencies and authorization flaws through potentially overlapping role profile

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

names. When you create a role profile, the system automatically merges the authorization profile into an intended role profile starting with **T-*** in SAP standard. Also, the system generates the value in the **Profile Text** field and shows the current authorization profile status, as shown in Figure 6.67. The generated role profile is necessary for the system to load this data into the end user's user buffer and to compare the user buffer with the `AUTHORITY-CHECK` statements in the program code.

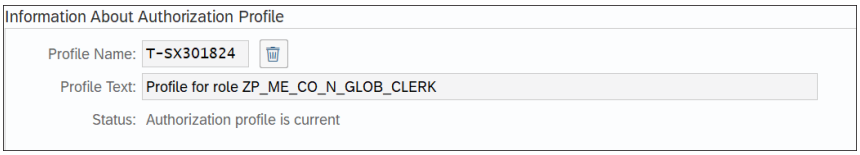


Figure 6.67 Information about the Generated Role Profile

6.6 Role Versions

Since Basis version release 7.31, SAP offers an automatic role versioning functionality that is based on a role's change documents. You can use this capability to save the current status of a role before changing its authorization profile. The system saves automatically after each authorization change that creates a new change document and enables a fallback scenario where you can revert to the initial status or to a specific authorization maintenance status. In addition, you can also compare two versions of the same role and display a particular version's authorization data. You can directly use the SAP standard report RSUSR_AUTH_DATA_VERSION or jump into the role versioning tool via Transaction PFCG.

Execute Transaction PFCG for a targeted role, navigate to the authorization profile, and click the **Versions** button in the header bar or select **More** • **Utilities** • **Versions,** as shown in Figure 6.68.

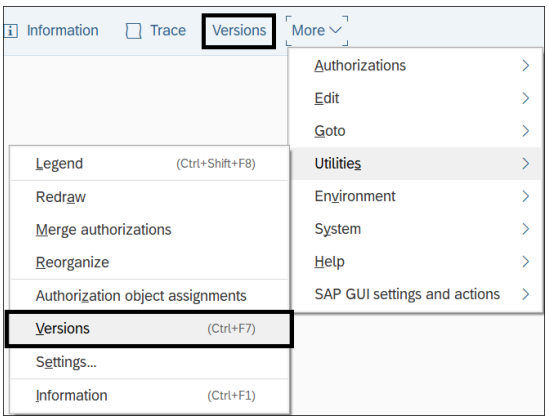


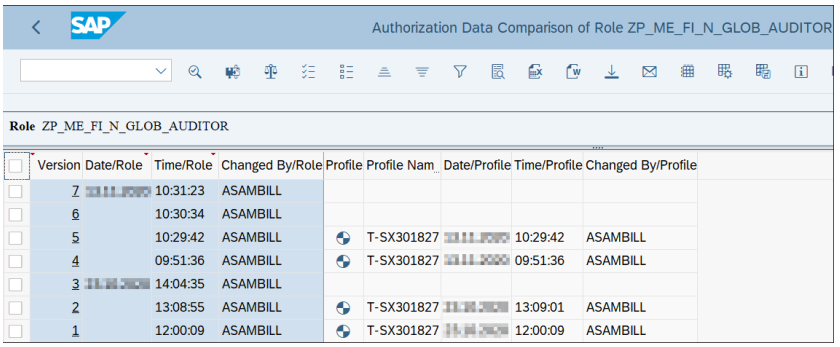
Figure 6.68 Role Versioning Buttons in Transaction PFCG

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

To analyze roles that have already been deleted from the system, start the related SAP standard report RSUSR_AUTH_DATA_VERSION via Transaction SA38. See the referring hints and the implementation guide for the role versioning tool in SAP Note 2248464.

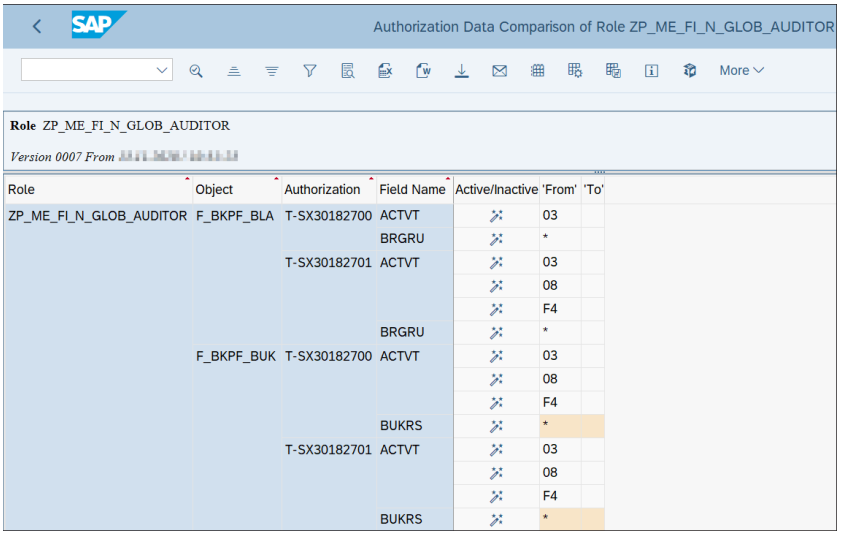
The role versioning tool's initial screen provides an overview of all available role versions for the specific role. You can see information about who changed the role and when, as shown in Figure 6.69.



Version	Date/Role	Time/Role	Changed By/Role	Profile	Profile Nam	Date/Profile	Time/Profile	Changed By/Profile
7	[redacted]	10:31:23	ASAMBILL					
6		10:30:34	ASAMBILL					
5		10:29:42	ASAMBILL		T-SX301827	[redacted]	10:29:42	ASAMBILL
4		09:51:36	ASAMBILL		T-SX301827	[redacted]	09:51:36	ASAMBILL
3	[redacted]	14:04:35	ASAMBILL					
2		13:08:55	ASAMBILL		T-SX301827	[redacted]	13:09:01	ASAMBILL
1		12:00:09	ASAMBILL		T-SX301827	[redacted]	12:00:09	ASAMBILL

Figure 6.69 Results of the Role Versioning Report for a Specific Role

The role version tool enables you to display each available role version's **authorization data**. For this step, you can double-click a version, click the **Display Details** button, or press F9. You'll see all the authorization details of the selected role version, as shown in Figure 6.70.

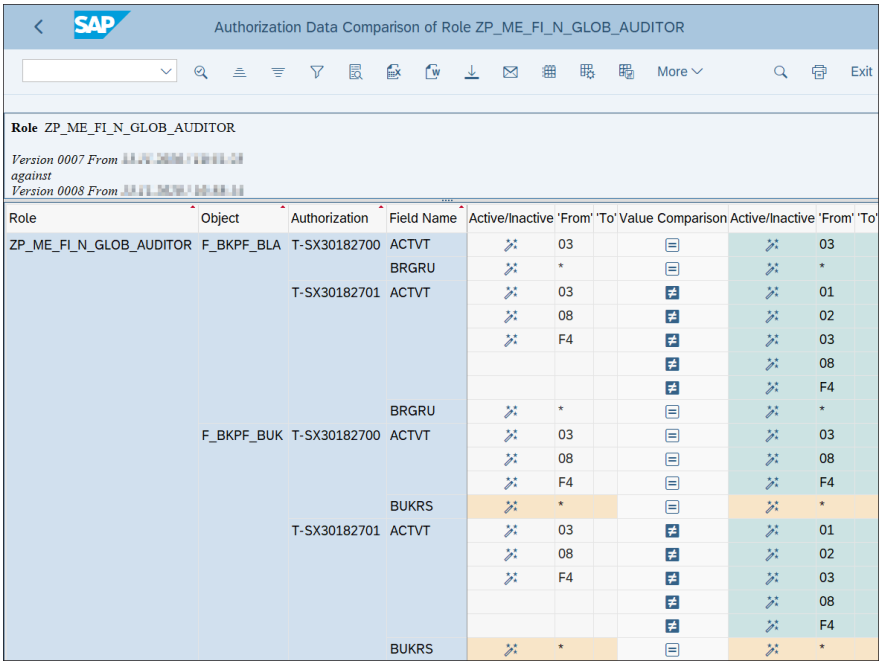


Role	Object	Authorization	Field Name	Active/Inactive	'From'	'To'
ZP_ME_FI_N_GLOB_AUDITOR	F_BKPF_BLA	T-SX30182700	ACTVT		03	
			BRGRU		*	
		T-SX30182701	ACTVT		03	
					08	
					F4	
			BRGRU		*	
	F_BKPF_BUK	T-SX30182700	ACTVT		03	
					08	
					F4	
			BUKRS		*	
		T-SX30182701	ACTVT		03	
					08	
					F4	
			BUKRS		*	

Figure 6.70 Authorization Characteristics of a Specific Role Version

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

For comparison, select two versions and click on the compare icon in the header bar, shown earlier in Figure 6.69. The report displays the authorization data of both versions. Note the authorizations values and the **Value Comparison** status icons of the two versions. These icons show you whether the data is newly added, removed, identical, or changed in comparison, as shown in Figure 6.71.



Role	Object	Authorization	Field Name	Active/Inactive	'From'	'To'	Value Comparison	Active/Inactive	'From'	'To'
ZP_ME_FI_N_GLOB_AUDITOR	F_BKPF_BLA	T-SX30182700	ACTVT		03				03	
			BRGRU		*				*	
		T-SX30182701	ACTVT		03				01	
					08				02	
					F4				03	
									08	
									F4	
			BRGRU		*				*	
	F_BKPF_BUK	T-SX30182700	ACTVT		03				03	
					08				08	
					F4				F4	
			BUKRS		*				*	
		T-SX30182701	ACTVT		03				01	
					08				02	
					F4				03	
									08	
									F4	
			BUKRS		*				*	

Figure 6.71 Authorization Data Comparison of Two Roles

6.7 Roles Overview Status

For the administration of many different roles, Transaction PFCG also enables global role status analysis, which might be useful for an overview of your roles and to check whether some maintenance activities are required. This section introduces you to using the profile generator to perform a status analysis of your role concept.

Start the report from Transaction PFCG by selecting **More** • **Utilities** • **Overview status**, as shown in Figure 6.72.

Select your roles and execute the program. Besides the role name, change date, time, and last changed by, this result list provides the following status characteristics, as shown in Figure 6.73:

- Does the targeted role have a role menu, and does it include any transactions (**Menu**)?
- Is the role distributed (**Distribut.**)?

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Does the corresponding role profile exist, what is the name, and is it generated (**Profile Status/Profile Name**)?
- Is the role assigned to end users (**User**)?
- Is the role assigned to a composite role (**Role Assignment**)?
- Is the role indirectly assigned through SAP ERP HCM (**HR Org.**)?
- Is the profile comparison current (**Profile Comparison**)?
- Is the composite role comparison current (**Composite Role Comparison**)?

Using this report, you can significantly improve your role administration process. Moreover, you can also increase the stability and quality of your roles by focusing on the red circles, which show you exactly what you must correct.

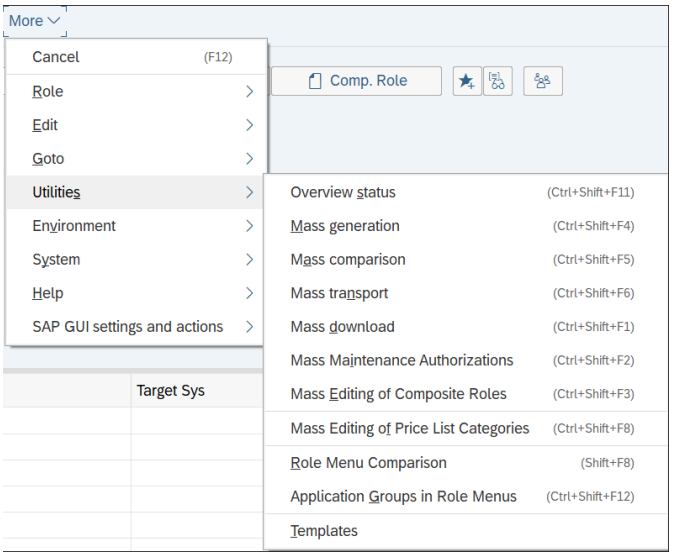


Figure 6.72 Utilities in Transaction PFCG

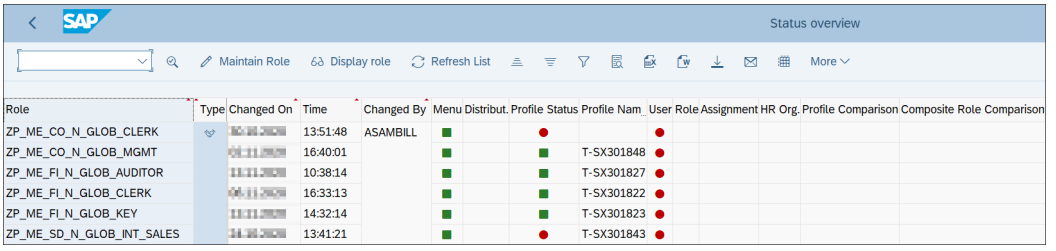


Figure 6.73 Role Status Overview in Profile Generator

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

6.8 Selected Mass Maintenance Options for Roles

In the context of role administration and maintenance, often business cases require you process many different roles simultaneously. Thus, single role selection and individual administration would lead to time-consuming and cumbersome effort. To reduce this work and simplify role-dependent activities, SAP offers some mass administration options for roles.

This section describes the utilization of these mass role administration options, including mass authorization maintenance, mass role profile generation, and mass role assignment.

6.8.1 Mass Role Maintenance

Since Basis version release 7.02, you can use Transaction PFCGMASSVAL to add, maintain, and change authorization field values and organizational levels for multiple roles simultaneously. Three different change modes are available on the initial screen, as shown in Figure 6.74 and listed in Table 6.5.

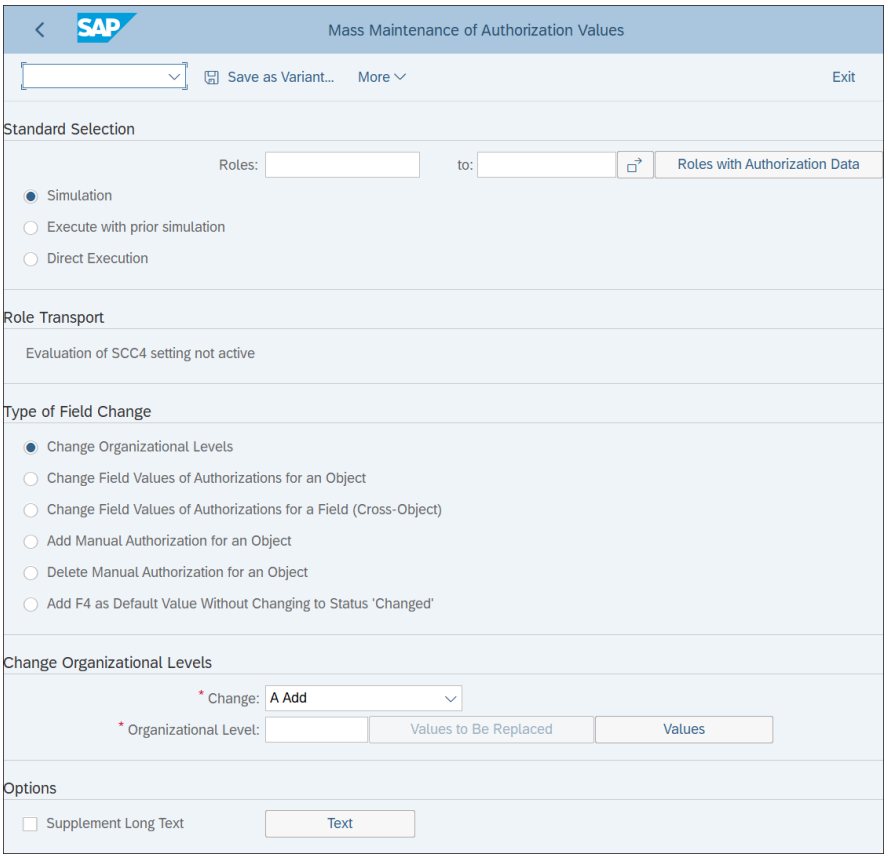


Figure 6.74 Initial Screen of Transaction PFCGMASSVAL

Personal Copy for Arun Singal, arun.singal560@gmail.com

Change Mode	Description
Simulation	Simulates proposed changes before you perform an actual change.
Execute with prior simulation	This mode simulates the changes too but also offers the ability to then push these changes to your roles directly.
Direct execution	The report immediately changes the roles according to your predefined settings and displays the result list.

Table 6.5 Change Modes for Transaction PFCGMASSVAL

Regardless of which option you choose, when you execute one mode, the SAP system automatically locks all the roles in scope so that no one can interrupt the analysis with parallel role changes. Before you execute the report, you must choose the targeted operation via the **Type of Field Change** options, as shown earlier in Figure 6.74 and listed in Table 6.6. Long descriptions for each option are available in the program documentation, accessed via the **More** button in Transaction PFCGMASSVAL.

Type of Field Change	Description
Change Organizational Levels	You can change the global maintenance of one organizational level for all selected roles. You can only update one organization level change for each report execution. This option does not affect manually maintained organization levels.
Change Field Values of Authorizations for an Object	You can change the field values for a selected authorization object in all selected roles.
Change Field Values of Authorizations for a Field (Cross-Object)	You can change the authorization values of a specific authorization field like ACTVT. This option affects all authorization objects with that field as an authorization default value within your role selection.
Add Manual Authorizations for an Object	You can manually add a specific authorization object with maintained or open field values for your role selection. This option is not recommended.
Delete Manual Authorization for an Object	You can manually delete a specific authorization object for your role selection.
Add F4 as Default Value Without Changing to Status "Changed"	You can automatically add the new authorization field value "F4" to activate the input help feature for all menu objects for which the value "F4" is maintainable within your role selection. This option does not change the status of the objects to "Changed."

Table 6.6 Types of Field Changes in Transaction PFCGMASSVAL

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Please note that the Transaction PFCGMASSVAL selection shows you a warning icon when you intend to change an authorization object that contains organizational levels. If you change the organization levels for this specific object manually, the authorization object will receive the "Changed" status flag. Avoid this approach, which overrides central organization level maintenance and thus increases your role maintenances efforts. See Section 6.4.4 for further information.

Suppose you've introduced a new subsidiary (company code 2000) into your system customizing because of a merger. In this case, you must provide the organization level value to all relevant roles. First, select all roles you want to change because they are affected by the merger. Then, select the **Execute with prior simulation** radio button, choose the **Change Organizational Levels** radio button from the **Type of Field Change** section, and select **A Add** for the **Change** field, as shown in Figure 6.75. Execute the report, and you'll see a value comparison of the selected roles.

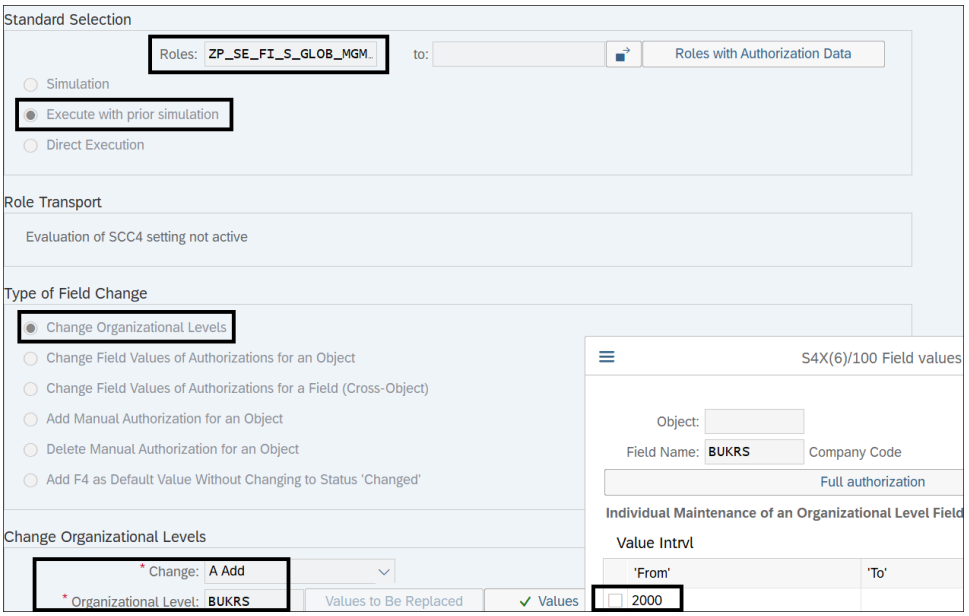


Figure 6.75 Adding a New Company Code to All Selected Roles

The results list shows the already maintained company codes and the company code you want to add. Select a line via its checkbox and click the **Execute** button to change its values. You can also choose other change options for deleting, replacing individual company code values, or replacing all company code values with the selected company code (in our case, **2000**). Your choice depends on your maintenance objectives, but you must consider that the mass actions might result in adverse side effects and further

Personal Copy for Arun Singal, arun.singal560@gmail.com

mass maintenance issues. Transaction PFCGMASSVAL is an expert tool, so before running the actual execution, ensure that the business approves of the change and also use the simulation mode first (see Figure 6.76).

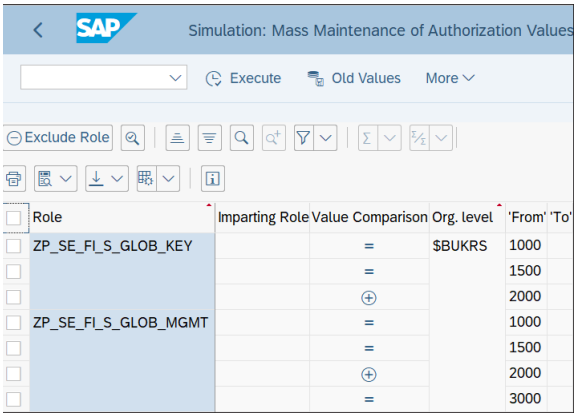


Figure 6.76 Simulation of Company Code Mass Maintenance

Transaction PFCGMASSVAL extends the mass maintenance capability of Transaction PFCG. This handy program enables you to save time when organizational changes or fast mass authorization maintenance actions in roles are required.

Hint

Since Basis version release 7.50, Transaction PFCGMASSVAL is a standard feature, and you won't need a separate implementation. See SAP Notes 2177996, 2336271, 2405256, 2421626, and 2450747 for detailed information.

6.8.2 Mass Generation of Role Profiles

Role profile generation is an essential step for saving the current status of the authorization characteristics you've maintained for each role. Otherwise, your end users cannot use the updated authorizations. Therefore, you can also select **More** • **Utilities** • **Mass generation**, as shown earlier in Figure 6.72. You can also directly enter this program via Transaction SUPC. Enter the desired roles or enter a wildcard string (i.e., "ZP*" to cover all roles starting with "ZP"). Then, select whether or not you want to generate the role profiles automatically, as shown in Figure 6.77. If you do not opt for automatic generation, the program only displays its findings, and you'll manually decide which profiles to generate.

Once you execute the program without the automatic generation option, the system shows a list of role profile issues. As shown in Figure 6.78, some roles lack a generated profile (**No profile name exists**), but another possibility is that the profile status is not current.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

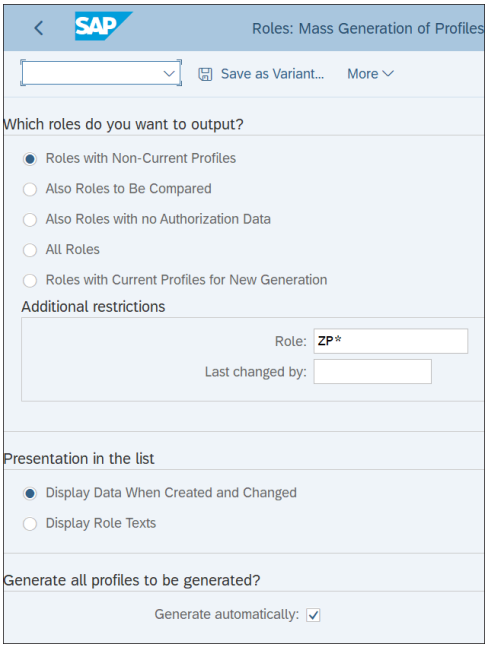


Figure 6.77 Mass Generation of Role Profiles through Transaction SUPC

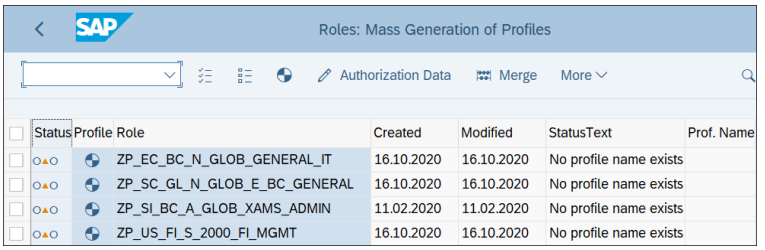


Figure 6.78 Result List of the Mass Generation of Profiles

Select the role whose profile you want to generate and click on the generate button F8. You can also display or change the selected roles' authorization data to check what has been changed but not generated. The **Merge** option offers deep insight into the authorization changes expected through the profile generation process including whether a role will get new proposals from Transaction SU24. Thus, before starting with the execution, you should verify your changes, especially whether or not they are correct, to reduce adverse side effects.

6.8.3 Mass User Comparison of Roles

Another handy functionality of Transaction PFCG is its mass user comparison feature, as shown in Figure 6.79. You can also enter the application directly via Transaction PFUD. Every time you change authorization characteristics, you must generate the role

Personal Copy for Arun Singal, arun.singal560@gmail.com

profile and transport the role. This process also requires updating the role-to-end user comparison. Therefore, enter the role name and run the program in dialog processing mode for specific roles. For the entire user comparison, you should perform this task after midnight with a background job of transaction PFUD for all actively used roles, so the role assignments are updated in time for the upcoming workday.

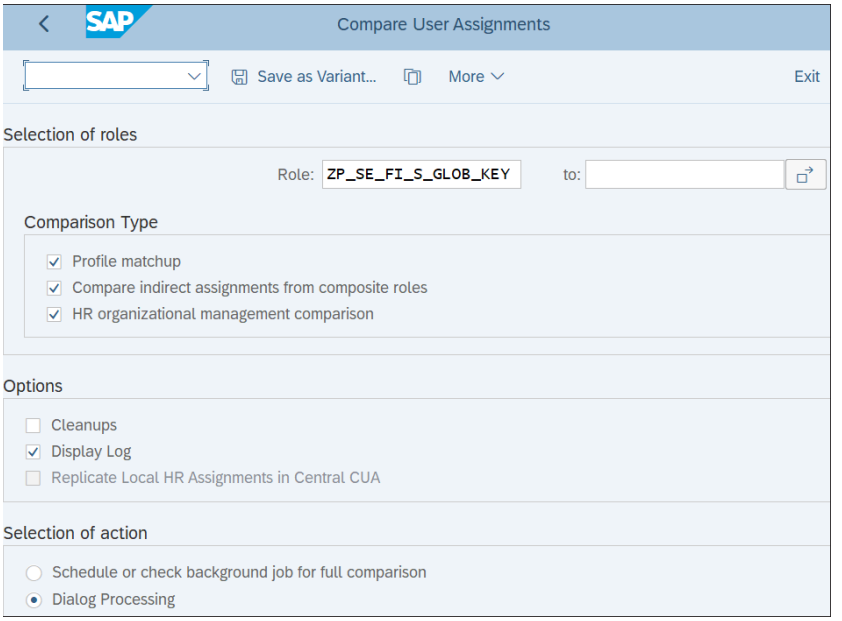


Figure 6.79 Compare Role to End-User Assignments in Transaction PFUD

To make this comparison periodically, create a variant for the productive roles in scope in Transaction PFUD and create a specific background job for program RHAUTUPD_NEW via Transaction SM36. Program RHAUTUPD_NEW is behind Transaction PFUD. There you can select further criteria and steps for your job, for instance, determine the date on every day at 02:00 am, inbound the variant (your role setting, adjusted in Transaction PFUD) and program name (RHAUTUPD_NEW). Don't forget to activate the job in a system user context, because background jobs are system-related and should not run through dialog user. Moreover, if the dialog user is inactivated or run out of validity, the job would stop. In this way, you can enable the automatic and periodic comparison of your end user roles on PRD.

6.9 Transfer of Roles

After role creation and maintenance, an essential step is to transport these changes to your PRDs and assign roles to end users. To accomplish this step, you can transport the

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

roles or download and upload them. A best practice and also a recommendation from SAP is to transport roles only. Otherwise, with the download/upload option, you'll lack transport and change documents, thus hindering any review and testing processes. In addition, the download/upload option might lead to critical access issues because the manual file can be changed through common editor tools before being uploaded to the PRD.

Hint

For detailed information about the necessity of role transports, check Section 6.2.1.

For transporting roles, you can choose between two options. The first option is to transport only one role. The second option is mass role transport. Typically, the mass role transport option is what you'll choose in the real world.

For single role transport, launch Transaction PFCG, enter the role name you want to transport, and click on the transport icon, as shown in Figure 6.80. Choose the **Generated Profiles of Single Roles** flag and, if necessary, the **Personalization Data** or **Direct User Assignments** options as well. After your selection, execute the program. You'll then be prompted for the selection of an existing transport request or the creation of a new transport request (customizing request).

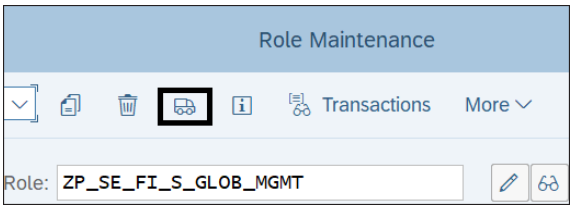


Figure 6.80 Role Transport Icon in Transaction PFCG

Now, you can release the task and transport request in Transaction SE09 (Transport Organizer). You also must import the transports via Transaction STMS on your subsequent systems until the transports reach the productive layer. For these transport actions, you'll need transport authorizations based on your internal regulations. Otherwise, delegate the transport actions to authorized users like the Basis administrators.

For multiple roles, use the mass transport option accessed via the header bar of Transaction PFCG. Select **More** • **Utilities** • **Mass transport**. The procedure is similar to the transport of a single role, but you can select more than one role at once.

For composite roles, select the **Single Roles in Composite Roles** checkbox, which enables the transport of the related single roles that make up the composite role. Otherwise, you'll only transport an empty composite role shell.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

You should periodically check several settings in table PRGN_CUST to avoid negative side effects during your role transport, such as the following:

- SGL_ROLES_TRANSPORT = YES (SAP Note 1723881)
- PROFILE_TRANSPORT = YES (SAP Note 571276)
- PERSDAT_TRANSPORT = YES (SAP Note 1723881)

Sometimes, transferring roles beyond the existing transport lines is necessary. For this use case, SAP offers a corresponding functionality: the download/upload function for roles. For this option, launch Transaction PFCG and enter a role name. Then, select **More • Role • Download**, as shown in Figure 6.81. You can store the resulting SAP file in a local folder on your computer and subsequently upload the role to any other system via **More • Role • Upload**. For mass downloading and uploading, use Transaction PFCG's mass maintenance utilities.

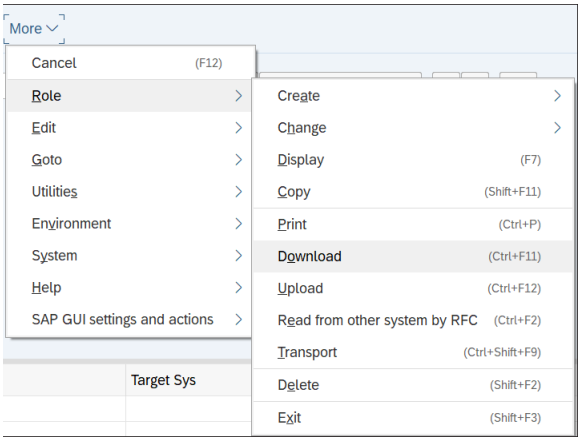


Figure 6.81 Role Download in Transaction PFCG

Hint

See SAP Note 2323438 for further information about distributing roles via the download/upload option.

6.10 Xiting Authorizations Management Suite: Virtual Role Design with Xiting Role Designer

Creating a sustainable and secure role concept can be a complex and time-consuming process for any security administrator. One common problem during daily business or

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

project-based role redesign is the inability to rely on end-user input. You also must involve technical entities to capture real transactional usage or and to determine critical authorization or SoD issues. As a result, you must combine a top-down approach (focused on specialized department requirements) and a bottom-up approach (focused on the analysis of technical usage data). Furthermore, some additional hurdles you may face include the following:

- Identifying the functional and organizational business needs for new or existing roles is technically complex.
- You should ensure that your role definitions match actual transaction usage to avoid over- and underauthorizing end users.
- Identifying common functionalities for several end users to create job function roles is a highly time-consuming task.
- You must forecast effects on your role concept if transaction changes occur during the role design to reduce critical authorizations and transactional extent.
- To reduce both effort and critical authorization issues, you should perform an audit-based analysis of your role concept before testing.

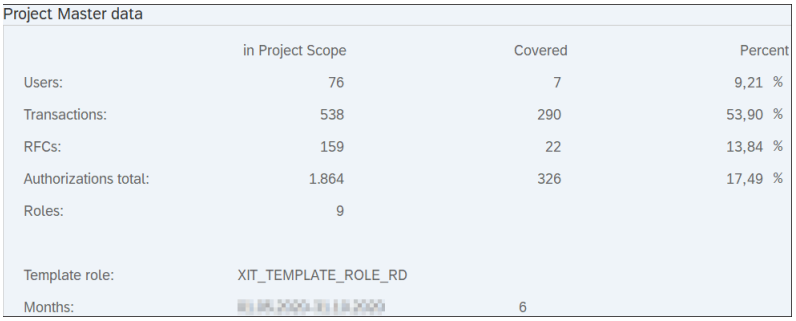
A tool-driven approach to accomplish these issues and for optimizing the role creation process is one solution for which Xiting offers its Xiting Role Designer. This solution enables security administrators to design new roles in a drag-and-drop cockpit with fast implementation functions on a virtual project basis. "Virtual" in this context means that your work won't affect the profile generator until you're ready to push your virtual role to Transaction PFCG. You can also simulate what-if scenarios through virtual roles assigned to end users. Additionally, you can migrate your existing roles to SAP S/4HANA without manually looking for simplification list requirements. When beginning a project with Xiting Role Designer, you'll quickly and easily transfer end-user usage data from your PRD(s) to your virtual design project on the central DEV. In this way, you'll also satisfy the SAP standard that the DEV be reserved for role building but also enjoy the benefit of access to end-user usage data from PRDs.

6.10.1 Project Cockpit

In addition to the project description and role creation process dashboards, the project overview summarizes the project master data (see Figure 6.82). You'll see the final scope of your project, especially the coverage rate for individual checkpoints. The coverage rate describes how many users can fully execute their functional business duties with the virtual role implemented and assigned, compared against their former usage data.

Through Xiting Role Designer, you can also consolidate end-user usage data and combine several menu objects from various systems and clients into a central project where you can fully achieve a global enterprise-level role concept.

Personal Copy for Arun Singal, arun.singal560@gmail.com



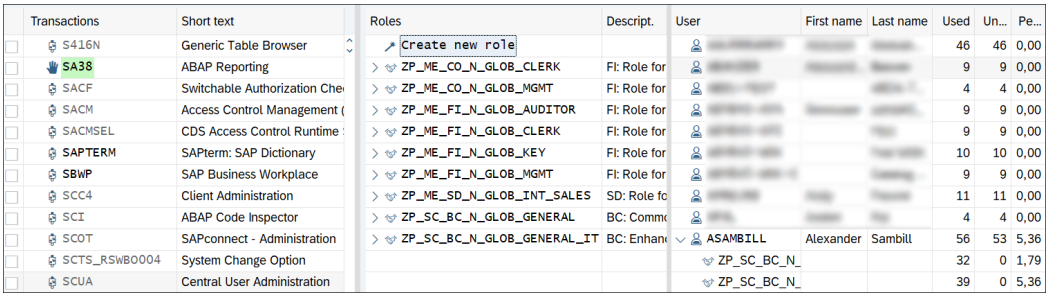
Project Master data

	in Project Scope	Covered	Percent
Users:	76	7	9,21 %
Transactions:	538	290	53,90 %
RFCs:	159	22	13,84 %
Authorizations total:	1.864	326	17,49 %
Roles:	9		
Template role:	XIT_TEMPLATE_ROLE_RD		
Months:	[redacted]	6	

Figure 6.82 Project Master Data in Xiting Role Designer

6.10.2 Design Cockpit

The assignment of role menu objects, like transactions or function modules, to roles and then roles to end users is easily possible through drag-and-drop options. The split screen, shown in Figure 6.83, provides an overview of menu objects, based on usage data, on the left. Existing project roles with their assigned role menu objects are in the middle, and end users are displayed on the right, with their coverage rates and assigned virtual roles.



Transactions	Short text	Roles	Descript.	User	First name	Last name	Used	Un...	Pe...
S416N	Generic Table Browser	Create new role		[redacted]			46	46	0,00
SA38	ABAP Reporting	ZP_ME_CO_N_GLOB_CLERK	FI: Role for	[redacted]			9	9	0,00
SACF	Switchable Authorization Che	ZP_ME_CO_N_GLOB_MGMT	FI: Role for	[redacted]			4	4	0,00
SACM	Access Control Management (	ZP_ME_FI_N_GLOB_AUDITOR	FI: Role for	[redacted]			9	9	0,00
SACMSEL	CDS Access Control Runtime	ZP_ME_FI_N_GLOB_CLERK	FI: Role for	[redacted]			9	9	0,00
SAPTERM	SAPterm: SAP Dictionary	ZP_ME_FI_N_GLOB_KEY	FI: Role for	[redacted]			10	10	0,00
SBWP	SAP Business Workplace	ZP_ME_FI_N_GLOB_MGMT	FI: Role for	[redacted]			9	9	0,00
SCC4	Client Administration	ZP_ME_SD_N_GLOB_INT_SALES	SD: Role fo	[redacted]			11	11	0,00
SCI	ABAP Code Inspector	ZP_SC_BC_N_GLOB_GENERAL	BC: Comm	[redacted]			4	4	0,00
SCOT	SAPconnect - Administration	ZP_SC_BC_N_GLOB_GENERAL_IT	BC: Enhan	ASAMBILL	Alexander	Sambill	56	53	5,36
SCTS_RSWBO004	System Change Option			ZP_SC_BC_N_			32	0	1,79
SCUA	Central User Administration			ZP_SC_BC_N_			39	0	5,36

Figure 6.83 Design View in Xiting Role Designer

You only need to click on **Create new role** and specify a role short description. Then, select the target menu objects from the left and assign them to that role. Based on data about end-user usage, you can assign the role to specific users, like **ASAMBILL**. Notice that this user has used **56** menu objects in the past, but the two virtual assigned roles only cover **3** of them. Consequently, the coverage rate is only **5,36** percent. In this case, you can conclude that this role is not well suited to the end user's actual requirements and should be withdrawn or rebuilt.

Within the design view, you can quickly migrate your roles from SAP ERP 6.0 to SAP S/4HANA via the simplification list.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

6.10.3 Reports Cockpit

For mass maintenance and analyses, you can use the **Reporting** section of Xiting Role Designer. More than 50 valuable reports regarding role design are available. These reports enable detailed analyses of end users, roles, and menu objects. For instance, you can calculate which roles fit better than the virtual assigned roles or also directly introduce organizational requirements. In the **List role status** section, as shown in Figure 6.84, you'll see an overview of the virtual roles or physical roles (column **PFCG**) available. You'll also see whether the profiles have been created and which menu objects they contain in detail. As shown in Figure 6.84, the role setting overview enables some other possible report sections.

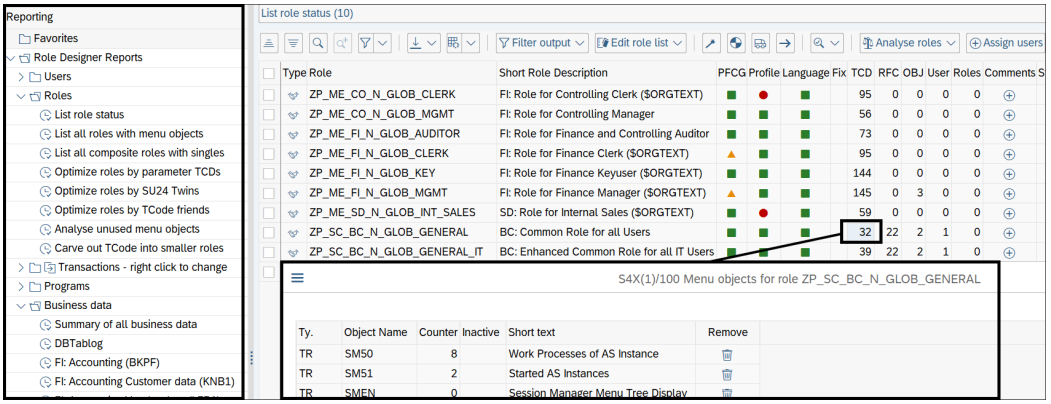


Figure 6.84 Report Section in Xiting Role Designer

Hint

The string **($ORGTEXT)** in a role's short description is a variable you can use within XAMS to directly introduce an OrgSet description into your replicated roles through Xiting Role Replicator. This string is not required in SAP standard.

Moreover, you can directly analyze your role setup based on the integrated Xiting security rule set, your SAP governance, risk, and compliance solutions (SAP GRC solutions) rules, or your own rule definitions, as shown in Figure 6.85. Thus, you can avoid inappropriate authorizations, even before the role testing phase, during your design, and thus guarantee a secure and sustainable authorization concept.

Personal Copy for Arun Singal, arun.singal560@gmail.com

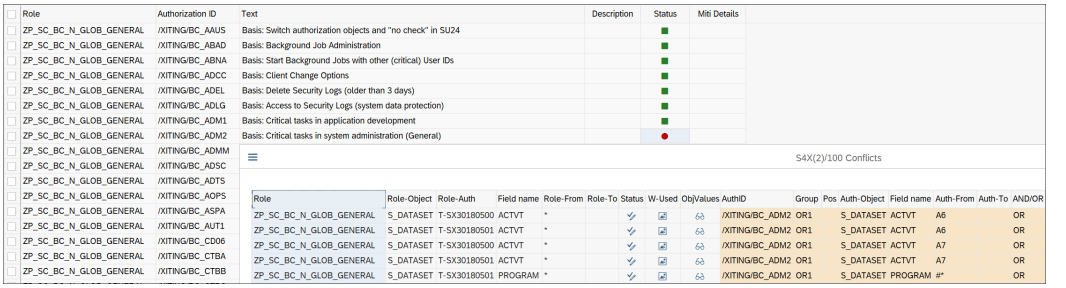


Figure 6.85 Role Analysis according to Critical Authorizations

6.11 Summary

The profile generator is the master tool for role creation and end-user authorization allocation, required for every security administrator. Knowing and understanding Transaction PFCG's capabilities and functionalities is mandatory to achieve a sustainable and secure role concept. Roles are the dominant elements to authorize end-user job duties.

Every enterprise is unique, as will be your role and user concept. This chapter covered several recommendations for preventing flaws and incorrect end-user authorizations or preventing inconsistencies within your entire role concept, such as the following:

- Use a strict role naming convention for a transparent role administration.
- Try to work with job function roles in conjunction with a holistic top-down and bottom-up approach to enable your specific role and authorization concept.
- Always assign menu objects to the role menu to ensure that you're using authorization default values because they are required based on the program code. Maintain Transaction SU24 data when required. Periodically update this data through Transaction SU25 as necessary.
- Avoid adding manual authorization objects into authorization profiles or working with manual profiles, like SAP_ALL, for end users.
- If you don't use or don't know specific authorization objects, fields, or values in your authorization profile, enter a special character like "@" to serve as a dummy value or inactivate those object instances. Then, test your roles to determine the required values.
- Use Transaction PFCG's expert mode option **Read old status and merge with new data** during authorization maintenance.
- Generate the role profile after every authorization profile change.
- Use the inheritance concept for organizational access scenarios by creating master roles and derived roles.
- Build your roles in the DEV and then transport them to PRD.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

If you consider these important best practices and integrate your knowledge from this chapter, you'll have the necessary tools for accomplishing a sustainable and maintainable role concept.

In the next chapter, we'll discuss authorization analysis, trace tools, and authorization debugging.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 7

Authorization Analysis, Trace Tools, and Authorization Debugging

Analyzing missing user authorizations is an essential part of any security administrators' day-to-day work. Therefore, SAP provides useful analysis tools out of the box. These tools enable you to evaluate and fix authorization issues and are also helpful for maintaining and customizing your role concept based on your users' application usage data.

Even with well-maintained and sustainable authorization concepts, both business users and technical users might occasionally experience authorization issues. Most issues occur during or after a release upgrade, after implementing SAP Notes, or when new business functions are implemented. To analyze, evaluate, and solve such issues, you can use traces. A trace is a technical record of end user or system process activities. The trace allows you to find missing authorizations to form a baseline for discussing findings with business users. Once adding the missing authorizations has been approved, a security administrator can go ahead and maintain the required authorizations in the template or in specific end-user roles.

You can also use traces to enrich your role menus or maintain authorization default values for specific applications. In addition, analytical applications like Transactions SU53 or STSIMAUTHCHECK can assist with various authorization maintenance use cases. For instance, you can use these transactions to find missing end-user authorizations or simulate new job function roles against end-user activities. Thus, running trace and analysis tools can support you with fixing authorization issues and improve your role concept by making it more robust.

This chapter explains the different trace and analyzing tools available to help you solve authorizations issues and enhance your authorization concept. Therefore, this chapter's overview provides some basic information about authorization traces and their related return codes. Then, we'll provide an introduction to SAP standard tools like Transactions SU53, STAUTHTRACE, ST01, STUSOBTRACE, STUSERTRACE, and STSIMAUTHCHECK. Finally, this chapter shows you how to debug authorizations issues and utilize enhanced trace evaluation with the Xiting Authorizations Management Suite (XAMS).

Personal Copy for Arun Singal, arun.singal560@gmail.com

7.1 Overview

SAP provides different types of traces to evaluate and troubleshoot authorizations, such as the following:

- System trace: Transaction ST01/ STAUTHTRACE
- Authorization trace: Transaction STUSOBTRACE
- User trace: Transaction STUSERTRACE

The decision of what trace you should use depends on the type of authorization issue you're facing and whether you want to use short- or long-term tracing. However, additional tools do not belong to area of trace applications that you can also use to analyze authorizations, like Transactions SU53 or STSIMAUTHCHECK. All in all, you can validate and maintain role menus, authorization profiles, authorization default values, and core data services (CDS) view authorizations for applications with the help of many tools.

Therefore, this section offers an overview of numerous trace and analysis options. Additionally, this section summarizes the different authorization check return codes you must know to appropriately maintain your end users' roles and authorizations. As a prerequisite to using some of these traces, you might have to enable system parameters. This section will dive into these requirements as well.

7.1.1 Analysis Tools

Since you have various options for troubleshooting authorizations in an SAP system, choosing the correct tool for the job at hand is essential. On this account, Table 7.1 provides an overview of the most popular analysis tools and outlines their advantages and disadvantages.

Type	Transaction	Use Case	Pro (+)/ Con (–)
Failed Authorizations Check (no trace)	Transaction SU53	Evaluating authorization checks	(+) Transaction SU53 records show failed authorization checks only. (+) Active for every user, no need to activate. (+) As an administrator, you can check other users' Transaction SU53 data. (–) You won't see possible further authorization errors within the subsequent program check's flow. (–) Successful checks are not recorded.

Table 7.1 Targets and Usage of Various Analyzing Tools in SAP Standard

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Type	Transaction	Use Case	Pro (+)/ Con (–)
System Trace (short-term trace)	Transaction ST01 (for one application server) Transaction STAUTHTRACE (for multiple application servers)	Tracing end-user authorizations	(+) Records all authorization checks whether successful or not. (+) Output in ABAP List Viewer (ALV) format with enhanced information (e.g., CDS views). (+) Trace information can be read in Transactions PFCG and SU24. (–) The system overwrites the data records through the ring buffer mechanism (Section 7.2.1).
Authorization Trace (long-term trace)	Transaction STUSOBTRACE	Analyzing and maintaining the required authorization defaults for applications	(+) Each authorization check is recorded once per application. (+) Ability to use trace information in Transactions SU24 and PFCG. (+) Allows optimizing Transaction SU24 data based on actual application usage. (+) Works with filters. (–) No end user-specific evaluation, (–) Might negatively impact system performance.
User Trace (long-term trace)	Transaction STUSERTRACE	Analyzing and maintaining authorizations for users	(+) Each authorization check is logged once per user. (+) Trace information can be used in Transactions PFCG and SU24. (+) Works with filters. (–) The filter allows 10 simultaneous users at a time or all at once (without filter). (–) Might negatively affect system performance.
Simulation of Authorization Checks (requires user trace)	Transaction STSIMAUTHCHECK	Simulating the required authorizations	(+) Simulation of end-user activities against specific roles. (+) Ability to verify new role concepts against user trace data. (–) This analysis tool requires user trace data (Transaction STUSERTRACE).

Table 7.1 Targets and Usage of Various Analyzing Tools in SAP Standard (Cont.)

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

SAP also offers other traces that might help you with other use cases. For instance, you can use Transactions SAT, ST05 and ST12 (SAP Note 2436955) to access the SQL trace, table buffer trace, enqueue trace, remote function call (RFC) trace, HTTP trace, ABAP Push Channels (APC) trace, and ABAP Messaging Channels (AMC) trace. SAP Note 2524975 provides an overview of the primary uses of these transactions.

For the RFC statistic records evaluation, you can also use Transaction STRFCTRACE. This application enables the Unified Connectivity log analysis. SAP Note 2080378 provides some further information about this use case.

7.1.2 Selected Authorization Trace Return Codes

To interpret trace results during evaluation, you'll need to understand the return codes of an authority check. A return code shows you which authorization is missing and why. Return codes vary slightly depending on the application. Any value greater than 0 indicates a failed authorization check, and the system provides further details about the error. Table 7.2 lists the most common return codes you may encounter during authorization analysis. Please note that the specific return codes depend on the trace source and might vary.

Return Code	Context	Description
0	Transaction SU53/ST01/	Authorization check successful—The end user has the authorizations for all specified values, or the authorization object check is switched off.
1	Transaction SU53	Authorization check not successful—The end user has the authorization object in the user buffer but not the expected value.
3	Transaction SU53	Authorization check not successful—The end user does not have the required authorization object in the user buffer.
4	Transaction ST01	Authorization check not successful—The end user has the required authorization object in the user buffer but not the expected value.
12	Transaction ST01	Authorization check not successful—The end user does not have the required authorization object in the user buffer.
40	Transaction ST01	Authorization check not successful—The end user does not exist (to check on other users).

Table 7.2 Common Authorization Check Return Codes

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

You might sometimes see the return code 0, which indicates a disabled authorization check. Typically, this value appears in the **Additional Information for Check** column.

In this context, four different types of deactivation exist, as follows:

- **A**: Globally deactivated authorization objects, which you can check and maintain in Transaction AUTH_SWITCH_OBJECTS.
- **B**: Application-related deactivated authorization objects, which you can check and maintain in Transaction SU24.
- **C**: Deactivated authorization objects during a `CALL TRANSACTION` source code statement, which you can check and maintain in Transaction SE97.
- **D**: Deactivated authorization objects by profile parameters, which you can check and maintain in Transaction SE97.

7.1.3 Activation of Profile Parameters

Before you can use the user and authorization trace, you must activate these features first. Therefore, consult your Basis team to configure the profile parameters shown in Table 7.3.

Trace Option	Transaction	Profile Parameter
Authorization Trace	STUSOBTRACE	`auth/authorization_trace`
User Trace	STUSERTRACE	`auth/auth_user_trace`

Table 7.3 Profile Parameters to Activate the Trace Functions

Both parameters take three different values, as shown in Table 7.4.

Maintainable Value	Description
Y|y	Trace is activated.
N|n	Trace is deactivated.
F|f	Trace is activated with a filter for recording, set in the transaction.

Table 7.4 Possible Profile Parameter Values for Trace Functions

Hint

For further information regarding the maintenance of selected profile parameter values, check SAP Notes 31395, 1847663, 1854561, and 543164.

Personal Copy for Arun Singal, arun.singal560@gmail.com

We recommend activating traces with a filter (value F) to avoid system performance issues. Profile parameters allow for dynamic switching, which means you can change the value in a running system. If you want the parameters to persist beyond system restart, you must maintain the value of the intended profile parameters in the **Default Profile** via Transaction RZ10.

Hint

The activation of profile parameters for trace options might affect system performance. Therefore, deactivate these options when you no longer need them. Please note that the system will not record anything if the profiler parameter value is set to F (with filter), but you do not specify a filter.

In this process, you must consult your Basis team, but only once, and you can keep the same value later. To start and stop these traces, you can manipulate filters.

7.1.4 Trace Tool Use Cases

Table 7.5 provides an overview of some typical use cases. Please note that this table only provides recommendations based on project experience and best practices and cannot serve as a definitive specification. You can use all traces for the use cases listed in in Table 7.5, but not all traces are always the best option depending on technical and functional prerequisites and also personal preference. "Well supported" highlights a best practice recommendation to achieve the best and fastest result for the related use case.

Use Case	Transaction ST01/STAUTHTRACE	Transaction STUSOBTRACE	Transaction STUSERTRACE
Find missing end-user authorizations	Well supported	Not supported	Well supported
Maintain the role menu	Well supported	Partially supported	Well supported
Maintain authorization data	Well supported	Partially supported	Well supported
Maintain authorization proposals	Partially supported	Well supported	Partially supported

Table 7.5 Use Cases for the Main Trace Types

7.2 Transaction SU53

To evaluate failed authorization checks, you can use Transaction SU53, which is not a trace but rather an analysis tool for display failed end-user authorization checks and other authorization-related data. Moreover, as a security administrator, you can check

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

authorization failures for other users as well. Therefore, this tool is suitable for verifying missing end-user authorizations. Moreover, you can compare failed authorizations with the user buffer (Transaction SU56). Thus, Transaction SU53 provides several evaluation functions to provide quick insight into missing authorizations—without using or activating a trace.

Therefore, this chapter introduces you to the capabilities available in Transaction SU53 and describes how you can evaluate authorization check failures.

Hint

SAP Note 1671117 provides further information about Transaction SU53 and its related profile parameters.

7.2.1 Description

All the failed authorization check records of end users are stored in the application server's ring buffer as data files. The *ring buffer* is a sort of buffer where data is stored and overwritten by new data within a specific period. Thus, this new data collection and storage is restricted to specific values. For instance, Transaction SU53 only displays a maximum of 100 failed authorization checks within the last 3 hours at most, by default. The number of failed checks and the retention period covered might be smaller if you have many end users with many failed authorization checks all at the same time. You can increase the number of saved authorization failures with profile parameter `auth/su53_buffer_entries`.

In Transaction SU53, you'll see the failed authorization checks for your user. The result list shows you relevant system information, such as the system ID, date, instance, and client. Moreover, you'll see a list of all failed authorization checks, as shown in Figure 7.1, including date, time, type, return code, and specific failed authorizations. In addition to this information, Transaction SU53 displays the application context of the failure, indicating whether the application is a transaction, function module, or Web Service (**Type** field).

Via the header bar in Transaction SU53, you can refresh the current result list to use updated data records, check other end-user authorization failures, or perform stored checks. You can save those checks on the database or as an HTML file. This download is handy if you want to keep the failed authorizations or to share with your support desk because the ring buffer mechanism routinely overwrites its log entries. Furthermore, you can click on any line of the result list and display related authorization object information. Remember, Transaction SU53 only records failed authorization checks and does not display subsequent failed authorization checks in the program flow after the first failed program's authorization check—a significant limitation of this analytical transaction.

Personal Copy for Arun Singal, arun.singal560@gmail.com

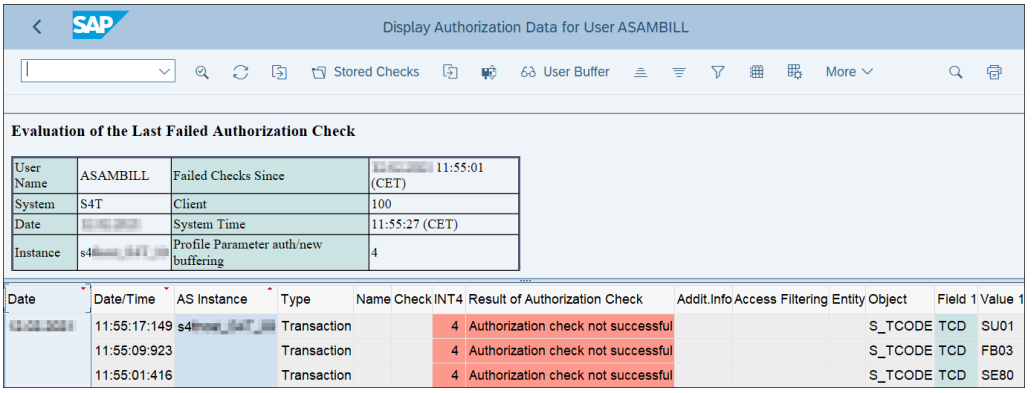


Figure 7.1 Display Authorization Data of Failed Authorization Checks

7.2.2 Authorization Check Failures Evaluation

Once end users run into an authorization issue, they should immediately execute Transaction SU53 and forward a screenshot to the security administrator. This information often allows you to understand the problem and lets you correct the end user's roles.

Hint

Provide Transaction SU53 through a common end-user role to make it available for everyone. For example, a simple screenshot of the fully expanded failed authorization check should provide sufficient information to solve the authorization issue.

You can also directly check missing end-user authorizations by pressing F5 or by clicking the first icon, which display failures for a different end user (not yourself). Then, in the popup window that opens, enter the other user's user name in the **Users** field, as shown in Figure 7.2.

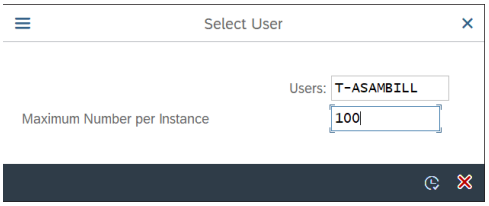


Figure 7.2 Selecting a Different End User

Hint

To view another user's authorization data with Transaction SU53, you must have the authorization object S_USER_GRP with ACTVT = 03 and the corresponding user group.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Figure 7.3 shows you all failed authorization checks of the end user **T-ASAMBILL** within the last 3 hours at the most. The end user could successfully start Transaction **FB03** (Display Documents). An authorization error occurred when **T-ASAMBILL** tried to access documents from company codes (**BUKRS**) **0003** and **0MB1**. Furthermore, this user cannot display general ledger accounts (**S**), customers (**D**), or vendors (**K**).

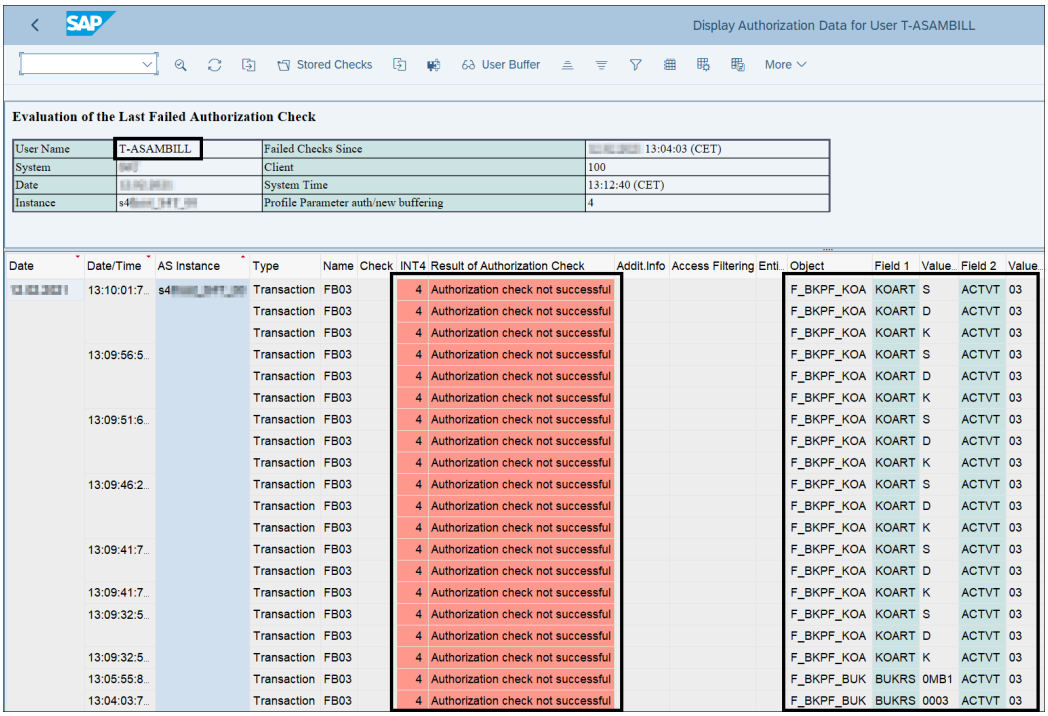


Figure 7.3 Authorization Check Errors for End User T-ASAMBILL

Thus, you can see that end user **T-SAMBILL** needs some additional authorizations or roles. Before you verify these requirements with your business units, you can compare these authorization failures with existing user buffer records. Double-click on a line to get into the user buffer. Another option is to click on the **User Buffer** button located in the header bar. This comparison allows you to evaluate the actual state (which caused the error) with the target state.

7.3 Transactions ST01/STAUTHTRACE

A system trace is a short-term trace option. You can choose between two different applications to run and evaluate a system trace—Transactions ST01 and STAUTHTRACE. These transactions differ by application server (instance) level and in reporting capability. Whereas the trace via Transaction ST01 is an application server-dependent trace, you can run a system-wide trace with Transaction STAUTHRACE. Technically,

Personal Copy for Arun Singal, arun.singal560@gmail.com

Transaction STAUTHTRACE activates the authorization trace of Transaction ST01. If you activate the trace globally through Transaction STAUTHTRACE, the authorization trace (Transaction ST01) is activated on each application server. Transaction STAUTHTRACE allows you to analyze trace data globally (from all application servers), whereas, in Transaction ST01, you can only analyze the local application server. Furthermore, Transaction STAUTHTRACE provides various filter and reporting options for your analysis and evaluation. Based on this data about the application usage of your end users, the system trace allows you to perform the following activities:

- Maintain authorization default values and check indicators
- Maintain the role menu
- Maintain authorization profiles
- Evaluate CDS view authorizations

This section explains the system trace in detail and describes how you can use it to identify missing authorizations.

Hint

See SAP Notes 1707841, 1603756, and 1373111 for additional information about the usage of, conditions for, and functions in the system trace capability.

7.3.1 Description

A system trace is both client and user specific. Each authorization check is recorded with a timestamp and stored in a local trace file. If the maximum size of the trace file is reached, the automatic ring buffer mechanism overwrites the oldest entry with the most recent. Therefore, you should activate the system trace in productive systems (PRDs) only for limited times to reduce the load on the system.

Hint

You can maintain the maximum file size for traces in the administration section in Transaction ST01. Alternatively, you also can increase the maximum size of one trace file (default: 20 MB) through the Transaction RZ11 parameter `rstr/max_filesize_MB`. Furthermore, the maximum number of trace files (default: 10) is adjustable via the profile `parameter rstr/max_files`. For further information, refer to SAP Note 2560768.

Remember that Transaction ST01 is application server dependent and that trace data will only be recorded if the traced user is logged on the same application server. Transaction STAUTHTRACE, on the other hand, allows you to trace application servers independently. In other words, you won't have to activate the trace on each application server. Instead, you can centrally start and stop the trace for all application servers

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

from one application server. Besides, Transaction STAUTHTRACE offers an ALV grid view from which you can drill down into the source code and see more advanced details. Furthermore, you can directly check the documentation and other information for authorization objects. Cross-application features are also offered, for instance, for directly launching into user master data (Transaction SU01), into the user buffer (Transaction SU56) via the **User Buffer** button, and into the CDS access control capability via the **CDS Access Control** button, as shown in Figure 7.4. In contrast, Transaction ST01 only offers line-by-line text, without any sorting or filtering features. Both trace options offer download options for Microsoft Excel, Microsoft Word, and other file formats like HTML.

One advantage of Transaction ST01 is its selection capabilities, which make it helpful in several use cases. You can filter for only failed authorization checks in various contexts, for instance, specific transactions, programs, or function modules. This detailed selection feature allows you to define and save trace targets to reduce the necessary data collection. For instance, you can focus on specific transactions, for instance, only those starting with Z* or Y* to evaluate your custom transactions only. In contrast to Transaction STAUHTTRACE, with Transaction ST01, you do not have to log all data and then filter during evaluation. Transaction STAUTHTRACE allows you to restrict trace collection for failed checks only. Nonetheless, using Transaction STAUHTTRACE is recommended since it lacks application server restrictions. This option also provides a more easy-to-use results overview, with detailed information, and includes cross-application features.

An additional advantage of Transaction STAUTHTRACE, which you can also utilize through STUSOBTRACE and STUSERTRACE, is the **CDS Access Control** button, as shown in Figure 7.4. This function helps check and maintain the CDS entities required by the CDS view's authority checks. Note that you can only click this button when selecting a CDS entity row in the result list.

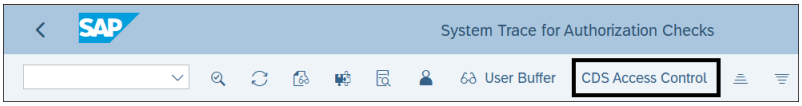


Figure 7.4 CDS Access Control in Transaction STAUTHTRACE

Moreover, Transaction STAUHTTRACE allows you to extend the system trace capability with data from the system kernel (Transaction STAD). For this task, you must select the "Evaluate Extended Passport" filter option in the initial selection screen of the trace evaluation. This option enriches your data, especially for inbound RFC calls, and adds the following columns at the end of the output list:

- **Initial Component**: Adds the calling system, relating application server and client.
- **ActionType**: Adds the type of action, such as transaction call or batch processing.
- **Initial Action**: Adds the transaction or job name.

Personal Copy for Arun Singal, arun.singal560@gmail.com

While you can evaluate the trace directly with the intended system trace transactions, SAP also provides some indirect cross-application features. The first is to use the trace in Transaction SU24 to maintain your proposals and check indicators based on the log entries generated by various traces, as shown in Figure 7.5.

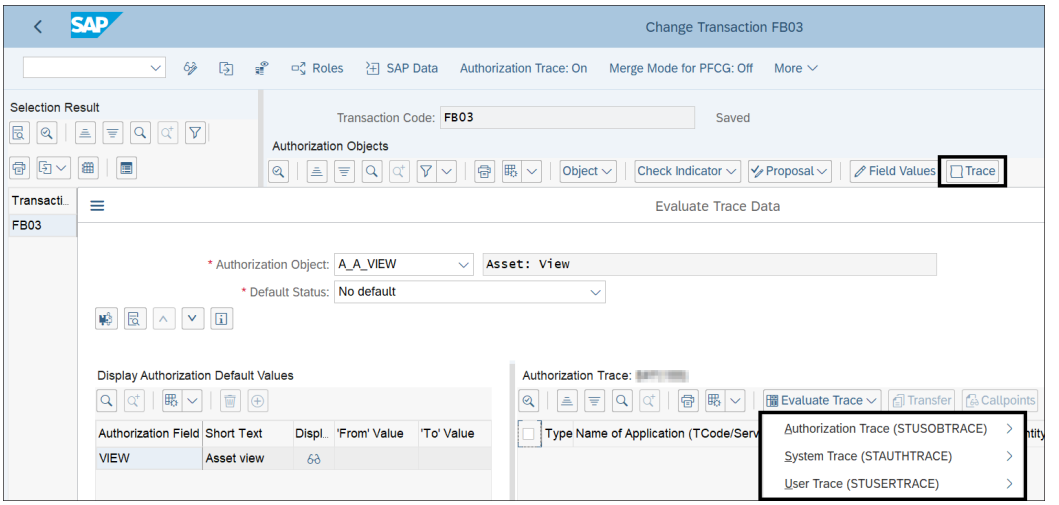


Figure 7.5 Proposal Maintenance in Transaction SU24 Based on Traces

Hint

Chapter 5, Section 5.4, explains the process of maintaining authorization default values based on traces.

You can also use the system trace to create and maintain your role menu in Transaction PFCG. In this way, you'll create a role menu based on your actual end-user trace data. This option is also handy to directly use trace data for maintaining your authorization profiles in the profile generator.

Hint

For detailed explanations about using the system trace within the profile generator, see Chapter 6, Section 6.4.7.

7.3.2 Trace Evaluation for an Authorization Error

Suppose an end user has authorization issues when executing a transaction or a program or when processing data. This error mainly occurs due to missing authorizations. To analyze missing authorizations, activate the system trace to see what authority checks the system has performed and which checks failed for the end user. For

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

instance, activate the trace on the PRD with Transaction STAUTHTRACE and a specific end user (in our example, **T-ASAMBILL**), as shown in Figure 7.6.

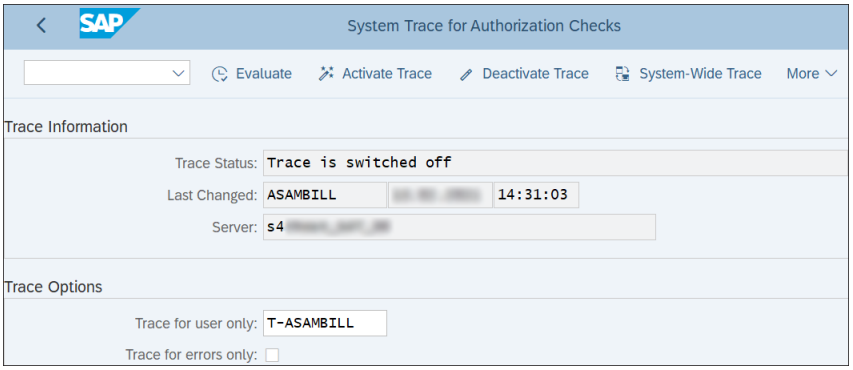


Figure 7.6 System Trace Activation for a Specific End User

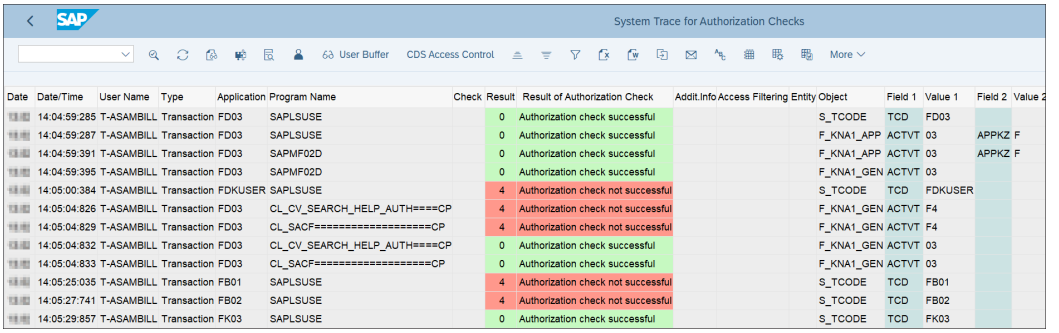
Once you switch on the system trace, the system automatically logs the authorization checks for **T-ASAMBILL**. Depending on whether you've selected the **Trace for errors only** checkbox, the trace file may only contain failed authorization checks. After you trace the end user, you can switch off the trace and start your trace analysis. If you know the applications causing issues, you can filter the data to these applications during evaluation to reduce the number of results to analyze. In addition, you can use the option to filter duplicate entries.

Hint

Please note that, if you've assigned a `REFERENCE` user to a `DIALOG` user, the system analyzes the authorization of the `REFERENCE` user in the user buffer first. If the authorization is not sufficient, then the directly assigned authorizations in the buffer are checked next. See SAP Note 1960916 for more information.

Figure 7.7 shows you the result list of the system trace. Notice that some authorization checks have passed, and others have failed. Particularly interesting are the failed checks marked in red. The return code of an authority check indicates why the check failed and what was missing. Any return code larger than 0 indicates that the authorization check failed, and the system provides more details of what was missing. Check the return code table in Section 7.1.2 for further interpretations of the failures. Another option is to press F1 for the selected return code. In the evaluation list shown in Figure 7.7, notice that entries with the return code **4**, which indicates that the end user has the required authorization objects but not the correct authorization field values in the user buffers. Thus, user **T-ASAMBILL** requires the additional Transactions **FB01**, **FB02**, **FK03**, or **FD03**.

Personal Copy for Arun Singal, arun.singal560@gmail.com



Date	Date/Time	User Name	Type	Application	Program Name	Check	Result	Result of Authorization Check	Addit.Info	Access Filtering Entity	Object	Field 1	Value 1	Field 2	Value 2
[redacted]	14:04:59:285	T-ASAMBILL	Transaction	FD03	SAPLSUSE		0	Authorization check successful			S_TCODE	TCD	FD03		
[redacted]	14:04:59:287	T-ASAMBILL	Transaction	FD03	SAPLSUSE		0	Authorization check successful			F_KNA1_APP	ACTVT	03	APPKZ	F
[redacted]	14:04:59:391	T-ASAMBILL	Transaction	FD03	SAPMF02D		0	Authorization check successful			F_KNA1_APP	ACTVT	03	APPKZ	F
[redacted]	14:04:59:395	T-ASAMBILL	Transaction	FD03	SAPMF02D		0	Authorization check successful			F_KNA1_GEN	ACTVT	03		
[redacted]	14:05:00:384	T-ASAMBILL	Transaction	FDKUSER	SAPLSUSE		4	Authorization check not successful			S_TCODE	TCD	FDKUSER		
[redacted]	14:05:04:826	T-ASAMBILL	Transaction	FD03	CL_CV_SEARCH_HELP_AUTH====CP		4	Authorization check not successful			F_KNA1_GEN	ACTVT	F4		
[redacted]	14:05:04:829	T-ASAMBILL	Transaction	FD03	CL_SACF====================CP		4	Authorization check not successful			F_KNA1_GEN	ACTVT	F4		
[redacted]	14:05:04:832	T-ASAMBILL	Transaction	FD03	CL_CV_SEARCH_HELP_AUTH====CP		0	Authorization check successful			F_KNA1_GEN	ACTVT	03		
[redacted]	14:05:04:833	T-ASAMBILL	Transaction	FD03	CL_SACF====================CP		0	Authorization check successful			F_KNA1_GEN	ACTVT	03		
[redacted]	14:05:25:035	T-ASAMBILL	Transaction	FB01	SAPLSUSE		4	Authorization check not successful			S_TCODE	TCD	FB01		
[redacted]	14:05:27:741	T-ASAMBILL	Transaction	FB02	SAPLSUSE		4	Authorization check not successful			S_TCODE	TCD	FB02		
[redacted]	14:05:29:857	T-ASAMBILL	Transaction	FK03	SAPLSUSE		0	Authorization check successful			S_TCODE	TCD	FK03		

Figure 7.7 Trace for End User T-ASAMBILL in Transaction STAUTHTRACE

In contrast, Transaction FDKUSER is only background noise. The transaction is unnecessary for a particular program's access or function, but many finance transactions will call Transaction FDKUSER behind the scenes. Thus, while perhaps necessary for cross-application features, this transaction is rarely required for direct transaction usage, unlike Transaction FB01. Authorization objects like S_ALV*, S_TRANSLAT*, or S_PROJECT *are further candidates that produce background noise because these objects are often checked based on the program code but not required for the functional usage of most applications. Also, the authorization value "F4" for the authorization object F_KNA1_GEN is missing in our example shown in Figure 7.7.

Thus, you must contact the responsible business department to clarify whether the end user needs an additional role or whether you can adjust an existing role.

Hint

For Basis version release 7.53, SAP introduced a new authorization check to protect the available system status information. The content popup window that displays the system status in the session manager is now restricted through authorization object S_SYS_INFO. Note that you won't see this authorization object while you trace for this specific authorization check error. Thus, administrators especially need the following authorization fields and their values in their user buffers to provide access to the user information they will need:

- ACTVT:
  - 03 (Display)
- INFO:
  - USER to display the **User data** section
  - SYSTEM to display the **SAP System** data section
  - HOST to display the **Host data** section
  - DB to display the **Database data** section

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- KERNEL to display the **Kernel information** section
- * to display everything

SAP also provides an official SAP Note for further information: SAP Note 2658772.

7.4 Transaction STUSOBTRACE

Whereas you can use the system trace as a short-term trace option, the authorization trace (Transaction STUSOBTRACE) constitutes a long-term trace. This trace collects data from all application servers, clients, and end users and is consequently also a system-wide trace. Transaction STUSOBTRACE records authorization checks for an application and is primarily designed to maintain the authorization proposals and check indicators of applications in Transaction SU24.

Hint

For further details about Transaction SU24 and authorization proposals, see Chapter 5.

In addition, you can use this trace method as a source for maintaining role menus or authorization profiles, although this approach is not recommended because the trace contains application-dependent information, not information for a specific user or a job function. To analyze end-user authorization issues, the better approach is to use the system trace or user trace functionalities.

This section introduces you to Transaction STUSOBTRACE and selected technical details. We'll also describe how to work with authorization traces to maintain your authorization concept, especially default data in Transaction SU24.

Hint

You can find more information regarding authorization traces in SAP Note 1866210.

7.4.1 Description

SAP itself uses the authorization trace via Transaction STUSOBTRACE to determine the required authorization default values (e.g., for transactions, function modules, and Web Services in Transaction SU22). Before you can start your trace evaluation, you'll need to activate the profile parameter auth/authorization_trace. The activation of this parameter might affect system performance. On non-PRDs, however, you can activate the trace permanently to record authorization checks in the context of your applications.

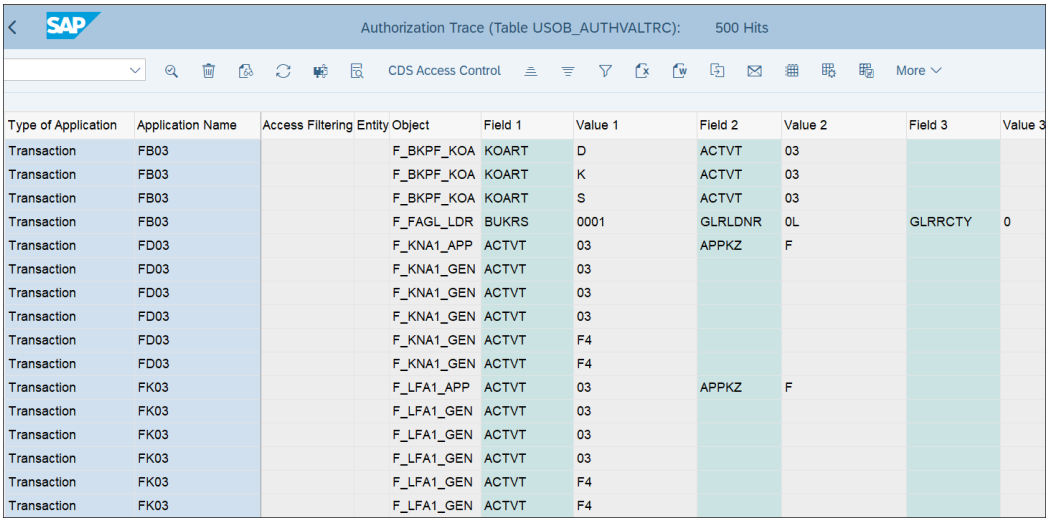
Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Section 7.1.3 describes how to activate the appropriate profile parameter to use Transaction STUSOBTRACE.

When the trace has been activated, the system records all trace data in the database table USOB_AUTHVALTRC. Transaction STUSOBTRACE does not overwrite the trace data but instead records each authorization check (as authorization object, field, and value) once per application only. When activating the trace, you can set filters for up to 5 end users as well as up to 5 authorization objects. Since Transaction STUSOBTRACE is the intended trace to capture authorization checks for an application regardless of the end user, the user information is secondary, and authorization checks are only recorded once per application—not once per user. Transaction STUSOBTRACE's trace information can be a great source to help you evaluate and maintain proposals and check indicators for custom developments.

Figure 7.8 shows an example of the system trace result list.



Type of Application	Application Name	Access Filtering Entity	Object	Field 1	Value 1	Field 2	Value 2	Field 3	Value 3
Transaction	FB03		F_BKPF_KOA	KOART	D	ACTVT	03		
Transaction	FB03		F_BKPF_KOA	KOART	K	ACTVT	03		
Transaction	FB03		F_BKPF_KOA	KOART	S	ACTVT	03		
Transaction	FB03		F_FAGL_LDR	BUKRS	0001	GLRLDNR	0L	GLRRCTY	0
Transaction	FD03		F_KNA1_APP	ACTVT	03	APPKZ	F		
Transaction	FD03		F_KNA1_GEN	ACTVT	03				
Transaction	FD03		F_KNA1_GEN	ACTVT	03				
Transaction	FD03		F_KNA1_GEN	ACTVT	03				
Transaction	FD03		F_KNA1_GEN	ACTVT	F4				
Transaction	FD03		F_KNA1_GEN	ACTVT	F4				
Transaction	FK03		F_LFA1_APP	ACTVT	03	APPKZ	F		
Transaction	FK03		F_LFA1_GEN	ACTVT	03				
Transaction	FK03		F_LFA1_GEN	ACTVT	03				
Transaction	FK03		F_LFA1_GEN	ACTVT	03				
Transaction	FK03		F_LFA1_GEN	ACTVT	F4				
Transaction	FK03		F_LFA1_GEN	ACTVT	F4				

Figure 7.8 Trace Results in Transaction STUSOBTRACE

Various features are available to further process this trace data, as shown in Figure 7.8, such as the following:

- Deleting specific data records
- Displaying AUTHORITY-CHECK statements in the source code
- Displaying information and documentation of the authorization object
- Accessing the **CDS Access Control**
- Downloading and uploading this data, with filter capabilities

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The download and upload options are important when activating traces in a PRD. Trace information can be captured in production while processing in development to optimize Transaction SU24 authorization proposals.

Hint

You can find more information regarding Transaction STUSOBTRACE in SAP Note 1866210.

7.4.2 Authorization Default Value Maintenance

Transaction STUSOBTRACE allows you to maintain authorization default values in Transaction SU24 for any application, including custom developments as well as custom transactions (e.g., parameter transactions).

For instance, suppose you have a parameter transaction for Transaction SE16 for a specific table with or without inheritance from that parent transaction activated. In Transaction SU24, you lack proposals for the required table authorizations for the custom application (**Z_USER**), as shown in Figure 7.9.

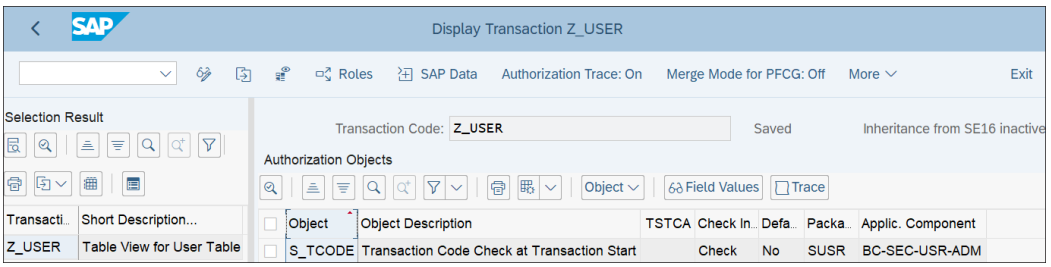


Figure 7.9 Custom Transaction Z_USER in Transaction SU24

Hint

When creating custom transactions, as a good practice, adopt transaction names and write short descriptions that capture your application's intention. Establish a naming convention also for custom transaction names. For example, instead of using transaction names like Transaction Z_USER for table access to table USR02, call it Transaction ZSE16_USR02. Also, use short descriptions to communicate your intention (e.g., "Table View for Table USR02" or "Table View for User Master Record Data").

When tracing applications, you can activate the authorization trace with filter (F) option. Then, launch Transaction STUSOBTRACE and filter for transactions by clicking on the **Change Filter** button. Please note that you cannot filter for specific applications but for users and authorization objects only. The authorization trace logs all authorization checks within the context of the application (e.g., start authorizations, program

Personal Copy for Arun Singal, arun.singal560@gmail.com

authority checks). Transaction STUSOBTRACE logs every authorization check only once and is therefore suitable for long-term activation. Consider that the more you functions you use within an application, the more authority checks are involved based on the program code. Consequently, your trace results will also increase. For the evaluation of the trace data, you can use various filters to select the data, like transactions. Figure 7.10 shows the recorded authorization checks for Transaction Z_USER. Remember that Transaction STUSOBTRACE logs unique authorization checks only and is independent of the user executing it.

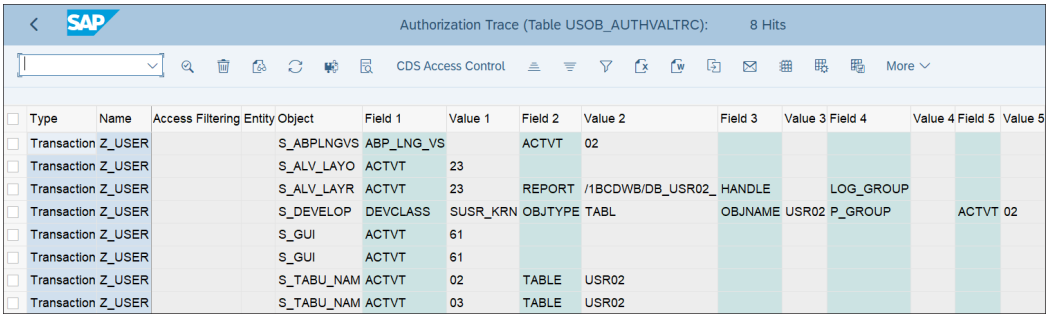


Figure 7.10 Trace Output List in Transaction STUSOBTRACE

As you know from your development department, they only need a display-only table transaction. On that basis, you only need the activity (**ACTVT**) for display (**03**) regarding the authorization object **S_TABU_NAM**. The corresponding table is **USR02** because the custom transaction should only give one table access and not additional access through cross-application features in table USR02. The other authorization objects like **S_ALV_LAYO**, **S_ALV_LAYR**, or **S_DEVELOP** are not required for specific table display-only access. Finally, maintain the findings in Transaction SU24 for the application, as shown in Figure 7.11.

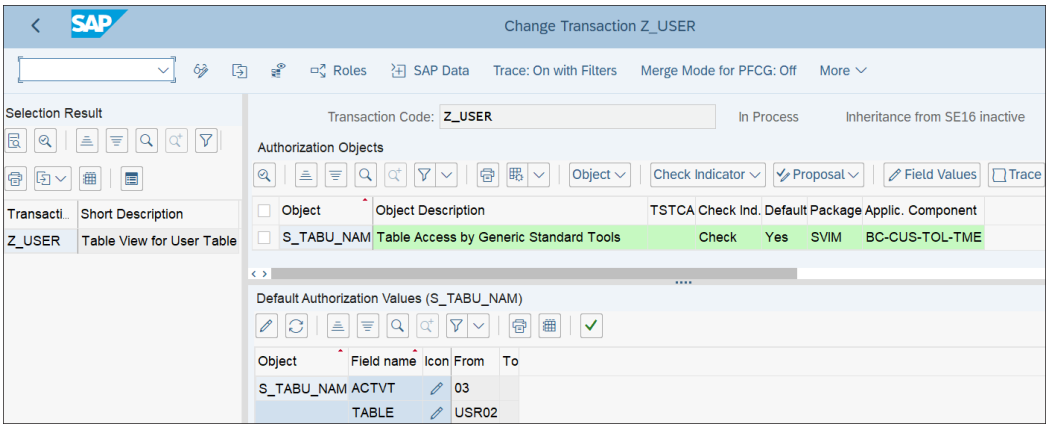


Figure 7.11 Proposal Maintenance for Transaction Z_USER

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

You can abstract this approach according to existing custom developments to enrich your proposal setup. Additionally, you can use Transaction STUSOBTRACE to maintain authorization default values in alignment with your business processes. Please do not maintain such business proposals unilaterally; always consult the related business units. In this way, you can reduce your role maintenance effort and reach consensus on the individualization of your authorization concept.

Hint

Note that you can also use the authorization trace as a data source in Transactions PFCG and SU24, as described in Section 7.3.

7.5 Transaction STUSERTRACE

Similar to an authorization trace, a user trace is also a long-term trace that is client and end user specific. Thus, you can evaluate authorization checks in the end user's context. In contrast to a system trace, Transaction STUSERTRACE records the authorization checks (as authorization object, field, and value) only once per application and per end user, which allows you to analyze users' authorizations over the long term. Similar to system and authorization traces, you can use a user trace to adjust role menus, authorization profiles, and Transaction SU24 data.

Hint

SAP Notes 2220030, 2421733, and 2437980 contain essential information about utilizing this tracing method.

The system stores the user trace data records in a database table (table SUAUTHVALTRC). You can activate the user trace with the profile parameter auth/auth_user_trace. We recommend activating the trace with filter (F) since the trace can impact system performance if no filter is applied. The functionalities and evaluation capabilities found in Transaction STUSERTRACE are similar to Transaction STAUTHTRACE. You can utilize the user trace to adjust role menus, authorization data, and authorization default values.

When activating the user trace with filters, you can limit the trace to up to 2 application types (e.g., transactions, function modules, background jobs, etc.), for up to 10 users, and up to 10 authorization objects. In this section, we'll introduce you to the technical user trace capabilities and the evaluation of end-user trace records through Transaction STUSERTRACE to help you resolve authorization issues. Additionally, you'll learn about the capabilities available in Transaction STSIMAUTHCHECK and how to simulate your roles against testing trace logs.

Personal Copy for Arun Singal, arun.singal560@gmail.com

7.5.1 Evaluation of Specific Job Functions

A user trace can be used to evaluate the consistency of different business job functions and related roles in your role concept. With this trace, you can verify whether your role concepts cover the applications and processes required for the tasks of specific end users.

For instance, suppose you need to check whether the financial clerk's current job function roles cover the authorizations required to perform those business processes. First, start the trace with filters via Transaction RZ11 and filter for the end user who represents the financial clerk, as shown in Figure 7.12 for our example, **T-ASAMBILL**. Additionally, you can also select options from the **Type of Application** dropdown list (i.e., **Transactions**) or leave this field empty to cover other applications like function modules and SAP Fiori applications as well.

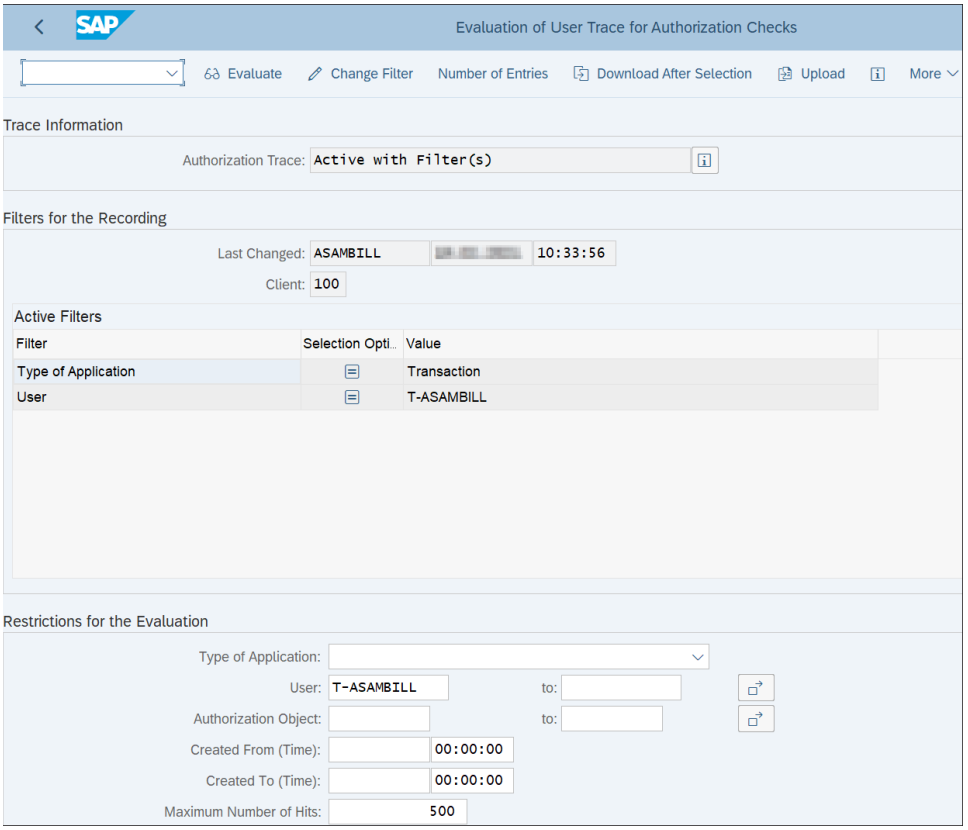
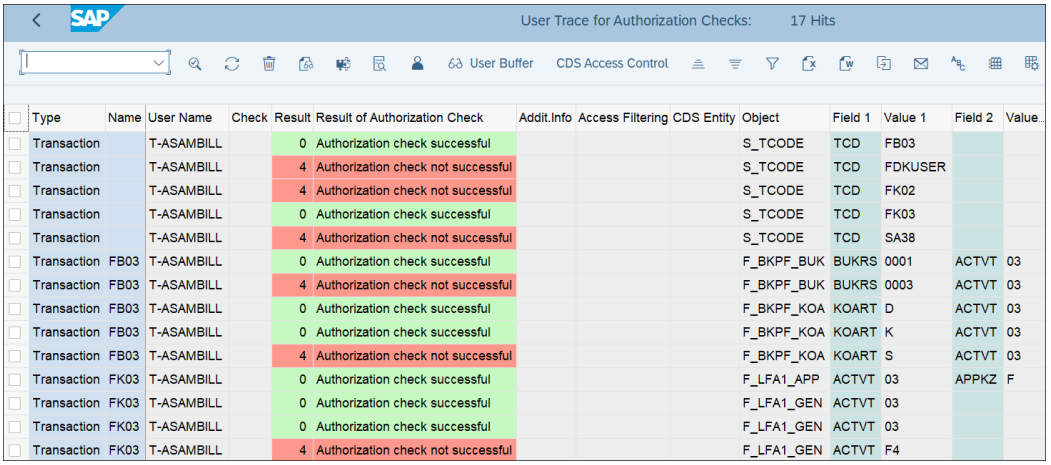


Figure 7.12 Activated Filters and Trace Evaluation Scope in Transaction STUSERTRACE

Once the data has been collected, you can start the analysis. Filter the data to the end user (**T-ASAMBILL**) and click on **Evaluate**, as shown in Figure 7.12. The output list shows a list of all user-specific authorization checks, both successful and unsuccessful, within

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

the trace period, as shown in Figure 7.13. Validate these findings in collaboration with your business process owners. For instance, Transaction SA38 is a critical transaction that allows for program access, which you should generally assign to business users. In contrast, Transactions FKO2 and FKO3 are financial applications that might be required in the financial job function role to cover various processes. Together with your business process owners, decide which applications and authorizations are required and expand your roles accordingly. The trace information provides all the details you need to update these roles. Remember that you can also use the integration within Transaction PFCG to optimize role menus based on trace data.



Type	Name	User Name	Check	Result	Result of Authorization Check	Addit.Info	Access Filtering	CDS Entity	Object	Field 1	Value 1	Field 2	Value...
Transaction		T-ASAMBILL		0	Authorization check successful				S_TCODE	TCD	FB03		
Transaction		T-ASAMBILL		4	Authorization check not successful				S_TCODE	TCD	FDKUSER		
Transaction		T-ASAMBILL		4	Authorization check not successful				S_TCODE	TCD	FK02		
Transaction		T-ASAMBILL		0	Authorization check successful				S_TCODE	TCD	FK03		
Transaction		T-ASAMBILL		4	Authorization check not successful				S_TCODE	TCD	SA38		
Transaction	FB03	T-ASAMBILL		0	Authorization check successful				F_BKPF_BUK	BUKRS	0001	ACTVT	03
Transaction	FB03	T-ASAMBILL		4	Authorization check not successful				F_BKPF_BUK	BUKRS	0003	ACTVT	03
Transaction	FB03	T-ASAMBILL		0	Authorization check successful				F_BKPF_KOA	KOART	D	ACTVT	03
Transaction	FB03	T-ASAMBILL		0	Authorization check successful				F_BKPF_KOA	KOART	K	ACTVT	03
Transaction	FB03	T-ASAMBILL		4	Authorization check not successful				F_BKPF_KOA	KOART	S	ACTVT	03
Transaction	FK03	T-ASAMBILL		0	Authorization check successful				F_LFA1_APP	ACTVT	03	APPKZ	F
Transaction	FK03	T-ASAMBILL		0	Authorization check successful				F_LFA1_GEN	ACTVT	03		
Transaction	FK03	T-ASAMBILL		0	Authorization check successful				F_LFA1_GEN	ACTVT	03		
Transaction	FK03	T-ASAMBILL		4	Authorization check not successful				F_LFA1_GEN	ACTVT	F4		

Figure 7.13 Trace Records Evaluation in Transaction STUSERTRACE

7.5.2 Using Transaction STSIMAUTHCHECK

With the user trace, you can use an additional authorization analysis tool with Transaction STSIMAUTHTRACE. This application enables you to simulate whether the recorded authorization checks would succeed for selected user. You can run this simulation for all end-user authorizations or for the authorizations from assigned roles only. Transaction STSIMAUTHCHECK reads user trace data from a local or remote system. Thus, this simulation requires an existing list of authorization check records (user trace data) for the business scenarios you want to examine, which means you must have run a user trace previously. With this information, this application enables you to, for example, check the effects of a new role concept. You can compare the simulation results in a development system (DEV) with the authorization check results from the user trace in another system (e.g., PRD).

For instance, suppose you want to check whether your newly created finance job role would work for existing users. Activate the user trace on the PRD or quality system (QAS) and wait until the required users have been traced and have performed their predefined job tasks and scenarios. For example, if you activate the trace on the QAS, the

Personal Copy for Arun Singal, arun.singal560@gmail.com

tester (ASAMBILL) must reproduce the desired business scenarios. Then, you can execute Transaction STSIMAUTHTRACE and select this user for simulation (**T-ASAMBILL**). Select the **Only Authorizations from Assigned Roles** radio button and specify the source role **ZP_ME_FI_N_GLOB_ACC** in the associated field. Finally, select the **Use Mapping Table** radio button, as shown in Figure 7.14.

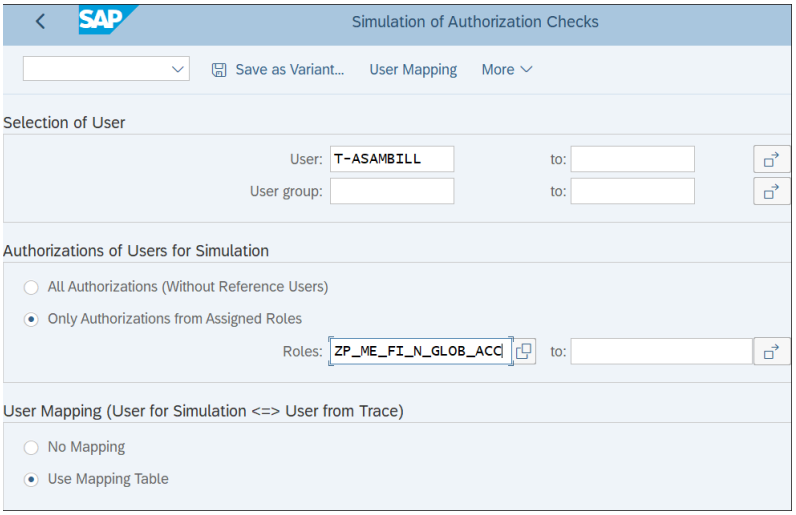


Figure 7.14 Simulation of Authorization Checks Selection Mask

Hint

For remote simulation, enter the RFC destination and make sure that the RFC user is authorized to the RFC function module SUAUTH_READ_TRACE_VALUES with authorization object S_ADMI_FCD and value STUR.

Note that, if you want to use different user names for the simulation, you'll utilize a user mapping. In this table, you can map your test user (**ASAMBILL**) to a user for simulation (**T-ASAMBILL**), for instance, who may have the new job role assigned on the DEV, as shown in Figure 7.15.

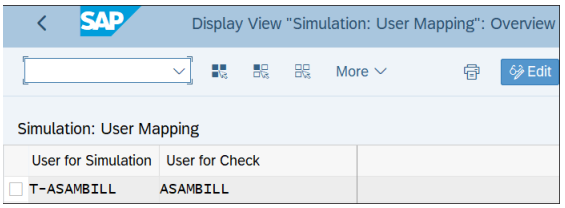
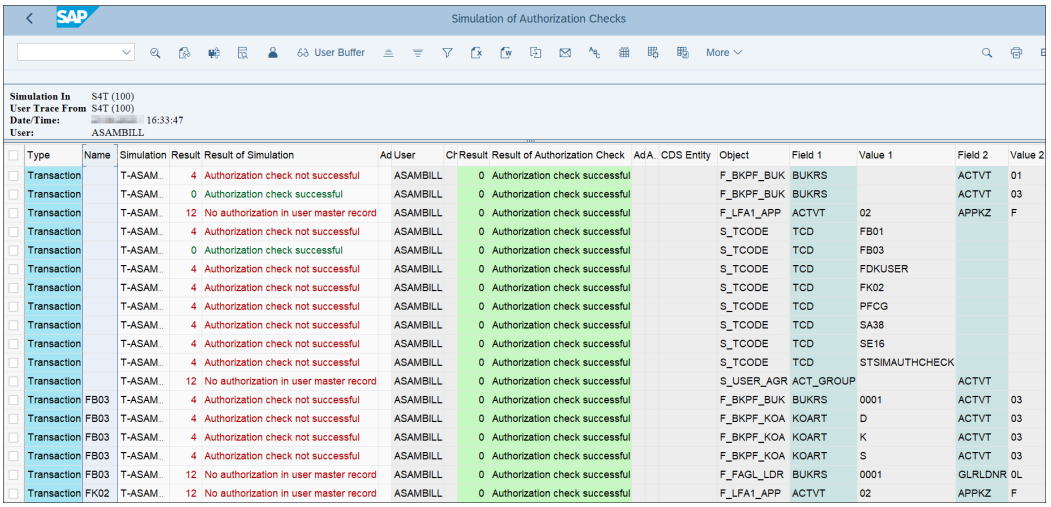


Figure 7.15 Simulation: Check User Mapping

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

After this preparatory step, execute your selection. You'll see both successful (already maintained authorizations in the assigned roles) and unsuccessful authorization checks (not maintained authorizations). Furthermore, the application shows you missing authorizations in the user master record. All this data is based on the actions of the user **ASAMBILL** compared to the simulation user with the assigned accounting role **T-SAMBILL**, as shown in Figure 7.16.

The simulation of end-user roles allows for more efficient analysis when creating or updating your role concept.



Type	Name	Simulation	Result	Result of Simulation	Ad	User	Cl	Result	Result of Authorization Check	AdA..	CDS Entity	Object	Field 1	Value 1	Field 2	Value 2
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			F_BKPF_BUK	BUKRS		ACTVT	01
Transaction		T-ASAM..	0	Authorization check successful		ASAMBILL		0	Authorization check successful			F_BKPF_BUK	BUKRS		ACTVT	03
Transaction		T-ASAM..	12	No authorization in user master record		ASAMBILL		0	Authorization check successful			F_LFA1_APP	ACTVT	02	APPKZ	F
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	FB01		
Transaction		T-ASAM..	0	Authorization check successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	FB03		
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	FDKUSER		
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	FK02		
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	PFCG		
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	SA38		
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	SE16		
Transaction		T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			S_TCODE	TCD	STSIMAUTHCHECK		
Transaction		T-ASAM..	12	No authorization in user master record		ASAMBILL		0	Authorization check successful			S_USER_AGR	ACT_GROUP		ACTVT	
Transaction	FB03	T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			F_BKPF_BUK	BUKRS	0001	ACTVT	03
Transaction	FB03	T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			F_BKPF_KOA	KOART	D	ACTVT	03
Transaction	FB03	T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			F_BKPF_KOA	KOART	K	ACTVT	03
Transaction	FB03	T-ASAM..	4	Authorization check not successful		ASAMBILL		0	Authorization check successful			F_BKPF_KOA	KOART	S	ACTVT	03
Transaction	FB03	T-ASAM..	12	No authorization in user master record		ASAMBILL		0	Authorization check successful			F_FAGL_LDR	BUKRS	0001	GLRLDNR	0L
Transaction	FK02	T-ASAM..	12	No authorization in user master record		ASAMBILL		0	Authorization check successful			F_LFA1_APP	ACTVT	02	APPKZ	F

Figure 7.16 Trace Data Simulation Results

Hint

See SAP Note 2442227 for further details about the simulation of authorization checks.

7.6 Authorization Debugging

In certain cases, tracing authorization issues is insufficient or doesn't help you get to the root cause of an authorization issue. Also, as a more advanced security administrator, you'll need to utilize authorization debugging to better understand how specific applications work. For example, suppose we want to understand at which point a particular authorization object and its value are checked.

Debugging, in general, is a sensitive topic and requires critical authorizations. To access debugging, you require the authorization object S_DEVELOP with value `DEBUG` in field `OBJTYPE`. When debugging in productive environments, one shall not be allowed to

Personal Copy for Arun Singal, arun.singal560@gmail.com

change/replace variables which is controlled with the ACTVT field and value "02" (change).

Tip

Debug and replace is the ability to change the values of variables during a debugging session. With debug and replace, a user can change the behavior of some program logic or manipulate data during the debugging session. This feature enables you to lever out any system or program authorization checks. This authorization is critical and must be avoided in PRD. The system log (Transaction SM21) allows you to record debug and replace activities.

Debugging is the ability to intercept the program execution and advance step by step through the program code. For example, during a debugging session, you can see how the values of variables (e.g., of an authorization check, a value inserted into a table, etc.) may change and follow the program execution. To start debugging, *breakpoints* are essential since they allow you to stop the code processing at the code line you specify for individual code statements like AUTHORITY-CHECK or table names. A breakpoint comes in the form of a session breakpoint, hard-coded into the program code.

Figure 7.17 shows an active debugging session with the following two breakpoints:

- Line 17 is a hard-coded breakpoint with the BREAKPOINT statement.
- Line 19 is a session breakpoint.

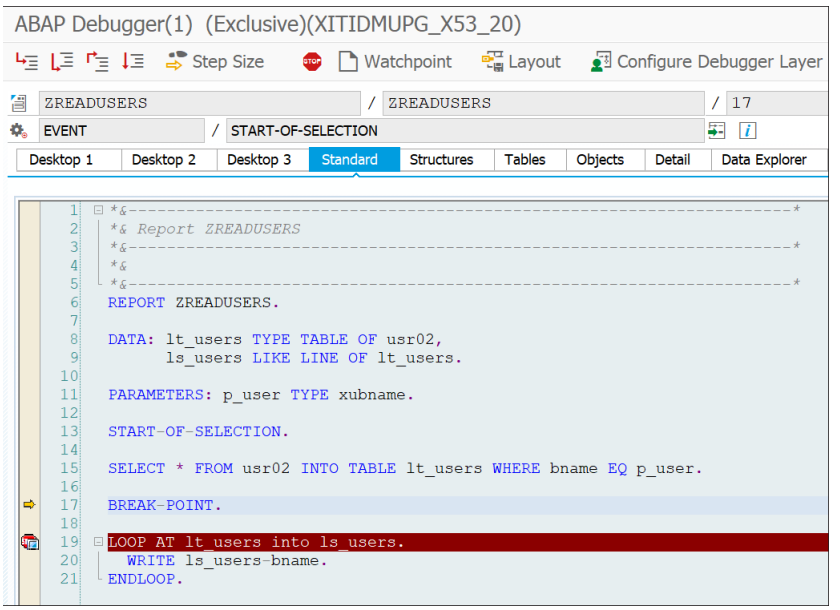


Figure 7.17 ABAP Debugger

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Session breakpoints are temporary and will intercept the program execution only for the user who set it. Hard-coded breakpoints, on the other hand, are permanent (as long as they exist in the code) and will intercept the program for any user during dialog sessions. Hard-coded breakpoints must never find their way into PRDs.

Note

The ABAP statement `BREAKPOINT` behaves differently depending on how it has been implemented in the code and the type of execution of the session (i.e., dialog session, etc.).

Session breakpoints can be used in different ways. The most common way is to enter the command `/h` during an SAP GUI session in the command box. This command will set a temporary breakpoint at the next executable position. For example, Figure 7.18 shows the initial screen of Transaction SU01 and executing command **/h**.

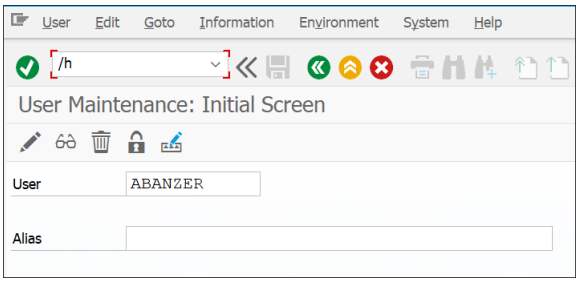


Figure 7.18 Activating a Session Breakpoint

After you press Enter, the status bar will indicate that **debugging is switched on**, as shown in Figure 7.19.

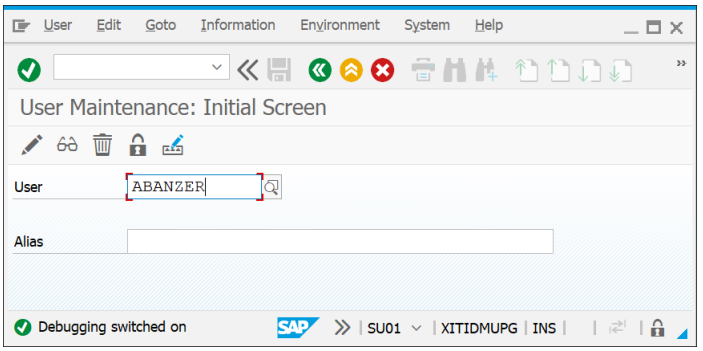


Figure 7.19 Debugging Switched On

Once debugging has been switched on, you can execute any command within Transaction SU01, and the debugger will intercept the command. For our example, we chose to

Personal Copy for Arun Singal, arun.singal560@gmail.com

display the user master of user **ABANZER**. As soon as you click the display icon (or any other button), the debugger starts, as shown in Figure 7.20. In the debugger session, a yellow arrow indicates the next executable command. The debugger offers different ways to navigate through the program code. To navigate, press the F5, F6, F7, and F8 keys or click the icons in the navigation bar, as shown in Figure 7.20.

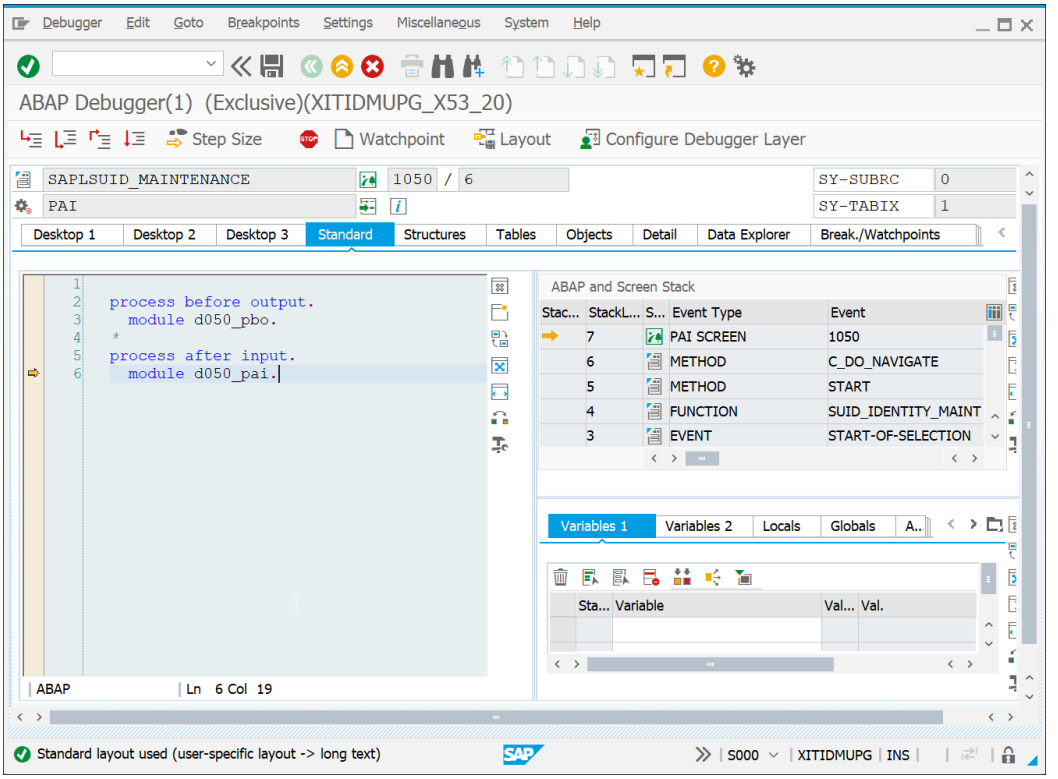


Figure 7.20 Session Debugger

The navigation keys are defined in the following way:

- F5 Single Step: the debugger proceeds one step at a time.
- F6 Execute: allows you to execute a step without going into the called program or module.
- F7 Return: allows you to continue the code and return to the next higher layer of code.
- F8 Continue: the debugger continues until the next breakpoint or the end of the program.

An important concept to understand is that ABAP code is built in a modular way, which means that one program might call others. Therefore, you must understand the differences between the navigation steps and when to use them to your advantage when

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

debugging. The single step key F5 allows you to go one step at a time and follow the code to deeper levels but is slow for navigating throughout extensive code. The execute step F6 is helpful when you want to stay in the layer of code you're currently in without following the code to a deeper level. When pressing F6, the code on the deeper level will be executed automatically without the need to advance one step at a time. The return step F7 is helpful when you've followed the code to a deeper level, but you want to return to the next higher layer without advancing every single step. The continue step F8 allows the code to continue until another breakpoint is reached or the program code comes to an end.

Let's return to our example with Transaction SU01 and our debugging session accessed by the /h command. As shown in Figure 7.20, the debugger is currently waiting on line 6. Since you don't want to advance step by step, and you don't know anything about the code and the program in general, you want to advance to the next authorization check. Authorization checks are mostly implemented with the `AUTHORITY-CHECK` statement in ABAP.

The debugger allows you to create breakpoints to serve as watchpoints during a debugging session. While in the debugger, you can create a breakpoint under the **Breakpoint/Watchpoint** tab. Figure 7.21 shows the creation of a breakpoint for the ABAP command **AUTHORITY-CHECK**.

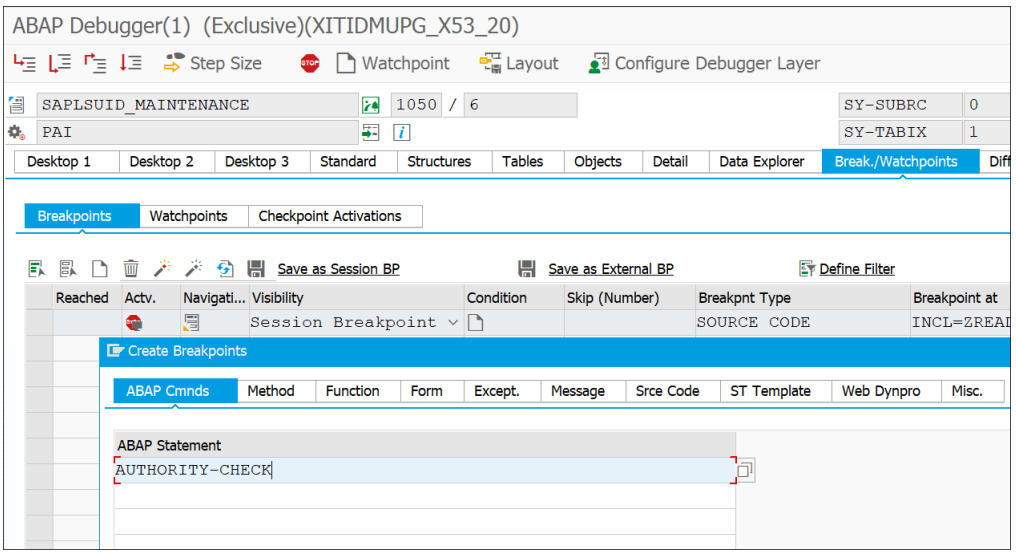


Figure 7.21 Creating Breakpoints in ABAP Debugger

Once the breakpoint has been set, you can continue the code execution with the navigation step continue F8. Remember, F8 will continue until it reaches the next breakpoint, or the program comes to an end. As shown in Figure 7.22, the debugger has multiple breakpoints (highlighted in green) set for all **AUTHORITY-CHECK** statements.

Personal Copy for Arun Singal, arun.singal560@gmail.com

The yellow arrow indicates that the debugger has stopped the code on line 37. Notice how an **AUTHORITY-CHECK** statement has been implemented for authorization object **S_USER_GRP**. The check occurs for two authorization fields: **CLASS** and **ACTVT**. Both fields are evaluated with a variable, shown on the right side of the **Variables 1** window. You can either double-click on a variable on the left and drag it into the **Variables** screen or manually enter a variable name. The variable window also shows you the current values of the variables. In our example shown in Figure 7.22, the value for variable **IV_GRP** that is used for the **CLASS** field is **SUPER**, and the value variable **IV_ACT** for the **ACTVT** field is **03**.

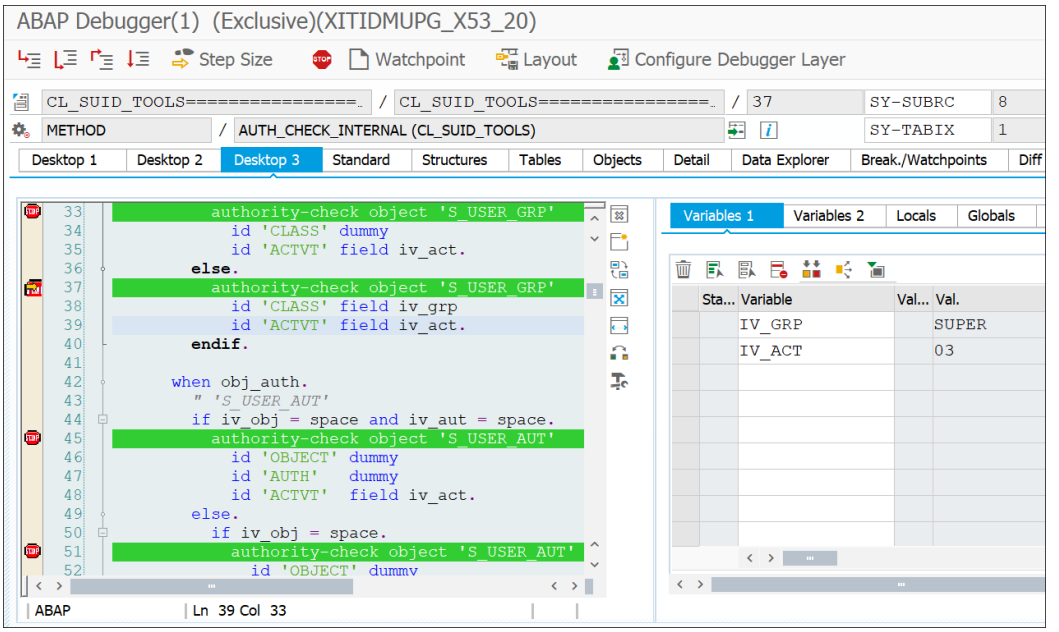


Figure 7.22 Active Breakpoints in the ABAP Debugger

Besides AUTHORITY-CHECK statements, you can also set breakpoints for any other ABAP statements. The MESSAGES statement is helpful to issue error/warning messages that take you to the code location where the error occurs. For example, Figure 7.23 shows an error message for a user that is missing authorizations to evaluate trace data. However, in the authorization trace as well as in Transaction SU53, no missing authorizations are visible.

To understand the issue at hand, a helpful approach is to use debugging and set a breakpoint for that specific message that is shown. The help button F1 will provide more detail about the error message, as shown in Figure 7.24. The performance assistant indicates that the error message that we've received comes from message number TCO53. With this information at hand, you can start a debugging session and specifically look out for that message number.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

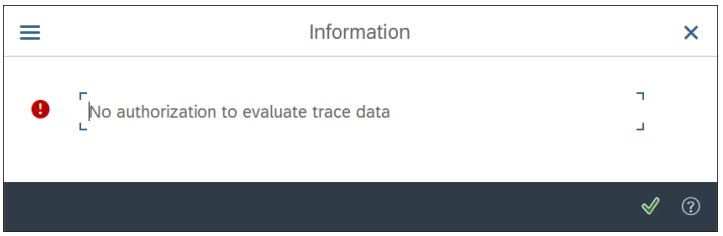


Figure 7.23 Error Message during Program Execution

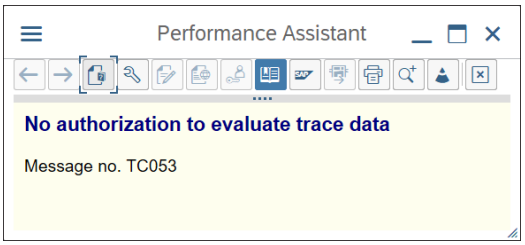


Figure 7.24 Performance Assistant for Error Message

To start the session debugging, use the command /h before executing the program that leads to the error message. Once you execute the program, the ABAP Debugger will start. In the ABAP Debugger, create a breakpoint for **Message TC053**, as shown in Figure 7.25.

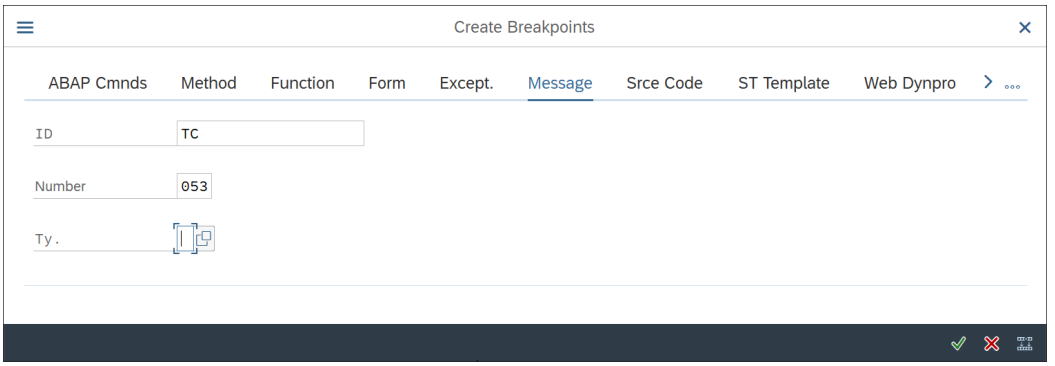


Figure 7.25 Creating Breakpoints in the ABAP Debugger

Once the breakpoint has been created, you can advance the code with the continue F8 key. If you advance and switch to either of the desktop tabs in the ABAP Debugger, you'll see that the code has stopped at the **Message** statement. As shown in Figure 7.26, the error message is written on line 17. Since this message is an error message, you must understand and analyze the code beforehand to understand what the issue is. In this example, the code calls a function module **AUTHORITY_CHECK_TCODE** to check the users' authorizations to a transaction. The function module returns a value that

Personal Copy for Arun Singal, arun.singal560@gmail.com

indicates whether the authorization check for the transaction code was successful or not. For example, 0 indicates success, 1 indicates failure, and 2 indicates a failure with other errors. In this example, the return code (variable **sy-subrc**) has the value 2. Therefore, the **IF** statement on line 16 is **TRUE** (2 not equal to 0), and the error message was raised. Thus, the issue was not a missing authorization but, rather, that transaction code **ZPFCGMASSVAL** does not exist, which was reported with the return code 2. Therefore, you must be aware that neither Transaction SU53 nor authorization traces will show any missing authorizations in this case.

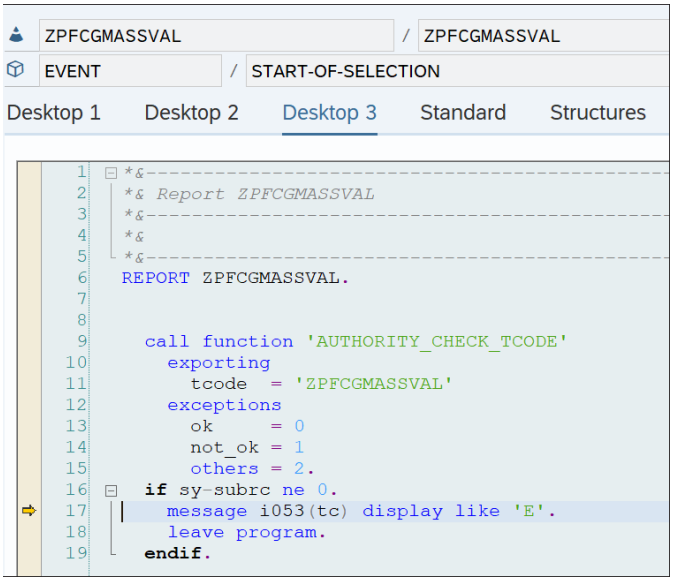


Figure 7.26 ABAP Debugger

Debugging is an advanced tool in the arsenal of an authorization administrator to get to the root cause of a problem. As our example in this section illustrates, an error message indicates an authorization issue. After further investigation, the issue was a transaction code that did not exist, not a missing authorization.

7.7 Xiting Authorizations Management Suite: Enhanced Trace Evaluation

Besides the Productive Test Simulation (PTS) capability in Xiting Role Builder, you can use XAMS to analyze various standard traces and authorization data like Transaction SU53 or the global system trace. Specifically, you can use Xiting Role Builder to bring your authorization evaluation capabilities to the next level with enhanced filter and analysis options.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The following section provides insight into using Xiting Role Builder for your daily business trace analysis.

Hint

SAP recommends using Xiting Role Builder to evaluate, optimize, and maintain your RFC user authorizations, as further described in SAP Note 1682316.

7.7.1 Description

Xiting Role Builder provides the options for evaluating different standard traces and kernel data. You must use the standard transactions and profile parameters to activate the various SAP traces because this module uses the SAP standard trace sources and data. With XAMS, you can evaluate your data more easily and use enhanced analysis capabilities, as shown in Figure 7.27.

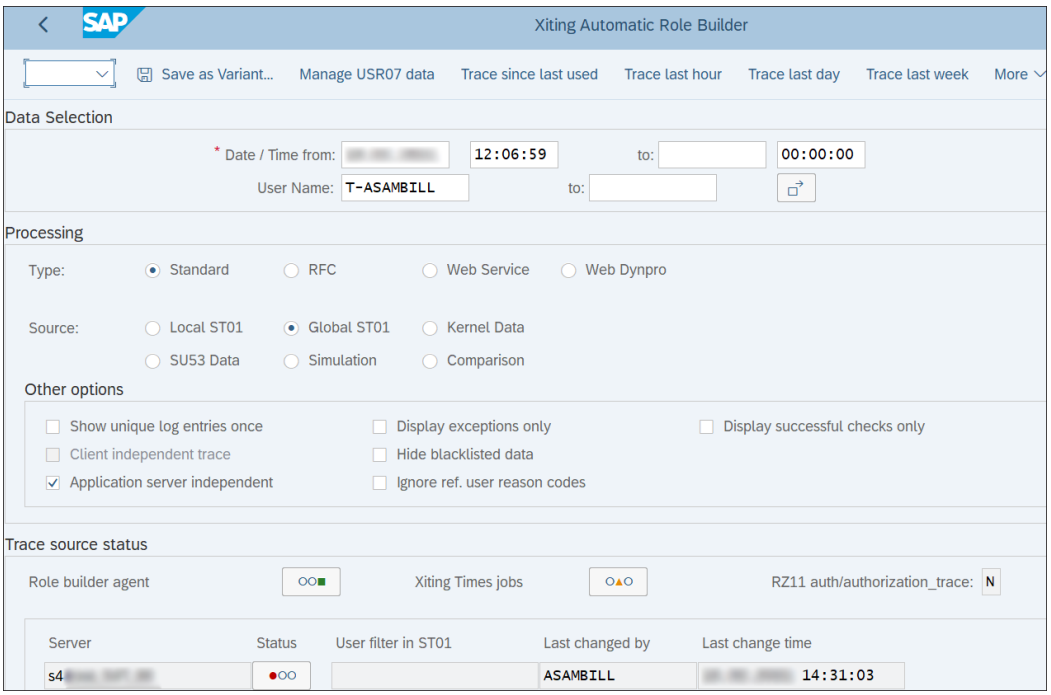


Figure 7.27 Selection Screen for Xiting Role Builder Trace Evaluation

On one hand, Xiting Role Builder offers a centralized selection screen for trace data evaluation with unique filter criteria. Thus, you can use filters to select the target **Type** and **Source** of your trace. Other filter options help provide focused and individual output lists with enhanced information. On the other hand, you can use this solution's

Personal Copy for Arun Singal, arun.singal560@gmail.com

integrated blacklist to hide forbidden or unnecessary authorizations from the results list and also see trace-related system information. Shortcuts in the header area allow you to access some quick selections and save your selections as variants for recurring evaluations.

Additionally, you can use Xiting Role Builder Coverage Analyzer or Xiting Role Builder SU24 Checkman to maintain authorization default values. Xiting Role Builder Coverage Analyzer helps you find missing end-user authorizations easily.

Hint

To learn more about Xiting Role Builder and its PTS capability, which offers compliant and realistic role testing on the PRD, refer to Chapter 4, Section 4.5.

7.7.2 Rapidly Analyze Authorization Failure

Suppose you have an end user with missing authorizations. Activate your system trace via Transaction STAUTHTRACE and let the end user rerun the scenario that leads to the authorization issue. Then, use Xiting Role Builder Coverage Analyzer and analyze the specific end user with the **global ST01** trace as **source**. The result list with additional features directly shows whether the authorization object, field, or value is missing, as shown in Figure 7.28.

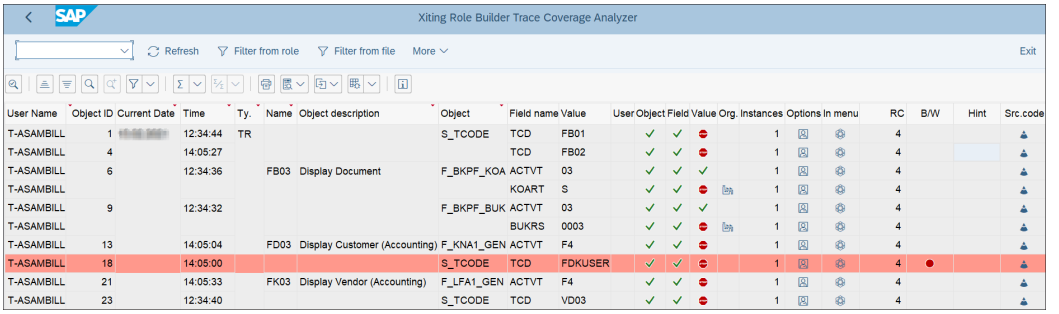


Figure 7.28 Trace Analysis with Xiting Role Builder Coverage Analyzer

You can directly see which authorizations are missing through the different icons in the context of the end user and application. In addition, you'll see whether the missing authorizations are **Organizational Fields**, and you can directly jump into the source code (**Src.code**). For a quick cross-check reference, use the **Instances** information column to see which end-user roles contain the selected authorizations and how they are maintained, as shown in Figure 7.29, which is helpful for finding the correct job function role for your adjustments.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Role	Short Role Description	Object	Authorization	Field name	and	Object	Field	Value
ZP_FI_S_0001_ACC	FI: Rights for FI Accounting (BUKRS 0001)	S_TCODE	T-ST16141100	TCD		FB02	✓	✓

Figure 7.29 Popup Window for Affected Roles

7.8 Summary

Traces are one of the most important tools for finding, evaluating, and maintaining missing or inappropriate end-user authorizations. On one hand, you'll need both technical know-how and business process-related knowledge to analyze and understand the results of various traces. On the other hand, you must understand the intended use cases for the different trace types and their capabilities. In certain cases, traces will fail to get you to the root cause of an issue, and you must debug code to understand what is going on. As discussed in this chapter, authorization debugging is an advanced means of finding issues but practical to know.

In the next chapter, we'll discuss SAP Fiori authorizations.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 8
SAP Fiori Authorizations

SAP Fiori 3.0, the latest user interface (UI) and user experience (UX) from SAP, replaces traditional UIs, like SAP GUI. With SAP Fiori 3.0, SAP provides applications via cards (formerly called tiles) to encapsulate standard business tasks, such as approving purchase requisitions and displaying sales orders, each accessed through role-based SAP Fiori apps.

SAP Fiori is available for most SAP software products, such as SAP ERP (formerly SAP ECC), SAP S/4HANA, SAP Ariba, SAP Cloud for Customer, SAP SuccessFactors, and many more, and utilizes the latest in-memory computing technology with the SAP HANA database.

To use SAP Fiori, an end user must have proper authorizations for specific applications and their underlying business data. In addition to app-specific authorizations, end users also need certain general authorizations for the frontend server and backend server. These authorizations are required to run the SAP Fiori launchpad, to trigger the OData services required for SAPUI5 applications, and to run (for example) analytical SAP Fiori apps featuring key performance indicator (KPI) tiles.

Role administrators must maintain SAP Fiori authorizations in Transaction PFCG, which follows the same approach as with all other ABAP authorizations.

In this chapter, you'll gain a general understanding of SAP Fiori, how to implement SAP Fiori, what tools are available to authorizations administrators, and how you can troubleshoot issues with SAP Fiori.

8.1 Overview

To understand the impact of SAP Fiori on your authorization concept and business processes, you must understand the conceptional design approach, the system architecture, and various available deployment scenarios for SAP Fiori.

8.1.1 Principles of SAP Fiori

The main goal of SAP Fiori is to serve as an intuitive, role-based, and consistent UI. SAP Fiori enables end users to analyze, process, and adjust complex use cases in real time. The cornerstones of these goals are the five core principles of SAP Fiori:

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Role-based**
  Every end user has an individual SAP Fiori UI through the SAP Fiori launchpad for that person's related use cases and duties. So, the functional and viewable scope is restricted by the position and job role within the company.
- **Adaptive**
  According to various business use cases, SAP Fiori applies to mobile devices, computers, and laptops, all on different operating systems and through different browsers. This adaptivity allows operations without the need for a fixed workplace. Thus, end users can situationally adjust to changing work environments without impacting productivity.
- **Coherent**
  SAP Fiori also provides a consistent view through a homogeneous design and integrated interface among compatible business applications, which an intuitive learning curve while simultaneously processing various tasks.
- **Simple**
  The architecture of SAP Fiori apps enables end users to accomplish their tasks or access the required information for one use case with a maximum of three levels of navigation (called the *"one-one-three" principle*), which enables the focused and fast processing of use cases and activities.
- **Delightful**
  The new Belize theme and SAP Fiori's versatile functionalities create a pleasant and productive work environment for end users.

Hint

This new design approach is integrated into SAPUI5 applications. Traditional transactions and other types of legacy applications might not follow these core design principles.

8.1.2 SAP Fiori End-User Applications

The new SAP Fiori UI also provides some novel application types within the SAP Fiori launchpad for end users. One of these specific SAP Fiori app types is based on HTML5 and allows for widespread and fast data collection. SAP is focused on these SAPUI5-based SAP Fiori applications for new developments. As of 2021, already more than 10,000 SAPUI5 apps are available. Going forward, SAP will continuously develop new applications to enable the full potential of their business applications like SAP S/4HANA.

Besides true SAPUI5 applications, you'll encounter two other types of applications within SAP Fiori: SAP Fiori legacy apps and SAP Fiori Search.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Let's briefly provide at an overview of the different types of applications next:

- **SAPUI5-based SAP Fiori apps**
  SAPUI5 apps are specifically built for SAP Fiori and are based on HTML5. SAPUI5 apps require an OData service in the backend to communicate.
- **SAP Fiori legacy apps**
  SAP Fiori legacy apps are SAP GUI-based applications that are not specifically built in HTML5. Instead, legacy apps are ABAP transactions enabled for HTML to provide the SAP Fiori look and feel. Any legacy application (e.g., transactions or Web Dynpro applications) can be enabled for use in SAP Fiori.
- **SAP Fiori search**
  SAP Fiori search is more a search engine than an app, but this feature is directly integrated into the SAP Fiori launchpad. The search function provides a contextual enterprise search function to find the required information across all applications or business object data.

8.2 SAP Fiori Architecture

The architecture shown in Figure 8.1 is common in every SAP Fiori installation includes the SAP Fiori launchpad and SAP Web Dispatcher, as well as the SAP Fiori front-end server and the SAP Fiori back-end server. The SAP Fiori launchpad and SAP Web Dispatcher run on the SAP frontend server.

SAP Fiori is generally deployed in two different scenarios: as an embedded deployment or a central hub deployment. A third option—SAP Central Launchpad Service—is a kind of central hub deployment.

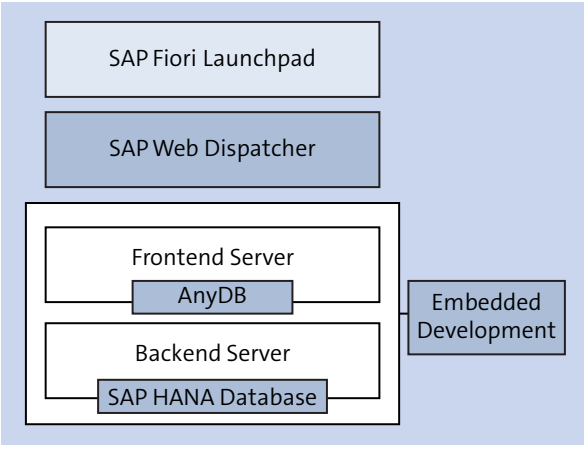


Figure 8.1 SAP Fiori Architecture

Personal Copy for Arun Singal, arun.singal560@gmail.com

In an embedded deployment scenario, the frontend and backend servers run on the same system, whereas in the central hub scenario, the frontend and backend servers are physically separated and connected through a remote function call (RFC). The backend server can be any type of an SAP system, like an SAP NetWeaver ABAP installation (e.g., SAP S/4HANA or SAP ERP).

In the early stages of SAP Fiori, SAP recommended the central hub scenario but has revised this recommendation with later releases. Currently, SAP recommends the embedded scenario in which the frontend and backend server are located on the same system. The main drivers for using the embedded option include better upgradability with new releases and lower costs (by reducing the number of systems required).

Regardless of the deployment scenario, your end users require authorizations for both the frontend server (SAP Fiori launchpad, cards, etc.) as well as the backend server (OData services). In an embedded scenario, you can build the frontend and backend authorizations into one role.

Conversely, in the central hub scenario, you must build two roles: one for frontend authorizations on the frontend server and one for backend authorizations on the backend system.

From an SAP security perspective, as shown in Figure 8.2, the end user needs the proper authorizations to start an application (tile/card) in the SAP Fiori launchpad by having authorizations for the corresponding SAP Fiori catalog on the frontend server. This approach ensures that the SAP Fiori application can be executed in the SAP Fiori launchpad and also call the OData service on the backend server.

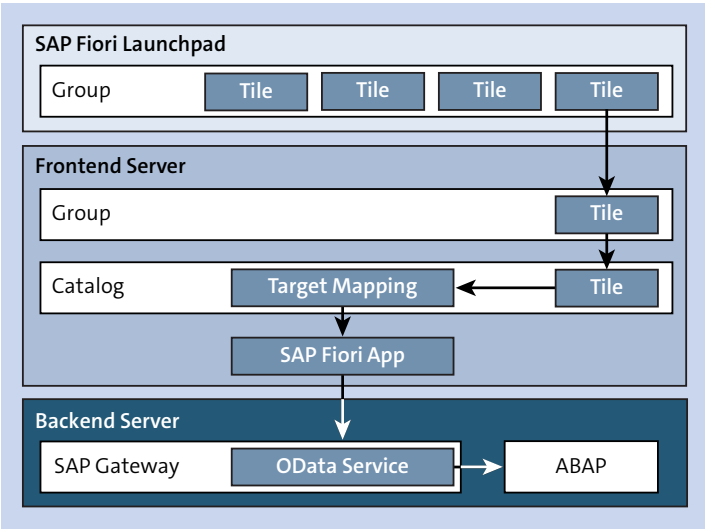


Figure 8.2 SAP Fiori Authorization Flow

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

On the frontend server, you must build a role in Transaction PFCG that contains and authorizes the catalog, groups/spaces, and frontend OData services (object IWSG). On the backend server, you must authorize the catalog and the backend OData services (object IWSV), as well as transactions, Web Dynpro applications, and the authorization objects required in the backend role.

8.3 Deployment Options

The SAP Fiori launchpad can be deployed in three different ways:

- Embedded deployment
- Deployed as a central hub deployment
- SAP Central Launchpad Service

We'll cover each of these methods in the following sections.

Hint

SAP Note 2590653, as well as the recommendation paper "SAP Fiori Deployment Options and System Landscape Recommendations" at *http://s-prs.co/v203612*, offer further details on these deployment options.

8.3.1 Embedded Deployment

For on-premise deployment options, SAP recommends the embedded deployment option, which is great when deploying applications for SAP S/4HANA or for one on-premise system at the time. However, if your end users require access to multiple applications (e.g., SAP S/4HANA, SAP BW/4HANA, and SAP Access Control), they must log on to each embedded launchpad. An end user might need to access, for example, three different launchpads with different authentication credentials to launch the applications they need.

The embedded deployment option is called an *on-premise or any-premise installation*. To enable this option, you must perform an integrated installation of frontend server components (SAP Fiori launchpad and SAP Fiori UIs) on the backend server. Thus, this option involves a combination of frontend server and backend server on the same instance. You must administer each embedded system separately, but at the same time, you can have different release versions in each embedded system. Note that you'll need an SAP HANA database on every backend server in the embedded scenario, as shown in Figure 8.3.

Personal Copy for Arun Singal, arun.singal560@gmail.com

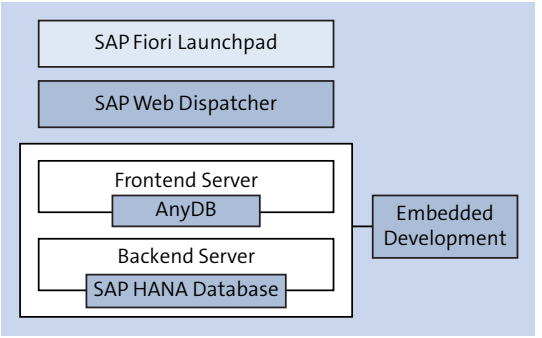


Figure 8.3 Embedded Deployment Landscape

Hint

Following SAP's recommendation of having both the frontend and backend servers on one system, you won't need to split your authorization roles into frontend and backend roles. You can provide all required authorizations within one role.

8.3.2 Central Hub Deployment

For a central hub deployment, one shared launchpad is available for end users to access on-premise. Through this launchpad, an end user can launch various applications (e.g., SAP S/4HANA, SAP BW/4HANA, and SAP Access Control). However, one downside to this approach are the dependencies of the SAP Fiori launchpad because frontend and backend components must be on the same release and patch level. Thus, when you patch one system, you must patch all systems that utilize the same central launchpad.

To overcome issues with dependencies in a central hub deployment, SAP offers SAP Launchpad service on SAP Business Technology Platform (SAP BTP). This service provides a central SAP Fiori launchpad for your end users to access and launch various applications. This cloud service does not require your backend systems to be on the same release and patch level.

In a central hub deployment, the SAP Fiori frontend server is a standalone system that connects to various backend systems, as shown in Figure 8.4. Please remember that every backend server must be on the same release level as the frontend server, which makes this approach difficult to maintain. You cannot technically use different SAP Fiori product UI releases for different backend servers.

This deployment option provides central access to an SAP Fiori launchpad for all connected backend systems without logging on to each system separately. However, SAP does not recommend this deployment option any longer due to the complexity of its dependencies and the availability of the cloud service.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

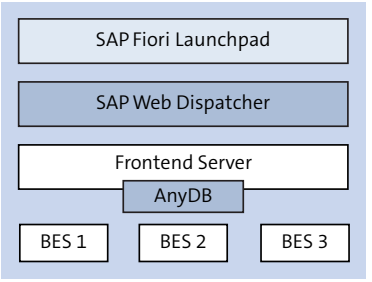


Figure 8.4 Central Hub Deployment Landscape

8.3.3 SAP Launchpad Service

The SAP Launchpad service in SAP BTP is a cloud-based solution for a central launchpad, as shown in Figure 8.5. This approach is similar to a central hub deployment but without the negative impact of dependencies. The central launchpad allows your end users to centrally launch various applications through a cloud-based launchpad. An added benefit of this approach is the availability of the SAP Fiori launchpad outside of your internal network since the access point is on the internet.

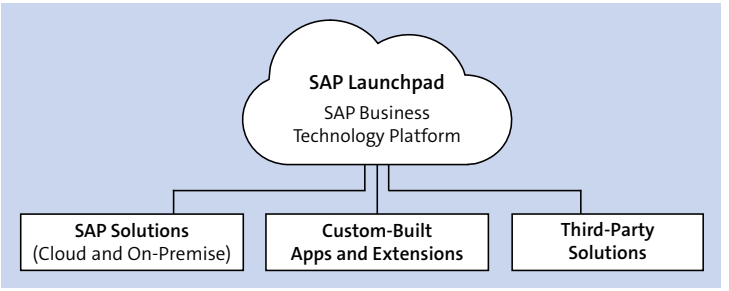


Figure 8.5 SAP Launchpad service on SAP BTP

The SAP Launchpad service is a cloud service that requires a license as well as connectivity from your on-premise applications to SAP BTP. The connectivity is achieved through the cloud connector, which provides a secure tunnel between your on-premise systems and the cloud.

With the SAP Launchpad service, you can increase user productivity and efficiency by enabling and establishing a central point of access for all SAP, custom, and third-party applications and extensions. The SAP Launchpad service provides the following benefits:

- **Increase user engagement**
  - Intuitive UX based on SAP Fiori design
  - Simplified access to apps and services (desktop and mobile)
  - Personalized homepage with relevant, role-based content

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Boost user productivity**
  - Fast access to information and efficient navigation via a central, unified experience
  - Proactive notifications
  - Focus on important KPIs and live business data
- **Improve operations efficiency**
  - Streamline UX integration for common SAP solutions
  - Out of the box integration with central services
  - Seamless app integration for common UI technologies

The SAP Launchpad service is the ideal tool for start your transition into the cloud. You can elevate your SAP Fiori launchpad experience into the cloud, especially if you're running on-premise applications like SAP ERP or SAP S/4HANA. You can build a central point of access for your SAP applications as well as for third-party solutions (both in the cloud and on-premise).

This service enables external-facing scenarios to grant your employees and business partners secure access to selected applications and services over the internet via desktop and mobile devices (outside the corporate network).

8.4 SAP Fiori Apps Reference Library

The SAP Fiori apps reference library is a database of all available SAP Fiori applications. It includes information about the technical components, installation guides, system requirements, or references to SAP Note. The SAP Fiori apps reference library is a great starting point for exploring new apps and learning how to correctly implement and authorize them. This section will provide an overview of the SAP Fiori apps reference library as well as describe its technical components.

Hint

The SAP Fiori apps reference library is accessible at *http://s-prs.co/v203609*.

8.4.1 Overview

The SAP Fiori apps reference library contains applications to various SAP products (e.g., **SAP S/4HANA**, **SAP Business Suite**, or **SAP Fiori Cloud**), as shown in Figure 8.6. To select applications for your product, use the categories to filter. For an overview of all available apps, or if you know the exact app you're looking for, you can also select the **All apps** category and in a second step narrow down your search.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

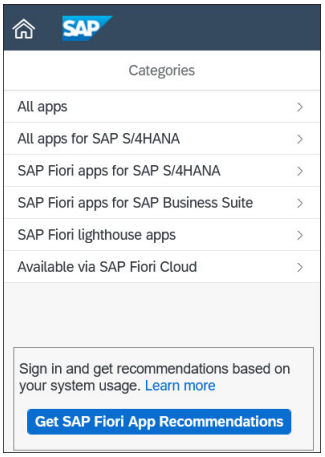


Figure 8.6 SAP Fiori Apps Reference Library Categories

Hint

SAP provides thousands of different SAP Fiori apps to enable business processes in different products. In addition, SAP recommends the most important and useful apps as **SAP Fiori lighthouse apps**—these apps are the most stable applications for common business processes.

If you select an application in the SAP Fiori apps reference library, you'll directly jump into the **Product Features** tab shown in Figure 8.7, which contains the basic information, description, related key feature list, screenshots, app documentation, and other references. Essential for your role building tasks is the **Implementation Information** tab. Section 8.4.2 explains which data is necessary for role building to authorize SAP Fiori applications.

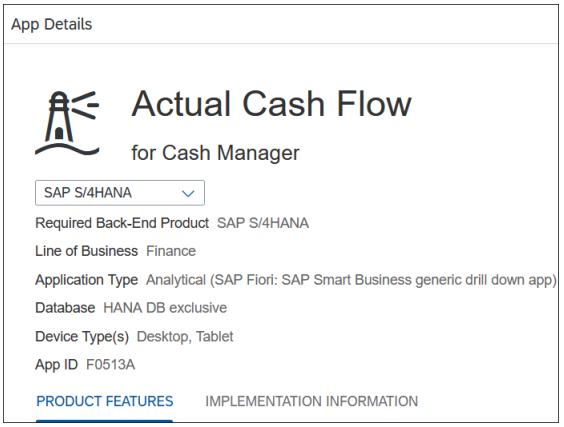


Figure 8.7 SAP Fiori App Information for Actual Cash Flow

Personal Copy for Arun Singal, arun.singal560@gmail.com

Since the SAP Fiori apps reference library is the single source for information about SAP Fiori applications, an important feature is the ability to download the information in bulk. You can achieve this task by changing from the **Detail View** to the **List View**, as shown in Figure 8.8. The list view provides an list of all application-relevant information that can be downloaded as a CSV file.

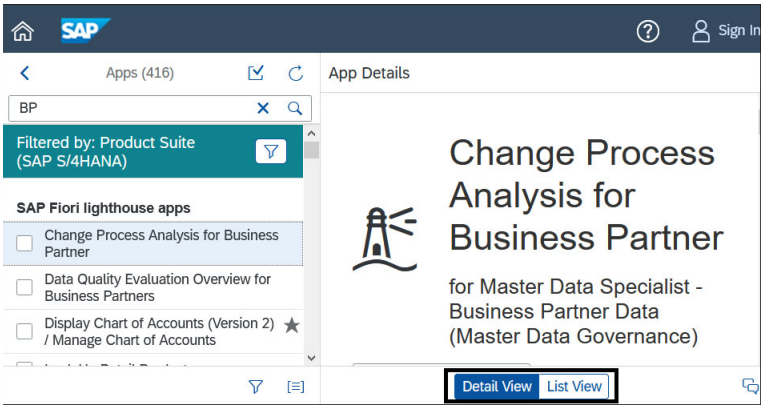


Figure 8.8 Detail View and List View in the SAP Fiori Apps Reference Library

Additionally, the SAP Fiori apps recommendation service can send you recommendations based on your product and data usage in your system. This service allows you to upload historical usage data (e.g., from Transaction ST03N) to see which SAP Fiori applications could possibly replace or enhance the transactions your users have used in the past.

To launch the recommendation service, click on the **Get SAP Fiori App Recommendations** button, available on the initial screen of the SAP Fiori apps reference library, shown earlier in Figure 8.6.

8.4.2 Technical Components

As a security administrator, you can see technical requirements and components within each application's **Implementation Information** tab. The following components are essential to understand during role building:

- **App ID**
  Every SAP Fiori application has its unique identification number (ID). The app ID is the fastest and most accurate way to find information about an app from the SAP Fiori apps reference library. Many apps share the same title and description and are therefore difficult to differentiate. Always use an app ID, which is a unique identifier.
- **Release level/component version**
  Always select the correct backend system release and patch level. Information and

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

data might change between releases and patch levels, so always make sure you select the correct version.

- **SAP Notes**
  SAP Notes provide additional information regarding an app including, for example, its prerequisites.
- **SAPUI5 applications**
  If the app is an SAPUI5 app, you must first activate the related Internet Communication Framework (ICF) node to enable and secure web-based communications with your backend system.
- **OData services**
  OData services are required for communication with frontend and backend servers. Ensure that the listed OData services are activated before authorization the application.

Hint

Section 8.6 provides more information about how to activate OData services.

- **Technical configuration**
  SAP delivers each application through at least one technical catalog. A technical catalog contains application-related configuration and can be used as a reference as you design your custom business catalogs to authorize various SAP Fiori applications.

Hint

The differences between technical catalogs and business catalogs are further discussed in Section 8.7.1.

- **Target mapping(s)**
  A semantic object and its related semantic actions describe the actions possible through an application for end users. This mapping is required to authorize the targeted utilization by the desired SAP Fiori application.
- **App launcher**
  Describes the SAP Fiori app-related cards (formerly called tiles) that are visible to and usable by end users on their SAP Fiori launchpads.
- **Business role(s)**
  SAP also provides for SAP Fiori applications in template roles. SAP standard roles allow for fast implementation in a sandbox environment but should not be used in a productive system (PRD). Always create custom roles for your end users.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

A best practice is to use template roles as a reference only and create your own custom roles for your SAP Fiori applications. SAP standard template roles often provide more authorizations than are necessary and should only be used in sandbox environments.

8.5 SAP Fiori Administrative Tools

SAP Fiori comes with various tools to administer the components of SAP Fiori. These tools include the SAP Fiori launchpad designer, one of the first tools included with SAP Fiori to create and maintain catalogs and groups, and newer tools like the SAP Fiori launchpad content manager, the SAP Fiori launchpad app manager, and the Manage Spaces and Pages app.

The following sections will provide a detailed overview of the use cases for each tool.

8.5.1 SAP Fiori Launchpad Designer

The SAP Fiori launchpad designer was the main tool for creating and maintaining catalogs, groups, and tiles, until SAP S/4HANA 2020. As of SAP S/4HANA 2020, the maintenance of technical catalogs has shifted to SAP Fiori launchpad content manager.

The SAP Fiori launchpad designer can be accessed with Transaction /UI2/FLPD_CUST in the customizing scope, as well as with Transaction /UI2/FLPD_CONF in the configuration scope. As a customer, you should always work in the customizing scope that is client dependent.

The SAP Fiori launchpad designer is the standard tool for the following activities:

- Configuring the tiles/cards and their target mappings
- Creating and maintaining groups and catalogs
- Transporting configurations (groups, catalogs, and tiles/cards)

Figure 8.9 shows the SAP Fiori launchpad designer in the customizing scope, which is indicated by the client information (**Client: 100**) in the top-right corner. The SAP Fiori launchpad designer is divided into two main sections, **Catalogs** and **Groups,** in the top-left corner. The search box allows you to browse through your catalogs and groups, respectively. SAP-delivered technical and business catalogs and groups are available, too. Business catalogs are named SAP*_BC_*; business groups, SAP*_BCG_*; and technical catalogs, SAP_TC_*.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

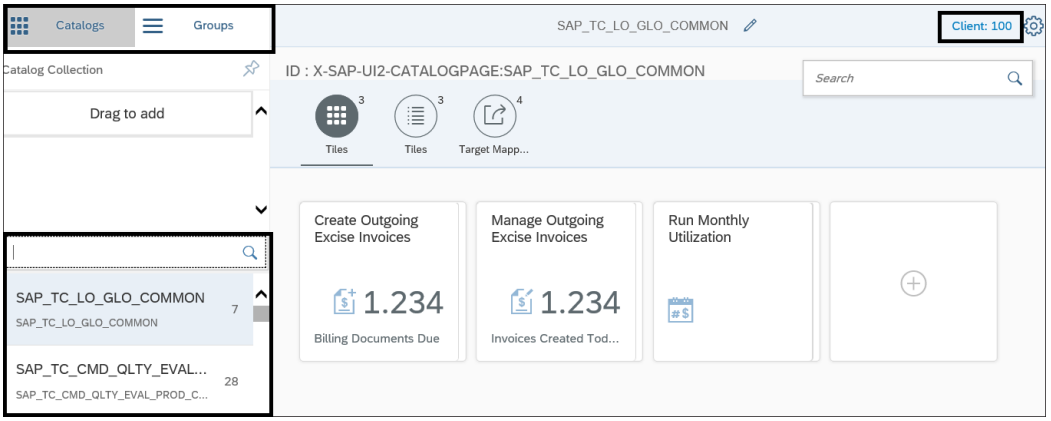


Figure 8.9 Client-Dependent SAP Fiori Launchpad Designer

Within the SAP Fiori launchpad designer, you can build and maintain your custom groups and catalogs. When building custom catalogs, always reference a predelivered technical catalog from SAP, so that you don't have to configure the application manually. To add applications to your custom catalog, simply drag and drop applications from the technical catalog and create a reference. Figure 8.10 shows an example of a technical catalog serving as a reference for an app. To create a reference, simply drag and drop an application, left click with your mouse and hold it down, then move your mouse so that the SAP Fiori launchpad designer will show a popup dialog that allows you to create a reference.

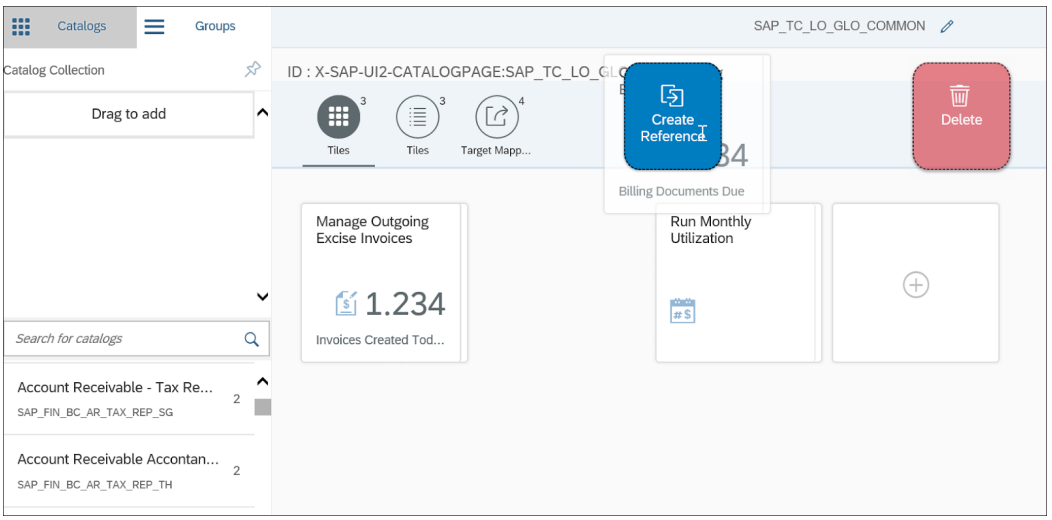


Figure 8.10 Drag-and-Drop Applications within the SAP Fiori Launchpad Designer

Personal Copy for Arun Singal, arun.singal560@gmail.com

For references, as long as you don't change the configuration of an application in your custom catalog, the reference to the original application from the technical catalog will remain intact.

If you make a change, the reference will be broken, which means that the application will still continue to work but you must transfer potential changes to the application manually. SAP might change the configuration to the application in the technical catalog with the next support package (SP), which you then must manually perform in your custom catalog. Therefore, we recommend you keep the reference intact. If the reference is intact, the configuration will automatically be updated when a change to the technical catalog is performed.

Tip

SAP recommends performing changes in the customizing scope and then transporting changes from one client to another, if required. With regard to authorizations, you should build roles and authorizations that are client dependent. Therefore, we recommend following the same principle for SAP Fiori content.

To create custom catalogs or custom groups, click on the icon in the bottom-left corner.

8.5.2 SAP Fiori Launchpad Content Manager

The SAP Fiori launchpad content manager helps you create and adapt SAP Fiori launchpad catalogs. This solution was introduced with SAP S/4HANA 1909 feature pack stack (FPS) 01 and can be used in addition to the SAP Fiori launchpad designer. You can use the SAP Fiori launchpad content manager to explore existing content and to create your own catalogs by copying and modifying existing content to fit your needs.

You can start the SAP Fiori launchpad content manager using Transaction /UI2/FLPCM_CUST (client specific) or Transaction /UI2/FLPCM_CONF (client independent). In the SAP Fiori launchpad content manager, you can check the catalogs for its services to make sure they are activated and properly configured.

In SAP Fiori launchpad content manager (shown in Figure 8.11), you can check the **Catalogs** for their content, like target mappings, to ensure they are activated and the catalogs are correctly configured. Moreover, you can also switch between the **Catalogs**, **Tiles/Target Mappings**, and **Roles** sections. The search box offers you focused analysis. As for the SAP Fiori launchpad designer, you can **Create**, **Delete**, **Copy**, **Change tile**, and **Transport** your catalogs. In addition, you can open catalogs through the SAP Fiori launchpad designer (**Open in Designer**) or directly check your catalog for the required OData or ICF services (**Check Services**). Furthermore, the SAP Fiori launchpad content manager enables the assignment of predefined spaces and pages.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

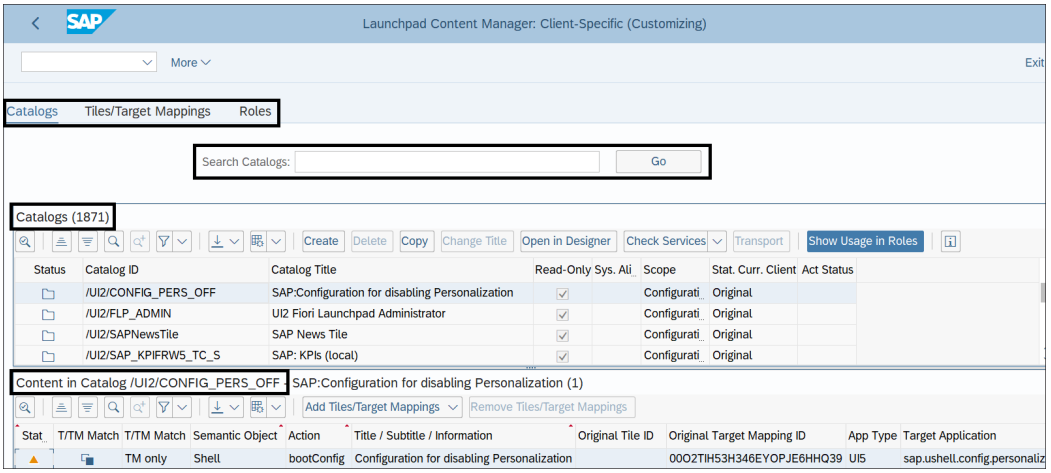


Figure 8.11 SAP Fiori Launchpad Content Manager

8.5.3 SAP Fiori Launchpad App Manager

The SAP Fiori launchpad app manager is the central tool for creating and maintaining apps in a technical catalog. You can start the SAP Fiori launchpad app manager with Transaction /UI2/FLPAM. This tool is designed to manage, configure, and manually update all technical catalogs in one place. Its key features include the following activities:

- Analyzing existing technical catalogs
- Customizing technical catalog content
- Maintaining technical catalogs

In the SAP Fiori launchpad app manager, you'll maintain *descriptor items*. The SAP Fiori launchpad app manager supersedes the SAP Fiori launchpad designer and complements the SAP Fiori launchpad content manager as the central tool to configure and maintain technical catalogs and SAP Fiori launchpad app descriptor items.

An app descriptor item is a new entity introduced alongside the SAP Fiori launchpad app manager. This item consists of a target mapping and, depending on the app type, one or more tiles. A technical catalog can contain multiple app descriptor items.

Once you launch the SAP Fiori launchpad app manager, as shown in Figure 8.12, you either start in the search view or in the catalog entry view. In the top-left corner, you can switch between these views and also apply filters to explore the content.

In the search view, you can search for the required entities under their respective tabs:

- **Catalogs**
- **Launchpad App Descriptor Items**
- **Tiles**

Personal Copy for Arun Singal, arun.singal560@gmail.com

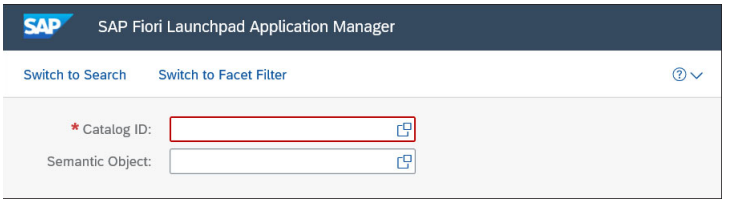


Figure 8.12 Initial Screen of the App Manager

Under the **Catalog** tab, you have the option of creating a new technical catalog or changing the catalog's title. You can also directly jump into a catalog and make further changes to the catalog's content. Instead of searching for catalogs, you can also search for tiles or launchpad app descriptor items.

When you open a technical catalog, you can perform the following activities:

- Create app descriptor items
- Copy launchpad app descriptor items to another catalog
- Edit existing launchpad descriptor items

The catalog view consists of two panes, as shown in Figure 8.13.

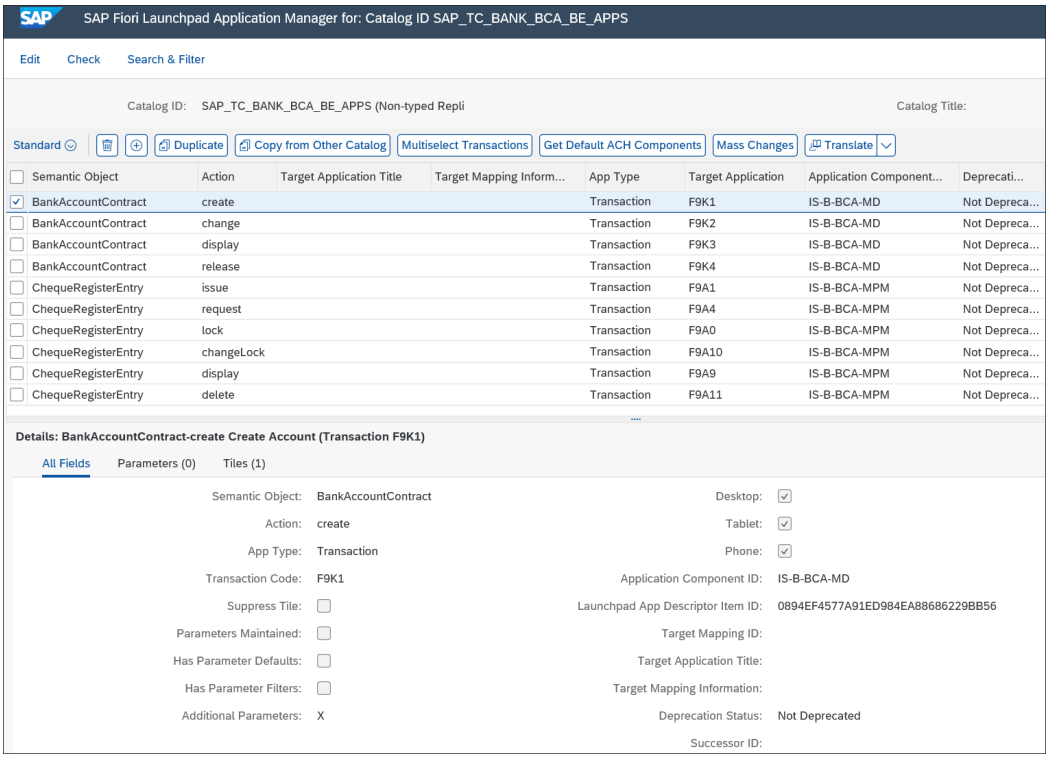


Figure 8.13 Viewing a Technical Catalog in the App Manager

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

In the top pane, you'll see a list of existing descriptor items. When you select one, you'll see more information related to the item in the lower pane, including additional fields to target mappings as well as corresponding tiles and parameters.

Hint

A descriptor item is a newly introduced entity managed through the SAP Fiori launchpad app manager. This item contains one target mapping with one or more tiles, depending on the app type. A technical catalog can contain various SAP Fiori launchpad app manager descriptor items.

8.5.4 Manage Spaces and Pages App

With SAP S/4HANA 2020 and SAP Fiori 3.0, SAP has launched a new concept involving *spaces and pages*. With this new concept, SAP introduced the ability to define the layout of the pages used by entire user groups. This feature allows users consume the content of the SAP Fiori launchpad in an easier and more structured way than before. Nor more overloaded homepages means that users won't get lost in too much content or because of a missing structure. More details about this approach are provided in Section 8.7.3.

For maintaining spaces and pages that can be displayed in a user's SAP Fiori launchpad, you can use the Manage Launchpad Spaces app and the Manage Launchpad Pages app in SAP Fiori. These apps follow the "what you see is what you get" (WYSIWYG) principle, and thus, you can structure the layout of a page via a drag-and-drop functionality.

To make the spaces and pages available for your users, you'll need to activate spaces first through two parameters in Transaction /UI2/FLP_CUS_CONF: `SPACES` and `SPACES_ENABLE_USER`, as shown in Figure 8.14. With the `SPACES` parameter set to `TRUE`, all users will automatically must use spaces and pages. With the `SPACES_ENABLE_USER` parameter set to `TRUE`, each user can individually switch between the old approach (groups) and the new approach (spaces and pages). Only one parameter can be used at any given time.

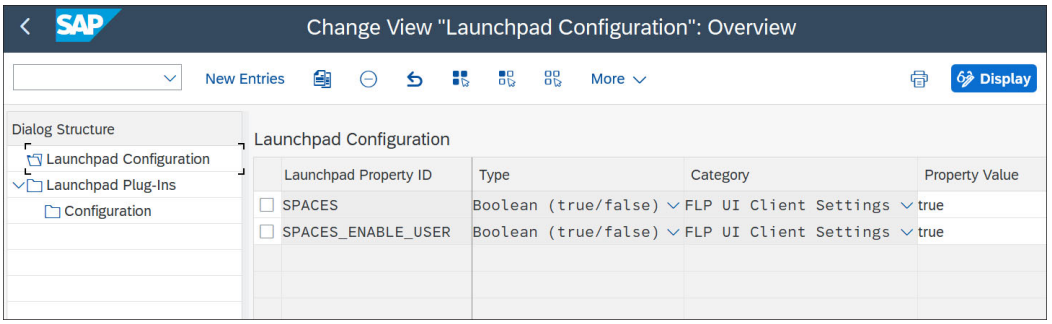


Figure 8.14 Configuration Parameters to Enable Spaces

Personal Copy for Arun Singal, arun.singal560@gmail.com

Warning

Please remember that, when switching from the old approach (groups) to the new approach (spaces and pages), an end user will no longer see your existing groups, and thus, content must be available through spaces and pages.

8.6 OData Services

With SAP Fiori, SAP has introduced a new UX based on SAPUI5. The communication between SAPUI5 apps and related systems in the background goes through the Open Data Protocol (OData). OData constitutes the link between the SAP Fiori UI and the frontend server, specifically SAP Gateway. OData services are required for the communication and the exchange of data between the frontend and the backend.

This section explains what an OData service is, why this service type is required, and how you can activate OData services on frontend servers to enable your SAP Fiori SAPUI5 apps.

8.6.1 Description

OData is a web protocol that enables open data exchanges, queries, and updates based on the Representational State Transfer (REST). Furthermore, OData uses web technologies like HTTP, Atom Publishing (AtomPub), and Really Simple Syndication (RSS). OData services are primarily used for the communication between the SAP Fiori UI and SAP Gateway. The interposed SAP Gateway enables secure data exchanges and utilization for different end users, platforms, databases, and terminals to avoid peer-to-peer infrastructure communication. In this way, widespread data access is available, and processing in disparate databases can be controlled by various fixed or mobile devices. For processing big data, a new level of information technology can combine with various SAP Fiori applications and their underlying core data services (CDS) views, as shown in Figure 8.15.

Some actions that OData services can provide include create, read, update, and delete (CRUD) operations on data. These operations should already be familiar to you from traditional SAP GUI transactions or Structured Query Language (SQL) processing. SAP has enhanced this protocol service and has somewhat limited (between OData V2 and V4) the ability for SAP Fiori to expose an underlying backend system's full capabilities. These new OData service (V4) applications, like the SAPUI5 apps, allow you, however, to unlock the full potential of SAP S/4HANA and the SAP HANA database.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

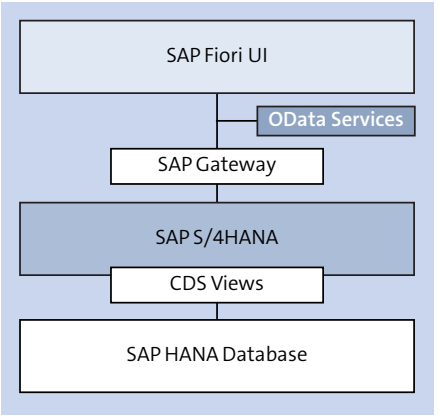


Figure 8.15 SAP Fiori Communication Architecture

Hint

CDS views are data processing options available within SAP S/4HANA to simplify the usage and presentation of frequently used data analysis scopes. You can encapsulate queries in CDS views, which thus enable direct database querying. For more details on this topic, refer to **Chapter 12**, **Section 12.5**.

8.6.2 Activation of OData Services in Backend Servers

Before you can use OData services in your backend system, you must activate them. If the external SAP Gateway system has another client other than the target backend server, you must activate the ICF service, too. Mostly this task is the responsibility of the Basis team, but you, as a security administrator, might have to perform this activation as well. Note that every SAP Fiori application has different OData service and ICF requirements, which you can find in the SAP Fiori apps reference library. In the following sections, we'll discuss the transactions you can use to activate these required services. This information is absolutely required before you can authorize SAP Fiori apps.

Transaction /IWFND/MAINT_SERVICE

Before activating OData services, you must understand the difference between the SAP Gateway: Business Suite Enablement – Service (object type IWSV) and SAP Gateway: Service Groups Metadata (object type IWSG). The IWSV service is the related service in the backend, which you don't have to activate. This service is automatically available in SAP S/4HANA and includes its own business logic. The IWSG service will call this logic, which contains a matching link to the IWSV service. The IWSG service is a service on the frontend server that must be activated by Transaction /IWFND/MAINT_SERVICE.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Note the enlisted frontend OData services from the SAP Fiori apps reference library and go to Transaction /IWFND/MAINT_SERVICE in SAP GUI. Next, click on the **Add Service** button and provide the target system for your activation (local or RFC) in the **System Alias**. Then, enter the service into the **Technical Service Name** field, then search for and select service, and click on **Add Selected Services** to activate it, as shown in Figure 8.16.

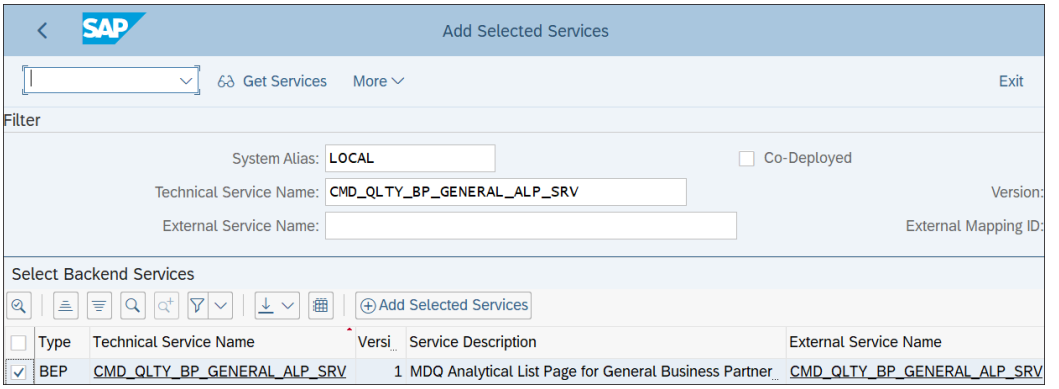


Figure 8.16 Activating an OData Service in Transaction /IWFND/MAINT_SERVIC

You should then see the activated OData services in Transaction SICF and the underlying node **sap/bc/opu/odata**.

Transaction STC01

The rapid activation task list for the mass maintenance of OData and ICF services has been available since SAP S/4HANA 1909. Execute Transaction STC01 and run the task list SAP_FIORI_FCM_CONTENT_ACTIVATION, as shown in Figure 8.17.

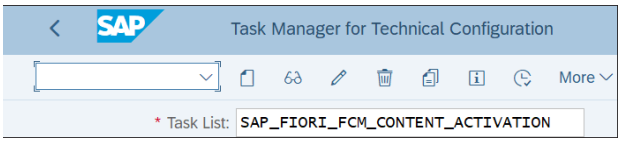


Figure 8.17 Rapid Activation Task List for OData Services

For individual mass activation, use the task lists included in Table 8.1.

Task List	Description
SAP_GATEWAY_ACTIVATE_ODATA_SERV	Mass Activation of OData Services
SAP_BASIS_ACTIVATE_ICF_NODES	Mass Activation of ICF Services

Table 8.1 Individual Mass Activation of OData and ICF Services

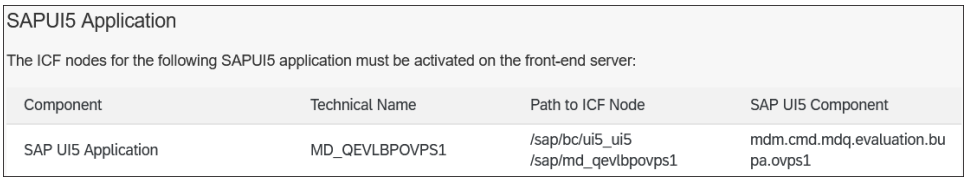
© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Check SAP Note 2834415 for detailed information.

Transaction SICF

Go to Transaction SIFC and select the node **/sap/bc/ui5_ui5/sap** to activate ICF services for it. You can find the correct ICF services requirement in the SAP Fiori apps reference library, as shown in Figure 8.18.



SAPUI5 Application

The ICF nodes for the following SAPUI5 application must be activated on the front-end server:

Component	Technical Name	Path to ICF Node	SAP UI5 Component
SAP UI5 Application	MD_QEVLBPOVPS1	/sap/bc/ui5_ui5 /sap/md_qevlbpovps1	mdm.cmd.mdq.evaluation.bupa.ovps1

Figure 8.18 ICF Requirements in the SAP Fiori Apps Reference Library

8.6.3 Overview of Activated Services

If you want to see all activated OData or ICF services, you have two options. For OData services, enter the table name "/IWFND/I_MED_SRH" in Transaction SE16(N), which provides an overview of all activated OData services. Through report RS_ICF_SERV_ADMIN_TASKS, you can export all active ICF services to a CSV file.

8.7 SAP Fiori Concept Implementation

Authorizing applications in SAP Fiori requires a few components to be built before you can add objects into your authorization concept. These components include the catalog as well as groups or pages/spaces. The catalog contains the apps and ultimately authorizes an end user. Groups, or spaces/pages, can be used to display SAP Fiori applications on the SAP Fiori launchpad. SAP predelivers what are called *technical catalogs* as well as business catalogs and predefined groups.

Similar to SAP standard roles in Transaction PFCG, you should build your own custom catalogs, groups, spaces, and pages, as we'll discuss in this section. This section also covers SAP Fiori launchpad personalization options.

In this section, our examples are based on an SAPUI5 app called the Sales Performance – Plan/Actual – for Sales Manager app (F2941), which is designed for the sales manager job function.

Personal Copy for Arun Singal, arun.singal560@gmail.com

8.7.1 Technical and Business Catalogs

Within SAP Fiori, catalogs contain the technical information required to enable several related SAP Fiori applications. SAP delivers most SAP Fiori apps in a technical catalog as well as in one or more business catalogs. These catalogs are technically similar but have different intentions. Technical catalogs follow a component approach, whereas the business catalogs are functional or job based. For example, the Sales Performance – Plan/Actual app (F2941) is delivered through the technical catalog SAP_TC_CEC_SD_COMMON (CEC: Customer Engagement and Commerce – SD) and is also part of the business catalog SAP_SD_BC_SP_PROC (Sales - Sales Planning). The technical catalog, in this example, for common transactions for Customer Engagement and Commerce (CEC), contains apps for CEC, whereas the business catalog contains apps for the sales planning job function.

In this section, we'll provide an overview of technical catalogs and business catalogs and show you how to create a business catalog. We'll also cover intent-based navigation and target mapping assignments to business catalogs.

Overview

A technical catalog contains tile definitions (e.g., title, subtitle, and icon) and their associated target mappings (actions). Technical catalogs for the basis for creating your own custom business catalogs. Technical catalogs are updated by SAP, and therefore, you should never change a technical catalog because your changes will be lost when the catalog is overwritten during the next upgrade. SAP also provides business catalogs that you can use as templates or for an idea of how a job can be structured. You can also use these catalogs throughout your SAP Fiori concept. A best practice is to build your own business catalogs and groups to prevent overauthorization, encourage more harmony with demands, and enhance individualization. The same principle applies to spaces and pages.

Also, you can use a business catalog to combine one or more SAP Fiori apps that you want to provide to, for example, a specific sales job function. Thus, consider adopting a naming convention for your business catalogs to achieve names that are similar to the names of your job function roles. The business catalog name should be similar to the definition of the job function in your SAP S/4HANA system. Apart from specific country-related apps, you don't have to respect any organizational restrictions, like you would in your system role naming convention. The business catalog only provides functional components as a container to use one or more SAP Fiori apps. Your restrictions through authorization characteristics, like activities and organization level, only start in your roles, which should be reflected in their naming convention.

Note that you should always find an SAP Fiori's app ID and technical catalog from the SAP Fiori apps reference library, as shown in Figure 8.19. Through the SAP Fiori launchpad designer and the SAP Fiori content manager, you have two different options for administering your business catalogs, and thus, you need distinct content.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Technical Configuration	
Technical Catalog	SAP_TC_CEC_SD_COMMON
Technical Catalog Description	CEC
SAPUI5 Application	SD_OVP_SMS1

Figure 8.19 Technical Configuration Section in the SAP Fiori Apps Reference Library

Hint

In the context of SAP security, end users must receive job-related app authorizations from business catalogs rather than only through view restrictions on the business group. Otherwise, these users can find all assigned SAP Fiori apps from their catalogs on the SAP Fiori launchpad, specifically in the **Me** area, although the business groups show less applications. So, prepare your authorizations concept with business catalogs because these catalogs reflect the authorizations of your end users. Groups are only responsible for the appearance of apps on the SAP Fiori launchpad.

Creating a Business Catalog

The administration of business catalogs starts in the SAP Fiori launchpad designer or the SAP Fiori content manager. In the following example, you'll see how to create a business catalog based on the SAP Fiori launchpad content manager, which is the enhanced tool for business catalogs (compared to the SAP Fiori launchpad designer). Particularly for some mass maintenance actions, the SAP Fiori content manager should be your tool of choice.

As long as role concepts are client specific, their business catalogs and groups should be implemented as client specific as well. Thus, use Transaction /UI2/FLPCM_CUST to follow best practices.

Hint

Check whether you've already activated the required frontend OData and ICF services. You'll find all requirements in the SAP Fiori apps reference library.

Therefore, start the client-specific SAP Fiori launchpad content manager. Then, click on the **Create** button. Enter meaningful values for the **New ID** and **New Title** fields, as shown in Figure 8.20. The naming convention of your catalog should align with your role naming convention. Replace your role type string with "BC" (to stand for "business catalog") and avoid organizational distinctions if not required by your business demands.

Then, assign your new business catalog to a customizing transport. You now have your first business catalog available as an empty container, which you must now fill with content by adding the desired cards and semantic objects for your SAP Fiori apps.

Personal Copy for Arun Singal, arun.singal560@gmail.com

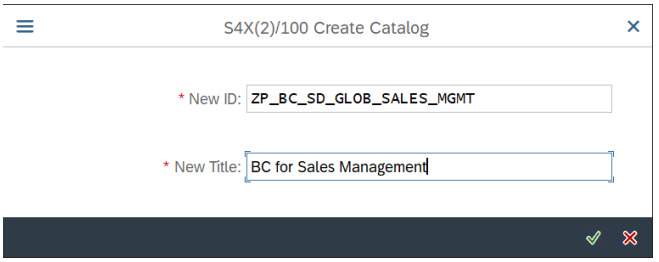


Figure 8.20 Creating a Business Catalog in the SAP Fiori Launchpad Content Manager

Intent-Based Navigation

A new dynamic navigation concept for the SAP Fiori launchpad allows end users to launch applications in various views or modes depending on underlying runtime parameters. Called *intent-based navigation* in SAP Fiori, you must consider new authorization entities as well. The new design approach enables you to authorize various users and user groups for different navigational actions within the SAP Fiori launchpad according to their assigned roles and business catalogs. The basis for desired end-user actions through your business catalogs are *target mappings*. Each target mapping contains a dynamic tile (card) and a semantic object with the referring actions. One SAP Fiori app ID can have one or more target mappings, and how many and what kind depends on the requirements listed in the SAP Fiori apps reference library. Table 8.2 lists a few new entities important for your custom business catalogs.

Entity	Short Description
Target mappings	Containers for semantic objects, actions, and parameters (optional).
Semantic objects	A business entity, such as an accounting document, a sales order, or a product. This technical component is required to technically refer user actions to business entities in an abstract, implementation-independent way.
Actions	Defines the operation level for a task (i.e., display, create, change, or approve a purchase order). You must always have a semantic object with one or more possible actions. They are fixed and correlated.
Parameters	This optional component in the SAP Fiori launchpad navigation flow defines a specific instance of a semantic object (e.g., an employee ID or a user group).

Table 8.2 New Entities of for Intent-Based Navigation in the SAP Fiori Launchpad

For example, suppose you have an accounting clerk that must display accounting documents (the intention). For this intention, the clerk requires a related key object—a target mapping. The mapping links the semantic object (an accounting document), which is a business object, to an action (to display the document). The related card allows the

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

user to click on a predefined button to display an accounting document to start the SAP Fiori launchpad navigation workflow.

In addition, you can assign the same target mapping for the same intent to various business catalogs but with different workflows. You might start with a standard SAP GUI window, but on the other side of the mapping is an SAP Fiori object page (an SAPUI5 app).

Tip

So that you avoid system and business process interruptions, a helpful approach is to only assign one target mapping for one intent to one end user. Multiple target mappings could lead to various access points and business processing. To analyze your intent-based navigation, use Transaction /UI2/FLIA.

Target Mapping Assignment to the Business Catalog

Now, select your newly created business catalog and click on the **Add Tiles/Target Mappings** button, as shown in Figure 8.21.

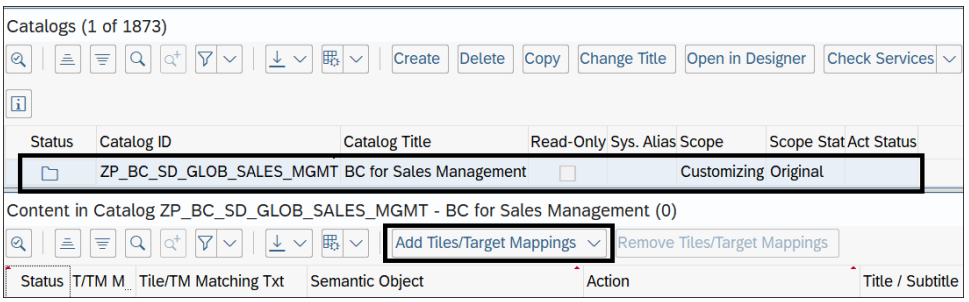


Figure 8.21 Selecting the Business Catalog in the SAP Fiori Launchpad Content Manager

Hint

Note that the activated **READ-ONLY** checkbox for a catalog shows that this catalog was built in a different scope (CUST instead of CONF), or that you've logged on using a different language to the language in which the catalog was created.

Now, you must filter for the SAP Fiori app ID (in our case, "F2941") in the **Fiori ID** column. You'll see all related tiles and target mappings (**Tile + TM**)—or only target mappings or only tiles for the app—in this filtered overview. When tiles and target mappings are available with your SAP release, you'll also see an implementation status with a green square. A yellow square indicates that you must configure some parameters based on the SAP Fiori apps reference library. Furthermore, this list shows you all

Personal Copy for Arun Singal, arun.singal560@gmail.com

further information regarding semantic objects and actions. Contrary to the SAP Fiori launchpad designer, you can mass maintain the available tiles and target mappings with a single click, if required. Therefore, select all and click on **Add Tile/TM Reference**, as shown in Figure 8.22. Which button you click depends on the value in the **T/TM Match** column.

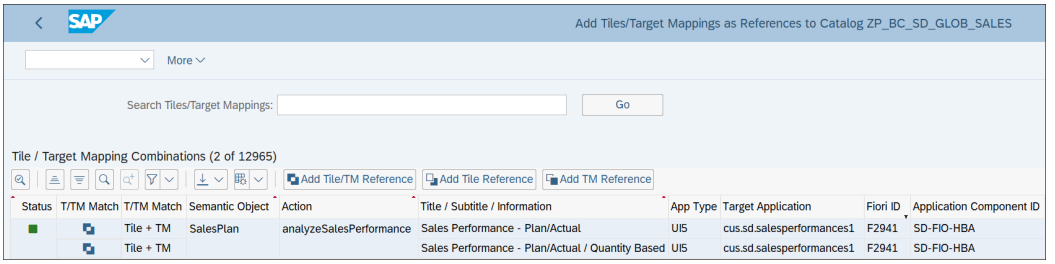


Figure 8.22 Adding a Tile/Target Mapping Reference to a Business Catalog in the SAP Fiori Launchpad Content Manager

Finally, you should see a message confirming the successful addition of the app in the taskbar. Your business catalog is ready to assign, and you can transport it to the PRD.

Tip

In the SAP Fiori launchpad designer, create a new business catalog (bottom-left corner) and then search for the technical catalog name. Refer the relating tiles and target mappings to your business catalog. In this way, you can ensure SAP Fiori app usage, and your business catalog components will be permanently updated by SAP through this connection. The business catalog itself is your company-related information container to enable the usage of the SAP Fiori app F2941 and other job function related apps.

8.7.2 Business Groups

After you've finished the technical information setup within your business catalog, you're ready to enable what the various end users can see in the SAP Fiori launchpad. These views are called custom or business groups in the SAP Fiori environment. You do not have technical groups because you use them only on the business level, and they do not contain any technical prerequisites.

We'll now provide an overview of business groups and show you how to create them.

Overview

SAP Fiori business groups are the technical term that defines which SAP Fiori apps are visible for end users in the SAP Fiori launchpad in terms of their job functions. These business groups contain a set of applications from a business catalog. According to the

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

assigned roles and their business groups and catalogs, the end user can see various apps on the SAP Fiori launchpad's entry page through different tabs. So, business groups only structure the SAP Fiori launchpad; they do not grant authorizations. If an end user has no authorizations through business catalogs and roles for an SAP Fiori app provided by the group, the unauthorized app will not appear on the end user's SAP Fiori launchpad homepage. In summary, there are groups provided by the administrator that end users can edit or not, but also groups allocated by SAP like **My Home** or personal groups end users have created themselves.

Furthermore, business groups should be based on business requirements, like, for example, a task-based approach. You can create and assign multiple business groups to one job function (role). According to the sales manager example, the business catalog **Sales Manager** contains four SAP Fiori applications, which are divided into three groups: **Internal Sales**, **Management**, and **Reporting**, as shown in Figure 8.23.

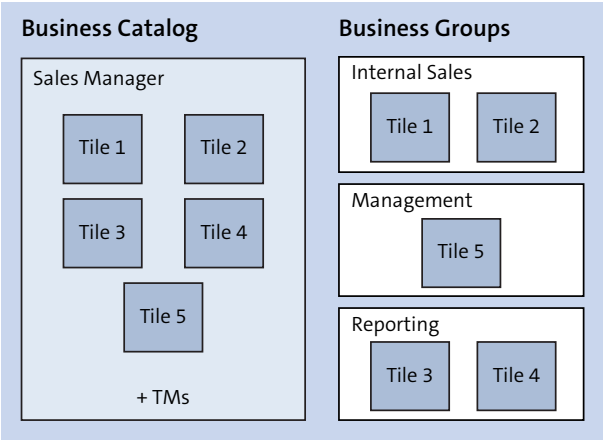


Figure 8.23 SAP Fiori Business Catalogs and Groups

Tip

If an end user is authorized for one or more catalogs, only the corresponding groups are displayed on the SAP Fiori launchpad. This limitation ensures that each user only sees the apps they require by default. Note that a business catalog contains all underlying app entities, so the end users are authorized for them, regardless of whether the SAP Fiori app is visible in a group or not. End users will not only see the cards on the SAP Fiori launchpad by default but can find the others through the App Finder. Thus, you should only build your business catalogs on existing job functions. By doing so, you can prevent the overauthorization of end users who might then have more authorizations than they should.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Creating a Business Group

While you can administer catalogs through the SAP Fiori launchpad designer or the SAP Fiori launchpad content manager, you can maintain business groups only with the SAP Fiori launchpad designer in the frontend server. So, the ideal order is to create business catalogs first, which will contain the applications of the desired business groups, as shown in Figure 8.23. For example, suppose you've already created the business catalog for the **Sales Manager** with the SAP Fiori app ID F2941. Now, the end user needs the visible tile for this app. Therefore, start the Transaction /UI2/FLPD_CUST.

Click on the **Groups** section in the left upper corner. You can now create a new business group by clicking on the ⊕ icon in the bottom-left corner. Next, choose a similar naming convention to your business catalog and only vary with the suffix. The title should properly identify the business area in the business catalog. For example, "Management" or "Sales Management," as shown in Figure 8.24, could be used since the business catalog was created for sales managers. When designing SAP Fiori business groups, you can enable personalization by end users, which means that, when allowed, an end user can personalize the applications in their groups. So, users can rearrange, remove, or change their visible groups and related applications as desired. Consider deselecting the Group personalization checkbox because you should provide a globally common SAP Fiori launchpad for all sales managers. For further suggestions, refer to Section 8.7.4.

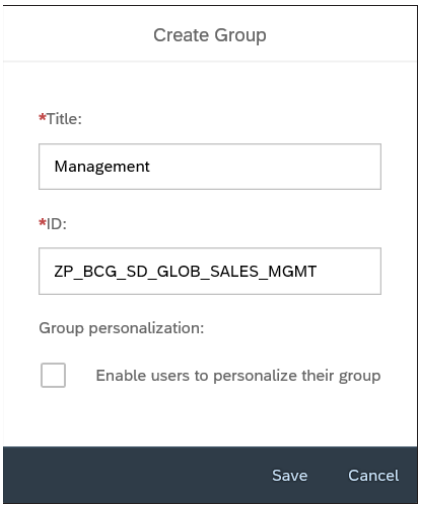


Figure 8.24 Creating a Business Group

Your last activity is to refer the business catalog and its tiles with target mappings to your business group. This step closes the connection between technical and visible components. Click on the ⊕ icon in the **Show as Tiles** section. Next, filter for your targeted business catalog, for example, **ZP_BC_SD_GLOB_SALES_MGMT** with the description **BC for Sales Management**, as shown earlier in Figure 8.20. Click again on the plus

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

icon for the desired tiles, and you've finished the reference between your business catalog and business groups, as shown in Figure 8.25. You're now ready for building roles in Transaction PFCG to access SAP Fiori.

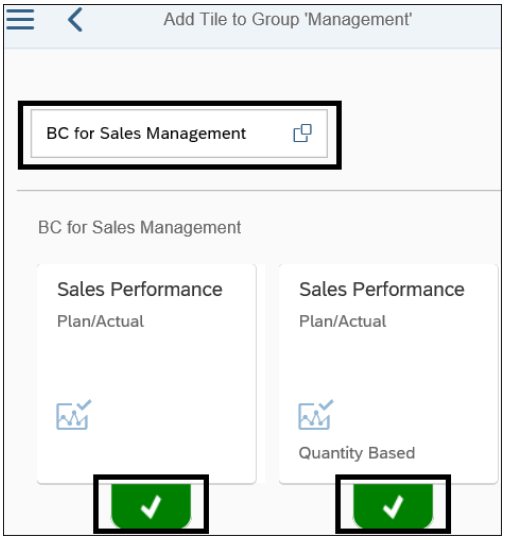


Figure 8.25 Adding Tiles to a Business Group

8.7.3 Business Spaces and Pages

Since SAP S/4HANA Cloud 2005 and SAP S/4HANA 2020, you can also use *spaces* and *pages* instead of groups on the SAP Fiori launchpad. This new approach can replace the groups approach where commonly end users faced an issue where too many groups existed and thus were not visible on the homepage or required scroll bars, which negatively impacted the usability of SAP Fiori. With the new spaces and pages approach, you can enhance SAP Fiori's usability for your end users.

Spaces are the main containers and offer a dropdown menu to access one or more pages. The concept of spaces provides end users with more than one homepage to access their SAP Fiori launchpad content. Through multiple spaces, you can define various pages with sections to organize different tiles. The sections within a page are similar to the previous groups concept. End users can personalize each page separately.

Figure 8.26 shows an example of this approach: the SAP Fiori **Accounts Payable** space. Within the **Accounts Payable** space, a page has various sections (**To-Do List** and **Supplier Invoices**).

To create and maintain pages and spaces, you require two SAP Fiori apps: the Manage Launchpad Spaces app and the Manage Launchpad Pages app. Please ensure that the OData services listed in Table 8.3 are active.

Personal Copy for Arun Singal, arun.singal560@gmail.com

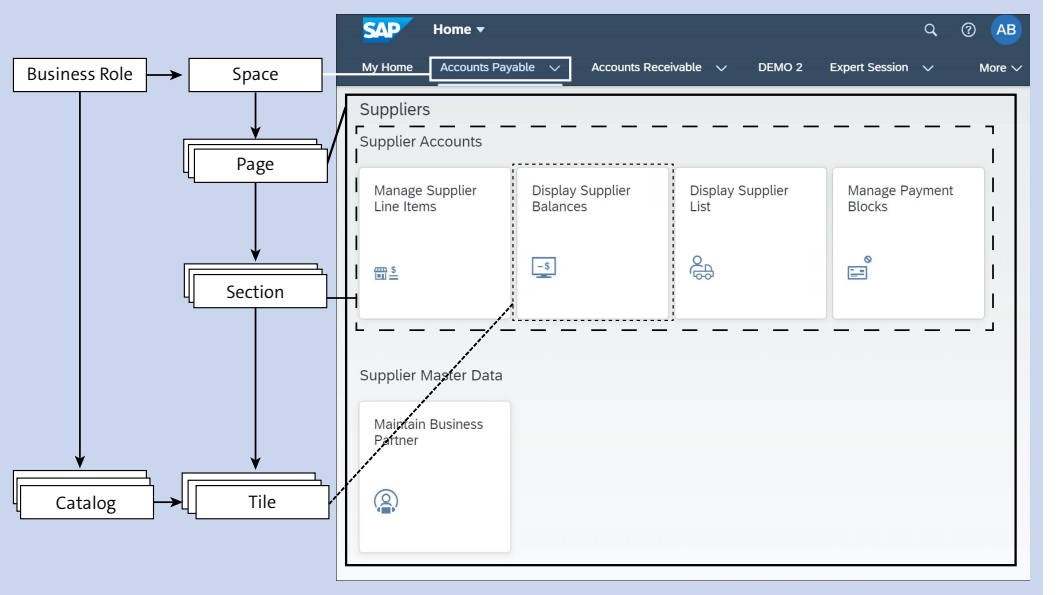


Figure 8.26 SAP Fiori Spaces Concept

OData Service	Description
FDM_SPACE_REPOSITORY_CUST_SRV	Administrative access to the Manage Launchpad Spaces app
FDM_PAGE_REPOSITORY_CUST_SRV	Administrative access to the Manage Launchpad Pages app
FDM_PAGE_RUNTIME_SRV	Enables end users to view spaces and pages on the SAP Fiori launchpad
FDM_TRANSPORT_SRV	Required for transporting spaces and pages

Table 8.3 OData Services for the Apps for Managing Pages and Spaces

To access SAP Fiori apps, you must maintain the required apps in a catalog and ensure that you're authorized to use the catalog.

8.7.4 SAP Fiori Launchpad Personalization

Similar to the SAP user menu in SAP GUI, SAP provides several personalization options for SAP Fiori. End users can personalize their groups by adding or removing apps if the group allows personalization. Thus, end users can add applications—from the catalogs they are authorized for—to the groups that allow personalization. The principle behind

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

personalization is to enable end users to create for themselves a more intuitive UI and improve productivity.

When building your groups, you can deactivate the personalization feature for certain groups if you want them to be locked in place. This limit is often useful generic access apps like the Time Entry app or the Vacation Request app, which you wouldn't want a user to change.

Tip

To reset the personalization data of an entire SAP Fiori launchpad homepage, use Transaction /UI2/FLP_DEL_PERS (see SAP Note 2891617). You can also reset the personalization for specific groups through the implementation of SAP Note 295118. With Web Dynpro application WD_ANALYZE_CONFIG_USER via Transaction SE84, you'll see the personalization data for each person and can reset these personalization settings separately.

To disable personalization (see Figure 8.27), use Transaction /UI2/FLP_CUS_CONF for client-specific disabling and insert the value **false** in the **Property Value** column. To disable personalization system wide, use Transaction /UI2/FLP_SYS_CONF.

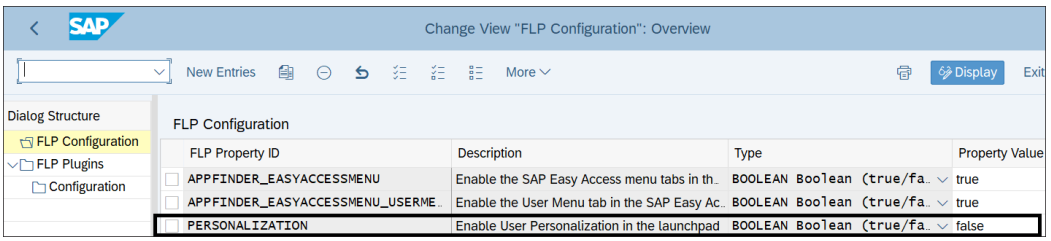


Figure 8.27 Disabling SAP Fiori Launchpad Personalization through a System Parameter

Warning

Please keep in mind that personalization is a great way to allow your end users personalize their homepages. At the same time, however, potential issues can arise if users accidentally delete apps from a group and don't know how to get them back through the App Finder application. Education is important so that your end users understand the personalization concept and how to leverage these settings to their advantage.

8.8 Frontend/Backend Server Authorizations

Despite the new UI and technical administration of catalogs, groups, spaces, and pages in SAP Fiori, Transaction PFCG is still the tool for authorizing end users to access SAP

Personal Copy for Arun Singal, arun.singal560@gmail.com

Fiori applications via roles. Therefore, as for any role building activity, a security administrator must build SAP Fiori roles in the DEV and then transport these roles to their PRDs.

When authorizing SAP Fiori applications, you must authorize the underlying OData services, which requires authorization objects, fields, and values. A difference exists between frontend and backend authorizations, which we'll discuss in this section. Before you start building your roles, an important step is to prepare the system (e.g., by updating Transaction SU24 values) as well as to evaluate your authorization concept to ensure it includes your SAP Fiori applications. Be sure you include SAP Fiori into your existing authorization concept.

This section elaborates on some considerations surrounding the SAP Fiori role concept, like role naming conventions as well as conceptual approaches. We'll describe some preparatory actions that you must perform before maintaining end-user roles. Furthermore, we'll describe a best practice approach to SAP Fiori role building. According to SAP's recommendation, you'll learn how to integrate SAP Fiori applications into your job function roles within an embedded deployment.

8.8.1 SAP Fiori Role Concept

Before we get started, an important step is to consider how to approach the authorization concept, especially regarding your existing roles and authorizations, such as the following:

- **Job function roles**

  According to the best practices described in Chapter 3, Section 3.1, you should follow a job function role approach for your SAP Fiori authorizations. Thus, your end users will have authorizations for related menu objects. For SAP Fiori, you'll integrate the SAP Fiori application components, like the catalogs, groups, spaces and pages, and SAP Gateway services (IWSV/IWSG) into an existing job function role. Also, SAP Fiori apps can belong to various job functions (e.g., the sales manager job function). Thus, rather than creating an additional role for SAP Fiori, you can include the required SAP Fiori apps into your existing concept.

  One advantage of integrating SAP Fiori into your existing job roles are the current authorizations that exist in a role. Often, SAP Fiori simply extends a legacy transaction with a modern UI through its applications. The process itself has not changed, and thus, the authorizations are similar. Since your job roles are already properly authorized, many of the required authorizations for related SAP Fiori applications already exist in your roles and can be merged.

  If you keep to the job function role concept, your end users can access an SAP system either through the SAP GUI or SAP Fiori.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Tip

Maintaining dedicated SAP Fiori roles (in addition to traditional SAP GUI authorization roles) is cumbersome and doubles the required effort. Therefore, we recommend integrating SAP Fiori components into your existing roles to leverage your existing authorizations and also to control the maintainability of your authorization concept going forward. Utilizing existing roles also helps when assigning authorizations to your end users since the roles are already assigned and the context of the role is already defined.

- **Role naming convention**
  Following the job function role concept, you should utilize the same role naming convention because you can still use your current roles with their existing names. For example, the job function role "Sales Manager" remains but now with an additional functional scope (SAP Fiori applications).

  For task-based roles, you should enhance your role naming convention, as described in Chapter 3, Section 3.5. An enhancement might be the addition of the pattern *_FE_* for an SAP Fiori role for end users, similar to the pattern *_SE_* for single roles.

- **Conceptual approach**
  Before integrating SAP Fiori application components into your end-user roles on DEV, you must consider your SAP Fiori deployment. For further information about the differences, as shown earlier in Figure 8.2. An important question to answer is whether your SAP Fiori launchpad runs on a dedicated frontend server (central hub deployment) or has been integrated into your backend server (embedded approach).

  If you're using an embedded deployment, you won't have to divide your authorizations between frontend and backend systems. You can integrate all SAP Fiori application components into your current job function role. On the contrary, in the central hub deployment (dedicated frontend), you'll need both frontend and backend roles.

- **Business roles**
  In general, SAP provides two common end-user roles that contain the basic authorizations to start and use the SAP Fiori launchpad: role SAP_UI2_USER_700 for end users and role SAP_UI2_ADMIN_700 for administrators. SAP also delivers additional predefined role templates for end users; these role templates start with SAP* and have the string "_BR_" (business role) in their role names.

  Typically, these role templates should already be integrated into your SAP S/4HANA system through new support packs (SPs) containing business role templates. If you can't find the right business role for your setup, check your current system's release level because business roles are release dependent. Otherwise, go to the SAP Best Practices Explorer. This tool helps you understand the process and technical changes that come with SAP S/4HANA and SAP Fiori and includes all the required

Personal Copy for Arun Singal, arun.singal560@gmail.com

information, based on the module and business process area. You can also find related SAP template roles in SAP Best Practices Explorer.

Therefore, go to SAP Best Practices Explorer and log on with your SAP S-user ID. Then, browse through the **Solution Packages** menu and choose your target release (solution package), as shown in Figure 8.28.

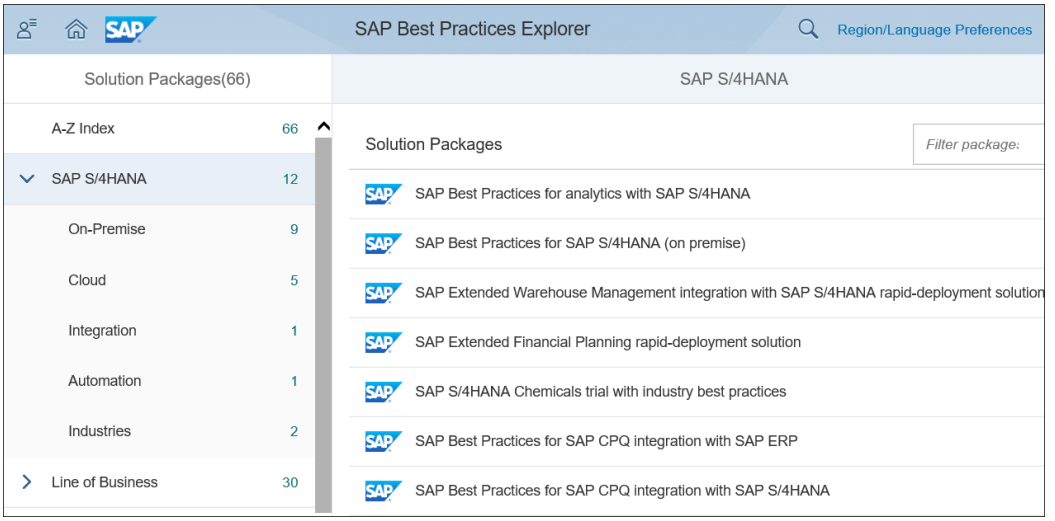


Figure 8.28 Solution Packages in SAP Best Practices Explorer

In SAP Best Practices Explorer, you'll find various solution scopes and their related template role names in the test script, which you can download if you're logged on.

Tip

We recommend you build custom roles for your end users with individual authorizations and integration with SAP Fiori applications. SAP standard roles should only be used in sandboxes, never in your productive landscape.

8.8.2 Role Building Preparation

Some preparatory steps are mandatory before you can start building roles. Some of these steps only need to be performed once; others are repetitive tasks for different components.

Before you can start building your roles, even before SAP Fiori applications can work, you must make sure that the components are properly activated. This step is mostly performed by a Basis administrator but as a security administrator, you should be familiar with these activities.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

OData services and ICF nodes for SAP Fiori applications must be activated before they can be authorized. Detailed information can be found in Section 8.6. Transaction SU24 is, as for legacy transactions, still an important tool for role building. Thus, essential tasks include optimizing, maintaining, and updating your SAP proposals for all role menu objects, including SAP Fiori. Before you start building your roles and include SAP Fiori applications, make sure that Transaction SU25 has been executed. Updating Transaction SU24 also includes updates to custom SAP Fiori applications.

In this section, we'll discuss the general SAP Fiori end-user role and provide a role building preparation checklist.

General SAP Fiori End-User Role

For the SAP Fiori launchpad to function properly, and so that end users can start and execute the SAP Fiori launchpad, general authorizations are required. Table 8.4 lists the required menu objects that must be authorized through a general end-user role for SAP Fiori.

Level	Type	Name
Frontend server	Transaction (TRAN)	/UI2/FLP
Frontend server	Web Service (IWSV)	/UI2/PAGE_BUILDER_PERS_0001
Frontend server	Web Service (IWSV)	/UI2/INTEROP_0001
Frontend server	Web Service (IWSG)	ZPAGE_BUILDER_PERS_0001
Frontend server	Web Service (IWSG)	ZINTEROP_0001
Frontend server	Web Service (IWSG)	/IWFND/SG_MED_CATALOG_0002
Backend server	Function Module (FUNC)	/IWBEP/FM_MGW_HANDLE_REQUEST

Table 8.4 Role Menu Objects for the SAP Fiori Common End-User Role

We recommend you update your Transaction SU24 proposals for the function module `/IWBEP/FM_MGW_HANDLE_REQUEST`, as shown in Figure 8.29. This required authorization enables the end user to communicate between the frontend and the backend.

Object	Field Name	Icon	From	To
S_RFCACL	ACTVT		16	
	RFC_CLIENT			
	RFC_EQUSER		Y	
	RFC_INFO		*	
	RFC_SYSID			
	RFC_TCODE		*	
	RFC_USER		sy-uname	

Figure 8.29 Default Authorizations for Function Module /IWBEP/FM_MGW_HANDLE_REQUEST

Personal Copy for Arun Singal, arun.singal560@gmail.com

Maintain the targeted frontend system (**RFC_SYSID**) and client (**RFC_CLIENT**) in the end-user role.

Also, check whether the authorization object **/UI2/CHIP** for Transaction **/UI2/FLP** is maintained, as shown in Figure 8.30. These recommended values prevent overauthorization in the SAP Fiori launchpad (**ACTVT**) and provides all SAP standard UI2 page building services (**/UI2/CHIP**) that an end user requires.

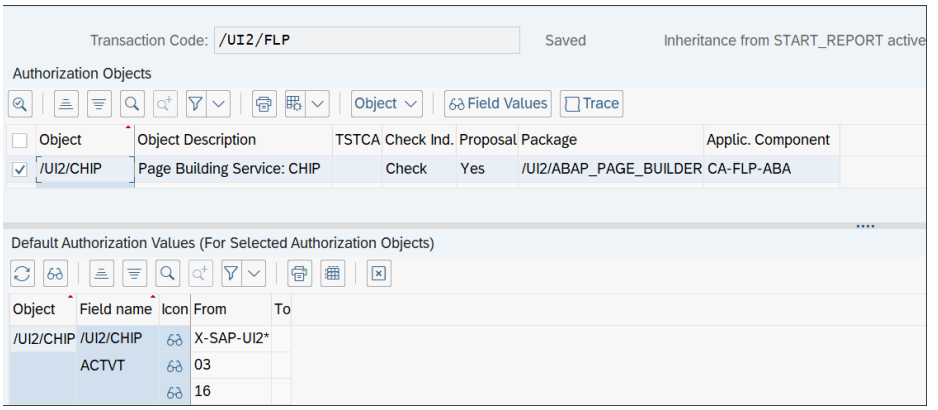


Figure 8.30 Proposal Maintenance of Transaction /UI2/FLP

Hint

The SAP Fiori launchpad (Transaction /UI2/FLP) is the entry point to the UI and only accessible on the frontend server. Therefore, the SAP Fiori launchpad itself is an exception to the typical SAP Fiori role building approach, and you'll need IWSG and IWSV backend services in the frontend role for end users, regardless of whether you deploy SAP Fiori in a central hub or as an embedded deployment.

Role Building Preparation Checklist

Once your system is up and running, with your OData services and ICF nodes activated, you can start creating your custom roles to include SAP Fiori applications. Table 8.5 provides an overview of all SAP Fiori authorization preparation activities.

Step	Activity	Description
1	System patches	Update your system to the latest SAP S/4HANA release.
2	Transaction SU24 optimization	Optimize your proposals in Transaction SU24 according to your business demands and custom developments.

Table 8.5 Role Building Preparation Checklist for SAP Fiori

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Step	Activity	Description
3	User maintenance	The same end user is required on the frontend server and the backend server.
4	SAP Fiori apps reference library	Check your business demands and find the referring SAP Fiori apps via the SAP Fiori apps reference library, SAP recommendation services, or third-party tools.
5	Activation of services	Activate all necessary OData and IFC services.
6	Creation and maintenance of catalogs, groups, and space/pages	Create and maintain all required SAP Fiori components like the catalogs, groups, pages, and spaces.
7	SAP Fiori common end-user role	Assign the common end-user role to all SAP Fiori users.
8	SAP Fiori frontend/backend system roles	Create, maintain, and assign the business roles with all necessary SAP Fiori components (OData services, catalogs, groups, spaces, and pages).

Table 8.5 Role Building Preparation Checklist for SAP Fiori (Cont.)

8.8.3 Role Building for SAP Fiori Applications in the Embedded Deployment

With the SAP Fiori launchpad designer, you can build and maintain custom groups and catalogs. You can also use the SAP Fiori launchpad content manager for managing your catalogs and use SAP Fiori administrative apps for managing spaces and pages.

Go to Transaction PFCG and choose an existing job function role for which you want to maintain an SAP Fiori application. For example, choose the sales manager end-user role to integrate SAP Fiori app ID F2941 and all its components. Assign the business catalog that contains the required apps into the role menu, and Transaction PFCG will automatically add the various OData services (ISWG/IWSV), like `*SALESPERF*` to enable app ID F2941. The OData services propose authorization default values from Transaction SU24. In an embedded deployment, you can put all your business catalogs into the frontend end-user role.

Tip

The only difference between the embedded deployment and the central hub deployment when it comes to role building is that you'll need one frontend role and one backend role with the central hub deployment option. In the embedded approach, you can assign all the required objects into one role. In the central hub deployment, you must assign the two roles separately on each system, that is, on the frontend system and on the backend system.

Personal Copy for Arun Singal, arun.singal560@gmail.com

8.9 Troubleshooting Tools for SAP Fiori

SAP Fiori provides various novel features but also enhances existing authorization and system requirements. Functional complexity through its novel features can increase the technical preparation required and require consideration about new authorization components. SAP continuously allocates new analyzing options via patches and SAP Notes to enable comprehensive SAP Fiori reporting in the SAP Standard. New transactions may be added, and reports enhanced within existing or new applications to overcome hurdles and resolve issues.

The following list summarizes a few selected SAP standard reporting and analyzing applications in SAP Fiori. You should use the following features for the sustainable administration of your SAP Fiori UI authorizations:

- **SAP UI technology support**
  Transaction SUI_SUPPORT provides a comprehensive overview of all SAP UI-related technologies. As a central entry point for setting up SAP Fiori, logs, caches, and jobs, you can use this transaction as the single entry point for SAP Fiori administration, as shown in Figure 8.31. Transaction SUI_SUPPORT also allows various cross-application access like OData service maintenance, managing the SAP Gateway, or role maintenance. Thus, you should provide access to this transaction only to SAP Fiori administrators or security administrators.

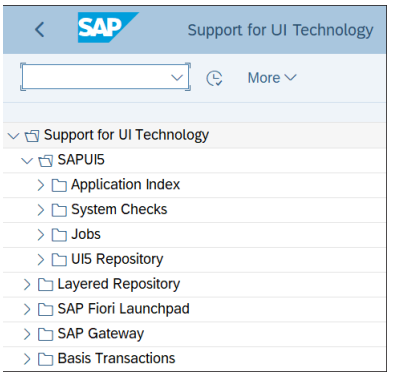


Figure 8.31 Transaction SUI_SUPPORT Initial Screen

- **App Support**
  The App Support option is an application within SAP Fiori that provides similar functionalities to Transaction SU53. App Support allows an end user to display failed authorization checks, information specific to the application, and SAP Gateway and runtime errors. The App Support application must be enabled in SAP Fiori customizing and authorized through a catalog.

  Once configured, a user can access the SAP Fiori launchpad app manager from the user dropdown menu, shown in Figure 8.32.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

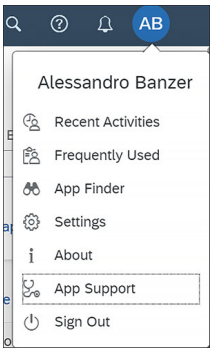


Figure 8.32 App Support from the End-User Dropdown Menu

Once launched, the App Support application shows information about the current application from which App Support was accessed as well as different types of errors. The App Information application is also helpful and indicates the SAP Fiori app ID and other relevant information of the application. This vital information can be included in a support ticket when an end user reports an issue with SAP Fiori. Figure 8.33 shows an example list of SAP Gateway errors, which can also be downloaded by the end user.

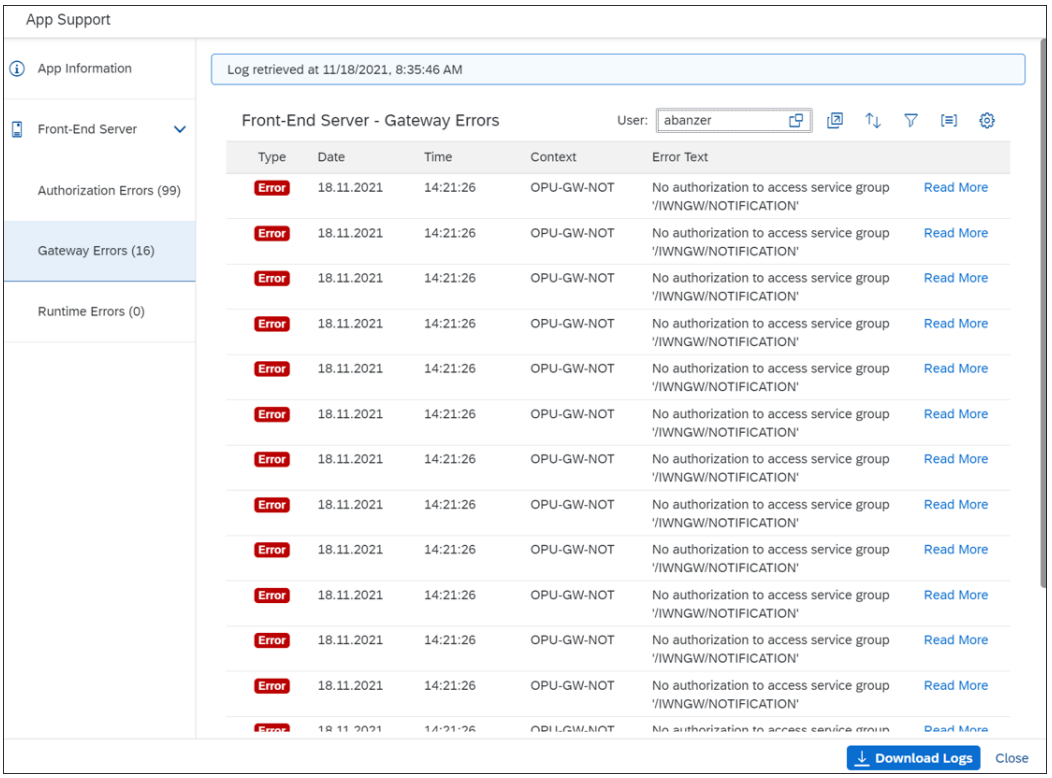


Figure 8.33 Gateway Errors in App Support

Personal Copy for Arun Singal, arun.singal560@gmail.com

The App Support application allows you to display errors from the point of view of your own user or of another user. The ability to access other users' errors is controlled by the authorization object **S_FLP_AS (App Support for SAP Fiori Launchpad)**, as shown in Figure 8.34. This object allows to you either grant access for the **Current user only** or **All users**. We recommend authorizing the App Support application through the general end-user role so that every user can access it. For security administrators, as well as key users and power users, you should grant the ability to access the information of other users (**All users** authorization).

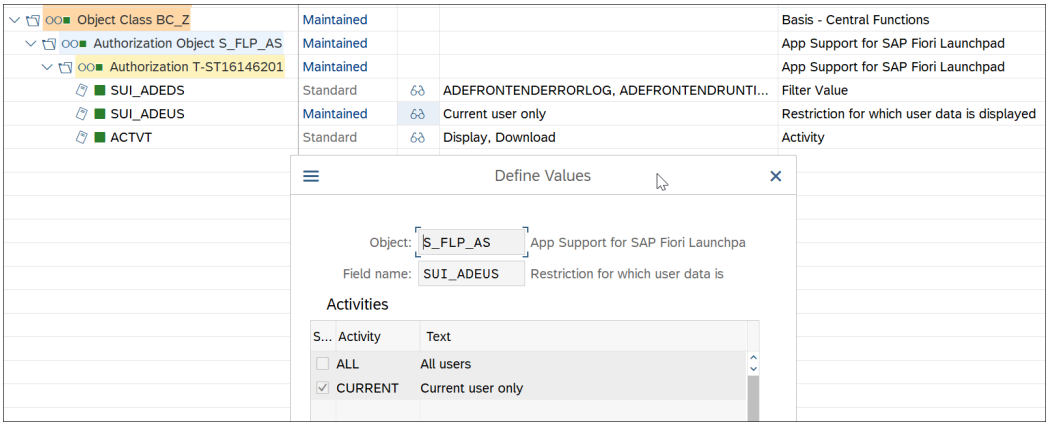


Figure 8.34 Authorizations for App Support

The App Support application is a great tool that should be made available to all your end users since the information can be quite helpful when investigating issues.

- **In-education help**
  The in-education help combines on-screen guidance and e-learnings into one. The in-education help feature must be customized and enabled before it can be used. Once available, the in-education help is accessible from the top navigation bar in the SAP Fiori launchpad as shown in Figure 8.35.

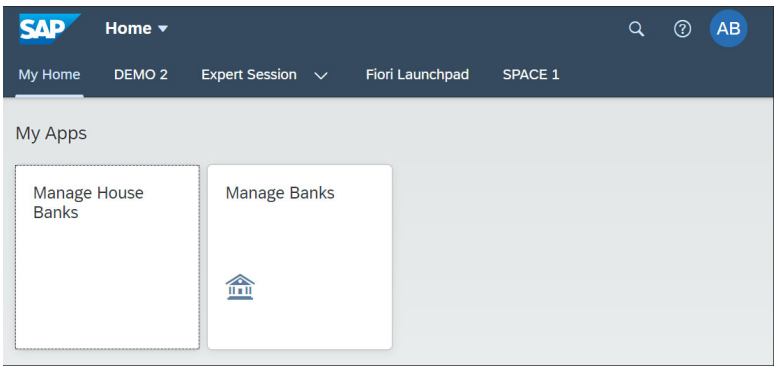


Figure 8.35 In-Education Help in the SAP Fiori Launchpad

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The **Help** icon can be accessed from any application and shows the information relevant to the currently activate application. The in-education help is a great feature to provide learning content to your end-user community. The on-screen guidance is a fast and efficient way to learn how to navigate the application at hand. In addition, the e-learnings provide an interactive way to master an application.

Once you access the in-education help from an SAPUI5 application, you can switch between the on-screen guidance and the e-learnings via the navigation bar on the right. The on-screen guidance, shown in Figure 8.36, relates directly to your current application. For example, the Manage Banks app has four different on-screen guidance options: **My Banks**, **Create Bank**, **Mark as Deleted**, and **Edit Contact**. The **Create Bank** guidance, shown in Figure 8.36, provides advice on where a user must click to create a bank. You can hover over the blue circles to show more information about that particular field or button.

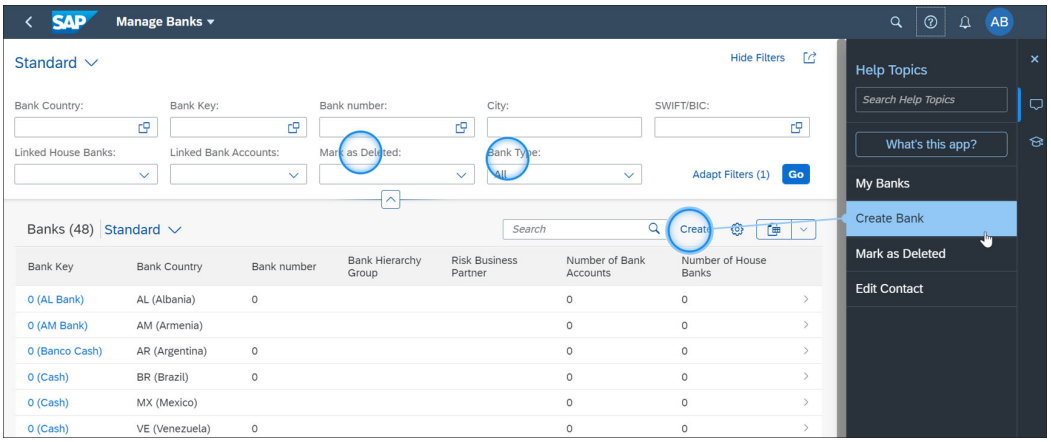


Figure 8.36 In-Education Help on-screen guidance

On the **Learning** pane, you'll find direct links to interactive e-learnings hosted at *https://learning.sap.com*. These interactive e-learnings are an efficient way to train end users that are new to SAP Fiori and provide guidance on how to create and maintain certain scenarios in SAP Fiori. For example. Figure 8.37 shows the **Managing Banks** learning module, which can guide end users through the process of creating a bank in the system.

The in-education help feature is a great extension of the SAP Fiori experience and should always be made available to your end users. This feature provides solid knowledge about SAP Fiori apps as well as other educational content in form of interactive e-learnings.

Personal Copy for Arun Singal, arun.singal560@gmail.com

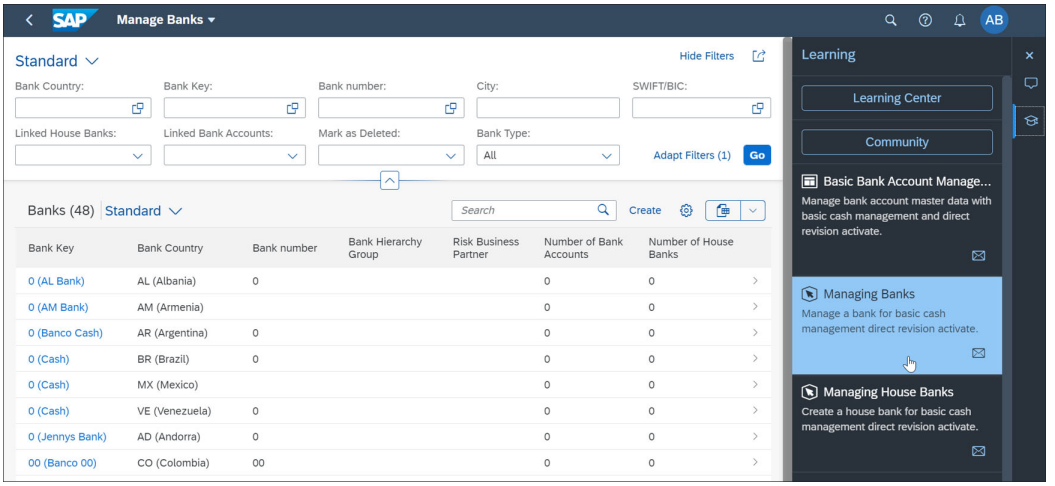


Figure 8.37 Learning Resources in the In-Education Help

Tip

More information on how to activate and enable the In-Education Help feature can be found at *https://blogs.sap.com/2020/01/07/sap-fiori-for-sap-s-4hana-how-to-setup-the-user-assistant-in-your-s-4hana-fiori-launchpad/*.

- **SAP Fiori reporting and troubleshooting transactions**
  In practice, technical issues are not always based on authorization failures but instead could be provoked by, for example, missing system components, outdated applications, careless custom code developments, or even hardware problems. For example, through the new SAP UI, SAP Fiori, you must activate specific system settings and parameters and consider novel entities like business catalogs, OData services, or CDS views. So that you can handle possible errors in this web-based environment, Table 8.6 lists some required and helpful transactions for failure analysis.

Level	Transaction	Description
Frontend	/IWFND/ERROR_LOG	Error log from SAP Gateway.
Frontend	/IWFND/APPS_LOG	SAP Gateway: Application-Viewer.
Frontend	/IWFND/CACHE_CLEANUP	Resolving of SAP Gateway model caches.
Frontend	/IWFND/MAINT_SERVICE	Activate and dispense services.
Frontend	/UI2/CHIP_SYNCHRONIZE_CACHE	Synchronize the chip cache.

Table 8.6 SAP Fiori Reporting and Troubleshooting Options

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Level	Transaction	Description
Frontend	/UI2/DELETE_CACHE	Delete the chip cache.
Frontend	/UI2/FLC	Checks for the SAP Fiori launchpad.
Frontend	/UI2/FLC1	Check for orphaned business catalogs and groups.
Frontend	/UI2/FLIA	SAP Fiori launchpad intent analysis.
Frontend	/UI2/FSAC	SAP Fiori launchpad system alias check.
Frontend	PRGN_COMPARE_ROLE_MENU	You can mass update the role menu with business catalogs, business groups, and space/pages (SAP Note: 2465999).
Frontend	RSUSR_ROLE_MENU	Transaction SUIM to search for business catalogs and BUSINESS GROUPSs (SAP Note: 2341600).
Frontend	RSUSR_START_APPL	Transaction SUIM to search for authorizations to start applications (SAP Note: 2449011).
Frontend	SACM	Use the Runtime Simulator to check CDS entity failures.
Frontend	SE16(N)	Check table `/IWFND/I_MED_SRH` to determine if all required IWSG services are activated.
Frontend	SLG1	Check the application logs.
Frontend	SU25	Check step 2d for enhanced SAP Fiori information.
Frontend	STAUTHTRACE/ST01	Analyze missing authorizations while the Web Service starts (S_SERVICE).
Backend	/IWBEP/ERROR_LOG	SAP Gateway backend error log.
Backend	/IWBEP/VIEW_LOG	SAP Gateway: Protocol Viewer.
Backend	/IWBEP/CACHE_CLEANUP	Resolving of SAP Gateway model caches.

Table 8.6 SAP Fiori Reporting and Troubleshooting Options (Cont.)

You can also use the developer tools found in every web browser for more information about error codes and issues causes within the SAP Fiori environment.

In addition, for authorization issues, you can check the role menu objects and authorization characteristics in your end-user roles. Go through the preparation checklist from Section 8.8.2 for further insights.

Personal Copy for Arun Singal, arun.singal560@gmail.com

8.10 Xiting Authorizations Management Suite: Tool-Driven SAP Fiori Objects Implementation and Analysis

SAP provides several tools and functionalities to create and maintain SAP Fiori components. However, mass features to create catalogs, groups, and pages, as well as the ability to create roles in batches, are missing. XAMS offers functionalities and tools that help you build these components en masse as well as access insightful reports and functionalities to detect issues before they occur on the user level.

The following sections outline some of XAMS's main capabilities with SAP Fiori.

8.10.1 Xiting Role Replicator

Xiting Role Replicator offers various tools for creating and maintain SAP Fiori components more efficiently by providing the ability to mass process data from Microsoft Excel or CSV files. For example, you can prepare an upload file that contains two columns (catalog name and catalog description) to mass create hundreds of catalogs in one shot. Not only can you create catalogs; you can also assign tiles and target mappings to your catalogs to fully build them. Assigning catalogs to roles can also processed via an upload file.

Spaces and their pages, as well as groups, can be mass created via an upload file too. Xiting Role Replicator is the preferred tool for mass creating and mass maintaining various components for SAP Fiori, as well as for traditional authorizations.

Figure 8.38 shows an example of an upload file (CSV or Excel file) for mass creating five catalogs. Xiting Role Replicator processes this upload file in one shot and creates the five catalogs in just a few seconds.

ZP_BC_FI_GLOB_ACC_MGMT	BC for Accounting Management
ZP_BC_MM_GLOB_PUR	BC for Purchaser
ZP_BC_SD_GLOB_SALES_KEY	BC for Sales Keyuser
ZP_BC_SD_GLOB_INT	BC for Sales Internal
ZP_BC_CO_GLOB_REP	BC for Controlling Reporting

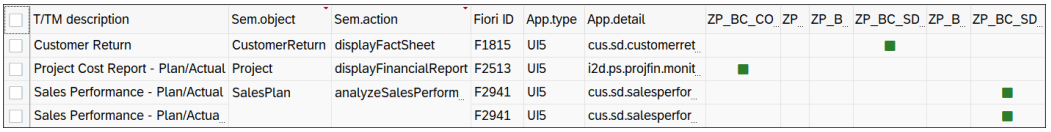
Status	Message Text
	Catalog ZP_BC_CO_GLOB_REP has been created
	Catalog ZP_BC_FI_GLOB_ACC_MGMT has been created
	Catalog ZP_BC_MM_GLOB_PUR has been created
	Catalog ZP_BC_SD_GLOB_INT has been created
	Catalog ZP_BC_SD_GLOB_SALES_KEY has been created

Figure 8.38 Mass Generation of Business Catalogs via XAMS

In addition to mass processing based on upload files, Xiting Role Replicator offers graphical views of catalogs and their assigned tiles and target mappings. You can use this solution to compare different catalogs with each other or model them if you want to rearrange their contents. You can also automatically add additional tiles and target mappings that are currently not assigned to any catalogs. Also, directly in the view, you

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

can manually add missing SAP Fiori elements by clicking in an empty cell or unassign elements by clicking on an object's green icons, as shown in Figure 8.39. Furthermore, an export function helps you download your entire collection of catalogs with all their details.



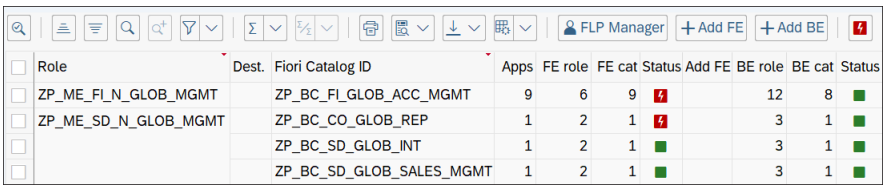
T/TM description	Sem.object	Sem.action	Fiori ID	App.type	App.detail	ZP_BC_CO	ZP	ZP_B	ZP_BC_SD	ZP_B	ZP_BC_SD
Customer Return	CustomerReturn	displayFactSheet	F1815	UI5	cus.sd.customerret				■		
Project Cost Report - Plan/Actual	Project	displayFinancialReport	F2513	UI5	i2d.ps.projfin.monit	■					
Sales Performance - Plan/Actual	SalesPlan	analyzeSalesPerform	F2941	UI5	cus.sd.salesperfor						■
Sales Performance - Plan/Actua			F2941	UI5	cus.sd.salesperfor						■

Figure 8.39 Graphical Matrix View for Catalog and Tile/Target Mapping Modeling

8.10.2 Xiting Role Profiler

Xiting Role Profiler, the analysis tool of XAMS, contains several helpful reports for managing your SAP Fiori environment. Due to the increased complexity that comes with additional entities like catalogs, groups, spaces, and pages, or to the massive information available in the SAP Fiori apps reference library, you must consider more requirements than during traditional role creation. Time-consuming effort might be required to collect all necessary details or to match the former transactions to their new SAP Fiori applications.

For example, the OData Services for SAP Fiori report checks a role for its SAP Fiori catalogs and then analyzes the relevant OData services for those catalogs. The report provides an overview of the actual status to see what roles contain OData services that don't exist. This report differentiates between frontend and backend services so you can run this report in either scenario. If an error arises, you can automatically create the missing services and add them to the role menu from Xiting Role Profiler, as shown in Figure 8.40.

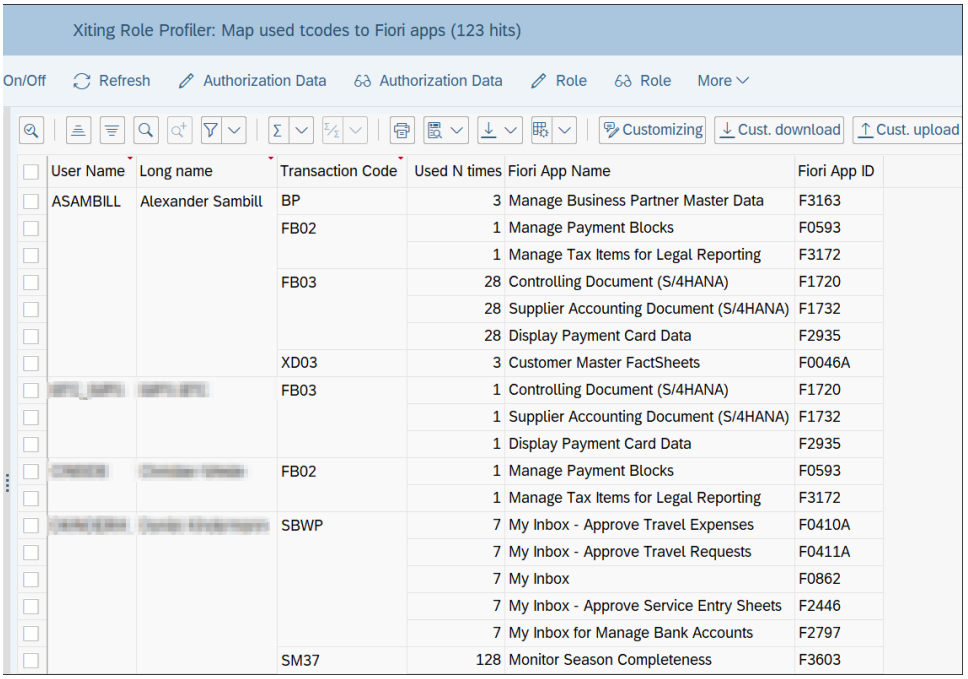


Role	Dest.	Fiori Catalog ID	Apps	FE role	FE cat	Status	Add FE	BE role	BE cat	Status
ZP_ME_FI_N_GLOB_MGMT		ZP_BC_FI_GLOB_ACC_MGMT	9	6	9	■		12	8	■
ZP_ME_SD_N_GLOB_MGMT		ZP_BC_CO_GLOB_REP	1	2	1	■		3	1	■
		ZP_BC_SD_GLOB_INT	1	2	1	■		3	1	■
		ZP_BC_SD_GLOB_SALES_MGMT	1	2	1	■		3	1	■

Figure 8.40 Overview of OData Services within Existing Roles

In addition, Xiting Role Profiler includes reports that provide insight into your current authorization concept. For example, you can see the SAP Fiori applications required by your end users based on their transactional usage in the past (e.g., from Transaction ST03N). The report provides proposals of possible SAP Fiori apps that replace or enhance the functionality of previous transactions, as shown in Figure 8.41.

Personal Copy for Arun Singal, arun.singal560@gmail.com



User Name	Long name	Transaction Code	Used N times	Fiori App Name	Fiori App ID
ASAMBILL	Alexander Sambill	BP	3	Manage Business Partner Master Data	F3163
		FB02	1	Manage Payment Blocks	F0593
			1	Manage Tax Items for Legal Reporting	F3172
		FB03	28	Controlling Document (S/4HANA)	F1720
			28	Supplier Accounting Document (S/4HANA)	F1732
			28	Display Payment Card Data	F2935
		XD03	3	Customer Master FactSheets	F0046A
[redacted]	[redacted]	FB03	1	Controlling Document (S/4HANA)	F1720
			1	Supplier Accounting Document (S/4HANA)	F1732
			1	Display Payment Card Data	F2935
[redacted]	[redacted]	FB02	1	Manage Payment Blocks	F0593
			1	Manage Tax Items for Legal Reporting	F3172
[redacted]	[redacted]	SBWP	7	My Inbox - Approve Travel Expenses	F0410A
			7	My Inbox - Approve Travel Requests	F0411A
			7	My Inbox	F0862
			7	My Inbox - Approve Service Entry Sheets	F2446
			7	My Inbox for Manage Bank Accounts	F2797
		SM37	128	Monitor Season Completeness	F3603

Figure 8.41 Xiting Role Profile Report: Mapping between Transaction Codes and SAP Fiori Apps

8.11 Summary

SAP Fiori is an exciting new UI that enhances business processes with a unified UX. The setup, configuration, and authorization of SAP Fiori may seem cumbersome at first, but this process follows many of the known tools and approaches common from the traditional ABAP world. SAP Fiori introduces a few new components like catalogs, groups, spaces, and pages, which must be built through tools that are only available with SAP Fiori. Once built, authorizing these components in your existing authorization concept is similar to the traditional approach with transactions.

In the next chapter, we'll discuss user maintenance.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 9
User Maintenance

The user ID grants access to an SAP system so that users can perform certain functions based on their authorizations. Managing different types of users and understanding their capabilities is a key part of managing authorizations.

To log on to an SAP system, you require a user ID, also called a *user master record*. A user master record contains all the information necessary to log on and successfully execute transactions in an SAP system. Authorizations are granted by authorization profiles, which are either assigned through roles or profiles.

This chapter presents the management and handling of user accounts and the measures you should take to configure your systems securely. Every user master record has a lifecycle, from the initial creation of the account, through changes in existing attributes, all the way to the deletion of the account. In this chapter, we'll provide an overview of managing user master records in SAP. We'll explain the various types of users available, when to use which type, and how to differentiate them from one another.

Changes to a user master record are always necessary since parameters, processes, jobs, and their assigned authorizations change. How to mass change users, for example, or how to mass assign and reassign authorizations will be described in this chapter. In addition, this chapter will provide insights into the central user administration (CUA), a free solution from SAP to centrally manage users across your landscape. This chapter also discusses naming conventions and highlights the importance of putting standards into place as well as how to group users into user groups.

Since every SAP installation starts with a standard user (a standard user is created when the SAP system is installed), this chapter also provides some tips and tricks on how you should take care of your standard users and properly protect them. This discussion includes password rules—for all user types, not only standard users—as well as how to deal with inactive accounts.

9.1 Maintenance of the User Master Record

A user master record contains authorization objects that allow or deny a user from viewing, updating, and/or deleting relevant data in the SAP system. An SAP ABAP-based

Personal Copy for Arun Singal, arun.singal560@gmail.com

system follows a positive authorization concept, which means you must explicitly specify which functions can be executed by a user.

User IDs are client dependent and stored in table USR02. To access different clients, the user must be created in each client separately. Also, passwords are client dependent and must follow the password rules that are specifically described in Section 9.2. In the following sections, we'll provide an overview of the various user types available when creating a user account, how to create and maintain user accounts, and how you can document user master records. Since changes will always be required, the following sections will also guide you through mass change tools.

9.1.1 Different User Types

An SAP system has five different types of users that can be created and authorized, as shown in Table 9.1.

User Type	Dialog Logon	Multiple Logon	Remote Function Call (RFC) Logon	Password Expires	Password Change by User	Background Job Execution
Dialog	yes	no	yes	yes	yes	yes
System	no	yes	yes	no	no	yes
Communication	no	yes	yes	yes	yes (RFC function module)	no
Service	yes	yes	yes	no	no	yes
Reference	no	yes	no	no	no	no

Table 9.1 Properties of the Users of Different User Types

Let's look at each of these user types:

- **Dialog user: type "A"**
  The DIALOG user is the most common user type in an ABAP system. A DIALOG user can log on to SAP via SAP GUI or an equivalent logon method (e.g., SAP NetWeaver Business Client). A DIALOG user should always represent one natural person and cannot be shared with other natural persons, due to licensing compliance. During a dialog logon, the SAP system checks if the password is expired, or if this logon attempt is the first logon for the user, and requests a new valid password be set. Multiple dialog logons are checked and logged if necessary. Users can change their own passwords.
- **System user: type "B"**
  A SYSTEM user is used for technical, system-related processing like background processing or workflows. Specific applications like the SAP Transport Management

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

System (STMS) and CUA use the SYSTEM user. The SYSTEM user is excluded from password validity settings. Contrary to a DIALOG user, multiple logons are permissible. This password can only be changed by an administrator.

- **Service user: type "S"**
  A user of the type service is a DIALOG user available to a large number of anonymous users. SERVICE users are authorized restrictively since the system doesn't check whether the password has expired, nor does it check whether a password has been used. Also, the maintenance of SERVICE users should be restricted. A typical example of a SERVICE user is a firefighter ID used in SAP Access Control. The firefighter ID is available to a predefined set of users so these users can log on and perform emergency activities, which usually involve highly sensitive access. Even though SAP Access Control tracks the usage of firefighter IDs, all the activities are performed in the context of the firefighter ID, which is a SERVICE user.
- **Communication user: type "C"**
  A COMMUNICATION user is used for dialog-free communication between systems using RFC or CPIC. Dialog logon using SAP GUI is not possible with this kind of user. Its password can be changed by a user and does expire. However, to change the password, the caller system must use the RFC function module USR_USER_CHANGE_PASSWORD_RFC.
- **Reference user: type "L"**
  A REFERENCE user is like a SERVICE user and not assigned to a specific person. Dialog logon is not possible. The REFERENCE user was introduced to assign additional authorizations to users and go beyond the authorization profile limit of 312. The kernel always performs authority checks against the REFERENCE user first and, if failed, next against the DIALOG user assigned to the REFERENCE user.

9.1.2 Creating and Maintaining a User

The central transaction for administering users is Transaction SU01. With this transaction, an administrator can create, maintain, and delete users as well as change user properties and parameters, assign roles and manual profiles, change logon data, and more.

Let's look at the various screens and tabs in Transaction SU01 and walk you through the steps for creating and maintaining users next:

- **Navigation**
  On the initial screen, shown in Figure 9.1, you can select or define a user based on the user ID or alias. Once selected, you can create, change, display, copy, delete, and lock/unlock a user as well as reset its password.

  To create a user, you must define a user ID that is a maximum of 12 characters long. User IDs should follow a naming convention so you can easily differentiate between, for example, users for real people or SYSTEM users. This distinction is also important

Personal Copy for Arun Singal, arun.singal560@gmail.com

when searching for users (e.g., for mass changes). In addition, you should easily distinguish between technical users and DIALOG users.

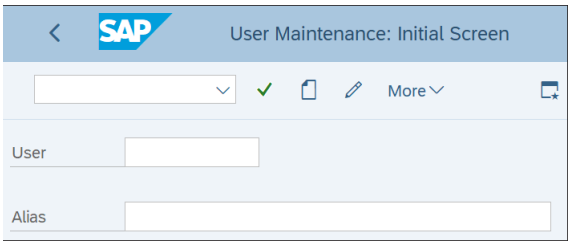


Figure 9.1 Initial Screen of Transaction SU01

A user master record consists of different tabs that can be maintained through Transaction SU01. Table 9.2 provides a quick overview of the available tabs.

Tab	Description
Documentation	Free form text to capture documentation regarding the user
Address	Information about the user and how to contact them
SNC (Secure Network Connection)	Secure Network Connection (SNC) parameters
Logon Data	Password, user type, and validity for the user
Defaults	Default values for the user
Parameters	Standard field defaults
Roles	Role assignments to the user
Profiles	Profile assignments to the user
Groups	Assignment to user groups
Personalization	Person-related settings for personalization purposes
Lic. Data (license data)	Classification for measurement
DBMS	Database management for SAP HANA databases

Table 9.2 User Maintenance Tabs

- **Documentation**
  With SAP NetWeaver 7.50, the **Documentation** tab, as shown in Figure 9.2, was introduced to document changes to a user. The idea behind this tab is that changes to a user can only be detected by the change documents, which lack explanation. Therefore, the **Documentation** tab allows you to document the reason for a change,

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

including for changes to technical users like RFC users. In addition, you can define a responsible person for the user.

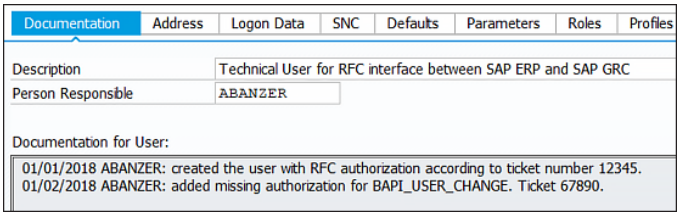


Figure 9.2 Documentation Tab in Transaction SU01

To delete the documentation of selected users, use report RSUSR_DELETE_USERDOCU. This report is a cleanup report and allows you to delete the documentation for several users en masse (e.g., after a system copy).

- **Address**
  When you create a user, the system asks for two mandatory fields. One of these mandatory fields is the **Last name**, which is maintained under the **Address** tab, as shown in Figure 9.3.

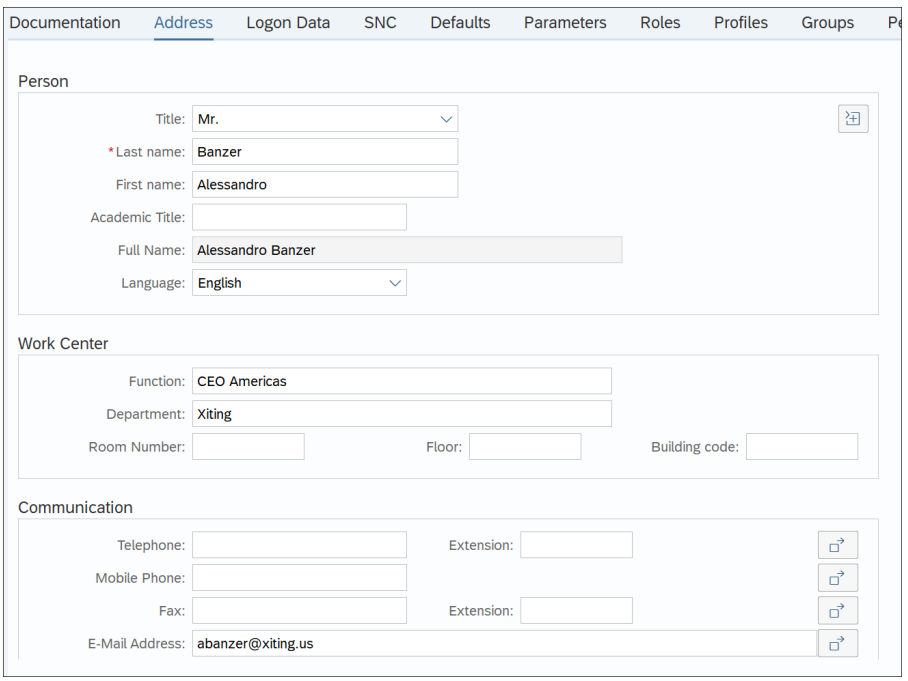


Figure 9.3 Address Tab in Transaction SU01

Under the **Address** tab, you'll maintain personal information about the user itself, about the work center the user works for, about communication methods, and

Personal Copy for Arun Singal, arun.singal560@gmail.com

about the company assignment. For example, when using workflows and automated system emails, most default programs work with the email address that is maintained in Transaction SU01. Therefore, you must ensure that those fields are maintained accordingly.

Company addresses can be maintained in Transaction SUCOMP.

- **Logon Data**

  Under the **Logon Data** tab, you can maintain a second mandatory field for the user master record—the initial password. Without an initial password, you cannot create a user. Other than the initial password, under the **Logon Data** tab, you'll define the user type as well as a specific security policy, if desired. Also, a user alias can be used to identify a user ID with a longer (over 40 characters) and more descriptive name.

  The initial password can either be entered manually or be automatically generated by the system based on the system password rules. Also, you can also deactivate a password so that the user cannot log on to the system with a password. If deactivated, an alternative logon method through single sign-on (SSO), for instance, X.509 certificates or logon tickets, must be used. When using SSO methods, we recommend deactivating passwords to increase security since most passwords will usually remain in their initial state because they are never used and thus never changed.

  An important field is in the **User Group for Authorization Check** section, shown in Figure 9.4, which is used to protect user maintenance. If you decide to divide up user maintenance responsibilities among several user administrators, you can segregate authorizations by user group, for example, in authorization object S_USER_GRP.

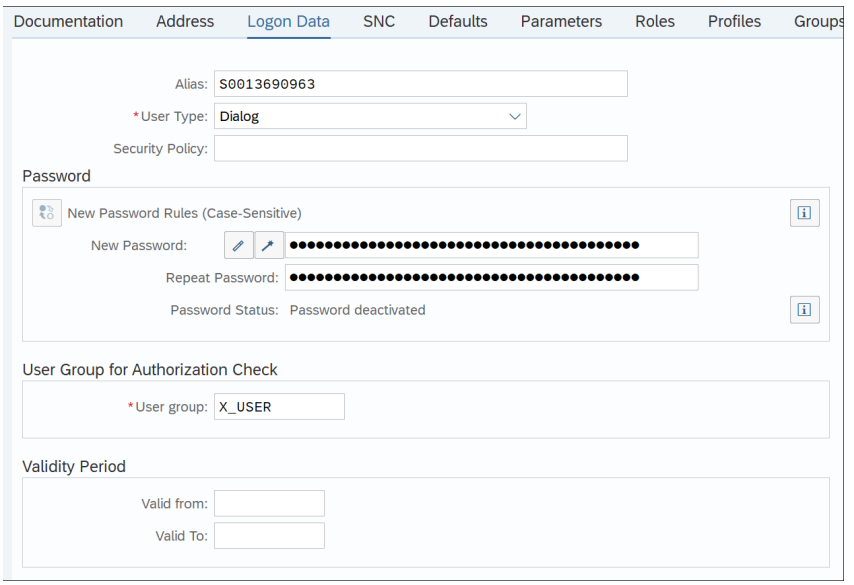


Figure 9.4 Logon Data Tab in Transaction SU01

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

If you wish to make the **User Group for Authorization Check** a mandatory field, check and implement SAP Note 1663177 – SU01: User group as required entry field.

In the **Validity Period** section, you can define the validity period for a user. If the validity period falls in the past, the system will not allow logons regardless of whether the user is locked or not.

It is important to remember that a user group for the authorization check should always be maintained. If the user group is not assigned, every administrator with access to S_USER_GRP and the corresponding activities will be able to administer the user.

Tip

You can configure automated emails that are encrypted to send out the initial password to the maintained email address of the user. For more information, check and implement SAP Note 1750161 – User administration: Saving additional information.

- **SNC**

  The **SNC** tab, shown in Figure 9.5, allows defining an external security product (e.g., SAP Single Sign-On) to secure the communication between the SAP GUI and the application server. Before SAP NetWeaver 7.40, the **SNC** tab was only shown if you had activated the profile parameter `snc/enable`. As of SAP NetWeaver 7.40, the tab is always shown.

Tip

SAP Single Sign-On is not only beneficial for end users but also for security administrators as it lessens the burden of user administration tasks like password resets. It does not completely eliminate password resets, but it reduces them to a minimum. At the same time, SAP Single Sign-On increases the overall security as user passwords can be deactivated, thus reducing the likelihood of abusing user IDs.

- **Defaults**

  You can define default settings for a user under the **Defaults** tab, as shown in Figure 9.6. Each user can change the defaults via Transaction SU3 for the own user. You can define the start menu for a user if it should be different from the system's default start menu. For more information about the system's default start menu or to set a default start menu, use Transaction SSM2.

Personal Copy for Arun Singal, arun.singal560@gmail.com

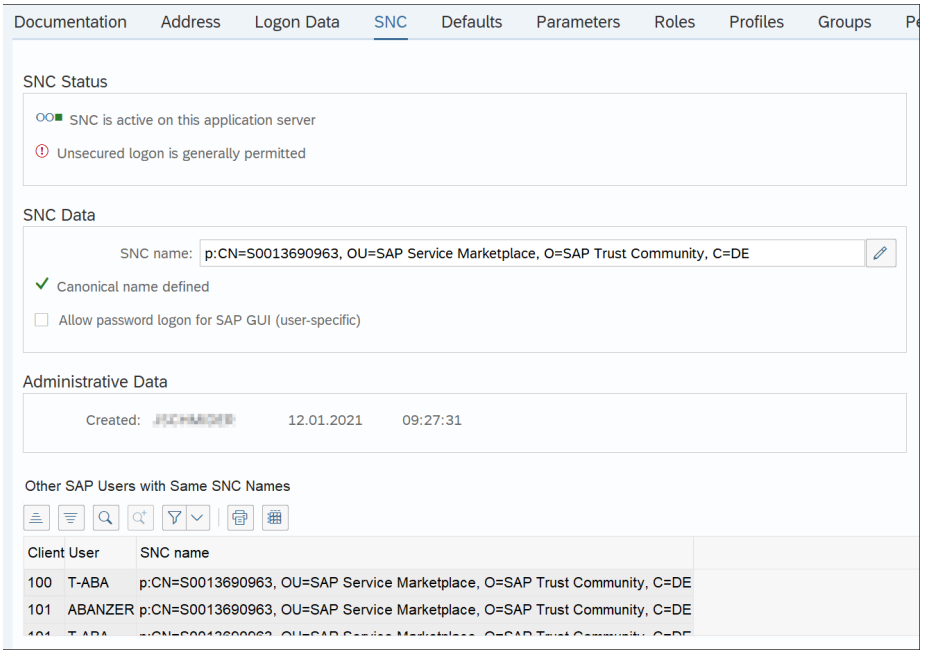


Figure 9.5 SNC Tab in Transaction SU01

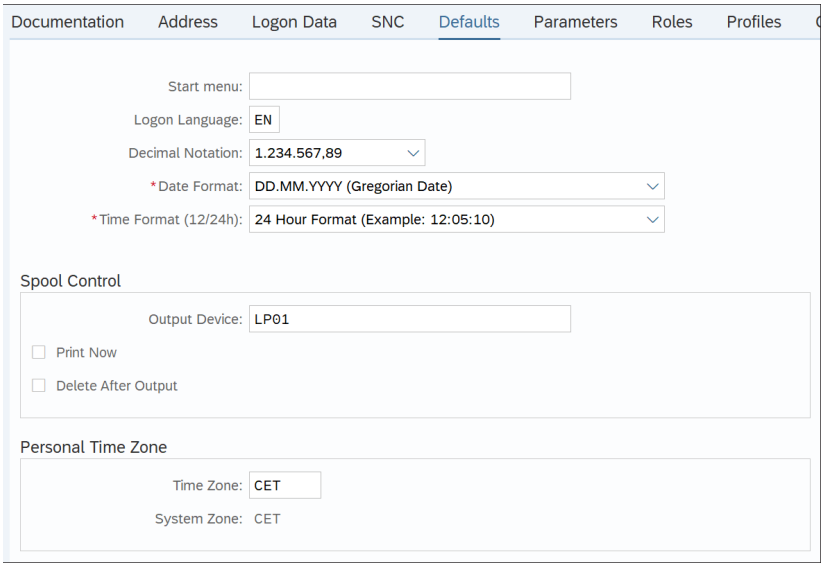


Figure 9.6 Defaults Tab in Transaction SU01

A logon language can be preset for a user. However, the user can later change the language during logon via the logon screen in SAP GUI. The date and time format as well as the decimal notation can be set using system proposals. Also, you can define an output device for a user as well as a time zone.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Parameters**

  Under the **Parameters** tab, you can define certain default parameters for a user. For example, you can define the **company code (BUK)** for a user. A user would usually set this parameter via Transaction SU3.

  Suppose you want to set the company code with the parameter ID **BUK**, as shown in Figure 9.7. In this case, the user won't need to enter their company code on input fields. The system will automatically populate the company code each time the system requires that input field.

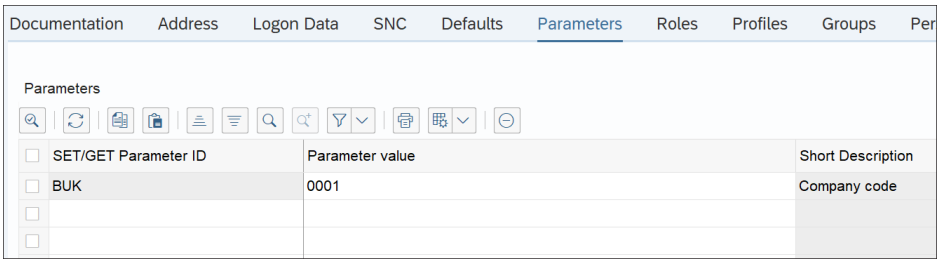


Figure 9.7 Parameters Tab in Transaction SU01

- **Roles**

  Under the **Roles** tab, you can assign and maintain the roles assigned to a user. Roles are assigned with a start and end date, as shown in Figure 9.8. Each role can either be assigned directly or indirectly. The last column indicates whether the role directly assigned or only indirectly assigned through a composite role or a `REFERENCE` user.

  As of SAP NetWeaver 7.40, you can display assignments that come through a `REFERENCE` user directly in Transaction SU01.

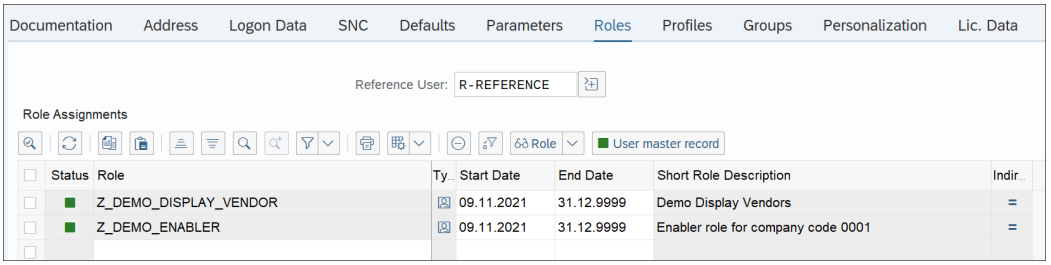


Figure 9.8 Roles Tab in Transaction SU01

Tip

Check SAP Note 2110144 - SU01: Display of reference user roles to display the role assignments that come through a `REFERENCE` user directly in Transaction SU01.

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Profiles**
  Under the **Profiles** tab, you'll see the authorization profiles of the assigned roles as well as directly assigned profiles, as shown in Figure 9.9. You can assign and remove profiles from this screen. A best practice is to authorize users via roles, not via manual profiles.

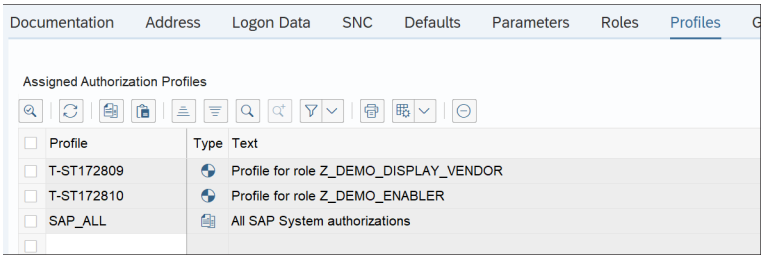


Figure 9.9 Profiles Tab in Transaction SU01

Before SAP NetWeaver 7.40, you could add authorization profiles under the **Profiles** tab manually. However, when you run the User Master Data Reconciliation job (Transaction PFUD) those assignments would be removed automatically. Therefore, always assign roles to a user; do not assign the authorization profiles of roles to users.

- **Groups**
  Under the **Groups** tab, you can create a grouping of users, as shown in Figure 9.10. An important point to note is that these groups are different from the user groups maintained under the **Logon Data** tab. The **Groups** tab is primarily used for grouping purposes and does not control any authorization. Only the user group specified under the **Logon Data** tab is checked during an authorization check.

  For example, this grouping can be used to select groups in Transaction SU10 (User Mass Maintenance) or Transaction SUIM (User Information System).

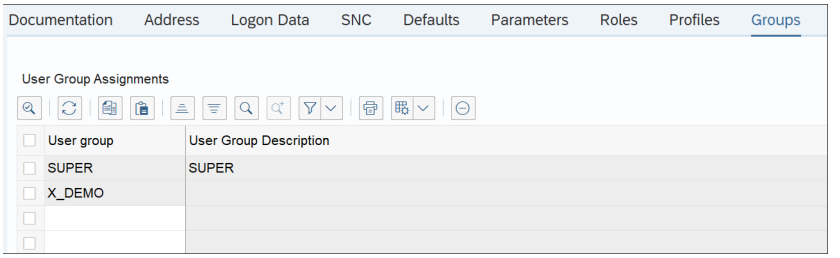


Figure 9.10 Groups Tab in Transaction SU01

- **Personalization**
  Under the **Personalization** tab, although not completely used yet, you can define person-related settings using a personalization object, as shown in Figure 9.11. The

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

same tab is also available during role maintenance in the profile generator (Transaction PFCG). As an example, you can define certain settings that control the output of certain programs, like number of entries that are displayed.

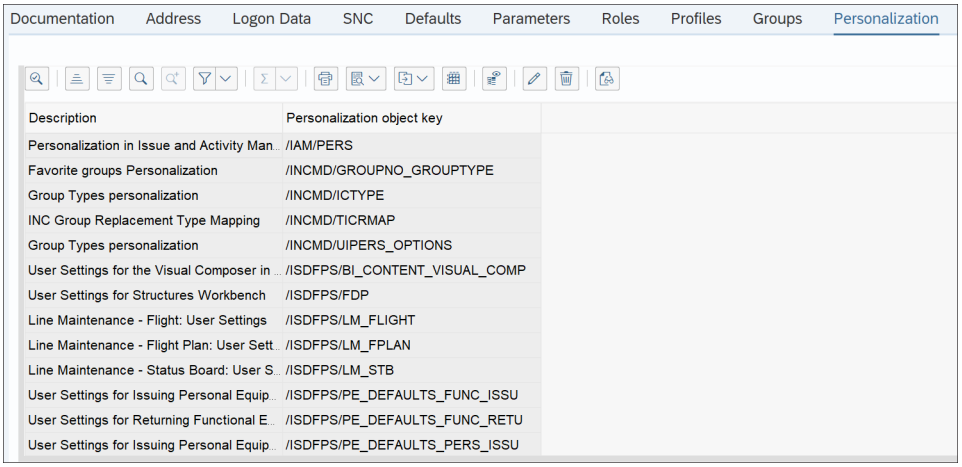


Figure 9.11 Personalization Tab in Transaction SU01

- **Lic. Data**

  Under the **Lic. Data** tab, you can define the contractual user type of a user for use in licensing classification, as shown in Figure 9.12. Each user can be assigned to one classification. For more information about the user classification, see Section 9.5.

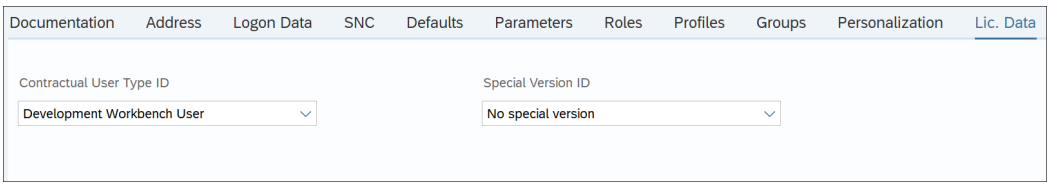


Figure 9.12 Lic. Data Tab in Transaction SU01

- **DBMS**

  In the latest SAP NetWeaver releases, a dedicated tab for the database management system (DBMS) has been introduced, the **DBMS** tab, shown in Figure 9.13. Under this tab, you can enable the application service to manage users and their privileges on the database. Currently, only SAP HANA as a database is supported.

  With SAP S/4HANA, certain use cases require a user also have a database user on the database (SAP HANA). To simplify the administration of these database user, SAP introduced the **DBMS** tab to create and maintain database users and their privileges in Transaction SU01.

Personal Copy for Arun Singal, arun.singal560@gmail.com

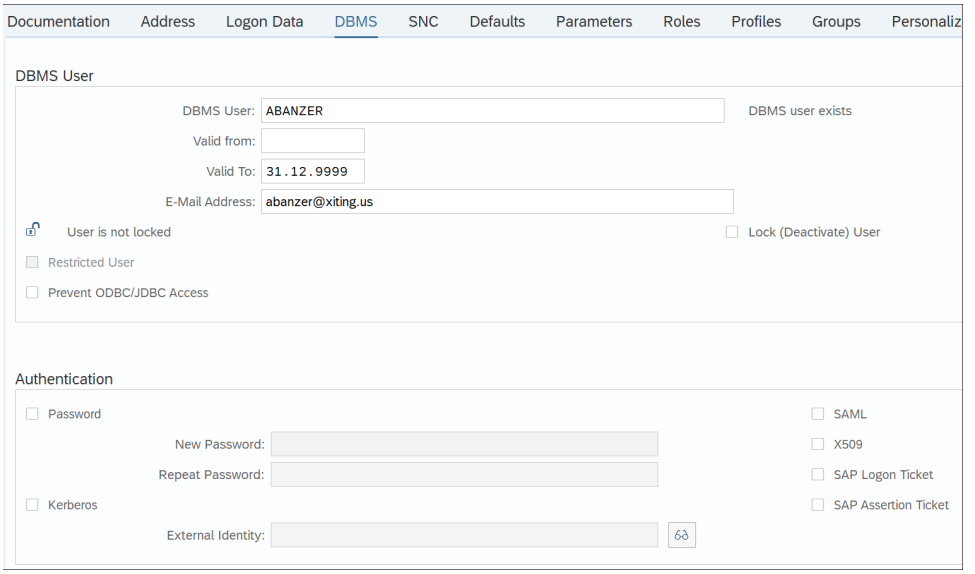


Figure 9.13 DBMS Tab in Transaction SU01

9.1.3 Copying a User

In Transaction SU01, you can copy an existing user and create a new user ID. To copy a user, enter the user ID you want to copy and click the **Copy** icon from the toolbar.

Once you click on the **Copy** icon, a popup window will display the user you want to copy from as well as a new user ID (in the **To** field), which must be changed accordingly. You must then also define which user attributes to copy, as shown in Figure 9.14. By default, the system suggests everything except the **Address Data** and **Documentation** information, which are usually user specific. Based on what you're trying to achieve, you can also select or deselect some attributes.

Once you click the **Copy** icon, you'll proceed to the regular Transaction SU01 screen but with the selected attributes prepopulated. Of course, you can always make changes in these sections since the attributes you've selected are only suggestive.

9.1.4 Change Documents for Users

Several ways exist to access the change documents of a user. The most common way is through Transaction SU01 by following the menu path **Information • Change Documents for Users**.

In the selection screen for change documents, select the user(s) and other parameters (like who performed the change, when it was changed, etc.), as shown in Figure 9.15.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

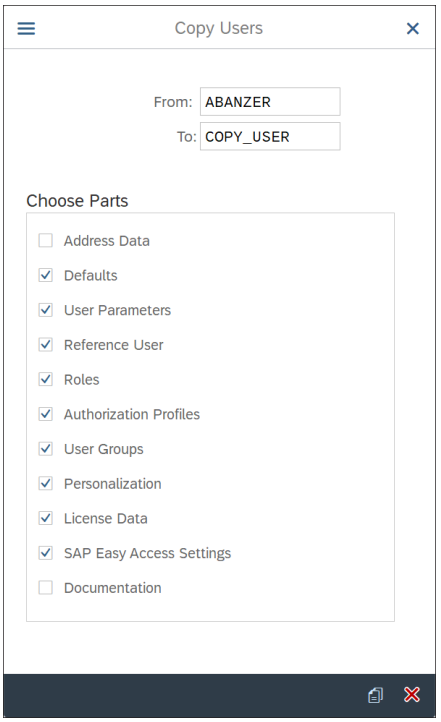


Figure 9.14 Copying a User

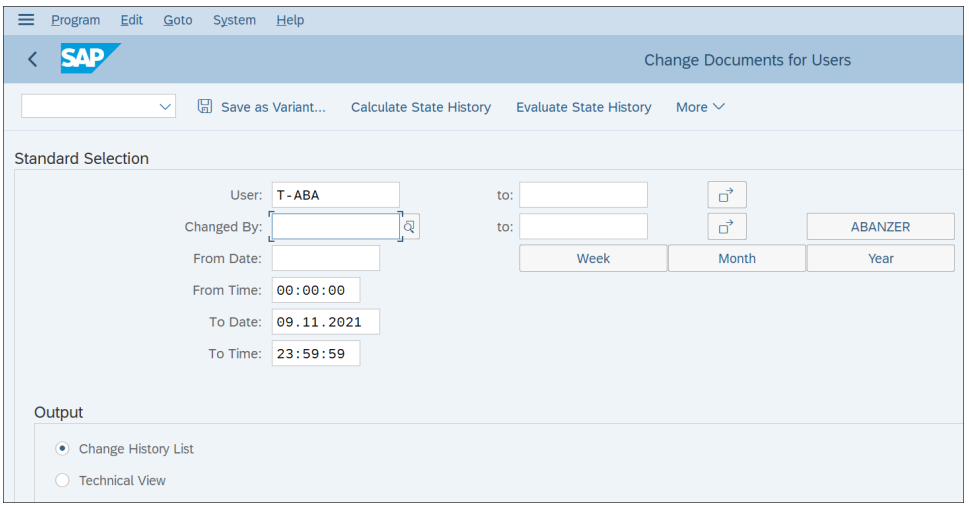


Figure 9.15 Change Documents for Users

Once the selections have been made, you can narrow down the selection criteria even more to the level of user, role and profile, and CUA system, as shown in Figure 9.16.

Personal Copy for Arun Singal, arun.singal560@gmail.com

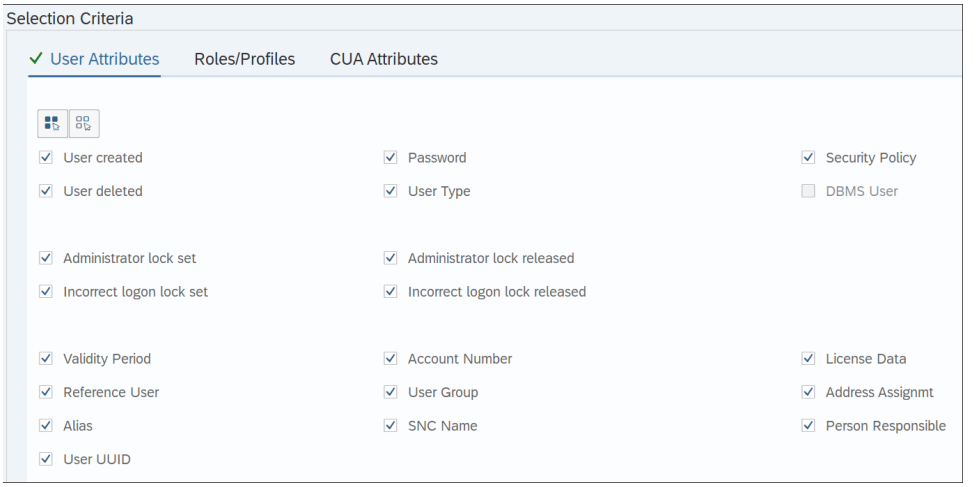
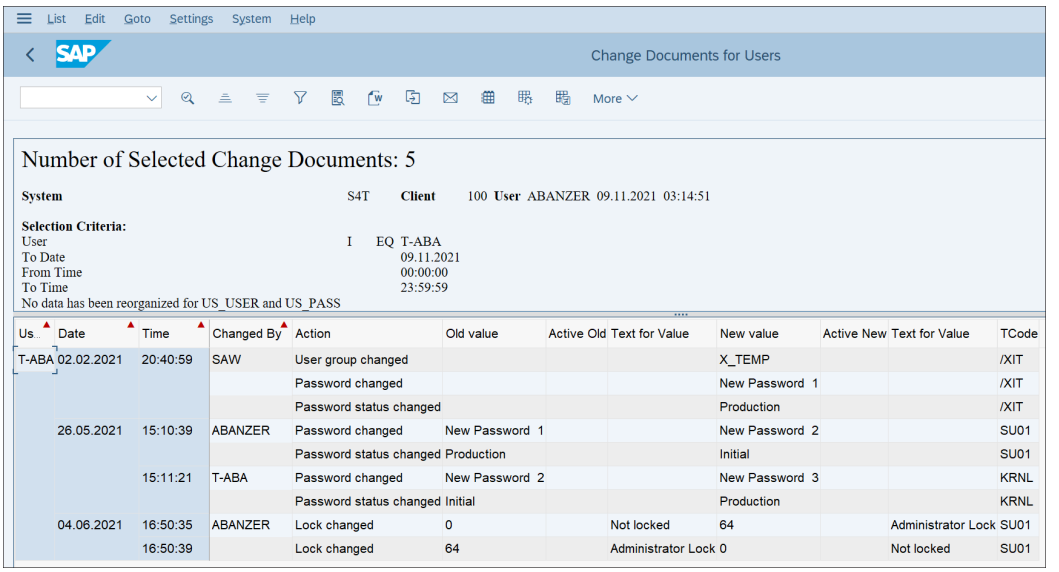


Figure 9.16 Change Documents for Users: User Attributes

The output list will appear as an ABAP List Viewer (ALV) list that offers sorting and filtering capabilities by default. In the output, you'll see all the change documents that are recorded for the user, as shown in Figure 9.17.



Us	Date	Time	Changed By	Action	Old value	Active Old	Text for Value	New value	Active New	Text for Value	TCode
T-ABA	02.02.2021	20:40:59	SAW	User group changed				X_TEMP			/XIT
				Password changed				New Password 1			/XIT
				Password status changed				Production			/XIT
	26.05.2021	15:10:39	ABANZER	Password changed	New Password 1			New Password 2			SU01
				Password status changed	Production			Initial			SU01
		15:11:21	T-ABA	Password changed	New Password 2			New Password 3			KRNL
				Password status changed	Initial			Production			KRNL
	04.06.2021	16:50:35	ABANZER	Lock changed	0		Not locked	64		Administrator Lock	SU01
		16:50:39		Lock changed	64		Administrator Lock	0		Not locked	SU01

Figure 9.17 Output of Change Documents for a User

These change documents create a good audit trail for finding out who changed what and when. Also, this information helps you identify role and profile assignments as well as user locks and unlocks.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

9.1.5 Mass User Changes with Transaction SU10

While Transaction SU01 allows changing one user at a time, with Transaction SU10, you can change multiple users in one shot. Transaction SU10 allows you to create, change, and delete users, as well as change roles and profile assignments. Even though Transaction SU10 allows mass processing, this transaction also has its limitations. With Transaction SU10, you must perform the change to all users in the selection. Individualization is not possible, nor can you assign a different set of roles to several users. For example, suppose you want to assign ROLE_1 to users 1 through 10, and ROLE_2 only to users 1, 2, 3, and 4. To perform this change, you must use Transaction SU10 twice. Once you assign ROLE_1 to all the users, then in a second step, you would assign ROLE_2 to the four special users. Uploading a template set is not possible.

Transaction SU10 works in a two-step approach. First, you'll select users and then, you'll make adjustments to these users. On the initial screen, you must define the set of users you want to maintain, as shown in Figure 9.18.

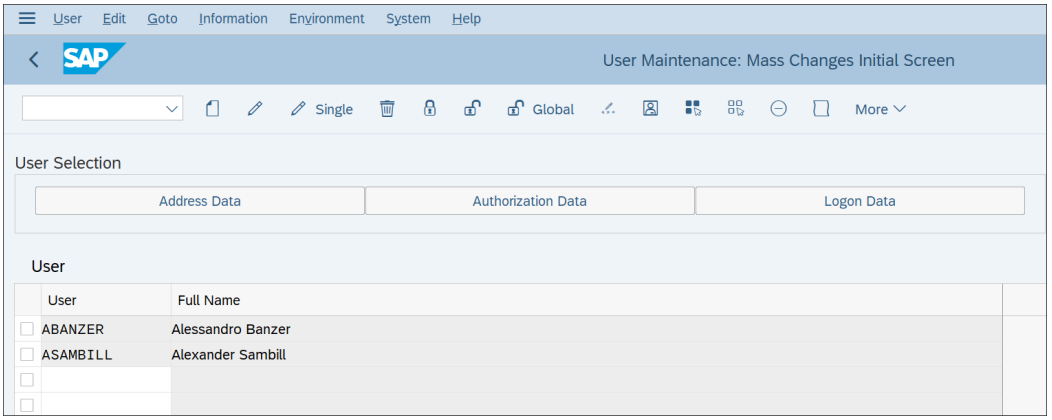


Figure 9.18 Initial Screen of Mass User Maintenance in Transaction SU10

While the user table on the initial screen is limited to inserting a large number of users from your clipboard (you must scroll down and insert a subset), you can use one of the available user selection options.

You can find users based on attributes related to the user master address data, as shown in Figure 9.19. For example, from a list of user names, you can use make multiple selections in the **Users** field. In the **Multiple Selection** prompt, you can insert values from the clipboard to massively select users.

Through the **Authorization Data** tab, you can find users based on different attributes belonging to the users. Common options are by user groups, by lock status, all unlocked users, within a validity period, based on user language, or specific roles, transactions, profiles, or authorizations, as shown in Figure 9.20.

Personal Copy for Arun Singal, arun.singal560@gmail.com

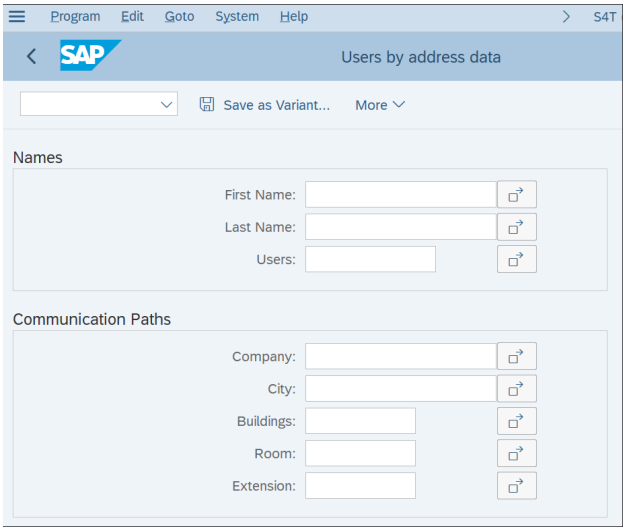


Figure 9.19 Searching Users by Address Data

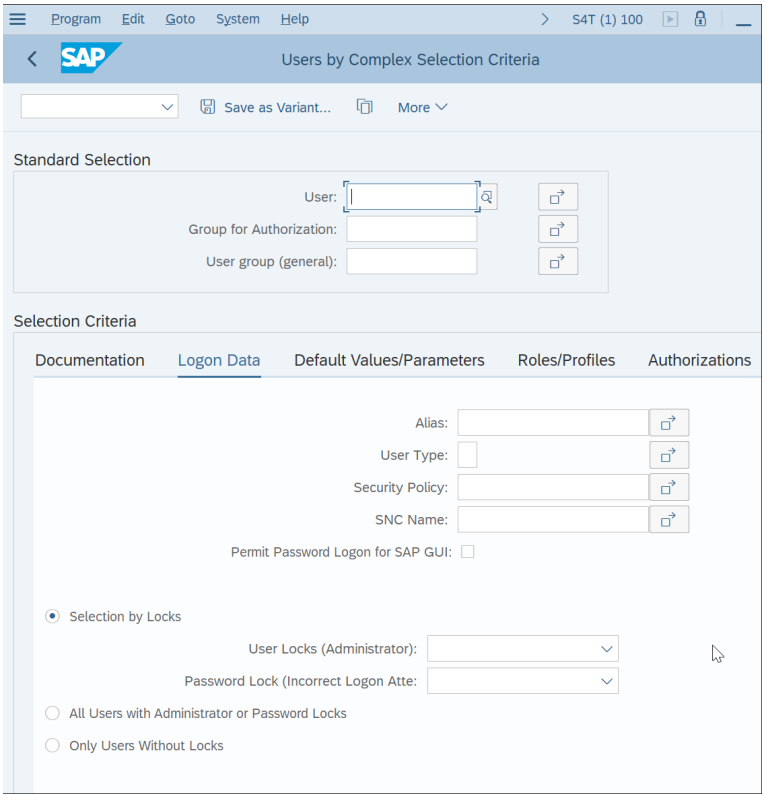


Figure 9.20 Users by Authorization Data in Transaction SU10

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Under the **Logon Data** tab, you can find users based on logon information. These options include selections based on the validity of the user; locks, logon attempts, and user types; and password status, as shown in Figure 9.21.

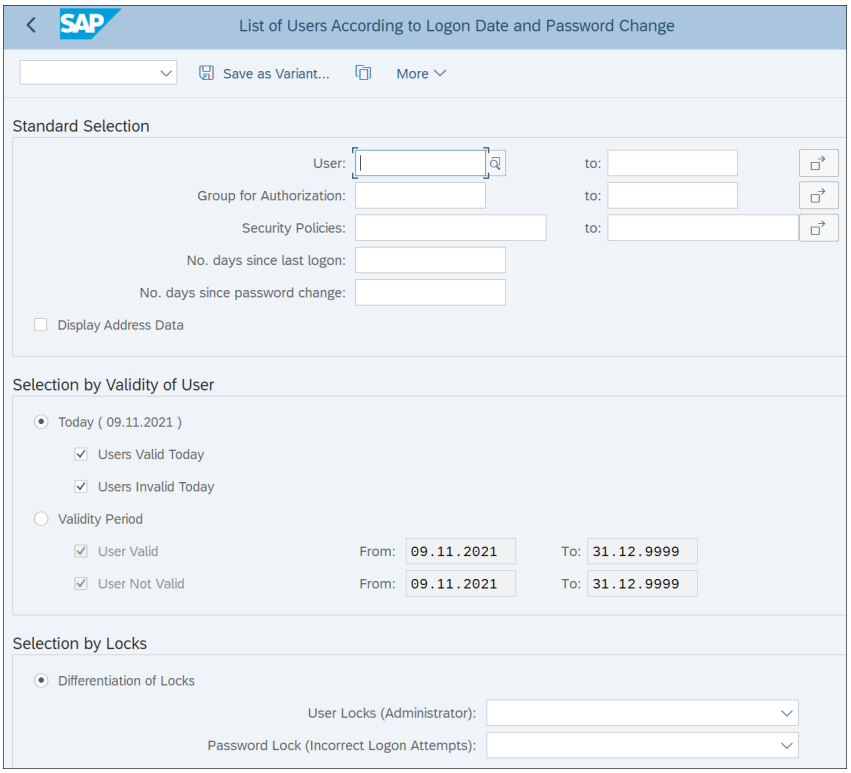


Figure 9.21 Searching Users by Logon Data in Transaction SU10

Once you run the report, the system will show you the users that match the selection criteria for each of the selection screens. From this report, select the users that you want to transfer to Transaction SU10 and click the **Apply** button, as shown in Figure 9.22.

Once transferred, you'll see the set of users in your initial screen in Transaction SU10, as shown in Figure 9.23. Now, you can decide the operation you want to perform.

Warning

One of the most common and costly mistakes is clicking the **Trash** icon to remove users from the selection. The trash button will immediately and irreparably delete all users in that selection. No undo button is available. If users are deleted, they must be re-created manually. Previous role assignments are only viewable from the user changelog, which is a time-consuming task.

Personal Copy for Arun Singal, arun.singal560@gmail.com

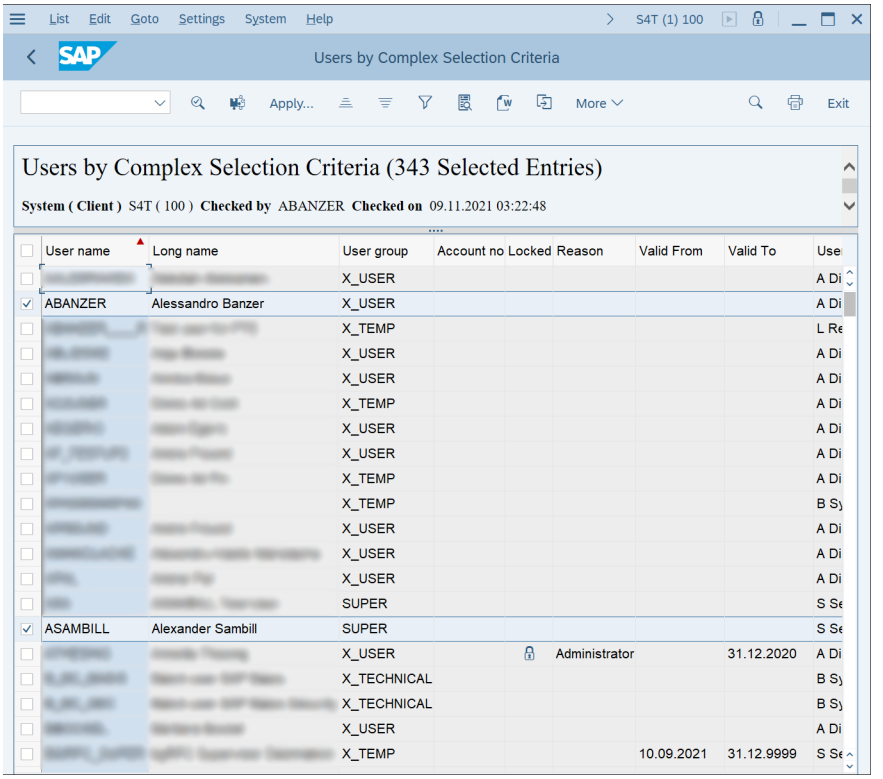


Figure 9.22 List of Users according to the Selection in Transaction SU10

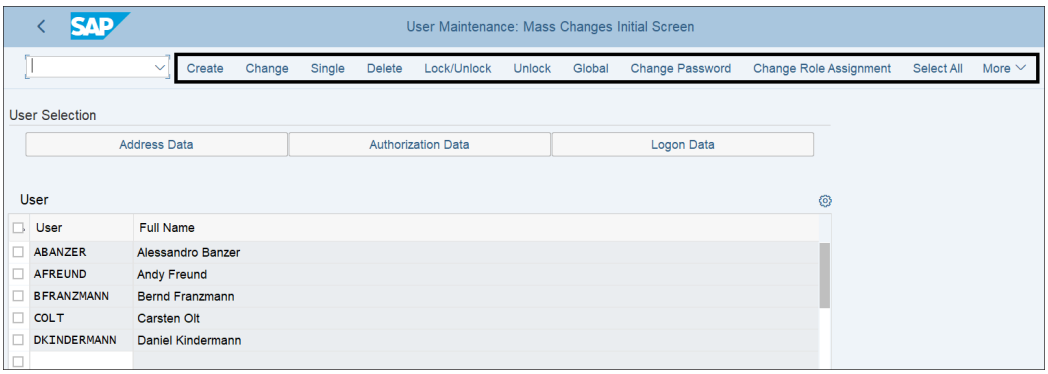


Figure 9.23 Initial Screen with the Selected Users

To change role assignments for users, you can either click the **Change** button or the **Change Role Assignment** button. With the first option, you can navigate to the exact same screen as the **Change Role Assignment** button, as shown in Figure 9.24. Under the **Roles** tab, add or remove roles from a user. You cannot do both at the same time; you can only either remove a role or add a role in a single processing step.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

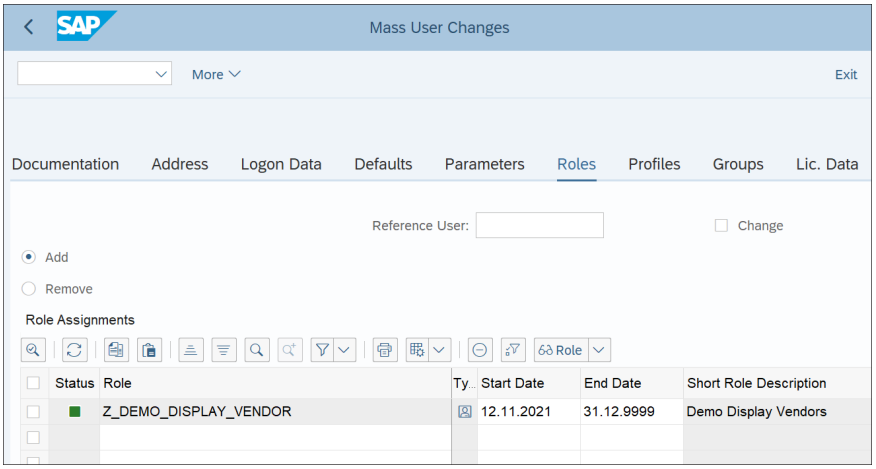


Figure 9.24 Change Users in Mass

Once the mass change has been performed, the confirmation screen will indicate what has been changed, as shown in Figure 9.25.

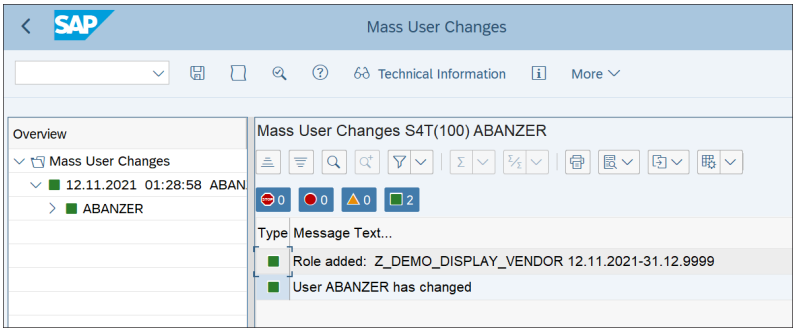


Figure 9.25 Mass Role Assignment Confirmation

When removing roles from a user, an important step is to define the **Start Date** field as early as the first assignment of that role to capture the validity period. We recommend setting this field to "01.01.1900" (earliest date possible), as shown in Figure 9.26.

If you perform a role removal, as shown in Figure 9.27, without backdating the **Start Date** field so that the range covers the actual role assignment, the role will not be removed. The system automatically sets the **Start Date** field to the current date.

Once you save the change, the system will inform you that no change was made to the user, as shown in Figure 9.28. This change failed is because the system could not find a role assignment in the time frame given.

Personal Copy for Arun Singal, arun.singal560@gmail.com

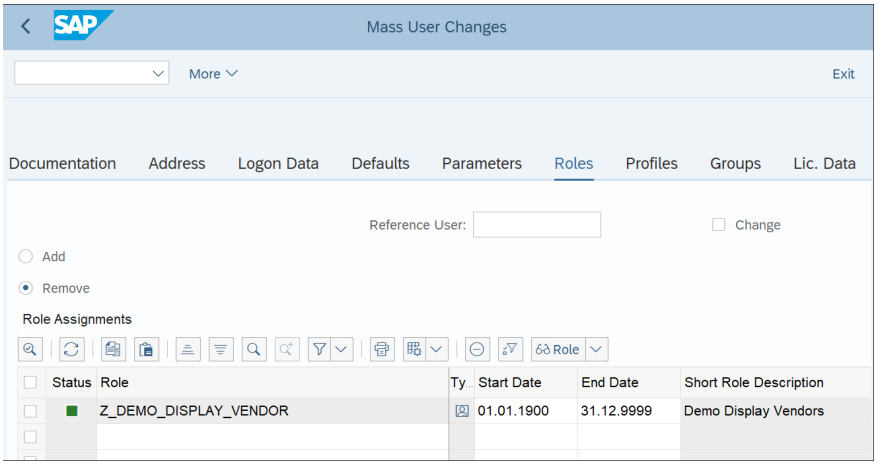


Figure 9.26 Removing Roles in Transaction SU10

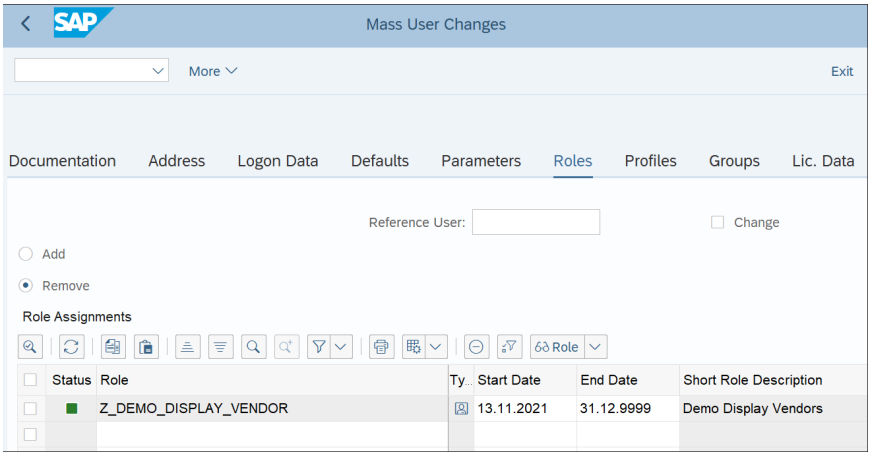


Figure 9.27 Role Removal without Changing the Start Date in Transaction SU10

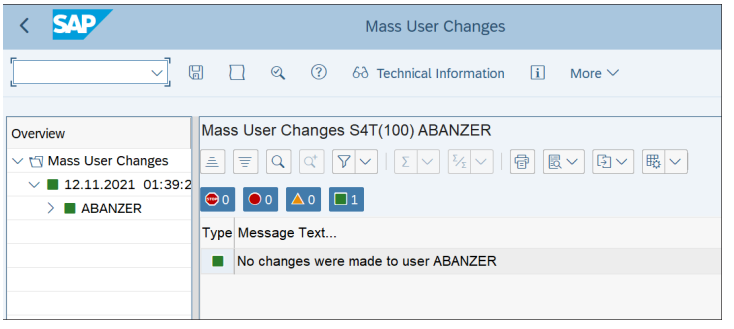


Figure 9.28 Mass Change without Any Changes Made

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

9.1.6 Inactive Users

In every SAP system, you can find users that haven't logged on for several months. You should define a process that describes how to deal with inactive users. For example, many companies lock users that haven't logged on for more than 30 days and delete these users after 90 days.

To find users that have been inactive for some time, use report RSUSR200, as shown in Figure 9.29. In the selection screen, specify a number of days since last logon.

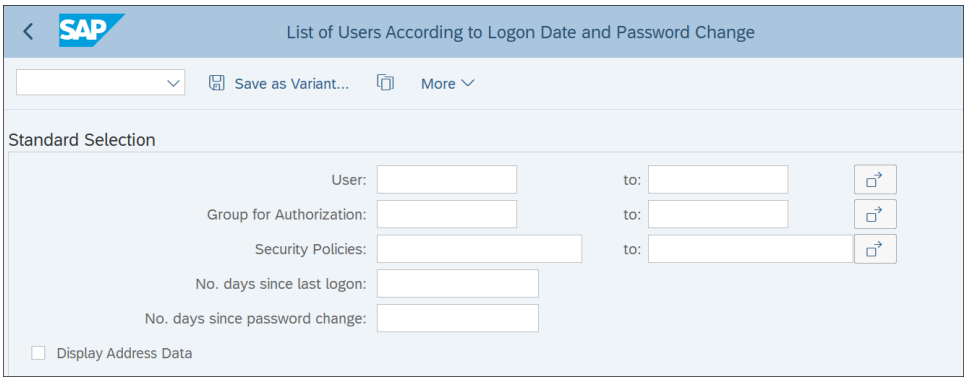


Figure 9.29 Report RSUSR200 to Find Inactive Users

Managing inactive users increases the security of your SAP system and might also have a positive impact on user classification and thus license costs. Inactive users pose a security risk since they exist in the system with authorizations and aren't used by any specific user. Therefore, locking or even deleting these users reduces the risk of inappropriate use.

9.2 Password Rules

When you create a new user or reset the password of an existing user, Transactions SU01 and SU10 have a standard functionality for generating a random initial password. By default, SAP generates passwords of 40 characters with numbers, letters, and special characters.

The length and complexity of the password can often be problematic for end users who can lock themselves out by entering too many failed attempts.

You can change these password generation rules in table `PRGN_CUST`, as shown in Figure 9.30, if you enter the table through Transaction SM30 in edit mode.

Personal Copy for Arun Singal, arun.singal560@gmail.com

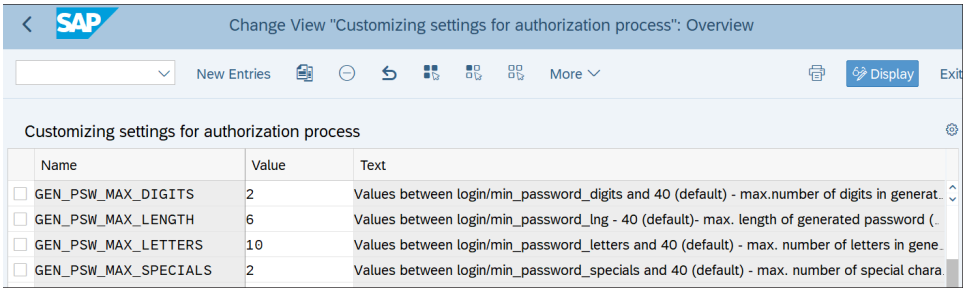


Figure 9.30 Transaction SM30 Editing Table PRGN_CUST

The following four customizing switches are available:

- GEN_PSW_MAX_DIGITS: Maximum number of letters in the generated password
- GEN_PSW_MAX_LENGTH: Maximum length of the generated password
- GEN_PSW_MAX_LETTERS: Maximum number of digits in the generated password
- GEN_PSW_MAX_SPECIALS: Maximum number of special characters in the generated password

Once the customizing switches have been set, Transaction SU01/SU10 will generate initial passwords according to the rules. You can try out this function in Transaction SU01 by clicking the **Generate** button under the **Logon Data** tab. The generated password will follow the customizing in table PRGN_CUST, as shown in Figure 9.31.

Figure 9.31 Generated Password in Transaction SU01

You can prevent users from creating passwords that you want to disallow. To prohibit the use of a password, enter that password into table USR40 via Transaction SM30. In table USR40, you can define backlisted passwords that can't be used as productive passwords.

To maintain table USR40, you can use two wildcards:

- ? stands for a single character.
- * stands for a sequence of any combination of characters of any length.

For example, as shown in Figure 9.32, the following statements are true:

- ***123*** prohibits any password that contains the sequence *123*, like 1234567890, Pass12345, etc.
- **Password?** prohibits any password that begins with "Password" and has one additional character, like Password1, Password!, etc.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

You can also define forbidden passwords as case sensitive. However, this doesn't always make sense, as a forbidden password should be forbidden whether it's entered in lowercase or uppercase. For example, if you forbid the term "password," it should be forbidden regardless of how it's entered: "PASSWORD," "password," "PassWord," etc. As such, case sensitivity is often not important when defining forbidden passwords.

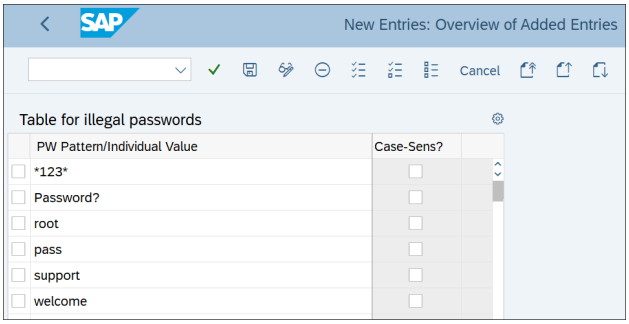


Figure 9.32 Blacklisted Passwords in Table USR40

In addition to the password rules we've covered so far, the following rules are predefined by SAP for every system:

- A password cannot be more than 40 characters long. Before SAP NetWeaver 6.40, passwords could not be more than 8 characters long.
- The first character must not be an exclamation point (!) or a question mark (?).
- The first 3 characters cannot all be the same.
- A password can only be changed after the old password has been entered correctly. Up to SAP NetWeaver Application Server 6.10, a user can only change their password during the logon procedure. As of SAP NetWeaver Application Server 6.20, a user can also change their password in Transaction SU3.

9.3 The User Buffer

As mentioned earlier, the SAP system follows a positive authorization concept, which means that authorizations must be assigned to a user to execute certain transactions in the system. To assign authorizations to a user, roles and profiles are assigned. Historically, SAP only used profiles to handle user authorizations. Roles were introduced later on to simplify the authorization maintenance process. Therefore, each role contains at least one authorization profile once the role is generated. When assigned to a user through a role, these profiles are then loaded into the user buffer during the logon procedure. Whenever the SAP system performs an authority check against the user, it does so against the user buffer. The user buffer holds all authorization objects with their corresponding values. You can display a user buffer in Transaction SU56. When you run Transaction SU56, as shown in Figure 9.33, you'll see your own user buffer.

Personal Copy for Arun Singal, arun.singal560@gmail.com

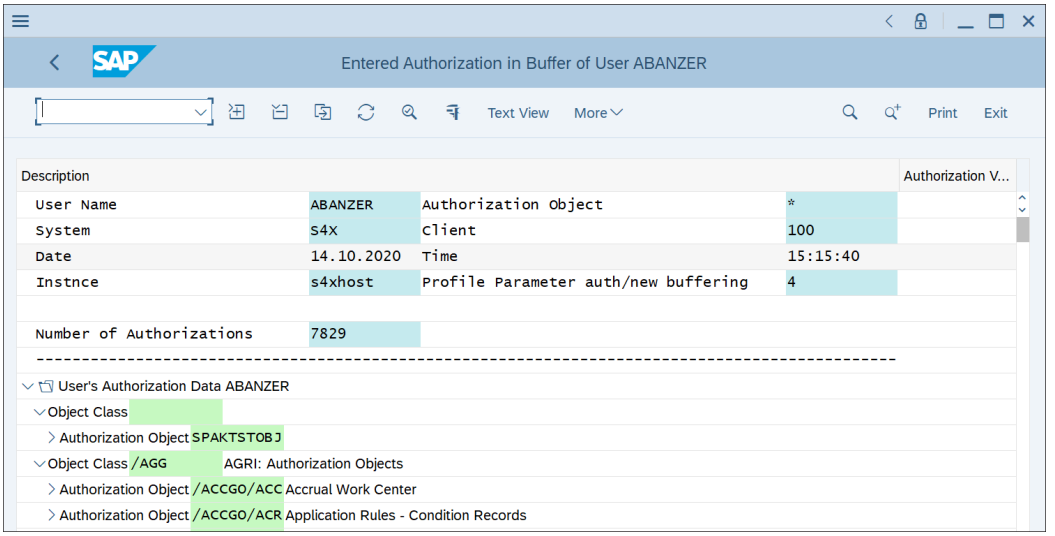


Figure 9.33 User Buffer in Transaction SU56

However, if authorized, you can also analyze the user buffers of other users, which is a great tool for finding and checking assigned authorizations. To display the user buffer of other users, click the **Display for different user/authorization object** button or press the F5 key. Then, in the popup window shown in Figure 9.34, enter the user name and the authorization object you want to analyze. If you want to see all user authorizations, keep the asterisk (*) in the authorization object input field. If you're interested in a specific authorization object, you can enter its name here.

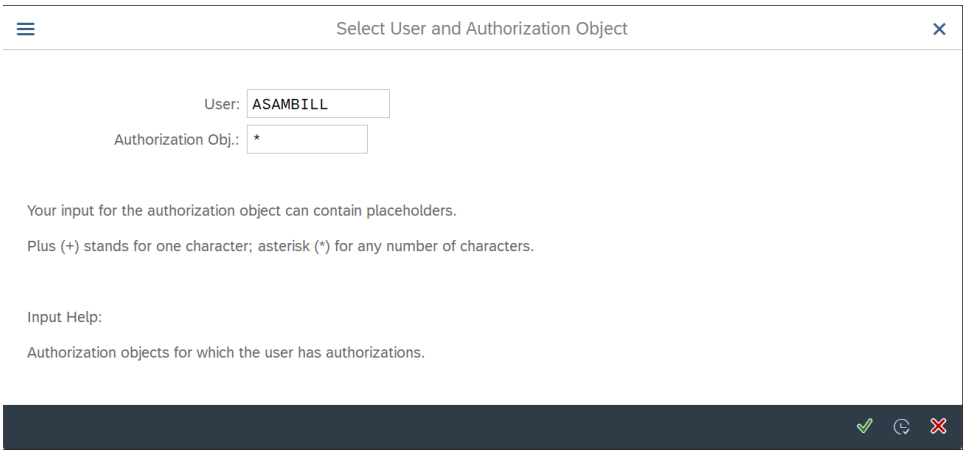


Figure 9.34 Displaying the User Buffer for Another User

The user buffer offers great capabilities for security administrators to find the authorizations of another user. Our example, shown in Figure 9.35, involves the user buffer for user **ASAMBILL** and the authorization object **F_BKPF_BUK**. Notice that the user has five

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

(5) instances of authorizations for that authorization object. By expanding the authorization profile, as shown in Figure 9.35, you can determine from which profile and role the authorizations derive. In our case, the authorization values are asterisks (*) for both fields ACTVT and BUKRS, which come from role SP_GL_GLOB_E_FI_MGMT.

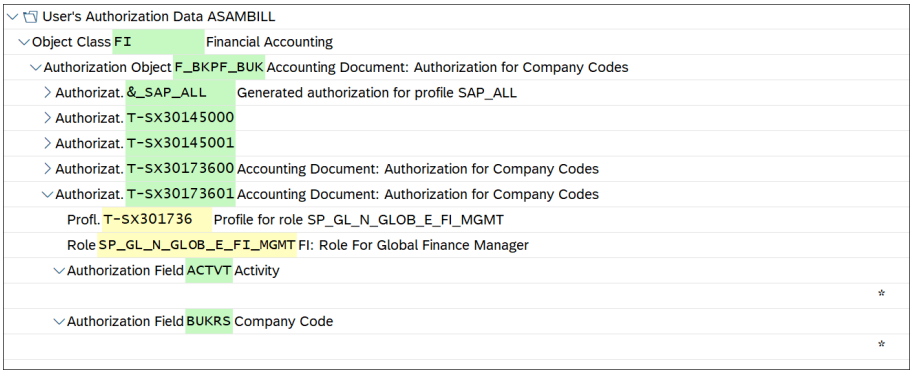


Figure 9.35 User Buffer for Authorization Object F_BKPF_BUK

Tip

When assigning roles to a user who is currently logged on, the user buffer must be refreshed to reflect the changes to authorizations. To refresh the user buffer, the user should log off and log on. Please note that, when assigning the manual profile SAP_ALL, the user buffer is refreshed automatically.

9.4 User Naming Conventions

Defining a naming convention for your users is important for reducing complexity in the long run. With a proper naming convention, you can easily identify your users, which allows you to define selection criteria more precisely.

As a general rule of thumb, you should define a naming convention to group certain sets of users. For example, all your technical users should have the same identifier so that you can distinguish them from your DIALOG users.

Let's look at a few examples:

- RFC users should be identifiable by the calling system and the system being called. You might follow a naming convention like RFC_<calling system SID>_<called system SID>, resulting in, for example, RFC_ERP_CUA and RFC_GRC_CUA.
- DIALOG users should start with the letter A (which is the value for the user type DIALOG) and then follow a mix of last and first name. For example, you might use the first 6 characters of the last name and the first 4 characters of the first name, resulting in, for example, A_BANZERALES and A_SAMBALEX.

Personal Copy for Arun Singal, arun.singal560@gmail.com

SAP user IDs can be up to 12 characters long. Using the full available length makes identifying these users easier, not just for you as an administrator but also for end users (for instance, when viewing changelogs, etc.). With a proper naming convention, as in our example naming convention for DIALOG users, you can easily identify who (in the sense of which person) performed a change in the system. Cryptic user IDs, for example, a combination of just numbers, can be difficult to connect to a real person. Cryptic user IDs are sometimes required for legal reasons or because the company wants to use the same user IDs across the landscape (i.e., Microsoft Active Directory, Portal, Web, SAP, etc.).

User naming conventions are important, and your naming convention should try to accomplish the following goals:

- For reducing complexity.
- To help identify users (i.e., according to user type, purpose, etc.).
- For enhancing legal or organizational requirements. For example, the use of a personnel number or random number can be used to obscure a user's identity, which is sometimes a legal requirement.

Your user naming conventions should, wherever possible, be consistent across your entire landscape. A properly designed user naming convention will ensure that one user does not have multiple user IDs across the SAP landscape.

Naming conventions are unique to each company, and no "best practice" exists. Common user naming conventions include the following patterns:

- <*Initials*>_<*Last 4 numbers of personnel number*> (Example: ABA_0987)
- <*User Type*>_<*Random Number*>
  - DIALOG user = A_12345678
  - REFERENCE user = R_12345678
  - SYSTEM user = S_12345678
  - GUEST user = G_12345678
- <*First initial*><*Last name*> = ABANZER, ASAMBILL, etc. If duplicate users arise (Alessandro Banzer and Andre Banzer), then you can always add a number or a middle initial in the concept.
- <*First initial*><*First 4 characters of last name*><2-digit number> = ABANZO1, ABANZO2, ASAMBO1, ASAMBO2, etc.

No absolute right or wrong way to proceed exists, nor are there common best practices for naming conventions. What's important is that you define and follow a naming convention that suits your organization, which might be different depending on the size, the systems in use, and more.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

9.5 User Classification

On a periodic basis, SAP requests a measurement of your system landscape to determine license costs. You, as an administrator, must provide a list of users, along with their user classifications. Based on the number of users for each classification, the license cost is calculated. You can be under- or overlicensed depending on recent changes in the number of your users and the transactions/reports they used.

Until the end of 2017, SAP measured license costs based on historical usage data in the system. The classification of a user was calculated based on the transactions and reports used. As of 2018, SAP has been approaching customers to change the licensing model to a new approach that considers the authorizations assigned to a user. For a user to be classified to a certain license type, the assigned roles are considered.

Warning

Please keep in mind that, with the change of the license classification, most businesses will tend to be underlicensed since the users who executed certain transactions and reports will probably have their usual authorizations for these tasks. However, in addition to users who require certain transactions/reports, some users who have the authorizations might not need them. With the new model, all those users will be classified as well, which results in higher license costs.

With the new way of classifying users, a particularly important task is to manage your authorizations to avoid license costs that are not utilized. Following the least privilege principle and/or redesigning your roles may result help you avoid unnecessary license costs.

9.6 User-Related Tables

User-related tables offer an easy way to access user data directly. Even though most of this data can be accessed through the User Information System (Transaction SUIM), security administrators tend to use the table browser (Transaction SE16) to access this data. Therefore, we recommend knowing the most common tables that are available, which are listed in Table 9.3.

Table	Description
USR01	Contains the runtime data of the user master record
USR02	Logon data of the user master record like passwords, etc.
USR03	User address data

Table 9.3 User-Related Tables

Personal Copy for Arun Singal, arun.singal560@gmail.com

Table	Description
USR04	User master authorizations
USR05	User parameter ID
USR09	Contains the user menu
USR10	User master authorization profiles
USR11	User master texts for profiles
USR12	User master authorization values
USR21	Assignment of a user master to the address data
USR40	List of blacklisted/forbidden passwords
USH02	Change history for logon data
USH04	Change history for user master authorizations
USER_ADDR	Generated table view for user address data
USRPWDHISTORY	User password history
ADRP	Person address information like first name, last name, etc.
ADR2	User telephone numbers
ADR3	User fax numbers
ADR6	User email addresses
USR_CUST	Customizing settings for users/authorizations

Table 9.3 User-Related Tables (Cont.)

9.7 User Access Reviews

To effectively protect your SAP system, an important ongoing task is to periodically perform user access reviews (UARs) of your users and their authorizations. SAP Access Control offers a workflow-driven UAR capability. However, regardless of the tools used (even if performed manually), most auditing firms request that a UAR be conducted once a year. For some user groups like high-privileged user (HPU) accounts, for example, security administrators, UARs must be more often.

UARs must include a thorough review of all roles and profiles assigned to a user with a proper sign-off procedure. The review must include all users in the system, regardless of if they are active or not. For inactive users, we recommend removing their authorizations. During the approval procedure, role assignments are removed, and new roles

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

might be requested. In several cases, a user might need a specific authorization but is assigned to a large set of roles that grant additional access that is not required. Therefore, as a security administrator, you might be contacted to create smaller roles with less authorization surplus.

9.8 User Lock Status

A user master record can be locked in various ways. User accounts are usually either locked due to too many failed logons, or an administrator locked the user. When locking a user, different lock statuses are used to indicate the type of the lock.

In the user master table (table USR02), you can modify the lock status of a user, in the UFLAG field. The following statuses are known to an SAP system:

- 0 – User is not locked.
- 32 – User is locked globally by an administrator.
- 64 – User is locked locally by an administrator.
- 128 – User is locked due to incorrect logons.

The different lock statuses lets you identify how a user was locked. Also, the lock status is cumulative, and thus, you might see a cumulative lock status like lock status 160. In this example, 160 means the user was locked globally by an administrator (32) and was also locked for incorrect logon attempts (128).

So, you might ask yourself why is this important? The simple answer is that, if you use tools like SAP Access Control or SAP Identity Management (SAP ID Management), which offer self-service password capabilities to unlock users independently, then the lock status is important. With password self-service, a user can only be unlocked if the lock is 128 (due to incorrect logon). A user cannot unlock a local or global lock.

In case a user is locked out due to incorrect logons but also locked globally by an administrator, the user can remove the 128 lock with the password self-service tool but will remain locked with the 32 lock (global lock by the administrator). In this case, the lock status in USR02-UFLAG will be reduced from 160 to 32 (160 – 128 = 32).

9.9 Security Policies

With the security policies functionality in Transaction SECPOL, as shown in Figure 9.36, SAP offers a way to flexibly define security policies for certain users. While most security parameters, like password complexity, are defined globally within the profile parameters, Transaction SECPOL allows you to more granularly define security parameters for a set of users. Suppose, for example, you want to increase the password

Personal Copy for Arun Singal, arun.singal560@gmail.com

complexity for your HPU accounts, like administrators. To increase that password complexity requirements for a set of users, you'll define a security policy in Transaction SECPOL.

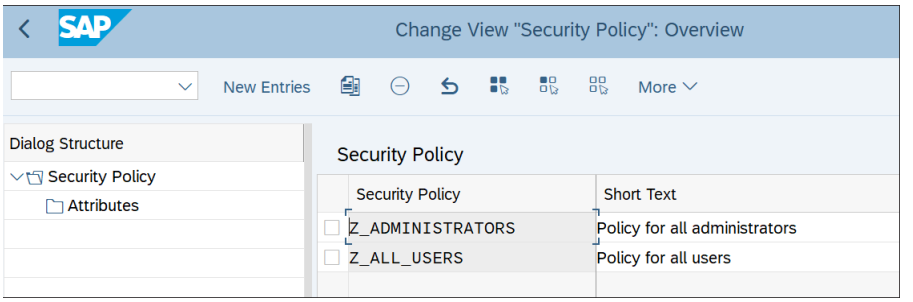


Figure 9.36 Initial Screen of Transaction SECPOL

A *security policy* is a set of attributes with values that can be configured in Transaction SECPOL. Once assigned to a user, the system will always evaluate the security policy, not the default parameters from the profile parameters. Profile parameters are only relevant to users who lack an assigned security policy. One user can only have one security policy. You must understand that a security policy will replace the values that are valid for the user. Also, if you maintain a security policy for a user, make sure you include all the parameters that are set in the profile parameters. By design, the SAP system will otherwise evaluate the kernel values, not the values from the profile parameters. So, what does all this mean? Let's assume you've defined a security policy for your administrators, and you want to increase password complexity by defining a minimum number of characters higher than the standard profile parameter value. For this task, you also must include all the other values.

In Transaction SECPOL, you can define a security policy and manage its attributes, as shown in Figure 9.37. To create a new policy, click on the **New Entries** in the **Change** view.

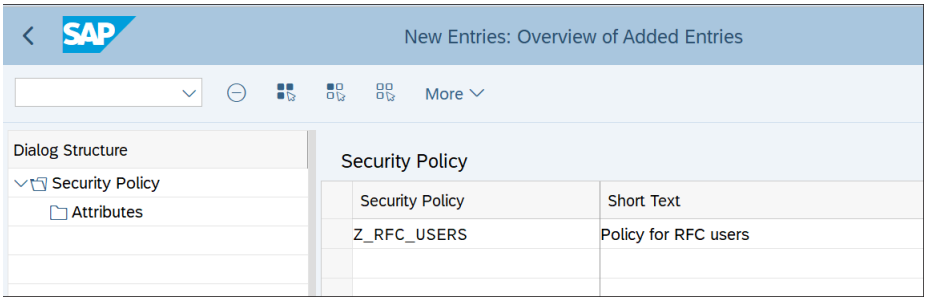


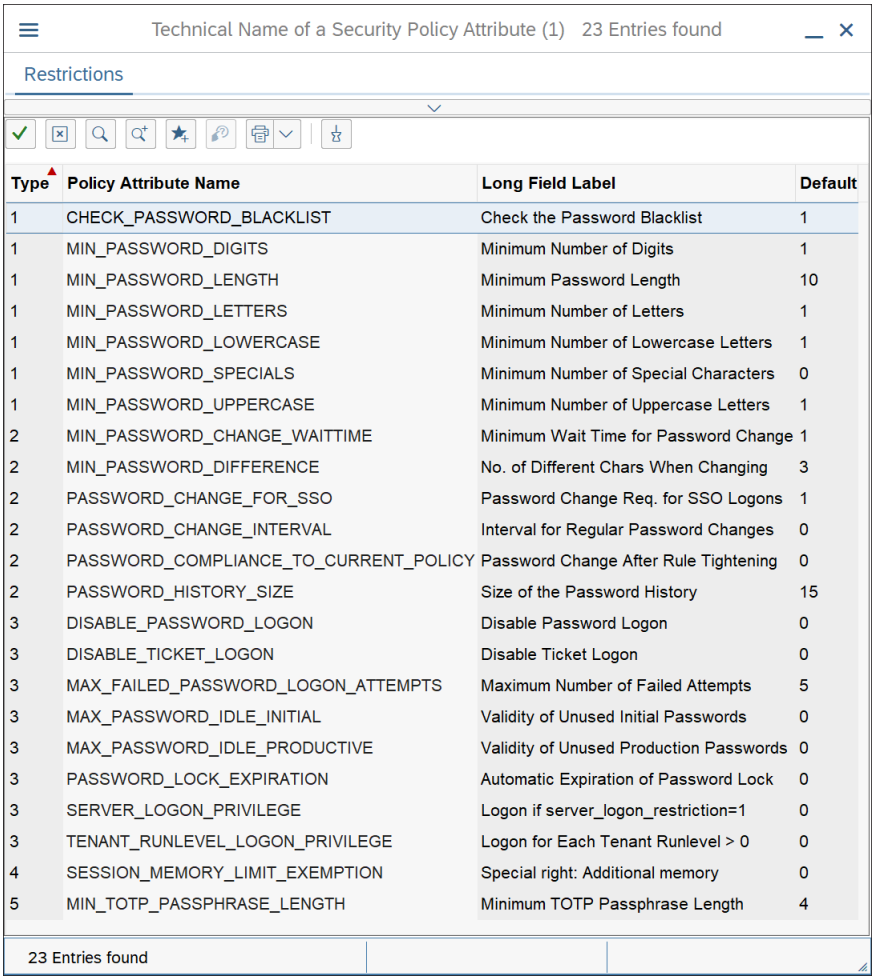
Figure 9.37 Creating a Security Policy in Transaction SECPOL

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Once defined, select the policy and double-click on the **Attributes** field. To add new attributes to the policy, click **New Entries**. Each attribute comes with the following classification values:

- **1**: Password rules
- **2**: Password change policies
- **3**: Logon restrictions

Use the matchcode search to see all available attributes and its classification, as shown in Figure 9.38.



Type	Policy Attribute Name	Long Field Label	Default
1	CHECK_PASSWORD_BLACKLIST	Check the Password Blacklist	1
1	MIN_PASSWORD_DIGITS	Minimum Number of Digits	1
1	MIN_PASSWORD_LENGTH	Minimum Password Length	10
1	MIN_PASSWORD_LETTERS	Minimum Number of Letters	1
1	MIN_PASSWORD_LOWERCASE	Minimum Number of Lowercase Letters	1
1	MIN_PASSWORD_SPECIALS	Minimum Number of Special Characters	0
1	MIN_PASSWORD_UPPERCASE	Minimum Number of Uppercase Letters	1
2	MIN_PASSWORD_CHANGE_WAITTIME	Minimum Wait Time for Password Change	1
2	MIN_PASSWORD_DIFFERENCE	No. of Different Chars When Changing	3
2	PASSWORD_CHANGE_FOR_SSO	Password Change Req. for SSO Logons	1
2	PASSWORD_CHANGE_INTERVAL	Interval for Regular Password Changes	0
2	PASSWORD_COMPLIANCE_TO_CURRENT_POLICY	Password Change After Rule Tightening	0
2	PASSWORD_HISTORY_SIZE	Size of the Password History	15
3	DISABLE_PASSWORD_LOGON	Disable Password Logon	0
3	DISABLE_TICKET_LOGON	Disable Ticket Logon	0
3	MAX_FAILED_PASSWORD_LOGON_ATTEMPTS	Maximum Number of Failed Attempts	5
3	MAX_PASSWORD_IDLE_INITIAL	Validity of Unused Initial Passwords	0
3	MAX_PASSWORD_IDLE_PRODUCTIVE	Validity of Unused Production Passwords	0
3	PASSWORD_LOCK_EXPIRATION	Automatic Expiration of Password Lock	0
3	SERVER_LOGON_PRIVILEGE	Logon if server_logon_restriction=1	0
3	TENANT_RUNLEVEL_LOGON_PRIVILEGE	Logon for Each Tenant Runlevel > 0	0
4	SESSION_MEMORY_LIMIT_EXEMPTION	Special right: Additional memory	0
5	MIN_TOTP_PASSPHRASE_LENGTH	Minimum TOTP Passphrase Length	4

Figure 9.38 Available Attributes for the Security Policy

From the matchcode, you'll also see default value from the profile parameter. Pick the attributes and define the values that you want to enforce with the security policy, as shown in Figure 9.39.

Personal Copy for Arun Singal, arun.singal560@gmail.com

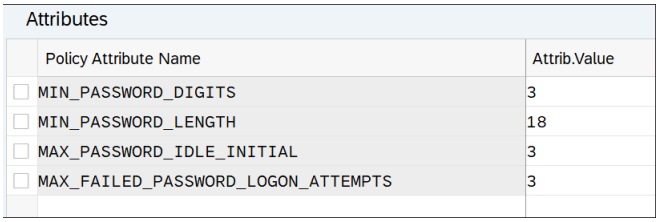


Figure 9.39 Example Attributes of a Security Policy

In the **Attributes** window, you can check the effectiveness of the policy as well as items that are similar to profile parameters, as shown in Figure 9.40.

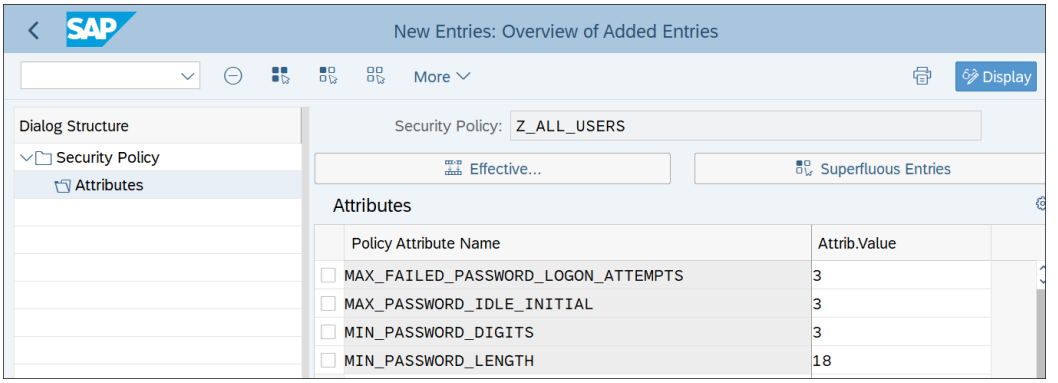


Figure 9.40 Effective and Superfluous Entries in Transaction SECPOL

To check the effectiveness, click on the **Effective...** button and check the new values against the values in the profile parameters, as shown in Figure 9.41, which is a good indication of whether your policy is actually more strict or if you should maintain what is already defined on a global level via its profile parameters.

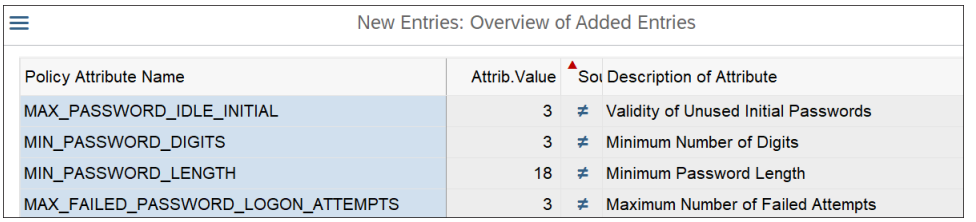


Figure 9.41 Checking Policy Effectiveness in Transaction SECPOL

If you click on the **Superfluous Entries** button, you'll see a list of parameters that are similar to the profile parameters, as shown in Figure 9.42.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

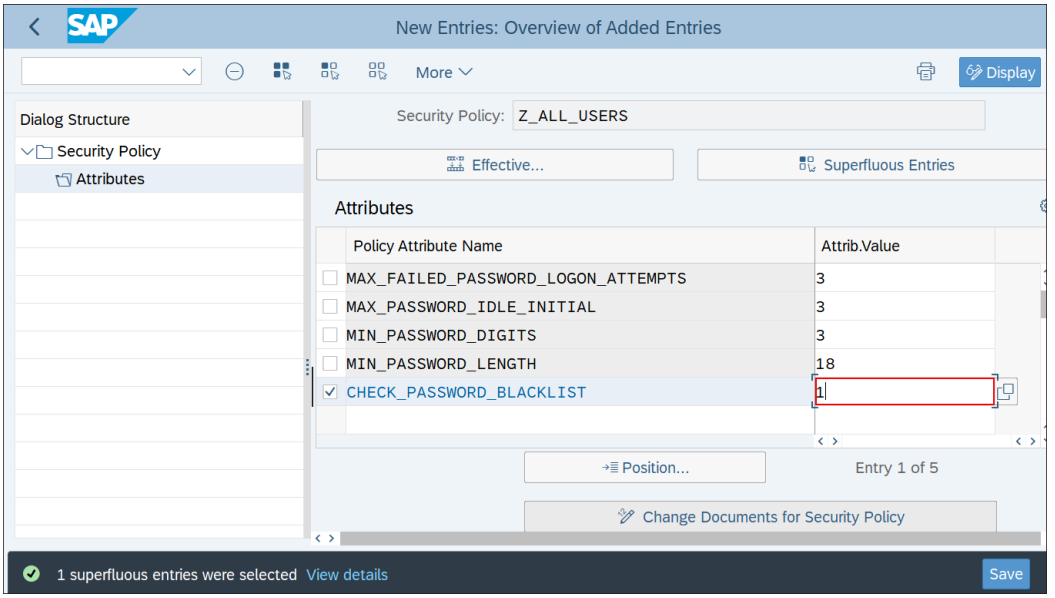


Figure 9.42 Superfluous Parameters in Transaction SECPOL

Once your security policy is defined, save your entries and assign the policy to a user. To assign the policy to a user, go to Transaction SU01/SU10 and assign the policy under the **Logon Data** tab, in the **Security Policy** field, as shown in Figure 9.43.

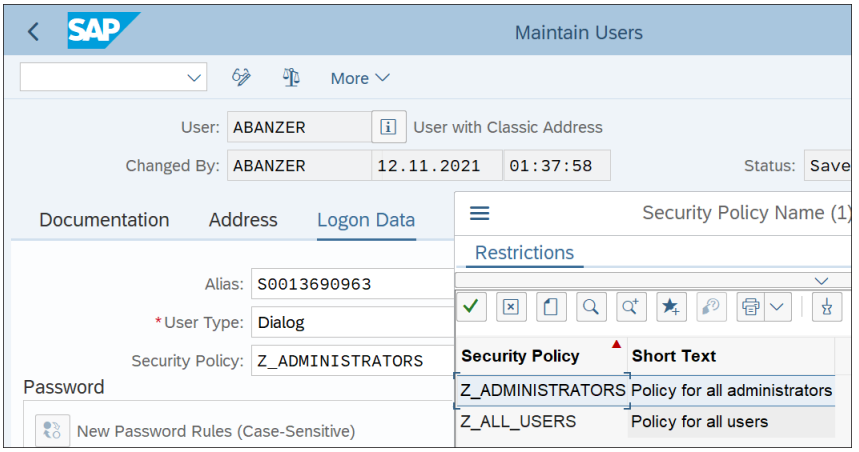


Figure 9.43 Assigning a Security Policy to a User in Transaction SU01

Once the security policy has been assigned and the user has been saved, the new policy will be enforced.

Personal Copy for Arun Singal, arun.singal560@gmail.com

9.10 Securing Default Accounts

SAP systems come with a number of default users that have extensive access to the system. These users are created during the installation process and during the implementation and customization of certain functionality. For example, when you install an SAP system, the standard users SAP*, DDIC, and EARLYWATCH are created. Table 9.4 provides details about standard SAP users.

User	Description	Clients	Default Password
SAP*	SAP system super user	000, 001, and 066 All new clients	06071992 PASS
DDIC	ABAP Dictionary and software logistics super user	000 and 001	19920706
EARLYWATCH	DIALOG user for the SAP EarlyWatch Alert service in client 066	066	SUPPORT
SAPCPIC	User for remote connections	000 and 001 All new clients	ADMIN
TMSADM	User for SAP Transport Management System (STMS)	000	Set during installation

Table 9.4 SAP Standard User Overview

Since these parameters are publicly known, a particularly important step is to protect these users from unauthorized use. To protect these users, deactivate user SAP*, change all the default passwords, assign the users to user group SUPER, and lock users DDIC and EARLYWATCH. Assigning these users to the user group SUPER protects them from being changed by anyone other than an administrator authorized to change users in the user group SUPER.

To avoid the automatic creation of user SAP*, set the profile parameter login/no_automatic_user_sapstar to "1" in the instance profile. You must set this parameter in the instance profile, not in the default profile (see SAP Note 68048). For emergency purposes, when the user SAP* is needed, set the parameter to "0," delete the user account, and restart the system. Once the system has restarted, the user SAP* will have been created with the profile SAP_ALL automatically. The **Change Documents for Users** screen (described earlier in Section 9.1.4) will show that the changes were performed by the kernel, as shown in Figure 9.44.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

User	Date	Time	Changed By	Action	Old Value	Text	New Value	Text	TCode
SAP*	29.03.2016	15:13:06	SAP*	User group changed			SUPER	SUPER	KRNL
				Password changed			New Password 1		KRNL
				Password status changed			Productive		KRNL

Figure 9.44 Example of Change Documents for User SAP*

Other standard users to check are users TMSADM and SAPCPIC. User TMSADM is required for STMS and should only exist in client 000 of each system. Make sure that the default password for user TMSADM has been changed in client 000 and that the user has been deleted from all other clients. To change the default password for user TMSADM, follow the directions described in SAP Note 1414256. User SAPCPIC must be locked in all clients or completely deleted. Also, change the standard password for user SAPCPIC.

The standard report RSUSR0003 displays standard users and its status across all clients in a system, as shown in Figure 9.45. An important step is executing this report in each system, since users are client-dependent and, thus, are different in each combination of client and system.

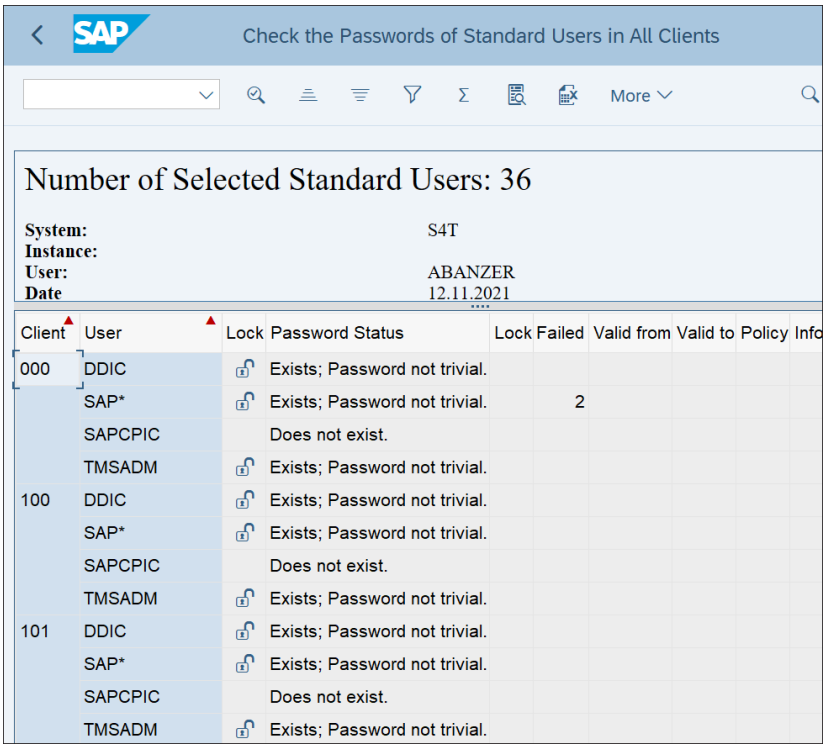


Figure 9.45 Example of Report RSUSR003

Depending on your current release, report RSUSR003 might not report on user TMSADM. Please check SAP Note 1552894 and learn how to update the report to show the status of user TMSADM.

Personal Copy for Arun Singal, arun.singal560@gmail.com

9.11 Maintaining User Groups

User groups can be used to categorize many users into common logical groups. You can use the user group functionality to segregate user administration, but also to search and sort users by a common grouping. To create and maintain user groups, use Transaction SUGR, as shown in Figure 9.46, where you can create, edit, display, and delete user groups from the system. Also, you can assign multiple users to a user group. Please note that assigning a user to a user group via Transaction SUGR will add the user to the user groups that can be utilized for grouping (under the **Groups** tab in Transaction SU01). This step, however, does not assign the user to the user group that is used for the authority check (under the **Logon Data** tab in Transaction SU01).

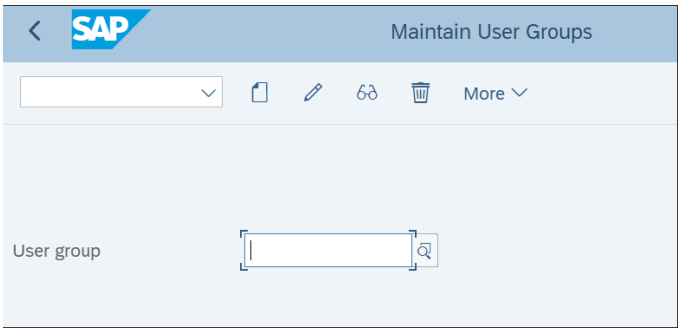


Figure 9.46 Initial Screen of Transaction SUGR

To maintain and change the assignment of user groups, enter a name for the group in the **User Group** field and hit Enter, then click on the eyeglasses icon, as shown in Figure 9.47. Changes will be effective immediately, once saved.

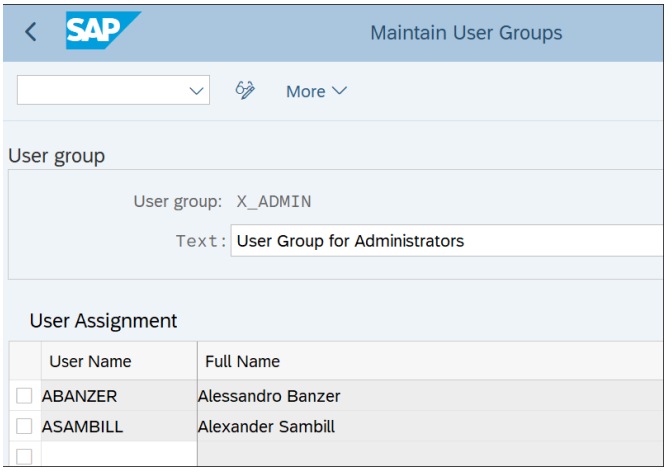


Figure 9.47 Maintaining User Groups in Transaction SUGR

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

In the user master record in Transaction SU01, under the **Groups** tab, as shown in Figure 9.48, notice that the user group has been added to the user.

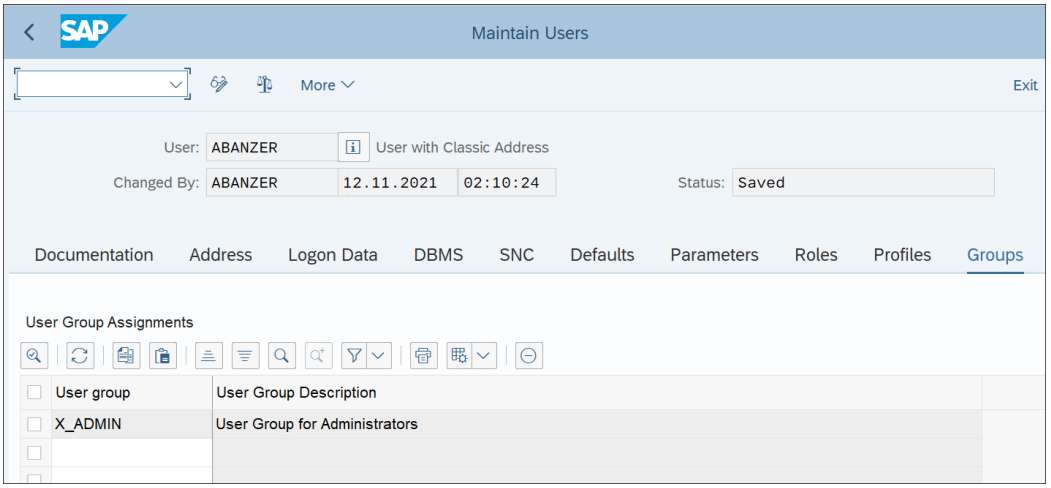


Figure 9.48 Grouping of Users under the Groups Tab in Transaction SU01

Notice how the value in the **User group** field, under the **Logon Data** tab, which is used for authority checks, remains untouched, as shown in Figure 9.49.

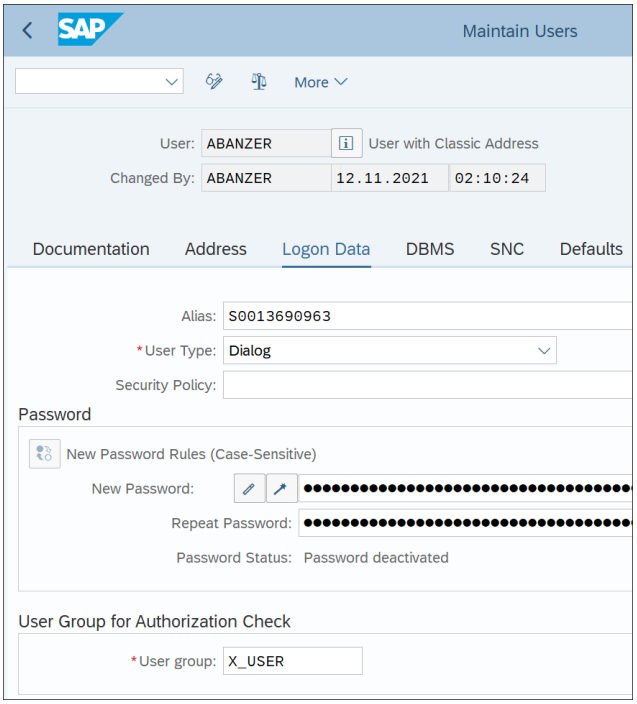


Figure 9.49 User Group for Authorization Checks under the Logon Data Tab in Transaction SU01

Personal Copy for Arun Singal, arun.singal560@gmail.com

Remember, if a user is not assigned to user group, every administrator with access to Transactions SU01/SU10 and the authorization object S_USER_GRP for the respective activity can maintain users. Therefore, we recommend assigning every user to a user group. To make a user group a required field, you customize an option to make checking the user group for authorization mandatory. Before you change this customizing, however, make sure that all your users have been assigned to a user group. Then, create a default user group and maintain this user group in the parameter USER_GRP_REQUIRED in the customizing table USR_CUST through Transaction SM30. If a user administrator wants to use a different user group than the default user group, he or she can define the user parameter S_USER_GRP_DEFAULT to override the default user group from table USR_CUST.

Note

For more information, refer to SAP Note 1663177 – SU01: User group as required entry field.

9.12 Central User Administration

In complex system landscapes, you'll manage many users and their many attributes (i.e., their role and profile assignments) locally in each system. With CUA, you can manage your users globally from a central system and distribute changes to all your connected child systems. This section describes how CUA works and also covers distribution parameters for fields (in Transaction SCUM) and CUA-related tables to help you find and manage data.

9.12.1 Overview

With CUA, you can maintain all your users from a single place and ensure they stay in sync across different clients and systems in multiple landscapes, as shown in Figure 9.50.

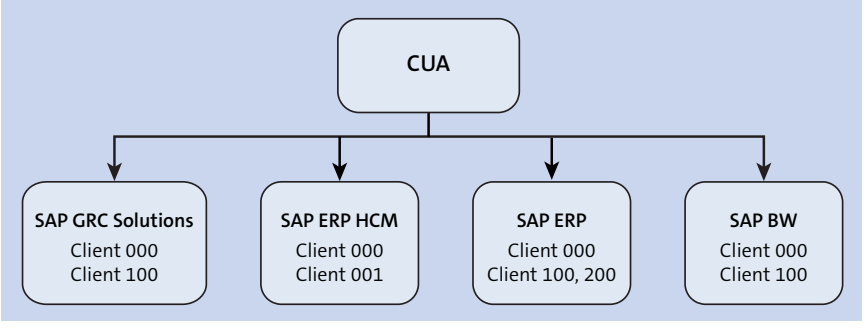


Figure 9.50 CUA Schema

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Since the user master record is client specific, a user must be maintained in each system independently. With CUA, you can simplify this process by distributing user master records to several systems simultaneously. You can distribute changes from a central system, which indeed serves as a central client, to all connected child systems. These child systems must be connected via RFC connections for transferring the data back and forth. These RFC interfaces must have a `SYSTEM` user with required authorizations to perform the changes.

SAP offers a set of predelivered roles that can be utilized for this purpose. Predelivered roles start with SAP_BC_USR_CUA* and include the following roles:

- SAP_BC_USR_CUA_CENTRAL - Authorizations for RFC Service User in CUA Central System
- SAP_BC_USR_CUA_CENTRAL_BDIST - Authorizations for RFC Service Users in CUA Central System (Back)
- SAP_BC_USR_CUA_CENTRAL_EXTERN - Authorizations for RFC Users in CUA Central System (for External Users)
- SAP_BC_USR_CUA_CHDOC_READ - To read the local change documents for the CUA landscape from the child systems
- SAP_BC_USR_CUA_CLIENT - Authorizations for RFC Users in CUA Child System
- SAP_BC_USR_CUA_CLIENT_BATCH - Authorizations for RFC Users in CUA Child System (Background Processing)
- SAP_BC_USR_CUA_CLIENT_PFCG - Authorizations for RFC Users in CUA Child System (for Calling PFCG)
- SAP_BC_USR_CUA_CLIENT_RFC - Authorizations for RFC Users in CUA Child System (for RFC)
- SAP_BC_USR_CUA_SETUP_CENTRAL - Authorizations for RFC Users in CUA Central System (for CUA Configuration)
- SAP_BC_USR_CUA_SETUP_CLIENT - Authorizations for RFC Users in CUA Child System (for CUA Configuration)

Once the RFC connection and your users are defined, you can continue with the configuration of the CUA landscape.

9.12.2 Distribution Parameters for Fields (Transaction SCUM)

In the configuration of CUA, you can define which fields should be distributed and how they are managed. In Transaction SCUM, you define the distribution parameter for each field that is available in the user master record. Table 9.5 lists the available distribution parameters.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Option	Description
Global	The field can only be maintained in the central system and is automatically distributed to the child system. In the child system, the field cannot be changed.
Local	The field can only be maintained in the child system. Changes are not distributed to other systems.
Proposal	The field can be maintained in the central system, and a change is automatically distributed to the child system when a user is created. Changes are maintained in the child system. The central system does not distribute changes to existing users.
Redistribution	The field can be maintained in the central and child system. Changed fields in a child system will be synchronized back to the central system and then distributed to all child systems.
Everywhere	The field can be maintained everywhere. However, only changes to the central system will be distributed. Local changes might be overwritten when the field is changed in the central system.

Table 9.5 CUA Distribution Parameters in Transaction SCUM

User distribution fields can be defined individually. As shown in Figure 9.51, the distribution settings can be found under the **Logon data** tab. The initial password can be defined everywhere, whereas the security policy will only be maintained locally.

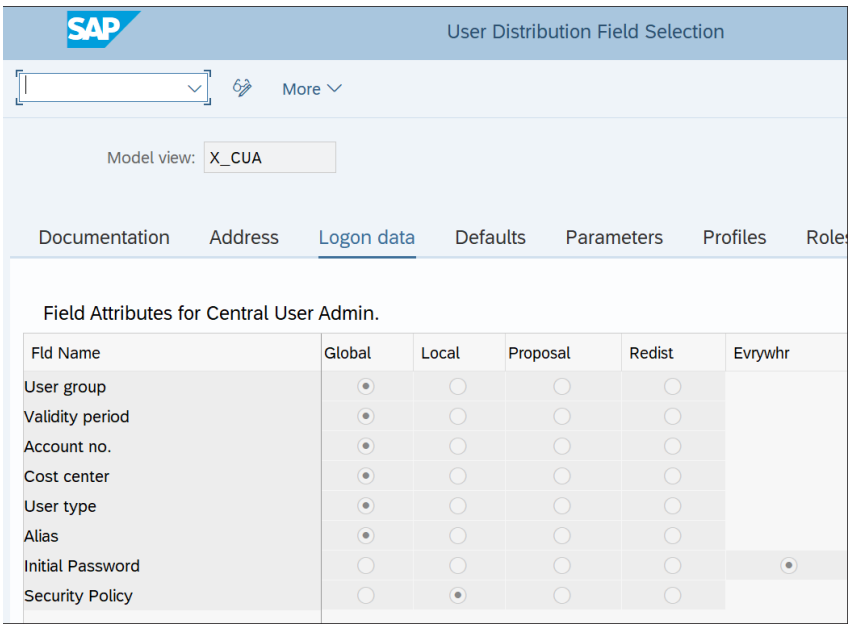


Figure 9.51 User Distribution Field Section for Logon Data in Transaction SCUM

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The same rule applies for roles and profile assignments. With a CUA master system, not only will you create and maintain your users, you can also manage the role assignments if set to **Global**, as shown in Figure 9.52.

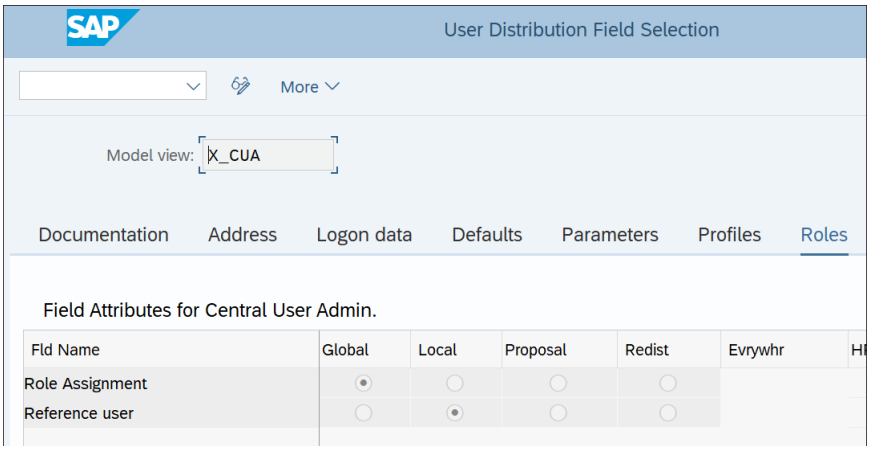


Figure 9.52 User Distribution Field Selection for Roles in Transaction SCUM

9.12.3 Central User Administration-Related Tables

In every CUA system, you can find helpful tables to slice and dice the data. Some examples are listed in Table 9.6. You should understand which tables are available in case you want to quickly check something through Transaction SE16 or SM30.

Table	Description
USRSYSACT	Roles in distributed systems
USRSYSACTT	Roles text in distributed systems
USRSYSLNG	User's language in distributed systems
USRSYSPRF	Profiles in distributed systems
USRSYSPRFT	Profiles text in distributed systems
USERSYSUPL	Price list in distributed systems
USERSYSUPPL	Assignment of user types to price list
USLA04	Assignment of users to roles

Table 9.6 CUA-related tables

CUA is an easy way to simplify user administration. Regardless of the number of systems and clients you manage, you might profit from using CUA. You can install the CUA as a dedicated client in one of your systems.

Personal Copy for Arun Singal, arun.singal560@gmail.com

9.13 SAP Usage Data for Users

A treasure trove of information related to transaction execution is Transaction STO3N (Workload Monitor). Among many other things, this transaction shows you user transaction execution activity. Using that information, you can analyze what transactions your users executed over the past few months. The exact timeframe depends on your system configuration. By default, your SAP system retains three months' worth of usage data, unless you changed the configuration.

The Workload Monitor is the central access point for analyzing performance problems in the SAP system as well as reading usage information. Transaction STO3N is a revised version of Transaction STO3. Transaction STO3N is used to analyze statistical data for the ABAP kernel and monitor the performance of a system. You can display the total values for all instances and compare the performance of particular instances over a period of time. Figure 9.53 shows an example of the workload analysis for the period **This Month**. You can see that **User Profile** analysis for user **ABANZER** shows the application executions for the current month. In this example, we can see that user **ABANZER** used Transaction **SE11** 23 times.

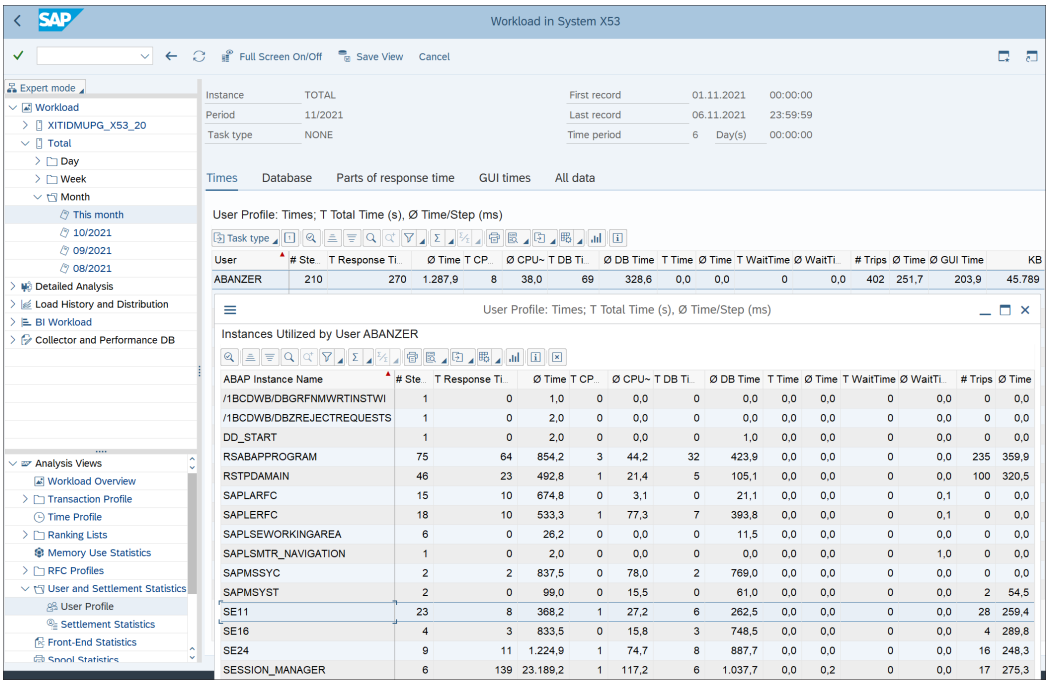


Figure 9.53 Workload Monitor: User Profile Analysis

This overview provides system administrators access to detailed information about the most important workload data, such as CPU time, the number of database changes,

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

and response times. You can display the workload overview for all task types (**Dialog**, **Background**, **RFC**, **ALE**, and **Update**) or only for one particular task type.

We generally recommend accumulating between 3 to 6 months' worth of usage data for a solid analysis of which transactions your users use. If you have SAP Access Control, you can get the same information from SAP GRC's Action Usage Report (table GRACACTUSAGE). SAP Access Control synchronizes transaction execution from satellite systems into the central table. These synchronization jobs must be scheduled periodically to ensure accuracy in your data.

9.14 Summary

Managing user master records is a critical task since the user ID enables your employees, vendors, contractors, and others to access your SAP systems. Each user ID requires authentication to the system—either via password or SSO. Once authenticated, the user requires authorizations to run applications within the SAP system.

User accounts are always changing, and thus, a security administrator must understand the powerful tools available to administer user master records both one by one as well as en masse. The next chapter will introduce you to SAP Access Control and SAP Cloud Identity Access Management (SAP Cloud IAG)—tools to help you to streamline your user lifecycle processes.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 10

Access Governance with SAP Access Control and SAP Cloud Identity Access Governance

With SAP Access Control and SAP Cloud Identity Access Governance, you can streamline identity and access management (IAM) in complex on-premise and cloud environments. Both tools work either as standalone solutions or alongside each other to provide capabilities for user provisioning, user access review (UAR) and certification, and emergency access management (EAM). With these tools, you can access various role management capabilities to manage business roles.

This chapter provides an overview of SAP Access Control with its four modules and SAP Cloud Identity Access Governance as well as some methodologies for role management and authorization remediation. The key benefits of using SAP Access Control and SAP Cloud Identity Access Governance include preventing identity access and authorization risks in cross-enterprise SAP systems to prevent fraud while at the same time reducing the cost of continuous compliance and control.

With their integrated risk analysis and workflow engine, these two solutions reduce the time required to detect, remediate, and approve access across different IT system. Both solutions offer centralized request and approval processes with integration to human resources (HR) systems, like SAP ERP Human Capital Management (SAP ERP HCM) and SAP SuccessFactors, to support user lifecycles from hire to retire. If elevated access is required for a short time, temporary access can be checked out, elevated, and reviewed by a supervisor.

10.1 SAP Access Control

SAP Access Control, part of SAP governance, risk, and compliance solutions (SAP GRC solutions), offers a robust access governance technology that brings digital services and applications to employees and business partners without exposing sensitive information to the wrong people. You can leverage SAP Access Control, which integrates with SAP Cloud Identity Access Governance, as the backbone of your company's access

Personal Copy for Arun Singal, arun.singal560@gmail.com

governance by automating user administration and user provisioning activities while securing your applications, processes, and data against unauthorized use.

The key benefits of using SAP Access Control include the following:

- **Detect and remediate risk**
  Identify and remediate access risk violations automatically across SAP and non-SAP systems, including cloud applications.
- **Enforce compliance**
  Embed compliance checks and mandatory risk mitigation into business processes.
- **Empower users**
  Enable users to submit self-service, workflow-driven access requests and approvals.
- **Carry out regular reviews**
  Conduct periodic UARs and comply with rules for ensuring the segregation of duties (SoD).
- **Enable emergency access**
  Grant temporary elevated access with "firefighter" logon IDs—in a controlled, auditable environment.

SAP Access Control comes with four core modules that are integrated with each other:

- **Access risk analysis**
  An access risk is one or more actions or permissions that, when available to a single user (or single role, profile, or HR object), creates the potential for fraud or unintentional error.

  As part of regular business operations, you should define access risks that require additional control to ensure that your organization operates securely. You can then monitor and control these risks to proactively prevent users from exploiting vulnerabilities to commit fraud or post unintentional errors.

  An important step is to separate and control a user's authorizations to comply with, for example, the Sarbanes-Oxley (SOX) Act and other laws and regulations. The access risk analysis (ARA) modules allows you to identify and detect access violations throughout the entire enterprise. This module can check for SoD violations, critical transactions, and authorizations as well as look for critical roles and profiles. To check these violations, the access risk analysis module uses a *ruleset* that contains the definition of the critical authorizations. The system compares the defined rules from the ruleset with the authorization in scope and reports any violation that might occur. The access risk analysis module enables you to analyze critical access and SoD conflicts on the user level, the role level, and the profile level as well as against HR positions. Furthermore, the access risk analysis module is natively integrated with the access request management (ARM) module to perform what-if simulations during an access request. With this simulation, the requester or the approver can simulate the impact of granting the requested access to the end user and decide whether alternative access should be requested instead.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

After you've defined the risks, you can use access risk analysis to generate reports presenting various types of information, including reports presenting access risks; conflicts; or the use of critical actions by a user, role, profile, or HR object.

When you identify an access risk in a report, you can resolve or remediate the risk by either removing it or by applying a mitigating control. You can also use reports in the ARA module to view mitigated risks and risks that have not yet been remediated.

The access risk analysis module also offers a mitigation framework to mitigate critical access and SoD conflicts. Mitigations are an important step when remediating access violations from a compliance point of view but are also important during regular access request workflows. Integrated with the ARM module, during an access request, access violations can be mitigated if this risk is new, while existing risks that have previously been mitigated will be hidden.

In a traditional organization, access was granted after completing paper-based forms that were sent through the organization for approval before finally making its way to IT security. The IT security administrator then grants the user access manually. Compliance checks and traceability capabilities were limited. During the manual approval process, how would a signee identify possible threats that an assignment would create? Also, an approval process can typically take days to complete, depending on the size and complexity of your organization.

- **Access request management**
  With ARM, a user can request access through a workflow-based module. When an access request is submitted, the request takes a predefined path, which allows for multiple approvals and security checks. Since the ARM module is tied into the access risk analysis module, an approver can execute compliance checks in form of access risk analysis to identify possible threats before they occur. You can customize the workflow to reflect your company's policies. Roles and authorizations are automatically logged when access requests are approved for future reference and for auditing. ARM ensures corporate accountability and compliance with Sarbanes-Oxley (SOX) along with other laws and regulations.

  During an access request, suppose the approvers are out of the office or don't perform the necessary steps on time. In this case, the ARM module includes a deputization concept and features escalation rules to address the problem of access not being approved on time.

- **Business role management**
  With business role management (BRM), your enterprise can implement certain steps involved in the lifetime of a role. During role creation, BRM allows you to apply naming conventions and then perform role updates with approvals from role content approvers, supporting you all the way to providing attributes for role provisioning and fully supports the lifecycle of a role.

Personal Copy for Arun Singal, arun.singal560@gmail.com

BRM empowers role owners to be involved in the role building process and to run risk analysis before a role is deployed as well as to contribute to documentation about role testing.

With its business role concept, BRM offers the ability to create system-independent roles to simplify technical role assignments in backend systems. This concept is similar to the use of composite roles but not restricted to a single system. The business role construct is only known in SAP Access Control but can be shared with SAP Identity Management (SAP ID Management) in an integrated provisioning scenario. When a business role is assigned to a user, the system distributes the technical role assignments to various backend systems, either via central user administration (CUA) or directly. The backend system, however, will not know that the role assignment originates from a business role.

The BRM module offers several role methodologies for implementing a complete role lifecycle process. However, in most implementations, BRM is only used to provide the roles and their attributes to access request workflows. In this scenario, the roles are imported into BRM and attributes like role owner, business processes, company assignments, etc. are maintained. Once activated in BRM, the roles are available during an access request, and the attributes allow for better role mining.

- **Emergency access management**
  With EAM, a user can perform emergency activities outside his or her standard assigned roles. A user performs these emergency activities in a controlled and fully auditable environment by checking out a *firefighter ID*. EAM allows you to temporarily use a firefighter ID that grants the user (the firefighter) broad but regulated access. All activities performed in the context of a firefighter ID are logged and can be reviewed.

  The firefighter scenario usually arises in emergency situations where executing certain tasks immediately is imperative. These tasks mostly disregard SoD violations and access risk violations. Integration with the ARM module allows you to control the assignment of firefighter IDs as well as to view their logs and report on review workflows. Firefighter access can be requested through ARM where various approvers can be part of the approval process. Most commonly, the user's manager and the firefighter owner are part of the approval process. Once a firefighter session has been concluded, review workflows can be utilized to properly document and review the audit trail of the firefighting activity. In this scenario, most commonly, the firefighter owner or controller is the main reviewer.

SAP Access Control 12.0 also integrates with a variety of SAP systems. You can connect to SAP S/4HANA, SAP SuccessFactors, SAP HANA databases, SAP SuccessFactors Employee Central Payroll, and SAP Process Control, as well as to SAP Cloud Identity Access Governance.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

SAP Cloud Identity Access Governance supports integrations with cloud-based applications to efficiently use SAP's cloud-based solutions like SAP Ariba, SAP Fieldglass, and SAP Concur. By integrating SAP Access Control 12.0 with SAP Cloud Identity Access Governance, you can natively adapt the risk analysis and user provisioning capabilities for SAP on-premise and cloud applications. In addition, continuous integration with SAP SuccessFactors is ensured, and access analysis is available for the following components:

- SAP Fiori apps in SAP S/4HANA
- EAM for SAP HANA database
- SAP ID Management for central provisioning and BRM

10.2 SAP Cloud Identity Access Governance

SAP Cloud Identity Access Governance is a cloud service from SAP Business Technology Platform (SAP BTP). This service offers similar functionality to SAP Access Control.

This service offers a range of IAM capabilities, including (among others) self-service access requests for on-premise and cloud-based applications, access risk analysis, and role design. Each service that comes with SAP Cloud Identity Access Governance can work independently or in combination with each another.

The following sections will provide a short overview of the core functionalities and capabilities of SAP Cloud Identity Access Governance and explore integration options.

10.2.1 Core Functionalities

SAP Cloud Identity Access Governance offers the following five core features:

- **Access analysis service**
  The access analysis service enables you to detect and remediate SoD and critical access risks. The **Access Analysis Overview** dashboard, shown in Figure 10.1, allows you to review the risk across the landscape by displaying the users who have a high risk score based on the critical actions they've executed. Further, you can dive into mitigated risks to see which users have compensating controls assigned. You can also display the defined business processes based on their risk level and similar metrics.

  SAP Cloud Identity Access Governance comes with rulesets for various applications including SAP S/4HANA, SAP Fiori, and SAP ERP, but also SAP Cloud solutions like SAP SuccessFactors, SAP Ariba, and more. With SAP Cloud Identity Access Governance, you can run continuous access analysis and use real-time insights to support access compliance management.

Personal Copy for Arun Singal, arun.singal560@gmail.com

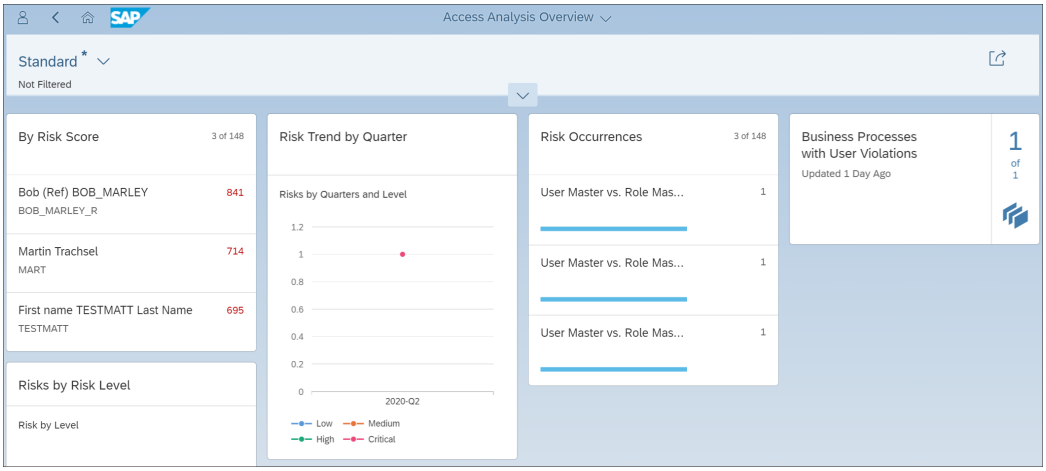


Figure 10.1 SAP Cloud Identity Access Governance: Access Analysis Overview

- **Access request service**
  The access request service integrates with additional SAP BTP services to utilize workflow management, provisioning, and business logic. SAP Cloud Identity Access Governance provides compliant provisioning of user access to various on-premise and cloud applications. Figure 10.2 shows an example of how the creation of an access request looks in SAP Cloud Identity Access Governance.

  With SAP Cloud Identity Access Governance, you can synchronize various backend systems—both on-premise and cloud applications—to enable access provisioning workflows, including SAP ERP, SAP S/4HANA, SAP SuccessFactors, SAP Ariba, SAP Analytics Cloud, and many more.

  In addition, with SAP Cloud Identity Access Governance, you can configure HR integration with SAP SuccessFactors to automate joiner, mover, and lever processes. With HR integration, you can automatically create user accounts and assign predefined access when a new hire is created in SAP SuccessFactors, as well as trigger role certification and removal processes when an employee leaves the company or changes positions.

- **Role design service**
  The role design service enables you to define and maintain compliant business roles directly in SAP Cloud Identity Access Governance to optimize role definition and streamline governance. This service also provides risk metrics and usage trends within a business role to evaluate the impact of a role on end users (so that role adjustments can be made). Figure 10.3 shows an example of business role maintenance in SAP Cloud Identity Access Governance.

  SAP Cloud Identity Access Governance offers role design capabilities to support you in building business roles based on usage information from the various backend systems.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

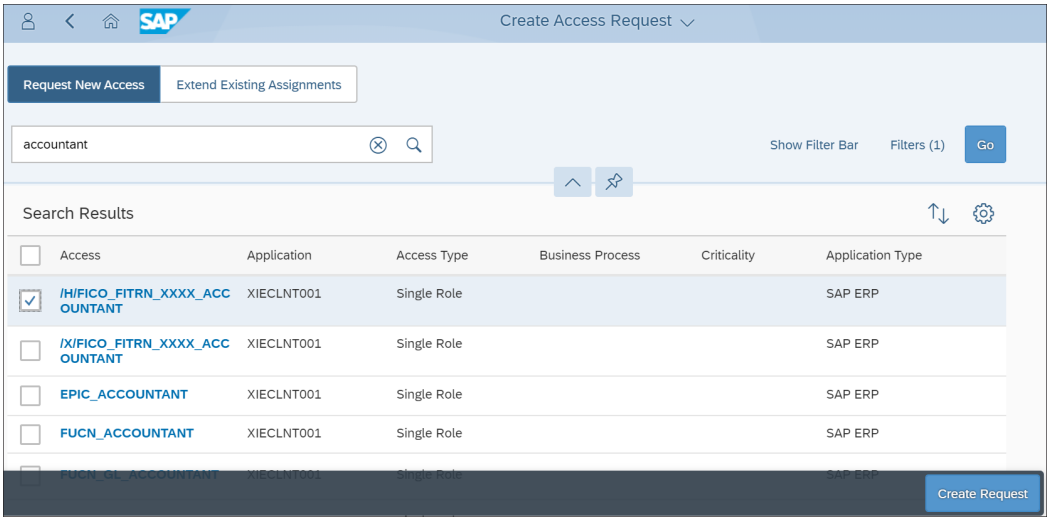


Figure 10.2 SAP Cloud Identity Access Governance: Create Access Request

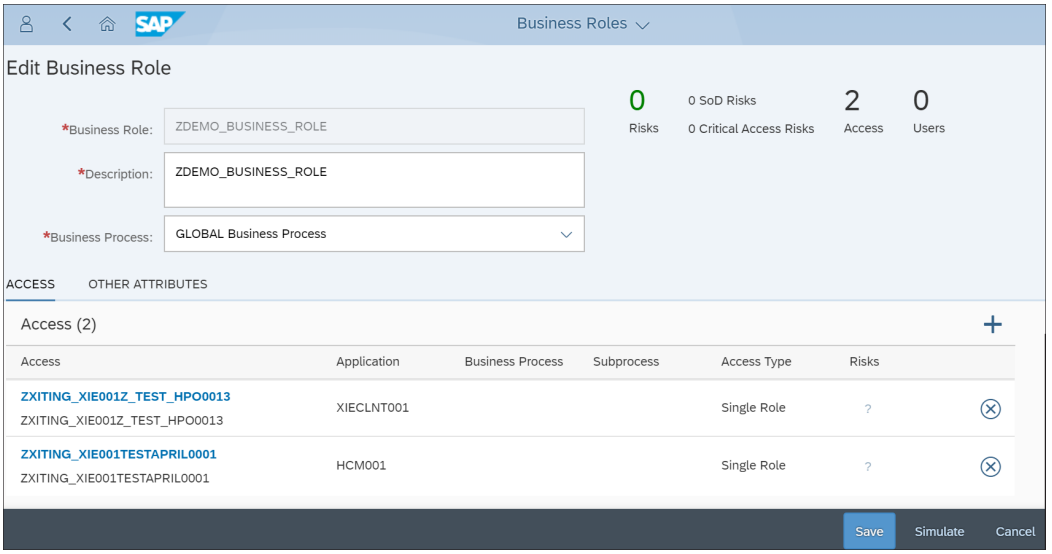


Figure 10.3 SAP Cloud Identity Access Governance: Edit Business Role

- **Access certification service**
  The access certification service allows you to review user access, roles, risks, and mitigation controls for on-premise and cloud-based applications. When an employee's job changes, an important task is to review and remediate their authorizations. Figure 10.4 shows an overview of ongoing campaigns to review access on the user level. On this overview screen, you'll see the progress and current stage of each campaign and whether it is on time or overdue.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Accumulated access often leads to security risks, so periodic recertification of a user's access helps establish a governance process to stay compliant. Under SOX, for example, user access must be reviewed annually at a minimum.

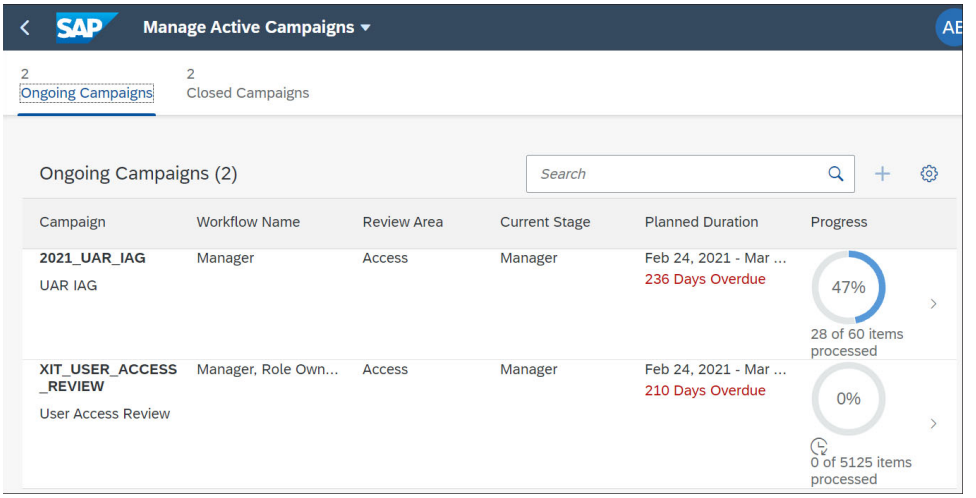


Figure 10.4 SAP Cloud Identity Access Governance: Manage Active Campaigns

- **Privilege access management service**

  The privilege access management service enables you to monitor access to sensitive and critical transactions, providing you better insight into how users with elevated authorizations interact with your organization's data.

  Additionally, SAP plans to leverage machine learning capabilities to help differentiate suspicious and fraudulent activity from normal behavior. This capability will become a key feature for reviewers, supporting them in the assessment and auditing of log files.

  As shown in Figure 10.5, log review requests are workflows that start once a firefighter session has been concluded. During the firefighter session, log files and other information are collected from the backend system and made available for review during the workflow.

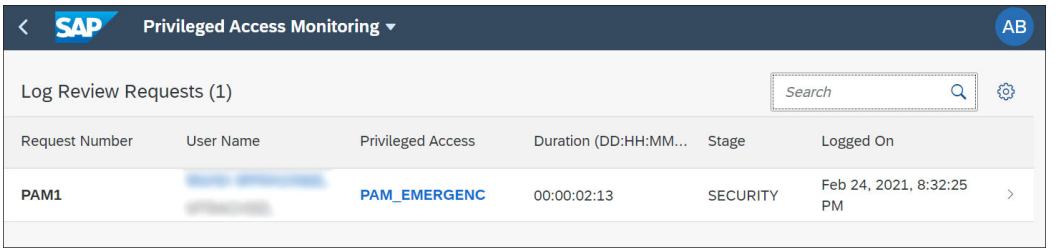


Figure 10.5 SAP Cloud Identity Access Governance: Privileged Access Monitoring

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Check SAP Road Maps for Future Releases and Dates

Refer to SAP Road Maps (*http://s-prs.co/v203611*) to see the release schedule for upcoming features.

10.2.2 Key Capabilities of SAP Cloud Identity Access Governance

The key capabilities of SAP Cloud Identity Access Governance are important for you to understand and include the following features:

- A secure environment for managing identities across your hybrid landscape from a central instance that runs on SAP BTP.
- Dashboard-based user interfaces (UIs) based on the familiar SAP Fiori user experience (UX) so that your end users can use familiar technologies. With SAP Fiori, these technologies can be integrated into your central launchpad.
- Instant visibility into access issues with drilldown capabilities to dig into an issue to determine the best method for remediation.
- Comprehensive access governance across your hybrid landscape with integrated workflows and readily available rulesets for various applications.
- Workflows are simple, seamless, and transparent and offer an audit log for your auditors.
- Modern, up-to-date, and scalable solutions that run on SAP BTP and can be extended to meet your needs.
- The SAP Cloud Identity Access Governance bridge, which provides a powerful tool to extend your on-premise SAP Access Control as shown in Figure 10.6. The bridge offers the following features:
  - Connectivity to cloud applications
  - Cross-application access risk analysis, including cloud applications, by using SAP Cloud Identity Access Governance's Access Analysis Service
  - Remediation processes with access refinement functions
  - Role designer to build business roles based on current assignments

  A disconnect between your system landscapes and your business applications can lead to additional work when it comes to support, customization, and integration. With the bridge, you can connect both worlds to achieve better governance and fully comply with regulations.

  In the age of digitalization, new business models, and cloud-first strategies, many organizations face challenges in managing access and authorizations in both cloud-based and on-premise systems.

Personal Copy for Arun Singal, arun.singal560@gmail.com

The bridge concept offers an intuitive way to extend SAP Access Control. With this extension, you can group cloud applications under one compliance domain, easily connect to cloud applications, and extend your cross-application risk analysis into the cloud.

Furthermore, the role design service allows you to extract proposals based on assignments to build stable and powerful business roles.

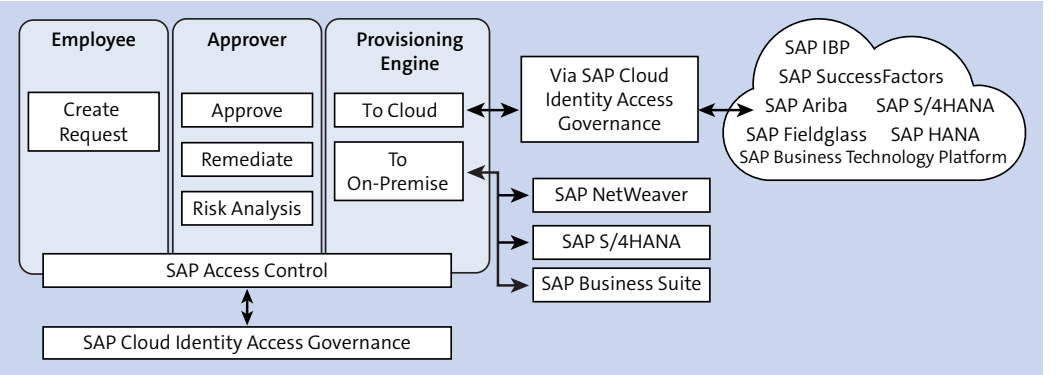


Figure 10.6 SAP Cloud Identity Access Governance Bridge: Overview

Other key features offered by the bridge include the following:

- Synchronization of master data from SAP Access Control to SAP Cloud Identity Access Governance, including:
  - Access risk definitions
  - Mitigating controls
- Connectivity to target on-premise applications from SAP Access Control
- Connectivity to various cloud-based applications (e.g., SAP Ariba, SAP S/4HANA Cloud, etc.)
- Analysis of cross-system risks (between on-premise and cloud)
- Extend your current SAP Access Control installation without compromising on functionality, access governance, or other compliance requirements

10.2.3 Integrated Identity Access Governance for Hybrid Landscapes

SAP BTP offers a variety of services related to IAM. In the age of digitalization, new business models and cloud-first strategies, many businesses are encountering new challenges when trying to manage the identity lifecycle.

Employees (end users) require access to various systems, which can become extremely complex in a hybrid landscape involving both on-premise and cloud-based applications.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

SAP BTP offers three main services to manage the identity lifecycle:

- SAP Cloud Identity Access Governance to analyze access risks and SoD issues
- Identity Authentication service to authenticate users to cloud-based applications
- Identity Provisioning service to provision users to cloud-based applications

These three services integrate with each other to provide a holistic solution to meet common IAM challenges.

You can seamlessly achieve access governance across a hybrid landscape, automate access request approval, automate provisioning based on HR events, expand your systems for key business applications (between on-premise and the cloud), and natively integrate with SAP S/4HANA to access rule content and to support new authorization models.

SAP Cloud Identity Access Governance is offered in the software as a service (SaaS) model, which enables a company to access several distinct identity management and access governance capabilities. Each of these capabilities can be used separately to address specific business needs and can also be integrated with native applications via SAP BTP.

You have the flexibility to use one, many, or all the available services, depending on your business requirements. As a cloud-based solution, SAP Cloud Identity Access Governance can be easily extended across your entire enterprise to meet your demands.

10.3 Understanding the Ruleset

To understand how a business risk occurs, you must understand the methodology that both SAP Access Control and also SAP Cloud Identity Access Governance follow to identify a risk by its components. One or more business risks can be grouped into a ruleset. This section covers the architecture of a ruleset and its components so that you can understand why a risk is displayed. As a role administrator, often role redesigns are triggered by SoD and critical access violations causing failure in audits. Understanding how to read and process a ruleset is therefore imperative.

10.3.1 Ruleset Components

A ruleset is where rules are defined in relation to specific SAP transaction codes that are/are not permitted for assignment to users. For SoD risks, the rules can define which combinations of transactions are not permitted. The rules also define which transactions are critical in nature, which may involve potentially compromising data confidentiality, system or data integrity, or system availability.

SAP Access Control uses these rules to assess users, roles, and profiles to identify access that could lead to breaches. Such breaches (conflicts or violations) can either be found

Personal Copy for Arun Singal, arun.singal560@gmail.com

in roles (due to combinations of transactions found in a role), at the user level (due to combinations of roles and thus combinations of transactions assigned to the user), at the profile level (due to conflicting authorizations within a profile itself, e.g., SAP_ALL), or at the HR position level (indirect access through the HR module).

A ruleset consists of the following components:

- **Access risks**
  An access risk is one or more actions or permissions that, when available to a single user (or single role, profile, or HR object), creates the potential for fraud or unintentional errors. An access risk consists of one or more functions depending on the type of the risk. The following risk types are available:
  - **Critical action**
    Critical action risks consist of transactions that are considered critical. You have options to run the risk analysis at both the action level and/or the permission level. Critical action risks are created with one function only.
  - **Critical permissions**
    Critical permission risks consist of authorization objects/permissions that are considered critical. Critical permission risks are created with one function only, which cannot contain transactions.
  - **SoD risks**
    SoD risks consist of conflicting transactions along with their authorizations objects and values that are considered critical. SoD risks are created with two or more functions. Each function is combined with the OR operator.

Example

An example of a common SoD violation occurs when the ability to create vendor master data and the ability to process accounts payable payments both belong to one role.

This particular SoD conflict describes the risks that arises when a single individual is allowed to create a (fictitious) vendor, including maintaining its payment information, and then can generate (fraudulent) payments to that vendor.

- **Functions**
  A function—in governance, risk, and compliance terms—can be defined as a task that is executed in SAP, for example, purchase order maintenance or vendor master data maintenance. A function is a wrapper in the ruleset to house all the various transactions that could be executed by a user to run a particular task. For example, in SAP ERP, Transactions ME21N (Create Purchase Order) and ME22N (Maintain Purchase Order), among others, can be used for the task of purchase order maintenance and would therefore be found in the corresponding function.

  As well as defining the transactions that a user could execute to run a task, the function will also contain a definition of all the authorization objects and authorization

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

values that are required to execute each transaction. This detail is required to fully establish whether a role or a user has all the access required to execute a transaction. If they do not, then the transaction cannot be executed and would thus the risk of breach is minimized.

10.3.2 Ruleset Architecture

Figure 10.7 shows the systematic architecture of a ruleset with its components. Our example involves two SoD risks, consisting of two functions each. Functions can be involved in one or more risks. In this example, Business Risk 1 is defined through the functions Business Function 1 and Business Function 2. A function is defined through transactions (Actions) and authorizations (Permissions). Each action is defined with permissions. For example, Transaction SU01 requires authorization object S_USER_GRP to have the ACTVT values 01, 02, 05, or 06 for the transaction to be deemed critical. Therefore, in the ruleset, if this transaction is part of a function for user management, the transaction and its authorization values are maintained. A risk is then created when, in each function at least one action with a permission, is found.

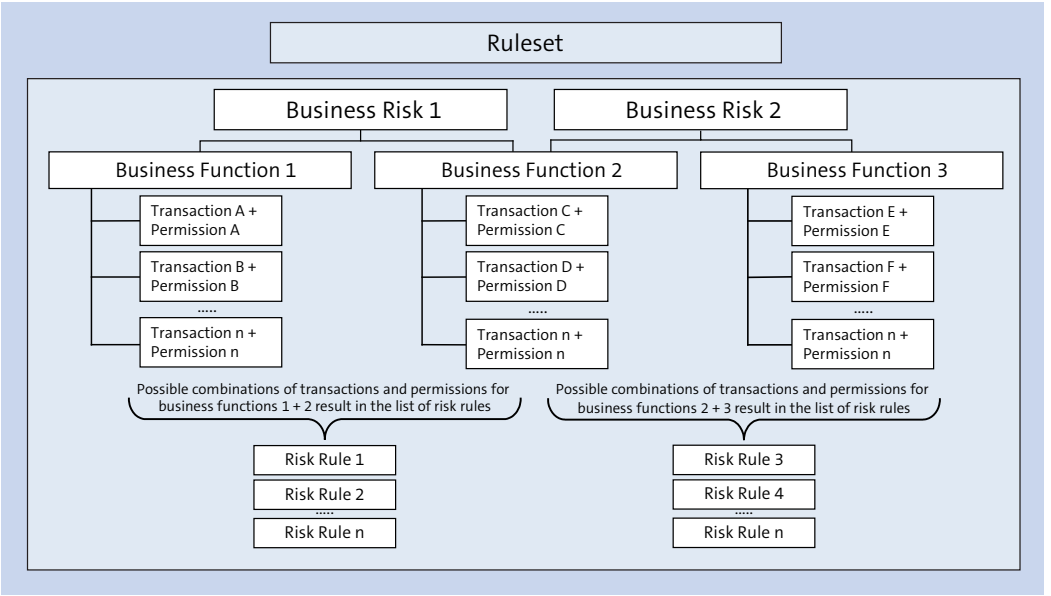


Figure 10.7 Architecture of a Ruleset

Figure 10.8 shows an example of a common SoD conflict from a business view. In this example, the SoD "Maintain Purchase Orders versus Manage Goods Receipt" is defined through an access risk (of type SoD). The access risk contains two functions: Maintain Purchase Orders and Manage Goods Receipt. Each of these two functions have been defined with actions and permissions.

Personal Copy for Arun Singal, arun.singal560@gmail.com

When running an SoD analysis, the SoD is caused when one of the rules is found. The rule represents every single combination of SoD that is possible in this scenario. As shown in Figure 10.8, both functions are defined with two transactions, which thus requires four rules.

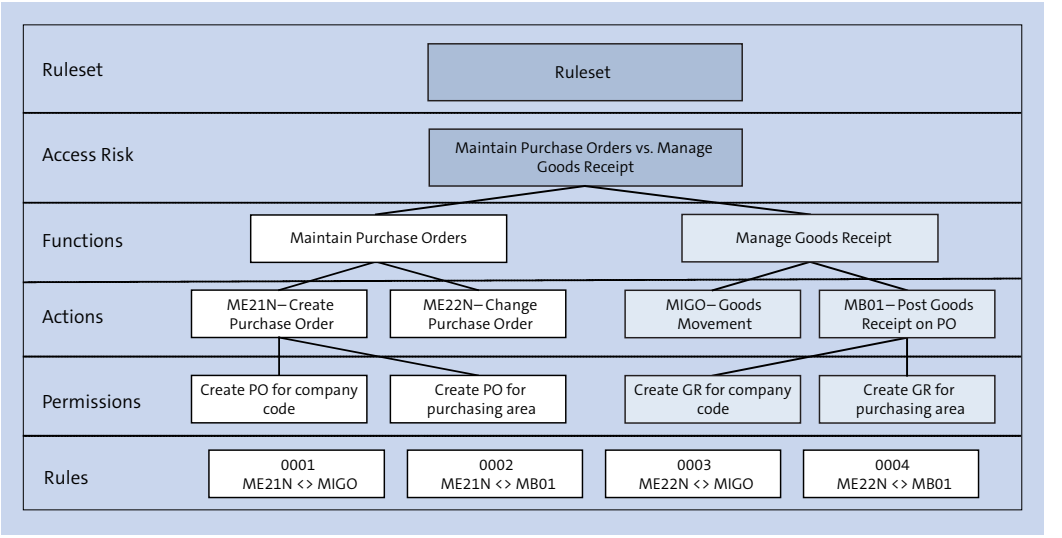


Figure 10.8 Ruleset Example with SoD

When changing the ruleset in SAP Access Control, you must execute the job GRAC_GENERATE_RULES to generate all possible combination rules via Transaction SPRO. Navigate to **GRC • Access Control • Access Risk Analysis • SOD Rules • Generate SoD Rules**. Without the generation of rules, content changes to the ruleset will not be available for analysis. Therefore, we recommend scheduling the job for updating rules to run frequently.

Tip

The number of rules defined for a risk is determined by a) the number of action combinations and b) the permission/field value combinations contained in each function of the risk. For more information, refer to *http://s-prs.co/v203613*.

10.3.3 SAP Standard Rulesets

SAP delivers industry standard rulesets with SAP Access Control that contain extensive sets of known SoD and critical risks. Table 10.1 provides an overview of rulesets available in SAP Access Control 12.0.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Business Configuration Set	Description
GRAC_RA_RULESET_COMMON	Common rules
GRAC_RA_RULESET_ISU_COMMON	ISU common rules
GRAC_RA_RULESET_JDE	JDE rules
GRAC_RA_RULESET_ORACLE	ORACLE rules
GRAC_RA_RULESET_PSOFT	PeopleSoft rules
GRAC_RA_RULESET_S4HANA_ALL	SAP S/4HANA and SAP Fiori app rules
GRAC_RA_RULESET_S4HANA_CORE	SAP S/4HANA core rules
GRAC_RA_RULESET_S4HANA_FIORI	SAP S/4HANA SAP Fiori apps only rules
GRAC_RA_RULESET_SAP_APO	SAP Advanced Planning and Optimization rules
GRAC_RA_RULESET_SAP_BASIS	Basis rules
GRAC_RA_RULESET_SAP_CRM	SAP Customer Relations Management (SAP CRM) rules
GRAC_RA_RULESET_SAP_ECCS	SAP ERP rules
GRAC_RA_RULESET_SAP_HANA	SAP HANA rules
GRAC_RA_RULESET_SAP_HR	HR rules
GRAC_RA_RULESET_SAP_ISU	SAP for Utilities rules
GRAC_RA_RULESET_SAP_NHR	R/3 excluding HR Basis rules
GRAC_RA_RULESET_SAP_R3	R/3 rules
GRAC_RA_RULESET_SAP_SRM	SAP Supplier Relationship Management (SAP SRM) rules

Table 10.1 Available Rulesets in SAP Access Control 12.0

Tip

You can check the available BC sets and activate them in Transaction SCPR20.

The SAP standard rulesets form the basis of the customer ruleset. During customization of your ruleset, you should identify your business processes and adjust accordingly. SAP recommends creating custom functions and access risks in your customer namespace (e.g., starting with "Z") and not to modify the standard predelivered objects at all. This approach also allows you to update (reimport the BC sets) the standard rules and then compare the standard against your customizations.

Personal Copy for Arun Singal, arun.singal560@gmail.com

In SAP Cloud Identity Access Governance, SAP provides standard rulesets for various target systems (SAP ERP, SAP S/4HANA, SAP Fiori, SAP SuccessFactors, SAP Ariba, etc.) that must be requested through an incident ticket in SAP Support Portal.

SAP Note 2782388

SAP Note 2782388: IAG - How to load default standard ruleset explains how you can request that standard rulesets be loaded into SAP Cloud Identity Access Governance.

10.3.4 Organizational Rules

Organizational rules in SAP Access Control are used to eliminate false positives in SoD reporting based on organizational level restrictions for users. Organizational rules should not be created for mass organization level reporting; organizational rules should only be enabled for functions that you specifically need to segregate. Most companies control what data a user has access to via role assignment.

Organizational rules allow you to filter false positives from risk analysis. False positives in the context of organizational rules are caused when the risk analysis does not consider organizational levels. For example, a user can maintain master data for company code A and perform a posting for company code B. Without respecting organizational values, this scenario may involve an SoD conflict since one individual can both maintain master data and also post transactions.

To elaborate on this topic, suppose, for example, we have the following roles:

- Role A: Z_ROLE_A_1000 for company code 1000 with action FB60, as shown in Figure 10.9
- Role B: Z_ROLE_B_2000 for company code 2000 with action FK02, as shown in Figure 10.10

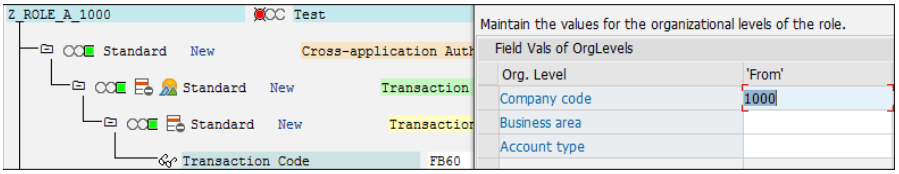


Figure 10.9 Example: Role Z_ROLE_A_1000

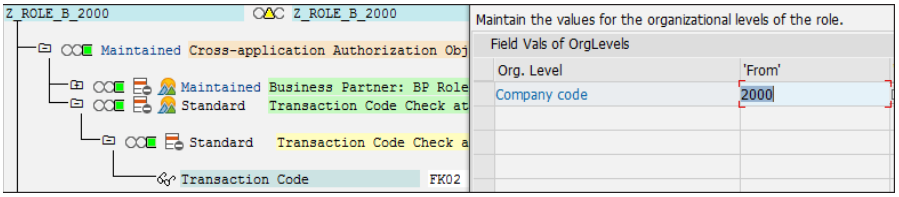


Figure 10.10 Example: Z_ROLE_B_2000

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Role A contains Transaction FB60 (posting of vendor invoices) for company code 1000, whereas Role B contains Transaction FK02 (changing vendor master data) for company code 2000.

The combination of Transaction FK02 and Transaction FB60 with their permissions constitutes an SoD risk since the posting of vendor invoices and the changing of vendor master data shouldn't be performed by the same person. A user who receives these two roles would have both transactions assigned, and thus, the risk analysis will show a risk. However, this risk isn't really a risk since the same individual is limited in their actions by organizational level (company code). This result is a false positive, and by utilizing organizational rules, you can ensure these scenarios are not reported as risks during risk analysis.

In most cases, organizational rules are created for individual risks, but not for all risks. This limitation is mainly due to the potential performance impact that organizational rule analysis causes.

10.3.5 Simulating Risk During Role Building with the Risk Terminator

The Risk Terminator is a component delivered automatically with SAP Access Control. With the access risk analysis module, risk analysis should be carried out manually for every role/user change. But, what if a critical role is assigned to the user without performing risk analysis? What if critical transaction codes like Transactions SCC4, PFCG, and SPRO are added to a newly created role or an existing role?

The Risk Terminator provides the ability to keep the SAP systems free of risk. Running in the background, a popup window will appear when a role is assigned in Transactions SU01, SU10, and PFCG or when a role modification in Transaction PFCG might cause risk. The Risk Terminator resides on the backend ABAP system and uses the access risk analysis module to run an ad-hoc risk analysis. Depending on the configuration, the Risk Terminator can work as both a detective (reporting on access violations) or as a preventive (the system will prevent violations from being introduced into roles).

Whenever a change is made to an existing SAP role, or a new role is created, the Risk Terminator checks the content of the role. With the Risk Terminator, a role administrator can immediately remediate access violations during the development of roles and thus play an important part in ensuring that the system stays clean (by preventing violations from being introduced in the first place). In this scenario, the Risk Terminator is used in the development system (DEV). You can also use the Risk Terminator when assigning roles to users, a powerful feature in your productive system (PRD). When checking role assignments, the Risk Terminator runs a simulation and displays all the risks on the user level (similar to an ARM workflow). As a security administrator, you also can mitigate the risk if the risk cannot be avoided.

Personal Copy for Arun Singal, arun.singal560@gmail.com

In the area of role development, the Risk Terminator can be a valuable asset to a role administrator in preventing SoD conflicts and preventing sensitive access violations from being introduced into roles.

Example

You can use the Risk Terminator in your DEV to scan role changes against the ruleset to avoid introducing risks to roles.

You can also use the Risk Terminator in your PRD to simulate role assignments through Transactions SU01, SU10, and PFCG to avoid introducing risks to users.

10.4 Segregation of Duties Management Process

The goal of an SoD management process is to eliminate, or at least reduce, the possibility of errors and fraud. Because a single user shouldn't have access to multiple phases of any business process, the management of such risks is important. This section covers the steps required to implement an SoD management process in your organization. A best practice approach involves three phases with various steps, as discussed in this section.

10.4.1 Phases of Segregation of Duties Management

To achieve SoD, a business process must be divided, distributed, and allocated among various individuals. This segregation is carried out in three phases, and SAP Access Control is an ideal tool to support this process by providing you the necessary tools and functionality to work through the process.

Let's look at the three phases you'll follow next:

- **Phase 1**
  - *Risk recognition*

    In this first step, you'll define a high level list of applicable SoD conflicts that may allow fraud or generate significant errors. The outcome of this step is that you've determined what is an unacceptable risk that your company may want to report on and manage via remediation or mitigation. This step is carried out outside the system and includes a fundamental understanding of business processes and their vulnerabilities.
  - *Rule building and validation*

    In the second step, you'll build the technical ruleset based on the recognized risks from step 1. The outcome of this step is the technical ruleset that allows you to analyze and identify risks on users, roles, or profiles. The technical ruleset is built in the access risk analysis module.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Phase 2**
  - *Risk analysis*

    The first step in phase 2 is to analyze the result of the risk analysis. The access risk analysis module allows you to perform a risk analysis against users, roles, profiles, and even HR objects (positions, jobs, etc.). The result of the risk analysis will identify if a single user, a single role, a single profile, or a job/position can perform any of the conflicting functions defined in step 1. As a security administrator, you can use these results to provide the business insights into alternatives for correcting or eliminating discovered risks.
  - *Remediation*

    One of the most important steps in the process, the goal is to remediate the occurrence of a conflict on the user level. Please note, the occurrence of an SoD conflict occurs most often at the point when a role is assigned to a user. Therefore, evaluate whether conflicting tasks can be separated to another user. In this step, role changes and the reassignment of roles become necessary because only then is hard remediation of access violations possible. The result of this step is to reduce the number of conflicts to a minimum so that only a few risks must be mitigated.
  - *Mitigation*

    If remediation isn't possible, the remaining risks must be mitigated. Mitigation requires a formal description and an action to appropriately mitigate the risk. In most cases, mitigation is achieved by implementing additional monitoring procedures to compensate for a risk after an action has occurred. Mitigating actions are, in most cases, performed after an event occurs, and therefore, you should avoid mitigations as much as possible.
- **Phase 3**
  - *Continuous compliance*

    In this final phase, an important step is to establish a continuous process wherein every access request is reviewed against the SoD conflict matrix prior to provisioning. In addition, make sure that all role changes undergo risk analysis and are remediated before becoming available to end users. The result is that your system is clean from violation.

10.4.2 Remediation and Mitigation of Risks

The access risk analysis module enables you to define user access risks (Section 10.3); execute risk analysis to identify access risk (or simulate access to find potential risks); and then provide you with system functionalities to remediate a risk, including the assignment of a mitigating control. This approach can apply to any version of SAP Access Control.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Like any other risk process, a reviewer has four options: accept, transfer, mitigate, or remediate. This section describes some strategies and approaches to risk remediation. Your first goal should always be to remediate a risk before you mitigate. Remediation removes the risk (perhaps to an acceptable residual level) from the system and does not rely on the use of compensating controls (typically manual control that requires a person to take regular action and can thus result in human error). Accepting and transferring risk should be last resorts. As always, your job is to balance the cost and benefits of any remediation effort. Spending more on the control than the true cost of the risk (financial, reputation, legal and compliance, etc.) doesn't make sense.

When a risk has been identified (violation, issue, etc.), someone must take action to resolve it. Depending on your master data setup, SAP Access Control automatically displays the risk definition, including who is responsible (the risk owner), the relevant business process, and mitigation owners/monitors. This information is important so you know who to contact to discuss the risk and where to get advice on how to approach the risk. The following sections describe where to start a remediation process and what should be considered along the way. Remediating access risks (e.g., critical access) and SoD conflicts can be a cumbersome task that requires both technical understanding and business process understanding.

Warning

Be aware that, the first time you run a risk analysis, the number of violations will likely be rather high. Users may suffer from access creep from changes in job function while retaining old access. Roles may have been built with too much access. At the time, perhaps your business lacked the adequate tools to identify these risks. Many organizations undergo a security redesign project once they've implemented SAP Access Control due to the number of inherent conflicts in their roles. In the end, completely rebuilding your security concept (security by design) may be easier than trying to resolve issues and clean up your existing roles. In some cases, a company is aware of an issue but mistakenly believes implementing SAP Access Control will fix it automatically. SAP Access Control will give you the number of violations but cannot help you if you don't go down the path of remediation and mitigation.

Starting the Remediation

Your security role design and your access provisioning strategies will impact how you approach remediation. The graphic shown in Figure 10.11 assumes that a position-based security concept is used in your organization. Depending on the authorization concept and access management in your system, the number of circles will vary. For example, you may not require business roles or composite roles.

When approaching risk remediation, use the diagram shown in Figure 10.11 as a reference and work your way from the inside out.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

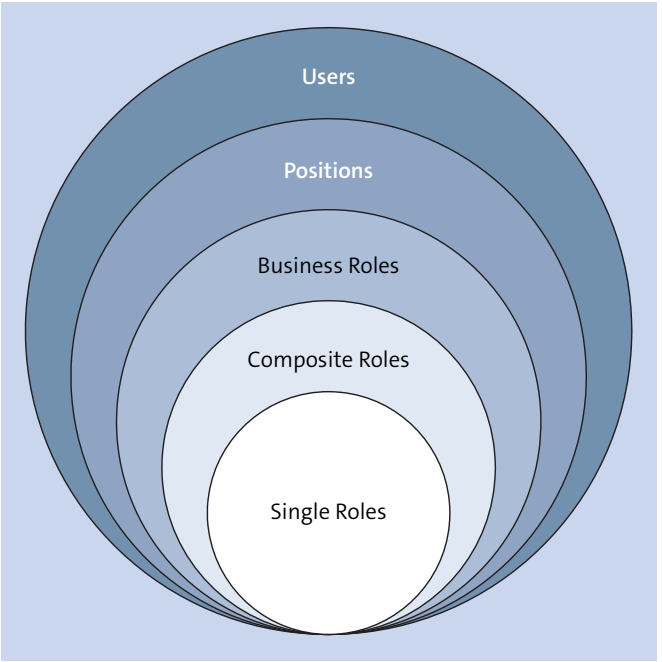


Figure 10.11 Where to Start Remediating

Several approaches can be taken, depending on the type of role, as follows:

- **Single roles**
  Focus on remediating conflicts in your imparting roles and other non-derived single roles. You'll fix your derived roles when you distribute a change from the master role (assuming you've followed SAP standard security rules and have not added additional authorizations to your derivations). Single role cleanup might involve the removal of transactions and other authorizations.
- **Composite roles**
  By this stage, you expect that none of the single roles have inherent conflicts. You cannot remediate risk in a composite role if one of its single roles has a conflict. Your choice to remediate at this point is to remove single roles assigned to the composite role (possibly replacing them with a different single role). Another option is to remove access from the single role (which may thus not cause an inherent conflict) if the access is not required but is contributing to the violation.
- **Business roles**
  This approach assumes you've built business roles via BRM in SAP Access Control for provisioning or you've built business roles in SAP ID Management. The same principal applies to business roles as for composite roles.

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Positions**
  If you're using position-based security, then you can consider removing roles (single, derived, composite, etc.) from a position to avoid conflicts.
- **Users**
  Finally, you've removed all inherited risks. The only unmitigated risk violations against the user might be due to a combination of a user's access authorizations. At this stage, you can try removing roles, reassigning other roles, etc.

Note

Remediating inherent role conflicts will take time. You'll need to work with business process owners (the business) to determine the appropriate solution. Once you identify the permissions to remove from a role, follow your company's change management process to schedule the change and arrange a transport to production. As an interim measure, you may need to implement a mitigating control.

Regardless of approach, remediation is still a business decision. To begin remediation, you'll need to consider meeting with your business process owners, line managers, or other stakeholders, depending on your company's organizational model and approach to risk management.

In these conversations with stakeholders, you must outline and explain the risk and why it needs to be remediated. In some cases, the conversation may be as simple as asking, "Is this access really required?" You may discover over time that access creep has caused conflicts and requires cleanup. Where a user is concerned, you might ask, "Does this user really need both access authorizations?" Your stakeholders can identify noncompliance in job duties or suggest alternative users to take on part of a function. Again, your approach will all depend on the business, so get out there and talk to your stakeholders.

Choosing and Implementing a Remediation Approach

Figure 10.12 shows the process of deciding how to remediate a risk. You may devise a similar approach and change the sequence of questions, depending on your organization's policy.

Use the diagram shown in Figure 10.12 as a reference when considering the following points:

- **Is it a risk?**
  Before investing work effort into remediation, you'll need to verify that violation is a risk and not a false positive. You may have executed the report at the action level only, and when you re-run the report at the permission level, the violation no longer appears. Alternatively, you may look at the violation and question why it is a risk in the first place.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

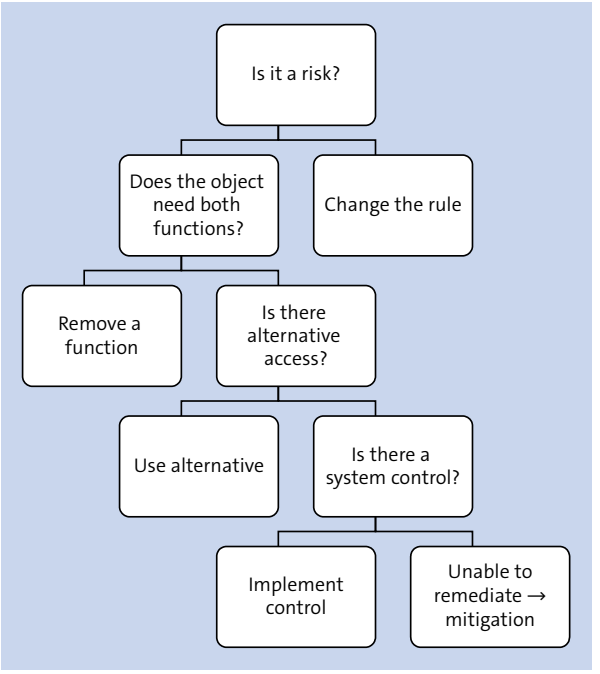


Figure 10.12 Remediation Approach

If you realize the risk definition is incorrect, then you need to change it. The ruleset is not static and must be reviewed regularly. Ensure that you follow the proper change management process when touching the ruleset.

- **Does the object need both functions?**
  The violation is a risk, and you need to take action. Does the object (role, position, etc.) require both actions? To assist in this decision, you could look at action usage reports in SAP Access Control. If one of the functions is not used, then remove it. For roles, this removal will involve a change request, and for users/positions, removal will require an access request. Approval from the business will be required regardless.
- **Is there alternative access?**
  You've determined that both functions are used, but you could assign a different transaction or authorization combination to restrict access. For example, a user might have Transaction XK01/02 for vendors but doesn't need all the views—such as payment details. Instead, this user only needs Transaction FK01/02, which does not include payment details. By changing the transaction, the user can still perform their job function but via a different, perhaps more focused, transaction.
- **Is there a system control?**
  Can system controls via IMG configuration, workflows, or ABAP development be implemented to remove the risk? Alternatively, can a business process be changed

Personal Copy for Arun Singal, arun.singal560@gmail.com

to include a new step? For example, you might add a vendor confirmation step using Transaction FK08/FLO9 for sensitive fields to force a second pair of eyes to review a change to a vendor master record.

- **Unable to remediate**
  By this stage, you've exhausted all options to remediate access and must investigate mitigation as an option. First, always try to find a way to remediate a risk instead of defining compensating controls. Mitigation, whether through spot checks, reviewing postings, etc. is always a reactive approach, and fraudulent actions might be performed in the meantime or might even go on undetected. Still, you'll need to balance between managing risk and allowing the business to function. If you cannot remediate, you must consider a mitigation.

Once you've remediated all risks, we recommend you perform a risk analysis again. You must ensure that by remediating a violation you did not introduce a new violation (for example, when reassigning roles or moving transactions from one role to another). The good news with SAP Access Control is its ability to simulate access risks. Before going through a role change or an access change, you can execute a risk simulation to test how removing the conflicting function and replacing it with an alternative will impact your roles. In this way, you can be confident during remediation that you are avoiding introducing new risk. Using the simulation feature will also reduce rework through continual rebuild or access change.

10.4.3 Continuous Segregation of Duties Monitoring

Unfortunately, risk identification and analysis are continual processes. You must regularly plan to review your rulesets to ensure risks are valid and can handle updates, including support packs (SPs), enhancement packs (EHPs), custom development, changes to configuration, changes to the business, and more. The system and your business are in a constant state of change. In addition, when security role changes are migrated to PRD, then users may now have new risks.

Make sure that you keep on top of review tasks, so that you'll only encounter small numbers of violations at a time. Scheduling role recertifications in BRM, SoD review workflows, and UAR review workflows will help you manage this continuous process.

SAP Access Control offers functionalities to continuously monitor your risks with the SoD review workflow. SoD review is a process that allows you to periodically scan your SAP systems for any risks associated with users. The SoD review workflow also shows previously mitigated risks but is mostly used to detect new violations.

When an SoD review is performed, SAP Access Control generates requests automatically, based on your organization's internal policy. The SoD review provides a workflow-based review and approval process for either the manager of a user or the risk owner of the risk that appears.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The SoD review workflow allows you to stay compliant with your internal policy. Even though you're using ARM to simulate role assignments to users to avoid undetected SoDs, new violations can occur (mostly due to role changes that occur behind the scenes). If a security administrator changes an existing role that is already assigned to users, that change might potentially create a risk. Therefore, we recommend periodically executing the SoD review workflow to find these undetected violations that may creep in.

10.5 Custom Transactions for the Ruleset

Organizations are constantly evolving, and new requirements arise that might not be available in SAP standard. If functionality is missing, some companies create custom functionalities to satisfy specific requirements. Over the lifespan of an SAP system, companies may introduce custom code and custom transactions that might allow access to sensitive data as well as enable the manipulation of master data and business processes. Often, these customizations are overseen or ignored when implementing a compliant ruleset. Custom transactions must be considered in the ruleset, and many auditing firms routinely review the use and applicability of custom transactions in the ruleset.

This section describes a best practice approach for analyzing and assessing custom transactions. In most organizations, the number of custom transactions grows over time, making analyzing and understanding what a custom transaction does difficult and cumbersome. Often, hundreds perhaps even thousands, of custom transactions aren't even used but still exist in the system and are authorized to end users. Therefore, you must understand the steps required to properly tackle an analysis of your custom transactions in regard to your rulesets.

Note

Analyzing custom transactions and custom code is potentially back-breaking work since understanding the intention and use of a customization can be difficult. Use tools that explore what the customization does so that you can assess whether it needs to be included in the ruleset.

10.5.1 Analyzing Custom Transactions

The graphic shown in Figure 10.13 illustrates an approach to analyzing custom developments.

Before you can add a custom transaction to the ruleset, you must identify and assess what is available in your system. As a guideline, let's look at each of the steps shown in

Personal Copy for Arun Singal, arun.singal560@gmail.com

Figure 10.13. In the process, we'll provide helpful tips and tricks and advice on where you can extract the data you need.

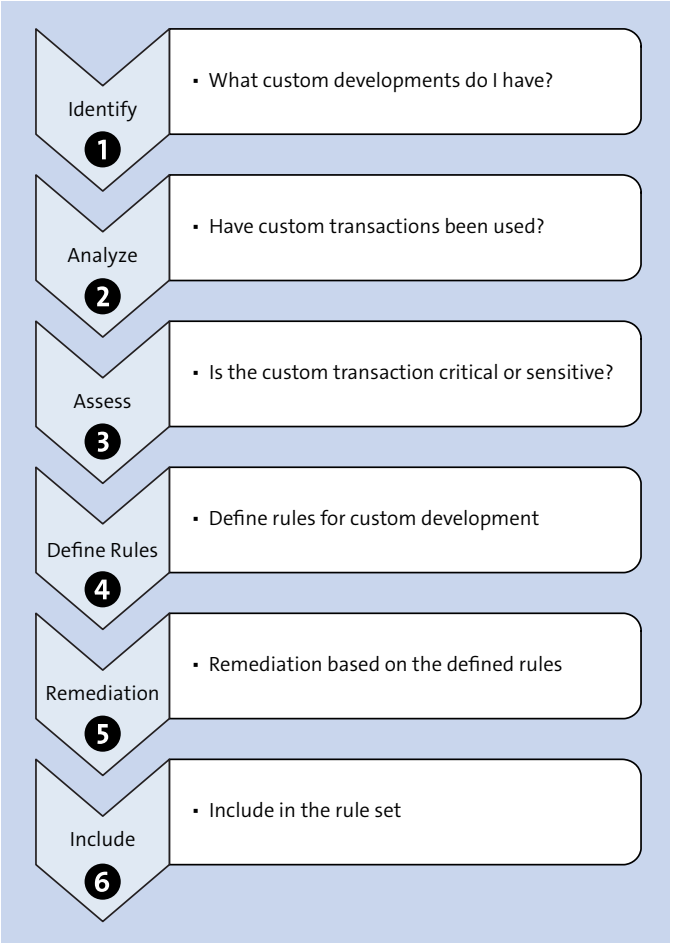


Figure 10.13 How to Approach Custom Developments

To add a custom transaction to the ruleset, follow these steps:

❶ **Identify**
As a first step, you'll identify what custom developments are available in your system by using Transactions SE38, SE80, SE93, etc. Also, you could check table TSTCT to see which transactions exist in your customer namespace.

❷ **Analyze**
Analyze which custom transactions have actually been used. You can check the workload of an SAP system in Transaction ST03N or view the Action Usage report in SAP Access Control. Try to identify who owns each custom transaction in case you have any questions.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

With newer releases, SAP may have introduced a new functionality that covers a requirement that was previously only available with a custom development. In this case, you should consider going back to SAP standard.

❸ **Assess**

Only assess custom transactions that are in use to save yourself a lot of work. Try to understand what a custom transaction does and assess whether it's critical/sensitive and must be considered for the ruleset.

To understand and assess these transactions you have two options. You can either talk to the owner/functional consultant who represents the custom transaction or talk to a developer to perform a technical analysis. Both options are time consuming.

Make use of code scanners to see what a transaction does. You can use report RS_ABAP_SOURCE_SCAN or tools like Xiting ABAP Alchemist, which is part of the Xiting Authorizations Management Suite (XAMS). These tools can speed up your analysis and allows for efficient assessment.

❹ **Define rules**

An imperative step is to define rules for custom development. A few examples of rules include the following:

- Define security requirements for custom developments.
- ABAP code must perform an authority check.
- Dialog programs must only be available through custom transactions.
- Maintenance of Transaction SU24.
- Define naming conventions for simple identification of developments (e.g., names for display-only reports versus names for update/modify reports, etc.).
- Establish automated ABAP source code scans, such as the code inspector, vulnerability scanner, and Xiting ABAP Alchemist.
- Define security gates and change management processes for transports
- Define authorization principles
- Avoid authorization to Transactions SE38, SA38, etc. for generic report/program access or to Transactions SE16, SE16N, SM30, etc. for generic table access; instead, use parameter transactions.
- Always authorize transactions through the role menu in Transaction PFCG for proper and sustainable role building.

❺ **Remediate**

Start by dealing with unused custom transactions. We recommend removing them from all roles, but you can leave them in the system and not delete them for now.

Next, maintain Transaction SU24 proposals for sustainable authorization maintenance. Remove code that does not belong to a program.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Make sure that direct table access is protected with an authorization check. To access SAP standard tables, check for the use of an SAP-provided application programming interface (API). APIs often come with the required authorization checks. In addition, the upgradability of your code is ensured when table structure changes.

❻ **Include**
Include sensitive and critical transactions in your ruleset. Build and test the rules similarly to SAP standard rules.

10.5.2 Enhanced Analysis with Xiting ABAP Alchemist

Xiting ABAP Alchemist, part of XAMS, offers a unique approach to scanning and analyzing custom developments. Xiting ABAP Alchemist allows you to scan custom developments en masse and will detect missing authorizations as well as evaluate existing authorization checks in your custom code. By following the call stack, Xiting ABAP Alchemist can detect authorization checks (or missing ones) several levels down, which you might never get to manually.

With unique features to find missing and existing authorization checks, you can speed up the assessment of your custom transactions. In addition, Xiting ABAP Alchemist allows you to propose missing and existing authorizations into Transaction SU24.

Figure 10.14 shows an example of a scan result by Xiting ABAP Alchemist on a custom transaction. In this example, the custom transaction was built to delete user masters.

Object	Message text	Message Variable
DEFAULT@ZDELETEUSER<--1-->11	Database access found, access type DELETE, table(s) USR02	DELETE
DEFAULT@ZDELETEUSER<--1-->11	Consider using a stable API (Function BAPI_USER_DELETE) instead of the direct access to tabl	(Function BAPI_USER_DELETE)
DEFAULT@ZDELETEUSER<--1-->11	Change operation DELETE on SAP standard table USR02 in the customer namespace	DELETE
DEFAULT@ZDELETEUSER<--1-->11	Access to tab. USR02 should be protected with auth-check S_USER_GRP, check not found	USR02

Figure 10.14 Scan Results in Xiting ABAP Alchemist

Notice that the custom transaction performs direct table access on table `USR02` with type `DELETE`. Xiting ABAP Alchemist shows that, instead of writing our own code, we should consider using a stable API (in this example, BAPI_USER_DELETE). In addition, notice also that table access to table `USR02` should be protected with authorization object S_USER_GRP, which is the standard object for protecting user master data and often used for transactions like Transaction SU01.

Since the authorization check on S_USER_GRP was not found, Xiting ABAP Alchemist will tell you what you should implement. Also, you can consider missing authorizations for Transaction SU24 with a semi-automated update functionality, shown, for example, in Figure 10.15.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Ty.	Name	Authorization Object	Authorization Field	Authorization Value	Object	Field	Value	SU24	Update	Upd. obj.
TR	ZDELETEUSER	S_USER_GRP	CLASS							
TR	ZDELETEUSER	S_USER_GRP	ACTVT	03						
TR	ZDELETEUSER	S_USER_GRP	CLASS							
TR	ZDELETEUSER	S_USER_GRP	ACTVT							

Figure 10.15 Missing Authorization Checks in Xiting ABAP Alchemist

Updating Transaction SU24 is important because, when building roles, you can easily incorporate the proper proposals. In addition, and more importantly, XAMS allows you to run a risk analysis against your Transaction SU24 data for transactions. With this feature, you can analyze whether a transaction should be considered for the ruleset in SAP Access Control. In addition, Transaction SU24 data is synchronized with the authorization sync job in SAP Access Control, which populates the proposals when building access rules. As shown in Figure 10.16, authorization object **S_USER_GRP** with activity **06** (Delete) is proposed.

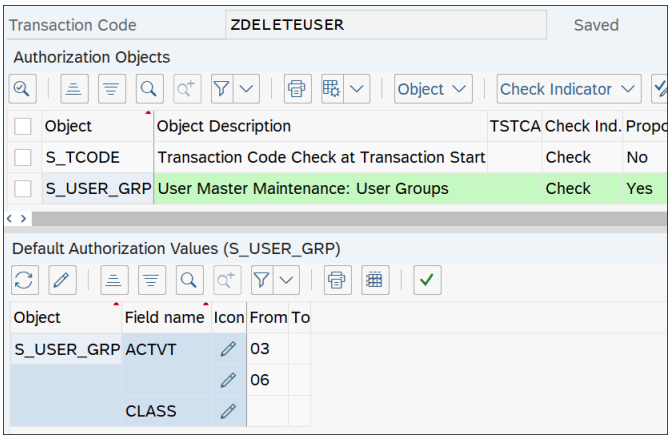


Figure 10.16 Transaction SU24 for Custom Transaction ZDELETEUSER

With XAMS, you can analyze what functionality a custom transaction provides based on the proposal values in Transaction SU24. This analysis is executed against the proposals from Transaction SU24 and carried out on the authorization level of functions. Figure 10.17 shows an example of a critical authorization risk.

Figure 10.17 Example Conflict in the Custom Transaction ZDELEUSER

Personal Copy for Arun Singal, arun.singal560@gmail.com

Notice that Transaction **ZDELETEUSER** has a conflict with the authorization ID **/XITING/BC_ADM2**. The authorization ID is equivalent to the function in SAP Access Control.

With this approach, you can analyze your custom transactions en masse, update existing as well as missing authorization checks in Transaction SU24, and then (based on this analysis) determine whether a transaction should be considered for the ruleset. Missing authorizations and failed authorization checks also serve as a worklist for developers to engage in remediation.

10.6 Business Roles

Business roles serve as containers in SAP Access Control to simplify the provisioning of access across multiple systems. Often, organizations map business roles based on a job function to allow end users to pick the role based on their jobs.

The biggest challenge for an organization is staying in compliance in an environment of constant access changes. Using SAP Access Control, business roles can specify the access necessary for a function or a process the user is involved with, thus helping you better manage changes to access. Once business roles have been mapped with the appropriate job tasks, organizations can more easily control compliance or business risk by running their rules against the requests.

Each business role represents a job function and thus contains one or more technical roles, possibly across different systems and landscapes. For example, a business role for a purchaser might contain a technical role from the SAP S/4HANA system, which grants access to transactions like Transactions ME21N/ME22N/ME23N; a technical role from SAP Fiori to use purchasing applications; and also a technical role from SAP Ariba. Instead of requesting three roles, for example, an end user can simply request the purchaser business role, and SAP Access Control will provision the underlying technical roles that exist in multiple systems. Figure 10.18 shows the systematic architecture of the business role.

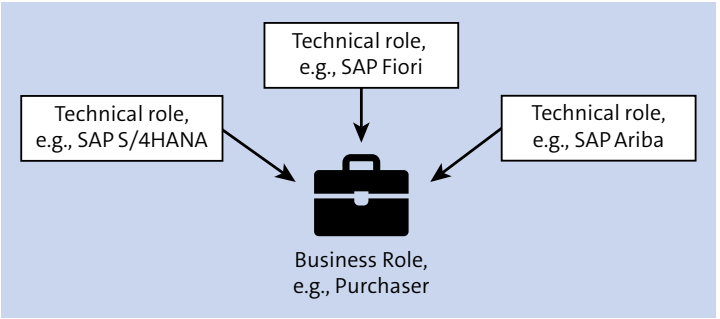


Figure 10.18 Example of a Business Role in SAP Access Control

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Business roles are system independent. When you create a business role, two technical roles (one for system A and one for system B) might be involved. When this business role is assigned to a user (having two technical roles from two different systems), you won't need to select the system for the business role itself. The request will automatically take both technical roles from both systems.

The following recommendations should be followed to avoid inconsistencies in your repository of roles if business role provisioning is being used:

- Never remove/assign roles directly in target systems: Roles should be provisioned via access request only. Business role definition is available in GRC only, but the target system is not aware of this fact. So, if some role assignment/removal is performed directly in a target system, then the information saved in SAP Access Control repository will not be consistent.
- Never delete a user account directly from a backend system: User accounts should be deleted via an access request only, and if possible, you should delete the user from all the systems together rather than deleting the user from individual systems. While creating an access request, you can select all the systems present in an existing assignment and request to delete user from all of them. If the user is deleted from individual systems, then when you would run a repository sync job so that the business role assignment of the user is deleted from the repository and all the roles that were assigned via the business role will appear as though they were assigned as single roles.
- Retaining a provisioning action is not supported in business roles: With SAP Access Control 10.1 SP 8 retaining provisioning actions is not supported for business role due to complexity involved in different scenarios. For later support packages, refer to SAP Note 2109358.
- Never run compression reports (like report PRGN_COMPRESS_TIMES) in a target system: As in the first point, if this report is executed, user assignments are compressed in the backend system, but the repository still has old assignment data.
- Use configuration parameter `4019` to ensure consistency in your repository: This parameter has been created specifically for businesses using business role provisioning. This parameter is useful for maintaining consistency in your repository.
- Don't execute user sync for an SAP Enterprise Portal system if portal roles are part of a business role: The roles/groups assigned in the portal won't have a validity date assigned. When the user sync job for portal is executed, the system deletes all the validity dates that are maintained in the repository corresponding to portal roles. This fact causes problems only if portal roles are part of business roles.
- Don't use indirect provisioning with a business role: Doing so will cause inconsistencies since the business role's relationship with its HR position/job/organizational unit is not maintained.

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Don't use single roles with the same name but a different landscape within a business role: Doing so will cause inconsistencies when fetching a business role's history, resulting in incorrect provisioning.

BRM in SAP Access Control allows you to update organizational values in derived roles. You can this functionality to push updates of an organizational field's values to multiple derived roles.

To change the authorization data in derived roles, you must propagate this new authorization data from the master role. To change the organizational values of derived roles, you must open and change the value for each derived role. This feature allows you to use organizational value maps to update values for multiple roles at one time.

10.7 User Access Review

Many businesses must adhere to certain compliance regulations like SOX and thus require processes in place to periodically review user access. Each role assigned to a user must be reviewed following policy. For example, many organizations review all SAP access once a year and review critical access quarterly, but your schedule depends on your compliance regulations and can vary.

The UAR feature provides a workflow-based review and approval process for user access requests. Periodic reviews of user access are performed by business managers or role owners, and the system automatically generates the necessary access requests based on the company's internal control policy. The review assesses the roles assigned to users and the frequency with which the user uses that role.

In the UAR process, the following key users included:

- Access risk analysis administrator: This person has an admin role assigned for SAP Access Control. The administrator can perform UAR-specific administrator tasks, such as cancelling UAR requests and regenerating requests for rejected users. An admin can review an access request before generating the workflow to fulfill that request.
- Reviewer: This term refers to the approver at the reviewer stage. The reviewer may be the user's manager or the role owner:
  - User's Manager: The direct manager of a user as defined in the `User Details Data Source` table.
  - Role Owner: The role owner specified in BRM master data.
- Coordinator: The coordinator is assigned to a reviewer. The coordinator monitors the UAR process and coordinates activities to ensure the process is completed in a timely manner.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

By default, the workflow is a one-step workflow in which either the user's manager or the role owner performs the review. For example, if the reviewer is the manager, then the manager will receive a workflow for all his subordinates with the assigned access. If the reviewer is the role owner, then the role owner will receive a workflow for all roles owned with the users assigned to it. In either scenario, the reviewer reviews the assigned access and decides whether access should be retained or removed.

Since reviewing all access may result in large and unmanageable workflows, SAP Access Control allows you to select roles based on various filter criteria. The most commonly used filter criteria include functional area, role sensitivity, role name, or other custom attributes maintained in your roles.

As mentioned earlier, many businesses must prove they review all access annually, but critical access should be reviewed more frequently. Therefore, the ability to filter the roles that require more frequent reviews is necessary, and we recommend using existing role attributes (e.g., role sensitivity) for this process.

10.8 Roles for Firefighters

The purpose of the EAM, or often referred to as firefighting, is to allow users to temporarily take responsibility for tasks outside their normal job functions. This component allows temporary access to be granted to certain users tasked with solving a problem and gives them provisionally broad, but still regulated, access that is monitored and recorded in the application.

SAP Access Control's firefighting capabilities offer a number of advantages for the management of emergency access, including the following:

- Mitigates the most common open audit issues faced by virtually every company (e.g., with profiles SAP_ALL and SAP_NEW)
- Eliminates emergency phone calls to approve access outside of normal business hours
- Tracks and logs transaction code usage and changes made within the firefighting session
- Allows you to provide defined authorizations with validity dates
- Sends email notifications of emergency access logons immediately to defined controllers
- Generates auditable reporting logs

This section will help you understand when to use firefighters and provide an overview of common firefighter types and provisioning strategies.

Personal Copy for Arun Singal, arun.singal560@gmail.com

10.8.1 Defining Appropriate Usage

Firefighters are often used as a form of remediation/mitigation for SoD. This section focuses on firefighting in emergency situations rather than on mitigating critical access. In either scenario, you must define what is appropriate versus inappropriate use of the firefighter. Only if you understand the intention of the firefighter are you able to build proper roles.

Appropriate usage of EAM includes the following activities:

- Emergency changes required in a productive environment
- Sensitive transactions not available via end-user security roles
- SOX-sensitive and restricted transactions
- Infrequent and sensitive tasks (e.g., opening and closing of posting periods)
- Cutover activities

Inappropriate usage of EAM includes the following activities:

- Daily business tasks performed by support users (e.g., creating purchase orders, etc.)
- Non-sensitive tasks available via security roles (e.g., display access)
- Displaying sensitive reports
- Using EAM as a crutch to support a bad security design

Excessive usage represents one of the largest issues that arise with firefighting. Frequently, firefighters are used as crutches to prop up an otherwise poor security role concept. End users tend to rely on their firefighter access instead of using their regular access given to their personal user ID. Simple table display (e.g., Transaction SE16) and daily activities supporting business tasks are both examples of inappropriate usage seen in several companies. The high volume of use generates longer logs, requiring more system resources, and more time to review. As a result, logs are not reviewed in detail, and firefighters cannot be relied on as a security control. It is important that the concept of firefighting is defined properly as excessive usage might cause real danger to your organization as fraudulent actions might remain undetected due to the high volume of logs. Inappropriate usage could be eliminated with a proper provisioning strategy, and the proper type of firefighting, as well as a proper authorization concept defined by your Basis or security team.

Furthermore, you must correctly assess the role design of the firefighter roles, which impacts the size of the logs. Firefighter logs do not differentiate between display and change, and thus, SAP Access Control collects all information that is logged, which means the log file can become overwhelming for a controller to review.

Tip

Instead of using firefighter, if you're on SAP NetWeaver 7.40 or higher, you could configure Read Access Logging (RAL) to monitor and log read access to sensitive data.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

10.8.2 Firefighter Types

SAP Access Control offers two types of firefighting—ID-based firefighting and role-based firefighting. Only one type can be configured at a given time. In SAP Cloud Identity Access Governance, only ID-based firefighting is available.

Some differences between each firefighter type include the following:

- **ID-based firefighter**
  With ID-based firefighters, each firefighter ID has its own user master record with roles assigned directly to the firefighter ID, as shown in Figure 10.19. The end user (firefighter) executes a transaction code and checks out an ID. Multiple users can check out firefighter IDs (which are assigned to end users via roles), but only one user can have any one firefighter ID checked out at any given time. A reason code and the expected activity must be documented prior to gaining firefighter access. Relevant changes in SAP are captured in the change history under the firefighter ID. It is important to highlight that changes are documented with the firefighter ID and not the user's normal user ID.

Figure 10.19 ID-Based Firefighter

- **Role-based firefighter**
  With role-based firefighters, you can define a role as a firefighter role and then assign the firefighter role directly to a user, as shown in Figure 10.20. You can make the assignment through ARM, if in place, or directly in the backend system through Transaction SU01 or equivalent. To use the firefighter role, a user doesn't have to check out a separate ID (like in the ID-based scenario). Transactions and change histories are logged with the user's own ID, which has some advantages over ID-based firefighters. On the other hand, these end users are not always aware when they are utilizing emergency/firefighter access since checking out an ID is not required and the user's own user ID is logged at all times.

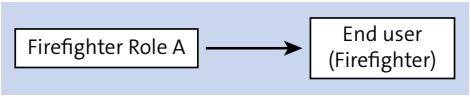


Figure 10.20 Role-Based Firefighter

As mentioned earlier, you can only use one of these scenarios at a given time, and therefore, understanding their capabilities and their differences is vital. Table 10.2 provides an overview of the main functionality and indicates whether the functionality is available in the respective firefighting type.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Functionality	ID Based	Role Based
Ability to grant user additional access	X	X
Firefighting activities logged	X	X
Integration with SAP Access Control ARM workflows for assignment	X	X
Integration with log review processes (e.g., workflows)	X	X
Utilizing existing user ID		X
Firefighter logs onto multiple clients	X	X
Required to document reason for using firefighter	X	
Notification upon usage	X	
Notification after session is complete	X	X

Table 10.2 Comparison of Firefighting Types

10.8.3 Provisioning Strategies for Firefighters

SAP Access Control's EAM capability allows two provisioning strategies since firefighter ID access is not always readily available and their usage must be checked out.

Some users are preapproved for specific firefighter IDs and can have preassigned access in SAP Access Control. When a firefighter ID is checked out, the application sends a notification to the controller whenever the firefighter logs onto a system (parameter 4008). Additionally, the controller is informed when the log report is available (parameter 4007), and the controller's responsibility is to confirm that the actions taken were appropriate. An application sends a notification either as an email or a workflow item to the controller (as controlled by the notification settings in the firefighter ID assignment).

On the contrary, a user must request access to EAM before the firefighter ID can be used. Access can be requested in ARM. The super user access request type is available to automate provisioning access to firefighter IDs via workflow in ARM.

Both strategies have advantages as well as disadvantages. Having preapproved firefighters means that the necessary IDs are available at any time, and emergency activities can be provided immediately (e.g., during the weekend), and a critical task might be to investigate fraudulent activities. If a user must request access to EAM, emergency access might be delayed because an approval from the controller is required before usage. In case of an emergency (especially during the weekend), a controller might not be available, and thus work will stall.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

10.9 Impact to Governance, Risk, and Compliance When Migrating and Upgrading SAP Systems

Every upgrade or migration involving your SAP systems requires that you to analyze the impact from a governance perspective. For example, migrating to SAP S/4HANA or implementing SAP Fiori brings new functionalities that are SOX-/SoD-relevant and thus must be considered in your rulesets. Not updating your rulesets can lead to false negatives when analyzing access risks, which results in non-compliance. Therefore, whenever you touch an SOX-/SoD-relevant system, you must assess the impact the change will have to SAP Access Control and/or SAP Cloud Identity Access Governance. If new functionality is being added (e.g., upgrade or developments), you must understand the capabilities of that new functionality and whether it should be included as a critical action/critical permission or if the function must be assessed from an SoD perspective.

Many businesses are currently in the process of moving to SAP S/4HANA or have recently migrated. With SAP S/4HANA, the new architecture must be integrated into your existing SAP Access Control and SAP Cloud Identity Access Governance environment, including user provisioning, risk analysis, and emergency access for SAP HANA databases and for the SAP Fiori gateway system (frontend server). As of SAP Access Control 10.1, the ability to perform risk analysis, conduct user provisioning, and provide emergency access has been available for SAP HANA databases. SAP Fiori—whether as a frontend or backend server—is an SAP NetWeaver system, which is also fully supported.

With the new architecture of SAP HANA and SAP Fiori, your end users will require additional access in those systems. Therefore, you must enable the user provisioning functionality as well as conduct risk analysis. In these scenarios, not only do you need to analyze access in one system, but cross-system access as well. For example, suppose we have the job function "purchaser" in an SAP S/4HANA environment. This purchaser needs access to various functions that include sourcing, contracts management, reports, dashboards, etc. To access all these different functions, the purchaser requires access to transactions in the SAP S/4HANA backend system (for example, Transactions ME21N, ME22N, ME23N, etc.) and also requires dashboards and reports in SAP Fiori that themselves require access to specific tables and views in the SAP HANA database. Therefore, for the user to properly access all these applications, access must be set up in SAP S/4HANA, in SAP Fiori, and in the SAP HANA database.

With the transition to SAP S/4HANA and the implementation of SAP Fiori, your existing SAP Access Control version must be at least release 10.1, but we recommend upgrading to SAP Access Control 12.0 since mainstream maintenance for release 10.1 has already ended.

Personal Copy for Arun Singal, arun.singal560@gmail.com

In addition, the following considerations are important to keep in mind:

- Include and set up new connectors for the SAP HANA database as well as for SAP Fiori Gateway (frontend server).
- Make sure that these new connectors are properly configured in your workflow so that they follow the respective process.
- Implement and adjust your ruleset. Utilize the provided BC sets:
  - For SAP HANA, use GRAC_RA_RULESET_SAP_HANA
  - For SAP Fiori Gateway, use GRAC_RA_RULESET_S4HANA_FIORI
  - For the SAP S/4HANA core, use GRAC_RA_RULESET_S4HANA_CORE
  - For SAP S/4HANA with embedded gateway, use GRAC_RA_RULESET_S4HANA_CORE
- Import roles and make them available for provisioning.
- Set up emergency access to SAP HANA as well as to SAP Gateway.
- With a migration to SAP S/4HANA, your role design and architecture will change. Thus, you must ensure that your GRC solutions are updated accordingly to reflect those changes. Plan upgrades as part of the migration approach—as often this topic is often forgotten.

10.10 Summary

As a security administrator, you'll need a general understanding of GRC functionalities and how you can manage your day-to-day role management tasks. For example, role changes could lead to sensitive access or SoD violations, which result in poor audit findings, if not addressed properly in a timely manner. You'll work closely with your compliance team to remediate authorization-related audit findings. Understanding the available tools and how to use them is imperative. SAP Access Control and SAP Cloud Identity Access Governance are both tools to help govern access across your entire SAP landscape. Integrating these tools into your daily routine not only enables you to ensure a compliant authorization design, but also allows you to work more efficiently.

In the next chapter, we'll discuss interface security.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 11

Interface Authorizations and Hardening of Interfaces

In the age of digitalization and the need to be digitally connected, SAP systems allow interconnectivity to other SAP systems as well as non-SAP systems. The communication to and from SAP systems follow an authorization concept that is important to be considered in any landscape as attackers can compromise your environment. In this chapter, we'll outline the most important aspects of interface security and what you should know to ensure a certain level of security.

In the old days of SAP, the enterprise resource planning (ERP) solution followed a straightforward implementation with development (DEV), quality (QAS), and productive (PRD) systems with little to no interfaces with other systems. Over the years, and especially recently, integrations of all sorts have become increasingly important. Not only must you integrate various SAP systems, whether ABAP based or not, but also non-SAP systems that may be hosted on-premise or in the cloud. The importance of cloud applications, and especially software as a service (SaaS) solutions, require integrations into core applications like SAP ERP and SAP S/4HANA.

ABAP systems communicate through the remote function call (RFC) protocol whereas cloud applications utilize REST application programming interfaces (APIs), RESTful APIs, or the OData protocol. SAP Fiori applications, whether on-premise or in the cloud, consume OData services and require specific authorizations to process data. Web Services are another form of interface most often seen and used by various business running SAP.

With new technologies, new ways to connect and secure interfaces are required. This chapter provides an overview of the proprietary RFC protocol as well as describes how interfaces in general should be treated and secured.

11.1 Remote Function Call Security

RFC is a proprietary protocol from SAP that allows business applications to communicate and exchange information. The communication and exchange of information follow a predefined format. Typically, an RFC calls a function module in a remote system

Personal Copy for Arun Singal, arun.singal560@gmail.com

(which is different than the calling system). However, you can also call a function module that is the local system by an RFC.

This section provides an overview of several RFC-related topics, including trusted and untrusted RFCs, common challenges and risks, authorization objects for securing remote connections, RFC callback whitelisting, and RFC connections with logon data.

11.1.1 Overview

In practice, various reasons exist for using RFC calls, and the following list summarizes the most common uses):

- For communication between two logical systems
- For communication within a single system, but through clients
- As a user switch through an RFC call
- To enable parallel processing for improved performance within a system
- To enable asynchronous calls where the calling system waits for the recipient to answer

Hint

A logical system is a client of a system and represents the lowest standalone unit of user authentication.

In an SAP system, the RFC interface system provides functionality that enables function calls between two logical systems (e.g., SAP and SAP, or SAP and non-SAP). Therefore, the RFC interface system consists of two interfaces):

- **Calling interface for ABAP programs**
  Each ABAP program can call a remote function module using the command `CALL FUNCTION... DESTINATION`. The parameter `DESTINATION` informs the SAP system that the called function module runs in a different logical system to the calling system. RFC communication with the remote system takes place as a part of the `CALL FUNCTION` command.

  RFC function modules in an SAP system must be real function modules and must be registered as remote enabled in the SAP system.

  If the calling program and the called program are both ABAP programs, the RFC interface provides both communication partners. The calling program can be any ABAP program. The called program must be a function module that is registered as remote enabled.
- **Calling interface for non-SAP programs**
  If either the calling program or the called partner is not an SAP program, the

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

program in question must be programmed in such a way that it can play the role of the other partner in an RFC communication.

The destinations that can be used in RFCs are defined in Transaction SM59 and stored in table RFCDES.

Hint

Typical examples of a non-SAP program is the .NET connector for Microsoft, the Java connector, or the C++ connector. Note that, even if these programs are not used, you should secure your systems as though they are because they can easily be used by a malicious person accessing your system. A laptop inside your company's network is all that is required to use these connectors against your SAP systems simply by knowing the standard SAP functions and their weaknesses.

11.1.2 Trusted and Untrusted Remote Function Calls

To mitigate the risk of storing logon information in an RFC destination, you can establish a trust relationship between the calling system and the called system. In this case, the called system accepts the user as authenticated from dedicated calling systems, known as *trusted systems*). In other words, the called system trusts the authentication process of the calling system. No password is needed to access the destination from the trusted system. Since you can also map individual users and their authorizations between the two systems, therefore, you can control a user's authorizations in the trusting target system. Unlike situations where service users are used, log files will provide information about precisely which user accessed the target system and what actions they performed there. Otherwise, the actions of the users in remote systems would have been mapped to the user name of the connection user and therefore not detailed enough and auditable.

In some scenarios, you can and will want to keep a user's identity consistent across system boundaries using a trust relationship; in other scenarios, using a connection user is the correct approach.

Let's look at some examples:

- A salesperson works on sales documents in an SAP ERP system as well as in an SAP Customer Relationship Management (SAP CRM) system. The two systems are connected together via an RFC scenario for the salesperson to complete his tasks without being slowed down by system boundaries. This one process carried out by a specific user is useful, even important, to keep the users' actions bound together by a single user name in both systems.
- A list of materials is needed both in an SAP ERP system and an SAP CRM system. Users maintain the material data in SAP ERP, and SAP ERP remembers who changed which attributes of the materials, but SAP CRM only needs to have the same material

Personal Copy for Arun Singal, arun.singal560@gmail.com

data. The change logs are not needed in SAP CRM. Therefore, a technical user carries out the synchronization of the material master data and the individual user actions cannot be seen in the SAP CRM version of the master data.

11.1.3 Challenges and Risks with Remote System Connections

With the urgent demand for digitalization and the booming supply of Internet of Things (IoT) devices, every business faces demands for connectivity to provide uninterrupted services. A surge in the need for connectivity often leads to security risks due to the high complexity of hybrid landscapes and the lack of an easy overview of all your interfaces, which poses a major threat to your overall cybersecurity.

Figure 11.1 shows a simple overview of several SAP systems connected in a typical implementation. Most businesses will run a "core" ERP system (SAP ERP or S/4HANA) that is connected to at least SAP Solution Manager, the central user administration (CUA), a governance, risk, and compliance solution like SAP Access Control, and other business applications that require data from the "core" ERP like SAP BusinessObjects Business Intelligence (SAP BusinessObjects BI), SAP CRM, SAP Supplier Relationship Management (SAP SRM), and SAP ERP Human Capital Management (SAP ERP HCM) systems. The connectivity between the SAP systems is based on RFC, which allows for data to be exchanged.

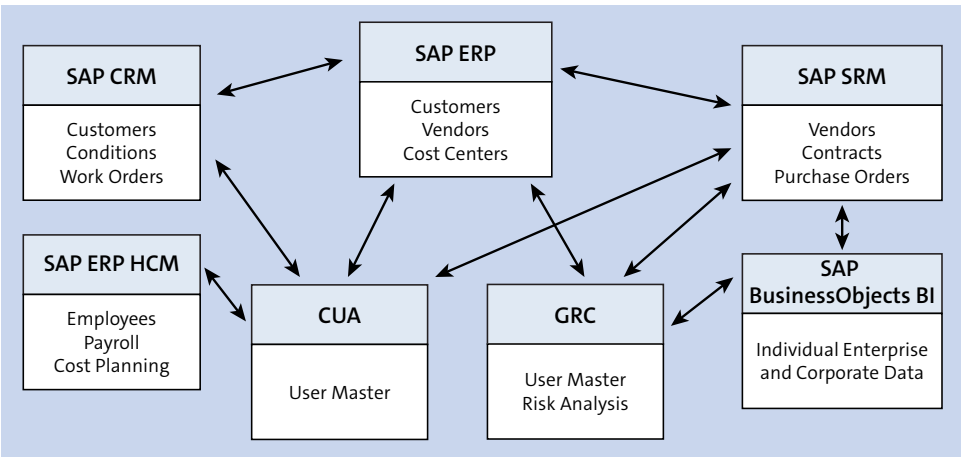


Figure 11.1 RFC Challenges

Not only do you have multiple different systems, as shown in Figure 11.1, these systems all require interfaces, also within this one landscape, as shown in Figure 11.2. Every SAP system has multiple system layers (DEV, QA, PRD) probably with multiple clients (000, 066, etc.). Most of these systems and clients require interfaces for various purposes, perhaps even for simple tasks like using CUA to provision users across the landscape. All these interfaces also pose potential threats if not secured properly.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

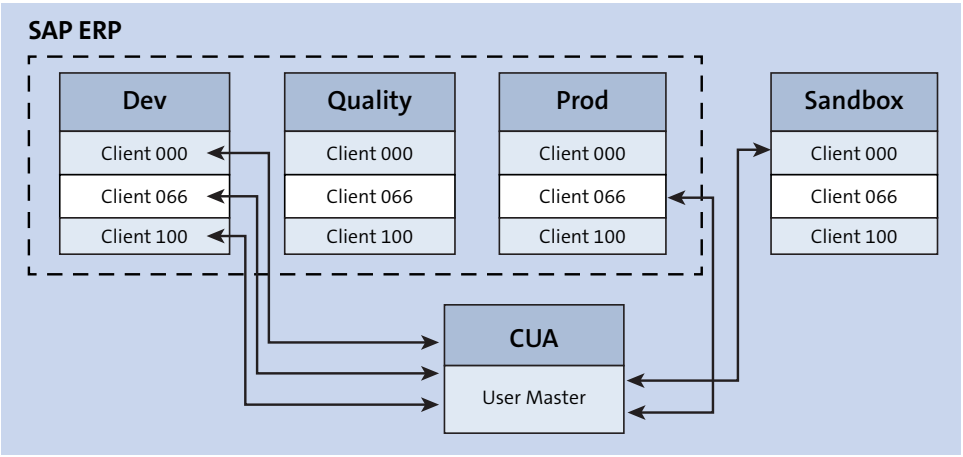


Figure 11.2 Interface Examples with SAP ERP

When you grant access across system boundaries, however, a certain element of risk is always involved. In the case of RFC connection, two primary vulnerabilities) exist:

- Logon data stored for system users in the RFC destination
- Reliance on authorizations to repel any potential attack

Depending on the type of application and use case, you either need to configure a service user for the RFC destination in your calling system, or you must ensure that the appropriate user information is forwarded—and these users must be assigned to appropriate authorizations.

11.1.4 Authorization Objects to Secure Your Remote Connections

To securely authorize RFC connections with your authorization concept, you must understand three authorization objects: S_ICF, S_RFCACL, and S_RFC. Each of these three authorization objects is critical and must be properly configured, which we'll look at next:

- **S_ICF**
  The S_ICF object is optional and only checked when a value is maintained in Transaction SM59. If an SAP system wants to establish an RFC connection to another SAP system, S_ICF is carried out in the calling system/client to determine whether the user is allowed to call function modules using the RFC destination. This object could be found in the authorization profile of the user who is logged on to the calling system. The user can use only the RFC destinations that are configured in the S_ICF object.
- **S_RFCACL**
  When using trusted RFCs, the authorization object S_RFCACL is used on the server

Personal Copy for Arun Singal, arun.singal560@gmail.com

side (the target system) to determine whether the user logged on to the client is permitted to access the server.

- **S_RFC**
  Since restricting access on a system level is not sufficient, an important task is to define which function modules can be accessed remotely. This access is controlled by authorization object S_RFC. The S_RFC object controls which specific RFC functions in the target system can be executed by a user. The S_RFC object is the most important authorization object to protect the target system since S_ICF works only on the client system and S_RFCACL is used only in the case of trusted RFC. In either scenario, S_RFC is always used and protects the server system at all times.

Tip

Maximal granularity of the access is advised for RFC authorizations. Never use asterisk (*) for the object fields. Use the standard behavior of the role menu in Transaction PFCG, which automatically generates granular S_RFC object data from the list of function modules added to the role menu.

Table 11.1 provides a better understanding of the three authorization objects) and how they are used.

Authorization Object	Description	Used for
S_ICF	Authorization check in the client system used to determine whether the logged-on user is permitted to use the RFC destination to call function modules by RFC	To connect an SAP system to another SAP system
S_RFCACL	Authorization check in the server system used to determine whether the logged-on user in the client system can log on to the server system with the desired user ID	Trusted RFC systems are in place
S_RFC	Authorization check in the server system used to determine whether the user can execute the RFC function module in the target system	To determine which function modules can be accessed remotely

Table 11.1 Authorization Objects for Secure RFC Connections

The authorization check for object S_RFC is influenced by the profile parameter `auth/rfc_authority_check`. Depending on the setting of the profile parameter, the S_RFC check can either be deactivated (when value = 0) altogether or set more restrictively.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Table 11.2 outlines the details of the possible values. SAP recommends you use value 6 (see SAP Note 2216306).

Value	Description
0	Logon required but no authorization check.
1	Logon and authorization check required. All function modules of the function group SRFC are executed without a logon and without an authorization check, too. In the case of an RFC logon in the same system with the same user and client, no authorization check is executed.
2 (obsolete)	Logon and authorization check required, but not for the function group SRFC. All function modules of the function group SRFC are executed without a logon and without an authorization check.
3	Logon and authorization check required for all function modules except `RFC_PING` and `RFC_SYSTEM_INFO`. No authorization check takes place for the function module `SRCC_GET_CODE_COMPLETION` if called from SAP GUI.
4	Logon and authorization check required, but not for the function modules `RFC_PING` and `RFC_SYSTEM_INFO`. The function modules `RFC_PING` and `RFC_SYSTEM_INFO` are executed without a logon and without an authorization check. In the case of an RFC logon in the same system with the same user and client, no authorization check is executed.
5	Logon and authorization check required for all function modules except `RFC_PING`. No authorization check takes place for the function module `SRCC_GET_CODE_COMPLETION` if called from SAP GUI.
6 (recommended value)	Logon and authorization check required, but not for the function module `RFC_PING`. The function module `RFC_PING` is executed without a logon and without an authorization check. In the case of an RFC logon in the same system with the same user and client, no authorization check is executed.
8	Logon required for all function modules; authorization check required for all function modules except `SRCC_GET_CODE_COMPLETION` if called from SAP GUI.
9	Logon and authorization check required for all function modules.

Table 11.2 Possible Values of Profile Parameter auth/rfc_authority_check

Before you switch your profile parameter, always ensure that the RFC users have the required authorizations.

Personal Copy for Arun Singal, arun.singal560@gmail.com

SAP Note

More and updated information regarding profile parameter `auth/rfc_authority_check` can be found in SAP Note 2216306 - S_RFC check and profile parameter `auth/rfc_authority_check`.

11.1.5 Remote Function Call Callback Whitelisting

With Basis version release 740, and later downported to ABAP 731 with kernel 7.21, support pack (SP) 321, SAP has introduced a whitelist for callbacks) for each RFC destination. RFC callbacks are considered dangerous as an attacker could utilize RFC callbacks to attack your SAP system. The RFC callback check security feature is shown in Transaction SM59. You'll either see the message **RFC callback check secure** with green traffic lights, as shown in Figure 11.3, or **RFC callback check not secure** with red traffic lights.

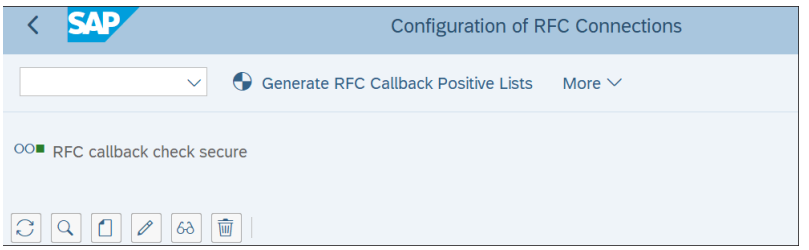


Figure 11.3 RFC Callback Check Secure Message in Transaction SM59

Technically, RFC callbacks are possible due to the ABAP statement `CALL FUNCTION`, which allows the firing back of RFC function modules to the sending system. These RFCs are then executed in the originating system under the user credentials of the original caller. As a result, if the target system is compromised, a callback to the non-compromised system can occur. For example, if an attacker gains access to any system that is connected to a PRD system and modifies a function module that is called from the PRD, the compromised function module will fire back an RFC call to the originating system.

A simple example is shown in Figure 11.4 where an attacker gains access to a PRD after compromising a remote system. In this example, the attacker can access one system and modify the function module `RFC_PING` so that, when executed, it fires back two function modules to create a user (`BAPI_USER_CREATE1`) and assign profiles (`BAPI_USER_PROFILES_ASSIGN`). When executed, a new user account is created, and the profile SAP_ALL is assigned in the PRD. In addition, in the changelog of the PRD, you'll see the user has been created under the name of the administrator who originally executed the connection test to the compromised system.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

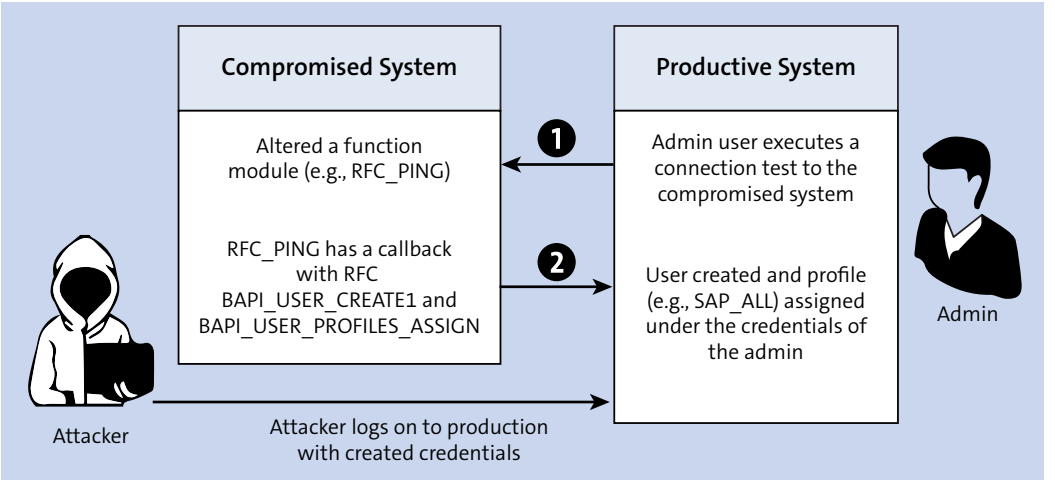


Figure 11.4 RFC Callback Attack Example

To counter these kinds of attacks, the RFC callback security functionality is critical. The profile parameter `rfc/callback_security_method` determines the behavior of the RFC callback, as shown in Table 11.3.

Value	Description
1 (default value)	Callback security is deactivated.
2	Simulation active. In this setting, RFC callbacks are allowed but recorded in the Security Audit Log (SAL). This option is recommended for tracking and recording which callbacks are required.
3	RFC callback security is active, and only whitelisted RFC callbacks are allowed. All other callbacks are intercepted and will not be allowed.

Table 11.3 RFC Callback Security Settings

Tip

RFC callback is only supported during synchronous RFC. When using other types of RFCs, for example, asynchronous, transactional, or background RFCs, the RFC callback security feature is not supported.

If you're not using RFC callback security) today, we recommend switching on the simulation mode (value = 2) first, so that you can record the required function modules that utilize callbacks. RFC callbacks are required in some cases, and activating the check without enabling the whitelist can result in process interruptions.

Personal Copy for Arun Singal, arun.singal560@gmail.com

If you have the simulation mode enabled, the system will record callbacks in the SAL. Transaction SM59 allows you to generate an RFC callback positive list (click **Generate RFC Callback Positive Lists,** shown earlier in Figure 11.3).

> **SAP Note**
>
> For more information about and detailed examples of RFC callback security, refer to SAP Note 1686632 - Positive lists for RFC callback.

11.1.6 Remote Function Call Connections with Logon Data

To display RFC destinations), you can either use Transaction SE16/SE16N and access table RFCDES, or you can use report RSRFCCHK, as shown in Figure 11.5. Report RSRFCCHK has the advantage of showing additional information about RFC destinations, including user credentials, but also allows you to execute connection tests for all RFC connections at once.

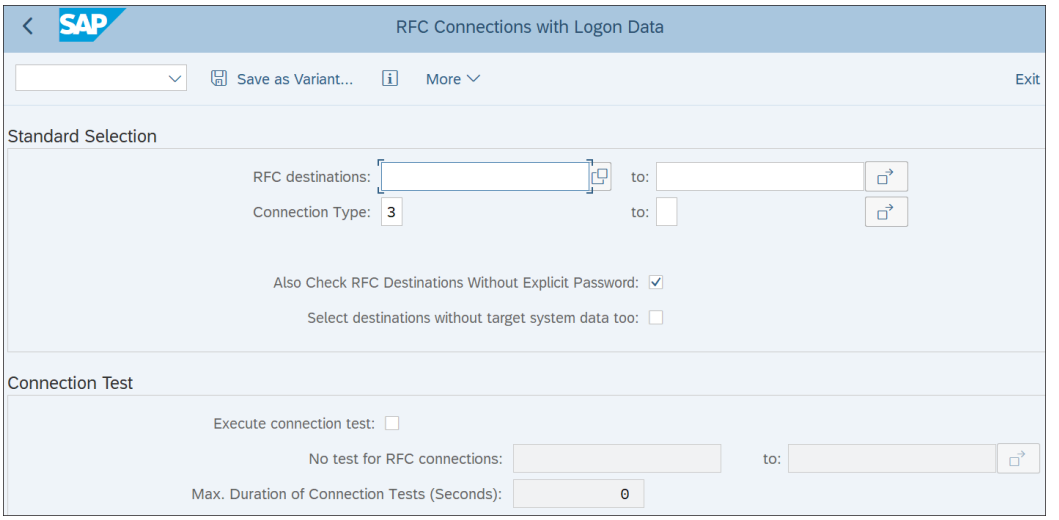


Figure 11.5 RFC Connections with Logon Data

This report is a fast way to access an overview of your RFC destinations, with additional features for testing and accessing more detailed information about each connection.

11.2 Best Practices

This section provides an overview of some best practices and golden rules to follow when securing interfaces, whether through RFC connections or other means of communication.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

11.2.1 Golden Rules

When securing interfaces, a few considerations are absolutely mandatory to keep in mind regardless of whether the connection is between two ABAP systems, SAP cloud applications, Web Services, or SaaS applications. Follow these rules:

- Always create a dedicated role for an interface scenario (whether for a single user, a connection user, or a group of users).
- Don't use manual profiles like SAP_ALL, SAP_NEW, etc.
- Avoid connections from non-PRD to PRD systems particularly when the connections save user credentials.
- If more than one distinct integration scenario is used at the same time, consider having them run through different connection users. This separation increases the security and auditability of your landscape. Using one "central" Materials Management (MM) user and one "central" Human Resources (HR) user is typically not the granularity you're looking for. Instead, build dedicated users for dedicated scenarios in MM and HR, respectively.
- Always analyze if a trusted connection should be used or not. One rule of thumb is to afford trust to actual people, not for machines. People are themselves in every system, while the purpose of a machine changes with the user, system type, client, release, etc.
- If you want to run multiple distinct interface scenarios through a single user, build separate roles for the scenarios/processes from the start. Processes change or become obsolete, which means you'll be adding and removing authorizations from your interface users. The extra granularity will reduce maintenance efforts down the road.
- When building roles in Transaction PFCG, always build roles from role menus. RFCs, Web Services, OData services, and more must be added to the role menu. When you add RFCs through the role menu, the authorization object S_RFC is populated with `RFC_TYPE = FUNC` instead of `RFC_TYPE = FUGR`. This approach is more restrictive and authorizes only one function module (`FUNC`), instead of the entire function group (`FUGR`). This behavior is similar as table authorizations with authorization objects S_TABU_NAM and S_TABU_DIS.
- The default behavior of Transaction PFCG is to automatically generate the start authorizations (S_RFC, S_SERVICE, etc.) from the applications in the role menu. For RFCs, S_RFC will be populated with `RFC_TYPE = FUNC` and `RFC_NAME = <list of functions>`. This approach is the best and most granular approach, which `RFC_TYPE = FUGR` is the original/old approach, which is unlikely to ever be needed again. Avoid this setting as much as possible.
- Never ever create manual or changed instances of start authorization objects like S_RFC or S_SERVICE. Utilize Transaction PFCG and add an application to the role

Personal Copy for Arun Singal, arun.singal560@gmail.com

menu since only in this way will you get authorization proposals from Transaction SU24.

- Never ever put manual or changed instances of authorizations into interface roles. You'll mostly only need an interface role once, and in that case, it's protected through Transaction SU24. Function modules, OData services, etc. have a Transaction SU24 context and must be maintained through the role menu. All authorizations in your roles should either be "standard" or "maintained."
- Interface functions like function modules are typically single-purpose tools, which means you typically can and will want to close as many fields as you can in Transaction SU24 and maintain only a few values within a role.
- Communicate with your development team about custom function modules. Make sure custom code comes with meaningful authorization checks. If a custom function is built and used for the standard functionality, demand an explanation why SAP standard business application programming interfaces (BAPIs) or standard function modules aren't being used instead.

11.2.2 Interface User Best Practices

When creating and maintaining users for interface, you must follow a few basic principles. These principles prevent misuse and allow you to maintain a secure landscape:

- You must follow a naming convention for your interface users. Obviously, when trust connections are used and the users are themselves in the satellite system, this approach is not required.
- The name of the user must identify the calling system. Therefore, for the calling ABAP system SAP client 001, a name like RFC_SAP_001 is recommended. To achieve the best granularity, RFCSAP001*<scenario/module>* makes even more sense because it clearly indicates that more than a single communication user will be needed for each calling system.
- Note that your users must be traced during role building, and the only filter possibility in Transaction ST01/STAUTHTRACE is the user prefix. With a proper naming convention, you can filter for RFC* or RFC<system>*, etc.
- When you rename users but need to trace them later, you must ensure you copy the existing user under the new name and put the new name into the RFC destination. This step ensures that all user data, not just roles and profiles, is copied. For example, parameter values might be crucial for the RFC process.
- If errors arise after the renaming of the users, you can almost be certain that this problem is due to hard-coded checks (mostly user names in the code). These issues are based on bad coding and should be remediated immediately by the developer. These issues must be addressed and prevented in the future.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- If your interface processes too much within a single user, create additional users and redirect part of the traffic through separate interfaces. This separation will allow for easier tracing of your users in the called system since the traffic for different scenarios/modules will already be separated when it reaches the called system.

For interface users, an important step is to put in place the rules that must be followed. In theory, this approach to users is straightforward and only requires a few distinct steps. Make sure you always follow these rules and don't allow any shortcuts, which can lead to security issues.

Warning

Some interfaces only exist in a PRD environment and cannot be tested in a DEV or QAS. An example is a connection to banking software. Always be sure you understand the importance and severity of each interface.

11.2.3 Interface Authorizations Best Practices

Similar to the maintenance of your interface users, it's imperative you set rules on how roles and authorizations must be maintained. Ultimately, the authorizations assigned to a user decide what the user is allowed to perform in the system. In the case of interfaces, we want to follow a least privilege approach and restrict to the lowest possible granularity.

Before you start changing the authorizations of your interface users, start collecting statistical usage data from Transaction ST03(N). Transaction ST03(N) retains the execution of transactions, function modules, and other applications. This information allows you to build your specific roles in Transaction PFCG. In addition to the statistical usage data, Transaction STAUTHTRACE/ST01 or also Transaction STUSERTRACE can provide details about what has been used and which authorizations have been checked.

In Transaction PFCG, always make sure that you add the applications (e.g., function modules) to the role menu so that the required start authorization (e.g., S_RFC) is automatically populated. Never change start authorization objects manually. When adding applications to the role menu, the context from Transaction SU24 will populate the authorization data. You must, however, update Transaction SU24 data for function modules and other objects since this data might be missing or has not been recently updated.

To trace authorizations and then populate Transaction SU24 and ultimately Transaction PFCG, three options are available:

- **Transaction STAUTHTRACE/ST01**
  - Apply a filter to narrow the tracing to just the RFC user(s).

Personal Copy for Arun Singal, arun.singal560@gmail.com

  - Check the trace often because the size of the trace is limited. If RFC users produce many trace records, the trace will start overwriting itself and therefore possibly hide some values from you by accident.
  - Manually maintain the values found for the RFC contexts in Transaction SU24.
- **Kernel trace in Transaction STUSOBTRACE**
  - Turn on the kernel trace using the parameter and filter and restart the system to activate it.
  - Let the kernel collect the values checked in authority checks for the RFC contexts.
  - The performance impact is minimal, and for a properly sized system, this trace is the most efficient way to collect values over a longer time without major effort.
- **Use the Xiting Authorizations Management Suite (XAMS)**
  - As described in SAP Note 1682316, SAP recommends utilizing XAMS to redesign authorizations for interface users.
  - XAMS does not utilize a trace but instead monitors the user directly.
  - Utilize the Productive Test Simulation (PTS) feature to automatically monitor your interface users in various systems without negatively impacting them.
  - Automatic update to Transaction SU24 to populate authorization proposals.

Make sure you regularly update Transaction SU24 and merge the data into your roles. If you keep tracing your users, over the period of a few weeks and months, you'll reach the right maturity in your roles.

Warning

Remember that certain scenarios require an extended timeframe for proper testing. These scenarios include year-end closing, month-end closing, or any activity that is not performed regularly.

Once you have your roles built, you must plan for activating the new authorizations. This task includes removing old authorizations (sometimes SAP_ALL) and assigning the specific roles that you have built for the scenario.

The biggest threat to activating new authorizations is the risk of a business process failing. Most interface scenarios are not necessarily built in such a way that they fail nicely. In most cases, important business documents might go missing, automated processes stop working, etc. To mitigate risk, SAP recommends using the protected go-live feature of XAMS. Not only does XAMS monitor and simulate interfaces over an extend period in any of your systems, but fallback scenarios can be set up in case something goes wrong during go-live.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

Warning

Remember that interface scenarios are run by machines and are thus amazingly fast and repetitive. If a scenario with a dialog user fails, the user can stop the process and pick up the phone to report the problem. A machine-driven interface keeps repeating itself since most often they are not designed to report execution failures. You must look out for error message and log files like the SAL, system log, or the application log, as well as dumps.

Since interface scenarios vary depending on the system type (e.g., PRD versus DEV), testing in a less critical system and assuming everything will work in PRD is not sufficient. Always utilize the tools available and consult SAP Note 1682316 to mitigate the most pressing risks when redesigning and hardening interface authorizations.

Tip

Always use one user per RFC to specifically authorize the interface. Avoid reusing generic RFC users like `DDIC`, `ALEREMOTE`, `WF-BATCH`, etc.. Instead, create dedicated users for each interface/scenario. Only then can you fully adhere to the least privilege principle.

11.3 SAP Unified Connectivity

To help you keep pace with ever-growing security challenges, SAP NetWeaver 7.40 includes a new framework called Unified Connectivity to secure RFCs. This section covers how Unified Connectivity works and how it functions in conjunction with authorizations.

11.3.1 How Unified Connectivity Works

Unified Connectivity uses a straightforward approach to make RFCs more secure on the server side—by simply reducing the overall attack surface that the remote function modules (RFMs) of your ABAP-based systems can expose to the outside world (to other clients of the same system or other systems) by completely blocking access to all RFMs in your systems that are not relevant for the immediate connectivity scenario, as shown in Figure 11.6. Most businesses run only a portion of the business and technical scenarios offered by SAP, and a large number of RFMs are needed only for load balancing and parallelization in the same client of the same system. RFMs that are unused or relevant only internally within a single client simply don't need to be exposed.

Personal Copy for Arun Singal, arun.singal560@gmail.com

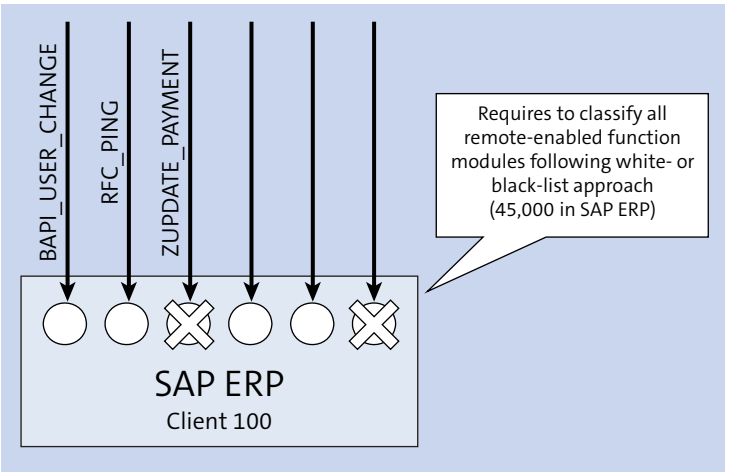


Figure 11.6 Example of How Unified Connectivity Works

Unified Connectivity is not enabled by default and must be configured. For this task, you'll classify which RFMs) are needed and assign them to what's called the *default communication assembly (CA)*. RFMs that are not assigned to the default CA are automatically protected by Unified Connectivity and can no longer be accessed from the outside. These RFMs can still be used for load balancing and parallelization purposes from callers within the same client.

With this step, Unified Connectivity provides an additional layer of security on top of authorizations checks on object S_RFC.

Note

In a typical ABAP implementation, for example, of SAP S/4HANA or SAP ERP, over 38,000 RFMs are available, but only a few hundred are actively used. By activating Unified Connectivity, you can reduce the potential attack surface in terms of RFC by roughly 95%.

11.3.2 Unified Connectivity and Authorizations

Unified Connectivity is not a replacement for proper authorizations. Unified Connectivity is a kind of firewall that blocks incoming RFCs. With Unified Connectivity, you either allow or disallow a function module to be called from the outside. What you don't consider at all within Unified Connectivity is the calling user. As shown in , even with Unified Connectivity activated, authorizations are still checked.

When an outside user tries to access an RFM on a Unified Connectivity-protected system, the framework checks whether the RFM is included in Unified Connectivity's default CA, the grouping of RFMs designated as externally accessible. If the RFM is not

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

in the default CA (not exposed), the RFC session is terminated with an informative message, and access is denied. If the RFM is in the default CA, consequently, access is granted, and the usual user-dependent S_RFC checks are then performed, as shown in Figure 11.7.

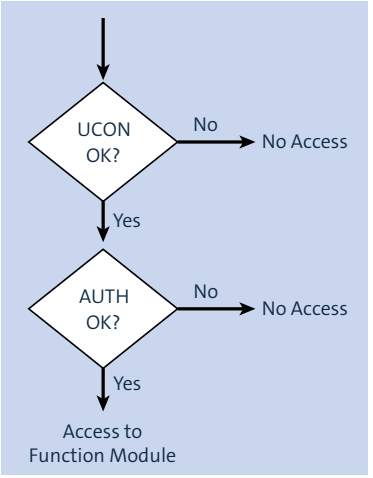


Figure 11.7 Sequence of Unified Connectivity and Authorizations

When you use Unified Connectivity), you still must maintain all the usual the RFC authorizations since Unified Connectivity does not block RFMs on a user level. Certain RFMs are required and should thus be allowed but can still pose a risk to the overall security of your system. For example, RFMs that are used by CUA to create and change users are allowed within Unified Connectivity, and therefore, the RFC authorizations (S_RFC) of your users must be configured properly.

Note

Unified Connectivity does not replace the proper management of your RFC authorizations and only adds an extra level of security to reduce the overall attack surface of your ABAP system.

11.4 Xiting Authorizations Management Suite: Automated and Risk-Free Role Testing and Go-Live

RFC interfaces play a crucial role in many SAP implementations by enabling the data exchange among SAP systems as well as enabling exchanges between SAP and non-SAP systems. Unfortunately, many RFC interfaces are overauthorized and have more powerful roles than they need (or even use profile SAP_ALL). This mistake opens up critical vulnerabilities in your SAP landscape.

Personal Copy for Arun Singal, arun.singal560@gmail.com

XAMS can safely reauthorize your RFC interfaces and their associated technical users without negatively impacting the operation of the interface.

XAMS achieves this task by analyzing an interface's activity in PRD and automatically creating actionable reports that role administrators can use to quickly create matching roles in the DEV. That concept has helped countless businesses optimize their RFC interfaces without interrupting operations.

In a nutshell, XAMS allows you to perform the following activities:

- Analyze all RFC destinations, with its users, to understand what an RFC interface does and requires
- Semiautomatically build RFC authorizations in Transaction PFCG
- Automatically simulate RFC authorizations in any environment without negatively impacting the RFC interface (e.g., directly in production)
- Finalize RFC authorizations following the least privilege principle and leveraging standard role building based in Transaction SU24
- Fallback scenario during go-live to mitigate the risk of authorization failures to ensure interfaces don't go down
- Documentation of RFC interfaces to follow regulations, for example, General Data Protection Regulation (GDPR).

XAMS not only helps you build RFC authorizations much more quickly compared to a traditional approach but also reduces the effort and (more importantly) the risk involved. With its unique PTS capabilities, RFC authorizations can be simulated directly in any given system (e.g., PRD) without impacting the RFC interface. This feature allows you to simulate new authorizations to understand what is missing, to ensure a smooth go-live when activating new authorizations. In case of a problem after go-live, which is unlikely since interfaces should be thoroughly simulated over an extended period of time (e.g., 4 to 6 months), in the unlikely event of an authorization failure, XAMS can instantly provide the RFC interface with the missing authorizations.

SAP Note

SAP endorses adopting XAMS as the best practice approach for an RFC redesign, as described in SAP Note 1682316 - Consulting: Optimizing RFC User Authorizations.

11.5 Summary

In recent years, the drive to digitalize and move to the cloud has sped up like never before. This results in hybrid landscapes that require various systems (SAP and non-SAP) to talk to each and other to exchange and process data. Even if you don't have any cloud applications today and you maintain a fully on-premise landscape, you'll have

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

multiple connections that need to be protected. It is important to remember that the weakest link in the chain poses the biggest risk. Therefore, make sure you protect your environment properly, follow a least privilege approach, and granularly authorize your interfaces to avoid overauthorizations that could potentially lead to security incidents. SAP offers a variety of tools to increase the overall interface security like SAP Unified Connectivity to block incoming RFCs or RFC callback whitelisting. As for third-party tools, SAP recommends using XAMS, an expert tool that reduces both the effort and the risk involved when hardening authorizations of your interfaces.

In the next chapter, we'll discussing migrating your authorizations to SAP S/4HANA.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 12

Migrating Authorizations to SAP S/4HANA

With SAP's new business suite, SAP S/4HANA, transitioning from SAP ERP 6.0 and its authorization concept is inevitable. Thus, you'll need to understand upcoming technical and processing-related impacts and how to adjust your business and IT infrastructure. Please note that a one-to-one migration of your current authorization concept to SAP S/4HANA is simply impossible.

In the era of big data, the Internet of Things (IoT), and Industry 4.0, technological developments are invented more quickly than their implementation and integration into existing business processes. Companies want new technologies, faster data transfers, less system maintenance costs, and mobile information processing, to name just a few features. In 2015, SAP responded to these business demands and launched a new product line, SAP Business Suite 4 SAP HANA, officially known as SAP S/4HANA.

Be aware that SAP S/4HANA is not a legal successor of SAP ERP 6.0 but instead is SAP's next-generation business suite, in its 4th generation. SAP S/4HANA adopts features like machine learning, advanced analytics, and artificial intelligence, combined with the advanced in-memory database technology of SAP HANA. For your company's potentially worldwide big data approach, an enhanced database infrastructure provides a simplified data model, enables faster data calculations, and facilitates data transmission in real time. Please note that SAP HANA is the only available database for SAP S/4HANA.

SAP S/4HANA comes in various editions, including the well-known on-premise edition and various cloud-based versions. Moreover, SAP S/4HANA incorporates modern design principles through the enhanced SAP Fiori user interface (UI) and delivers several technical and data model-related simplifications. Thus, this solution enables improved operational use cases and business processes for your SAP system landscape with novel deployment options, next-generation functionalities, and scalable technical enhancements. You must understand that SAP S/4HANA is not a simple SAP ERP 6.0 upgrade but an entirely new solution. In other words, moving from SAP ERP 6.0 to SAP S/4HANA requires a more or less complex migration project that may involve a change in your business processes, data models, architecture, and other areas of your current SAP landscape. You'll need think about upcoming process-related and technological

Personal Copy for Arun Singal, arun.singal560@gmail.com

changes and how to align those changes with your business needs and technical requirements. Please note that SAP has announced the end of SAP ERP 6.0 support as the end of 2027, with optional extended support until 2030.

On one hand, this chapter provides some general information about SAP S/4HANA, focusing on its changes and novel features. This discussion includes its simplification principles, data management architecture, deployment options, and essential business process changes. Furthermore, we'll provide an overview of SAP HANA security and include helpful information about the holistic SAP S/4HANA migration process. On the other hand, this chapter primarily focuses on the SAP S/4HANA authorization migration process so that you can estimate your migration efforts and the required prerequisites. This information enables a broad understanding of how you can migrate your existing SAP ERP 6.0 system and its authorization concept to this new product line.

Hint

The main focus of this chapter is the migration of authorizations to SAP S/4HANA. However, SAP Fiori authorizations are discussed in detail in Chapter 8.

With its various applications and functions, the entire SAP Fiori UI plays an essential part of SAP's next-generation business suite, SAP S/4HANA. SAP has replaced transactions with SAP Fiori apps, and thus, you may need to consider authorizations for OData services and SAP Fiori entities like business catalogs, business groups, or spaces and pages as well. Thus, within your SAP S/4HANA implementation and authorization migration process, you might also need to integrate an authorization concept for the SAP Fiori UI.

12.1 Overview

Before considering business process integration, SAP Fiori applications, and SAP HANA database administration, let's look at the upcoming changes expected with SAP S/4HANA. The new solution includes integrated features, novel database technologies, new tools, and new terms. Moreover, these changes can significantly impact your existing role design and authorization concept since these fundamental changes result in thousands of smaller changes to authorization objects, applications, and modules. Thus, you'll need a basic understanding of these innovations.

This section introduces you to the fundamental changes and modifications that are part of SAP S/4HANA's simplification approach. This chapter also contains essential information about the simplification list and SAP S/4HANA architecture models. Finally, you'll learn how these changes impact migrating to SAP S/4HANA, especially in terms of roles and authorizations.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Chapter 1 summarizes the evolution from SAP ERP 6.0 to SAP S/4HANA.

12.1.1 Simplifications within SAP S/4HANA

One radical change with SAP S/4HANA is its simplification of business processes and applications. SAP aims to reduce complexity, optimize operations, and make it easier for end users to use its business suite. SAP's goal is taking intuitive work and digital business transformation to the next level. Thus, the new solution aims for increased simplicity and faster innovation cycles to satisfy constantly changing business needs. SAP splits this simplification into the following four pillars:

- **Data model simplification**
  The former SAP ERP 6.0 data model contains countless tables dedicated to containing the master data and transactional data records for your business. This data model required many background processes and caused many redundancies. To resolve these issues, SAP has developed the *principle of one*, the central goals of which are reducing applications and transactions, optimizing the database structure, and providing only one solution for each business challenge. These changes lead to faster throughput, higher flexibility, smaller data footprints, and simpler code customizing. Figure 12.1 shows this approach using the example of the new inventory management functionality—the material ledger in accounting, which underlines these modifications. Above the horizontal line, you'll see the SAP ERP 6.0 data model, and below, the new SAP S/4HANA data model. You'll no longer require countless subtables or even cross-reference tables to serve as multiple data sources for the same process (thus providing access to those data records) but instead use centralized main tables containing all essential information.

- **Process simplification**
  Before the data model simplification, many time-consuming processes were required when using SAP ERP software. Besides reducing the number of transactions and manual steps, SAP has enhanced many of its applications. On that account, SAP has also introduced novel, more practice-oriented programs. With these programs, an end user should be able to work more quickly, more efficiently, and more comfortably. One principle underlying SAP S/4HANA is to provide simple processes that require the least number of steps to execute. The removal of obsolete process steps leads to increased user productivity and more efficient operations administration. For example, under the one-one-three principle, the goal is that one user can access the desired information in three clicks. This approach is one of the main intuitive navigation principles at work with SAP S/4HANA and SAP Fiori.

Personal Copy for Arun Singal, arun.singal560@gmail.com

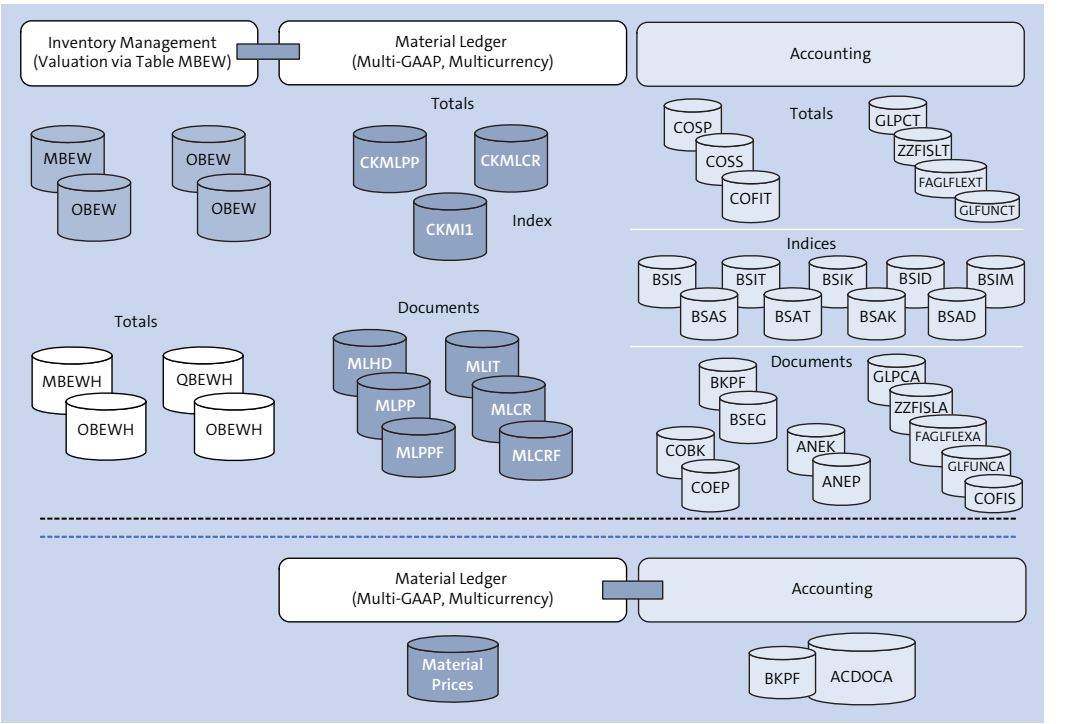


Figure 12.1 Material Ledger and Accounting Data Model Simplification

- **UI simplification**
  SAP also provides a new "look and feel" for its solutions through additional application layouts and themes, like the Belize theme. The most essential visual and procedural change is the new UI, SAP Fiori. This entirely upgraded UI, with its broad range of applications, enables novel business approaches that will significantly impact your business processing for the foreseeable future. For example, SAP Fiori can serve as the single point of entry for SAP S/4HANA Cloud. For SAP S/4HANA Cloud, extended edition (EX); SAP S/4HANA Cloud, private edition; or SAP S/4HANA, you can still choose between the standard SAP GUI, the Web UI, or the SAP Fiori UI. The SAP Fiori UI updates enhance usability, productivity, and UX. Besides, this simplification approach reduces the screen loading times, click counts, screen changes, and fields that must be filled in.

  From an authorization point of view, the conceptional and technical integration of SAP Fiori into your authorization concept is a must, and the same compliance-related restrictions that apply to your backend systems apply for SAP Fiori as well.

- **Landscape simplification**
  Combined with the new data model approach within SAP S/4HANA, SAP also provides a fully integrated and updated landscape model following the same principle

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

of one mentioned earlier. This SAP S/4HANA landscape simplification leads to complete integration of the various SAP Business Suite modules. SAP has enriched, merged, and retrofitted existing modules to improve their capabilities. For example, with SAP S/4HANA, the former SAP ERP 6.0 modules Material Management (MM), SAP Supplier Lifecycle Management, and SAP Supplier Relationship Management (SAP SRM) have been consolidated under SAP S/4HANA Sourcing and Procurement. Thus, such changes might impact your current business model, processes, user authorizations, and SAP user licenses.

As shown in Figure 12.2, SAP splits the various modules into two categories: core and cloud solutions.

According to SAP's product management, SAP expects that many of its businesses will have a hybrid system landscape (a combination of on-premise and cloud-based systems) with SAP S/4HANA. Some SAP products are only available in the cloud.

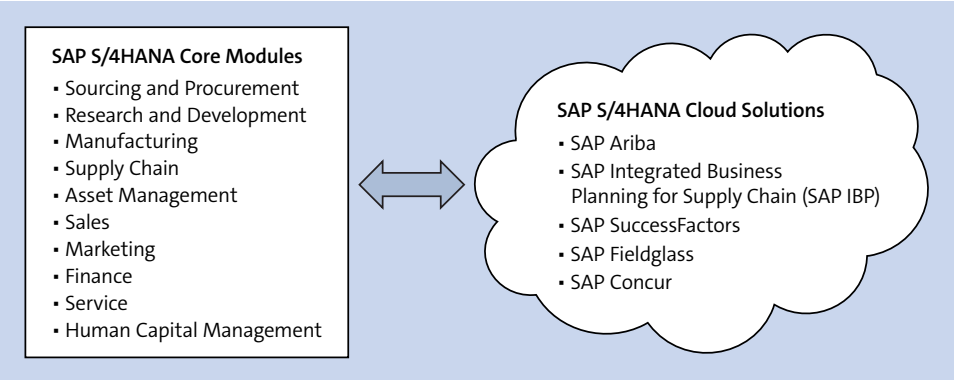


Figure 12.2 SAP S/4HANA Core and Cloud Solutions

All of these simplifications are documented in SAP S/4HANA's simplification list, which is essential for implementing SAP S/4HANA. On a functional level, this list describes the changes, in SAP S/4HANA, to individual transactions and solution capabilities found SAP ERP 6.0. Thus, the list contains technical requirements, innovations, and changes within the provided SAP S/4HANA applications. According to SAP's approach to modern business processes and digitalization, many of these changes are purely technical. Thus, many changes are mandatory when migrating an existing SAP ERP 6.0 system to SAP S/4HANA. The simplification list covers all the capabilities of the system, including specific industry solutions.

Hint

SAP has already provided many of its innovations in SAP ERP 6.0. However, most are optional for SAP ERP 6.0 but mandatory for SAP S/4HANA. Therefore, if you have the

Personal Copy for Arun Singal, arun.singal560@gmail.com

capacity and the time, we recommend deploying these new features within your existing SAP landscape in preparation for an SAP S/4HANA migration. For instance, you should convert your current SAP ERP 6.0 processing early according to the business partner approach or work on the new general ledger as an upstream project before starting your migration. In this way, your end users can gain exposure to some of these new processes. Additionally, doing so reduces the technical conversion effort to SAP S/4HANA.

Please note that the more your authorizations and roles comply with the SAP standard and best practices, the less your authorization migration effort will be.

Thus, in practice, not every system or every business will be affected by all of the documented changes. In addition, SAP has integrated many business-related developments and functionalities in its SAP S/4HANA standard. These innovations may render some of your custom code and custom applications obsolete. Therefore, you should map the simplification list against your productive environment to determine the impact of an SAP S/4HANA implementation on your business and system landscape.

Hint

The best solution for simplification mapping is to use SAP Readiness Check for SAP S/4HANA. This report shows you the relevant simplification items for your SAP ERP 6.0 system. See Section 12.6.4 for more details about this report.

Please note that you'll still need to convert those changes for all your roles manually. Thus, you'll need to search for the individual simplification items in the PDF document based on this results list and write out the transactions (or other menu objects) that will require attention.

You can download the simplification list from SAP Help Portal as a PDF document to get the latest simplification data. Please note that the simplification list is release dependent. Thus, you must match the simplification list's edition with your installed SAP S/4HANA release.

12.1.2 SAP S/4HANA Data Management Architecture

SAP S/4HANA can be deployed using a two- and three-tier architecture. What's best for you depends on your specific use cases and requirements. The essential question for the two-tier deployment option is whether you want to provide end users direct access to data via programs, which are then run on the integrated SAP HANA webserver and are directly callable.

In the three-tier architecture model, end users use applications that process data on an application server layer through a technical user to access the database. This technical

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

user responds to the business tier, and the business application provides the requested information to the presentation layer. Therefore, direct access to the SAP HANA database is not required by end users in this scenario. Thus, you can divide the architecture into the following three layers, as shown in Figure 12.3:

- Client tier = Presentation layer
- Business tier = Application layer
- Data tier = Database layer

The first layer (the presentation layer) is also called the frontend and is where clients interact. This layer enables end-user input and data presentation. This layer is operated by an application server that makes up the application layer. This server manages all system processes required of business applications. The lowest and third layer is where data records are stored, in the SAP HANA database.

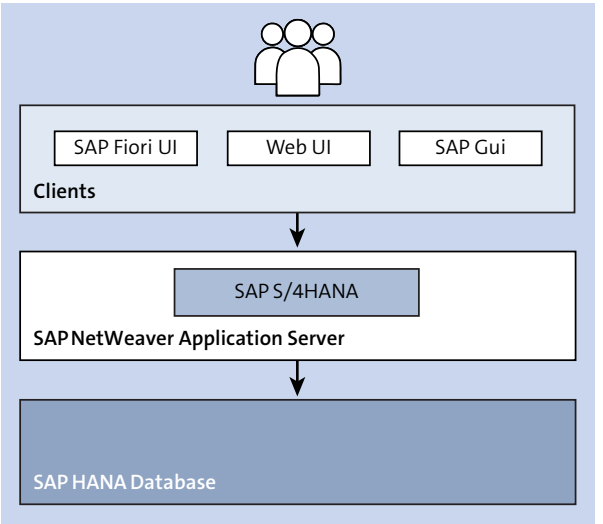


Figure 12.3 Three-Tier Data Management Architecture

In the two-tier architecture model, clients consume data directly from the SAP HANA database. In this case, business applications like SAPUI5 apps can be designed to run directly on SAP HANA's native application server instance, SAP HANA extended application services. From an architectural point of view, leaving out a separate application server enables quicker data transfers and faster processing, as shown in Figure 12.4. Direct database access involves using virtual data models (VDMs) as data sources, which act as generic interfaces to provide data from SAP HANA database tables and views. Business applications that use SAP HANA's XS engine require an end user have direct access to the SAP HANA database. Additionally, they may require permissions for SAP HANA extended application services, depending on the nature of the business application and its built-in security measures. Thus, you'll need to adapt your former

Personal Copy for Arun Singal, arun.singal560@gmail.com

database authorization concept to reflect the new, SAP HANA-specific requirements for this querying.

Some SAP products like SAP Analytics Cloud, SAP Lumira, SAP BusinessObjects Business Intelligence, and SAP Analysis for Microsoft Office may be connected straight to the database via an Open Database Connectivity (ODBC) or Java Database Connectivity (JDBC) connection to query the database directly. This connection also requires the end user have an existing user ID on the database.

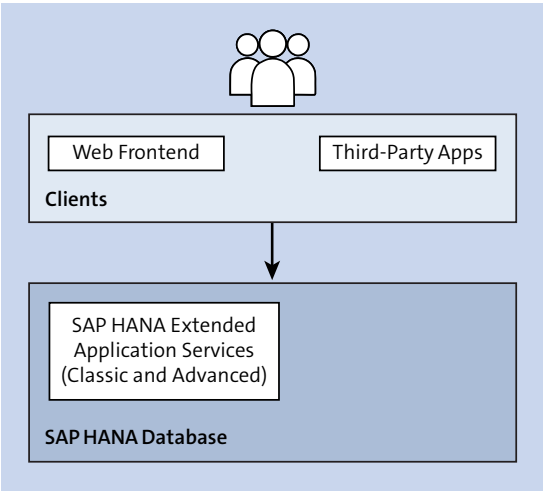


Figure 12.4 Two-Tier Data Management Architecture

12.2 SAP HANA Database

SAP launched its High-Performance-Analytic-Appliance (HANA) database in 2011. The data processing of an SAP HANA database is fundamentally different from other established relational database management systems (RDBMS). The enhanced SAP HANA database now combines embedded in-memory technology for data handling and retention, row- and column-oriented data processing, and native integration of services. As a result, SAP HANA allows you to evaluate more extensive data pools with much shorter processing times. In the past, SAP HANA was an optional choice for the underlying database for your SAP ERP 6.0 system, but with SAP S/4HANA, SAP HANA is mandatory. Thus, you must integrate an SAP HANA database into your existing system setup to run SAP S/4HANA and create an updated database authorization concept.

Since SAP HANA is the only database choice for SAP S/4HANA, this section focuses on fundamental authorization-related concepts for SAP HANA databases that you should keep in mind when migrating to SAP S/4HANA. This section also provides a summary of essential database authorization concepts.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

12.2.1 User Types

SAP HANA mainly distinguishes between *normal end users* and *restricted end users*, which differ in their usage concepts. Furthermore, with an SAP HANA database, you'll differentiate users according to their purposes like technical access or business-related access. Therefore, a user group called technical users also exists. The following list includes the most common user types:

- **Database end users**
  This SAP HANA user type corresponds to a real person who works as an administrator or business user on the database layer. You can use the technical user `SYS` to create such users. When database end users leave the company and are inactivated, their database objects are dropped automatically. Thereby, the database management system (DMS) also revokes any assigned privileges.
- **Normal users**
  This user type, sometimes also referred to as standard users, can log on to the SAP HANA database through ODBC or JDBC. This user type is authorized to access their own schema and is granted the `PUBLIC` role. The `PUBLIC` role grants access to various system views and cannot be granted manually since this role is a predefined, system-managed role.

  SAP HANA user administrators can create this type of user through a `CREATE USER` SQL statement, the SAP HANA cockpit, the SAP HANA Web-Based Development Workbench, or SAP HANA Studio. In addition, if configured, SAP HANA users may also be created through the DBMS user management in ABAP using Transaction SUO1.
- **Restricted users**
  This user type has no direct access to the database by default as this user type's user master record is designed with generally no database permissions. However, this user can be granted permission to log on and further to connect via ODBC or JDBC directly if required.

  SAP HANA user administrators can create this type of user through a `CREATE RESTRICTED USER` SQL statement and through the same applications used for creating normal users.
- **Technical users**
  Technical users, like `SYSTEM`, `SYS`, or `_SYS_*`, are not associated with an individual. You cannot log on to the `SYS` user or any `_SYS_*` user. These users are involved in technical processes for database administration, monitoring, and maintenance, such as collecting statistical data.

  A unique critical technical database user is the `SYSTEM` user. This user has privileged access in SAP HANA and should only be used for installation and update processes. Otherwise, the `SYSTEM` user should always be locked, as recommended by SAP, due to its critical nature. Please note that copying the `SYSTEM` user is possible because this copied system user will not have as many authorizations as the original.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

See SAP Note 2493657 for more details about deactivating the super user SYSTEM.

12.2.2 SAP HANA Authorizations

The access model in SAP HANA is fundamentally different from the access model used in an ABAP environment. In ABAP, authorizations, roles, and profiles are maintained in Transaction PFCG. In SAP HANA, you're facing a privilege and role framework using various UIs or SQL.

In SAP HANA, effective access rights are called *privileges*, which are based on standard SQL privileges but with some customizations specific to SAP HANA. These privileges enable operations to be performed on a database object. Consequently, more than one privilege is often required to perform an activity in an SAP HANA database. Further, privileges do not contain components like authorization objects, fields, and values like in ABAP. You can assign privileges directly or indirectly via roles to a user. However, before you start assigning privileges directly, note that a best practice is to assign them through roles.

In SAP HANA, five different types of privileges are available, as shown in Figure 12.5. Table 12.1 lists these privileges and provides short descriptions.

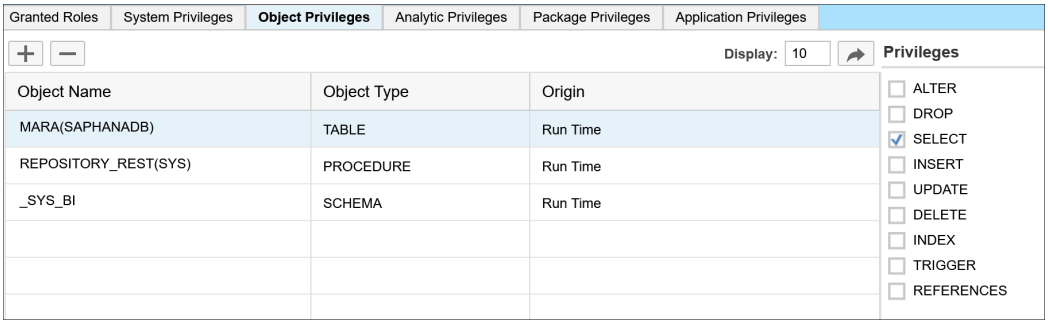


Figure 12.5 Different SAP HANA Privileges

Privilege Type	Description
System privilege	Authorizations for Basis functions of an SAP HANA database like user or transport management.
Object privilege	Authorizations to access an SAP HANA database and modify database objects like schemas, tables, or views.

Table 12.1 Types of Privileges in SAP HANA

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Privilege Type	Description
Analytic privilege	Authorizations for monitoring and reporting. The privilege grants "display" access to particular views like analytic views, attribute views, and calculation views. This privilege is comparable to authorizations for analysis in SAP Business Warehouse (SAP BW).
Package/repository privilege	Authorizations for access to packages and actions in the repository, except for SAP HANA extended application services, advanced.
Application privilege	Authorizations for application functions with the SAP HANA extended application services, except for SAP HANA extended application services, advanced.

Table 12.1 Types of Privileges in SAP HANA (Cont.)

A *role* is a collection of privileges or other roles. This entity is necessary for structuring and assigning various privileges to a user. As in an ABAP-based system, a role can consist of other roles (composite roles to reflect a role hierarchy) or privileges only (single roles). The existing role types in SAP HANA are repository roles (design-time artifacts), catalog roles (runtime artifacts), and SAP HANA Deployment Infrastructure (HDI) roles (used by the SAP HANA extended application services, advanced). However, apart from the role type, all database roles have in common that they can technically serve as a single role or as a composite role.

12.3 SAP S/4HANA Deployment Options

SAP S/4HANA provides several cloud-based deployment options, in addition to the traditional on-premise deployment. As a result, an important task is understanding the impact of and the differences between the five available deployment scenarios (known as *editions*). This decision will affect your entire system architecture, your technical preparation, your authorization concept, and your business processes. Also impacted is your SAP S/4HANA implementation approach, including whether you can migrate your existing SAP ERP solution or must pursue a new implementation. Thus, your choice constitutes the foundation for your SAP S/4HANA system and all subsequent migration steps. No standardized guidance on choosing a deployment option exists; your choice depends on what best suits your business demands, regulations, budget, and resources. Figure 12.6 shows a first impression of the many available SAP S/4HANA product variants, with their service levels and functional scopes. Notice that all the cloud options are software as a service (SaaS) deployments. On the flip side, the on-premise options vary between SAP S/4HANA, managed by SAP HANA Enterprise Cloud

Personal Copy for Arun Singal, arun.singal560@gmail.com

(or not), and between in-house or partner-hosted. Whereas SAP S/4HANA Cloud contains only the core ERP (a subset of SAP ERP) with a functional scope for specific industries and 42 countries, the other deployments provide the full scope of SAP S/4HANA functional, country, and industry capabilities and partner add-ons.

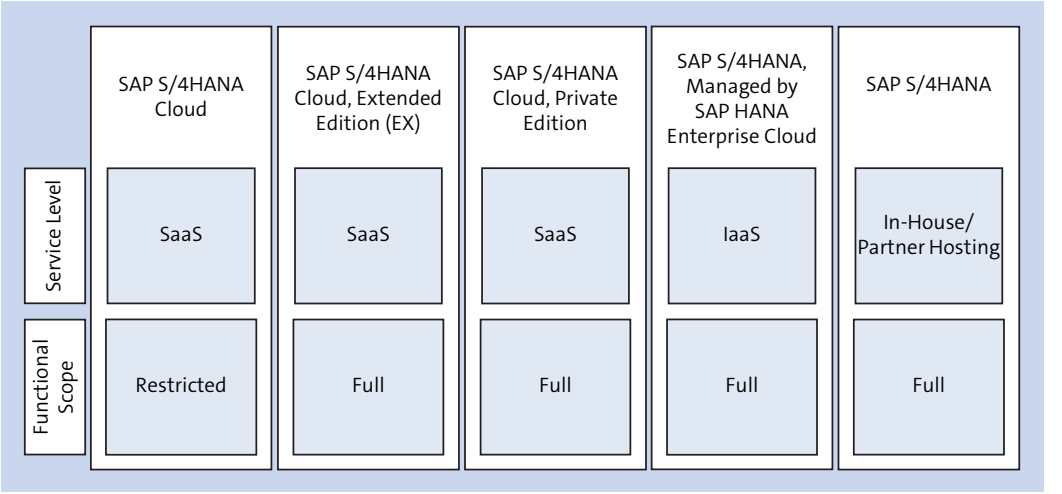


Figure 12.6 Overview of SAP S/4HANA Deployment Options

The following sections describe the five product variants and summarize the various deployment options. We'll highlight the varying service levels of each edition.

12.3.1 SAP S/4HANA Cloud

SAP S/4HANA Cloud, formally known as SAP S/4HANA Cloud, essentials edition, public cloud, or cloud multi-tenant edition, is an SaaS deployment. The software owner and operator is SAP, who will provide standardized, best practice configurations and processes for your finance, human resources (HR), and sales/distribution departments. You'll share one instance with multiple other SAP customers with SAP Fiori serving as the frontend UI. Furthermore, you won't have access to a transport management system to distribute changes in subsequent systems nor can you conduct traces to investigate authorization and functional issues. In addition, you'll be subject to the periodic 3-month release cycle managed by SAP but bear no responsibility for hardware maintenance. Custom developments are only usable on the extensions platform, SAP Business Technology Platform (SAP BTP), which is SAP's platform as a service (PaaS) solution.

You cannot use Transaction SU01 or Transaction PFCG for user and role maintenance within this edition. Only standardized business roles are available, which you'll have to assign to end users through SAP Fiori administrator tools.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Table 12.2 lists the key features of SAP S/4HANA Cloud.

Indicators	Short Description
Implementation	Only a new implementation (greenfield).
Infrastructure	A multitenant landscape shared with other customers, hosted and operated only by SAP.
Functional scope	Restricted functional scope (core ERP) for 42 countries.
Industries support	Specific industries.
Extensibility	Predefined enhancements (options) via SAP BTP.
Innovation cycle	Fixed and mandatory quarterly releases managed by SAP.
Licensing model	Subscription model, for instance, SaaS.

Table 12.2 Indicators for SAP S/4HANA Cloud

12.3.2 SAP S/4HANA Cloud, Extended Edition

SAP S/4HANA Cloud (EX), formerly known as SAP S/4HANA Cloud single-tenant edition or private cloud edition, is deployed as an SaaS but as a single tenant. Thus, you won't share your instance with other SAP customers. This deployment offers full functional scope and access to applications similar to the on-premise options. Moreover, you can enter and work within the system using familiar UIs (SAP GUI or SAP Fiori). Custom code (in namespaces Z* and Y*) can be extensible, but you should not extend or modify the SAP namespace (SAP*). A client has full access to the application server. In combination with an additional SAP BTP instance, you can use the SAP S/4HANA extensibility framework and utilize custom development extensions like application programming interfaces (APIs) or BadIs, for instance, for in-app extensions. Release management is coordinated between SAP and you, as the customer, for two upgrades within 12 months. Mainstream maintenance up to the highest release within 5 years is mandatory.

In contrast to the SAP S/4HANA Cloud deployment option, you can still use transactions for role and user management, including Transactions PFCG and SUO1. Additionally, you won't have to use a predefined authorization framework. Instead, however, you must establish your own role concept.

Table 12.3 summarizes the deployment indicators for SAP S/4HANA Cloud (EX).

Indicators	Short Description
Implementation	Only a new implementation (greenfield).
Infrastructure	Dedicated landscape on a cloud infrastructure operated by SAP or another hyperscale cloud provider.

Table 12.3 Indicators for SAP S/4HANA Cloud (EX)

Personal Copy for Arun Singal, arun.singal560@gmail.com

Indicators	Short Description
Functional scope	Same full functional scope as for an on-premise deployment for 64 countries with some limitations for third-party add-ons.
Industries support	Mostly all (for 25 industries).
Extensibility	SAP S/4HANA extensibility framework and enhancements via SAP BTP allow for in-app and classic ABAP extensibility with modifications.
Innovation cycle	Half-year SAP releases with your choice to apply within 12 months.
Licensing model	Subscription model for the software.

Table 12.3 Indicators for SAP S/4HANA Cloud (EX) (Cont.)

Hint

See SAP Note 2920697 for more details about extensibility in the SAP S/4HANA Cloud (EX).

12.3.3 SAP S/4HANA Cloud, Private Edition

In 2021, SAP released SAP S/4HANA Cloud, private edition, which is based on SAP S/4HANA Cloud (EX) but provides more flexibility. For instance, you can perform code modifications and also apply system upgrades at your own pace. In addition, deployment with SAP partners, third-party tools, or custom code is easier. In contrast to the other cloud deployments, you can also implement SAP S/4HANA through a system conversion or through a selective data transition from a preexisting SAP environment. Moreover, you can still deploy a single-tenant cloud environment with the full functional scope and access to applications that SAP S/4HANA Cloud (EX) offers.

This edition also provides the same opportunities and applications for your authorization, role, and user maintenance as provided in SAP S/4HANA Cloud (EX).

Table 12.4 provides an overview of these indicators, along with their technical descriptions.

Indicators	Short Description
Implementation	New implementation, system conversions (brownfield), or selective data transitions (bluefield).
Infrastructure	Dedicated landscape on cloud infrastructure operated by SAP or another hyperscale cloud provider.

Table 12.4 Indicators for SAP S/4HANA Cloud, Private Edition

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Indicators	Short Description
Functional scope	Same full functional scope as for the on-premise deployment for 64 countries with some limitations for third-party add-ons.
Industries support	Mostly all (for 25 industries).
Extensibility	SAP S/4HANA extensibility framework and enhancements via SAP BTP allow for side-by-side and in-app extensions. Code enhancements and code modifications are allowed.
Innovation cycle	Annual upgrades where you are responsible for staying in mainstream support. SAP only does some specific technical aspects of the upgrade, and you must manage the innovation process.
Licensing model	Subscription model, for instance, SaaS.

Table 12.4 Indicators for SAP S/4HANA Cloud, Private Edition (Cont.)

Hint

SAP S/4HANA Cloud, private edition, is a key component of RISE with SAP, a full-service agreement offering. This "business transformation as a service" deployment option is not only a product but an entire transformation contract. With this model, SAP supports your SAP S/4HANA business process redesign and technical migration, establishing an intelligent enterprise with individual tools and services managed by SAP. Thus, SAP accompanies you through a full transition into the cloud, thus enabling a modern, flexible, and innovative SAP S/4HANA implementation with direct system and business processing optimization. RISE with SAP is available for SAP S/4HANA Cloud, private edition, or for SAP S/4HANA Cloud.

12.3.4 SAP S/4HANA: Managed by SAP HANA Enterprise Cloud

SAP S/4HANA, managed by SAP HANA Enterprise Cloud, is an on-premise infrastructure as a service (IaaS) hosting option with predefined service agreements. The SAP HANA Enterprise Cloud system is based on a private cloud environment. In this scenario, you'll engage SAP or a hyperscale cloud provider to provide and administer the infrastructure in your own data center or an outsourced data center. Possible hyperscale cloud providers might include Microsoft Azure, Amazon Web Services (AWS), or Google Cloud Platform. Included services are storing backups, applying upgrades or patches, and restoring backups, if necessary. The infrastructure provider encapsulates all these activities. As the customer, you can choose the hyperscale cloud provider and roll out your own licensed SAP products equal to the on-premise deployment option. A third option is using the customer edition of SAP HANA Enterprise Cloud, where you can run and manage your SAP software landscape and data in your own data centers.

Personal Copy for Arun Singal, arun.singal560@gmail.com

With this SAP HANA Enterprise Cloud option, you can leverage Hewlett Packard Enterprise (HPE) GreenLake or Lenovo TruScale™ as hardware IaaSs to deliver cloud-based solutions, in their own data centers, to your on-premise systems. As of March 2021, SAP HANA Enterprise Cloud, customer edition, is known as SAP S/4HANA Cloud, private edition, customer data center option. No matter which SAP HANA Enterprise Cloud approach you choose, you'll have full access to the application server and the entire functional scope as SAP S/4HANA. Thus, SAP S/4HANA, managed by SAP HANA Enterprise Cloud is an on-premise solution with individual and private hardware on a private cloud environment. The hyperscale cloud provider approach offers you a flexible infrastructure management service.

The authorization-related scope is the same as for SAP S/4HANA as listed in Table 12.5.

Indicators	Short Description
Implementation	New implementation, system conversion (brownfield), or selective data transition (bluefield).
Infrastructure	A customer-specific landscape on SAP HANA Enterprise Cloud in SAP or hyperscale cloud provider data center. Also, your own data center is possible (Customer Edition).
Functional Scope	Full SAP S/4HANA functional, country, and industry scope with integrable cloud options and partner add-ons.
Industries support	All
Extensibility	Complete customization, modification, and extensibility possible as with SAP ERP 6.0.
Innovation cycle	Annual upgrades with self-responsibility.
Licensing model	IaaS subscription and bring your own license (BYOL).

Table 12.5 Indicators for SAP S/4HANA, Managed by SAP HANA Enterprise Cloud

12.3.5 SAP S/4HANA: On-Premise or Managed by Hyperscale Cloud Providers

SAP S/4HANA is similar to a traditional SAP ERP 6.0 on-premise system. In this deployment scenario, you'll provide the hardware infrastructure, which can be hosted in your own data center or by a hyperscale cloud provider, for instance, Microsoft Azure, Amazon Web Service (AWS), Google Cloud. Ultimately, the installation of applications and their operation, maintenance, and administration are your responsibility. With SAP S/4HANA, you have all the available flexibility and can still use custom developments (in the Y* and Z* namespace). Moreover, with this edition, you can modify the SAP code. SAP S/4HANA offers the highest level of customizing, extensibility, and modification. This flexibility also applies to all applications, the SAP HANA database, modules, servers, networks, and all other related systems or system-related entities. In addition to

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

the classic on-premise approach, you can also add cloud options into your system infrastructure as well. This combination is called a *hybrid deployment*.

From an authorization point of view, you can continue working with Transactions PFCG and SU01 to maintain and provide access to end users via roles and authorization profiles. Also, you can use any other authorization-related applications to maintain your authorization concept.

Table 12.6 summarizes the most critical facts about deploying SAP S/4HANA.

Indicators	Short Description
Implementation	New implementation, system conversion, or selective data transition.
Infrastructure	Customer data center or hosted by any hyperscale cloud provider like Microsoft Azure, AWS, or Google Cloud Platform.
Functional scope	Full SAP S/4HANA functional, country, and industry scope with integrable cloud options and partner add-ons.
Industries support	All
Extensibility	Complete customization, modification, and extensibility possible as with SAP ERP 6.0.
Innovation cycle	Annual upgrades with self-responsibility.
Licensing model	Perpetual or BYOL.

Table 12.6 Indicators for SAP S/4HANA

12.3.6 Comparison of SAP S/4HANA Deployment Options

For many companies, scalable cloud computing constitutes future-ready business solutions since the cloud cuts back on the necessity of an in-house IT infrastructure and also relieves you from administrative responsibilities for Basis, security, or applications management. Cloud-based ERP systems can enable a company to focus on its core business without requiring time-consuming and possibly costly backend or front-end maintenance activities. However, only using cloud computing is not suitable for all businesses. A broad range of functionalities might be available, but these functionalities cannot always holistically align to every company's business processes, restrictions, and needs. Therefore, the various SAP S/4HANA deployment options, from classic on-premise to cloud environments, allow a business to leverage the model that best meets their requirements.

As shown in Figure 12.7 in terms of responsibilities, for cloud solutions, in general SAP or another hyperscale cloud provider primarily manages the infrastructure, platform, and most of the software, in an SaaS agreement. You, as the customer, are only responsible for business data management and processing within the cloud environment

Personal Copy for Arun Singal, arun.singal560@gmail.com

(SAP S/4HANA Cloud; SAP S/4HANA Cloud (EX); and SAP S/4HANA Cloud, private edition). Also, SAP or any hyperscale cloud provider can provide some SaaS data services. The line of business (LOB) applications of the various cloud editions exclusively depends on the chosen deployment option. Whereas SAP S/4HANA Cloud only includes rudimentary scenarios (e.g., for finance, sales, marketing, or customer services), SAP S/4HANA Cloud (EX) and SAP S/4HANA, private edition, provide full access to the SAP S/4HANA, scope. By integrating the optional SAP BTP, which comes with a PaaS agreement, and the SAP S/4HANA extensibility framework, you can enable a wide range of extensibility and code modification opportunities. Referring to the digital core in cloud environments, you can benefit from significantly lower maintenance and operational costs and, on the other hand, also rapidly increase system performance. The cloud-based variants mostly fit best for medium-size or fast-developing companies that require basic business functions. These companies can mainly use SAP standard processes and easily adopt this high-performance and scalable platform and technology.

The on-premise solutions will engage you much more in customization tasks. For instance, the IaaS SAP S/4HANA, managed by SAP HANA Enterprise Cloud deployment option offers more flexibility. However, platform and software maintenance efforts are also greater compared to the cloud deployment options. The combination of insourcing and outsourcing simultaneously may lower initial hardware costs, but you'll have access to the entire on-premise business scope. Your infrastructure maintenance depends on your provider. Within this model, you can leverage full-scale business applications with a flexible hardware setup.

SAP S/4HANA might be your best choice if you want the most individualization and customization capabilities. The classic on-premise approach suits large enterprises with business processes that are exceptional in their operating range and customization needs. In addition, SAP S/4HANA provides extensive features that provide a high level of individualization and modification options to meet specific business requirements.

SAP S/4HANA is SAP's new business solution, not merely an enhancement of SAP ERP 6.0, as many have initially thought. This new product line offers many improved and novel functionalities, business processing opportunities, and stakeholder integrations that can tie into the even most complex system landscapes. Whereas SAP S/4HANA covers the full functionality of SAP Business Suite for all industries, the various cloud-based editions offer scalability and flexible service level agreements (SLAs). Thus, you can choose among a broad range of capabilities, from a minimum degree up to a maximum, as shown in Figure 12.8. On the other hand, the degree of standardization has an inverse relationship with flexibility. Thus, your deployment decision highly depends on your internal processes, functionalities, demands, and resources.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

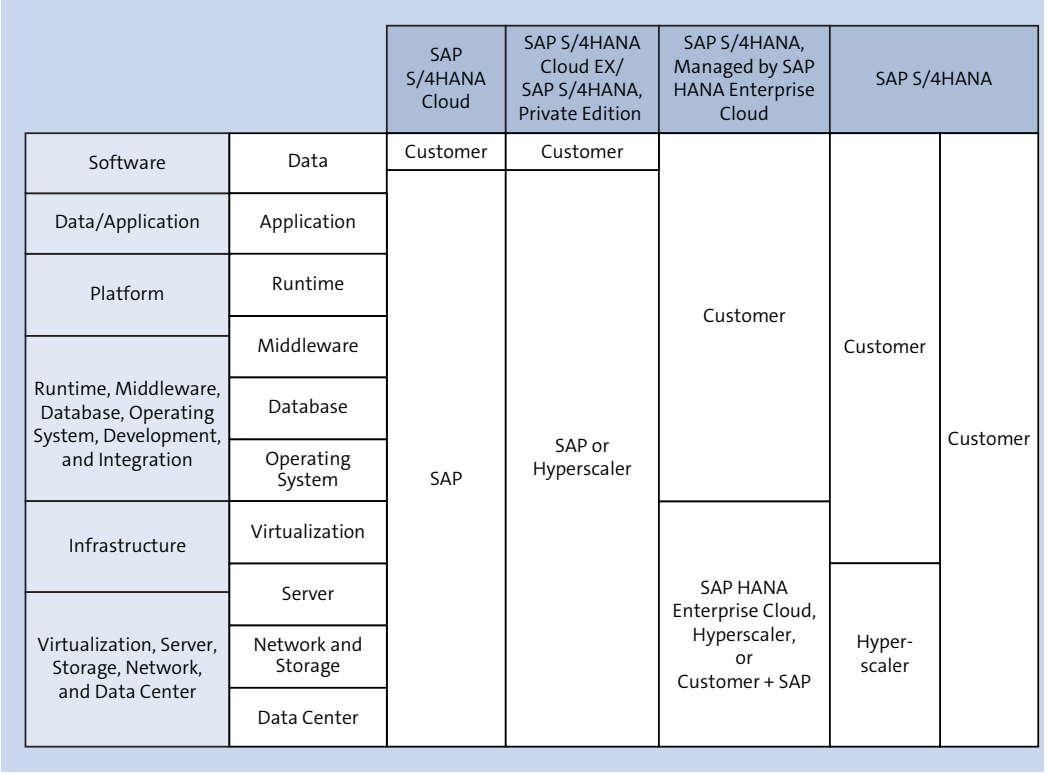


Figure 12.7 SAP S/4HANA Edition Responsibility Levels

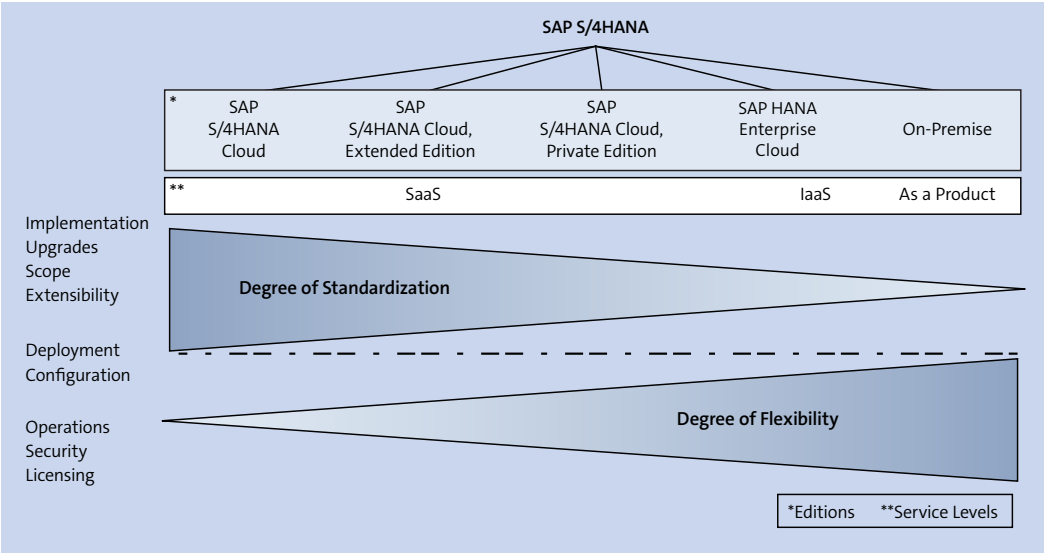


Figure 12.8 SAP S/4HANA's Standardization and Flexibility Opportunities

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

SAP offers the SAP Transformation Navigator to help you identify the required SAP products based on your business priorities, IT strategy, and current products. Features include transformation services, integration steps, and impact analysis related to your licensing agreements. You can launch SAP Transformation Navigator at *http://s-prs.co/v203602*. In addition, RISE with SAP provides complete support for migration and business transformation for both private and public cloud models.

From an authorization point of view, your responsibilities in creating, maintaining, and achieving a secured authorization concept are mostly correlated to the chosen edition. An authorization concept migration or even a redesign and further maintenance are an absolute must within the SAP S/4HANA implementation project for on-premise solutions. In contrast, SAP S/4HANA Cloud comes with predefined authorizations and roles. This edition offer nearly ready-to-use authorizations, and you can establish a new role concept with the help of SAP's application catalogs. In this case, you are responsible for creating business roles, for general authorization maintenance, and for assigning roles to end users. Of course, SAP S/4HANA Cloud, extended edition and SAP S/4HANA, private edition are cloud models as well. Concerning their individualization, you, as the customer, are responsible for the authorization concept and have the flexibility to enhance your end-user authorizations due to your business needs without depending on SAP templates. However, since you're moving into the cloud, you must establish an entirely new role concept to cover the cloud environment objectives and processes. But since you're still working with transactions like Transactions PFCG or SU01 for authorization maintenance, you can also still use your former roles to inform your migration.

12.4 Business Process Changes through SAP S/4HANA

Based on principle of one, SAP S/4HANA has introduced several changes that might affect your existing business processes. These changes have made many applications that you might have used in SAP ERP 6.0 obsolete. For example, in SAP ERP 6.0, you could register a vendor invoice in either MM or Finance (FI). Now, with SAP's new business suite, the same task is only available through invoice management. Figure 12.9 shows some further examples of new functions that might directly affect your business processing with SAP S/4HANA.

These shifts in your business processes will have a direct impact on your existing authorizations concept. Overall, SAP has changed approximately over 5,500 authorization objects that might impact your current authorization concept. These changes will likely trigger at least a partial role redesign as part of your journey towards SAP

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

S/4HANA. As a result, you must understand that an SAP S/4HANA implementation requires not only adjustments on a technical level but could also lead to changed end-user activities and processes. Thus, you must integrate the new end-user actions into your authorization concept, which will require adjustment and, in some cases, a complete redesign of your business roles. The extent of these adaptations depends on the functionalities used and the level of standardization in your business processes.

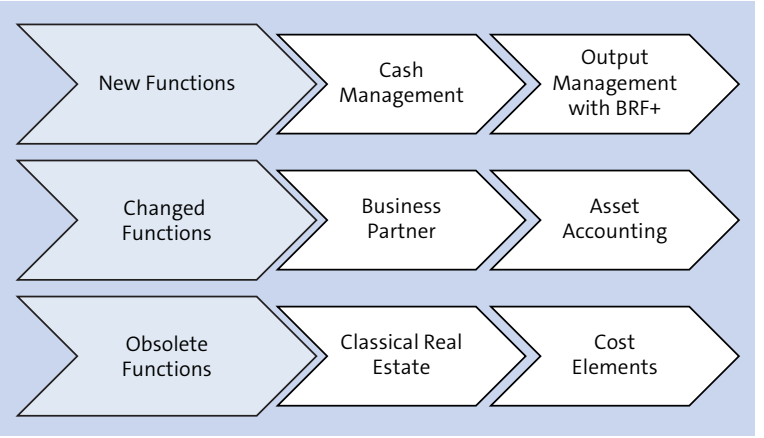


Figure 12.9 Affected Functions through SAP S/4HANA

Before you can remodel your authorizations concept, your business departments must collect and validate the relevant changed end-user actions. Then, they can distribute new business use cases and guidelines for their end users so that you can test and align the required authorizations. Both security administrators and the business in general can use various SAP business role templates from SAP Best Practices Explorer to simplify this process. These role templates contain the new business functions for various SAP S/4HANA modules and process areas. SAP Best Practices Explorer offers an extensive overview to help you determine the relevant process changes and enable the new processes and features for your end users.

Hint

Avoid reusing and renaming standard business roles from SAP Best Practices Explorer for your role concept. Instead, use them as templates to create your own job-based roles. For more information about SAP Best Practices Explorer, Section 12.6.5.

In a nutshell, your new authorization concept will be based on the new business partner approach, the new integration between finance and controlling, the universal journal, and mandatory material ledger activation. The following list introduces you to the most important changes related to business processes in SAP S/4HANA to enable you to understand better how these changes impact your authorization concept:

Personal Copy for Arun Singal, arun.singal560@gmail.com

- **Business partner approach**
  An important fact, the simplification list outlines, is that only SAP ERP 6.0 customers with C/V (Customer/Vendor) integration in place can move to SAP S/4HANA. SAP S/4HANA features centralized master data maintenance of business partners via Transaction BP. This application is the central point for maintaining and displaying all relevant information concerning stakeholders, whether vendor or customer. In practice, all 50+ transactions that were previously used to maintain customer or vendor data in SAP ERP are no longer available in SAP S/4HANA. You no longer have independent transactions, for example, for creating vendors (Transaction FK01) versus for creating customers (Transaction FD01). As a result, the changes SAP has introduced with the business partner concept have far-reaching impact on your authorization concept and thus directly impacts your entire security design.

Hint

See SAP Note 2570961 for further information related to the novel business partner approach.

In addition, Chapter 5, Section 5.3, outlines a practical solution for differentiating end-user access through the central Transaction BP. With Transaction SU24, you can create various default data variants with different authorization characteristics for the same application.

- **Finance and controlling integration**
  One of the most crucial process-related aspects of migrating to SAP S/4HANA is the transformation of Finance and Controlling (FI-CO) into SAP S/4HANA Finance, which was also available for SAP ERP 6.0 as SAP Simple Finance. For SAP's new product line, SAP S/4HANA Finance is mandatory and provides many novel features.

  For instance, you'll still differentiate between the general ledger account and cost elements, but cost elements are now simplified into master records. With SAP ERP 6.0, the controlling department created, changed, or displayed cost elements through Transactions KA01, KA02, or KA03. In SAP S/4HANA, these transactions are now obsolete and are an integral part of Transaction FS00 (central general ledger account). Transaction FS00 typically belongs to the finance department, which means that the CO account assignment must now be considered within the FI chart of accounts. This merger of finance- and controlling-related transactions that had been separate applications creates procedural issues or conflicts that you must resolve on two levels. On the first level, you must clarify the responsibilities within this migrated transaction for both departments. Second, since you won't have separate transactions to distinguish department-related access, you must authorize this central transaction's proposals differently in the role authorization profiles related to the target job function.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Universal journal**
  With SAP S/4HANA, the universal journal serves as the single source of truth for all finance and controlling department business operations data. The central table behind the universal journal is table ACDOCA. This table is thus also the key data source for general ledger accounting, asset accounting, controlling, profitability analysis, and the material ledger. This consolidation prevents redundancies and reduces synchronization efforts.
- **Material ledger activation**
  According to the principle of one, SAP has removed the material management functionality from inventory management and combined material valuation and inventory management into the material ledger. The central material ledger contains the most features for materials, including the actual cost system, and you can use multiple currencies and evaluations. Because of this new data model, the activation of the material ledger is mandatory for all companies adopting SAP S/4HANA.

Hint

One of the areas with the most impact on security, roles, and authorizations is the mandatory customer and vendor integration via the business partner concept. This enforced integration requires redesigning any role that contains authorizations for customer data, vendor data, or any other master data. New functions, modules, and the SAP Fiori UX also require additional security concerns, and administrators must take new transactions, apps, and authorizations into account.

12.5 Core Data Services in SAP S/4HANA

In SAP S/4HANA, performance improvement has always been a key objective. One element contributing to achieving this objective is the introduction of core data services (CDS), which has replaced ABAP Dictionary views. The new programming model with CDS views enables pushing code from an application server down to the database level instead of executing the code on the application server. Technically, CDS views represent semantically rich data models on top of one or more tables. The data is still physically stored in the SAP HANA database. Using the SAP HANA in-memory technology, data is processed quickly without aggregating or indexing the data. Instead, all expensive operations concerning resource consumption are performed on the database layer, through the support of many SQL functions. The results are eventually returned to the application, which exposes the data to the client. Thus, CDS views enable a new enhanced database query with SAP HANA.

The following sections cover the difference between CDS views in ABAP and SAP HANA, as well as discuss several security and troubleshooting considerations with ABAP CDS views.

Personal Copy for Arun Singal, arun.singal560@gmail.com

12.5.1 ABAP versus SAP HANA Core Data Services Views

CDS view definitions use data definition language (DDL) sources, which represent an ABAP development object. CDS views also support annotations related to security. CDS access control definitions reside in separate data control language (DCL) specifications.

The most important advantage of using CDS views in the authorization context is that a developer can insert authorization checks into source code through SQL statements based on ABAP authorization objects. Consequently, a developer can predefine what data and authorizations are essential for the database query. In contrast to the classic approach, where the entire dataset was processed and mapped with source code authorization checks and end-user authorizations, the system now only provides predefined data if the user is authorized for this view.

You can implement CDS views either in ABAP or in SAP HANA. However, some differences exist, mainly in the target use case and other technical considerations, as shown in Table 12.7.

Indicator	ABAP CDS Views	SAP HANA CDS Views
Platform	Application server	SAP HANA extended application services
Database	Any database	SAP HANA database
SQL	OpenSQL	Native SQL
Use case	ABAP application development	Native SAP HANA application development
Development	ABAP Development Tools	SAP Web IDE
Main purpose	View creation	Model creation

Table 12.7 Differences between ABAP and SAP HANA CDS Views

For both types of CDS views (or the respective CDS entity), access controls may be implemented based on CDS roles, CDS access policies, or other CDS aspects. These parameters are specified in separate CDS source code using DCL.

Hint

In ABAP, only the CDS entity being used as a data source can be secured through access controls. In contrast, only a view, such as a calculation view, can be secured in SAP HANA. A view is an entity that describes a predefined data scope for a specific database table. Thus, the available options in the CDS DCL syntax for the definition of access controls may vary slightly. Since SAP HANA CDS views are database dependent and the involved CDS objects for SAP HANA CDS are not controlled by the ABAP Dictionary, they

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

cannot be consumed in ABAP programs or OpenSQL. Therefore, the following information focuses ABAP CDS views because this book is focused on ABAP in SAP S/4HANA.

12.5.2 Security in ABAP Core Data Services

Like any other application development, a developer is typically tasked with implementing security for CDS entities as required. Sensitive data may be disclosed if end users can access CDS entities due to a missing authorization check if a DCL access control (e.g., defining a CDS role) has not been implemented. A developer creates ABAP CDS entities and roles using ABAP Development Tools.

The access control mechanisms are applied in the course of querying the database when the data is being selected from the tables. In contrast, in the classic approach, the entire dataset is processed, and then authorization checks occur.

The classic approach is explicitly based on the `AUTHORITY-CHECK` statement of a program's source code, but access to data via the VDM using CDS in SAP Business Suite may be secured through multiple authorization checks. First, end users must pass the ABAP start, program, and service authorization checks (e.g., they require authorization objects like S_TCODE, S_START, or S_SERVICE in ABAP). Second, an instance-based, user-specific authorization check is performed for the relevant CDS entity. Finally, an instance-based authorization is derived dynamically during runtime from the end user's ABAP authorizations, which are assigned to the user via Transaction PFCG roles. In conclusion, the DCL approach does also take into consideration whether an authorization check is implemented as part of the ABAP CDS view definition, which would be indicated by following annotation:

```
@AccessControl.authorizationCheck
```

The permitted values for this definition are shown in Table 12.8.

Value	Description	Syntax Warning (If Not Defined)
#CHECK	Access control is performed implicitly when a CDS role has been defined.	Yes
#NOT_REQUIRED	Same authorization check as for #CHECK.	No
#NOT_ALLOWED	Authorization check is disabled.	Yes

Table 12.8 Permitted Values for the CDS AccessControl Annotation

By default, the value "#CHECK" is applied if no value has been specified. As the access control annotation is applied implicitly to all users, this annotation may be considered an additional rule to determine what data an end user is authorized to display. Instead

Personal Copy for Arun Singal, arun.singal560@gmail.com

of returning a classic authorization error if not authorized, the access rule acts as a filter when the data is being retrieved.

The `@AccessControl` annotation is the only security-related element in a CDS entity that enables an authorization check. A CDS role commonly defines how and what access controls are applied implicitly to a CDS entity. CDS DCL supports the following annotations concerning CDS roles:

```
@EndUserText.label [short text]
```

```
@MappingRole [true / false]
```

Two different types of CDS roles can be created:

- Mapping roles) (the only option supported by SAP)
- Assignment roles)

A mapping role is created to map a CDS entity to an ABAP authorization. Access is granted implicitly based on instance-based, user-specific ABAP authorizations as maintained in Transaction PFCG. An assignment role is defined as part of the CDS data model itself. Access must be granted explicitly by the user administrator, which is currently not supported by SAP. The conditions for data access are specified in separate DCL source code via the following DCL CDS role statement:

```
@DEFINE ROLE role_name { access_rules }
```

One or more conditional inherited rules or full-access rules can be defined. You can combine rules with each other. By default, the access rules in a CDS role are combined by an `OR` operator. You can change this behavior by adding `@COMBINATION MODE AND|OR` to the `@DEFINE ROLE` statement. An access rule based on another CDS role can only be inherited once. While a full-access rule grants unrestricted access to data, conditional access rules use Transaction PFCG conditions (in a mapping role) or other conditions to further restrict data access, as listed in Table 12.9.

Condition Type	Description
Literal	Compares a CDS element with a static value.
Profile generator (Transaction PFCG)	Compares a CDS element with an ABAP PFCG authorization. Used in mapping roles.
Self-defined aspect	Compares one or multiple CDS elements with a value set (of another CDS entity).
User	Compares a CDS element with the current user name as operand.
Inheritance	Inherits conditions from another CDS role.

Table 12.9 CDS Access Rule Condition Types

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Condition Type	Description
Boolean predicates	Compares a CDS element against the Boolean expressions true or false.
Void predicate	Conditions that result in non-existence. Not required for CDS roles (may occur only when conditions are inherited).

Table 12.9 CDS Access Rule Condition Types (Cont.)

The second option to implement an access control logic is the definition of a CDS access policy. Such a policy is implemented via the following DCL CDS access policy statement:

```
DEFINE ACCESSPOLICY access_policy { pfcg_mapping_definition | aspect_definition }
```

An ABAP CDS access policy supports both conditions based on aspect conditions and Transaction PFCG settings and can be used for further definitions, listed in Table 12.9.

Authorization checks are performed implicitly when the CDS entity is accessed via OpenSQL. However, access to the relevant CDS database view via Transaction SE11 does not perform an authorization check as specified in the DCL source code.

In addition, CDS entity-level access controls do not apply in the following situations:

- The annotation `@AccessControl.authorizationCheck` is set to `#CHECK` or `#NOT_REQUIRED`, but a CDS role has not been defined.
- The annotation `@AccessControl.authorizationCheck` is set to `#NOT_ALLOWED`.
- You're using the expression `WITH PRIVILEGED ACCESS` in the `FROM` clause of the ABAP SQL statement.
- Specified access controls of a CDS entity are used as the data source in another CDS entity. Only access controls of the entry-level CDS entity are applied.
- Full-access rules have been defined to grant access to all data.

12.5.3 ABAP Core Data Services View Troubleshooting

Since access controls for CDS views are implemented in various ways, authorization error analysis may be required on various stages. To facilitate effective troubleshooting, Table 12.10 lists the most relevant transactions.

Transactions	Process Short Description
STAUTHTRACE	Check the **CDS entity** column in your result list and click on the **CDS Access Control** button.

Table 12.10 Applications for ABAP CDS Views Troubleshooting

Personal Copy for Arun Singal, arun.singal560@gmail.com

Transactions	Process Short Description
SACM	Enter the **Runtime Simulator** and check for the missing CDS access control name. Then, you can validate the lack of access control.
SDDLAR	An additional useful transaction to display the definition of CDS database views.
ST05	To perform an analysis of the executed ABAP SQL statement.
RSRTS_ODP_DIS	To check transient providers.
RSRTS_QUERY_CHECK	To check transient query definitions.
SE80	With the input "DDLNAME," you can also display CDS database view definitions.

Table 12.10 Applications for ABAP CDS Views Troubleshooting (Cont.)

Troubleshooting your CDS authorizations starts with Transaction STAUTHTRACE. Based on the end-user action, you'll see which authority checks were implemented within the specific application and thus are also required in the end-user master record. Always begin your analysis in Transaction STAUTHTRACE since this trace tool provides detailed CDS-related information, in the **CDS Entity** column, as shown in Figure 12.10. Transaction ST01 does not reveal whether CDS entities are being accessed.

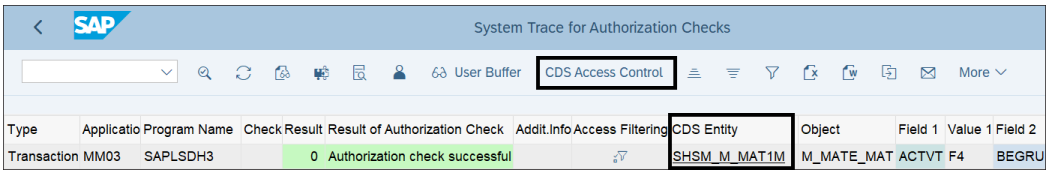


Figure 12.10 CDS Entity Appearance in Transaction STAUTHTRACE

Hint

For missing CDS access authorizations, you can also use Transaction SU53, but this application does not provide as many details as Transaction STAUTHTRACE does.

Select the row for your CDS entity and click on **CDS Access Control**. The system forwards you to the control area where you can, for example, generate or delete the related ABAP artifact of **DCL**s and check the consistency of the DCL and whether it contains any errors, as shown in Figure 12.11.

By double-clicking on the access control name, you can drill down into the detailed information about the entity and its source code. This overview provides the current status of your CDS entity, including **syntax check**, **in-depth analysis**, and **last log result**.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

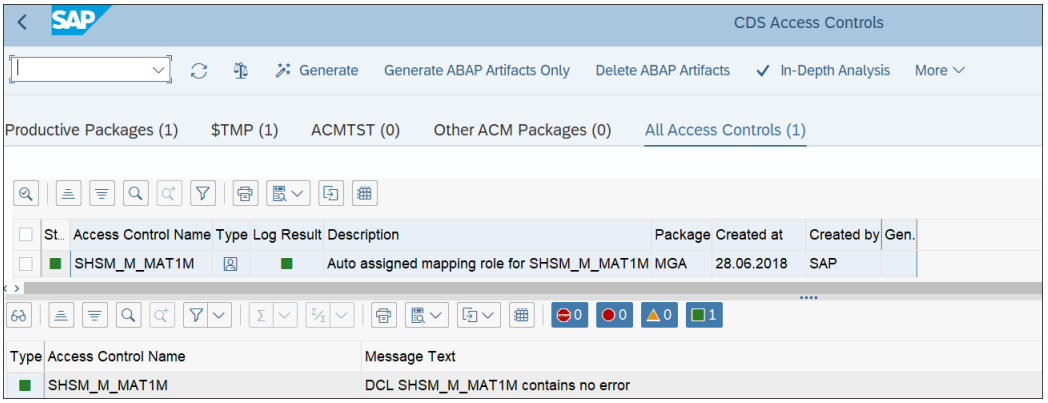


Figure 12.11 CDS Access Controls Area

Furthermore, you can jump into various cross-application features for more details about these status flags. At the bottom is technical information, providing access to the source code and to checked authorizations (in our example Figure 12.12, for the authorization object **M_MATE_MAT** with fields **BEGRU** and **ACTVT** for values **F4** or **03**). Thus, this screen shows you the required authorizations.

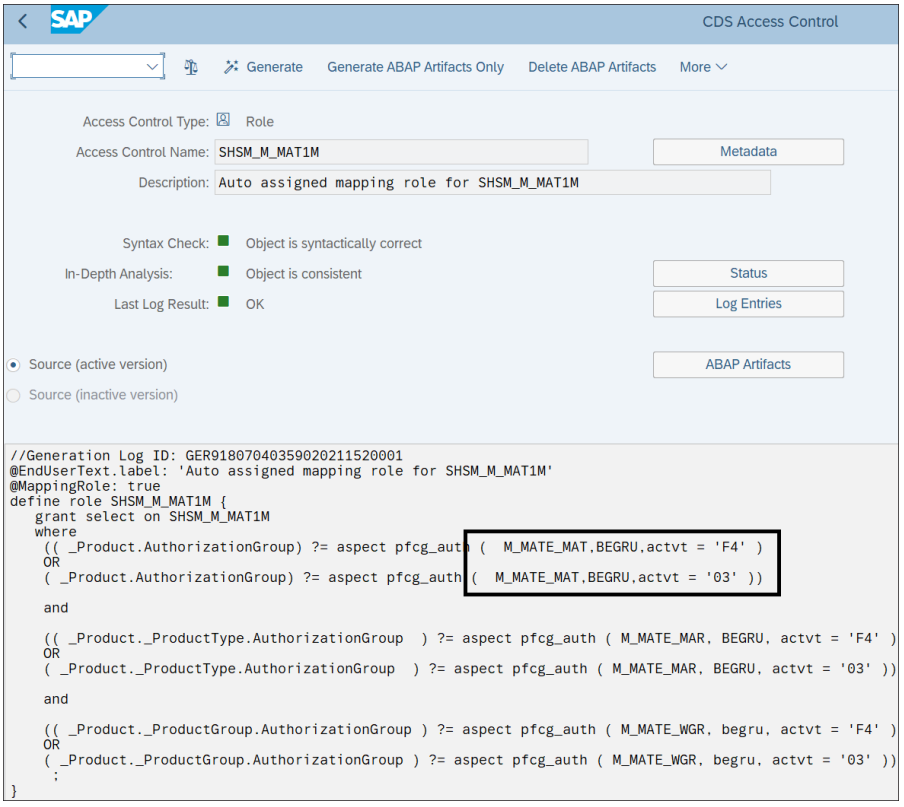


Figure 12.12 Detailed CDS Information

Personal Copy for Arun Singal, arun.singal560@gmail.com

When using Transaction SACM, notice the required authorization objects and the values used for the query execution. Then, start the runtime simulator. In this application, enter the CDS entity name, as shown in Figure 12.13.

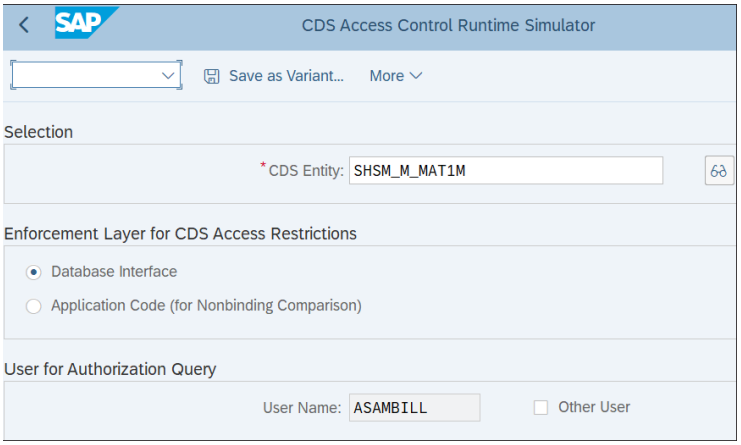


Figure 12.13 CDS Access Control Runtime Simulator

By executing your selection, the system displays the related SQL trace information. In addition, you'll also see the required data in the **Matching Access Controls** and **Authorizations of User for PFCG-Aspects** sections, as shown in Figure 12.14.

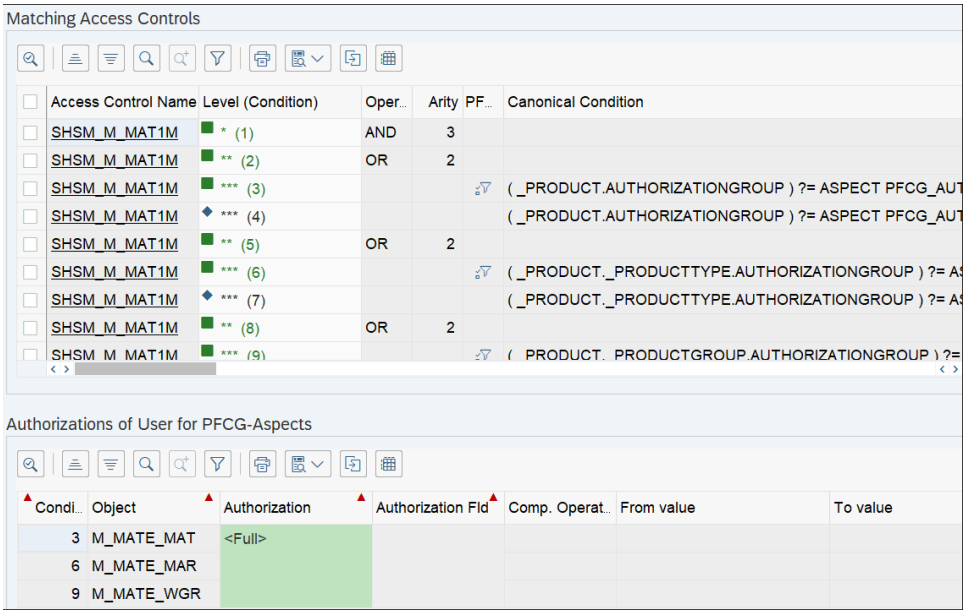


Figure 12.14 Runtime Simulator CDS Information

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

Please note that you'll require a user's password to analyze the authorization query for other users. Since providing one's own password to another person is strictly against any security policies, you should repeat the faulty action with a test user and then perform the analysis.

12.6 Preparing for an SAP S/4HANA Migration

One prerequisite to preparing for your migration is deciding on your preferred SAP S/4HANA deployment option to best suit your business demands. Please note that you'll get predefined authorizations and roles as SAP templates in SAP S/4HANA Cloud, which you'll only have to slightly configure and assign to end users. Thus, SAP S/4HANA Cloud does not require as much extensive authorization maintenance as other deployment options. Therefore, the following information focuses on the following SAP S/4HANA deployment options:

- SAP S/4HANA Cloud (EX)
- SAP S/4HANA Cloud, private edition
- SAP S/4HANA, managed by SAP HANA Enterprise Cloud
- SAP S/4HANA, on-premise or managed by hyperscale cloud providers

12.6.1 Migration Considerations

Since you are not upgrading your existing SAP ERP 6.0 system but instead migrating to SAP S/4HANA, you must analyze all impacts on your current system, processes, and authorizations. Please note that you should see migrating to SAP S/4HANA as an excellent opportunity to clean up your system and eliminate unnecessary data, old documentation, and outdated processes. The following questions should help you through your preparation phase by focusing your attention on some essential considerations:

- Do you need SAP Fiori applications?
- Will you introduce entirely new functions and solutions?
- Is it necessary or only requested to enable direct database querying through SAPUI5 apps?
- Which technical SAP S/4HANA transition route(s) (greenfield, brownfield, or bluefield) is suitable for your system landscape, business, and authorization concept?
- How can you integrate the simplification list into your role concept?
- Are there any SAP standard program replacements for your custom developments?
- What custom code requires migration?

Personal Copy for Arun Singal, arun.singal560@gmail.com

- Are your roles standard-compliant and can run periodic SAP release upgrades without interruptions and stay compliant with your predefined ruleset?
- How can you harmonize and standardize your business processes with SAP S/4HANA?
- Which technical and process-related changes affect your authorizations concept?
- What is your SAP S/4HANA transition project plan?
- Do you see SAP S/4HANA as an opportunity to improve and clean up your current role and user concept (authorization concept)?

Thus, this section's general objectives highlight some important tools for your SAP S/4HANA business process alignment, data management, and custom code validation processes, and we'll offer some considerations for compliance. We'll summarize the preparatory activities required for transitioning your SAP S/4HANA authorizations, including the approach decision, the simplification item check, SAP Readiness Check, and tools like SAP Best Practices Explorer or the SAP S/4HANA migration cockpit. We'll also discuss custom code validation.

Hint

SAP provides an "SAP Activate Methodology for Transition to SAP S/4HANA Roadmap-Viewer," which contains essential information for your SAP S/4HANA migration for its customers. You can launch this resource at *http://s-prs.co/v203603*.

12.6.2 SAP S/4HANA Approaches

You also must choose a technical transitioning route in addition to evaluating and selecting the required tools, architecture, and business data for your move from SAP ERP 6.0 to SAP S/4HANA. Apart from which path you choose, you can merge multiple SAP ERP solutions and systems into one. Please note that your approach depends on your deployment, system requirements, and purpose.

Hint

Regardless of which approach you choose, you must perform an entire data migration. To this end, you can use SAP Data Services and the SAP S/4HANA migration cockpit. What data you want to and can migrate depends on your data consistency and requirements.

As shown in Figure 12.15, three routes are available: greenfield, brownfield, and bluefield.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

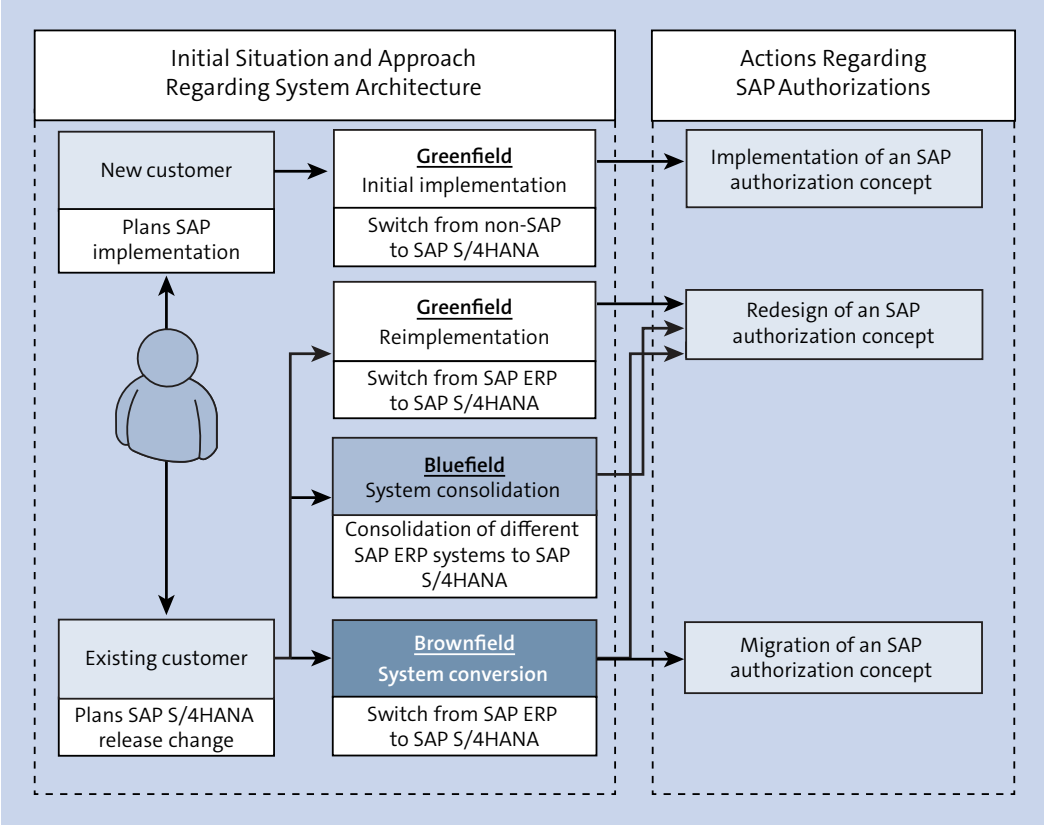


Figure 12.15 SAP S/4HANA Authorization Migration Approaches

Let's briefly look at each of these migration approaches next:

- **Greenfield approach**

  This approach involves a new implementation of an SAP S/4HANA system starting from scratch. You can choose this path to deploy SAP S/4HANA or one of the cloud editions. Whether you have one or more existing SAP systems doesn't matter, but you'll track your system landscape requirements, business needs, and purposes in the new system. A greenfield implementation is an excellent opportunity to abandon old business processes and data and start fresh.

  A greenfield approach might be the best option for existing customers with non-migratable or outdated system setups, processes, and poor authorization concepts. This approach enables a clean and smooth SAP S/4HANA transition.

  A new SAP customer that has never used another SAP Business Suite solution and that lacks inventory data from a legacy system requires an entirely new implementation of SAP S/4HANA. Within this scenario, you must set up the system and all its processes from scratch.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Referring to the new cloud-based possibilities, you can perform an entire changeover to new cloud-based processes, data models, and authorizations. In this way, you might require a new implementation, especially for the SAP S/4HANA Cloud or SAP S/4HANA cloud, Extended editions, for which the greenfield approach is mandatory. You must align your former business processes, and the required individual authorizations, with the available standardized SAP cloud processes and infrastructure for the cloud deployment option. For SAP S/4HANA Cloud (EX) or SAP S/4HANA Cloud, private edition, you can also choose either the brownfield or the bluefield approach.

- **Brownfield approach**
  The brownfield approach is also known as system conversion of a current SAP ERP 6.0 to SAP S/4HANA. You can choose this option to deploy SAP S/4HANA, managed by SAP HANA Enterprise Cloud; SAP S/4HANA Cloud (EX); or SAP S/4HANA, private edition, in your data center or with a hyperscale cloud provider. The indicator for a brownfield scenario decision is the quality level of the existing system setup, data, authorization concept, and process adaption possibility from the former into the new system. From an authorizations point of view, you can choose standard-compliant migration or only a technical conversion. This choice depends on the quality of your role concept. SAP recommends using the brownfield approach for a successful and rapid migration if you have a more or less standard-compliant system setup and authorizations concept and custom developments following SAP Best Practices.

  Standard-compliant migration means you perform a procedural and technical migration of a standardized authorization concept with compliant custom developments and system data. In this way, you can adapt your old data and settings to the new product line. The more standard-compliant your authorization concept is, the less migration effort and the fewer technical changeovers you'll require. The central part of this brownfield migration is integrating your former processes into the new SAP S/4HANA system. Moreover, to achieve this best-case scenario, you can also conduct an upstream role concept redesign to create a secure, functional, and best practice role concept.

  On the other hand, you might need to perform a technical conversion if you lack a standard-compliant authorization concept with clearly defined business processes and also don't have much time for your migration. This approach is only a functional setup for SAP S/4HANA without sustainable process and authorization alignments. This scenario constitutes only a rudimentary cutover of your processes and your role concept. Please note that you move a more or less unsecured and unmaintainable authorization concept into the new SAP S/4HANA landscape. This approach will not solve your authorization and process issues. You might spend more effort on this transition approach than with a greenfield approach or upstream role concept redesign due to the many manual interventions required when trying to run an inconsistent role concept on a new system. This route is possible for SAP S/4HANA; SAP S/4HANA Cloud (EX); or SAP S/4HANA, private edition.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

- **Bluefield approach**
  This technical path to SAP S/4HANA is also called *selective transformation*. Primarily, this approach is used for transitioning multiple legacy systems (old SAP ERP 6.0 systems) into one consolidated SAP S/4HANA system. SAP recommends using the various available Data Management and Landscape Transformation (DMLT) tools and services for this type of migration. In this case, you'll install the SAP S/4HANA release on a new instance (ABAP server), independent of your existing system landscape. Then, you'll selectively transfer configuration- and business-related data from your legacy systems to your new SAP S/4HANA instance. Then, the integration of business processes, system customizing, and authorization maintenance starts in your initial SAP S/4HANA system. This possible path helps you move into the cloud or migrate to SAP S/4HANA, without starting entirely from scratch.

Mainly your business objectives and consistency of your former ERP systems will determine your choice of technical route. For instance, if you choose to move to SAP S/4HANA Cloud, the greenfield approach must be your choice. For maximum innovation, overhauling business processes, and adopting additional cloud solutions like SAP SuccessFactors or SAP Ariba, a new implementation is also recommended for the other editions. In particular, if your system and authorization concept do not fit the SAP Standard and SAP Best Practices, we recommend starting from scratch. In contrast, if you want to initially minimize the changes and effort to enable a fast SAP S/4HANA transition, a system conversion is the preferred option. This path is the best option if you're on a single instance and have a well-maintained authorization concept. Also, you can choose a brownfield approach for your system landscape without worrying about creating sustainable system and authorization settings. More postprocessing efforts will be needed in this case, which might consume your savings much more than in a greenfield approach. Regardless of which brownfield method you choose, you may need to roll out further innovations selectively later. Thus, project duration is often a crucial factor to consider as well.

All in all, hybrid approaches are common in practice. Thus, you might not only choose one path but instead a combination of paths, like brownfield plus greenfield. For instance, you could choose a system conversion for one leading SAP ERP 6.0 system and, in parallel, a new implementation of your human resources (HR) system to adopt SAP SuccessFactors in the cloud. Moreover, you might need to combine this brownfield approach with a bluefield approach if you have a highly complex system landscape. On the other hand, if you lack standard-compliant systems and your business processes are outdated, the most sustainable way for your SAP S/4HANA transition is a greenfield approach. However, for an accelerated SAP S/4HANA integration timeline, the brownfield approach is the most common option for SAP S/4HANA, and certain editions of SAP S/4HANA Cloud, which might even lead to more preimplementation efforts. Finally, your technical and business objectives will be important influences. Still, you should see the SAP S/4HANA transition as an opportunity to clean up your security

Personal Copy for Arun Singal, arun.singal560@gmail.com

concept since so many process-related, technical, and authorization-related changes are required anyway.

12.6.3 Simplification Item Check

This check enables you to evaluate the simplification impact of SAP S/4HANA on your system. For this check, go to the simplification item catalog on the SAP ONE Support Launchpad at *http://s-prs.co/v203604*, as shown Figure 12.16.

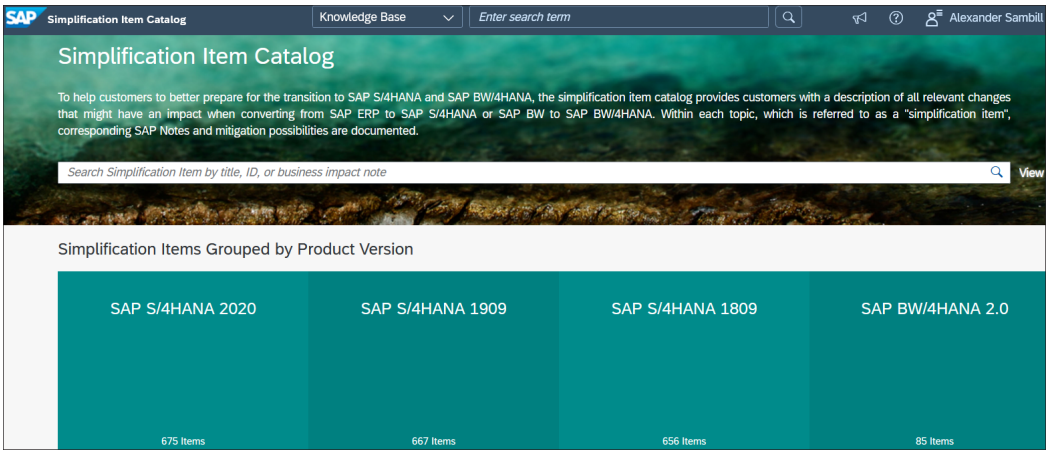


Figure 12.16 Simplification Item Catalog Initial Screen

Choose between the various SAP S/4HANA initial shipment stacks. After entering your source and target validity, you can search and filter for the target simplification item information like the business impact SAP Note or other hints. Then, you can download this content into a .zip file and upload it into the simplification item check through the report /SDF/RC_START_CHECK via Transaction SE38, as shown in Figure 12.17.

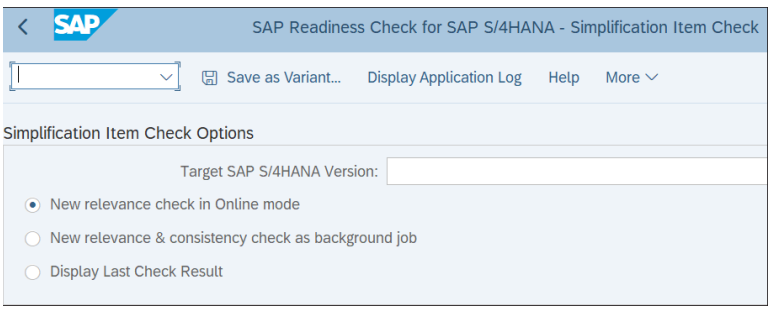


Figure 12.17 SAP Simplification Item Check via Transaction SA38

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Run this report for the following two purposes:

- Run the report on your current SAP ERP system to prepare for a system conversion to SAP S/4HANA.
- Run the report on your SAP S/4HANA system to prepare for a release upgrade to a higher SAP S/4HANA release.

On one hand, within this tool, you can use the relevance check to evaluate the functional and technical impact of an SAP S/4HANA system conversion on your current system. On the other hand, using the consistency check helps you identify data inconsistencies or missing preparation activities that could lead to a failed system conversion. Note that the simplification item check is intended for analyzing the backend, not the frontend, and thus, you won't run the report on an SAP Fiori frontend server.

This approach based on the simplification list provides detailed information about application areas, including descriptions, sources, changes, available checks, and related SAP Notes. Thus, you can clearly determine potential business process-related impacts. The simplification item catalog can serve as the single source of truth for all simplification items. You can use this data, combined with the results of SAP Readiness Check, as an overview of all integrated check results. This holistic output helps you evaluate, define, and adjust your next steps in the SAP S/4HANA migration based on your system settings.

Hint

SAP Notes 2399707, 2182725, and 2502552 contain some helpful information about the processing of the simplification check.

12.6.4 SAP Readiness Check

Use SAP Readiness Check to evaluate your SAP ERP 6.0 system's readiness to move to SAP S/4HANA. This check is a consistency check provided by SAP for their customers. This check shows whether your system requirements and related add-ons and other components are ready for an SAP S/4HANA migration. Therefore, an essential task to following the introduction and instructions in SAP Note 2913617. This SAP Note provides the basic setup needed to perform SAP Readiness Check for SAP S/4HANA and contains answers to frequently asked questions.

Hint

Please note that, for an SAP S/4HANA upgrade, you must follow the instructions in SAP Note 3059197.

Personal Copy for Arun Singal, arun.singal560@gmail.com

The following source releases are supported by the SAP Readiness Check for SAP S/4HANA:

- SAP ERP 6.0 enhancement packages (EHPs) 0 to 8
- SAP S/4HANA Finance 1503 and 1605 (technically based on SAP ERP 6.0 EHP 7 and 8)

Table 12.11 provides an overview of SAP Readiness Check 2.0, including the required steps for a comprehensive analysis of your SAP S/4HANA migration options.

ID	Step Description	SAP Note Recommendation
1	Implementation of the required SAP Notes	2913617
2	Custom code analysis	2185390
3	Running the SAP HANA sizing report	1793345/1872170
4	Simplification item check	2399707
5	SAP business process analytics analysis	2745851
6	IDoc analysis	2769657
7	Data volume management analysis	2612179
8	SAP Readiness Check for SAP S/4HANA execution	2758146
9	Importing and evaluating the SAP Readiness Check system data, available at *http://s-prs.co/v203605*	–

Table 12.11 SAP Readiness Check 2.0 Processing Overview

Hint

You can also use the guided SAP Readiness Check tool available at *http://s-prs.co/v203606*. At this website, you can choose between **SAP Readiness Check for SAP S/4HANA**, **SAP Readiness Check for SAP S/4HANA Upgrades**, and **SAP Readiness Check for SAP BW/4HANA**.

12.6.5 SAP Best Practices Explorer

SAP Best Practices Explorer contains best practices information from SAP, including items for SAP S/4HANA. This resource is free of charge, and you can use SAP Best Practices Explorer to access essential technical and process information. Primarily, the scope in SAP Best Practices Explorer covers SAP S/4HANA Cloud; SAP S/4HANA Cloud (EX); and SAP S/4HANA, as shown in Figure 12.18.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

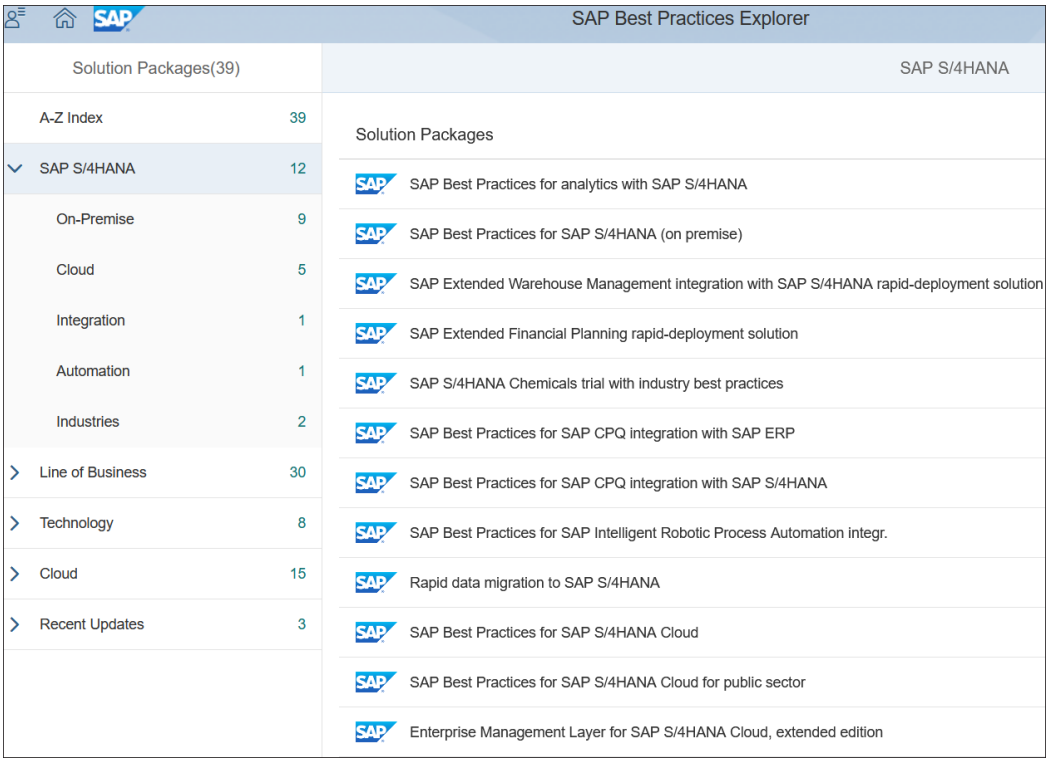


Figure 12.18 SAP Best Practices Explorer for SAP S/4HANA

You can access SAP Best Practices Explorer at *https://rapid.sap.com/bp* and then select your deployment, scope item, and business process. Then, you can download a "test script" to access the recommended SAP business role templates for individual processes. Another option is the **Accelerators** process register, which offers you the opportunity to download the complete process documentation for one solution, with related process steps, business roles, apps, and APIs. Under the **Register** tab, you'll also find all software and delivery requirements.

12.6.6 SAP S/4HANA Migration Cockpit

Another significant task within your SAP S/4HANA transition project is your data migration. Formerly, you could use the SAP S/4HANA migration cockpit to validate and migrate your existing master data and transaction data to your SAP S/4HANA or SAP S/4HANA Cloud system. With SAP S/4HANA 2020, the SAP S/4HANA migration cockpit is available in display-only mode through Transaction LTMC. Thus, you can display existing migration projects, but you cannot create new ones. Therefore, to accomplish your data migration task, you must use the Migrate Your Data app (ID F3473) in SAP Fiori, as shown in Figure 12.19.

Personal Copy for Arun Singal, arun.singal560@gmail.com

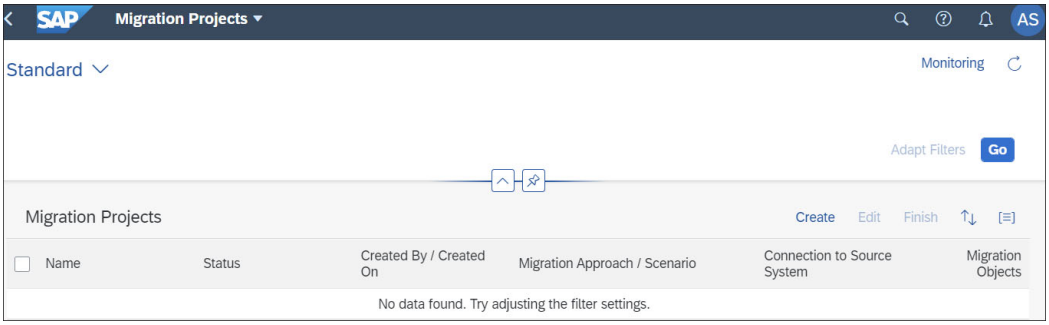


Figure 12.19 Migrate Your Data App

The easiest way to access this app is by assigning the SAP role SAP_BR_CONFIG_EXPERT_DATA_MIG to the migration administrators. This tool allows new and current customers to transfer their data from an SAP ERP 6.0 or non-SAP system to SAP S/4HANA. The SAP S/4HANA migration cockpit is the successor of the legacy system migration workbench (Transaction LSMW).

Hint

An end user needs specific roles to work with the SAP S/4HANA migration cockpit and transfer data. For SAP S/4HANA, these required roles are roles SAP_CA_DMC_MC_USER and SAP_BR_CONFIG_EXPERT_DATA_MIG for the frontend server. Tole SAP_CA_DMC_MC_DEVELOPER is required to use the SAP S/4HANA Migration Object Modeler (Transaction LTMOM).

For SAP S/4HANA Cloud, an end user also needs the administrator role SAP_BR_CONFIG_EXPERT_DATA_MIG and the corresponding role for each migration object, like SAP_BR_CASH_MANAGER for the bank migration object.

See SAP Notes 2481235 and 2733253 for further information and FAQs.

12.6.7 Custom Code Validation

Nowadays, security is no longer only an optional provision for IT systems. Your custom applications written in ABAP are primary targets for internal and external threats. Custom developments might have high-risk security flaws. Insufficient SAP standard AUTHORITY-CHECK statements and BAPIs within custom programs can exacerbate security vulnerabilities because they often provide unintentional system access. Besides, some applications might be obsolete with the new product line because SAP provides many novel practical functions in its SAP S/4HANA standard. Furthermore, your system might contain many custom development objects that are not in use anymore.

Thus, you should consider your custom developments when migrating to SAP S/4HANA and identify code that must be updated, or you can replace these applications

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

with standard functionalities. Therefore, check your programs for standard compliance, convertibility, and usefulness. SAP provides some tools for these compatibility- and security-related checks, such as the ABAP test cockpit or the code inspector.

Table 12.12 lists a few helpful SAP Notes you should explore during your custom code validation. Another handy information source is SAP's "Custom Code Migration Guide for SAP S/4HANA" guideline.

SAP Note	Short Description
2436688	Recommended SAP Notes for using SAP S/4HANA Custom Code Checks in the ABAP test cockpit or the Custom Code Migration App
2190420	SAP S/4HANA: Recommendations for Adaption of Customer Specific code
2241080	SAP S/4HANA: Content for Checking Customer Specific Code
2296016	SAP S/4HANA Custom Code Adaption - Removal of Orphaned Objects
1885926	ABAP SQL Monitor
1912445	ABAP Custom Code Migration for SAP HANA - Recommendations and Code Inspector Variants for SAP HANA Migration

Table 12.12 SAP Notes for SAP S/4HANA Custom Code Validation

Hint

You can turn on the ABAP Call Monitor (Transaction SCMON) in your PRD for housekeeping and for eliminating unused custom code in business applications. In this way, you can determine which custom ABAP objects are in use by your users based on your current business processes. This monitoring feature has no impact on the performance of your SAP system.

To analyze your SAP S/4HANA custom code, SAP recommends the ABAP test cockpit with its ability to conduct remote code analysis. You can enter the initial screen in Transaction ATC, as shown in Figure 12.20. This application offers a centralized validation tool for static functional checks, security code checks, and performance checks. Moreover, you can combine this analysis with the checks and variants of the code inspector (Transaction SCI). Thus, the ABAP test cockpit offers various scan features, including the following capabilities:

- You can use exemptions to suppress false-positive statements.
- The enhanced data flow analysis reduces false-positive findings.
- The ABAP test cockpit provides various developer analysis features like syntax check, ABAP dictionary check, SAP S/4HANA custom code check, and ABAP Unit.

Personal Copy for Arun Singal, arun.singal560@gmail.com

- The ABAP test cockpit also offers quality assurance features, like quality gates, exemptions, and mass regression tests, to reduce production errors to a minimum.
- Integration into the development infrastructure through the SAP GUI or Eclipse-based ABAP Development Tools is possible.
- You can remotely scan multiple systems from one central system.
- The ABAP test cockpit enables the prioritization of checks and also extensive documentation.
- You can use the baseline integration for your ABAP test cockpit results and point out new findings.

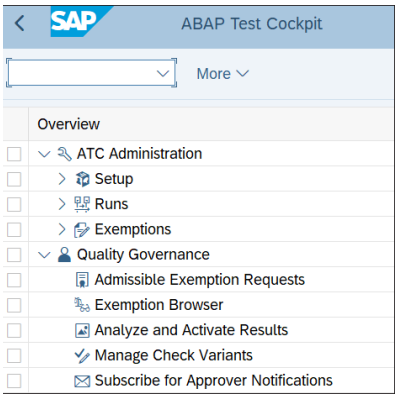


Figure 12.20 ABAP Test Cockpit Initial Screen

This tool provides many predefined checks for your code migration to SAP HANA and SAP S/4HANA. Therefore, run the check variant S4HANA_READINESS_REMOTE in the ABAP test cockpit to check all the items of the simplification list. You can use specific check variants (e.g., S4HANA_READINESS_1909 or S4HANA_READINESS_2020) by clicking the **Manage Check Variants** button to validate your custom code against the simplification items relevant to your target SAP S/4HANA release.

Hint

To learn more about this powerful tool, see SAP Note 2436688, which provides all the required information. Moreover, SAP Notes 2812556 and 2959341 explain how to get the S4HANA_READINESS_1909 and S4HANA_READINESS_2020 check variant into your central ABAP test cockpit check system.

In addition, the ABAP test cockpit offers the fee-based application SAP Code Vulnerability Analyzer. This static code scanning tool enables you to identify and fix your ABAP source code security weaknesses for the cloud environment. Since this tool is integrated into the ABAP test cockpit, you can start code scanning your developer applications like ABAP Development Tools or Transactions SE80 and SE38.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

As an alternative to the ABAP test cockpit, you can also use the code inspector directly for your compatibility checks for SAP S/4HANA.

You can start this application with Transaction SCI, which enables checks on repository objects and also several performance, security, or syntax checks. Moreover, this transaction covers an analysis of your existing custom developments for an SAP S/4HANA migration with several check variants starting with **S4HANA_READINESS**. First, you must enter a custom code migration variant, as shown in Figure 12.21. Then, you'll verify which custom code objects are still in use and create an **Object Set** for them. Next, you'll run the combination of object set and check variant. Finally, you can analyze your custom developments for their readiness for your SAP S/4HANA migration.

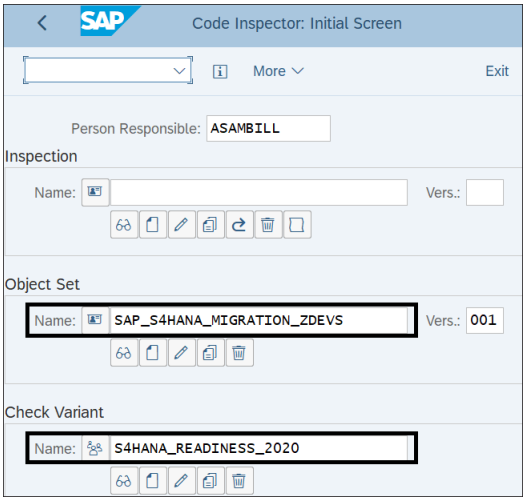


Figure 12.21 Code Inspector Initial Screen

Hint

See SAP Notes 2271900 and 2270689 for additional content on generating a code inspector variant or on using the remote function call (RFC) extractor for performing static checks.

12.6.8 Regulatory Requirements and Compliance

Typically, an SAP security administrator runs various periodic system analyses to fulfill risk and compliance regulations. The technical changes of SAP S/4HANA require a re-evaluation and adjustment of existing guidelines and rulesets for these analyses. Also, the simplification approach, business model consolidation, new processes, enhanced system architecture, and the SAP Fiori UI all affect your current business control mechanisms. Thus, you must validate the transition of these upcoming technical and business changes for your company's compliance infrastructure and monitoring.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Therefore, always ensure that your security resources are an integral part of your overall SAP S/4HANA migration project team. On one hand, you'll need to check whether your existing control system fits the new business settings, with the following considerations in mind:

- The new business partner approach affects your existing automatic and manual compliance controls.
- SAP S/4HANA Finance leads to new and changed invoice processing.
- The consolidation of Finance (FI) and Controlling (CO) from SAP ERP requires a remodeling of responsibility and control scenarios.
- The consolidation of multiple charts of accounts requires adjustment to end-user access.
- The principle of one and the integration of cloud solutions can also change and extend your business processing model.

On the other hand, the SAP S/4HANA migration significantly impacts more than only your core ERP functionalities but also your technical regulations integration and custom ruleset. You'll need to pay attention to quality assurance and compliance to governmental restrictions, branch-specific regulations, data protection, Good Manufacturing Practice (GMP) and good practice (GxP) requirements, release strategies, and internal guidelines. Implementing and modifying predefined rulesets into your new system through existing tools like SAP governance, risk, and compliance solutions (SAP GRC solutions) or third-party software might be necessary because an SAP S/4HANA-compatible ruleset should be available before starting your authorization migration and should also cover updated security requirements in this process. Thus, we recommend focusing on several technical security-relevant topics such as the following:

- The replacement and consolidation of applications affect your end-user authorizations.
- New and enhanced business processes and related upcoming regulation integrations require the renewal of your authorization concept.
- Centralize your authorization concept and integrate the database security and possible end-user access.
- Verify whether your end-user authorization fits a job function role concept and is compliant to present regulations.
- You might have to integrate new SAP Fiori authorization entities and cloud security for used cloud solutions into your existing authorization concept and monitoring as well.

Thus, the transition to SAP S/4HANA is an excellent opportunity to revise core processes, but your approach might be a holistic revision of your current Internal Control System (ICS) and thus potentially introduce new business risks. These considerations

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

also enable a realistic estimation of your SAP S/4HANA implementation or migration project.

Hint

One helpful tool to manage this issue is SAP Access Control. See Chapter 10 to get acquainted with its compliance approaches and learn how to handle the adjustment of your compliance architecture. Moreover, the Xiting Authorizations Management Suite (XAMS) offers a predefined ruleset to help you handle security topics like critical authorization and segregation of duties (SoD) monitoring, periodic analysis, the definition of custom checks, and the technical integration of business regulations.

12.7 Migrating Authorizations to SAP S/4HANA with Standard SAP Tools

Since the process-related and technical transition to SAP S/4HANA impacts your current roles and end-user authorizations, your authorization migration effort and how much you must invest in getting a running and secured SAP S/4HANA system depends on your role concepts quality.

The remodeling of your existing authorization concepts is a chance to perform a general procedural and technical cleanup since the new data model introduced in SAP S/4HANA removes numerous redundancies that render may legacy roles and authorizations incompatible. Therefore, make sure that you only use your former roles as starting points for the following guided procedure if they reflect exact job functions and approved processes and are created following the SAP standard-compliant role building approach. Otherwise, create new job function roles for your SAP S/4HANA authorization concept through a new role concept redesign. This task should be taken into account during your overall project planning.

Please note that the basis for your SAP S/4HANA migration should be one or more sandbox system(s): One system can be a copy of your PRD; another, a system for testing.

Hint

See "SAP Activate Methodology for Transition to SAP S/4HANA Roadmap-Viewer," available at *http://s-prs.co/v203614*, and "Conversion Guide for SAP S/4HANA," available at *http://s-prs.co/v203607*, for a holistic transition guideline for SAP S/4HANA.

In addition, SAP Note 2884313 contains helpful information and references to other SAP Notes for applying the feature package (FP) and support package (SP) stacks of SAP S/4HANA 2020.

Personal Copy for Arun Singal, arun.singal560@gmail.com

This section contains the main steps for your authorization migration using the SAP standard, focusing on the authorizations concept. New processes will need alignment, the architecture will need to be adjusted, or other activities will be required within the entire SAP S/4HANA transition, organized into consecutive or parallel project steps. Since the information in this section can only serve a general guideline, you should adjust and align the following content to your individual business needs, technical preconditions, and the deployment option you choose.

See Chapter 8 for essential information about SAP Fiori authorizations and integrating its new entities into your role concept.

12.7.1 Project Administration and Basis Activities

Due to the technical, organizational, and procedural project complexity, project management should initially clarify all applicable policies, processes, and responsibilities. An overview of the organization, its employees, and their job functions is important as well.

In general, before starting the authorization migration, you must finish (or at least determine the preparation steps as described in Section 12.6) for an SAP S/4HANA transition. This preparatory work also includes building a sandbox, installing the required migration and business tools, system customizing, custom code migration, and other project considerations, which can form the following three pillars:

- **Organizational aspects**
  The project's organization is necessary to initially clarify coordination and procedural aspects and their requirements as well as enable project tracking and progressing monitoring. Thus, we recommend keeping the following considerations in mind:
  - Determine the authorization project's declaration for the authorization migration as an official subproject supported by the management (top-down instruction) within the entire SAP S/4HANA transition.
  - Staff the project organization, define communication structures, and set recurring status meetings.
  - Create a rough timeline or phase plan for structuring and controlling the project.
  - Define persons from IT and business departments and specify responsibilities to determine objectives, needs, and role content.
  - Determine naming convention for users and roles.
  - Define milestones, procedures, and schedules for the delivery of results:
    - Plan an information event for stakeholders (kick-off).
    - Clarify contact persons from IT and the business departments.
    - Consider further dependencies like planned IT revisions or new software integrations.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

- Schedule meetings to clarify business department needs and job functions by end user to identify the affected roles for each department.

- **Technical aspects**
  The functional technical basis for your project is fundamental to starting your migration. Otherwise, you might suffer project interruptions from missing or inoperable system setups. Thus, we recommend keeping the following considerations in mind:
  - Determine all technical SAP S/4HANA requirements for your system landscape and also set up a sandbox system for your migration.
  - Obtain information about your system landscape overview and release plans like planned SAP upgrades for the affected systems.
  - Clarify system dependencies like it has for SAP GRC solutions, SAP Identity Management (SAP ID Management), job management, or third-party tools.
  - Specify the project scope, which should contain relevant roles, users, scenarios, and departments. Please note that you should only consider active end users and their assigned job function roles to reduce the overall migration effort.
  - Check the deployment options, system requirements, and product UIs for required SAP Fiori applications to enable the end-user SAP Fiori UI. See some additional information in SAP Note 2590653.
  - Verify the availability of necessary SAP Fiori business catalogs, groups, spaces, and pages. Also, consider required the ICF and OData services.
  - Coordinate the amendments and guidelines for your technical transition centrally.

- **Process aspects**
  While performing your migration, you must stay secure and compliant with your internal and external regulations, including end-user, role, transport, change, or third-party tools management. Thus, we recommend keeping the following considerations in mind:
  - Consider various change request processes, like collective orders in a ticket system or change management as a project reference.
  - Manage transports (customizing and workbench requests) in a compliant way. Also, take transport routes or dependencies on other system clients through import automation into account.
  - Clarify the user and role administration approach and whether it is centralized (working with central user administration [CUA] or SAP ID Management) or decentralized (each system).
  - Determine the responsibilities for SAP Fiori administration.
  - Involve cooperation with and the integration of Basis administrators or other service providers in your project steps.

Personal Copy for Arun Singal, arun.singal560@gmail.com

– Clarify the handling of high-risk or extended authorization assignments in the project's course. For instance, you can use Xiting Times as an emergency access management (EAM) solution.

12.7.2 Analyzing Current Role Concepts

Before the project starts, the first authorization migration check is the analysis of your current role concept's quality and validity. This dimension means checking whether the roles fit end-user business demands, job functions, security levels, and technical preconditions for a direct SAP S/4HANA migration. An extensive role and end-user evaluation enables you to reduce your unnecessary functional extent in your roles and enhances the simplification effort. You'll also reduces the risk that your current role concept becomes a roadblock in your migration project. Moreover, this analysis is a precondition for upcoming consultations in business department workshops where you'll discuss SAP S/4HANA's process-related and technical changes with key stakeholders.

In the following sections, we'll introduce you to the role concept's preconditions and provide some analysis to help you determine your individual authorization migration path.

Essential Considerations for a Standard-Compliant Authorization Migration

The best case for a smooth and straightforward SAP S/4HANA migration is a standard-compliant authorization migration. This approach is possible if your current authorization concept is based on authorization default values and process-related business requirements. For an initial verification of these preconditions, you'll need to be able to answer "Yes" to most of the following questions:

- Have you completely avoided any manual authorizations, especially manual start authorization objects, within your business roles? (Important!)
- Have you completely avoided any ranges for values in start authorization objects, like S_TCODE or S_SERVICE?
- Are you using authorization default values?
- Are your custom developments entirely maintained in Transaction SU24?
- Are you working with the role menu via Transaction PFCG?
- Do you work with the SAP Best Practices role inheritance concept, if required for organizational access?
- Have you completely avoided manual authorization profiles for all your end users?
- Have you completely avoided manual authorization profiles for all your technical users?
- Does your existing authorization concept follow the least privilege principle (need-to-know principle)?

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

If you cannot respond to most of these questions positively (with a "Yes"), you can only perform a technical authorization conversion or an upstream role concept redesign in a brownfield approach. Otherwise, we highly recommend following a greenfield approach to create a new authorization concept from scratch. These considerations not only concern your upcoming migration effort and approach but can also help you evaluate the robustness of your existing role concept. If you migrate roles that provide access that is too far-reaching, riddled with critical authorization and SoD issues, you'll dramatically increase your required migration effort and reduce your overall system security.

Hint

According to specific authorizations (e.g., for SAP Solution Manager) or cost center and profit center reporting, manual authorizations might be necessary (value role concept), but even the standard might be sufficient. For typical business roles, however, using manual authorizations is not recommended.

Validating the Authorization Objects

To enable a suitable matching between your current role concept and simplification list changes, you'll need an overview of the objects included in your role menus. Therefore, launch Transaction SE16 and enter table **AGR_TCODES**. Enter your roles' naming convention, execute, and you'll see a list of all transactions within your roles (**AGR_NAME**) to verify the transactional contents of your roles, as shown in Figure 12.22. In general, you'll validate your template roles because they transmit their functional extent to their derived roles.

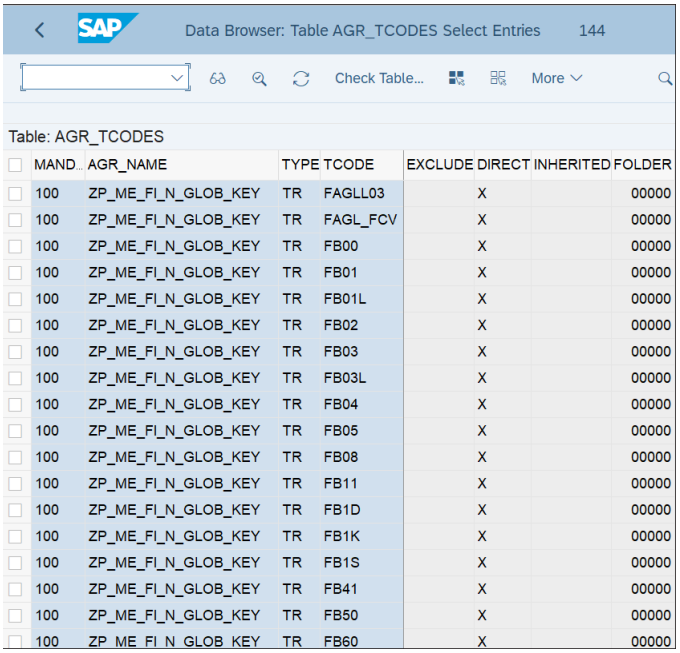
This approach is only suitable if you already have a standard-compliant and sustainable role concept based on job functions with integrated usage data. If you did not maintain your roles via the role menu, but instead with manual values in authorization object S_TCODE, table AGR_TCODES does not show you any results.

Moreover, you can analyze table AGR_1251 for all start authorization objects (like S_TCODE, S_SERVICE, S_START, or S_RFC) for more extensive information about required application starts you might need to compare and consider for your SAP S/4HANA authorization migration project, as shown in Figure 12.23.

Especially for a technical conversion and manual S_TCODE authorization objects, you'll need to analyze the S_TCODE authorization objects of your existing roles via table AGR_1251.

Regardless of whether you are following the standard-compliant migration or technical conversion option, you should also integrate an analysis for authorization object S_SERVICE to check Web Services activities as well as analyze authorization object S_START for Web Dynpro applications.

Personal Copy for Arun Singal, arun.singal560@gmail.com



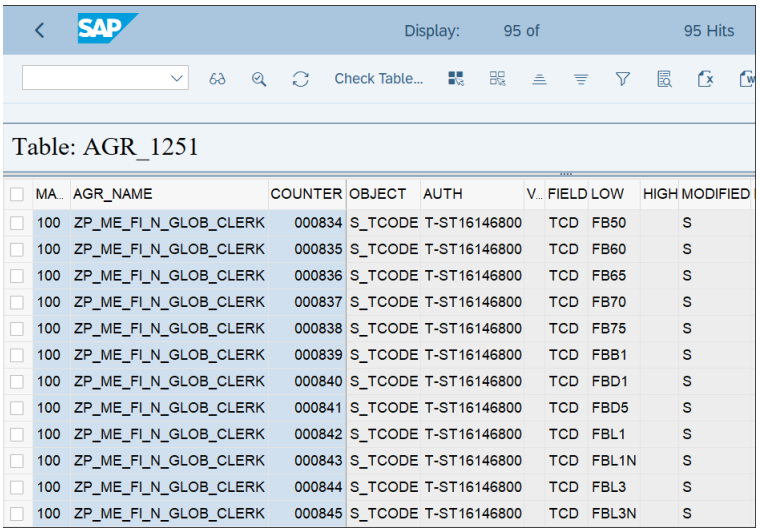
Data Browser: Table AGR_TCODES Select Entries 144

Check Table... More

Table: AGR_TCODES

MAND	AGR_NAME	TYPE	TCODE	EXCLUDE	DIRECT	INHERITED	FOLDER
100	ZP_ME_FI_N_GLOB_KEY	TR	FAGLL03		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FAGL_FCV		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB00		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB01		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB01L		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB02		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB03		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB03L		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB04		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB05		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB08		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB11		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB1D		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB1K		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB1S		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB41		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB50		X		00000
100	ZP_ME_FI_N_GLOB_KEY	TR	FB60		X		00000

Figure 12.22 Table AGR_TCODES Output List



Display: 95 of 95 Hits

Check Table...

Table: AGR_1251

MA...	AGR_NAME	COUNTER	OBJECT	AUTH	V...	FIELD	LOW	HIGH	MODIFIED
100	ZP_ME_FI_N_GLOB_CLERK	000834	S_TCODE	T-ST16146800		TCD	FB50		S
100	ZP_ME_FI_N_GLOB_CLERK	000835	S_TCODE	T-ST16146800		TCD	FB60		S
100	ZP_ME_FI_N_GLOB_CLERK	000836	S_TCODE	T-ST16146800		TCD	FB65		S
100	ZP_ME_FI_N_GLOB_CLERK	000837	S_TCODE	T-ST16146800		TCD	FB70		S
100	ZP_ME_FI_N_GLOB_CLERK	000838	S_TCODE	T-ST16146800		TCD	FB75		S
100	ZP_ME_FI_N_GLOB_CLERK	000839	S_TCODE	T-ST16146800		TCD	FBB1		S
100	ZP_ME_FI_N_GLOB_CLERK	000840	S_TCODE	T-ST16146800		TCD	FBD1		S
100	ZP_ME_FI_N_GLOB_CLERK	000841	S_TCODE	T-ST16146800		TCD	FBD5		S
100	ZP_ME_FI_N_GLOB_CLERK	000842	S_TCODE	T-ST16146800		TCD	FBL1		S
100	ZP_ME_FI_N_GLOB_CLERK	000843	S_TCODE	T-ST16146800		TCD	FBL1N		S
100	ZP_ME_FI_N_GLOB_CLERK	000844	S_TCODE	T-ST16146800		TCD	FBL3		S
100	ZP_ME_FI_N_GLOB_CLERK	000845	S_TCODE	T-ST16146800		TCD	FBL3N		S

Figure 12.23 Table AGR_1251 Output List

Another suitable analysis approach is to use Transaction SUIM (User Information System) and its available reports like **Roles by Complex Selection Criteria** or **Users by Complex Selection Criteria**. In this way, you can also get the required data, but the data browser in Transaction SE16(N) is easier and faster.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

If you see hash values for authorization object S_SERVICE in table AGR_1251, copy and search for these values in table USOBHASH (entering the hash values in the field name of initial the selection mask), which will show you the correct clear name of the Web Service.

Analyzing the Transaction Usage

Besides matching your current role concept with the changes from the simplification list, you can use this phase to evaluate the quality of your roles. You should adjust your current role concept to correlate with the real business usage of your end users. This approach applies a clear focus on business processes and prevents unnecessary application assignments to predefined job profiles, thus also reducing your migration effort.

Hint

You can also use Transaction ST03N data as a valid data basis if this data is collected from different systems with varying business processes. Even though you may have new user IDs in one SAP S/4HANA system or need to integrate the various processes, you can still have a solid historical data basis to inform your business unit discussions and harmonize and centralize your processes with SAP S/4HANA.

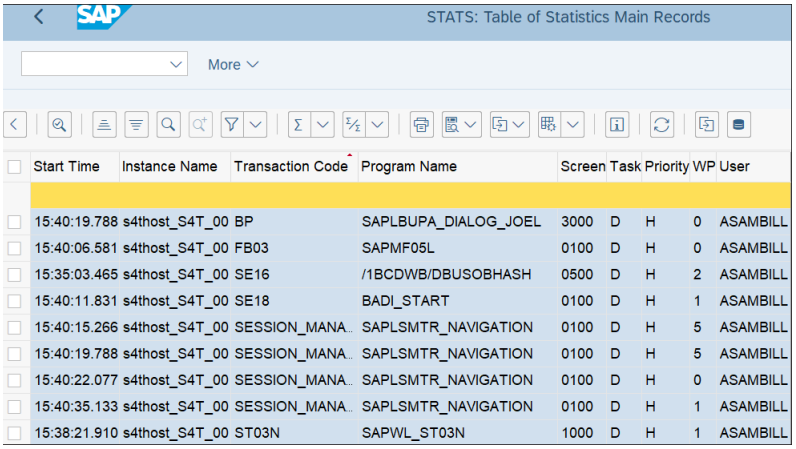
For this purpose, you can use Transaction ST03N to check transactional, job-related end-user usage data to assess each job function's required access. Initially, you can use existing SAP ERP 6.0 data records, but then you'll still need to handle SAP S/4HANA gaps afterward. Thus, perform this evaluation during your integration test on the SAP S/4HANA system once again to see whether your current role concept fits the new business requirements. For transaction usage analysis, launch Transaction ST03N. Execute the Business Transaction Analysis report, available in the **Detailed Analysis** section. Select a key user, select all transactions (*), and specify a monitoring interval within 100 hours. Then, you'll see a technical overview of the transaction codes used in this period, as shown in Figure 12.24. If you are consolidating more than one system, you must combine the end-user usage data from each system into one consolidated mapping file.

Hint

Please note that you can find any OData service calls that are necessary by using SAP Fiori apps in Transaction ST03N since Basis version release 7.55 for SAP S/4HANA. The usage data also contains other menu objects like transactions, function modules, or Web Dynpro applications.

See Chapter 9, Section 9.13, to get the required information using Transaction ST03N.

Personal Copy for Arun Singal, arun.singal560@gmail.com



Start Time	Instance Name	Transaction Code	Program Name	Screen	Task	Priority	WP	User
15:40:19.788	s4thost_S4T_00	BP	SAPLBUPA_DIALOG_JOEL	3000	D	H	0	ASAMBILL
15:40:06.581	s4thost_S4T_00	FB03	SAPMF05L	0100	D	H	0	ASAMBILL
15:35:03.465	s4thost_S4T_00	SE16	/1BCDWB/DBUSOBHASH	0500	D	H	2	ASAMBILL
15:40:11.831	s4thost_S4T_00	SE18	BADI_START	0100	D	H	1	ASAMBILL
15:40:15.266	s4thost_S4T_00	SESSION_MANA...	SAPLSMTR_NAVIGATION	0100	D	H	5	ASAMBILL
15:40:19.788	s4thost_S4T_00	SESSION_MANA...	SAPLSMTR_NAVIGATION	0100	D	H	5	ASAMBILL
15:40:22.077	s4thost_S4T_00	SESSION_MANA...	SAPLSMTR_NAVIGATION	0100	D	H	0	ASAMBILL
15:40:35.133	s4thost_S4T_00	SESSION_MANA...	SAPLSMTR_NAVIGATION	0100	D	H	1	ASAMBILL
15:38:21.910	s4thost_S4T_00	ST03N	SAPWL_ST03N	1000	D	H	1	ASAMBILL

Figure 12.24 Transaction ST03N Usage Data Evaluation

12.7.3 Upgrading and Maintaining Authorization Default Values

According to your authorization concept and role creation, staying standard-compliant is one of the essential prerequisites for any SAP Business Suite solution, but especially for SAP S/4HANA and its technical fundamentals. By implication, your roles must not contain manual authorization objects. It is also necessary to have consistent authorization data that is up to date with your technical release upgrades. Otherwise, migrating your authorization concept based on program source code is impossible. Therefore, you must work with Transactions SU24 and SU25. Also, continuously maintain all necessary authorization objects for custom developments in Transaction SU24 to enable sustainable role maintenance for custom code. Since the authorization default values and related check indicators are the backbones of your entire authorization concept, you must ensure you fulfill the following preconditions, as shown in Figure 12.25:

- You have initially imported Transaction SU22 data into Transaction SU24 in your sandbox system (Transaction SU25, step 1).
- You have checked your system for new SAP proposal data, and if required, imported them through Transaction SU25 (Transaction SU25, steps 2a through 2d).
- You have transported your Transaction SU24 data from the sandbox development system (DEV) to the subsequent quality system (QAS) layer if required, and a linear sandbox system layer concept (of DEV, QAS, and PRD) also exists (Transaction SU25, step 3).

This maintenance step enables sustainable and secure role creation using the SAP standard mechanism. Now, if you create and maintain your roles via the role menu in Transaction PFCG, the system automatically imports all related authorization objects, fields, and values for the targeted application into the role's authorization profile.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

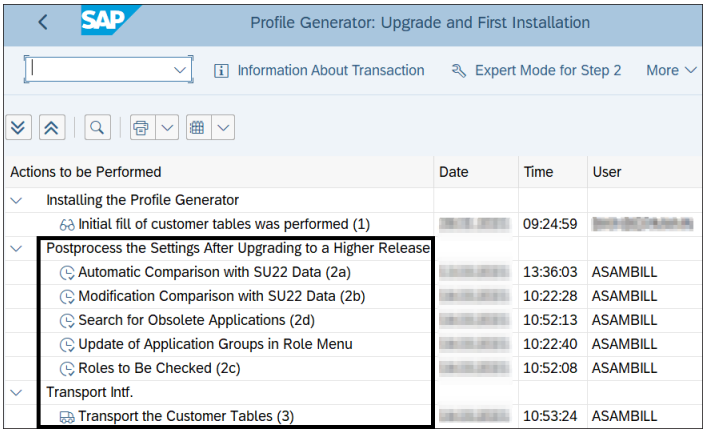


Figure 12.25 Transaction SU25 Upgrade Steps

For updating a role's authorization profile, a best practice is always to use the profile generator's expert mode option, **Read old status and merge with new data**. In this way, you'll integrate updated proposals into your role profiles.

Hint

If you perform the proposal upgrade step via Transaction SU25 (after evaluating and defining your SAP S/4HANA job function roles based on the business's functional requirements), you might reduce your upgrade effort. Filter for all adjusted role menu objects and enter them in the selection screen of the **Expert Mode for Step 2** in the header bar, shown in Figure 12.25. In this way, you can focus on only the required applications during your upgrade process. This filtering capability is also suitable with Transaction SU25, step 2b.

This possible upgrade simplification strongly depends on the current quality and business process coverage rate (in SAP S/4HANA) of your current authorization concept.

If your system contains new Transaction SU22 data through a new SAP release, always update your systems proposal data with Transaction SU25. This upgrade activity enables up-to-date Transaction SU24 data. Furthermore, continuously maintain your proposal data and optimize them for your business processes. These maintenance activities significantly reduce your role and end user administration effort.

Hint

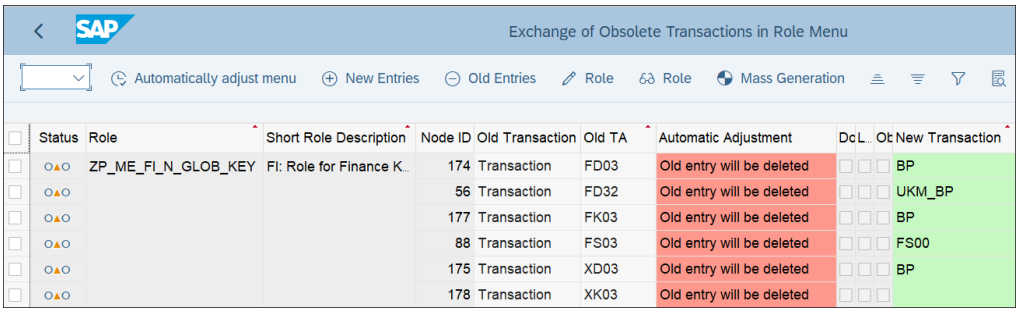
For more information about proposals, see Chapter 5.

Personal Copy for Arun Singal, arun.singal560@gmail.com

12.7.4 Analyzing SAP S/4HANA-Related Role Changes

After validating the quality of your roles, you must compare your business role requirements, like transactions, against the changes for SAP S/4HANA. The main information base is the simplification list, which shows you all changes required with SAP S/4HANA in detail. SAP provides many different ways to explore these shifts. You can use the standard .pdf list extracted from SAP Help Portal, the simplification item check, or SAP Best Practices Explorer. Even if this analysis of role changes is only a part of a larger preparatory activity, verify the process-related and technical role changes through business unit workshops. Thus, you can always stay up to date with this comparison of your current SAP S/4HANA release for all role menu objects like transactions, function modules, or Web Dynpro applications. Extensive changes might be required from one release to another. Every time you upgrade your existing SAP S/4HANA release, you may need to cover new functions and new authorizations. This analysis enables you to check for obsolete transactions in your role menu as well.

For this analysis, launch Transaction SU25 and execute step 2d. You'll see an output list of the exchange, as shown in Figure 12.26. Extract these results and enhance them with information from other simplification sources.



Status	Role	Short Role Description	Node ID	Old Transaction	Old TA	Automatic Adjustment	Dc	L...	Ot	New Transaction
	ZP_ME_FI_N_GLOB_KEY	FI: Role for Finance K...	174	Transaction	FD03	Old entry will be deleted				BP
			56	Transaction	FD32	Old entry will be deleted				UKM_BP
			177	Transaction	FK03	Old entry will be deleted				BP
			88	Transaction	FS03	Old entry will be deleted				FS00
			175	Transaction	XD03	Old entry will be deleted				BP
			178	Transaction	XK03	Old entry will be deleted				

Figure 12.26 Exchange of Obsolete Transactions in the Role Menu

Note that this list does not always cover replacement applications, and thus, you should use this list only as another information source. Otherwise, you might have massive gaps in functional extent of your roles and fail to meet some requirements if you rely solely on this list for your entire role concept.

As a part of your role change considerations-, validation should integrate SAP Fiori as well. For this goal, use the SAP Fiori apps reference library to determine whether this UI might be mandatory for specific job functions or duties. The SAP Fiori apps reference library also shows replacements for traditional transactions. For instance, you can directly enter a traditional transaction to find its related SAP Fiori app(s). In this way, you can estimate further needs and steps like required technical preconditions, job function validity, or business requirements. Another option is using the SAP Fiori Apps Recommendations Report as an additional data source to map your transactions to SAP Fiori apps.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

You can access the SAP Fiori Apps Recommendations Report at *http://s-prs.co/v203608*.

12.7.5 Evaluating and Defining Job Function Roles

Based on your Transaction ST03N data and analysis of your role, you can now arrange meetings with your business departments to share and validate your technical results. This necessary step involves consulting your business users, including key users, process owners, or application managers, to include both technical and business demands. In these meetings, you should discuss possible reductions or additions to the functional extent of relevant roles. This discussion can lead to an evaluation of the validity of job functions concerning SAP S/4HANA and the integration of new processes and responsibilities. Also, you might discover that you need to create new end-user roles to cover the expected changes.

Hint

A job profile or job function contains all necessary transactions (or other menu objects) and related authorizations to perform the necessary job-related activities. A classic example of job functions are accounts payable and accounts receivable and their differentiation. You should also differentiate between display-only access, master data administration, and access to accounting transaction data. With these in mind, you can prevent ICS conflicts on the role level, including SoD or other critical access issues.

In these workshops, focus on the results of your technical analysis of the roles assigned to active end users of each business unit. Clarify your approach with the following questions:

- How do you deal with transactions that are no longer available with SAP S/4HANA?
- Are there extensions or reductions of existing roles with transactions or SAP Fiori applications required?
- Does SAP S/4HANA require process adaptations, and what influences the current or new job function roles?
- Is there an interest in the use (or an associated need) of implementing entirely new SAP S/4HANA functionalities?

The main goal of these business interviews goal is to articulate a potential SAP S/4HANA role concept that is correlated to end users and their job functions. These workshops involve direct interaction between IT and business departments and thus enable both a top-down approach and a bottom-up approach for developing your authorization concept.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

The top-down approach means you'll integrate business needs into the technical role and end-user concept, that is, from the business down to the system.

In contrast, the bottom-up approach focuses on technical data, like Transaction ST03N data, to integrate various authorization restrictions, SAP Fiori entities, and custom developments. Thus, you are collecting technical data and possibly restrictions as preconditions and the basis for business workshops, thus, going from the system up to the business. See Chapter 3 for more detailed information about different role concepts and approaches.

Consider working with SAP Best Practices Explorer and its business role templates if you cannot estimate all the required SAP S/4HANA changes for your business. You'll find these templates in Transaction PFCG, starting with SAP* and with the string "_BR_" in their role names, as shown in Figure 12.27.

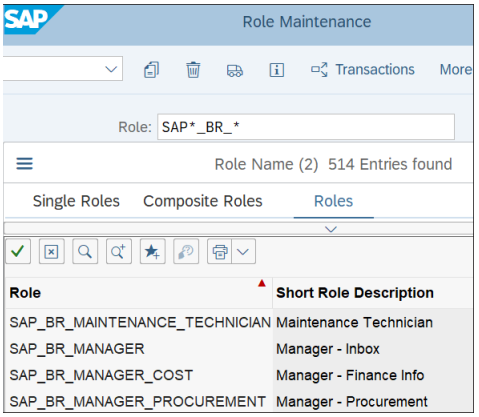


Figure 12.27 SAP Business Roles in Transaction PFCG

Also, use all collected technical information like the usage date, role changes due to the simplification list, or risk analysis to achieve a sustainable and secure role concept with all integrated business demands.

After you have figured out your company's matrix of relevant job functions, related end-user roles, and their functional SAP S/4HANA extent, you can match them to the end users. The result can be a list with the SAP user ID, job function, department, and related roles with their menu objects.

Hint

Section 12.4 and Section 12.6.8 contain helpful information for these business workshops. As a security administrator, please note that you can only analyze technical

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

changes like new transactions but not process-related adaptions. The business units are responsible for this area and must provide you that information.

12.7.6 Transition and Enhancement of Roles for SAP S/4HANA

In this project step, you'll technically convert the approved SAP S/4HANA-related technical and business changes into your role concept. The role implementation and adjustment phase, which is based on your previous role analyses and workshops, starts now.

Adjustment of All Affected Roles

First, maintain all changes in the affected business roles within a standard-compliant migration. In this case, you must introduce new transactions and/or withdraw obsolete transactions or other role menu objects. Then, you'll probably need to maintain open authorization field values in your authorization profiles or deactivate authorization object instances if these authorization objects are not required. You can reactivate them later on if their requirements are later confirmed during testing phases. Consider also possible business and process changes during your authorization maintenance. Finally, generate each role profile.

Hint

Do not entirely withdraw existing transactions if they are replaced through the simplification approach. This approach reduces your maintenance effort because your current application proposals are also often required for the replacement transaction. In this way, you can reduce your authorization maintenance to a minimum by using your former authorization profiles. This approach is practicable when your business processes aren't completely new and you have existing authorization default values to work with.

If you've performed only a technical conversion so far, you did not (entirely) work with proposals. However, because SAP S/4HANA insists on more standard compliance and upgradability than SAP ERP 6.0, you must work with proposals. Thus, you must first capture the current status of your role profiles to save your maintained authorization values for existing roles, which might not consistently connect to the new proposal defaults. Therefore, copy the role profile name for each role, as shown in Figure 12.28. Then,you have to insert it again into the same role to save the current authorization profile extent and disable any automatic proposal changes but only for this current authorization maintenance extent.

Personal Copy for Arun Singal, arun.singal560@gmail.com

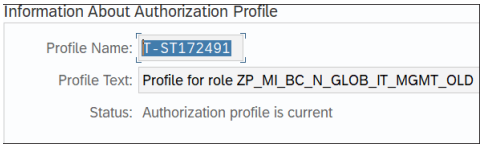


Figure 12.28 Copying a Role Profile Name

Then, enter the authorization profile and navigate to **More • Insert authorization(s) • From profile...** to introduce this profile in the same role manually, as shown in Figure 12.29. This step saves the entire status of your authorization profile.

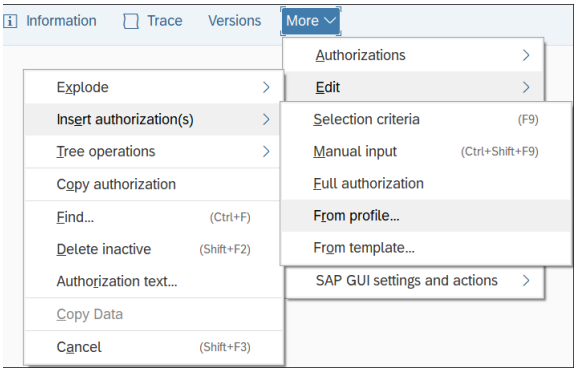


Figure 12.29 Introducing Role Profiles Manually

Please note that, in this way, you are inserting manual authorization objects without any application correlation, which is why a technical conversion is also considered a quick and dirty SAP S/4HANA transition. Next, you'll generate the role profile to fix your role's current authorization characteristics. Then, you can integrate into your role menus all the required applications based on your analyses (e.g., the simplification list and/or Transaction SU25 data) and based on approvals from your business units. Finally, you'll maintain the authorizations according to these business requirements and generate the role profile once again.

Integration of SAP Fiori

The SAP Fiori launchpad is necessary for all businesses moving to SAP S/4HANA. Therefore, a suitable approach is to adjust your existing basic global end-user role. This role mainly contains rudimentary SAP functions like Transactions SU53, SMX, SP02, SU3, or LAST_SHORTDUMP.

According to your SAP Fiori deployment option, you may require two roles (for each frontend and backend system) in a central hub deployment landscape. However, in the embedded deployment option, only one role is necessary, as shown in Figure 12.30.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

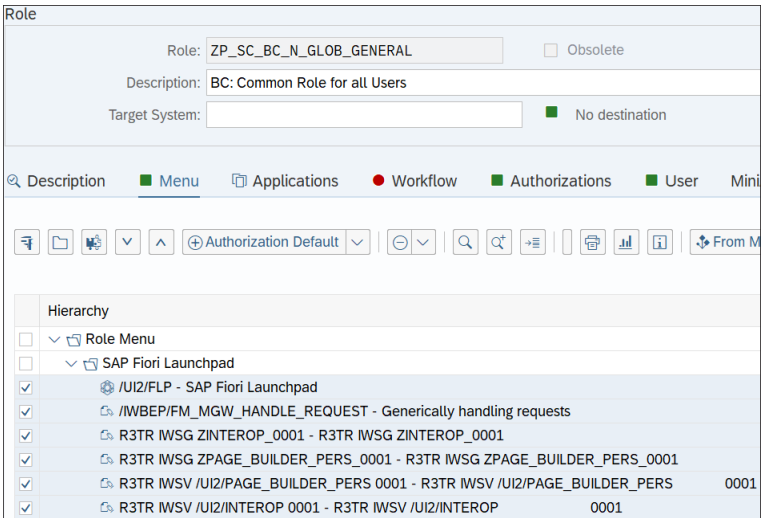


Figure 12.30 Basic Role Menu Objects Required for Using the SAP Fiori Launchpad

Table 12.13 lists the basic role menu objects to authorize end users for the SAP Fiori launchpad. However, you also should consider additional authorizations (e.g., for integrating the SAP Easy Access menu or SAP Fiori spaces, pages, and sections). Moreover, some of these objects might also require specific Transaction SU24 adjustments.

Layer	Role Menu Object	Description
Frontend	Transaction	/UI2/FLP
Frontend	OData service	/UI2/PAGE_BUILDER_PERS_0001
Frontend	OData service	/UI2/INTEROP_0001
Frontend	OData service	ZPAGE_BUILDER_PERS_0001
Frontend	OData service	ZINTEROP_0001
Backend	Function module	/IWBEP/FM_MGW_HANDLE_REQUEST

Table 12.13 SAP Fiori Launchpad Role Menu Objects

After this common end-user role adjustment, start maintaining the required SAP Fiori applications in your job function roles.

Hint

See Chapter 8 for detailed information about SAP Fiori, including what you must consider when authorizing and using SAP's enhanced UI.

Personal Copy for Arun Singal, arun.singal560@gmail.com

If you struggle with open or inactivate authorization fields during your authorization maintenance activities, contact your business departments. Do not maintain these values on your own if you're not sure. Instead, please ask your operators business-related questions to clarify the required authorization values and test these values first in a sandbox system.

12.7.7 Testing Your Authorization Concept

Testing enhanced and new roles is a significant step for a healthy go-live and suitable role concept going forward. According to your individual SAP S/4HANA deployment option choices, migration approach, processes, and new required business functions, you must adjust or re-create your entire authorization concept. Independently of the challenges you face, you may have only minimal useable references from a former SAP ERP system. Consequently, the SAP S/4HANA transition and the authorization migration require multiple test scenarios. You should divide your testing phase into three main test scenarios: function testing, integration testing, and user acceptance testing (UAT). You can still test your preapproved role concept in a sandbox system or on a QAS of the PRD line. Please note that authorization testing for SAP S/4HANA is an iterative process that might last months.

This section introduces you to the different best practice test scenarios and how you can implement your SAP S/4HANA authorization testing. We'll also explain the differences between function tests, integration tests, and user acceptance tests.

Hint

If you use SAP Fiori applications, you'll need to consider the different deployment options. With the central hub deployment option, you'll need to validate the roles in both your frontend and backend systems.

Function Tests

Since you generally can't use references from your former ERP system, your business, and SAP IT departments require an initial function test. This step requires that you've provided sufficient authorizations to your end users. Otherwise, they cannot explore and test the new processes and features. Therefore, the function test constitutes a basis for both business testing and IT testing to see the impacts of procedural and processing-related changes and to determine whether all systems settings and tools work as designed. Thus, this test is part of the discovery phase in SAP S/4HANA.

Please note that this phase is not mainly an authorization-related testing phase, but you, as a security administrator, must provide the necessary authorizations. For a comprehensive user experience (UX) during the functional tests and subsequent tests, extensive authorizations for all new SAP S/4HANA features are mandatory. The

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

SAP_APP role is your best option to guarantee this access. You can choose this role as an alternative to assigning the SAP_ALL profile to restrict system settings and critical company data access, like HR information. As the name implies, this role is a role for SAP applications. This standardized SAP role contains numerous necessary and extensive authorizations for the entire SAP S/4HANA system but does not provide SAP Fiori application access.

The system automatically generates this role if you start the report in Transaction SU25, as shown in Figure 12.31.

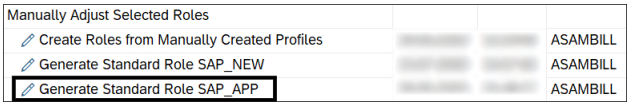


Figure 12.31 Generate Standard Role SAP_APP in Transaction SU25

Before you generate the role, you can customize its authorization extent. For instance, you can exclude **Basis** and **HR** authorization objects, as shown in Figure 12.32. You should not include any system- or personnel-relevant authorizations for business users, only administrators.

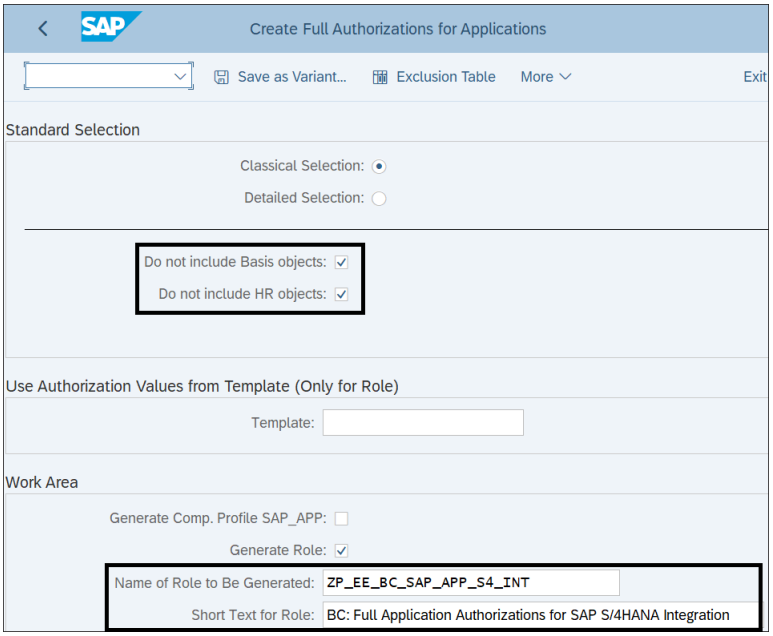


Figure 12.32 Generate Standard Role SAP_APP in Transaction SU25

At this moment, you can choose business-related template roles to serve as a foundation for various business SAP_APP roles. This differentiation is suitable but not absolutely required. A best practice is generating the SAP_APP role without SAP ERP Human

Personal Copy for Arun Singal, arun.singal560@gmail.com

Capital Management (SAP ERP HCM) and Basis authorizations. Then, you might have to evaluate the role's authorization profile against your internal and external regulations. Note that your sandbox system is mostly a copy of the PRD and, thus, also contains sensitive business data. Based on these restrictions, inactivate the critical authorization objects. Another essential step is to add the authorization objects S_TCODE (for transactions), S_SERVICE (for Web Services), and S_START (for Web Dynpro applications) with an asterisk (*) for full application access manually. Otherwise, end users cannot start any transactions or Web Services because the SAP_APP role only contains business authorizations when excluding **Basis** and **HR objects**. Please note that it is possible to add some further **Basis** authorization objects into the integration role authorization profile, like S_DATASET or S_ARCHIVE to cover further system functions for the end-users. You should also consider a separate SAP_APP role for the IT department without excluding **Basis** authorizations in the first run. Then, inactivate unnecessary authorization object in the integration roles to reduce the risk of unintentional access on the system.

This role enables full access to target applications during the initial function test without worrying about missing authorizations. Note that you'll have to clarify the end-user scope for these tests. A best practice is to enable key users or process owners, who will already have extensive authorizations and organizational access in their former roles. This approach prevents unintentional data access because the sandbox system contains productive data for testing and the SAP_APP role has wide-ranging authorizations.

Integration Tests

This test phase is essential to validate the new or adjusted authorization concept entirely. Predefined testers work with the changed or new SAP S/4HANA roles. In practice, the maturity of newly designed roles is not always optimal at first glance, or necessary business role assignments can be missing. Therefore, the integration test enables comprehensive evaluations of all new business processes with the approved job function roles, migrated custom developments, and novel SAP S/4HANA features. In addition, you can work with SAP standard tools like Transactions SU53, STAUTHTRACE, STUSERTRACE, STSIMAUTHCHECK, or STUSOBTRACE to analyze missing end-user authorizations within this test phase.

Hint

During the integration test, you should activate the user trace and use Transaction STSIMAUTHCHECK to simulate and compare your SAP S/4HANA roles with end-user test data. This testing approach enables direct role validation without test interruptions in contrast to the classic testing with predefined testing time slots and direct administration support during the entire tests. For more information about the different authorization analyzing tools, see Chapter 7.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The following list outlines some best practices to follow when implementing an integration test:

- **Test plan**
  A best practice is to differentiate the integration test into various test waves by business unit to focus on key users, process owners, or other specific end users. This separation means assigning the various target business users to different waves constituting similar business processes or organizational structures. Thus, waves symbolize different sets of specific users with similar business actions or duties. Do this planning in cooperation with your business departments and with other company test plans. Afterward, the varying waves of users should test new business roles and job functions. This wave-based testing is thus an iterative process in which end users might repeat tasks several times. For an SAP S/4HANA migration, we recommend repeating the entire authorization test sequence to have at least two integration test runs to establish a running system with appropriate authorizations for the new functions and processes.
- **Positive testing**
  As a preparation for authorization tests, testers may need instruction to perform only positive tests. Positive testing is a test type that describes the exact adherence of predefined actions or business processes to cover the entire operation's functions in the system. It is mandatory for the testers to do not look left and right in the system and check which other options are possible with the new business suite. This means the testers have to highly observe the defined test scenarios for the positive testing, so the IT can cover all required authorizations but not more than them for the specific job function roles (business roles). Otherwise, it would sophisticate the results and lead to a negative test. Thus, positive testing is impractical during the integration phase because you'll first want to cover all required authorizations before focusing on unnecessary access scenarios. Since you can only adopt a few processes from your former SAP ERP 6.0 system, positive testing for the new SAP S/4HANA system and its authorization migration is mandatory. Positive tests are an unavoidable requirement for a successful testing phase. Otherwise, you cannot handle background noise and unintentional business processing, which can lead to missing authorization records during tests, which are actually not required for the process. Otherwise, the IT and business departments have to repeat the tests.

  Therefore, your enterprise's business departments must help you configure straightforward system process plans for each business process within their LOB. These plans form the preconditions for migrating authorizations to SAP S/4HANA. If end users do not perform their business processes in a direct manner, you cannot know whether they require missing authorizations based on their defined processes or personal SAP S/4HANA discovery.
- **Authorization test evaluation**
  If testers run into an authorization error with their newly designed SAP S/4HANA

Personal Copy for Arun Singal, arun.singal560@gmail.com

roles, you can directly check for missing authorizations with Transaction SU53. This evaluation is most suitable if you have only a few testers.

For big companies and extensive analysis, the activation of the system trace via Transaction STAUTHTRACE or the user trace via Transaction STUSERTRACE are probably the best options. Using the user trace data in combination with Transaction STSIMAUTHCHECK enables you to simulate your new roles against the usage data of the testers. This simulation will compare the assigned SAP_APP role of the dialog user against the maintained authorizations in the selected role, which allows you to see the missing authorizations directly.

Hint

An integration test might be a good time to re-evaluate the transactional usage data of your end users and their business processing. Then, validate this new data and introduce it into your roles when required.

- **Authorization default value maintenance**
  During the integration test is an excellent moment to determine candidates for your Transaction SU24 data. You can ensure that the checked authorizations are required for the individual company authorization concept based on the results of positive testing. Authorization checks occurring many times are good candidates for proposals because they might constitute recurring business processes. For this purpose, also use Transaction STAUTHTRACE or activate the long-term authorization trace via Transaction STUSOBTRACE. Then, collect these potential proposal candidates and verify the result list with your business departments. After approval, maintain the application proposals in Transaction SU24 and update the affected role profiles.

User Acceptance Tests

Before you start your go-live, you'll need to pass the user acceptance test (UAT), one of the most crucial steps for an SAP S/4HANA authorization migration. The UAT is the last activity before the go-live phase, and thus, this kind of testing is significant for any security administrator, test manager, and business. Like an approval phase, configured business processes, authorizations, and tools are made ready for productive usage. Please note that efficient test management, technical system requirements, and the entire completion of this test on time are critical indicators for a successful user acceptance test. Thus, this test might need to be repeated if you've run out of time, but all authorizations were successfully tested.

We recommend including normal end users, not just key users, to participate in UAT testing, but this decision is an individual decision. The more users you're testing in

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

terms of their roles and job functions, the more you can prevent missing authorizations and business interruptions in advance. You can use the same tools for the UAT authorization evaluation. You'll still need to consider additional or other test approaches combined with third-party tools, like XAMS and its Productive Test Simulation (PTS) feature.

Hint

See Chapter 4, Section 4.4, and Chapter 13, Section 13.5, for more details about testing with XAMS.

You should also consider the following test strategies:

- **Negative testing**
  In contrast to a positive test, within the UAT, you should also test unintentional access. In this case, you can create plans to check unwanted and critical access processes to avoid SoD conflicts or other critical data operations with your new role concept. This kind of testing is one of the most important IT security policies necessary to guarantee a secure authorization concept that covers internal and external regulations.

Hint

UAT is also an excellent time to adjust and enrich your existing ruleset for critical authorization and SoD conflicts. For small companies, an initial Microsoft Excel matrix might be suitable for an initial overview of critical authorizations. An SAP tool like SAP GRC or another third-party tool might be the best option for large enterprises covering a complex authorization structure.

- **Regression testing**
  This test approach is necessary if your entire testing process takes too much time and when your company introduces new upgrades, system configurations, or tools. In this kind of testing, you must ensure that your existing business processes and authorizations are still up to date and running in correlation with new developments. Thus, repeat these tests for all your affected business units. This kind of testing is suitable for reducing the overall test effort by only focusing on the changed functions or requirements.

12.7.8 Go-Live and Project Documentation

If the degree of maturity in your authorization concept reaches a good state through your continuous optimizations, the time has come to convert your first (pilot) end users. This pilot go-live should contain business departments, or at least parts of

Personal Copy for Arun Singal, arun.singal560@gmail.com

departments, for whom job function testing ideally no longer results in any new missing authorization records. In this project phase, your new and enriched role concept goes live for all end users. In the best case, go-live is an iterative process, but it depends on your migration approach, total count of end users, changed processes, or technical migration hurdles, among other things. Therefore, plan and perform different go-live waves with approval from your business departments.

Go-live support for your end users is a particularly work-intensive period for administrators and requires fixed time slots and immediate reaction. Mostly, support requires direct interaction between an end user and an administrator to guarantee prompt authorization failure resolution. In the case of an authorization error, you can use the same analyzing tools that you used for role concept validation in SAP standard. For example, a system trace or user trace to find the required authorizations can be combined with Transactions STSIMAUTHCHECK or SU53 if suitable as well.

However, this classic "trial-and-error" process requires manual attention for each accident, thus consuming many resources. As a result, only activate the role concept for a predefined user scope that is realizable with your IT resources.

Hint

See Chapter 13, Section 13.5 and Section 13.6, to learn more about best practices in role validation and the protected role concept activation approach with automated and complex features available in XAMS.

After your SAP S/4HANA migration, an essential task is ensuring you don't just have a technical implemented authorization (or more precisely, a technically implemented security concept), but a written implementation as well. You should document all security- and system-relevant information for your system landscape for an external and internal audience. This documentation should also depict your current role concept and end-user status quo along with all mitigation controls. This concept will need continuous updating.

Moreover, you should draw up a project report in which important resolutions, anomalies, and open topics are recorded based on your previous project notes and determinations. This report should also contain your new SAP S/4HANA user matrix, job functions, role catalog, role owner, role content, and security regulations.

Hint

For additional information about an extensive security concept, see chapters like Chapter 2, Section 2.1 ; Chapter 4, Section 4.8; or Chapter 10.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

12.8 Xiting Authorizations Management Suite: Helpful SAP S/4HANA Migration Features

XAMS allows you to migrate the authorizations almost automatically to SAP S/4HANA. The provided automatic mechanisms support you in various manual and time-consuming migration project steps. Whether you do a greenfield or a brownfield approach, XAMS enables you to create a job function role concept with less effort. This tool-based migration is suitable for all SAP S/4HANA product variants, except for the SAP S/4HANA Cloud. This specific deployment has several system-dependent restrictions, which make it impossible to use third-party tools extensively.

This section explores some selected XAMS capabilities, such as collecting end-user usage data, migrating your roles to SAP S/4HANA, finding correlated SAP Fiori applications to transactions, or creating an individual SAP S/4HANA security concept. You may find these features helpful when used in combination with standard SAP migration tools.

Hint

Chapter 4 and Chapter 13 contain detailed information about all upcoming XAMS modules and their related migration features.

12.8.1 Comprehensive Usage Data Collection

End-user usage data collection with SAP tools can be cumbersome and time-consuming. For instance, Transaction ST03N and the related Transaction STAD collector provide only a rather technical overview, with limited filter options to conduct extensive analysis. For deeper analysis, you must separately re-evaluate and adjust your current job function role and end-user concept, which is moreover strictly system dependent. Thus, XAMS has a centralized module to accomplish this task: Xiting Role Designer. Through this module, you can perform a virtual, combined system landscape-wide analysis of required technical and business data for your authorization migration preparation, as shown in Figure 12.33. In this virtual cockpit, you can automatically integrate transaction usage data (found in the **Used** column). With various additional features, you can clarify the job function, department, and other specific user information. The assignment of your current role or of new roles to end users enables you to see the coverage rate of a role's content compared to the used menu objects. Moreover, you can massively assign any role menu objects to roles and analyze your roles, for instance, for unnecessary or required transactions or for critical authorizations, virtually before the implementing the role concept implementation in Transaction PFCG.

Personal Copy for Arun Singal, arun.singal560@gmail.com

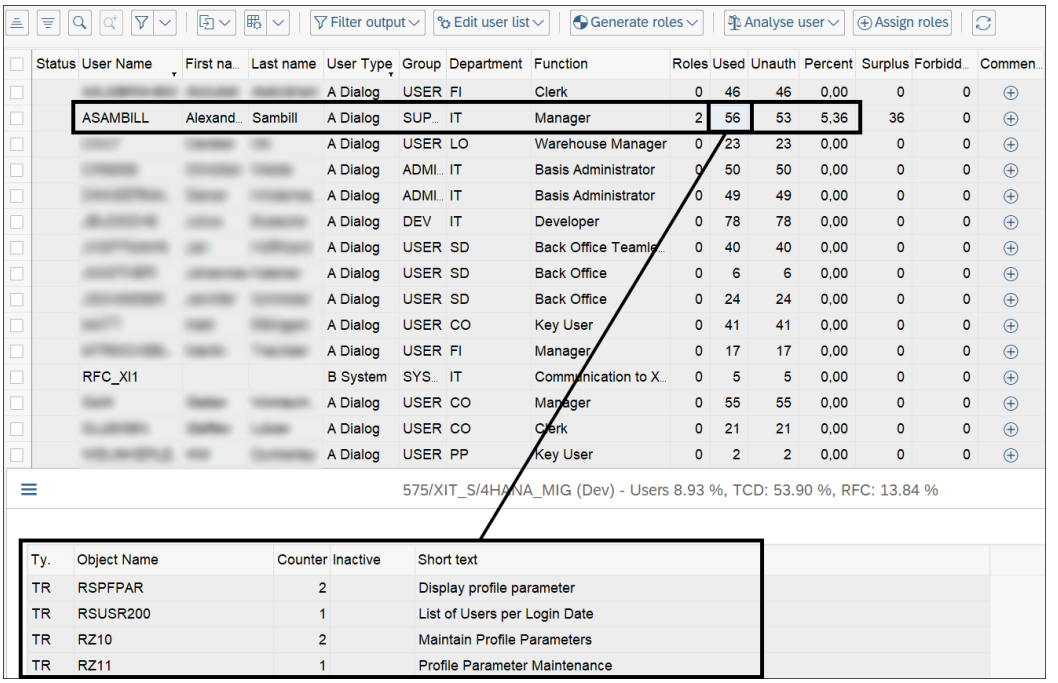


Figure 12.33 Virtual User and Role Modeling in Xiting Role Designer

12.8.2 Role Changes through the Simplification List

Since you must match your current or new role concept with the simplification list, you might be confronted with time-consuming and manual evaluations against this list to match the requirements. Therefore, Xiting offers a feature to automatically analyze the upcoming impacts based on your role concept. As a result, you'll get an overview of all transactional changes, and thus, you can see what you must cover and consider. Moreover, you'll also get necessary information about possible SAP Fiori application replacements and Web Services (**IWSV**), in the **replacement** or **App IDs** column, as shown in Figure 12.34. Note that whether you want to analyze single roles or also composite roles does not matter. Based on this list, you can directly **Adjust** or **Append** all application requirements in your business roles. Finally, please note that you can always update the latest simplification list data in XAMS by yourself.

Hint

XAMS also offers a report that shows the direct match between used transactions and their SAP Fiori substitutes. Thus, time-consuming comparisons in the SAP Fiori apps reference library are no longer necessary. Moreover, you can use various tools for massively transporting or translating SAP Fiori objects (like catalogs or groups) as well as for assigning tiles and target mappings to catalogs with an upload file. See Chapter 8 to discover the extensive SAP Fiori features in XAMS.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

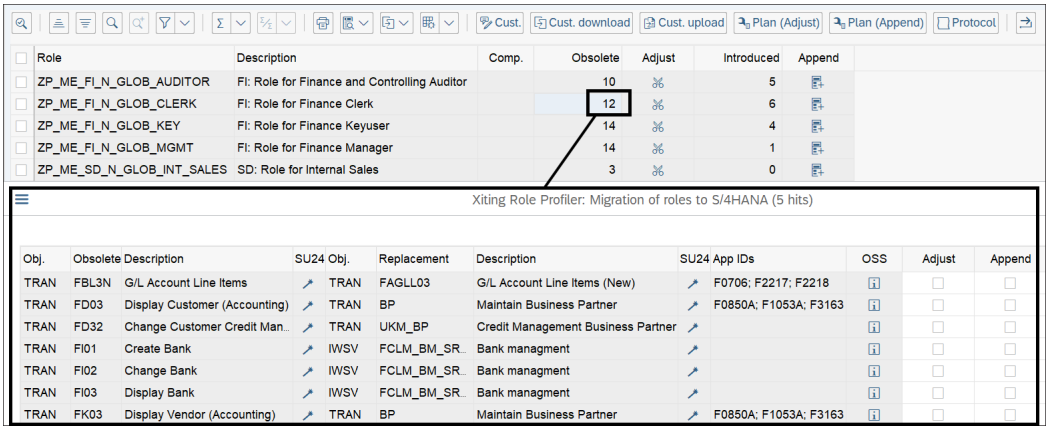


Figure 12.34 Automatic Simplification List Matching in XAMS

12.8.3 Security Concept

Creating a holistic and up-to-date security concept is complex and often problematic undertaking. On one hand, you'll initially require an understanding what you need cover in the concept and where you can find the relevant technical information in your systems. On the other hand, while your security concept is in progress, many findings may become out of date. The Xiting Security Architect in XAM might be a handy solution for these issues. This tool delivers ready-to-use security concepts for your SAP system landscape based on SAP Best Practices, SAP security guidelines, and Xiting's decades of experience in the field, as shown in Figure 12.35. In this way, you can easily generate and publish an individual security concept, continuously monitor your SAP systems for compliance issues centrally, and solve security issues on time. Thus, you'll have a combination of a written security concept template and an ICS tool.

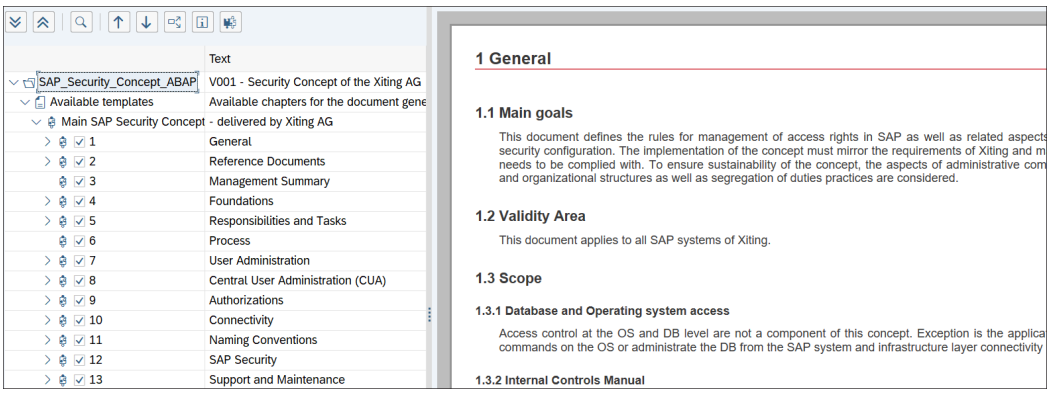


Figure 12.35 Xiting SAP Security Concept Template

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Please note that SAP follows an update cycle with releases for SAP S/4HANA every year, and for the cloud-based editions, every quarter. Currently, SAP officially supports individual releases for only 5 years. Thus, be ready for faster releases than previously with SAP ERP 6.0, which makes a standard-compliant authorization concept even more important than before.

12.9 Summary

SAP S/4HANA provides profound business opportunities through the deployment of competitive features in the era of big data and Industry 4.0. To apply these new functionalities, you must integrate the new solution and its required hardware into your system landscape. The transition from SAP ERP 6.0 to SAP S/4HANA requires extensive technical, organizational, procedural, and authorization-related considerations, changes, and efforts. This chapter has emphasized that a one-to-one transformation of all system-dependent criteria, such as authorizations, system architecture, or processes, is impossible. Once again, SAP S/4HANA is not an update. Thus, this chapter introduced you to various basic but essential information regarding SAP S/4HANA, like the SAP HANA database, different deployment options, changed business processes, and CDS. This chapter's content summarizes the knowledge required to start your authorization migration. Then, this chapter described all the necessary preparation and approaches to migration. For the sake of completeness, we also provided an overview of several non-authorization-related topics like the simplification item check, SAP Readiness Check, SAP Best Practices Explorer, and much more.

Moreover, this chapter provided information about required migration activities as well as information about using tools from SAP and XAMS. In the next chapter, we'll provide more details about migrating authorizations to SAP S/4HANA using XAMS.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Chapter 13

Migrating Authorizations to SAP S/4HANA with the Xiting Authorizations Management Suite

SAP S/4HANA has introduced significant changes to its data model that make migrating to the new flagship enterprise resource planning (ERP) platform challenging and complex for many SAP businesses. In particular, many changes to transactions and applications in SAP S/4HANA have far-reaching implications on roles and authorizations that could add layers of complexity to your overall migration project. Thus, an automation tool like the Xiting Authorizations Management Suite (XAMS) can help to reduce many manual migration processes to a minimum.

Despite what you may have heard, you must realize that migrating an authorization concept from SAP ERP 6.0 to SAP S/4HANA is not as simple as upgrading to a new enhancement package (EHP). Whereas a traditional SAP Business Suite upgrade might require a few modifications to your existing authorization concept, implementing SAP's new business suite is much more involved. Specifically, you'll require a complete revision of the existing authorization concept as well as require the integration and implementation of the new and enhanced authorization objects. These goals also require many manual processes, which is why automation tools, such as XAMS, can be so valuable. With XAMS, you can simplify and automate many of the time-consuming tasks involved in migrating authorizations to SAP S/4HANA.

But before we dive more deeply into how XAMS can help you migrate to SAP S/4HANA more efficiently, you should understand the different migration strategies you can pursue, including the following:

- Role concept redesign in SAP ERP 6.0 during or followed by a standard-compliant SAP S/4HANA migration of your roles
- A quick-and-dirty (lift-and-shift) migration of your role concept, which is only a technical conversion to SAP S/4HANA
- Standard-compliant role migration to SAP S/4HANA

Personal Copy for Arun Singal, arun.singal560@gmail.com

The strategy you choose will significantly impact your authorization concept's quality, maintainability, upgradeability, and sustainability. Your decision will likely also influence your level of compliance with external and internal regulations.

For these reasons, this chapter will lay out some essential indicators and describe the pros and cons of each migration approach, so you can make informed decisions about which approach is right for you from an authorization-related point of view. In addition to this approach decision, this chapter introduces you to XAMS, an automation solution that can help simplify and automate many SAP S/4HANA role migration tasks you would have to execute manually otherwise.

Hint

XAMS is SAP-certified for SAP S/4HANA, on-premise edition, and SAP S/4HANA Cloud, extended edition (EX).

13.1 SAP S/4HANA Migration Strategies with the Xiting Authorizations Management Suite

XAMS supports all the migration approaches mentioned earlier, regardless of whether you're pursuing a greenfield, bluefield, or brownfield migration strategy. Through the extensive tools and features available in XAMS, you can run any of these migration strategies, as shown in Figure 13.1.

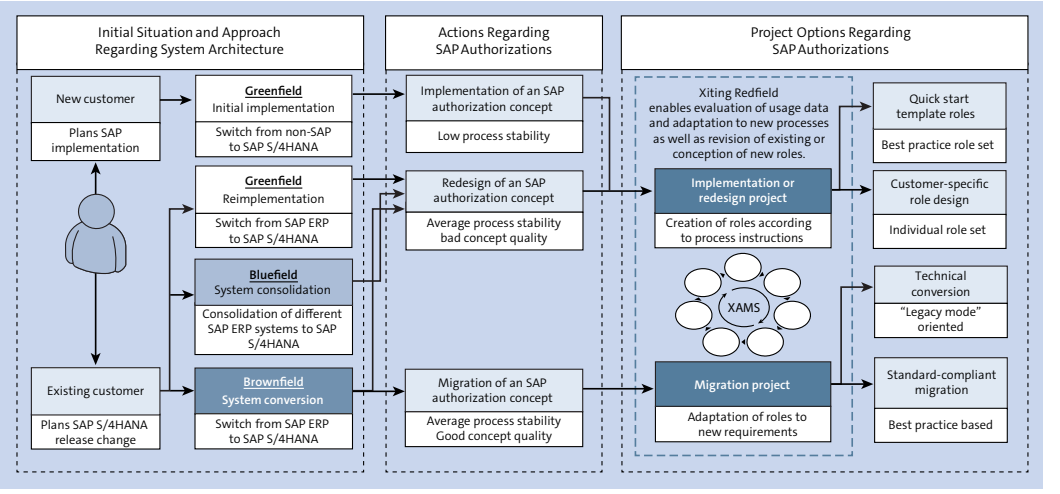


Figure 13.1 SAP S/4HANA Migration Strategies with XAMS

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Hint

For more information regarding these different SAP S/4HANA transition approaches, see Chapter 12, Section 12.6.2.

This chapter mainly focuses on the greenfield and brownfield SAP S/4HANA migration options with XAMS. We'll show you the pros and cons of the various approaches. Further, a practical what-if example illustrates a recommended migration approach for each scenario. In this way, we hope to provide you insight into which approach you should follow, according on your existing conditions.

Hint

Please note that the following comparisons and recommendations offer only some selected considerations for the chosen SAP S/4HANA migration approaches and do not depict an all-embracing evaluation.

A highly necessary step is to understand that this information is only general information to show the main transition approaches for SAP S/4HANA. Unfortunately, incorporating your system landscape into one of these three approaches in practice can be difficult. Your role migration will depend on many different variables, such as role quality, organizational extent, upcoming business process changes, integration of SAP Fiori, security focus on custom developments, and internal regulations. Thus, we recommend performing an extensive system analysis before starting your migration project to cover all requirements and restrictions and to make the project's extent tangible.

13.1.1 Greenfield Migrations

First, as a new SAP customer, an entirely new authorization concept implementation (greenfield) is necessary. You lack SAP system data and processes that you can reuse for your new concept and roles. Thus, you'll need to establish an SAP S/4HANA role concept from scratch, and XAMS can help with this task with its template roles, included as part of its Xiting Quick Start (QS) service. Another greenfield SAP S/4HANA transition option is an authorization reimplementation, which is a role concept redesign combined with an SAP S/4HANA migration.

Three implementation paths are available through XAMS to help you determine the best way to migrate to SAP S/4HANA in a greenfield approach:

- **Initial role concept implementation (traditional)**
  Using the traditional implementation path, you'll start on a blank page and align all your former processes and regulations into a new SAP authorization concept. XAMS can support you in many migration tasks, such as clustering your end users, determining job function roles, optimizing proposal data, establishing an organizational

Personal Copy for Arun Singal, arun.singal560@gmail.com

inheritance concept, integrating SAP S/4HANA and SAP Fiori changes, testing new roles, and performing an almost seamless role concept go-live.

A traditional SAP S/4HANA role concept implementation can be described with some project indicators and, in the context of authorizations, has both pros and cons, as listed in Table 13.1.

Indicators	SAP S/4HANA New Implementation with XAMS
Project scope	All required end users
Effort (IT)	High
Effort (business)	Approximately 75% of IT effort
Duration	Long
Complexity	High
Pros	■ Building a new role concept from scratch with SAP Best Practices (like Transaction SU24 conformity) ■ Fit all business requirements without any inherited liabilities ■ High degree of individualization
Cons	■ New establishment of SAP business processes ■ Creation of an entirely new role concept without any former references ■ Big project scope and much business unit integration

Table 13.1 Indicators of an SAP S/4HANA New Implementation with XAMS

- **Initial role concept implementation (Xiting Quick Start [XQS] service)**
  In contrast to a traditional XAMS authorization implementation, in which you are building up an entirely new role concept, the XQS service provides a ready-to-use role setup to avoid starting from scratch. The QS) concept is a set of transports that provide the system with best practice configurations, customizing, Transaction SU24 proposals, and a set of template roles that are consistent with each other, for instance, for critical or segregation of duties (SoD) authorizations. With this service, you can implement an authorization concept based on XAMS best practices. This concept contains basic building blocks, covering approximately 90% of recurring business functions, depending on how much custom development and exotic functionality you require. The intention is that, if you lack special, complicated requirements, then QS transports allow you to import a known set of objects (customizing, proposals, and roles) to serve as a basis for the new implementation or redesign project. Ideally, you can start the Xiting Productive Test Simulation (PTS) feature as soon as possible to find out what differences exist between the XQS best practice templates of job function roles and authorizations compared to the individual custom business needs. Even if the XQS templates already provide a high coverage degree

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

for all necessary business functions, you must include internal conceptual and business requirements. It is always necessary to align them to the custom use cases. Thus, it is ideal for smaller customer SAP installations but can also be used for large businesses with many installations as the start benefit is the same.

- **Role concept reimplementation (redesign) with SAP S/4HANA migration**
  A redesign of the role concept before, during, or after migrating your authorizations to SAP S/4HANA is a practical approach for most businesses with an existing role concept that might be inconsistent and does not entirely suit external and internal regulations. A redesign enables you to revalidate and maintain all business needs and authorizations to transform them into a standard-compliant role concept. You can achieve a sustainable, maintainable, and secured authorization concept covering all internal and external requirements. If you choose to perform a role concept redesign during your SAP S/4HANA authorization migration project, you can reduce overall project effort and costs. This approach is more efficient but also more complex than a redesign before or after the migration since you must cover both creating a new role concept and integrating SAP S/4HANA's requirements. Table 13.2 provides an overview of essential facts for an SAP authorization redesign with XAMS.

Indicators	SAP Authorization Redesign with XAMS
Project scope	All active end users
Effort (IT)	Intermediate to high
Effort (business)	Approximately 25% of IT effort
Duration	Middle to long
Complexity	Intermediate to high
Pros	■ Building a new role concept according to real end-user usage data ■ Fit all business requirements and optimize current processes ■ Achieving a standard-compliant role concept and high role quality without any legacy issues ■ A well-maintained role concept following the SAP standard is fundamental for achieving a standard-compliant SAP S/4HANA migration
Cons	■ Risk of additional unknown effort if process changes are introduced during the SAP S/4HANA migration ■ Time-consuming and complex project scope ■ Additional integration for business process requirements

Table 13.2 Indicators of an SAP Authorization Redesign with XAMS

Suppose that ACME (a fictitious company) is starting with an SAP S/4HANA migration and is in the planning phase. This company might have many custom programs that

Personal Copy for Arun Singal, arun.singal560@gmail.com

are unnecessary or have been replaced through SAP standard code with SAP S/4HANA. One strategy is to revert to more closely align with the SAP standard. Furthermore, suppose ACME wants to undertake a business transformation, resulting in significant changes to its current business processes. Other crucial considerations are role concept quality and security level, which ACME wants to improve entirely. In such a case, an SAP authorization redesign as a part of the migration project is advisable.

13.1.2 Brownfield Migrations

Whereas a greenfield approach lets you start on a blank page, choosing the brownfield approach means you're still working with your former authorization concept and want to migrate this concept to SAP S/4HANA with its previous role adjustments and enhancements. This approach is more like an upgrade or a renovation of your former SAP ERP roles. With XAMS, you can also adopt this approach in two ways, a lift-and-shift migration or a standard-compliant migration.

Let's briefly look at these two options next:

- **Lift and shift of current authorizations to SAP S/4HANA**
  For this SAP S/4HANA transition type, you retain your existing non-best practice role concept and make only necessary consistency adjustments for compliance and role inheritance. In this way, you technically migrate a non-standard-compliant role concept and its authorizations without considering upgradability or sustainability. This technical approach is a compromise solution for businesses that lack the required role concept quality for a best practice migration and cannot perform an authorization redesign because of time constraints. However, you must ensure the future role concept's maintainability and security in the medium term with a technical conversion anyway to fulfill internal and external requirements. Please note that you'll only transport your insecure, non-sustainable, and unmaintainable role concept into your new ERP solution. Thus, this approach requires a subsequent role concept redesign. Table 13.3 provides an overview of the technical conversion.

Indicators	SAP S/4HANA Technical Conversion with XAMS
Project scope	All actively assigned roles
Effort IT	Low
Effort (business)	Approximately 10% of IT effort
Duration	Short
Complexity	Low

Table 13.3 Indicators of an SAP S/4HANA Lift-and-Shift Technical Conversion with XAMS

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Indicators	SAP S/4HANA Technical Conversion with XAMS
Pros	■ No business discussions about the contents of roles and their organizational levels ■ A mostly fast move to SAP S/4HANA
Cons	■ Legacy issues not resolved (technical conversion without conceptual rework) ■ Lift-and-shift transition to SAP S/4HANA does not enhance the security or quality level of your current role concept ■ Redesign of authorizations still required ■ Additional investments are required in the long run to solve upcoming process interruptions and security flaws

Table 13.3 Indicators of an SAP S/4HANA Lift-and-Shift Technical Conversion with XAMS

Suppose that ACME is in the middle of the its SAP S/4HANA migration project and wants to go live in 2 months. The company, however, now realizes that it must update and clean up its role concept for SAP S/4HANA. As a result, ACME must lift and shift its role concept to SAP S/4HANA and only partially adjust the necessary authorization requirements (like updating organizational settings, cleaning up role inheritance, integrating SAP Fiori, or creating new roles to cover new business functions). Furthermore, based on a tight project schedule, the company must perform an entire role cleanup process after going live.

- **Standard-compliant role concept migration to SAP S/4HANA**
  With a standard-compliant migration approach, you'll adapt existing roles to adapt to relevant SAP S/4HANA changes. This approach requires that your entire role concept fit the SAP standard. Thus, you must ensure that your authorization concept is well maintained, including roles, not manual authorization profiles. Also, your roles must be based on the authorization default values and consider your most up-to-date business requirements. Consequently, this precondition also excludes manual authorization objects in roles. In particular, you cannot merge roles with manual start authorization objects like S_TCODE, S_SERVICE, S_START, and S_RFC. The same limitation applies to roles with authorization value ranges for these authorization objects. Otherwise, you won't be able to directly compare role menu objects with the simplification list in SAP S/4HANA, and thus, you cannot transfer your roles to SAP S/4HANA directly. The migration of the inheritance concept also requires a cleanup if any inconsistencies exist. If your role concept does not fulfill these requirements, and your company does not want to perform a role concept redesign, the only option is an unhealthy lift-and-shift technical conversion. Table 13.4 provides an overview of technical conversion indicators.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Indicators	SAP S/4HANA Standard-Compliant Migration with XAMS
Project scope	All actively assigned roles
Effort (IT)	Low
Effort (business)	Approximately 10% of IT effort
Duration	Short
Complexity	Low
Pros	■ Easily migrate your healthy role concept to SAP S/4HANA ■ Include compliance to SAP-expected standards in your authorization concept ■ Retain the upgradability, maintainability, and security of your role concept
Cons	Additional investments are required to fit new SAP S/4HANA business needs with the updated role concept

Table 13.4 Indicators of an SAP S/4HANA Standard-Compliant Migration with XAMS

Suppose that ACME already has a standard-compliant role concept. In other words, ACME uses authorization default values without any manual authorization objects in its roles, and its job function roles are strongly correlated to existing business requirements. Thus, ACME only needs to adopt new processes and SAP S/4HANA requirements like SAP Fiori. Then, the company can perform a standard-compliant technical migration to SAP S/4HANA since its role concept uses the SAP standard. This scenario is the quickest and most affordable approach to transition to SAP S/4HANA.

13.2 Preparation Phase: Role Concept Validation

Experience has often shown that existing custom role concepts are typically unsuitable for a quick and easy SAP S/4HANA transition. For instance, your role concept may contain manual authorizations, extensive access without considering job functions, or organization level allocations that are not based on an inheritance concept. Thus, the administration of your entire role concept is cumbersome work and might provide unintentional data access. For your authorization migration, you must analyze your current role concept to determine which SAP S/4HANA migration strategy fits best. During your preparation, you must evaluate the required technical needs, like the quality of your roles and proposals as well as any existing custom code and inheritance concepts. This analysis should also cover individual requirements for SAP Fiori, which is more than a new web-based user interface (UI). Its applications are no longer optional in SAP S/4HANA and are often mandatory. During the preparation phase, you should

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

look for potential flaws in your authorization concept as well as determine what you might have to cover in your migration project to fit SAP S/4HANA's requirements. Apart from these technical considerations, now is also the best time to check new functions, changed system data processing, and new business processes to leverage, for instance, the new general ledger, parallel accounting, and document split capabilities for finance.

Your role concept's proposal compliance is another indicator that can help you determine your SAP S/4HANA approach. If you consistently work with role menus and proposals, you can perform a standard-compliant migration easily with XAMS. In contrast, if you haven't or have only partially worked with the authorization default values and Transactions SU25 or SU24, we highly recommend performing an upstream or simultaneous role concept redesign. A lift-and-shift approach is also suitable, depending on your company's objectives and project schedule, especially when you're not using default data. However, using proposals for your entire authorization concept is not only be mandatory for SAP S/4HANA but also simplifies your role concept maintenance, administration, monitoring, and upgradeability efforts.

This section had a purely technical focus on analyzing your current role concept, adjusting inconsistencies, upgrading authorization default values, and other optimizations. In the process, we introduced you to several XAMS analysis tools to help you find the best path to SAP S/4HANA.

Hint

For a general guideline for SAP S/4HANA authorization migrations in the SAP standard, refer to Chapter 12, Section 12.7.

13.2.1 Verifying Role Concept Quality

Verifying the technical quality of a role can be a decisive factor in determining which migration approach you choose. Therefore, the first challenge is to find the required data to evaluate whether your role concept is standard-compliant or better suits another migration approach. For this analysis, you can use Xiting Role Profiler, which is a XAMS module. This module offers broad and extensive analysis reports for your entire migration process and to support daily authorization administration.

The scope for this validation should be your current business role templates or specific inheritance-independent end-user roles. Please note that you can only cover the actively assigned roles of end users. Then, you can use the **Manual authorizations**; **Open authorizations**; **Changed authorizations**; **Read old, merge new**; and **Non-org. interval ranges** reports, available in the **Role Quality & Sustainability** folder, as shown in Figure 13.2. In this way, you can determine the consistency of your roles and clean up authorizations when particular issues arise.

Personal Copy for Arun Singal, arun.singal560@gmail.com

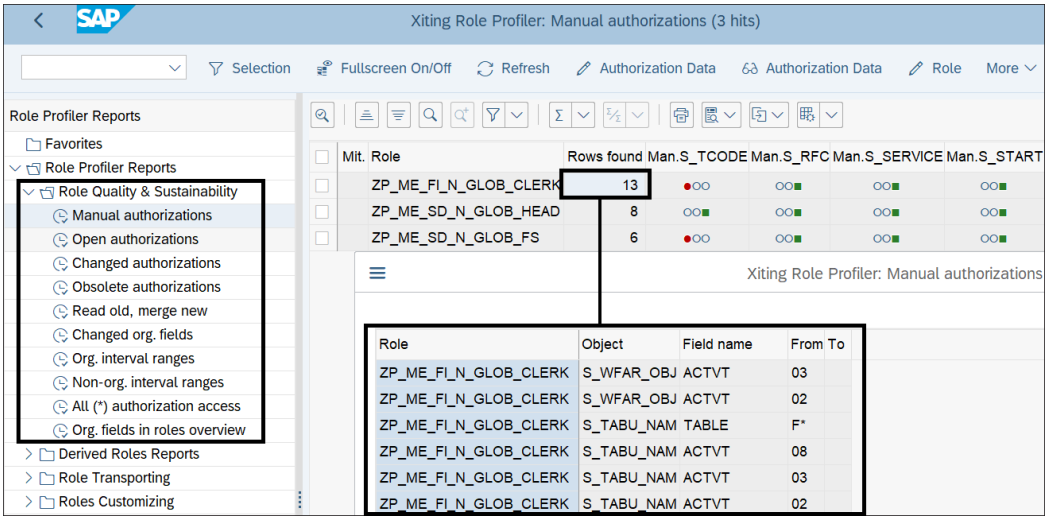


Figure 13.2 Role Analysis for Manual Authorizations

You can validate the quality of your role concept by using these reports to find your path to SAP S/4HANA. Having many manual, open, and changed authorizations in your roles are indicators for a technical conversion or redesign. In addition, intervals in authorization values (for example, the authorization object S_TCODE with the values **A*-Z*** for the field **TCD**) can harm your security concept because you cannot determine exact end-user access. Also, you might offer extensive unintentional operations, as shown in Figure 13.3. The ranges between the authorization values for the field **BRGRU** from **A-G** and **Q-Z** offer access to all existing and new values within these ranges. Furthermore, they cannot be exactly monitored for security audits and role validations because you won't know which values are required and used by the underlying job function.

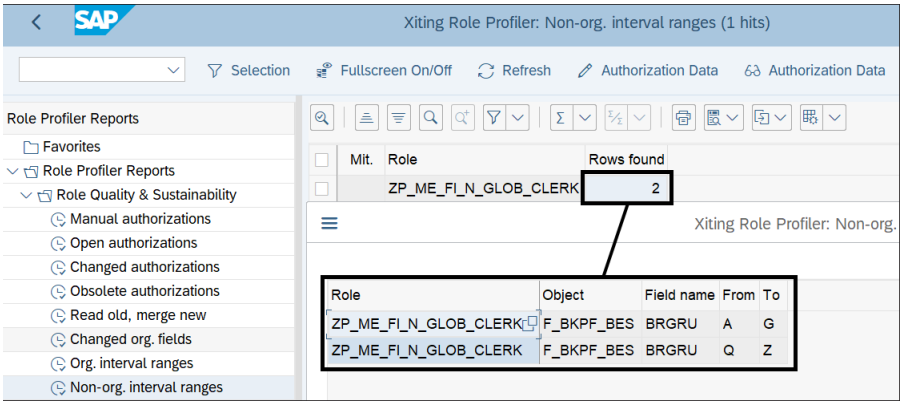


Figure 13.3 Xiting Role Profiler Non-Org. Interval Ranges

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Additionally, you should analyze your role concept for critical authorizations and SoD conflicts as well. These authorizations constitute the most harmful influences on the security concept in your system landscape. You can extensively analyze these possible issues with the Xiting Role Profiler reports **Critical auth watchdog** and **Critical combination watchdog**, as shown in Figure 13.4. Based on the entire Xiting Critical Authorization Framework (CRAF) framework with unique authorization IDs down to the authorization value level, which constitutes various authorization issues, Xiting Role Profiler scans all selected roles and users against these predefined checks.

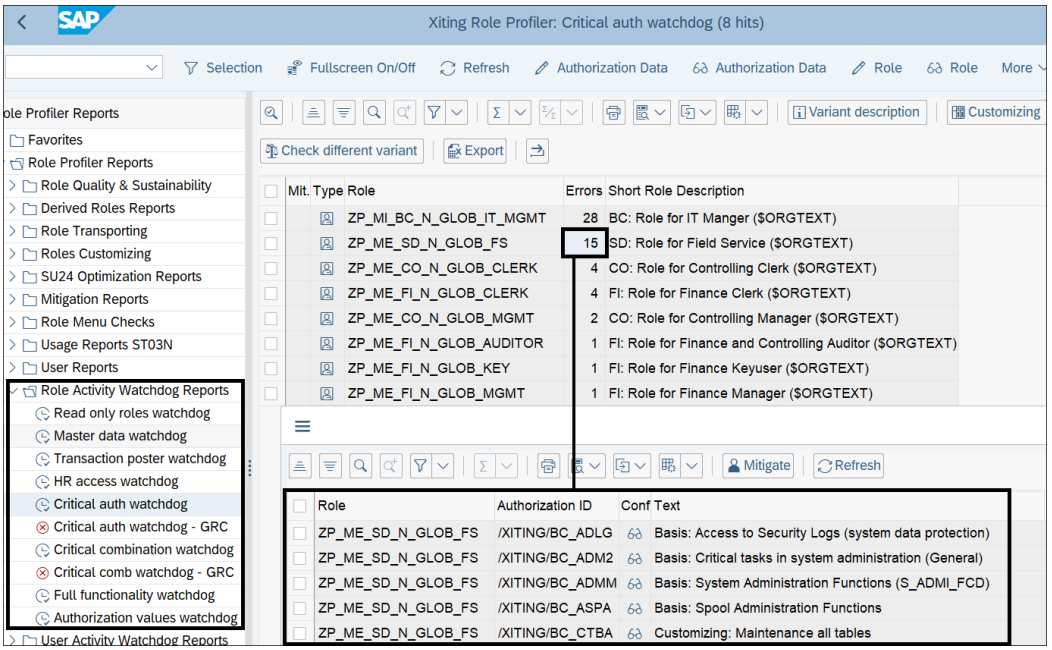


Figure 13.4 Xiting Role Profiler Critical Auth Watchdog

Finally, Xiting Role Profiler enables you to analyze whether a standards-compliant SAP S/4HANA authorization migration is suitable for your current role concept. Otherwise, your move to SAP S/4HANA requires a role concept redesign, or only a technical conversion fits with your project timeline.

We highly recommended performing a role concept redesign if you receive countless failure results, especially when using manual (start) authorizations. With manually introduced authorizations, a standard-compliant role migration is impossible since the existing role concept is not based on authorization default values and role menu objects. First, you won't be able to entirely match your applications with the simplification list in SAP S/4HANA. Second, manual authorization objects in your roles could adversely affect existing characteristics during your role profile comparison to SAP

Personal Copy for Arun Singal, arun.singal560@gmail.com

S/4HANA and also involve high risks. Finally, you cannot forecast whether your existing authorizations still fit the requirements for new or revised SAP S/4HANA applications because you have not worked with proposals in the past, which SAP technically expects for a clean migration. Thus, if you have many manual authorization objects and value ranges, and you do not fit organizational values into your roles, you must choose a redesign or technical conversion of your roles through the lift-and-shift approach with XAMS.

13.2.2 Authorization Default Values Compliance

According to SAP's focus on standards compliance with SAP S/4HANA, you are tasked with staying closer to the SAP standard and with integrating the standard in your custom code. In addition to the many advantages that come with using authorization default values, you can handle the obligations that come with fast-paced release upgrades and avoid business interruptions due to new functions being introduced. Thus, a necessary step is to evaluate your role concept to fit those requirements for your transition. Especially for a standard-compliant SAP S/4HANA migration, this step is necessary. Therefore, you should check the validity of your proposals through Transaction SU25 for all SAP-delivered and partner-delivered applications. Optimizing the authorization default values for your custom code is also helpful for your further migration processes and for checking how up to date your role profiles are. We'll discuss these concepts further in the following sections.

Hint

For all the necessary information about authorization proposals and their importance, refer to Chapter 5.

Transaction SU25 Upgrade

First, enter Transaction SU25 and determine whether you performed either the initial and the latest proposal value upgrade to incorporate SAP's new defaults into your proposal setup in Transaction SU24. This step enables the functional usage of updated programs and features for which authorization checks have changed. Since a standard-compliant role concept implies the use of authorization default values for your authorization migration, you also must update these proposals. For this task, you'll compare your customer-specific default values (Transaction SU24) and update these values with the new SAP S/4HANA values (Transaction SU22) via Transaction SU25. This upgrade process enables role creation based on current technical system requirements. The Xiting Role Profiler report **Read old, merge new** provides a function to check whether your role concept is up to date according to your proposal upgrade. For an extensive Transaction SU25 upgrade guideline, see Chapter 5, Section 5.6.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Custom Code Validation and Proposal Optimization

Next, check the proposals for your custom code programs you want or need to migrate to SAP S/4HANA. Thus, besides validating your programs to determine whether they can be migrated to SAP S/4HANA (using, for instance, the ABAP test cockpit or the code inspector), you'll need to cover their required proposals. For this task, use Xiting ABAP Alchemist, another XAMS module. This code scanner removes the disadvantages of manual code scanning, like finding incorrect access protections, identifying complex and manual analysis processes, evaluating the time-consuming documentation of required authorization default values, and ensuring compliance with developer guidelines. Thus, apart from compliance in terms of authorization default values, you can use this module to establish quality gates and conduct validity analyses for custom code. Concerning the authorization default values, scan your custom programs separately or as a whole via inspection variants in this tool. Then, you can validate your programs for code patterns like `AUTHORITY-CHECK` statements, `DATASET` operation authorities, Open SQL patterns, or `CALL TRANSACTION` authorization checks. Based on this information, you'll see whether the authority checks you introduced in your custom code are maintained in Transaction SU24. If not, you can directly introduce the required values into Transaction SU24 for the intended transactions for which the defaults based on the authority checks are missing by clicking the blue arrow icon, as shown in Figure 13.5.

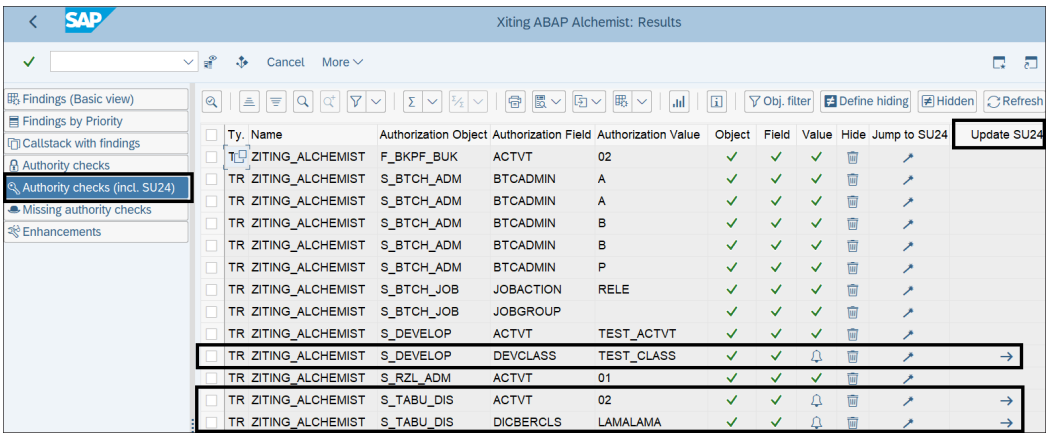


Figure 13.5 Code Scanning for Proposal Optimization

In addition to the system's implicit authorization checks (e.g., against start authorization objects like S_TCODE) and explicit checks through program code, you must include dynamic parameter checks, which are also captured in the source code's `AUTHORITY-CHECK` statements. These parameters predefine individual values like table names, report names, program groups, or TSTCA values.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

For more information about ABAP authorization check processing, see Chapter 2, Section 2.6.

These committed rules always lead to specific authority checks before or during program execution. For instance, these rules evaluate fixed, predefined values to start programs. When you start a program, the system checks the authorization object S_PROGRAM with this exact program group value, specifically the authorization field `P_GROUP`. Therefore, the maintenance activities we describe in this section focus on testing outside the program source code. With this approach, you can verify and enhance your Transaction SU24 data and improve role sustainability and quality based on system rules. This step can also be part of your readiness activities for SAP S/4HANA authorization migration, which is essential for the future functioning and security of your role concept. Otherwise, your end users might lose access to the affected programs.

Hint

Please note that direct execution of a program through a report transaction or Transaction SA38 (and related transactions) leads to an authorization object S_PROGRAM check. However, when you submit a program from another program, the check will not happen. Therefore, navigation between programs should be used carefully and ideally via `CALL TRANSACTION` statements instead of `SUBMIT` statements on a program. This recommendation is because using a transaction forces an authority check, whereas directly submitting a value to a program with Transaction SA38 does not, especially when the program is not assigned to a program group.

For analysis and future maintenance, Xiting Role Profiler offers various reports in the **SU24 Optimization Reports** folder, as shown in Figure 13.6. The following ten optimization reports for Transaction SU24 represent a worklist for system rule-based proposal maintenance for applications in your selected roles:

- **SU24 remove excessive values**
- **SU24 param.tcodes S_PROG***
- **SU24 report writer S_PROG***
- **SU24 param.tcodes S_TABU***
- **SU24 par.tcd. S_TABU* clusters**
- **SU24 par.tcd. S_NUMBER**
- **SU24 par.tcd. B_MASSMAIN**
- **SU24 par.tcd. S_ARCHIVE**
- **SU24 cost.center rep. K_KA_RPT**
- **SU24 from missing TSTCA**

Your target should be to analyze and update as many roles with red traffic light indicators as possible. In this process, your proposal data is made to represent the system's predefined rules and parameters in the context of your own parameter transactions. Please note that some exceptions to this rule exist for authorization objects S_TABU*

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

and S_PROG**. For these authorization objects, you must verify in advance the required granularity of the proposed table and program access in coordination with your IT and business units. For instance, clarify whether granular access should be provided on the table level (S_TABU_NAM) or perhaps on the table group level (S_TABU_DIS). Also, you should consider whether you need additional restrictions by program name (**S_PROGNAM**) or by program group (**S_PROGRAM**). Please note that the authorization object S_PROGRAM for program executions is always mandatory, whereas authorization object S_PROGNAM is optional.

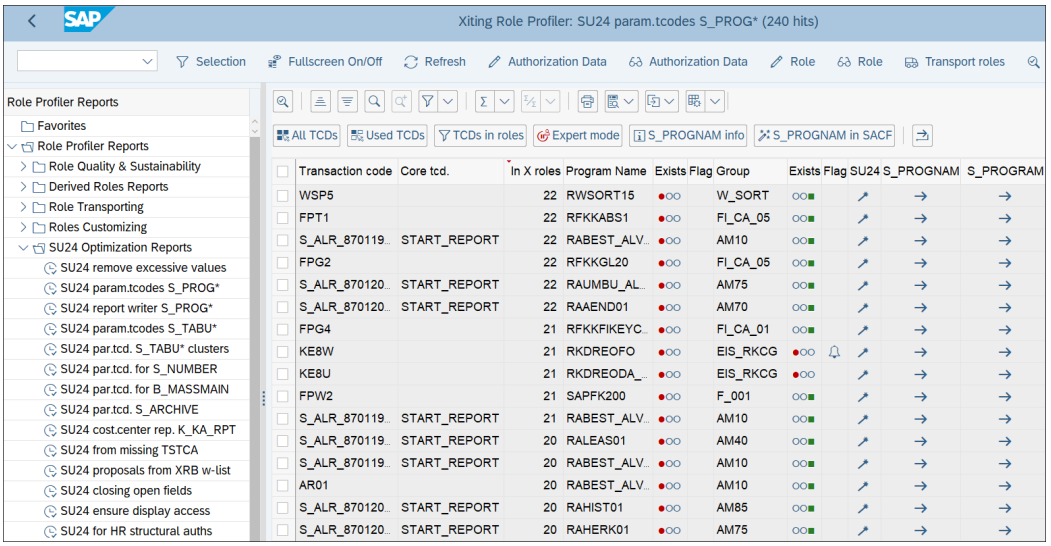


Figure 13.6 Xiting Role Profiler Report SU24 Param.tcodes S_PROG*

Hint

To enable the use of authorization object S_PROGNAM, you must activate this object via Transaction SACF. See SAP Notes 101146 and 2272827 for further details as well as Chapter 2, Section 2.6.8.

In general, your choices will depend on your objectives. In practice, you should restrict change access at the table level while display rights are tolerable at the table group level. Additionally, it might be suitable and secure to maintain authorization object S_TABU_DIS for SAP standard applications if highlighted in the Xiting Role Profiler report, but especially for custom developments that often process access to explicit tables, you should maintain the authorization object S_TABU_NAM. However, always authorize S_TABU_NAM for parameter transactions to be on the safe side. Please note that you should never maintain the table group &NC& for the authorization field DICBERCLS of the authorization object S_TABU_DIS because this table group is a container for all tables not assigned to a particular table group.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Verification of the Up-to-Dateness of Role Profiles

One of the most important preconditions for a standard-compliant migration is being up to date, and you must ensure that your role profiles contain the latest authorization default values. Otherwise, you'll work in an updated system but with outdated authorization proposals, which might lead to many authorization errors for your end users. For this purpose, Xiting Role Profiler offers the **Read old, merge new** report, shown in Figure 13.7. This report simulates the Transaction PFCG expert mode **Read old status and merge with new data** function for all selected roles. You'll see the affected roles that are not up to date due to new or changed proposal data. Also, you can directly jump into a target role's authorization profile by double-clicking a role so you can easily maintain open authorizations as required for your business needs.

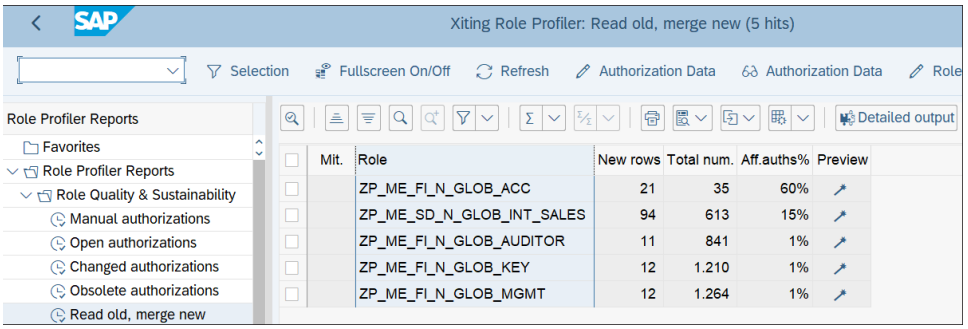


Figure 13.7 Updating Role Profiles with Changed Proposal Values

Please note that an essential precondition is having an up-to-date role concept in place before you migrate to SAP S/4HANA in the standard-compliant approach. Since you may not entirely use proposals, if you migrate with a quick technical conversion (lift and shift), you can skip this task. However, when considering a redesign, you should perform the proposal upgrade in any case.

Hint

We highly recommend using a new sandbox or development system (DEV) for your SAP S/4HANA transition. Also, consider the impact of the authorization proposal on your current role concept if you work on your existing DEV for your SAP S/4HANA migration or upstream redesign. For example, if you did not work with the authorization default values before but now want to achieve a standard-compliant role concept, do not maintain roles that are actively used after upgrading and optimizing the authorization default values. In other words, do not adjust the role menus or regenerate existing role profiles with the updated proposal data, which would lead to many inconsistencies and additional role maintenance effort. Instead, you must create what are called *delta roles* for any role adjustments on roles required for daily business. You would then assign delta roles temporarily to end users in addition to their existing roles.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

13.2.3 Consistency Verification of the Inheritance Concept

Regardless of whether you use the SAP inheritance concept or the XAMS replication concept to differentiate organizational access within your roles, a necessary step is to clean up derivation inconsistencies. This step ensures the faultless migration of template roles and their correct inheritance to the derived roles. In addition, you can guarantee the functional derivation concept for your organizational access scenarios operates as designed. On this account, you can use the reports in the **Derived Roles Reports** folder in Xiting Role Profiler. These reports will show you discrepancies between master and derived roles and indicate what needs to be cleaned up. For example, as shown in Figure 13.8. the role profiles of some child roles were changed manually, as indicated by the timestamps older than the template's. Therefore, always change the authorizations in the templates themselves and then push the changes to the derived role; only then should you change the organization levels in the derived roles.

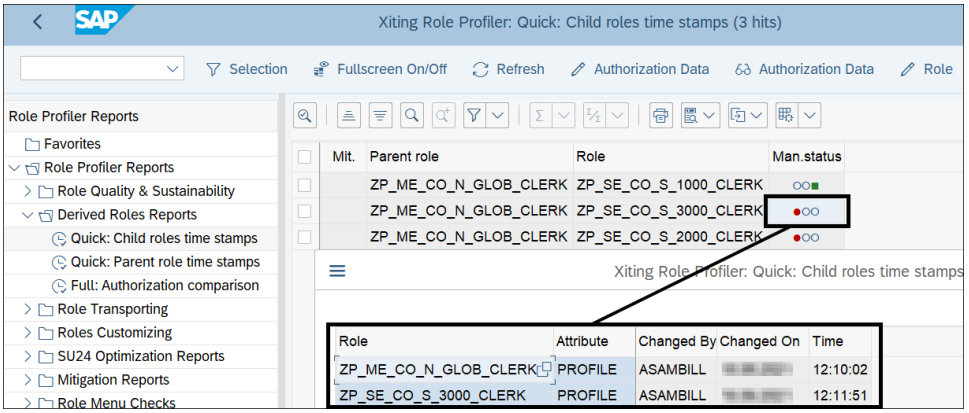


Figure 13.8 Validation of your Role Inheritance Concept

Furthermore, you should also validate your organizational authorizations. For this task, you can also use Xiting Role Profiler reports like the **Changed org. fields** and **Org. interval ranges** in the **Role Quality & Sustainability** folder.

Regardless of which migration approach you choose, your organizational role concept must be conceptionally and technically functioning to provide restrictive company-wide access. If you don't meet this precondition, you must rework your role concept before starting with your migration.

13.3 Design Phase: Conceptual Role Migration

The design phase involves conceptual work for the migration of the authorizations in your existing role concept. You should coordinate role content, process compliance,

Personal Copy for Arun Singal, arun.singal560@gmail.com

and security-related guidelines within this project step with your business departments. This coordination can also help verify and define the user ID assigned to each department, job functions, and thus required roles. This classification enables a department-specific analysis to inform your preparation with role design-relevant information. In this way, you can also reduce your conceptual effort because you'll have a precise categorization of your end users, which helps you identify and adjust their functional requirements (like transactions, SAP Fiori applications, or specific authorization values).

Regardless of your migration approach, you should conceptually build up an approved project scope (e.g., end users, applications, or restriction requirements) to cover all business needs.

To this end, this section analyzes several SAP S/4HANA-related changes in roles and explores the business unit workshops that you should conduct to verify role contents. In addition, we'll walk you through some conceptual considerations regarding the introduction of SAP Fiori with XAMS.

13.3.1 Virtual Role Concept Design

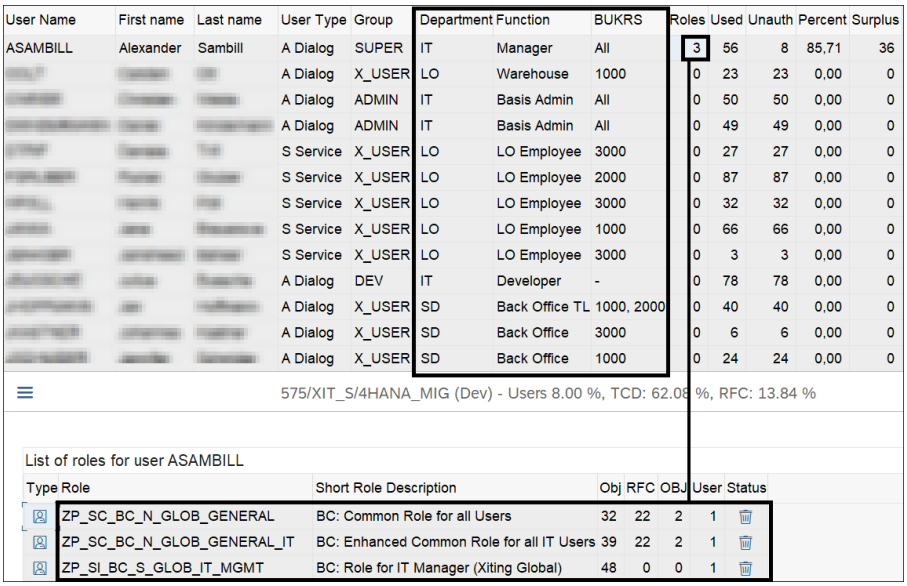
In practice, collecting all the relevant data you need for a migration is often a complicated task since you must cover all your end users and the applications they use, find the related job functions, and evaluate the coverage rate of your new roles against your end users' requirements before testing. Also, in SAP standard, creating multiple roles all at once, maintaining applications in multiple roles, or automatically integrating SAP S/4HANA-relevant changes and adjustments to many roles can be difficult. The solution to all these issues and much more is Xiting Role Designer. Within this tool, you can create a virtual role and user concept. Then, before you start searching for the required system data manually to form the foundation for your migration project, the Xiting Role Designer can do this research automatically for you.

Start by creating an initial virtual project and have the tool automatically collect project data directly from the productive system (PRD), for instance, of all active dialog users; their Transaction ST03N data (e.g., to collect used transactions or function modules); and required organizational data, for instance, accounting customers through the changelogs of table KNB1 or sales through the changelogs of table VBAK. Xiting Role Designer can serve as your project module, even if starting from scratch (in a greenfield implementation).

Now, you can maintain your project and PRD data on the DEV. For instance, you can first classify all end users according to their departments (**Department**), job functions (**Function**), and organizational restrictions (e.g., **BUKRS**—company code), as shown in Figure 13.9. Furthermore, you can directly create virtual roles, massively maintain applications in roles using the SAP standard, and assign them to the end users in your project. In addition, you can also import existing roles into your project to work with

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

your current role concept. Furthermore, you can validate whether your job function roles fit the objectives and applications used by your end users, which you can see through the **Percent** column. This column shows the end-user coverage rate of the virtual assigned roles (e.g., ZP_SI_BC_S_GLOB_IT_MGMT) compared against their previously used applications (e.g., **ASAMBILL**).



User Name	First name	Last name	User Type	Group	Department	Function	BUKRS	Roles	Used	Unauth	Percent	Surplus
ASAMBILL	Alexander	Sambill	A Dialog	SUPER	IT	Manager	All	3	56	8	85,71	36
[redacted]	[redacted]	[redacted]	A Dialog	X_USER	LO	Warehouse	1000	0	23	23	0,00	0
[redacted]	[redacted]	[redacted]	A Dialog	ADMIN	IT	Basis Admin	All	0	50	50	0,00	0
[redacted]	[redacted]	[redacted]	A Dialog	ADMIN	IT	Basis Admin	All	0	49	49	0,00	0
[redacted]	[redacted]	[redacted]	S Service	X_USER	LO	LO Employee	3000	0	27	27	0,00	0
[redacted]	[redacted]	[redacted]	S Service	X_USER	LO	LO Employee	2000	0	87	87	0,00	0
[redacted]	[redacted]	[redacted]	S Service	X_USER	LO	LO Employee	3000	0	32	32	0,00	0
[redacted]	[redacted]	[redacted]	S Service	X_USER	LO	LO Employee	1000	0	66	66	0,00	0
[redacted]	[redacted]	[redacted]	S Service	X_USER	LO	LO Employee	3000	0	3	3	0,00	0
[redacted]	[redacted]	[redacted]	A Dialog	DEV	IT	Developer	-	0	78	78	0,00	0
[redacted]	[redacted]	[redacted]	A Dialog	X_USER	SD	Back Office TL	1000, 2000	0	40	40	0,00	0
[redacted]	[redacted]	[redacted]	A Dialog	X_USER	SD	Back Office	3000	0	6	6	0,00	0
[redacted]	[redacted]	[redacted]	A Dialog	X_USER	SD	Back Office	1000	0	24	24	0,00	0

575/XIT_S/4HANA_MIG (Dev) - Users 8.00 %, TCD: 62.08 %, RFC: 13.84 %

List of roles for user ASAMBILL

Type	Role	Short Role Description	Obj	RFC	OBJ	User	Status
	ZP_SC_BC_N_GLOB_GENERAL	BC: Common Role for all Users	32	22	2	1	
	ZP_SC_BC_N_GLOB_GENERAL_IT	BC: Enhanced Common Role for all IT Users	39	22	2	1	
	ZP_SI_BC_S_GLOB_IT_MGMT	BC: Role for IT Manager (Xiting Global)	48	0	0	1	

Figure 13.9 User Analysis in Xiting Role Designer

Please note that you should always create your role concept in collaboration with your business units because only those users can provide information about their actual requirements. Therefore, the conceptual perspective developed in design workshops can cover and create consensus on changed role contents, functionalities, and business processes. Due to SAP's principle of one concept, numerous applications have been centralized into particular transactions. For example, Transaction BP is now the single point of entry for the business partner model. In some cases, you must cover other centralized master data maintenance or actions according to new processes and security requirements. Changes you may also face involve the integration of the SAP Fiori launchpad and SAP Fiori applications. Thus, you must evaluate and discuss the previous role analysis results combined with your business departments' demands and process changes.

13.3.2 Analyzing SAP S/4HANA-Related Role Changes

The information basis for this project step analyzing SAP S/4HANA-related changes is the simplification list for SAP S/4HANA. Before you can start matching your current role concept with this list or via Microsoft Excel manually, we recommend using XAMS.

Personal Copy for Arun Singal, arun.singal560@gmail.com

The simplification list is embedded in XAMS as a customizing table and is a release-dependent delivery. With each new XAMS release, you'll get an update. However, you can update XAMS manually as well. Furthermore, even if you use Transaction SU25 to validate obsolete transactions with SAP S/4HANA, you may miss the entire extent of the simplification list and miss replacements.

For the immediate analysis of changes according to a standard-compliant SAP S/4HANA migration, you can use the Xiting Role Profiler report **Migration of roles to S/4HANA**, which lists all affected roles through SAP S/4HANA directly.

You can double-click on a column's **Obsolete** field value to get a list of related role menu objects, like transactions in the target role that are no longer valid or have been replaced in SAP S/4HANA, as shown in Figure 13.10.

Role	Description	Obsolete	Adjust	Introduced	Append
ZP_ME_CO_N_GLOB_CLERK	Co: Role for Controlling Clerk ($ORGTEXT)	11		4	
ZP_ME_CO_N_GLOB_MGMT	CO: Role for Controlling Manager ($ORGTEX...	3		1	
ZP_ME_FI_N_GLOB_AUDITOR	FI: Role for Finance and Controlling Auditor ($...	9		3	
ZP_ME_FI_N_GLOB_CLERK	FI: Role for Finance Clerk ($ORGTEXT)	11		4	
ZP_ME_FI_N_GLOB_KEY	FI: Role for Finance Keyuser ($ORGTEXT)	13		2	
ZP_ME_FI_N_GLOB_MGMT	FI: Role for Finance Manager ($ORGTEXT)	13		1	
ZP_ME_SD_N_GLOB_FS	SD: Role for Field Service ($ORGTEXT)	11		4	
ZP_ME_SD_N_GLOB_INT_SALES	SD: Role for Internal Sales ($ORGTEXT)	3		0	

Xiting Role Profiler: Migration of roles to S/4HANA (8 hits)

Obj. Type	Obsolete	Description	SU24	Obj. Type	Replacement	Description	SU24	App IDs
TRAN	FBL3N	G/L Account Line Items		TRAN	FAGLL03	G/L Account Line Items (New)		F2218; F0706
TRAN	FD03	Display Customer (Acc...		TRAN	BP	Maintain Business Partner		F3163; F0850A; F1053A
TRAN	FD32	Change Customer Cred...		TRAN	UKM_BP	Credit Management Business Partner		F4596
TRAN	FI01	Create Bank		IWSV	FCLM_BM_SR...	Bank managment		
TRAN	FI02	Change Bank		IWSV	FCLM_BM_SR...	Bank managment		
TRAN	FI03	Display Bank		IWSV	FCLM_BM_SR...	Bank managment		
TRAN	FK03	Display Vendor (Accou...		TRAN	BP	Maintain Business Partner		F3163; F0850A; F1053A
TRAN	FS03	Display Master Record		TRAN	FS00	G/L acct master record maintenance		F0731A; F0731
TRAN	FS10N	Balance Display		TRAN	FAGLB03	Display Balances		W0097; F2767; F0996; F308...
TRAN	XD03	Display Customer (Cen...		TRAN	BP	Maintain Business Partner		F3163; F0850A; F1053A
TRAN	XK03	Display vendor (centrall...		TRAN	BP	Maintain Business Partner		F3163; F0850A; F1053A

Figure 13.10 Xiting Role Profiler Migration of Roles to S/4HANA Report

In addition, OData services (**IWSV**) indicate SAP Fiori application (**App IDs**) replacements. You can also download the result list to discuss changes and requirements with your business units. Note that this export file only contains the present status of your roles with SAP S/4HANA-relevant changes. If you change your roles or change your system release, you should revalidate your changes. Please note that SAP provides ongoing SAP Fiori changes with each SAP S/4HANA release. After these updates, you can directly and massively change all roles and their contents in SAP S/4HANA with few clicks.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Another option is the direct analysis of your virtual roles in Xiting Role Designer. This module also contains an embedded SAP S/4HANA role change analysis and maintenance report.

Since these reports validate the role menu objects, you must be sure that you don't have any manual start authorization objects to avoid gaps in your analysis and SAP S/4HANA role changes. Thus, for a technical conversion with manual authorization objects in roles, you must maintain all applications via the role menu to provide a stable analysis basis. You can achieve this goal by analyzing start authorization objects (such as S_TCODE) of your current roles via table AGR_1251 and then maintaining the transaction in your role menus. This approach allows you to analyze non-standard-compliant roles through migration reports.

13.3.3 SAP Fiori Analysis

With SAP Fiori and its applications, you must fulfill several requirements to enable the usage of SAP Fiori launchpad in your roles. You'll need the correct system setup, including SAP Fiori business catalogs, groups, spaces, and pages so that your end users can use SAP Fiori. XAMS offers the ability to automatically match the transaction codes used by specific end users to decide on SAP Fiori applications. Launch the Xiting Role Profiler module and use the report **Map used tcodes to Fiori apps**. This report shows all end users (by user ID) in the scope the transactions they used against the SAP Fiori Apps Reference Library data to find suitable replacements in the SAP Fiori applications. Figure 13.11 shows you the different sources you can choose for the report. In detail, you can select between the Xiting Role Designer virtual project usage data (**Role Designer Repository**), Transaction **ST03N data** (system's end-user usage data), excel file for mapping massively specific transactions (**File upload data**), or through the **free selection data** for individual transactions to SAP Fiori, regardless of their former usage.

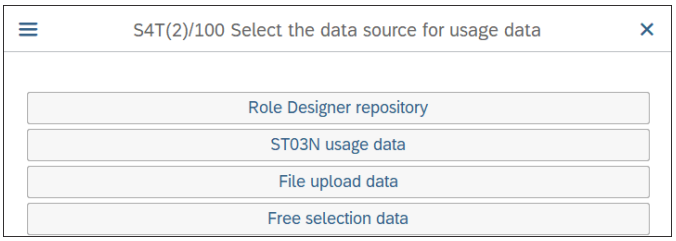
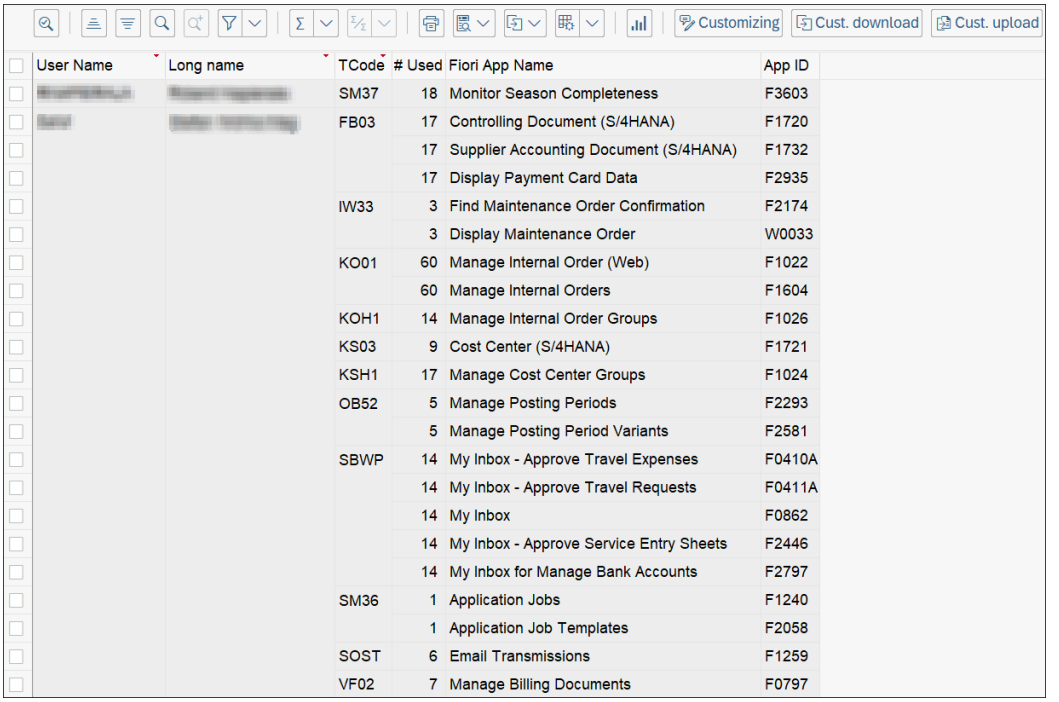


Figure 13.11 Source of Usage Data for the SAP Fiori Mapping

Based on this report, you'll see the possible SAP Fiori app replacements (**App ID**) and their names (**Fiori App Name**), as shown in Figure 13.12. You can also download this result list to assist secondary analysis perhaps during role design workshop discussions.

Personal Copy for Arun Singal, arun.singal560@gmail.com



User Name	Long name	TCode	# Used	Fiori App Name	App ID
[redacted]	[redacted]	SM37	18	Monitor Season Completeness	F3603
[redacted]	[redacted]	FB03	17	Controlling Document (S/4HANA)	F1720
			17	Supplier Accounting Document (S/4HANA)	F1732
			17	Display Payment Card Data	F2935
		IW33	3	Find Maintenance Order Confirmation	F2174
			3	Display Maintenance Order	W0033
		KO01	60	Manage Internal Order (Web)	F1022
			60	Manage Internal Orders	F1604
		KOH1	14	Manage Internal Order Groups	F1026
		KS03	9	Cost Center (S/4HANA)	F1721
		KSH1	17	Manage Cost Center Groups	F1024
		OB52	5	Manage Posting Periods	F2293
			5	Manage Posting Period Variants	F2581
		SBWP	14	My Inbox - Approve Travel Expenses	F0410A
			14	My Inbox - Approve Travel Requests	F0411A
			14	My Inbox	F0862
			14	My Inbox - Approve Service Entry Sheets	F2446
			14	My Inbox for Manage Bank Accounts	F2797
		SM36	1	Application Jobs	F1240
			1	Application Job Templates	F2058
		SOST	6	Email Transmissions	F1259
		VF02	7	Manage Billing Documents	F0797

Figure 13.12 Xiting Role Profiler for Mapping Transaction Codes to SAP Fiori App Reports

Hint

With a central hub deployment, job function roles will require newly designed SAP Fiori entities like business groups, catalogs, and OData services (IWSG) in the frontend system but will not require business authorization objects. This maintenance makes SAP Fiori applications visible to the end user in the SAP Fiori launchpad, and they can execute these applications. In contrast, you must ensure that the backend roles contain the OData services (IWSV), the business catalogs, and department-specific authorization maintenance. Note that SAP recommends using the embedded deployment approach. See SAP Note 2590653 for more details.

13.4 Implementation Phase: SAP S/4HANA Role Implementation

In this phase, you'll implement the SAP S/4HANA-related changes approved during business unit workshops into your role concept on your sandbox system. In addition, you must derive adjustments from the role template to your derived roles and analyze your new roles for critical authorizations and undesirable combinations. Furthermore, you must analyze your SAP Fiori authorizations. In practice, achieving all these objectives is cumbersome work in the short run. Thus, XAMS offers several features to easily

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

migrate your roles, push role template changes to your derived roles, and simultaneously validate your role concept for SoD conflicts and the required SAP Fiori authorizations.

This chapter describes the technical migration of existing roles into SAP S/4HANA. Also, we'll introduce you to the derivation of roles and features, which you can use to enhance quality assurance in your roles via XAMS.

13.4.1 Role Migration to SAP S/4HANA

This project step includes the technical transition of SAP S/4HANA changes into your roles as well as authorization value maintenance and role profile generation.

In this step, you should use the integrated migration function in Xiting Role Profiler or Xiting Role Designer on your target role selection once again. Please note that a best practice is to retain the old transactions to help your upcoming authorization data maintenance in the authorization profile. Thus, you should only activate the role menu changes in the **Append** column of the listed roles, instead of the role menu changes in the **Adjust** column, which replaces all former SAP ERP 6.0 role menus, as shown in Figure 13.13. Please note that SAP S/4HANA's simplification list does not completely require entire new check mechanisms and authorization default values. For instance, the system still checks the authorization objects F_KNA1* and F_LFA1* for business partner administration in Transaction BP since only these authorization objects restrict organizational access via organization levels. It is impossible to pass the implemented authority checks for those specific functions and actions for transaction BP with business partner authorization objects B_BUPA*. In this case, existing authorizations and their values from old applications can be helpful. You can reuse information from previous authorization profile maintenance and only handle newly introduced authorizations. Therefore, we recommend only using the appending mode to have a correlation between the former transactions and the new SAP S/4HANA replacements, as well as for their proposed authorizations. However, you also must adjust your current authorization characteristics or create new roles to respond to changed business processes.

After you append the new role menu objects (as shown in the **Introduced** column) following best practices via XAMS, you can directly move to role administration (Transaction PFCG) by double-clicking the role's name on the role overview screen, as shown in Figure 13.13. Now, you can maintain newly introduced default values for the added SAP S/4HANA role menu objects in the authorization profiles of your roles.

For a direct implementation of SAP S/4HANA changes into your roles, you can use Xiting Role Profiler or Xiting Role Designer when leading a role concept redesign and migration or a standard-compliant migration.

Personal Copy for Arun Singal, arun.singal560@gmail.com

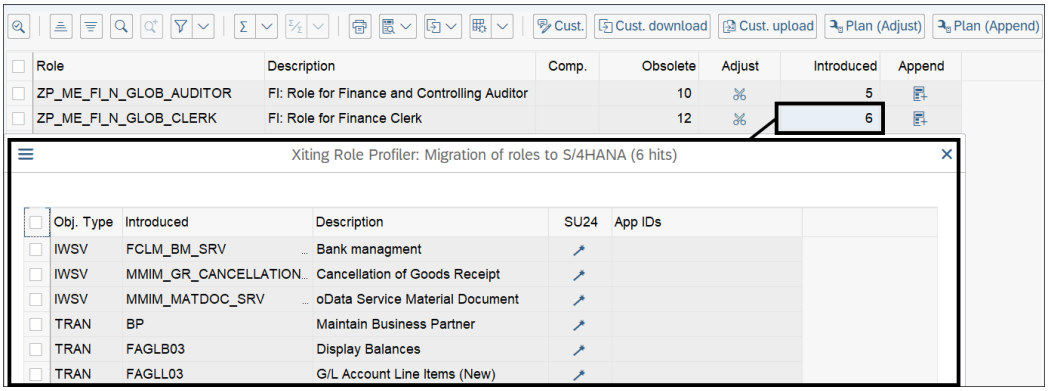


Figure 13.13 Introducing SAP S/4HANA-Related Changes in Roles

However, for technical conversions, direct implementation is not that easy. With this approach, you must save the original role profiles of your current roles because you may not know why an authorization exists (in the case of manual authorization objects). Your role menus may not be well maintained, and you may not have access to any where-used lists in the authorization profile.

Hint

Please note that, if your role menus are not maintained or are poorly maintained, your roles will only contain a manually maintained authorization object S_TCODE. This object also has value ranges, so you should avoid performing a technical conversion. Instead, a better process is to pursue an initial role concept redesign as, otherwise, this migration project might turn out more difficult than an upstream redesign and subsequent SAP S/4HANA role concept migration.

If you maintain the required role menu objects, adverse side effects may occur before saving the current status of the role profile. You cannot separate the old and new authorizations based on role menu maintenance, especially if you use manual authorizations combined with standard start authorization objects. This mix of authorizations makes examining the necessity of a role, against business requirements and applications, rather difficult. In this case, you can use Xiting Role Replicator's **Role Authorization Merger** report, as shown in Figure 13.14. The purpose of this tool is so you can select the authorization data of a role and import this data as manual authorizations into itself or into another role. Thus, you can also take the authorization data of multiple roles and merge them into a single role to simplify your authorization concept in the technical conversion approach. You can thus take a snapshot of a role, which makes its authorization independent of Transaction SU24, ensuring that nothing is lost when merging. After all, you had reasons for maintaining these manual authorizations in the past.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Please note that the role profile merge capability saves the current authorization characteristics in your roles as manual authorization objects. However, your roles are thus corrupted with manual authorizations, and a subsequent redesign is recommended anyway.

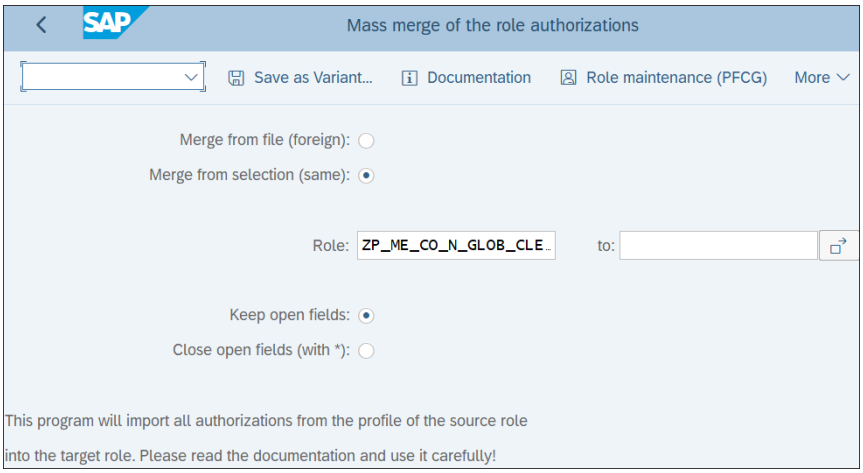


Figure 13.14 Mass Merge of Role Authorizations Report

Now, you can run XAMS for the SAP S/4HANA role migration. If you have a manually maintained authorization object S_TCODE, you must validate all required transactions and enter these transactions as role menu objects in your roles before starting your migration.

13.4.2 Extension of Roles with New SAP S/4HANA Functions

This project step probably requires the greatest technical effort. Before you can start maintaining your authorization objects, make sure that your job function roles contain the required SAP Fiori entities based on the business unit decisions made during the role concept design phase. Next, you must validate whether your SAP Fiori integration suits your technical needs. Also, you must implement or change your roles' authorizations according to the new required SAP S/4HANA functions and business processes as well as verify your role concept is compliant with external and internal security requirements. We'll discuss these concepts further in this section.

SAP Fiori Analysis

When you authorize SAP Fiori applications in your SAP S/4HANA roles, XAMS also offers many valuable reports and functions to analyze whether your users, roles, and business catalogs fit the technical requirements.

For instance, you can use Xiting Role Profiler to check the consistency of your SAP Fiori authorization concept during the role implementation phase. This module provides

Personal Copy for Arun Singal, arun.singal560@gmail.com

the report **OData services for Fiori** to directly compare the required OData services of your SAP Fiori apps with the selected roles and their role menus (based on the existing SAP **Fiori catalogs** definitions) to see if those required services are also part of the roles through the catalog assignment, as shown in Figure 13.15. Also, the report verifies other useful information, like the activation statuses of services and ICF nodes, covering both frontend services as well as backend (**BE**) services. If a mismatch exists, you can select the missing services and add them to role menus directly from Xiting Role Profiler.

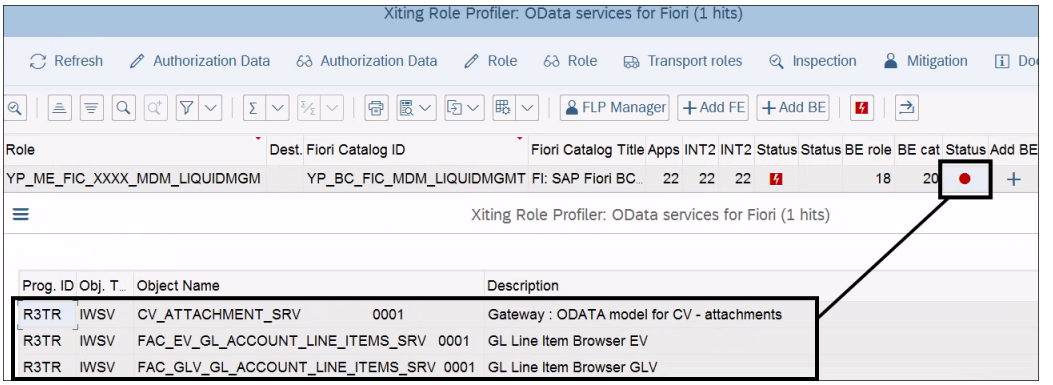


Figure 13.15 OData Services for SAP Fiori Xiting Role Profiler Report

Another useful report for this type of analysis is the **Catalogs with content problems** report, which lists SAP Fiori catalogs with possible content problems, like lost references and configuration errors. In this way, you can focus on incorrect catalogs, for direct analysis and resolution, as shown in Figure 13.16.

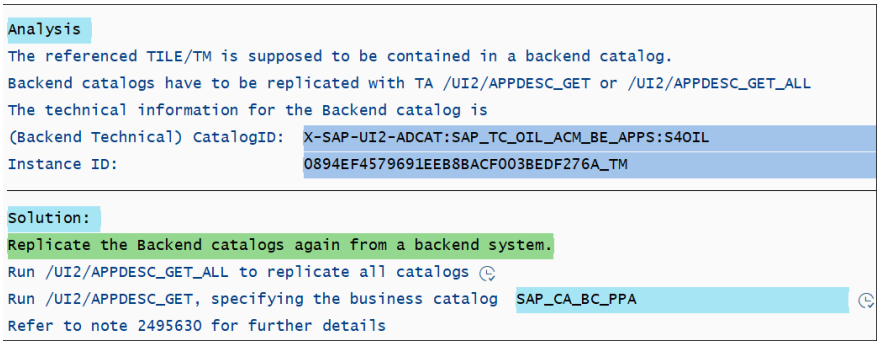


Figure 13.16 XAMS SAP Fiori Catalog Analysis and Issue Solution

Hint

See Chapter 8 for best practices in SAP Fiori role integration and further information.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Authorization Maintenance and Profile Generation

First, you must consider all the regulations articulated during business workshops as well as the decisions and differentiation required within authorization profiles of your roles. Therefore, always enter every required role authorization profile with the expert mode option **Read old status and merge with new data.** An additional option is to use the Xiting Role Profiler report **Read old, merge new** to see which roles require an update directly.

In the authorization profiles, you check each new or updated authorization field. In this process, you should deactivate critical access in advance and only activate them during the validation phase when required. You can fill in an approved value for new open authorization fields according to the intended business processes. If you do not know how to maintain some authorization values yet, flag them by using a dummy value like the special character "@." Authorization fields that do not require any access restrictions or any differentiation are good candidates to maintain with an asterisk (*) for full access, as shown in Figure 13.17, which simplifies your role validation and administration effort.

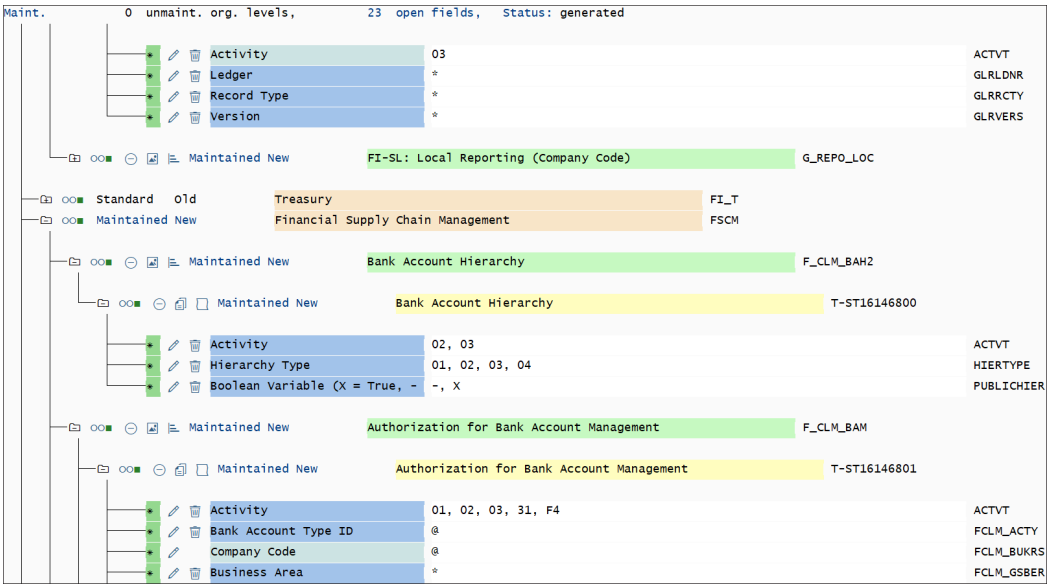


Figure 13.17 Authorization Maintenance in SAP S/4HANA Roles

Please note that using an asterisk depends greatly on your business requirements and internal regulations as well on related activity authorizations. Whereas the asterisk might be suitable for display-only activities, you should be more restrictive for activities like create or change activities.

According to your organizational structure, for master roles that serve as templates for inheritance or XAMS replication, define organizational levels also with a dummy value

Personal Copy for Arun Singal, arun.singal560@gmail.com

like "@," as shown in Figure 13.17. These roles are usually not assigned to end users. If only certain organizational levels have a fixed value, you can define these values in those templates to reduce your overall maintenance effort in its derived roles. Otherwise, you'll maintain all central organizational levels such as company codes, controlling areas, works, sales organizations, and purchasing organizations in your derived roles or in the OrgSet definitions of Xiting Role Replicator. Finally, generate each template role profile to save your authorization changes.

Hint

See Chapter 6, Section 6.5, for some best practices in role building and further information.

This authorization profile maintenance is suitable for a redesign or a standard-compliant migration without any manual authorizations in roles. For a technical conversion approach, first, you should inactivate new default data in your roles, or enter a dummy value like the special character "@", after making your role menu adjustments because these authorizations did not exist in your former roles. Otherwise, you would require tremendous authorization maintenance effort because of all the open authorization default values. Then, based on your role testing, you'll determine whether the dummy value authorization fields are additionally required combined with your manual authorization. In that case, activate them again and maintain them according to the test results.

Instead of directly maintaining open authorization fields during a technical conversion, a better approach is to clean up your role concept with a redesign to save time and effort in the long term.

Security Compliance Assurance

After role maintenance, you should check your newly maintained business roles against your updated compliance specifications to conform to internal and external rules. Do this step before you start role testing. For this verification, you can use Xiting Role Profiler. In addition, you can modify the delivered Xiting ruleset (CRAF) with your company requirements based on the authorization value level (**From**), as shown in Figure 13.18. Furthermore, you can also connect your existing SAP governance, risk, and compliance solutions (SAP GRC solutions) ruleset with the CRAF ruleset to use also your predefined SAP GRC solutions business checks during role creation and maintenance as well as for the role profiles security analysis.

Use the Xiting Role Profiler watchdog reports **Critical auth watchdog** and **Critical combination watchdog** for Internal Control System (ICS) validation. These reports are directly correlated with the implemented CRAF ruleset, which provides different check IDs with predefined check values.

 © 2022 by Rheinwerk Publishing Inc., Boston (MA)

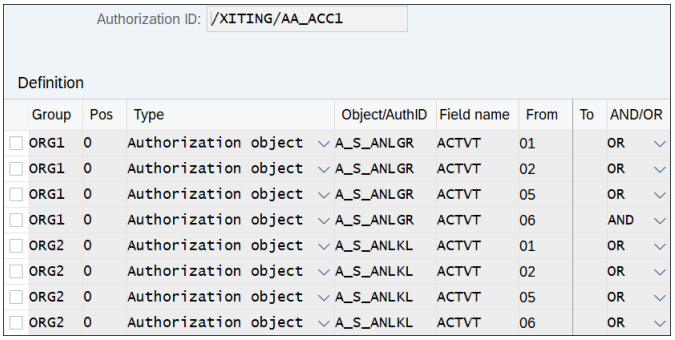


Figure 13.18 Asset Master Data Maintenance for an Xiting CRAF ID

Once you execute these reports, they'll show you the number of errors in each selected role and detailed information about the critical authorizations that caused these findings, as shown in Figure 13.19.

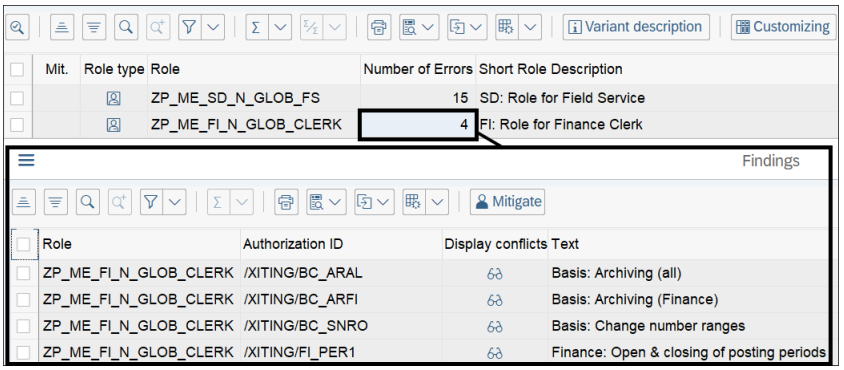


Figure 13.19 Xiting Role Profiler Critical Auth Watchdog Report

If possible, correct any identified inaccuracies. For unresolvable conflicts of functional separation, create an exception (by clicking the **Mitigate** button) and document mitigations in coordination with your business departments.

Hint

You can use Xiting Security Architect to establish an ICS into your system landscape. In addition, XAMS contains many specific reports and rulesets, including the Xiting Data Protection Authorizations (GDPR) set to conduct a role audit against specifications for General Data Protection Regulation (GDPR) compliance.

13.4.3 Template Roles Replication

Replicating your template roles (master roles) is crucial for synchronizing your authorization maintenance settings from your master roles to their derived roles. This data

Personal Copy for Arun Singal, arun.singal560@gmail.com

transfer includes all functional-related entities (role menu objects) and authorization characteristics (authorization objects, fields, and values). This replication is often complex because you must maintain the related template roles and always manually cover organizational changes for countless derived roles. Xiting Role Replicator enables a more efficient role synchronization and maintenance process with the introduction of two technical steps:

- The transfer of all role menu objects and authorization data from a template role to its derived roles.
- The transfer of the predefined organizational values in OrgSets and OrgSet groups in Xiting Role Replicator based on the organization-level specifications from a template role to its derived roles.

Due to organizational system changes with SAP S/4HANA, you might need to establish or update your organization access settings in XAMS (**orgset groups/orgsets**) before pushing all template role changes, as shown in Figure 13.20.

	Fa...	Value Fro...	Value To	Hierarchy
Orgset group SAP-00 (SAP AG)				
Orgset group GLOB (Xiting)				
Orgset 1000 (Xiting AG Switzerland)				
$BUKRS (Company Code)		1100		
$BUKRS (Company Code)		1200		
$BUKRS (Company Code)		1300		
$EKGRP (Purchasing Group)		001		
$EKORG (Purchasing Organization)		1000		
$IWERK (Maintenance planning plant)		1100		
$IWERK (Maintenance planning plant)		1200		
$IWERK (Maintenance planning plant)		1300		
$KOART (Account Type)		M		
$KOART (Account Type)		S		
$KOKRS (Controlling Area)		9999		
$PLVAR (Plan Version)		1		
$SPART (Division)		1		
$SWERK (Maintenance plant)		1000		
$VKGRP (Sales Group)		1		
$VKORG (Sales Organization)		1000		
$VSTEL (Shipping Point)		1		
$VTWEG (Distribution Channel)		1		
$WERKS (Plant)		1000		

Figure 13.20 Role Replicator OrgSet Definition

Hint

If you use the SAP standard derivation concept, template roles must be derived using the common procedure. See Chapter 6, Section 6.2.4, for more information. Furthermore, you can combine the SAP inheritance concept and the XAMS replication approach to get the best of both worlds.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

A successful XAMS role replication process requires only the following steps:

1. For newly created roles, reference the template role to the defined role replication target (the name of the derived role) with the desired OrgSet or OrgSet group, as shown in Figure 13.21.

   For instance, we can replicate all authorizations from **ZP_ME_CO_N_GLOB_CLERK** to **ZP_SE_CO_S_1000_CLERK** with the **Orgset 1000**. In this process, you must consider your role naming convention as well. For existing roles, you can start with step 2.

2. Next, copy the linked OrgSet or OrgSet group's organizational levels entirely in all role replication definitions or separately for each role. The red icons will switch to green in the **Prereq.** column, while the **Description** fields of each derived roles also becomes available. Both events indicate that the replication was successful, as shown in Figure 13.22. As a final step, you only need to generate the role profile.

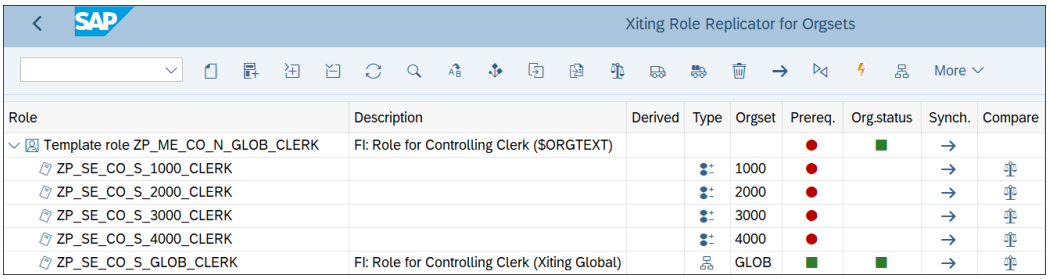


Figure 13.21 Role Replication Definition with XAMS

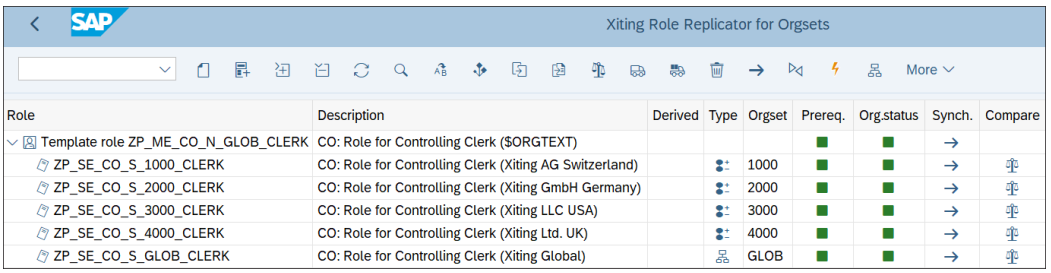


Figure 13.22 Finished Role Replication with XAMS

Furthermore, Xiting Role Replicator offers an extensive inheritance analysis feature. You can re-evaluate your OrgSet definitions if values defined in a template role's organizational levels are not mapped in an OrgSet entity or if other issues arise. The **Compare** column enables a direct evaluation between an OrgSet's definition and a role's organizational fields, as shown in Figure 13.23. The yellow triangle is a warning that the template role provides an organization level, for instance, **$ARBPL (Work Center)**, that is not covered in the OrgSet. A red icon would indicate a failure, for instance, an outdated role replication because the OrgSet and derived role organization level values do

Personal Copy for Arun Singal, arun.singal560@gmail.com

not fit. The green square shows that the derivation has been performed correctly, for instance, **$BUKRS (Company Code)**.

Org. field	ZP_ME_CO_N_GLOB_CLERK	Orgset group 1000	ZP_SE_CO_S_1000_CLERK	Status
$ARBPL (Work Center)	@	⊗	@	▲
$BUKRS (Company Code)	@	1100, 1200, 1300	1100, 1200, 1300	■
$EKGRP (Purchasing Group)	@	001	001	■
$EKORG (Purchasing Organization)	@	1000	1000	■
$ERKRS (Operating Concern)	@	⊗	@	▲
$FIKRS (FM area)	@	⊗	@	▲
$GSBER (Business Area)	@	⊗	@	▲
$IWERK (Maintenance planning plant)	@	1100, 1200, 1300	1100, 1200, 1300	■
$KKBER (Credit Control Area)	@	⊗	@	▲
$KOART (Account Type)	@	M, S	M, S	■

Figure 13.23 OrgSet Group and Derived Role Comparison

In addition, Xiting Role Replicator contains an complete role comparison function, as shown in Figure 13.24, so you can conduct an extensive role consistency check on different levels.

Figure 13.24 Role Replicator Consistency Check

Suppose you want to analyze incorrect derivations but don't know which derived role authorization failed to fit the template. You can compare all authorization values with Xiting Role Replicator to find the outliers, as shown in Figure 13.25. In this example, the activity (**ACTVT**) values of the authorization object **K_CSKB** vary in both roles. This inconsistency is labeled with the green and red icons. Please note that the reference role is the leading role within an inheritance concept for the comparison. For example, that in the reference role, the authorization value 01 (Create) is proposed as a standard value (illustrated through the string **S**) for the field **ACTVT** of the authorization object K_CSKB. On the contrary, this authorization object is inactivated in the derived role, which you can see through the **X** in the second line. Since the master and its derivation must only differ in the organizational levels, you must cover the correct template's default in the derived role. Hence you must push the changes from the template role to the derived one.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

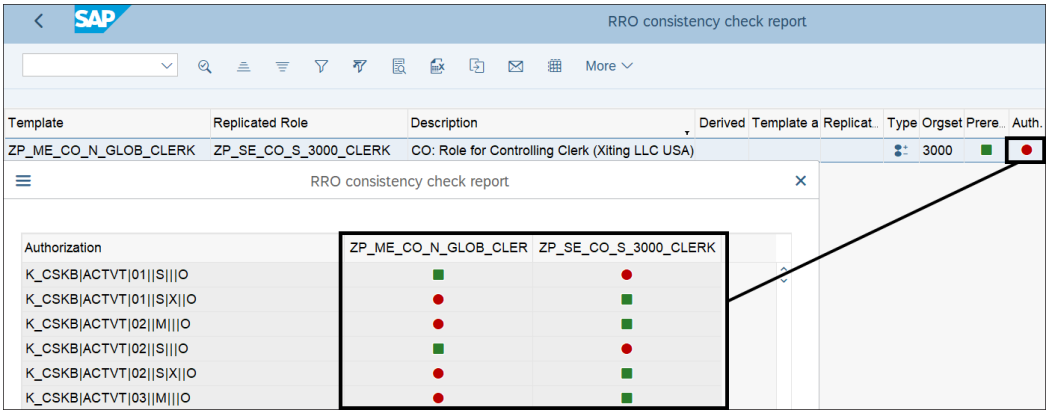


Figure 13.25 Authorization Consistency Check for Derived Roles

Hint

If you use Xiting Role Replicator for role derivation, maintain the variable `$ORGTEXT` in the master role's **Short Description**. This maintenance step makes the short text of the replicated roles as meaningful as possible because the variable corresponds to the short text of the OrgSet. During replication, Xiting Role Replicator copies this template role's short text but replaces the variable with the corresponding description of your OrgSet for that organizational structure. In this way, the short description of the template role **CO: Role for Controlling Clerk ($ORGTEXT)** enables the short description of the derived role **CO: Role for Controlling Clerk (Xiting AG Switzerland)**, as shown earlier in Figure 13.22. For further information, see Chapter 4, Section 4.4, and the module documentation.

13.5 Validation Phase: SAP S/4HANA Role Concept Analysis

The main target of the validation phase is to improve the maturity level and the stability of your entire role concept. Further, you can verify whether the business unit's role reconciliation and authorization maintenance fit your business requirements. Within this project step, you'll simulate and compare SAP S/4HANA roles using the PTS feature against test activities in a sandbox system instead of following an entirely manual approach. In SAP standard, you can neither test on the PRD nor prevent interruptions to end users. Also, testing is a complex and iterative procedure to identify missing or incorrect authorizations immediately. The XAMS modules Xiting Role Builder and Xiting Times solve these issues and reduce your entire role test effort.

In this section, we'll provide an overview of the preparation and evaluation of test scenarios with XAMS. We'll also explain the process of validating and implementing test results in your roles.

Personal Copy for Arun Singal, arun.singal560@gmail.com

Hint

Please note that fundamental to an SAP S/4HANA authorization migration is to only perform positive tests for the functional role testing. Then, you can also conduct negative testing to avoid unintentional access. Read Chapter 11, Section 11.7.7 , for more information about these various test approaches.

13.5.1 Defining and Preparing Test Scenarios

Before you can start your testing phase, you'll require some conceptual and technical preconditions. Thus, your first testing steps are implementing your technical setup and classifying test scenarios. Then, you can start your operative work, such as test analysis and the implementation of test results in your roles.

For this purpose, you can easily use the upload and download functions of Xiting Times to establish company-wide test scenarios with all required testers. You only need to maintain two required master data tables for your test simulation. The following information is required to enable the automatic PTS functions in XAMS so that you can test in the background without any business interruptions:

- Choose the required test mode scenario for each reference user
- Assign reference users to dialog end users in the Xiting Times master data tables

The final preparation task is assigning the different roles to the reference and dialog users. In this step, specific reference users require the new roles you want to validate, and the dialog users require the SAP_APP role in the context of an SAP S/4HANA test.

Hint

See Chapter 12, Section 12.7.7, for detailed information about processing your tests with the SAP_APP role.

The system validates first the attached reference user authorizations (indirect authorizations) of the related dialog user buffer. Then, if an authorization error occurs, the system compares the failed authorization check against the direct authorizations in the buffer of the dialog user. Please note that, with the SAP_APP role, SAP Fiori apps are not included, and you must assign the required SAP Fiori business catalogs (e.g., through custom or SAP standard business roles) additionally.

Hint

See SAP Note 1960916 for more information about authorization processing with an assigned reference user.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

At this point, you must maintain the correct role assignments. Therefore, open Xiting Role Replicator and use its mass maintenance functions, such as massively assigning roles to users via an Microsoft Excel file upload, as shown in Figure 13.26. Notice that the reference users (e.g., **S_ASAMBILL**) contain the new SAP S/4HANA roles, and the dialog users (e.g., **ASAMBILL**) contain the SAP_APP role to enable extensive testing without considering missing authorizations. You can use this upload file also within a CUA environment.

A	B	C	D	E
S_ASAMBILL	ZP_SI_BC_S_0000_IT_MGMT	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SI_BC_S_0000_IT_KEY	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SI_BC_S_0000_IT_BASIS	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SC_BC_N_GLOB_GENERAL	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SC_BC_N_GLOB_GENERAL_IT	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SE_HR_S_0000_TRAV_EXP	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SE_HR_S_0000_TIME_EVA_IT	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_VE_CO_COST_HI10001050	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_VE_CO_PRCT_PH10001050	S4XCLNT100	1900-01-01	9999-12-31
S_ASAMBILL	ZP_SE_HR_S_0000_WF	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_SE_SD_S_1000_INT_SALES	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_SE_SD_S_1000_MGMT	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_SE_SD_S_1000_KEY	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_SC_BC_N_GLOB_GENERAL	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_SE_HR_S_1000_TRAV_EXP	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_VE_CO_COST_HI10001010	S4XCLNT100	1900-01-01	9999-12-31
S_ABANZER	ZP_VE_CO_PRCT_PH10001010	S4XCLNT100	1900-01-01	9999-12-31
ASAMBILL	ZP_SC_BC_SAP_APP_INTEGRATION	S4XCLNT100	1900-01-01	9999-12-31
ABANZER	ZP_SC_BC_SAP_APP_INTEGRATION	S4XCLNT100	1900-01-01	9999-12-31

Figure 13.26 Upload File for Massive Role Assignments

Once you've assigned the roles via the upload file, you can start your test scenarios in one click in the sandbox system for an SAP S/4HANA migration or in the PRD for a role concept redesign.

13.5.2 Evaluating and Implementing of Test Results

At this point in your SAP S/4HANA authorization migration project, you can evaluate your new role concept's coverage rate and how it handles business and technical demands. In this step, you'll verify whether the new end-user authorizations fit their day-to-day tasks and determine what is missing. With the automatic Xiting Role Builder tools, you can analyze the collected test data and uncover potential deficits in your new role concept based on predefined test scenarios. In addition, now is also a good time to validate this data from the point of view of proposal maintenance by looking for potential candidates for Transaction SU24 data optimization. Especially for custom developments, we recommend performing these analyses during your validation phase. The following sections will cover ongoing authorization optimization for roles as well as how to analyze deviations in roles (also known as *delta analysis*).

Personal Copy for Arun Singal, arun.singal560@gmail.com

Ongoing Authorization Default Values Optimization

The necessary proposal analysis tool is Xiting Role Builder SU24 Checkman. With this tool, you can maintain your Transaction SU24 data based on test and trace data. Its primary focus is on custom code transactions because, in practice, these transactions are usually insufficiently maintained in Transaction SU24. However, don't forget other transactions, like third-party applications as well as SAP applications, if you have fixed processes that allow you to predefine their default data. Xiting Role Builder SU24 Checkman compares the trace data with the current proposal maintenance in Transaction SU24. Analyze these results and clarify missing authorizations as proposals. Never maintain all the listed authorizations without considering their necessity because not every authorization shown will be technically required for an application's functioning and processing. Consider using the blacklist and whitelist features (**B/W**) during validation, which shows you both non-valuable (red icon) and valuable (green icon) data to maintain based on Xiting project and development experience. You can also reduce this list of records by clicking the hide icon for each line item, and thus, this data won't be shown again for the intended application. To maintain some proposals, you can directly introduce their values by clicking the blue arrow →. To transfer the desired authorization object to Transaction SU24 directly, click the arrow in the **Upd. Obj.** column, or for the displayed missing authorization values, click the arrow in the **Update** column, as shown in Figure 13.27.

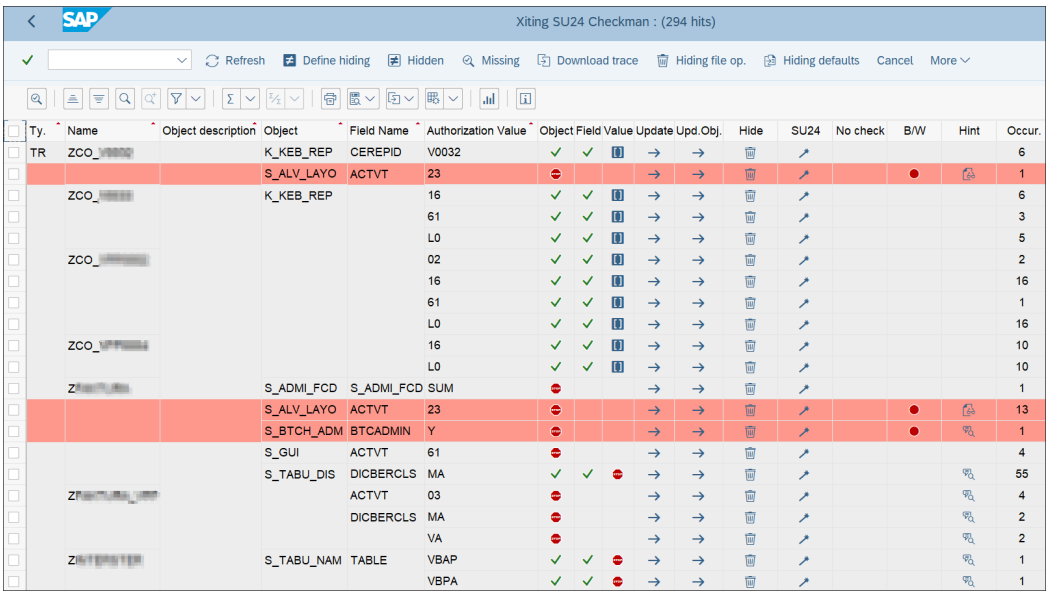


Figure 13.27 Xiting SU24 Checkman Output List

This authorization default value maintenance is essential for a standard-compliant migration and role concept redesign. However, you should also consider using proposals in the long run and working with the role menu to avoid manual authorization

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

objects with a technical conversion approach. Nevertheless, you should not mix up your roles with manual authorizations and also proposals. Therefore, you can skip this step during a technical conversion, although doing so is not recommended. You should always start or continue working with Transaction SU24 regardless of how well-maintained your role concept is. Also, consider an authorization redesign after the technical conversion anyway to establish a suitable and maintainable best practice role concept.

Hint

Changes in your Transaction SU24 data may affect many roles at this point, and thus, an essential step is to checking an authorization object is truly required or if a universal value can applies to all roles. After this proposal maintenance, use the Xiting Role Profiler report **Read old, merge new** for your business role scope again to merge and maintain new default data in the authorization profiles of your roles.

Determination of Deviations in Roles (Delta Analysis)

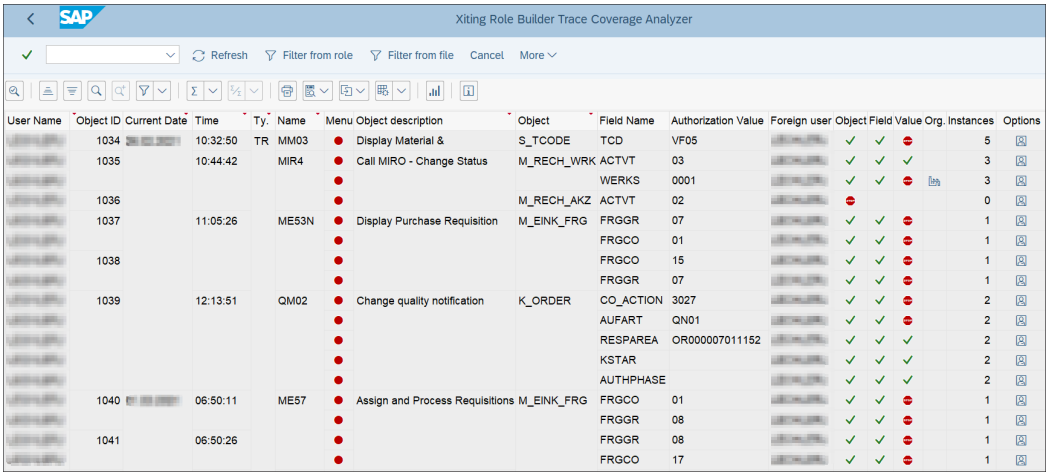
Once you've finished maintaining the default data based on earlier test activities, you can start with the iterative improvement of the quality and stability of your new role concept. Going forward, you will continuously evaluate new test data and optimize the authorization characteristics of your roles.

The Xiting Automatic Role Builder's reporting capabilities offer various tools with broad functions to help you meet this challenge. Of course, the tool you select depends on your personal preference. One suitable approach is to analyze test data with the Xiting Role Builder Coverage Analyzer (RBR COV). The RBR COV lets you analyze end-user activities to determine what is missing in the new roles based on the test scenarios. In addition, you can store various test evaluation selections as variants to keep your testing effort as low as possible for recurring validations.

After executing the selection, the RBR COV provides a result lists based on the contents of roles and on end-user test data. This tool directly shows deviations in the new roles at the authorization object (**Object**), field (**Field**), or value (**Value**) level. Missing authorizations are visually indicated with a stop sign icon, as shown in Figure 13.28.

These findings help you formulate your first objectives. Do not maintain all of these authorizations because they might not all be relevant for all business process execution. Thus, you must distinguish between essential and irrelevant authorizations. Indicators like empirical values, process logic, technical specifications, and integrated blacklist/whitelist value can facilitate your decision-making. In this dynamic evaluation phase, a best practice is to start entering new or missing role menu objects. A good place to start is to filter for the authorization object S_TCODE in the **Object** column. Then, you can verify whether the new roles require those missing transactions. Please note that you should first clarify changes of a role's content with your business units.

Personal Copy for Arun Singal, arun.singal560@gmail.com



User Name	Object ID	Current Date	Time	Ty.	Name	Menu	Object description	Object	Field Name	Authorization Value	Foreign user	Object	Field	Value	Org.	Instances	Options
	1034		10:32:50	TR	MM03		Display Material &	S_TCODE	TCD	VF05		✓	✓	⛔		5	
	1035		10:44:42		MIR4		Call MIRO - Change Status	M_RECH_WRK	ACTVT	03		✓	✓	✓		3	
									WERKS	0001		✓	✓	⛔		3	
	1036							M_RECH_AKZ	ACTVT	02		⛔				0	
	1037		11:05:26		ME53N		Display Purchase Requisition	M_EINK_FRG	FRGGR	07		✓	✓	⛔		1	
									FRGCO	01		✓	✓	⛔		1	
	1038								FRGCO	15		✓	✓	⛔		1	
									FRGGR	07		✓	✓	⛔		1	
	1039		12:13:51		QM02		Change quality notification	K_ORDER	CO_ACTION	3027		✓	✓	⛔		2	
									AUFART	QN01		✓	✓	⛔		2	
									RESPAREA	OR000007011152		✓	✓	✓		2	
									KSTAR			✓	✓	✓		2	
									AUTHPHASE			✓	✓	✓		2	
	1040		06:50:11		ME57		Assign and Process Requisitions	M_EINK_FRG	FRGCO	01		✓	✓	⛔		1	
									FRGGR	08		✓	✓	⛔		1	
	1041		06:50:26						FRGGR	08		✓	✓	⛔		1	
									FRGCO	17		✓	✓	⛔		1	

Figure 13.28 Xiting Role Builder Trace Coverage Analyzer Output List

For this purpose, you can export the RBR COV results as an Microsoft Excel file and add some business-related comments to the technical content for better comprehensibility. After approval, you can update the role menu, which enables the update or introduction of new authorization default values into your authorization profiles. Maintain open or required authorization characteristics based on the test results to work as efficiently as possible. To see the roles and their corresponding authorizations for a selected end user, click on a line item of the **Instances** or **Options** columns. In this way, you can directly see which role contains the related application of the missing authorization, for example, as shown in Figure 13.29.

Role	Descript.	Object	Authorization	Field name	and	Object	Field	Value
ZXITING_FI_DB_1_CH		F_FAGL_LDR	T-SD17009100	ACTVT	03	✓	✓	✓
				BUKRS	0001	✓	✓	⛔
				GLRLDNR	0L	✓	✓	⛔
				GLRRCTY	0	✓	✓	⛔
				GLRVERS	001	✓	✓	⛔
			T-SD17009101	ACTVT	03	✓	✓	⛔
				BUKRS	0001	✓	✓	⛔
				GLRLDNR	0L	✓	✓	⛔
				GLRRCTY	0	✓	✓	⛔
				GLRVERS	001	✓	✓	⛔

Figure 13.29 Authorization Instances Analysis

The RBR COV takes your testing to the next level because it offers multiple extensive and granular analyses features. Furthermore, this tool simplifies and reduces the detective work necessary for finding missing authorizations and corresponding roles.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

One challenge to ongoing role maintenance, you might encounter new conflicts of critical authorizations or authorization combinations. You'll need to validate these qualitative role aspects and protection requirement for compliance once again. To this end, you can use the Xiting Role Profiler reports found in the **Role Activity Watchdog Reports** or **User Activity Watchdog Reports** folders.

13.6 Activation Phase: Role Concept-Protected Go-Live

Some preconditions for this project step include that your roles have reached a suitable degree of maturity and authorization tests do not indicate that any relevant authorization is missing. At this point, you can convert a first set of end users (as a pilot), for whom testing has shown that the job function has all the authorizations it requires. For activation, we can use the Protected Go-Live (PGL) feature in XAMS, with its related tools, Xiting Times and Xiting Role Builder. Whereas Xiting Times enables the PGL feature, Xiting Role Builder serves as your analysis tool to solve authorization errors remaining in your new roles. PGL with XAMS means that you can guarantee no business interruptions on the PRD because all end users can request their former roles or the SAP_APP role and additional ones for SAP Fiori back in error cases. This approach enables you to avoid business interruptions as much as possible. Thus, you don't need to worry about any missing authorizations because the ongoing end-user processing is secured with the authorization backup, and you can analyze the findings in the background.

This section describes some features of XAMS for preparation and analysis, including end-user cloning and authorization backup, that you can use when going live with your entire SAP S/4HANA role concept.

13.6.1 End-User Cloning

Xiting Times allows you to create reference users simultaneously with backup roles and also maintain the related Xiting Times master data tables. Thus, you won't need to create backup reference users, manage role assignments, or set up your go-live concept manually. Instead, you can use the Xiting Times cloning tool to create reference users to accomplish these needs.

XAMS copies the go-live users to the user type `REFERENCE`, thus enabling business users to request their own reference user copy with the assigned SAP_APP role in error cases. The Xiting Times user cloning tool allows you to specify a prefix (e.g., **S_**) or a suffix (e.g., **_S**) to bulk reference users as a copy of the selected dialog users (e.g., **ASAMBILL**), as shown in Figure 13.30. You can also directly activate the adoption of the current role and profile assignments by selecting the **Assign current roles and profiles** checkbox. Thereby, the new reference users (dialog user copy) automatically get their dialog users' former roles, or you can assign extensive roles like the SAP_APP role. Since the

Personal Copy for Arun Singal, arun.singal560@gmail.com

SAP_APP integration role contains many business authorizations and should only enable an uninterrupted go-live, you should first provide this backup to key users. This approach requires starting your go-live with key users, remediating existing authorization failures, and iteratively bringing more users to the new SAP S/4HANA PRD to avoid too much unintentional business data access for "normal" end users with the SAP_APP role backup.

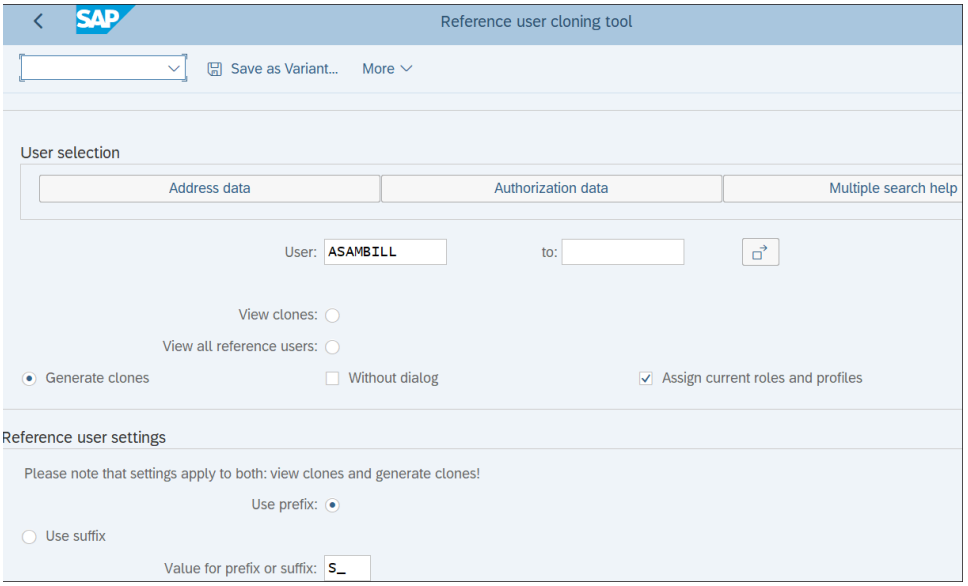


Figure 13.30 Xiting Times Cloning Tool

Now, you can transfer the created users to the master data tables of Xiting Times in the cloning tool's results view. Select the **Comparison mode** radio button in the customizing popup window to compare the new roles with your former roles for error cases that arose during go-live. Also, you can add a dedicated distribution address (like **X_XT_GOLIVE**) and a maximum Xiting Times session request time (like 10 hours) for the authorization backup via the reference user, as shown in Figure 13.31. This period is about one working day.

Hint

Due to the extensive authorizations in the SAP_APP role, you should first limit the number of users who can make such a request to only users like key users or process owners. This limitation depends on the requirements for protecting data and business processes. All these actions must take place in the PRD, or if required, initially in the quality system (QAS) again as an UAT.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

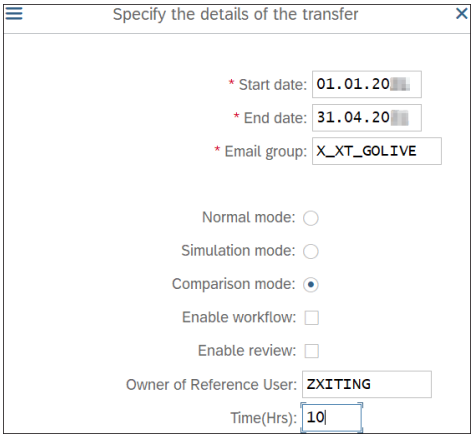


Figure 13.31 Direct Xiting Times Master Data Customizing

During the PRD setup, or in the course of operational stabilization, subsequent or even new requirements can arise for the adaptation of your newly designed role concept. In addition, since the migration project's duration usually extends over several months, you might have to handle changes on OrgSet definitions or new business demands. Subsequent adjustment or optimization activities may thus be required of your already validated roles. Consult with your business units about such changes to introduce them before activating the new role concept. Then, after informing end users about their pending PGL date, you can easily and massively switch to the new roles via the Xiting Role Replicator role assignment tool.

13.6.2 Authorization Backups

During go-live, you'll monitor setup of roles in PRD and provide support in error cases. End users can help themselves in such cases using their backup authorizations through Transaction /XITING/TIMES_MULTI, as shown in Figure 13.32. In this way, they can revert back to their former authorizations (e.g., during an SAP ERP redesign) or the SAP_APP role (e.g., during an SAP S/4HANA migration). Before an end user can use this transaction, you must assign this transaction to the global basic user role so that every end user can run the PGL feature. This backup function also works with the SAP Fiori launchpad if you provide this transaction as an SAP Fiori legacy app.

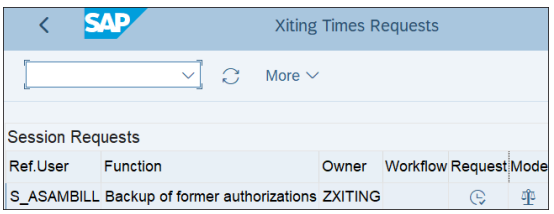


Figure 13.32 Authorization Backup Request

Personal Copy for Arun Singal, arun.singal560@gmail.com

Furthermore, the Xiting Times dashboard provides an overview of all currently running Xiting Times sessions in the system, as shown in Figure 13.33.

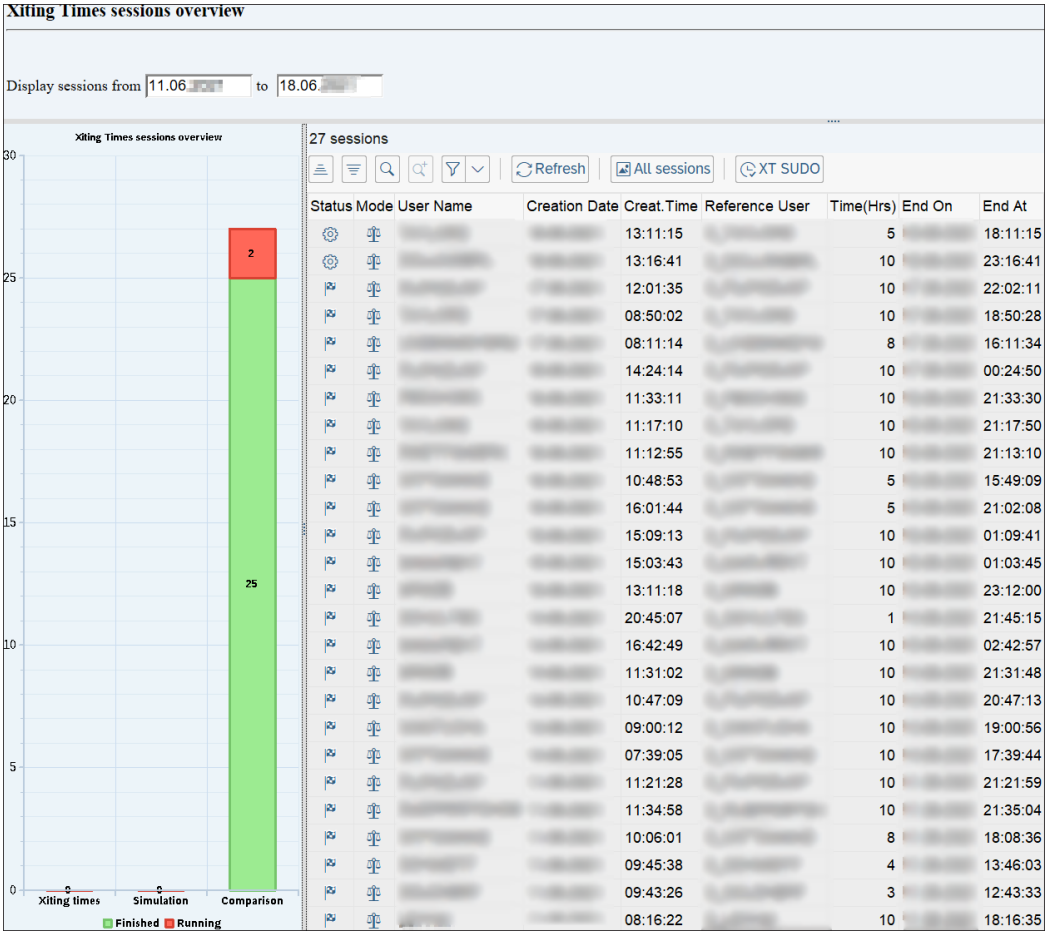


Figure 13.33 Xiting Times Session Overview

However, the dashboard's active monitoring is not mandatory because you'll also receive email notifications about session requests through a predefined distribution address like X_XT_GOLIVE. In this way, you'll receive an informational email directly whenever an end user requests an authorization backup due to an authorization issue during go-live. In this way, you can avoid interruptions in business processing with the new role concept, and the role administrator can still see, through Xiting Role Builder validation, which authorizations are missing.

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

13.7 Summary

As you've learned in this chapter, regardless of what migration strategy you choose, XAMS can help you expedite and simplify many of the tasks involved in an SAP S/4HANA migration. This coverage includes typical manual actions, like updating role menus in SAP S/4HANA, matching end-user data with the SAP Fiori apps reference library, optimizing authorization default values, mass replicating roles and organizational values, role testing, and going live with PGL without interruption. Thus, leveraging automation tools in XAMS can significantly speed up your SAP S/4HANA authorization migration project while reducing the risk of error. XAMS also significantly reduces the burden of migration projects on your business users and reduces the overall project effort. Additionally, while working on your roles and authorizations, you can assess the impact of these changes on your SAP licenses as well as on internal and external compliance with privacy regulations, such as GDPR or SOX, through the integrated CRAF ruleset in XAMS.

Even after successful migration to SAP S/4HANA, you can continue benefiting from the automation features of XAMS in your daily security work, including user and role changes, scanning for new custom developments, role concept monitoring, or proposal optimization. XAMS also offers the opportunity to establish a landscape-wide ICS with an integrated and individualized written authorization concept that can be automatically updated for the current system data.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

The Authors

Alessandro Banzer is the chief executive officer of Xiting Americas. He has worked in information technology since 2004, specializing in SAP since 2009. Since then, Alessandro has been involved with global SAP projects in various roles. Alessandro is an active contributor and moderator in the governance, risk, and compliance space on SAP Community, as well as a regular speaker at SAPPHIRE, ASUG, SAPInsider, and other SAP-related events. He holds a degree in business information technology, an Executive Master of Business Administration from Hult International Business School in London, UK, and various certifications in the IT and cybersecurity field.

Alexander Sambill is a senior SAP security consultant and certified SAP trainer at Xiting Germany. He is a security-minded professional with consulting and sales experience in many industries. During his years of work within SAP security, he specialized himself for SAP authorizations in SAP ERP and SAP S/4HANA with SAP Fiori. Alexander leads authorization migration and redesign projects for small-to-large enterprises, educates customers, and solves individual custom use cases. He is also a federally certified instructor (IHK) in commerce and industry.

Alexander is a passionate writer and active blogger of technical and scientific articles, e-books, white papers, surveys, and more about SAP security and authorizations. He is also the content manager of publications for SAP authorizations at Xiting AG. Before starting work for Xiting, he received a Master of Business Administration from the Technical University of Bergakademie Freiberg, Germany.

Alexander lives in Germany and loves to soak up new energy by hiking and cycling in the Ore Mountains or playing table tennis.

Personal Copy for Arun Singal, arun.singal560@gmail.com

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Index

A

ABAP 29, 158
authorizations 51
model 29
ABAP Call Monitor 537
ABAP Debugger 343, 344
ABAP Development Tools 521, 538
ABAP List Viewer (ALV) 291, 408
navigation 214, 215
ABAP test cockpit 537, 538, 579
ABAP workbench 96
Access analysis service 443
Access certification service 445
Access governance
migration implications 475, 476
Access management 24
external requirements 24
internal requirements 24
Access provisioning 42
Access request management (ARM)
module 441
Access request service 444
Access risk analysis (ARA) module 440, 441
Access risks 450
ACID principle 112
Activated services 369
ACTVT field 139, 221, 222
maintenance 210
Add Missing Transaction Start
Authorizations checkbox 227
Address tab 399
Amazon Web Service (AWS) 512
Analysis tools 316, 317
Analytic/structured privileges 38
Analyze transaction usage 547
Analyzing role concepts 544
API Finder 166, 168
App ID 358
App Launcher 359
App Support app 386, 387
Application navigation flags 219
Application privileges 38
Application start checks 75
Applications tab 251
Approval principle 51
auth/rfc_authority_check 482, 483
Authentication 23
AUTHORITY-CHECK statement 52, 75, 77, 86, 183, 185, 188, 240, 242, 282, 341, 342, 521
Authorization
backups 607
components 52
default values 56
download 98
object class 52
Authorization checks 74, 149, 173
deactivate 85
evaluate failures 322, 323
global deactivation 85
individual deactivation 86
required fields 328
SAP system 80
switchable 81, 82, 84
Authorization concept 135
analysis 315
bottom-up approach 137, 139
implementation 136
influences 48
principles 49
testing 556
top-down approach 136–138
Authorization debugging 337, 339, 340
navigation 340
Authorization default values 184, 185
advantages 187
check integrity 241
helpful tables 190
maintain 548
maintenance 331, 560
new statuses 200
optimization 602, 603
technical background 188
upgrading 223
Authorization field 55, 103
AUTYP 61
global deactivation 212
local deactivation 213
maintenance 209
program group maintenance 211
promote 63, 64
remove promoted field 64
Authorization instances 294
Authorization level 103
Authorization maintenance 274
best practices 294, 295

Personal Copy for Arun Singal, arun.singal560@gmail.com

Authorization maintenance (Cont.)
buttons 275, 276
Authorization object 53, 206
_TABU_NAM 90
B_MASSMAIN 211
F_BKPF BUK 214
F_KNA1_GEN 328
F_LFA1_BUK 148, 150
K_CCA 128
K_KA_RPT 211
K_ORDER 128
K_PCA 128
M_EINK_FRG 143
P_ABAP 103, 128
P_ORGIN 103, 105, 128
P_ORGINCON 103, 105
P_PCLX 103
P_PERNR 103
P_TCODE 103
PLOG 103
S_ADMI 127
S_ADMI_FCD 207, 336
S_ALV_LAYO 206
S_ALV_LAYR 206
*S_ALV** 328
S_ARCHIVE 127, 211
S_BDC_MONI 97
S_BTCH_ADM 97, 127
S_BTCH_JOB 97, 127
S_BTCH_NA1 ..... 97, 127
S_BTCH_NAM 127
S_CTS_ADMI 127
S_CTS_SADM 127
S_DATASET 127
S_DEVELOP 96, 127
S_GUI 98, 206
S_ICF 127, 481
S_NUMBER 211
*S_PROG** 581
S_PROGNAM 82, 83, 127, 211
S_PROGRAM 92, 94, 127, 211, 580, 581
S_PROJECT 328
S_QUERY 95
S_RFC 101, 127, 482, 487, 492, 493, 545, 573
S_RFC_ADM 127
S_RFCACL 101, 102, 127, 481
S_RZL_ADM 127
S_SCD0 127
S_SECPOL 127
S_SERVICE 544, 545, 558, 573
S_SPO_ACT 99, 127
Authorization object (Cont.)
S_SPO_DEV 99, 127
S_SPO_PAGE 99
S_START 545, 558, 573
S_TABU_CLI 90, 127, 207, 211
S_TABU_DIS 90, 95, 118, 127, 207, 211, 487
S_TABU_LIN 90, 127
S_TABU_NAM 90, 91, 95, 117, 118, 127, 207, 211, 217, 487
S_TABU_SQL 90, 127
*S_TABU** 580
S_TCODE 75, 215, 217, 544, 545, 558, 573, 587, 590, 603
S_TMS_ACT 127
*S_TRANSLAT** 328
S_TRANSPRT 127
S_USER_ADM 127
S_USER_AGR 127
S_USER_GRP 113, 127, 432, 451
S_USER_PRO 127
secure table access concept 90
statuses 277
update statuses 281, 282
validation 545
Authorization profiles 105
maintenance 593
Authorization templates 143, 144
button 193
Authorization test evaluation 559
Authorization trace 206, 329, 330
button 196
Authorization values 55
Authorizations tab 252
Available transactions 107

B

Background jobs 96, 97
Basic authorization role 140
Basis 239, 558
Batch input sessions 97
Bluefield approach 531
Breakpoints 338, 339, 343
create 341, 342
Brownfield migration 530, 531, 572
technical conversion indicators 573
Business application programming interfaces (BAPIs) 488
Business catalog 370
create 371
new entities 372

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Business catalog (Cont.)
target mapping assignment 373, 374
Business groups 374
create 376
Business partner approach 518
Business role management (BRM)
module 441
Business roles 39, 359, 381
Business transactions 103

C

C++ connector 479
CALL FUNCTION statement 484
Call stack analysis 167
CALL TRANSACTION statement 216, 242
Central user administration (CUA) 255, 432
distribution paramers 433, 434
predelivered roles 433
tables 435
Change documents 164, 165
Change role assignments 412
Change user documents 406, 408
Changed status 279, 281
Check modes 181
Check Values in Default Values checkbox ... 227
Client configuration 122
Cloud connector 42, 355
Cloud solutions 33
Cockpit transactions 220–222
Code inspector 537
Code-based namespaces 57
custom authorization objects 57
Communication user 397
Complete missing modification flags
in SU24 data checkbox 226
Composite roles 141, 145
maintenance 254
transport 307
Compositie roles
creation 259, 260
Conceptual approach 381
Conceptual role migration 583, 585
Consistency check 238
Continuous compliance 457
Control principle 50
Copy user 406
Core data services (CDS) 519
ABAP security 521, 522
access policy 523
assignemnt roles 522
mapping roles 522
Core data services (CDS) (Cont.)
troubleshooting 523, 524, 526
versus ABAP views 520
Critical access scenarios 88, 126, 128
Critical action risks 450
Critical Authorization Framework (CRAF) 87
Critical authorizations 87, 126
Critical permission risks 450
Cumulative processing logic 55
Custom authorizations
create 58
field 60, 61
object 58, 59
Custom code validation 536–538, 579, 581
Custom transactions
create 112
Customize security settings 130
Customizing roles 265–268

D

Data backup for Transaction SU24 230
Data definition language (DDL) 520
Data model simplification 499
Database end users 505
Database management system
(DBMS) 26, 405
Debug and replace 338
Default communication assembly (CA) 492
Default data variants 202, 203
Default Values Comparison button 193
Defaults tab 401
Delete and recreate profile and
authorizations button 276
Delete Invalid Default Values checkbox 227
Derived roles
creation 262, 263
maintain changes 264, 265
Description tab 249, 254
Descriptor items 363
Dialog transactions 108
Dialog user 396
Disabled authorization check 319
Do Not Check status 86
Document analysis 125
Documentation tab 398
Download button 193

E

Edit old status button 276
Editions 507

Personal Copy for Arun Singal, arun.singal560@gmail.com

Emergency access management (EAM) 175, 176, 471
appropriate usage 472
module 442
Employee group 105
Employee subgroup 105
Enabler role concept 142
Enabler roles 145
authorize activity fields 150
determining use 147, 148, 150
End-user cloning 605–607
Evaluating test results 601
Expert mode 237

F

Finance and controlling integration 518
Firefighting 471
functionalities 473, 474
provisioning strategies 474
types 473
Four-eyes principle 50
Friends principle 215
Function code 104
Function testing 556, 557
Functional role 140, 142
Functions 450

G

Go-live 561, 562
Good Manufacturing Practice (GMP) 540
Google Cloud 512
Greenfield migration 529, 531, 569
Groups tab 404

H

Hewlett Packard Enterprise (HPE) GreenLake 512
Hybrid system landscapes 39
access risks 43
Hyperscale cloud providers 31, 512, 514

I

ID-based firefighter 473
Identity Authentication 40, 42, 449
Identity management principle 49
Identity Provisioning 40, 449
Inactive users 415
In-education help 388, 389
Infotype 103
Infrastructure as a service (IaaS) 31
Inheritance concept
verification 583
Inheritance concept, verification 583
Initial role concept implementation
quick start 570
traditional 569
Integrated trace 206
Integration testing 558
Interface authorizations, best practices 489, 490
Interface user, best practices 488
Internal Control System (ICS) 594
Internal security concept 180
Internet communication framework (ICF) 101

J

Java connector 479
Java Database Connectivity (JDBC) 504
Job function 551
evaluating roles 551, 552
principle 50
roles 380
trace 334, 335
Job profile 551
Job-based role design 138, 140

K

Kernel 25
check 78
trace 490

L

Landscape simplification 500
Least privilege principle 49
Lenovo TruScale 512
Lic. Data tab 405
Lift and shift of authorizations 572, 573
Lock transactions 120
Locking status checks 74
Logon activity 128
Logon Data tab 400, 401

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

M

Maintained status 279
Maintenance Area button 197
Manage check variants 538
Manage Launchpad Pages app 365, 377
Manage Launchpad Spaces app 365, 377
Manually status 280, 281
Mass user changes 409, 411
Master role 261
  creation 261
Material ledger activation 519
Materials Management 487, 501
Menu bar and role information 249
Menu navigation 216, 218
  maintenance 217
Menu tab 255
Merge Mode for PFCG button 196
Microsoft Azure 512
Migrate Your Data app 535
Migration considerations 544, 545
MiniApps tab 253
Mitigation 457

N

Navigation considerations 220
Negative testing 561
NET connector for Microsoft 479
Normal users 505

O

Object transactions 109
Object type 104
Object/SQL privileges 38
OData services 359, 477
  backend activation 367
  description 366
Open Data (OData) 36
Open Database Connectivity (ODBC) 504
OpenSQL 521
Organization value field 139
Organizational aspects 542
Organizational key 105
Organizational levels
  create custom 61
  maintenance 282, 283
  maintenance best practices 284, 285
Organizational rules 454
OrgSets 171
Other objects button 196

P

Package privileges 38
Parameter checks 77
Parameter transactions 110
  create 116, 118
Parameters tab 403
Password generation
  blacklist 416
  customizing switches 416
  rules 415, 417
Personalization tab 253, 256, 404
Personnel area 105
Plan version 104
Planning status 104
Plausibility checks 76
Positive testing 559
Post-process settings 231
Preparing test scenarios 600, 601
Principle of audit trails 50
Principle of critical authorizations 49
Privilege access management service 446
Privilege types 506
Process aspects 543
Process simplification 499
Productive system (PRD)
  security analysis 121, 122
Productive Test Simulation (PTS) 290, 344, 490
Profile generator 65, 186, 189
  header 247
  initial screen 248
  navigation 247
  overview area 248
Profile parameters
  activation 319
  rfc/callback_security_method 485
Profiles 67
  manual 69
  role 68
  standard 69
  tab 404
Program access 92, 93
  tools 94
Program code authority check 78, 79
Project views 267
Proposals 183
  data comparison 199, 200
  data consistency check 230
  maintenance 195–198
  maintenance best practices 208
  status 194

Personal Copy for Arun Singal, arun.singal560@gmail.com

Proposals (Cont.)
system upgrade 230
upgrade process 228, 229
upgrade steps 229
upgrade tools 224
Protected Go-Live (PGL) 605

Q

Query access 94, 95

R

Read old status and merge with new data button 276
Reassess inconsistencies 232
Reference role 261
Reference user 173, 397
Regression testing 561
Relational database management system (RDBMS) 28
Release level/component version 358
Remediation 457
Remote function call (RFC) 100–102, 157, 477
ABAP interfaces 478
authorization objects 481, 482
authorizations 174
callback destinations 486
callback security 485
callback whitelist 484
interfaces 478
non-SAP interfaces 478
trusted systems 479
uses 478
vulnerabilities 481
Remote function modules (RFMs) 491–493
Remote system connections 480, 481
Remove Incorrectly-Defined SAP Organizational Level checkbox 227
Remove user roles 413
Repair bad field list in SU24 default values checkbox 225
Report
/SDF/RC_START_CHECK 532
Action Usage 464
AGR_RESET_ORG_LEVELS 283
Automatic comparison with Transaction SU22 data 231
Catalogs with content problems 592
Clean up application header data 230
Consistency check for default values 230
Report (Cont.)
Critical auth watchdog and Critical combination watchdog 594
Migration of roles to S/4HANA 586
Modification Comparison with SU22 Data (2b) 234, 235
OData Services for SAP Fiori 393
PFCG_ORGFIELD_CREATE 62
PFCG_ORGFIELD_DELETE 62
PFCG_ORGFIELD_UPGRADE 62, 233
PRGN_COMPRESS_TIMES 469
Read old, merge new 578, 593, 603
Role Authorization Merger 590
RS_ABAP_SOURCE_SCAN 80, 239, 240, 465
RSAUDITC_BCE 75
RSCSAUTH 94
RSRFCCHK 486
RSUSR_AUTH_DATA_VERSION 297
RSUSR_DELETE_USERDOCU 399
RSUSR000O3 429
RSUSR003 129
RSUSR008_009_NEW 125
RSUSRAUTH 125
SU24 cost.center rep. K_KA_RPT 580
SU24 from missing TSTCA 580
SU24 par.tcd. B_MASSMAIN 580
SU24 par.tcd. S_ARCHIVE 580
SU24 par.tcd. S_NUMBER 580
SU24 par.tcd. S_TABU clusters* 580
*SU24 param.tcodes S_PROG** 580
*SU24 param.tcodes S_TABU** 580
SU24 remove excessive values 580
*SU24 report writer S_PROG** 580
SU24_AUTO_REPAIR 225, 230, 232, 235
SU24_Auto_Repair 238
SU24, Expert Mode for Transferring SU22 Data 237, 238
SUSR_TABLES_WITH_AUTH 91
Report transactions 108
Restore backup transport 238
Restricted users 505
Ring buffer 321
RISE with SAP 516
Risk analysis 457
Risk mitigation 457
Risk recognition 456
Risk remediation 458
approach 460, 462
business roles 459
composite roles 459
positions 460

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Risk remediation (Cont.)
single roles ... 459
users ... 460
Risk Terminator ... 455
Role administration tables ... 257
Role building ... 257
best practices ... 292
Role concept analysis ... 599
Role concept reimplementation ... 571
Role concept validation ... 574
verify quality ... 575, 577
Role creation ... 256
Role derivation ... 141
Role design
approaches ... 135
trends ... 136
Role design concepts
comparison ... 145, 146
Role design service ... 444, 448
Role implementation ... 588
Role maintenance
best practices ... 291
Role menu ... 250
Role menu comparison ... 273
Role menu objects ... 270
maintenance ... 270, 271
Role migration ... 589, 591
Role naming convention ... 152–154, 258, 381
Role profiles
generate ... 296
mass generation ... 304, 305
up-to-dateness ... 582
Role quality ... 125
Role templates ... 268
Role transport ... 306–308
Role versioning ... 297–299
Role-based firefighter ... 473
Role-mining strategies ... 43
Roles ... 65
advantages ... 246
analysis ... 125
assign and remove ... 269
authorization ... 66
button ... 197
composite ... 67
delta analysis ... 603, 605
mass maintenance ... 301–303
mass user comparison ... 305
menu ... 66
overview status ... 299
single ... 66, 67
tab ... 255, 403
Roles (Cont.)
tracing ... 287–289
users ... 66
Rule building and validation ... 456
Ruleset
architecture ... 451
change ... 452
components ... 449, 450
custom transactions ... 463–466
standard ... 452, 453

S

S_A.DEVELOP profile ... 70
S_A.SYSTEM profile ... 70
S4HANA_READINESS_1909 check variant ... 538
S4HANA_READINESS_2020 check variant ... 538
S4HANA_READINESS_REMOTE check variant ... 538
Sales Performance – Plan/Actual – for Sales Manager app ... 369
SAP Access Control ... 41, 42, 44, 137, 152, 439, 440, 442, 448, 449, 458, 462, 467, 472, 475, 541
benefits ... 440
business roles ... 468–470
SAP Analysis for Microsoft Office ... 504
SAP Analytics Cloud ... 504
SAP Application Interface Framework ... 286
SAP Ariba ... 33, 443
SAP Best Practices Explorer ... 382, 517, 528, 534, 535, 552
SAP Business Client ... 34, 396
SAP Business Suite ... 27, 30, 94, 106, 514
SAP Business Technology Platform (SAP BTP) ... 39, 354, 448, 508, 514
SAP Business Warehouse (SAP BW) ... 102, 142, 177, 286, 287
SAP BusinessObjects Business Intelligence ... 504
SAP Cloud ... 39
SAP Cloud Identity Access Governance ... 41–44, 439, 443, 444, 448, 449, 454, 473, 475
bridge ... 447, 448
core functionality ... 443
key capabilities ... 447
SAP Cloud Identity Services ... 40
SAP Code Vulnerability Analyzer ... 538
SAP Customer Relationship Management (SAP CRM) ... 102

Personal Copy for Arun Singal, arun.singal560@gmail.com

SAP Data button ... 196
SAP Data Services ... 528
SAP Enterprise Portal ... 26
SAP ERP ... 26, 497, 501
SAP ERP Human Capital Management (SAP ERP HCM) ... 89, 212, 253, 256, 439, 558
all access ... 105, 106
authorizations ... 102
SAP Fieldglass ... 33
SAP Fiori ... 29
apps reference library ... 356–358
architecture ... 351, 352
check authorization concept ... 591
concept implementation ... 369
general end-user role ... 383, 384
legacy apps ... 351
principles ... 349, 350
reporting and troubleshooting transactions ... 390, 391
role analysis ... 588
role building ... 385
role checklist ... 384, 385
role concept ... 380
role preparation ... 382, 383
search ... 351
troubleshooting ... 386
UI ... 36
SAP Fiori Apps Recommendations Report ... 550
SAP Fiori launchpad ... 351, 352, 384, 554
app manager ... 363
central hub deployment ... 354
content manager ... 362, 371, 385
deployment options ... 353
designer ... 360, 361, 385
embedded deployment ... 353
intent-based navigation ... 372
personalization ... 378
role menu objects ... 555
SAP GUI ... 34
SAP HANA ... 28, 29, 520
authorizations ... 506
database ... 504
native authorizations ... 37
privilege framework ... 37
privileges ... 506
roles ... 507
security mechanisms ... 37
user types ... 505
SAP HANA Enterprise Cloud ... 507, 511
SAP Identity Management (SAP ID Management) ... 41, 42, 151, 543
SAP Integrated Business Planning for Supply Chain (SAP IBP) ... 33
SAP Launchpad service ... 355
benefits ... 355, 356
SAP Lumira ... 504
SAP NetWeaver ... 26, 28, 212
SAP ONE Support Launchpad ... 532
SAP R/3 ... 26
SAP Readiness Check ... 528, 533, 534
SAP Readiness Check for SAP S/4HANA ... 502
SAP S/4HANA ... 27, 28, 498, 511, 512, 514
analyze role changes ... 550
business process changes ... 516, 517
data management architecture ... 502
deployment ... 30–32
deployment options ... 507, 513
migration approaches ... 528, 531, 542, 553, 554
preparing for migration ... 527, 528
regulatory requirements ... 539, 540
role concept ... 570
simplification list ... 501, 502
simplifications ... 499
standard migration tools ... 541
SAP S/4HANA Cloud ... 32, 33, 500, 508, 509, 514
SAP S/4HANA Cloud, extended edition (EX) ... 509, 510, 514
SAP S/4HANA Cloud, private edition ... 510, 511, 514
SAP S/4HANA Finance ... 518
SAP S/4HANA migration cockpit 528, 535, 536
SAP Solution Manager ... 180, 280, 286, 287
SAP standard profiles ... 128
SAP standard users ... 129
SAP SuccessFactors ... 33, 439, 443
SAP Supplier Lifecycle Management ... 501
SAP Supplier Relationship Management (SAP SRM) ... 102, 501
SAP Support Portal ... 239
SAP Transformation Navigator ... 516
SAP Transport Management System (STMS) ... 178
SAP UI technology support ... 386
SAP Web Dispatcher ... 351
SAP_ALL profile ... 70, 105, 106
SAP_NEW profile ... 70
SAPUI5 ... 29, 36
applications ... 351, 359
Search for Obsolete Applications (2d) ... 236
Securing interfaces ... 487
Security audit log configuration ... 122

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Security compliance assurance 594
Security control matrix 50
Segregation of duties (SoD) 50, 137, 138, 146
  best practices 147
  continuous monitoring 462, 463
  management 456
  phases 456
  risks 450
  role calculation 146
  SoD principle 51
Selection screen options 193
Separate proposal data 118, 119
Service user 397
Simplification item check 532, 533
Simplification list 585
  role changes 564
Single roles 139–141, 145
  creation 259
  maintenance area 248
  transport 307
SNC tab 401
Software as a service (SaaS) 31
Spaces and pages 377
  create 377
  OData services 377
Spool authorizations 98, 99
Standard principle 51
Standard status 278
Standard users 428
  disable automoatic creation 428
  security 428
Standard-compliant role concept
  migration 573
Standards compliance 578
Start authorization objects 75
Subtype 105
Sustainable role building 290
System changeability 122
System configuration analysis 122
System layer
  alignment 191
  proposal maintenance 191
System privileges 38
System user 396

T

Table
  ACDOCA 519
  ADR2 422
  ADR3 422
  ADR6 422
Table (Cont.)
  ADRP 422
  AFRU 117, 118
  AGR_1016 258
  AGR_1251 ..... 125, 258, 545
  AGR_1252 ..... 64, 258
  AGR_AGRS 258
  AGR_BUFFI 258
  AGR_DEFINE 258
  AGR_PROF 258
  AGR_TCODES 545
  AGR_TEXTS 258
  AGR_TIME 258
  AGR_USERS 258
  BUT000 92
  DD02L 191
  GRACACTUSAGE 437
  PRGN_CUST 131, 132, 308, 415
  SSM_CUST 132
  SU2X_TEXT 202
  T000 110
  TADIR 191
  TCURR 91, 92
  TDDAT 91, 190, 205
  TOBJ 61
  TPGP 94
  TRDIR 94, 191
  TSTC 74, 80, 191
  TSTCA 76, 80, 191, 213
  TSTCP 118, 191, 212
  TSTCT 191, 210, 464
  USER_ADDR 422
  USERSYSUPL 435
  USERSYSUPPL 435
  USH02 422
  USH04 422
  USLA04 435
  USOBAUTHINACTIVE 76
  USOBT 57, 79, 188, 190, 199, 227, 231
  USOBT_C 57, 190, 199, 223, 227, 230, 236
  USOBX 57, 188, 190, 199, 227
  USOBX_C 57, 199, 223, 227, 230, 236
  USORG 212
  USR_CUST 133, 422
  USR01 421
  USR02 ..... 88, 396, 421
  USR03 421
  USR04 422
  USR05 422
  USR09 422
  USR10 422
  USR11 422

Personal Copy for Arun Singal, arun.singal560@gmail.com

Table (Cont.)
USR12 ... 422
USR21 ... 422
USR40 ... 416, 422
USRPWDHISTORY ... 422
USRSYSACT ... 435
USRSYSACTT ... 435
USRSYSLNG ... 435
USRSYSPRF ... 435
USRSYSPRFT ... 435
V_BRG_54 ... 91
Table access ... 89
security risks ... 89
standard tools ... 90
transparent ... 91
Table auditing ... 124
Table security ... 124
Target mapping ... 359
Task-based roles ... 139
Technical analysis ... 166
Technical aspects ... 543
Technical catalog ... 370
Technical configuration ... 359
Technical users ... 505
Template roles
replication ... 597
Template roles, replication ... 595, 597
Test plan ... 559
Three-tier deployment ... 502
Time Entry app ... 379
Traces ... 315, 324, 326
authorization error ... 326–328
populating data ... 205–207
use cases ... 320
Tracing applications ... 331
Traffic light icons ... 277
Transaction
/IWBEP/CACHE_CLEANUP ... 391
/IWBEP/ERROR_LOG ... 391
/IWBEP/VIEW_LOG ... 391
/IWFND/APPS_LOG ... 390
/IWFND/CACHE_CLEANUP ... 390
/IWFND/MAINT_SERVICE ... 367, 368, 390
/N/XITING/ROLEDESIGNER ... 160
/UI2/CHIP_SYNCHRONIZE_CACHE ... 390
/UI2/DELETE_CACHE ... 391
/UI2/FLC ... 391
/UI2/FLC1 ... 391
/UI2/FLIA ... 391
/UI2/FLP ... 384
/UI2/FLP_CUS_CONF ... 379
/UI2/FLP_DEL_PERS ... 379
Transaction (Cont.)
/UI2/FLP_SYS_CONF ... 379
/UI2/FLPAM ... 363
/UI2/FLPCM_CONF ... 362
/UI2/FLPCM_CUST ... 362, 371
/UI2/FLPD_CONF ... 360
/UI2/FLPD_CUST ... 360, 376
/UI2/FSAC ... 391
/XITING/TIMES_MULTI ... 607
AUTH_SWITCH_OBJECTS ... 85
BP ... 118, 203, 220, 295, 518, 585
F9SH ... 234
FB01 ... 26, 328
FB03 ... 184–186, 189, 214, 278, 323
FB60 ... 455
FD15 ... 209
FDKUSER ... 328
FK01/02 ... 461
FK02 ... 335, 455
FK03 ... 148, 149, 335
FS00 ... 518
IWFND/ERROR_LOG ... 390
KA01 ... 518
KA02 ... 518
KA03 ... 518
LAST_SHORTDUMP ... 554
LSMW ... 536
LTMC ... 535
ME21N ... 126, 450, 468
ME22N ... 450, 468
ME23N ... 468
ME24(N) ... 143
ME29N ... 126
MIGO ... 220, 222, 295
MM03 ... 209
PA10 ... 103
PA20 ... 103
PA30 ... 103
PA40 ... 103
PA51 ... 103
PFCG ... 62, 65–69, 75–77, 80, 102, 108, 145, 150, 160, 170, 172, 178, 189, 196, 220, 230, 235, 246, 247, 254, 260–262, 267, 269, 273, 280, 287, 288, 291, 297, 299, 304, 307, 308, 326, 335, 349, 377, 385, 455, 482, 487, 489, 494, 506, 508, 509, 513, 522, 552, 563, 589
PFCGMASSVAL ... 301–304
PFUD ... 256, 269
PM01 ... 103
PRGN_COMPARE_ROLE_MENU ... 391
RSAU_CONFIG ... 122
RSPFPAR ... 124

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Transaction (Cont.)
RSRTS_ODP_DIS 524
RSRTS_QUERY_CHECK 524
RSUSR_ROLE_MENU 391
RSUSR_START_APPL 391
RSUSR200 128
RZ10 ..... 85, 86, 99, 195, 320
S_ALR_87101219 91
S416H 89
S416N 88, 89
S4H16H 88
S4H16N 88
SA38 ..... 75, 80, 88, 92, 93, 111, 125, 126, 129, 162, 239, 283, 335, 465
SACF 76, 81–84
SACF_COMPARE 82, 84
SACF_INFO 84
SACF_TRANSFER 84
SACM 391, 524, 526
SCC4 ..... 110, 122, 216, 455
SCC5 120
SCI 537, 539
SCMON 537
SCOT 109
SCTS_RSWBO004 122
SCUM 433
SDDLAR 524
SE06 ..... 216, 218
SE09 307
SE16 ..... 88, 89, 92, 95, 110, 116, 118, 124, 126, 162, 205, 331, 435, 465, 486, 545
SE16(N) 202, 369, 391, 546
SE16H 89
SE16N 89, 162, 465, 486
SE17 90
SE37 126
SE38 ..... 111, 126, 162, 464, 465, 532, 538
SE54 91
SE80 ..... 464, 524, 538
SE84 379
SE93 ..... 77, 115, 117, 118, 197, 213, 464
SE97 219
SECPOL 423, 424
SHD0 112
SIFC 369
SLG1 391
SM01 120
SM01_CUS 120
SM01_DEV 120

Transaction (Cont.)
SM30 ..... 76, 88, 90–92, 110, 116, 126, 130, 162, 205, 415, 432, 435, 465
SM31 90
SM34 ..... 90, 126, 162
SM35 97
SM36 97
SM37 97
SM59 ..... 101, 479, 481, 484, 486
SMX 97, 554
SP00 99
SP01 99
SP02 ..... 99, 554
SP12 99
SPAD 99
SPRO 265, 267, 455
SPRO_ADMIN 265, 267
SQ00 ..... 94, 95
SQ01 ..... 94, 95
SQ02 95
SQ03 95
SQVI 94
SSM2 401
ST01 ..... 317, 318, 320, 323–325
ST01/ STAUTHTRACE 316
ST01/STAUTHTRACE 488
ST03(N) 489
ST03N 177, 234, 238, 358, 393, 436, 464, 547, 551, 552, 563
ST05 524
STAD 325
START_REPORT 92, 111
STAUTHRACE 323
STAUTHTRACE 239, 288, 317, 320, 324, 325, 346, 523, 524, 558, 560
STAUTHTRACE/ST01 ..... 391, 489
STC01 368
STDDAT 91
STMS 124, 216–218, 307
STMS_EXPORT 218
STMS_IMPORT 218
STRFCTRACE 318
STSIMAUTHCHECK 316, 317, 335, 558, 560, 562
STSIMAUTHTRACE 335
STUSERTRACE 239, 316, 317, 320, 333, 489, 558, 560
STUSOBTRACE 205, 209, 239, 316, 317, 320, 329–331, 333, 490, 558
SU_VCUSRVARCOM_CHAN 125

Personal Copy for Arun Singal, arun.singal560@gmail.com

Transaction (Cont.)
SU01 ..... 73, 74, 108, 110, 112, 113, 115, 162, 195, 197, 220, 254, 260, 269, 339, 341, 397, 398, 400, 403, 405, 406, 415, 427, 430, 431, 451, 473, 505, 508, 509, 513
SU01D 162, 222
SU02 ..... 65, 69
SU10 ..... 269, 404, 409, 411, 415, 427
SU21 ..... 54, 58, 60, 69, 225
SU22 ..... 57, 62, 100, 124, 188, 189, 223, 226, 227, 230, 238, 548, 549, 578
SU24 ..... 57, 59, 62, 86, 91, 92, 95, 108, 110–112, 115, 116, 118–120, 144, 150, 151, 167, 177, 178, 184–186, 189, 192, 194–200, 202, 203, 206, 208, 209, 211, 212, 215, 218, 220, 222, 224, 225, 227, 230, 231, 234, 238, 239, 241, 242, 251, 277, 278, 280, 281, 286, 287, 292, 294, 295, 305, 326, 331–333, 383, 465, 467, 468, 488–490, 494, 548, 555, 575, 578–580, 590, 602
SU25 ..... 85, 100, 124, 188, 191, 193, 196, 212, 224, 226, 228–231, 235, 236, 295, 383, 391, 548–550, 557, 575, 578, 586
SU3 ..... 401, 403, 554
SU53 ..... 239, 289, 316, 318, 320, 321, 342, 344, 386, 524, 560, 562
SU54 554
SU55 558
SU56 ..... 72, 149, 321, 417
SUCOMP 400
SUI_SUPPORT 386
SUIM . 87, 91, 94, 125, 128, 220, 404, 421, 546
SUPC 296, 304
SUPO 61–64
TCODE 167
XK01/02 461
ZDELETEUSER 468
ZSE16_AFRU 118
ZSE16_TDDAT 208
ZSU01_VAR_LOCK 110, 115
Transaction types 106
Troubleshooting system upgrade 238
TSTC check 74
TSTCA check 76
Two-tier deployment 502, 503

U

Unified Connectivity 318, 491–493
Universal journal 519
Upgrading customer-specific organizational levels 233
Upload button 193
User acceptance test (UAT) 560
User access 25
User access review (UAR) 422, 470, 471
User analysis 128
User buffer 25, 417, 418
User classification 421
User creation, navigation 397
User experience (UX) 23, 35
User groups
assign 432
maintain 430, 431
User IDs 420
User interface (UI) 34
simplification 500
User maintenance tabs 398
User master record 395
lock status 423
maintenance 396
security policies 423–426
User tab 253, 256
User-related tables 421, 422
Users 70
buffer 72
maintenance 73
master record 71
naming conventions 419, 420
trace 335–337
types 73, 396, 397

V

Vacation Request app 379
Value help 100
Variant transactions 109
create 112, 113, 115
Virtual data models (VDMs) 503

W

Web Dynpro 25
Where-used list 285, 286
Workflow tab 251
Workload Monitor 436, 437
Written form principle 51

X

Xiting ABAP Alchemist 158, 165, 166, 242, 466, 467
features 166

© 2022 by Rheinwerk Publishing Inc., Boston (MA)

Xiting Authorizations Management Suite (XAMS) 87, 157–159, 490, 567
authorize remote call function interfaces 494
migration tools 563
SAP S/4HANA migration 568
Xiting Automatic Role Builder 603
Xiting Productive Test Simulation (PTS) 570
Xiting Quick Start (XQS) 569, 570
Xiting RFC Stocktake Tool 159
Xiting Role Builder 159, 172, 174, 344, 345, 608
Xiting Role Builder Coverage Analyzer 346, 603, 604
Xiting Role Builder SU24 Checkman 242, 346, 602
Xiting Role Designer 158–160, 308, 563, 584, 585, 587, 589
business data reporting 164
design cockpit 310
Xiting Role Designer (Cont.)
function module reporting 163
project cockpit 309
project reporting 311
reporting 162
transaction reporting 163
virtual design cockpit 161
Xiting Role Profiler 159, 176, 241, 393, 575, 577, 580, 583, 589
reporting 177, 178
Xiting Role Replicator 159, 169, 171, 172, 311, 392, 594, 596–599, 601, 607
bulk processing 170
OrgSets 170
Xiting Security Architect 159, 179, 180, 182, 565
concept templates 180
Xiting Times 159, 172, 175, 176, 600, 605, 606, 608
Xiting User Locking Tool 159

Personal Copy for Arun Singal, arun.singal560@gmail.com

Service Pages

The following sections contain notes on how you can contact us.

Praise and Criticism

We hope that you enjoyed reading this book. If it met your expectations, please do recommend it. If you think there is room for improvement, please get in touch with the editor of the book: rachelg@rheinwerk-publishing.com. We welcome every suggestion for improvement but, of course, also any praise!

You can also share your reading experience via Twitter, Facebook, or email.

Technical Issues

If you experience technical issues with your e-book or e-book account at SAP PRESS, please feel free to contact our reader service: support@rheinwerk-publishing.com.

About Us and Our Program

The website http://www.sap-press.com provides detailed and first-hand information on our current publishing program. Here, you can also easily order all of our books and e-books. Information on Rheinwerk Publishing Inc. and additional contact options can also be found at http://www.sap-press.com.

Legal Notes

This section contains the detailed and legally binding usage conditions for this e-book.

Copyright Note

This publication is protected by copyright in its entirety. All usage and exploitation rights are reserved by the author and Rheinwerk Publishing; in particular the right of reproduction and the right of distribution, be it in printed or electronic form.

© 2022 by Rheinwerk Publishing, Inc., Boston (MA)

Your Rights as a User

You are entitled to use this e-book for personal purposes only. In particular, you may print the e-book for personal use or copy it as long as you store this copy on a device that is solely and personally used by yourself. You are not entitled to any other usage or exploitation.

In particular, it is not permitted to forward electronic or printed copies to third parties. Furthermore, it is not permitted to distribute the e-book on the Internet, in intranets, or in any other way or make it available to third parties. Any public exhibition, other publication, or any reproduction of the e-book beyond personal use are expressly prohibited. The aforementioned does not only apply to the e-book in its entirety but also to parts thereof (e.g., charts, pictures, tables, sections of text).

Copyright notes, brands, and other legal reservations as well as the digital watermark may not be removed from the e-book.

Digital Watermark

This e-book copy contains a **digital watermark**, a signature that indicates which person may use this copy. If you, dear reader, are not this person, you are violating the copyright. So please refrain from using this e-book and inform us about this violation. A brief email to info@rheinwerk-publishing.com is sufficient. Thank you!

Trademarks

The common names, trade names, descriptions of goods, and so on used in this publication may be trademarks without special identification and subject to legal regulations as such.

All of the screenshots and graphics reproduced in this book are subject to copyright © SAP SE, Dietmar-Hopp-Allee 16, 69190 Walldorf, Germany. SAP, ABAP, ASAP, Concur Hipmunk, Duet, Duet Enterprise, ExpenseIt, SAP ActiveAttention, SAP Adaptive Server Enterprise, SAP Advantage Database Server, SAP ArchiveLink, SAP Ariba, SAP Business ByDesign, SAP Business Explorer (SAP BEx), SAP BusinessObjects, SAP BusinessObjects Explorer, SAP BusinessObjects Web Intelligence, SAP Business One, SAP Business Workflow, SAP BW/4HANA, SAP C/4HANA, SAP Concur, SAP Crystal Reports, SAP EarlyWatch, SAP Fieldglass, SAP Fiori, SAP Global Trade Services (SAP GTS), SAP GoingLive, SAP HANA, SAP Jam, SAP Leonardo, SAP Lumira, SAP MaxDB, SAP NetWeaver, SAP PartnerEdge, SAPPHIRE NOW, SAP PowerBuilder, SAP PowerDesigner, SAP R/2, SAP R/3, SAP Replication Server, SAP Roambi, SAP S/4HANA, SAP S/4HANA Cloud, SAP SQL Anywhere, SAP Strategic Enterprise Management (SAP SEM), SAP SuccessFactors, SAP Vora, TripIt, and Qualtrics are registered or unregistered trademarks of SAP SE, Walldorf, Germany.

Limitation of Liability

Regardless of the care that has been taken in creating texts, figures, and programs, neither the publisher nor the author, editor, or translator assume any legal responsibility or any liability for possible errors and their consequences.